

Rodrigo do Carmo
Alexander Schlensoog

TARA in der Praxis – Bedrohungsanalyse und Risikobewertung im Automobilbereich

Ein Leitfaden nach ISO/SAE 21434 für
eingebettete Systeme und IT-/OT-Systeme

MOREMEDIA



Springer

TARA in der Praxis – Bedrohungsanalyse und Risikobewertung im Automobilbereich

Rodrigo do Carmo · Alexander Schlenso

TARA in der Praxis – Bedrohungsanalyse und Risikobewertung im Automobilbereich

Ein Leitfaden nach ISO/SAE 21434 für
eingebettete Systeme und IT-/OT-Systeme

Rodrigo do Carmo 
Eschborn, Deutschland

Alexander Schlensoğ
Essen, Nordrhein-Westfalen, Deutschland

ISBN 978-3-662-72357-9 ISBN 978-3-662-72358-6 (eBook)
<https://doi.org/10.1007/978-3-662-72358-6>

Die Deutsche Nationalbibliothek verzeichnet diese Publikation in der Deutschen Nationalbibliografie; detaillierte bibliografische Daten sind im Internet über <https://portal.dnb.de> abrufbar.

Übersetzung der englischen Ausgabe: „Automotive Threat Analysis and Risk Assessment in Practice“ von Rodrigo do Carmo und Alexander Schlensoğ, © Der/die Herausgeber bzw. der/die Autor(en), exklusiv lizenziert an Springer-Verlag GmbH, DE, ein Teil von Springer Nature 2024. Veröffentlicht durch Springer Berlin Heidelberg. Alle Rechte vorbehalten.

© Der/die Herausgeber bzw. der/die Autor(en), exklusiv lizenziert an Springer-Verlag GmbH, DE, ein Teil von Springer Nature 2026

Das Werk einschließlich aller seiner Teile ist urheberrechtlich geschützt. Jede Verwertung, die nicht ausdrücklich vom Urheberrechtsgesetz zugelassen ist, bedarf der vorherigen Zustimmung des Verlags. Das gilt insbesondere für Vervielfältigungen, Bearbeitungen, Übersetzungen, Mikroverfilmungen und die Einspeicherung und Verarbeitung in elektronischen Systemen.

Die Wiedergabe von allgemein beschreibenden Bezeichnungen, Marken, Unternehmensnamen etc. in diesem Werk bedeutet nicht, dass diese frei durch jede Person benutzt werden dürfen. Die Berechtigung zur Benutzung unterliegt, auch ohne gesonderten Hinweis hierzu, den Regeln des Markenrechts. Die Rechte des/der jeweiligen Zeicheninhaber*in sind zu beachten.

Der Verlag, die Autor*innen und die Herausgeber*innen gehen davon aus, dass die Angaben und Informationen in diesem Werk zum Zeitpunkt der Veröffentlichung vollständig und korrekt sind. Weder der Verlag noch die Autor*innen oder die Herausgeber*innen übernehmen, ausdrücklich oder implizit, Gewähr für den Inhalt des Werkes, etwaige Fehler oder Äußerungen. Der Verlag bleibt im Hinblick auf geografische Zuordnungen und Gebietsbezeichnungen in veröffentlichten Karten und Institutionsadressen neutral.

Springer ist ein Imprint der eingetragenen Gesellschaft Springer-Verlag GmbH, DE und ist ein Teil von Springer Nature.

Die Anschrift der Gesellschaft ist: Heidelberger Platz 3, 14197 Berlin, Germany

Wenn Sie dieses Produkt entsorgen, geben Sie das Papier bitte zum Recycling.

Geleitwort

„Alle Theorie ist grau“ – so heißt es. Deshalb soll dieses Buch mit nachvollziehbaren Anwendungsfällen und praktischen Umsetzungsbeispielen Licht ins Dickicht der Normung und Farbe in den Arbeitsalltag bringen.

Dieses Buch ist nicht vom Himmel gefallen. Als ich Dr. do Carmo damit beauftragte, die Komponenten-TARA (Threat Analysis & Risk Assessment) für ein elektronisches Bremssystem zu erstellen, hatte ich nur eine vage Vorstellung davon, wie verzweigt das Labyrinth war, in das ich ihn schickte. Die ISO-Norm 21434 war zu diesem Zeitpunkt noch nicht veröffentlicht, sodass er sich an Entwurfs-Ständen und den verfügbaren Interpretationen orientieren musste.

Durch meine eigene Arbeit und Erfahrungen in internationalen Normungs-Projekten (ISO-SAE PAS 8475, ISO TR 8477 und ISO-IEC 5888) kann ich bezeugen, dass die akribische Gestaltung des Geltungsbereichs von Normen oft eine Herausforderung für die Realisierung von Projekten darstellt. Im geschäftlichen Kontext führen die Projektziele oft zu unscharfen Grenzen zwischen den technischen Zielen und den Geltungsbereichen der Normen. Im Fall von Dr. do Carmo waren dies Trennlinien zwischen den Domänen Product Cybersecurity, Enterprise IT und Operational Technology (OT). Auf der Grundlage seiner wissenschaftlichen Forschungserfahrung machte er sich an die Arbeit. Er brachte System und Ordnung in eine großflächige Landschaft von Anwendungs- und Risikoszenarien mit PKIs, Produktionsservern, Produktionsausführungssystemen, Logistik- und Versand-Systemen, Garantie-Workflows – um nur einige Elemente zu nennen.

Die Ergebnisse dieser Tätigkeit sprechen für sich: Aus den gewonnenen Erkenntnissen zur Anwendung der relevanten Standards über die verschiedenen Anwendungsbereiche hinweg entstanden die Grundlagen für ein konsolidiertes Risikomanagement, welches unser Unternehmen erheblich bei der Optimierung bestehender und der Konzeption neuer Geschäftsprozesse unterstützt.

Als ehemaliger Vorgesetzter, Korrekturleser und Freund des Autors schwelgte ich beim Lesen dieses Buches in Erinnerungen an vergangene Herausforderungen und die belohnenden Erfolge. Den interessierten Lesern wünsche ich, dass ihnen durch die Lektüre und

Anwendung des dargestellten Wissens schmerzhaft und kostspielige Iterationen erspart bleiben mögen.

Eschborn
28.01.2025

Michael Gerhard Schneider
Principal Expert Product Cybersecurity & Privacy (CISSP)
Group Sector Automotive,
Continental AG

Geleitwort

Irgendwo zwischen „Wer jedes Risiko ausschalten will, der zerstört auch alle Chancen (Hans-Olaf Henkel)“ und „Vorsicht ist besser als Nachsicht (Sprichwort)“ liegt das Rezept für erfolgreiches und sicheres Handeln. Es ist kein einfaches Rezept, denn es muss laufend den ständigen Spagat zwischen Sicherheit, Kosten, Nutzen und Risiko leisten, sprich das „Risiko managen“. Dieses Risikomanagement muss in vielen Fällen auf nationaler und europäischer Sicherheitsgesetzgebung und Standards basieren, sich spezieller Risikoanalyseverfahren und Prozesse bedienen und dabei auch die individuellen Unternehmensanforderungen berücksichtigen.

Genau an dieser Stelle kommt Alexander Schlensofs besondere Expertise ins Spiel!

Als ich Alexander vor knapp 15 Jahren kennenlernen durfte, stand ich vor der Aufgabe einen hoch regulierten, sicheren und verbindlichen Kommunikationsdienst zu akkreditieren. Das dazu neu geschaffene Verfahren beruhte auf drei Zertifizierungen, dem Nachweis eines jeweils hohen Informationssicherheits- und Datenschutzniveaus sowie dem Nachweis von Funktionalität und Interoperabilität und ich hatte keine Erfahrung mit diesen Verfahren.

Alexander half mir mit seiner tiefgehenden und umfassenden Kompetenz im Bereich der Informationssicherheit und des Risikomanagements. Er kann sein umfangreiches Wissen gleichzeitig zielgruppenspezifisch und auf dem jeweils passenden Niveau weitergeben und vermitteln. Der pragmatische Umgang mit neuen Herausforderungen durch Gesetzgebung und Regulierung ist eine seiner großen Stärken. Nicht umsonst ist Alexander bis heute der Sicherheitsverantwortliche der Angebote, die ich leitend verantworte und betreut unsere zahlreichen Zertifizierungen in beratender Funktion.

Er hat das Wissen und kann es transportieren, das prädestiniert Alexander in meinen Augen als Autor eines Buches zum Risikomanagement in einem stark regulierten Markt, wie dem Automobilmarkt. Ich freue mich auf das Buch und dessen profunde Einblicke und bin überzeugt, dass es auch über die Branchengrenzen hinaus ein „Must-Read“ für

jeden ist, der sich ernsthaft und auf hohem Niveau mit dem Thema Risikoanalyse und -management auseinandersetzt.

Karlsruhe
10.12.2024

Leslie Romeo
Head of ID & Trust Services
1&1 Mail & Media GmbH
United Internet AG

Vorwort zur deutschen Übersetzung

Mit der vorliegenden deutschen Ausgabe möchten wir unser Buch einem noch größeren Kreis von Fachleuten zugänglich machen – insbesondere all jenen, die im deutschsprachigen Raum mit dem Thema arbeiten oder sich intensiver damit befassen möchten. Die Übersetzung haben wir mit viel Sorgfalt erstellt, immer mit dem Anspruch, möglichst nah am englischen Original zu bleiben, ohne dabei Verständlichkeit oder fachliche Präzision zu verlieren.

Fachbegriffe haben wir nach Möglichkeit auf Grundlage offizieller Übersetzungen einschlägiger Standards übernommen. Wo keine etablierte deutsche Terminologie vorlag oder die Übersetzung uneindeutig war, haben wir uns für eine nachvollziehbare und konsistente Formulierung entschieden.

Inhaltlich wurden nur wenige Anpassungen vorgenommen. Im Abschnitt zu relevanten Normen und Standards haben wir einige Referenzen an den aktuellen Stand der Normenlandschaft angepasst. Seit Erscheinen der englischen Originalausgabe wurden einzelne Standards fertiggestellt, zurückgezogen oder durch andere ersetzt – diese Entwicklungen haben wir in der deutschen Fassung berücksichtigt.

Wir hoffen, dass diese deutschsprachige Ausgabe dazu beiträgt, das Verständnis und die praktische Anwendung von Threat Analysis and Risk Assessment (TARA) im deutschsprachigen Raum weiter zu fördern – sowohl in der Industrie als auch in Forschung und Lehre.

Rodrigo do Carmo
Alexander Schlenso

Vorwort

Mit dem jüngsten Aufkommen von Cybersecurity-Vorschriften in der Automobilindustrie ist ein formalisierter Ansatz für das Risikomanagement obligatorisch geworden. Wir klassifizieren zunächst die Vorschriften und geben einen Überblick über die europäische Rechtslage im Bereich der Cybersecurity. Anschließend stellen wir die relevanten etablierten und neu entwickelten Standards im Bereich der Cybersecurity vor. Dabei konzentrieren wir uns auf die Produktion von Straßenfahrzeugen, berücksichtigen jedoch auch – wo es sinnvoll ist – die verarbeitende Industrie insgesamt.

Angesichts des starken Anstiegs von Risikomanagementprojekten im Automobilsektor konnten wir in der Vergangenheit durch zahlreiche TARA-Projekte (Threat Analysis and Risk Assessment) wertvolle Erfahrungen sammeln. Seitdem der Standard ISO/SAE 21434 für die Automobilindustrie veröffentlicht wurde, gibt es einen definierten Weg für die Durchführung einer TARA. Wir haben dabei festgestellt, dass es nicht immer einfach ist, die Herangehensweise des Standards in reale Projekte zu übertragen. Während unserer Arbeit an TARA-Projekten sind wir immer wieder auf grundlegende technische Diskussionen über bestimmte Aspekte einer TARA und den TARA-Prozess selbst gestoßen. Dies gilt insbesondere in der Zusammenarbeit mit Experten, denen es an Fachwissen im Bereich Risikomanagement und Bedrohungsmodellierung fehlt.

In diesem Buch versuchen wir, jeden Schritt des TARA-Prozesses auf pragmatische Weise anzugehen. Im Buch werden drei verschiedene Bereiche moderner Fahrzeuge behandelt: klassische TARA für einzelne elektrische und elektronische Systeme im Fahrzeug (E/E-Systeme), TARA auf Fahrzeugebene, einschließlich des damit verbundenen Ökosystems (E/E-Systeme inkl. der Infrastruktur), und TARA für Fertigungsanlagen (Produktion). Am Ende jedes Kapitels, das einen grundlegenden Schritt von TARA behandelt, finden Sie detaillierte Fallstudien zu den oben genannten Bereichen.

Der erste Bereich, die E/E-Systeme innerhalb des Fahrzeugs und das Fahrzeug selbst betreffend, ist der Hauptschwerpunkt der ISO/SAE 21434. ISO/SAE 21434 verlangt jedoch auch, dass das Fahrzeug und seine Komponenten während und nach der Produktion geschützt werden. Diese Anforderung ergänzt die UN-Regelung Nr. 155, die ebenfalls die

Cybersecurity während und nach der Produktion von Fahrzeugen vorschreibt. Um diese umfassende Abdeckung zu erreichen, halten wir uns an die TARA-Methodik, wie sie im Standard ISO/SAE 21434 beschrieben ist, wobei wir bestimmte Aspekte, wie z. B. die Auswirkungskategorien und die Definition von Items, Assets und Bedrohungen, mit etablierten Standards für Informationssicherheit (ISO/IEC 27000-Familie) und Cybersecurity in der Operational Technology (IEC 62443) verbinden. Wir versuchen in diesem Buch nicht, die Interoperabilität zwischen verschiedenen Standards zu harmonisieren oder formal zu demonstrieren. Unser Ziel ist es vielmehr zu zeigen, wie der generische TARA-Ansatz von ISO/SAE 21434 effektiv auf Fertigungssysteme angewendet werden kann, wobei wir den Prozess durch Erkenntnisse aus anderen Quellen ergänzen¹.

Sie, die Leser, können einen technischen Leitfaden erwarten, der das Vorgehen bei jedem Schritt des TARA-Prozesses beschreibt. Unser Mantra ist es, TARA mit technischer Strenge durchzuführen und dabei den Prozess so effizient wie möglich zu gestalten. Wir geben Empfehlungen zur Optimierung des TARA-Prozesses, wie z. B. Einblicke in die Definition von Assets, die Festlegung der Beteiligung von Teammitgliedern, Vorschläge für die Definition von Schadensszenarien und die Identifikation praktischer Auswirkungskategorien, die über die im Standard ISO/SAE 21434 vorgesehenen Kategorien hinausgehen. Ein wesentlicher Aspekt des Prozesses ist zum Beispiel die Ermittlung von Bedrohungsszenarien. Hier können die Leser praktische Ratschläge erwarten, die auf wohl definierten Ansätzen zur Bedrohungsmodellierung in der Welt der Cybersecurity basieren. Wir geben Empfehlungen, wie mit bestehenden Bedrohungskatalogen gearbeitet werden kann. Wir befassen uns mit Themen wie der Definition von Angriffspfaden und der Ermittlung der effektivsten Methoden zur Durchführung von Machbarkeitsbewertungen. Gegen Ende des Buches zeigen wir, wie die Verwendung statistischer Daten aus Risiken das Gesamtverständnis der TARA-Ergebnisse verbessern kann, was dann im letzten Schritt des TARA-Prozesses gipfelt: der Entscheidung über die Risikobehandlung.

Dieses Buch richtet sich in erster Linie an Cybersecurity-Ingenieure mit oder ohne Erfahrung im Automobilbereich, die mit der Arbeit an TARA-Projekten beginnen. Es ist jedoch auch eine wertvolle Ressource für diejenigen, die bereits an TARA-Projekten in der Automobilindustrie beteiligt sind und von unserer Erfahrung in bestimmten Bereichen des TARA-Prozesses lernen möchten. Darüber hinaus finden Cybersecurity-Teams aus der Automobilindustrie oder anderer Industrien, die TARA für Produktionsanlagen durchführen wollen, praktische Einblicke und Wissenstransfer auf Basis unserer umfangreichen Erfahrungen. Obwohl dieses Buch so gestaltet ist, dass es leicht verständlich ist, wird vorausgesetzt, dass die Leser ein grundlegendes Verständnis der allgemeinen Cybersecurity-Konzepte und -prinzipien haben.

¹ Das Konzept des CSMS wurde in der zweiten Ausgabe der IEC 62443-2-1 (August 2024) aus der IEC 62443 entfernt. Der Standard fordert nun, das Sicherheitsprogramm mit dem ISMS der Organisation zu koordinieren oder einen geeigneten Prozess einzuführen, wenn kein ISMS existiert. Es kommt unserem Ansatz damit stark entgegen.

Wir hoffen, dass dieses Buch als wertvolles Hilfsmittel für die Durchführung von TARA dient, ein tieferes Verständnis für das Risikomanagement vermittelt und Fachleute aus der Automobilindustrie mit dem nötigen Fachwissen ausstattet, um TARA-Projekte effizient durchzuführen. Wir legen es auch Fachleuten aus der produzierenden Industrie ans Herz, die von den Methoden aus dem Automobilsektor lernen möchten.

Rodrigo do Carmo
Alexander Schlenso

Danksagungen

Ich möchte meinen aufrichtigen Dank an Prof. Dr.-Ing. Sebastian Biedermann und Manuel Wurm aussprechen, die mit wertvoller fachlicher Unterstützung und Ideen zur Entstehung dieses Buches beigetragen haben. Ein besonderer Dank gilt meinem Kollegen und Freund Michael Gerhard Schneider für das Korrekturlesen, seine Anregungen und seinen Beitrag zum Vorwort dieses Buches. Unsere gemeinsame Reise durch den Dschungel der automobilen Cybersicherheit – von Tag eins an – hat dieses Buch erst möglich gemacht.

Mein ausdrücklicher Dank gilt auch meinem Mitautor Alexander Schlensog, dessen umfassende Erfahrung und tiefgehendes Wissen im Bereich Risikomanagement und Informationssicherheit den Inhalt dieses Buches maßgeblich bereichert haben.

Nicht zuletzt ist das Schreiben eines Buches neben dem Berufsalltag eine äußerst zeitintensive Aufgabe. Ich danke meiner Frau Katharina und meinem Sohn Maximo für ihre Geduld und ihre Unterstützung auf diesem Weg.

Rodrigo do Carmo

Mein aufrichtiger Dank gilt meinen langjährigen Weggefährten und Freunden Mete Boz, Cord Kielhorn und Werner Koch, die mein Interesse an der Informationssicherheit geweckt und mich dazu inspiriert haben, einen Weg in diesem Bereich einzuschlagen. Mein besonderer Dank gilt Leslie Romeo und Roland Brüggemann für die intensive Zusammenarbeit in besonders anspruchsvollen Projekten. Es ist die Erkundung des Neuen und Unbekannten, die mich immer am meisten herausfordert und meine Entwicklung vorangetrieben hat.

Ich bin meinen vielen Kollegen und Kolleginnen dankbar, die mich unermüdlich unterstützt und auf dem richtigen Weg gehalten haben. Mein besonderer Dank gilt meinem geschätzten Kollegen und Co-Autor, Dr. Rodrigo do Carmo, der eines Tages mit der Idee für dieses Buch an mich herantrat. Ich danke Dir für unsere Zusammenarbeit und freue mich auf unsere weitere Reise in diesem Feld. Mein herzlicher Dank gilt Justine Matzke und Dr. Hans-Jürgen Heinrich für die juristische Beratung, Korrekturen und Anregungen zu diesem Buch.

Alexander Schlensog

Inhaltsverzeichnis

1	Einführung	1
1.1	Europäische Regulierung	2
1.1.1	Übersicht über die aktuelle Regulierung und ihre Ziele	2
1.1.2	UN-Regelung Nr. 155	3
1.1.3	UN-Regelung Nr. 156	3
1.1.4	EU NIS-2	4
1.1.5	EU Cyber Resilience Act (CRA)	5
1.1.6	EU General Safety Regulation	6
1.1.7	EU-Maschinenverordnung	7
1.1.8	EU-Datenschutzgrundverordnung	7
1.2	UN-Regelung Nr. 155 und internationaler Standard ISO/SAE 21434	8
1.3	Aufbau dieses Buches	9
1.4	Namenskonvention	13
	Literatur	13
2	Standards für die Herstellungs- und Automobilbranche	15
2.1	ISO/SAE 21434	16
2.2	IEC 62443	16
2.3	ISO/IEC 27001	18
2.4	ISO 26262	18
2.5	ISO/SAE PAS 8475	19
2.6	ISO PAS 5112	19
2.7	ISO/SAE TR 8477	20
2.8	ENX und TISAX®	20
2.9	VDA Information Security Assessment	21
2.10	ENX VCS	21
2.11	Weitere Standards im Zusammenhang mit funktionaler Sicherheit und Cybersecurity	22
2.11.1	ISO/TS 5083	22
2.11.2	ISO/PAS 8800	22
2.11.3	ISO/IEC TR 5469	23

2.11.4	IEC 61508	23
	Literatur	23
3	Integrierte Managementsysteme und integriertes Risikomanagement	25
3.1	Überblick über Risikomanagementmethoden und -systeme	27
3.1.1	ISO/IEC 27001	27
3.1.2	BSI-Standard 200-1	27
3.1.3	ISO/IEC 27005	28
3.1.4	ISO 31000	28
3.1.5	ISO 22301	28
3.1.6	TISAX®	29
3.1.7	IEC 62443	29
3.1.8	ISO/SAE 21434	30
3.2	Harmonisierung und Integration von Managementsystemen	35
3.3	Ein ISO/SAE 21434 TARA für IT-/OT-Systeme	38
	Literatur	38
4	Bedrohungsanalyse und Risikobewertung	41
4.1	Warum ist es notwendig?	43
4.2	Wann findet es im Lebenszyklus eines Fahrzeugs statt?	43
4.2.1	Initiale TARA	44
4.2.2	TARA während der Entwicklung	46
4.2.3	TARA für die Produktion	46
4.2.4	TARA nach Software-Änderung oder Schwachstelle	47
4.3	Detailstufe gemäß den verfügbaren Informationen	47
4.3.1	„Die 3-Tage-TARA“ – Initiale TARA	48
4.3.2	„Die 30-Tage-TARA“ – TARA während der Entwicklung und Wiederverwendung	49
4.3.3	„Die 300-Tage-TARA“ – Die ineffiziente oder aufgeblasene TARA	51
4.4	Übersicht über den TARA-Prozess	52
4.5	Tooling	56
	Literatur	57
5	Definieren des Scopes eines TARA-Projekts	59
5.1	Wie man den Scope definiert	61
5.2	Annahmen	65
5.2.1	Wichtige Annahme: Sollen bestehende oder geplante Cybersecurity-Maßnahmen für das Item in der TARA berücksichtigt werden?	67
5.3	Scope für Automotive Embedded Devices	68

5.3.1	TARA für eigenständige Steuergeräte oder Funktionssysteme	68
5.3.2	TARA auf Fahrzeugebene (E/E-Architektur)	70
5.4	Scope für IT-/OT-Systeme für Fahrzeug-Backend-Architekturen	71
5.5	Scope für Produktionsanlagen	72
5.6	Definition des Angreifer-Modells	73
5.6.1	Wer sind die Angreifer?	74
5.6.2	Angriffsmodellierungsansatz nach ETSI TVRA	76
5.6.3	Beziehung zwischen Angreifer-Modell und Bedrohungen	79
5.7	Praktische Fallstudien	84
5.7.1	Fallstudie 1: Eingebettetes Fahrzeugsteuergerät	84
5.7.2	Fallstudie 2: Fahrzeug-Backend-Architektur	87
5.7.3	Fallstudie 3: Automobilproduktionsanlage	90
	Literatur	93
6	Identifikation der Assets des Items	95
6.1	Definition des Assets	97
6.2	Asset-Identifikation	97
6.2.1	Typische Assets für Automotive Embedded Devices	100
6.2.2	Typische Assets für IT-/OT-Systeme	110
6.2.3	Sicherheitsrelevante Assets	113
6.3	Cybersecurity-Eigenschaften	114
6.3.1	CIA-Triade: Vertraulichkeit, Integrität, Verfügbarkeit	115
6.3.2	Andere Cybersecurity-Eigenschaften	117
6.4	Schadensszenarien	118
6.4.1	Identifikation von Schadensszenarien	120
6.4.2	Bewertung des Schadens	121
6.4.3	Zusätzliche Stakeholder	124
6.4.4	Skalierbarkeit	127
6.5	Praktische Fallstudien	129
6.5.1	Fallstudie 1: Eingebettetes Fahrzeugsteuergerät	130
6.5.2	Fallstudie 2: Fahrzeug-Backend-Architektur	134
6.5.3	Fallstudie 3: Automobilproduktionsanlage	141
	Literatur	149
7	Modellierung und Bewertung von Bedrohungsszenarien	153
7.1	Identifikation von Bedrohungen	154
7.1.1	Brainstorming	156
7.1.2	Bedrohungskataloge	158
7.1.3	STRIDE	163
7.1.4	EVITA	165
7.1.5	HEAVENS	166

7.1.6	ETSI TVRA	167
7.1.7	PASTA	167
7.2	Angriffspfade	168
7.2.1	Wie werden Angriffspfade identifiziert?	168
7.2.2	Beschreibung von Angriffspfaden	169
7.2.3	Angriffsbäume	170
7.3	Machbarkeitsbewertung	171
7.3.1	Ansatz basierend auf Angriffspotenzial	174
7.3.2	CVSS-basierter Ansatz	179
7.3.3	Angriffsvektor-basierter Ansatz	183
7.3.4	Bestimmung der Bewertung der Angriffsmachbarkeit durch Angriffspfade (Attack Paths) mit mehreren Schritten ...	183
7.3.5	Beziehung zum Angreifer-Modell	185
7.4	Praktische Fallstudien	188
7.4.1	Fallstudie 1: Eingebettetes Fahrzeugsteuergerät	189
7.4.2	Fallstudie 2: Fahrzeug-Backend-Architektur	193
7.4.3	Fallstudie 3: Automobilproduktionsanlage	197
	Literatur	204
8	Durchführung der Risikobewertung	207
8.1	Risikobewertung	208
8.1.1	Risikomatrix	211
8.1.2	Risikoformel	212
8.2	Daten verstehen und mit Statistik arbeiten	213
8.2.1	Bedrohungsszenarien	213
8.2.2	Schadensszenarien	214
8.2.3	Assets	215
8.3	Praktische Fallstudien	216
8.3.1	Fallstudie 1: Eingebettetes Fahrzeugsteuergerät	216
8.3.2	Fallstudie 2: Fahrzeug-Backend-Architektur	216
8.3.3	Fallstudie 3: Automobilproduktionsanlage	216
	Literatur	221
9	Entscheidung über die Risikobehandlung	223
9.1	Entscheidung zur Risikobehandlung und Risikotoleranz	224
9.2	Risikovermeidung	225
9.3	Risikoreduzierung	225
9.3.1	Cybersecurity-Ziele	226
9.3.2	Cybersecurity-Maßnahmen	226
9.4	Risikoverteilung und Risikoakzeptanz	230
9.4.1	Cybersecurity-Aussagen	231
9.5	Nach der TARA ist vor der TARA – Risikoneubewertung	231

9.5.1	Statistik	232
9.6	Praktische Fallstudien	233
9.6.1	Fallstudie 1: Eingebettetes Fahrzeugsteuergerät	233
9.6.2	Fallstudie 2: Fahrzeug-Backend-Architektur	236
9.6.3	Fallstudie 3: Automobilproduktionsanlage	237
	Literatur	239
A Anhang A		241
Stichwortverzeichnis		281

Über die Autoren

Dr.-Ing. Rodrigo do Carmo absolvierte sein Studium der Nachrichtentechnik an der Universidad Blas Pascal in Argentinien im Jahr 2010 und promovierte 2014 im Fach Informatik an der Technischen Universität Darmstadt in Deutschland. Seit 2015 war er als Cybersecurity-Experte und Projektleiter für Cybersecurity bei der Continental Teves AG & Co. oHG tätig. Seit 2020 arbeitet er bei der secunet Security Networks AG als Principal Consultant und Abteilungsleiter.

Bei Continental war Dr. do Carmo technisch verantwortlich für alle Cybersecurity-Aktivitäten in der Forschung und Entwicklung von Bremssystemen. Bereits Jahre vor dem Erscheinen der Norm ISO/SAE 21434:2021 befasste er sich mit Cybersecurity-Prozessen, Cybersecurity-Management sowie technischen Entwicklungen, einschließlich Risikoanalysen und Bedrohungsbewertungen. Dr. do Carmo war außerdem an der Überprüfung des Standards ISO/SAE 21434:2021 beteiligt. Er koordinierte die Cybersecurity-Aktivitäten über den gesamten Fahrzeuglebenszyklus hinweg (z. B. Schlüsselmanagement) mit besonderem Fokus auf den Bereich Fertigung. Darüber hinaus war er Mitinitiator eines Center of Competence für Cybersecurity im Bereich Bremssysteme und arbeitete an zahlreichen Projekten für deutsche und internationale OEMs.

Seit 2020 berät Dr. do Carmo Unternehmen in der Fertigungsindustrie, einschließlich der Automobilbranche – von kleinen und mittelständischen Zulieferern bis hin zu großen Herstellern. Er hat zahlreiche TARA-Projekte für die Automobil- und Fertigungsindustrie geleitet, einschließlich solcher auf Basis des Standards IEC 62443. Dr. do Carmo ist Mitglied in ISO- und DIN-Ausschüssen zur Cybersecurity in der Automobilindustrie. Zudem ist er aktives Mitglied im VDMA-Ausschuss für industrielle Sicherheit sowie Vorsitzender des VDMA-Expertenkreises „Security Solutions for Industry“.

Dipl.-Phys. Alexander Schlenso studierte Physik an der Gerhard-Mercator-Universität in Duisburg und der Heinrich-Heine-Universität in Düsseldorf. Seit 2001 ist er in der Informationstechnologie tätig, 2006 hat er angefangen, Managementsysteme zu implementieren und zu betreiben.

Mit seinem Eintritt in die secunet Security Networks AG im Jahr 2008 liegt sein Schwerpunkt auf der Beratung zur Informationssicherheit. Als Principal Consultant hat er die Beratungspraxis maßgeblich geprägt und die Verantwortung für die Entwicklung des Beratungsgeschäfts übernommen, insbesondere für den Auf- und Ausbau des Bereichs Kritische Infrastrukturen.

Seit 2020 verantwortet er als Global Head das Beratungsgeschäft der Division Industry. Er ist Experte für Informationssicherheit in der Information- und Operational Technology und hat sich auf stark regulierte Märkte spezialisiert. Alexander Schlen-sog ist außerdem Experte und Mitglied in den ISO- und DIN-Normenausschüssen für Informationssicherheit und Datenschutz und Mitglied der IEEE.

Abkürzungsverzeichnis

AC	Attack Complexity
ADAS	Advanced Driver Assistance Systems
APT	Advanced Persistent Threat
ASIL	Automotive Safety Integrity Levels
ASRG	Automotive Security Research Group
ATM	Auto-ISAC Automotive Threat Matrix
Auto-ISAC	Automotive Information Sharing and Analysis Center
AV	Attack Vector
BCP	Business Continuity Planning
BIA	Business Impact Analysis
BOM	Bill of Materials
BSI	Bundesamt für Sicherheit in der Informationstechnik
CAL	Cybersecurity Assurance Level
CAN	Controller Area Network
CCC	Chaos Computer Club
CIA	Confidentiality, Integrity, Availability
CLI	Command-Line Interface
CNC	Computer Numerical Control
CRA	EU Cyber Resilience Act
CSMS	Cybersecurity Management System
CSF	NIST Cybersecurity Framework
CSIA	Cybersecurity Interface Agreement
CSR	Certificate Signing Request
CVSS	Common Vulnerability Scoring System
CWE	Common Weakness Enumeration
DA	Delegated Act
DDoS	Distributed Denial of Service
DID	Data Identifier

DIS	Draft International Standard
DoIP	Diagnostic over Internet Protocol
DoS	Denial of Service
DSGVO	Datenschutz-Grundverordnung
DSSAD	Data Storage System for Automated Driving
DTC	Diagnostic Trouble Code
E/E	Elektrik und Elektronik
ECU	Electronic Control Unit
EDR	Event Data Recorder
ENISA	European Union Agency for Cybersecurity ²
ENX	European Network Exchange Association
EOL	End of Line
ETL	ENISA Threat Landscape
ETSI	European Telecommunications Standards Institute
EU	Europäische Union
HLS	High-Level Structure
HTTP	Hypertext Transfer Protocol
FTP	File Transfer Protocol
GNSS	Global Navigation Satellite System
GPS	Global Positioning System
HARA	Hazard Analysis and Risk Assessment
HMI	Human-Machine Interface
HSM	Hardware-Sicherheitsmodul
HW	Hardware
IACS	Industrial Automation Control System
ICS	Industrial Control System ³
ID	<i>Bezeichner oder Kennung</i>
IEC	International Electrotechnical Commission
IMS	Integrated Management System
I/O	Input/Output
IP	Internet Protocol
ISMS	Informationssicherheitsmanagementsystem
ISA	International Society of Automation
ISO	International Organization for Standardization
ISO-TP	ISO 15765-2 Transport Protocol
IT	Informationstechnologie
JTAG	Joint Test Action Group
KI	Künstliche Intelligenz
LIN	Local Interconnect Network

² Vormals bekannt als *European Network and Information Security Agency*.

³ Im Buch als Synonym für IACS genutzt.

MAC	Message Authentication Code
MITM	Man-in-the-Middle (Angriff)
MOST	Media Oriented Systems Transport
NIST	US National Institute of Standards and Technology
OBD	On-Board Diagnostic
OEM	Original Equipment Manufacturer
OT	Operational Technology
OTA	Over the Air
PCB	Printed Circuit Board
PKI	Public Key Infrastructure
PM	Permission
PR	Privileges Required
RAM	Random-Access Memory
R&D	Research and Development
RDP	Remote Desktop Protocol
RED	EU Radio Equipment Directive
RF	Radio Frequency
RFID	Radio-Frequency Identification
RQ	Requirement
SAE	Society of Automotive Engineers
SBOM	Software Bill of Materials
SDV	Software Defined Vehicle
SecOC	Secure Onboard Communication
SMB	Server Message Block
SoC	System-on-Chip ⁴
SOME/IP	Scalable Service-Oriented Middleware over Internet Protocol
SOTIF	Safety of the Intended Functionality
SPS	Speicherprogrammierbare Steuerung
SQL	Structured Query Language
SID	Service Identifier
SUC	System under Consideration
SUMS	Software Update Management System
SSH	Secure-Shell-Protokoll
TAF	Targeted Attack Feasibility
TARA	Threat Analysis and Risk Assessment
TISAX®	Trusted Information Security Assessment Exchange
TCU	Telematic Control Unit
ToE	Target of Evaluation
TPMS	Tire-Pressure Monitoring System
TVRA	Threat Vulnerability and Risk Analysis

⁴ Das Akronym SOC wird in der Literatur auch als *Security Operations Center* genutzt.

UDS	Unified Diagnostic Services
UI	User Interaction
UN	United Nations
UNECE	United Nations Economic Commission for Europe
VCS	Vehicle Cybersecurity
VDA-ISA	VDA Information Security Assessment
V2V	Vehicle-to-Vehicle
V2X	Vehicle-to-Everything
VIN	Vehicle Identification Number
WLAN	Wireless Local Area Network
WP	Work Product
XCP	Universal Measurement and Calibration Protocol

Zusammenfassung

Dieses einleitende Kapitel legt den Grundstein für unser Buch, indem es einen Überblick über den aktuellen Stand der Regulierung im Bereich der Cybersecurity für Straßenfahrzeuge gibt. Wir konzentrieren uns auf die Darstellung der wichtigsten rechtlichen Rahmenbedingungen, die für die Hersteller von Bedeutung sind, darunter die EU-Richtlinie NIS-2, die UN-Regelungen Nr. 155 und Nr. 156 sowie weitere Rechtsnormen. Diese Gesetze und Vorschriften sind ein wichtiger Schritt hin zu einer umfassenderen Berücksichtigung der Cybersecurity in der Automobilindustrie, die bei der Anpassung an diese neuen rechtlichen Herausforderungen eine führende Rolle einnimmt. Außerdem geben wir einen kurzen Überblick über die UN-Regelung Nr. 155 und ihre Beziehung zum internationalen Standard ISO/SAE 21434.

Seit ihren Anfängen hat sich die Automobilindustrie als einer der dynamischsten und anpassungsfähigsten Sektoren der modernen Wirtschaft etabliert. Ihre Geschichte ist geprägt von ständiger Innovation und Veränderung. Der Sektor reagiert nicht nur auf neue Entwicklungen, sondern wirkt auch regelmäßig als Katalysator für technologische Fortschritte in der Industrie.

Straßenfahrzeuge haben sich von einfachen mechanischen Konstruktionen zu hochkomplexen und hochgradig vernetzten Systemen auf Rädern entwickelt. Heute kann ein einziges Fahrzeug über hundert Steuergeräte haben, die über spezielle Bussysteme und Protokolle miteinander kommunizieren. Diese Komplexität stellt selbst ein Risiko dar, das es zu beherrschen gilt.

Dieser Evolutionsschritt hat eine neue Dimension der Konnektivität eröffnet, bei der die Fahrzeuge nicht nur intern, sondern auch extern vernetzt sind. Sie interagieren mit den Backend-Systemen der Fahrzeughersteller, bieten den Insassen personalisierte Dienste an, kommunizieren mit anderen Fahrzeugen (V2V) und integrieren sich durch die Kommunikation von Fahrzeug zu Fahrzeug (V2X) in die breitere Infrastruktur.

Die Einführung dieser bahnbrechenden Technologien bringt neue Herausforderungen mit sich. Neue Angriffsmöglichkeiten, die Komplexität der einzelnen Komponenten und die Vernetzung zu hochkomplexen Systemen erfordern die Anpassung bestehender Verfahren und oft auch die Entwicklung neuer Verfahren und Standards, damit die erforderliche funktionale Sicherheit weiterhin gewährleistet werden kann.

Das Ziel der Gewährleistung von Security und funktionaler Sicherheit ist keineswegs neu, aber die Risikolandschaft hat sich deutlich verändert. Sie wird sich weiter verändern, und zwar in einer Geschwindigkeit, wie sie in den letzten Jahrzehnten im Automobilsektor nicht üblich war und ist. Damit ändern sich auch die Anforderungen an den Lebenszyklus grundlegend. Die Berücksichtigung von (Cyber-)Security ist unabdingbar geworden, um das Ziel der funktionalen Sicherheit überhaupt angemessen erreichen zu können.

Auch der Gesetzgeber hat erkannt, dass angepasste Regelungen notwendig sind und ist aktiv geworden. In den folgenden Kapiteln geben wir einen Überblick über den aktuellen Stand der Regulierung und Standardisierung.

1.1 Europäische Regulierung

In den folgenden Abschnitten geben wir einen Überblick über den aktuellen Stand der Regulierung und Standardisierung.

1.1.1 Übersicht über die aktuelle Regulierung und ihre Ziele

Die Regulierung im Bereich der Straßenfahrzeuge hat eine lange Historie. Das *1958 Agreement* [9], genauer das „Übereinkommen über die Annahme harmonisierter technischer Regelungen der Vereinten Nationen für Radfahrzeuge, Ausrüstungsgegenstände und Teile, die in Radfahrzeuge(n) eingebaut und/oder verwendet werden können, und die Bedingungen für die gegenseitige Anerkennung von Genehmigungen, die nach diesen Regelungen der Vereinten Nationen erteilt wurden“, wurde unter der Schirmherrschaft der UNECE auf Vorschlag der Bundesrepublik Deutschland ausgearbeitet und trat 1959 in Kraft. Ziel des Übereinkommens war es, einheitliche Verfahren für die Genehmigung von Kraftfahrzeugen zu schaffen. Es wurden technische Anforderungen und Prüfverfahren festgelegt, die von Herstellern und Lieferanten erfüllt werden müssen, um die EU-Typgenehmigung zu erhalten. Von besonderer Bedeutung ist dabei das Ziel der „funktionalen Sicherheit“, d. h. die Gewährleistung des Schutzes der Insassen und anderer Verkehrsteilnehmer. Mit der rasch zunehmenden Vernetzung von Kraftfahrzeugen, dem Einsatz digitaler Elemente (z. B. Steuergeräte) und neuer Technologien entstehen neue Risikoklassen. Mit einigen Jahren Verspätung hat die Regulierung nun sichtbar und deutlich reagiert, und zwar nicht nur im Automobilbereich. Die produzierende Industrie wird insgesamt verpflichtet, Risiken in Bezug auf Cybersecurity

und die Auswirkung auf den Aspekt funktionale Sicherheit in ihr Denken und Handeln zu integrieren.

Es ist nicht so, dass Sicherheit im Sinne von Security oder funktionaler Sicherheit in der Vergangenheit ignoriert wurde. Allerdings verschieben sich die Risikolandschaften und darauf bezogene Anforderungen immer mehr in Richtung „(Cyber-)Security for Safety“. Cybersecurity muss in Systemen mit digitalen Elementen zwingend betrachtet, bewertet und behandelt werden, um das Ziel der funktionalen Sicherheit erreichen zu können.

Nachfolgend geben wir einen Überblick über die wesentlichen Cybersecurity-Gesetzgebungsvorhaben, die sich auf produzierende Unternehmen und hergestellte Produkte konzentrieren, z. B. für die Zulassung von elektronischen Komponenten. Wir betrachten die produzierende Industrie im Allgemeinen und die Automobilindustrie im Besonderen, da diese hier eine Vorreiterrolle einnimmt.

Es gibt darüber hinaus weitere Branchen, wie z. B. Hersteller von Medizingeräten oder im Bereich der Kernenergie, die vergleichbar zur Automobilbranche individuellen Rechtsnormen unterworfen sind. Diese stehen hier nicht im Fokus, sind allerdings vergleichbar im Sinne der Herausforderungen, möglicher Vorgehensweisen und spezieller Methoden, wie der in diesem Buch diskutierten TARA.

1.1.2 UN-Regelung Nr. 155

UN-Regelung Nr. 155 [10] legt einheitliche Bestimmungen für die Cybersecurity von Straßenfahrzeugen fest. Die Regelung schreibt vor, dass eine Cybersecurity-Politik zu implementieren und ein Cybersecurity-Managementsystem einzurichten ist. Die Angemessenheit und Wirksamkeit dieses Systems ist zur EU-Typgenehmigung von neuen Fahrzeugen nachzuweisen. Das System soll Hersteller von Straßenfahrzeugen und deren Zulieferer unterstützen – durch Prozesse und Werkzeuge, die geeignet sind, Cybersecurity-Risiken systematisch zu identifizieren, zu bewerten und zu behandeln.

Der Standard ISO/SAE 21434 hilft Unternehmen dabei, Teile der Anforderungen umzusetzen.

1.1.3 UN-Regelung Nr. 156

UN-Regelung Nr. 156 [11] schreibt ein Software-Update-Management-System (SUMS) vor, um sicherzustellen, dass Software-Updates in Fahrzeugen sicher durchgeführt werden. Insbesondere sollen durch die Regelung gefährliche Fehlfunktionen der Software sowie Manipulationen beim Update-Prozess verhindert werden. Im Fall eines fehlgeschlagenen Updates muss die Software entweder weiterhin einwandfrei funktionieren oder einen sicheren Zustand einnehmen. Sie verlangt von den Herstellern, dass sie ein System für die Aktualisierung der Fahrzeugsoftware einrichten, das sicher und zuverlässig ist. Die Regelung sieht

auch vor, dass die Hersteller den Behörden einen detaillierten Bericht über die Software-Updates und die Änderungen, die sie vornehmen, vorlegen müssen. Die Regelung soll sicherstellen, dass Software-Updates die Sicherheit und die Umweltverträglichkeit des Fahrzeugs nicht beeinträchtigen.

1.1.4 EU NIS-2

Die EU-Richtlinie NIS-2 (EU-Richtlinie über die Sicherheit von Netzwerk- und Informationssystemen) [5] ist Teil der EU-Cybersecurity-Strategie^{1,2}. Es ist die Antwort auf eine immer weiter steigende Bedrohungslage im Cyberraum, und soll die Handlungsfähigkeit auf EU-Ebene konsolidieren und harmonisieren. Die Richtlinie ist die Weiterentwicklung der 2016 erlassenen EU NIS-Richtlinie (Directive (EU) 2016/1148), deren Umsetzung in Deutschland als *IT-Sicherheitsgesetz* bekannt ist.

Vorrangiges Ziel ist die Verbesserung des Cybersecurity-Niveaus und die Schaffung eines hohen gemeinsamen Niveaus zur Stärkung des EU-Binnenmarktes. Die Befugnisse der zuständigen Behörden werden ausgeweitet. Dabei soll das Handeln wirksam und verhältnismäßig und zugleich abschreckend sein.

Betroffene Unternehmen sind verpflichtet, ein aktives Risikomanagement umzusetzen, den Stand der Technik einzuhalten und dies nicht nur für sich selbst, sondern auch mit Blick auf die Lieferketten. Ein spätes Lernen aus diversen Krisen. Die „digitale“ Welt soll gekoppelt mit der „physischen“ Welt betrachtet und gesichert werden. Leitungsorgane werden haftbar gemacht, auch persönlich.

Mit der neuen Richtlinie wurde der Anwendungsbereich verändert, sodass der Fokus nicht mehr nur auf den sogenannten kritischen Infrastrukturen liegt, sondern große Teile der Wirtschaft umfasst und somit als „kritisch“ betrachtet. Dabei werden das verarbeitende Gewerbe und Hersteller von Waren als wichtig klassifiziert.

Allerdings ist der Mobilitätssektor selbst auch Teil der Energiewende und zugleich ein Baustein smarter Städte. Diese Vernetzung mit der kommunalen Infrastruktur hat mittelbare und unmittelbare Auswirkung auf die Sektoren Energie und Transport und Verkehr. Risiken und Sicherheitsmaßnahmen sollten im Gesamtzusammenhang betrachtet werden, um Betrachtungslücken zu verhindern.

Der Standard ISO/IEC 27001 bietet aufgrund der hohen internationalen Akzeptanz die beste Grundlage zur Implementierung eines Managementsystems. Der Standard bietet sich somit als Basis zur Umsetzung der Richtlinie bzw. genauer der Anforderungen der nationalen Umsetzungsgesetze an³. In Deutschland beispielsweise setzt das NIS2-Umsetzungs- und

¹ <https://digital-strategy.ec.europa.eu/en/policies/cybersecurity-strategy>

² <https://digital-strategy.ec.europa.eu/en/library/eus-cybersecurity-strategy-digital-decade-0>

³ Nur der ISO/IEC 27001 umzusetzen reicht dabei nicht aus, die Anforderungen des Gesetzes zu erfüllen, jedoch lassen sich die darüberhinausgehenden Anforderungen in das dabei entstehende System integrieren.

Cybersicherheitsstärkungsgesetz die Anforderungen der Richtlinie an die Cybersecurity und ein umfassendes aktives Risikomanagementsystem um.

1.1.5 EU Cyber Resilience Act (CRA)

Der europäische Cyber Resilience Act [7] (Verordnung (EU) 2024/2847 über horizontale Cybersicherheitsanforderungen für Produkte mit digitalen Elementen) bildet den rechtlichen Rahmen, der die Cybersecurity-Anforderungen an Hardware- und Softwareprodukte beschreibt, die in der Europäischen Union in Verkehr gebracht werden. Die Hersteller werden damit verpflichtet, die Cybersecurity während des Lebenszyklus eines betroffenen Produkts zu gewährleisten, vom Entwurf bis zum Betrieb.

Bislang haben verschiedene Rechtsakte und Initiativen auf nationaler und Unionsebene die Herausforderungen der Cybersecurity nur teilweise und zudem unterschiedlich behandelt, was zu unnötig hohen Aufwänden führte. Die neue Verordnung schafft einen kohärenten Cybersecurity-Rahmen für Hardware- und Softwarehersteller.

Die Verordnung ist ein weiteres Element der EU Cybersecurity-Strategie. Hauptziele der Verordnung sind die Stärkung der Cybersecurity und das reibungslose Funktionieren des Binnenmarktes. Es werden die Voraussetzungen für die Entwicklung sicherer Produkte mit digitalen Elementen geschaffen und der Cyberkriminalität vorgebeugt.

Mit der Verordnung werden zwei Hauptprobleme adressiert. Zum einen das häufig niedrige Niveau der Cybersecurity von Produkten mit digitalen Elementen, also Hard- und Software, das sich in weit verbreiteten Schwachstellen und der unzureichenden Bereitstellung von Sicherheitsupdates zeigt. Zum anderen das unzureichende Verständnis und der unzureichende Zugang der Anwender zu Informationen zu den adressierten Produkten. Dies hindert Käufer daran Produkte mit geeigneten Cybersecurity-Eigenschaften auszuwählen und diese auf sichere Weise zu betreiben.

Produkte mit digitalen Elementen, die in Informationssysteme integriert sind oder mit solchen verbunden werden können, sind potenziell ein Angriffsvektor für böswillige Akteure, wie Hacker oder Nation States. Für sich alleine betrachtet, als unkritisch gesehen, ermöglichen solche Produkte unter bestimmten Umständen die Kompromittierung der Informationssysteme oder Netzwerke.

Aus diesem Grund sind Sicherheitsanforderungen schon beim Entwurf bzw. der Entwicklung und Produktion zu betrachten. Produkte sollen in anderen Worten „secure by design and default“ sein. Unternehmen müssen risikoorientiert, sichere Produkte schaffen und ein wirksames Schwachstellenmanagement, verbunden mit aktiver Kommunikation, gewährleisten. Zudem ist eine umfangreiche Dokumentation zur sicheren Nutzung von Produkten bereitzustellen. Neue Sicherheitsbedrohungen müssen angemessen behandelt, und aufgetretene Lücken durch Softwarepatches schnell geschlossen werden.

Die Verordnung verpflichtet alle Unternehmen, die Produkte mit digitalen Elementen in den europäischen Wirtschaftsraum einbringen, jedoch sind bestimmte Bereiche ausgenom-

men. Dazu zählen der militärische Bereich, die zivile Luftfahrt und Flugsicherung aber auch die Automobilbranche. Für diese wird der Prozess der EU-Typgenehmigung für Fahrzeuge als äquivalent angesehen.

Zur Umsetzung der Verordnung kann allgemein die Standardreihe IEC 62443 genutzt werden, welche zum einen hilft, ein angemessenes Cybersecurity-Managementsystem innerhalb von Organisationen und entlang der Lieferkette aufzubauen, aber ebenso geeignet ist, Systeme oder einzelne Komponenten zu zertifizieren und damit die Cybersecurity über den Lebenszyklus nachzuweisen. Für den speziellen Bereich von Kraftfahrzeugen ist der Standard ISO/SAE 21434 vorgesehen, welcher eben diese Ziele verfolgt mit dem Unterschied, dass hier keine einzelnen Elemente oder Systeme zertifiziert werden, sondern Organisationen. Für weitere Wirtschaftsbereiche existieren zudem teilweise weitere ähnliche „ersetzende“ Standards.

Im Zusammenhang damit steht die Radio Equipment Directive (RED) (Directive 2014/53/EU) [2], oder Funkanlagenrichtlinie, welche in Europa „ein hohes Maß an Schutz auf den Gebieten der Gesundheit und der Sicherheit sowie für ein angemessenes Niveau an elektromagnetischer Verträglichkeit und für eine wirksame und effiziente Nutzung von Funkfrequenzen zur Vermeidung funktechnischer Störungen“ gewährleisten soll. Die RED wurde durch den Delegated Act (DA) 2022/30 [4] ergänzt, welche den Schutz von sogenannten „internetfähigen Funkgeräten“, (Mobilfunk-)Netzwerken und personenbezogener Daten zum Ziel hat. Die zunehmende Risikolage im Bereich Cybersecurity und Datenschutz ist auch hier ein wesentlicher Erwägungsgrund.

1.1.6 EU General Safety Regulation

Die allgemeine Sicherheitsverordnung⁴ [3] ist eine europäische Verordnung mit dem Ziel, die funktionale Sicherheit im Straßenverkehr zu verbessern und die Zahl der Verkehrsunfälle zu verringern.

Sie legt Mindestanforderungen für die funktionale Sicherheit von motorisierten Fahrzeugen und Anhängern sowie von Systemen, Komponenten und getrennten technischen Einheiten für diese Fahrzeuge und den Schutz von Fahrzeuginsassen als auch andere gefährdete Verkehrsteilnehmer fest.

In Bezug auf die Cybersecurity adressiert die Verordnung den Schutz und den Austausch von sicherheitsrelevanten Daten zwischen Fahrzeugen und Infrastrukturen. Es geht dabei um die Erfassung, Speicherung und den Austausch von Daten, die sowohl dem Schutz der Privatsphäre der Nutzer als auch der Verbesserung der Sicherheit im Straßenverkehr dienen sollen. Die Verordnung legt die Grundlage für robuste Cybersecurity-Praktiken und -maßnahmen, um die Integrität und Sicherheit von Fahrzeugsystemen und -daten zu gewährleisten, auch in Bezug auf autonome Fahrsysteme sowie Fahrassistenzsysteme.

⁴Die Verordnung 2019/2144 ist ein Rechtsakt im Zusammenhang mit dem EU-Typgenehmigungsverfahren.

Die Verordnung hebt die Bedeutung der Sicherheit der Straßeninfrastruktur hervor. Es werden Maßnahmen zur Verbesserung der Sicherheit auf den Straßen gefordert. Der Bereich Verkehr gehört zu den kritischen Infrastrukturen, welcher in besonderer Weise geschützt werden muss.

Für Ingenieure und Hersteller im Automobilsektor ist diese Verordnung von großer Bedeutung, da sie die Entwicklung sicherer Fahrzeuge und Systeme fördert und gleichzeitig die Einführung innovativer Technologien, insbesondere im Bereich der Informationssicherheit und Cybersecurity, unterstützt.

Der Standard ISO 26262 ist ein wichtiges Element für die Umsetzung von Sicherheitsanforderungen im Automobilsektor. Es gibt eine Reihe weiterer Sicherheitsstandards für andere Branchen, z. B. IEC 60601-1 für elektronische medizinische Geräte oder IEC 61511 für die Prozessindustrie.

1.1.7 EU-Maschinenverordnung

Ziel der EU-Maschinenverordnung⁵ [6] ist es, die Sicherheitsanforderungen an Maschinen zu aktualisieren und zu harmonisieren. Sie schafft einen neuen Rechtsrahmen für das Inverkehrbringen sicherer Maschinen und Produkte im EU-Markt. Neue Risiken im Zusammenhang mit aktuellen und aufkommenden Technologien, insbesondere digitalen Technologien wie dem Internet der Dinge oder künstlicher Intelligenz, werden berücksichtigt. In der Verordnung werden die grundlegenden Sicherheits- und Gesundheitsanforderungen festgelegt, die Maschinenprodukte erfüllen müssen, um auf dem europäischen Markt in Verkehr gebracht werden zu können. Ebenso werden Verfahren zur Bewertung ihrer Konformität beschrieben. Die neue Verordnung schreibt den Schutz vor Cyberangriffen vor. Maschinen und Produkte müssen so konstruiert und gebaut sein, dass Cyberangriffe keine Gefahr für Leib und Leben oder die Umwelt darstellen. Darüber hinaus wurde der Begriff „Safety components“ neu definiert und umfasst nun auch Software, die diesem Zweck dient und separat in Verkehr gebracht wird.

1.1.8 EU-Datenschutzgrundverordnung

Die europäische Datenschutz-Grundverordnung (DSGVO) [1] ist ein Rechtsrahmen der Europäischen Union, der am 25. Mai 2018 in Kraft trat und den Schutz personenbezogener Daten von EU-Bürgern regelt.

Die Verordnung regelt die Verantwortung von Unternehmen und Organisationen, die personenbezogene Daten verarbeiten und verpflichtet diese zur Transparenz in Bezug auf die Verwendung solcher Daten. Die DSGVO schreibt weiterhin vor, dass Datenverarbeiter

⁵ Verordnung (EU) 2023/1230 über Maschinen (die ab dem 20.01.2027 die „Richtlinie 2006/42/EG über Maschinen“ ersetzt).

angemessene und wirksame technische und organisatorische Maßnahmen ergreifen müssen, um ein geeignetes Schutzniveau der Daten zu gewährleisten.

Die Einhaltung der technischen und organisatorischen Anforderungen ist dabei von zentraler Bedeutung. Um diese Anforderungen zu erfüllen, müssen Unternehmen und Organisationen in der EU unter anderem angemessene und wirksame Cybersecurity-Strategien und -Systeme implementieren. Dazu gehören zum Beispiel die Verschlüsselung von Daten, regelmäßige Cybersecurity-Maßnahmen und die Schulung von Mitarbeitern im sicheren Umgang mit personenbezogenen Daten. Darüber hinaus müssen Datenschutzverletzungen den zuständigen Aufsichtsbehörden gemeldet werden.

Die Anforderungen der Verordnung machen Cybersecurity zu einem integralen Bestandteil der Datenverarbeitungspraktiken innerhalb der EU. Zur Umsetzung der Verordnung ist es erforderlich, ein Datenschutzmanagementsystem einzurichten und zu betreiben. Hierfür kann der Standard ISO/IEC 27701 verwendet werden.

1.2 UN-Regelung Nr. 155 und internationaler Standard ISO/SAE 21434

Die UN-Regelung Nr. 155 [10] ist ein umfassender Regelungsrahmen, der von der Wirtschaftskommission der Vereinten Nationen für Europa (UNECE) entwickelt wurde, um einen einheitlichen Ansatz für die Cybersecurity in Fahrzeugen zu schaffen. Die Verordnung ist eine Erweiterung des Übereinkommens von 1958, das technische Mindestanforderungen für die EU-Typgenehmigung und Zulassung von Fahrzeugen festlegt. Obwohl das Übereinkommen ursprünglich für Europa (insbesondere für die ECE-Mitglieder) entwickelt wurde, beteiligen sich inzwischen auch viele Nicht-ECE-Mitglieder an dem Übereinkommen. Die UN-Regelung Nr. 155 gilt zwar in erster Linie für Personenkraftwagen, insbesondere für Fahrzeuge der Klassen *M* (Fahrzeuge mit mindestens vier Rädern), *N* (Fahrzeuge zur Güterbeförderung) und *O* (Anhänger mit mindestens einem Steuergerät), erstreckt sich aber auch auf die Klassen *L6* und *L7*, wenn die Fahrzeuge über automatisierte Fahrfunktionen der Stufe 3 oder höher verfügen. Die an dem Übereinkommen von 1958 beteiligten Länder sind dafür verantwortlich, die Regelung in ihre nationalen Gesetze zu übernehmen.

Die UN-Regelung Nr. 155 ist von wesentlicher Bedeutung für die Förderung der Cybersecurity in der Automobilindustrie, da sie die Cybersecurity von Fahrzeugen während ihres gesamten Lebenszyklus, einschließlich Entwicklung, Produktion, Betrieb und Wartung, gewährleistet. Die wichtigste Anforderung der Verordnung besteht darin, dass die Automobilhersteller ein *Cybersecurity Management System (CSMS)* einführen und aufrechterhalten müssen. Im Wesentlichen verlangt ein CSMS von den Automobilherstellern die Einführung und Überprüfung von Prozessen in den Bereichen Cybersecurity-Management, Cybersecurity-Kultur, Risikomanagement, Validierung und Verifizierung, Datenüberwachung für forensische Analysen und Lieferantenmanagement. Die Automobilhersteller müssen sicherstellen, dass die Cybersecurity in der gesamten Lieferkette berücksichtigt wird.

Speziell für das Risikomanagement müssen die Risiken im Fahrzeug identifiziert und bewertet werden, und es müssen Schutzmaßnahmen implementiert werden, um diese Risiken anzugehen.

Der internationale Standard ISO/SAE 21434 [8], der von der Internationalen Organisation für Normung (ISO) in Zusammenarbeit mit der Society of Automotive Engineers (SAE) entwickelt wurde, enthält Prozessanforderungen für das Erreichen von Cybersecurity *Risikomanagement* über den gesamten Lebenszyklus eines Fahrzeugs, einschließlich Konzept, Produktentwicklung, Produktion, Betrieb, Wartung und Stilllegung von E/E-Systemen in Straßenfahrzeugen. ISO/SAE 21434 deckt verschiedene Aspekte der Cybersecurity ab, darunter organisatorisches Cybersecurity-Management, projektabhängiges Cybersecurity-Management, Risikobewertung, Validierungs- und Verifizierungstechniken, Lieferantenmanagement und kontinuierliche Cybersecurity-Aktivitäten. ISO/SAE 21434 bietet einen gemeinsamen Rahmen für die Kommunikation und das Management von Cybersecurity-Risiken. Die Beziehung zwischen der UN-Regelung Nr. 155 und der ISO/SAE 21434 über die gesamte Lieferkette hinweg ist in Abb. 1.1 dargestellt. Automobilhersteller und ihre Zulieferer können die Anforderungen der UN-Regelung Nr. 155 an das Risikomanagement erfüllen, indem sie die ISO/SAE 21434 umsetzen und die Aktivitäten durch Cybersecurity-Interface-Agreements aufeinander abstimmen.

- **Fokus auf ISO/SAE 21434** Dieses Buch konzentriert sich in erster Linie auf die Bedrohungsanalyse und die Risikobewertungsmethodik von ISO/SAE 21434. Obwohl im gesamten Buch auf die UN-Regelung Nr. 155 Bezug genommen wird, insbesondere bei der Behandlung der in der Regelung genannten Bedrohungen und der Durchführung von Risikobewertungen in der Fahrzeugproduktionsphase, ist es wichtig, darauf hinzuweisen, dass dieses Buch unabhängig und ausschließlich zur Einhaltung von ISO/SAE 21434 verwendet werden kann, und zwar unabhängig von einem bestimmten Regelungskontext.

1.3 Aufbau dieses Buches

In Kap. 1 legen wir die Grundlage für unser Buch, indem wir einen Überblick über den aktuellen Stand der Regulierung im Bereich der Cybersecurity für Kraftfahrzeuge geben. Wir konzentrieren uns auf die Darstellung der wichtigsten rechtlichen Rahmenbedingungen, die für die Hersteller von Bedeutung sind, darunter die EU-Richtlinie NIS-2, die UN-Regelungen Nr. 155 und Nr. 156 sowie weitere Rechtsnormen. Diese Gesetze und Vorschriften sind ein wichtiger Schritt hin zu einer umfassenderen Berücksichtigung der Cybersecurity in der Automobilindustrie, die bei der Anpassung an diese neuen rechtlichen Herausforderungen eine führende Rolle einnimmt. Außerdem geben wir einen kurzen Überblick über die UN-Regelung Nr. 155 und ihre Beziehung zum internationalen Standard ISO/SAE 21434.

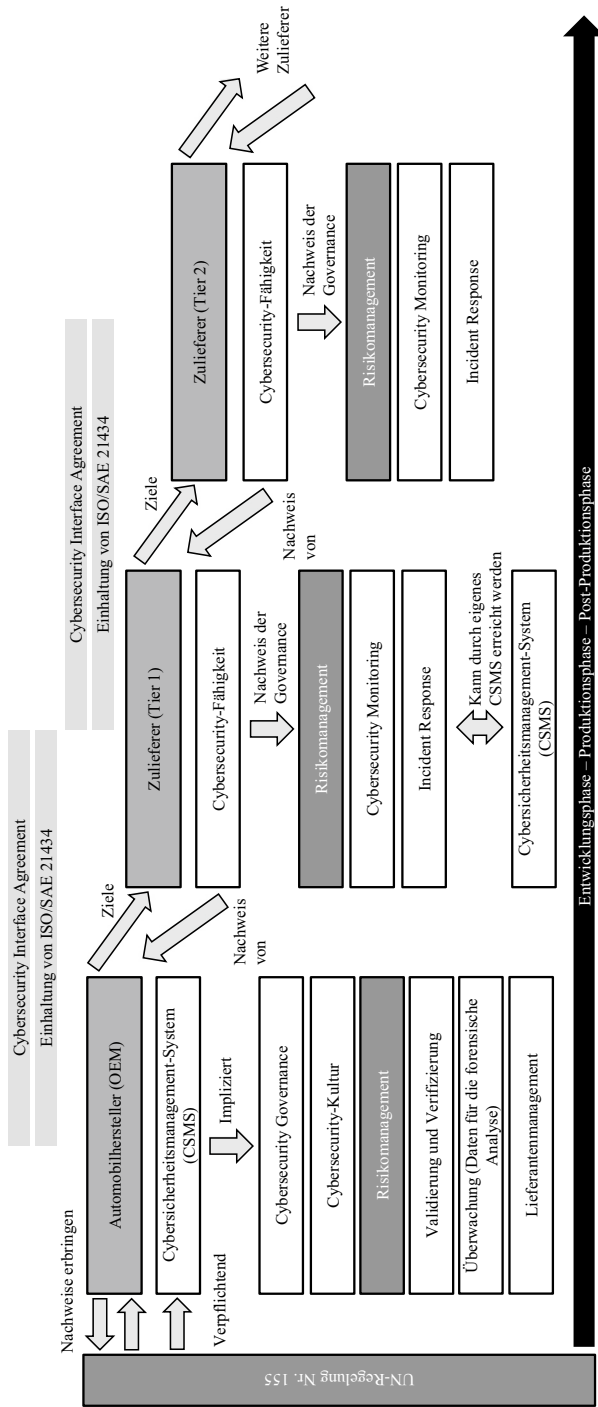


Abb. 1.1 Beziehung zwischen der UN-Regelung Nr. 155 und der ISO/SAE 21434 über die Lieferkette

In Kap. 2 geben wir einen Überblick über Standards für die Fertigungsindustrie und speziell für die Automobilindustrie, die für die Einhaltung und Umsetzung der zuvor vorgestellten Rechtsnormen relevant sind. Wir befassen uns mit etablierten und neu entwickelten Standards, die nicht nur in der Automobilindustrie, sondern im gesamten verarbeitenden Gewerbe angewendet werden können und in einigen Fällen auch müssen, darunter ISO/SAE 21434, ISO/IEC 27001, IEC 62443 und TISAX®. Diese Standards sind im Zusammenhang mit der zunehmenden Vernetzung und Automatisierung in Fahrzeugen und dem allgemeinen Trend zu intelligenten Fabriken (Smart Factories) und Produkten von Bedeutung, um Cybersecurity zu erreichen.

In Kap. 3 untersuchen wir die Merkmale verschiedener Standards im Bereich der Cybersecurity, der Informationssicherheit und des (Cyber-)Risikomanagements. Wir geben einen Überblick über die Risikomanagementmethoden und -systeme der bisher betrachteten Standards mit dem Ziel, ihre grundsätzliche Eignung für die Integration in ein einheitliches (Risiko-)Managementsystem zu beurteilen. Wir gehen dabei nicht auf technische Details oder rechtliche Einschränkungen ein. Wir betrachten vielmehr praktische Aspekte und mögliche Einschränkungen bei der Integration solcher Systeme.

In Kap. 4 geben wir eine tiefer gehende Einführung in den Prozess der Bedrohungsanalyse und Risikobewertung. Wir heben die Bedeutung von TARA in der Automobilindustrie hervor und erläutern ihren Zweck und ihre Notwendigkeit. Wir beschreiben auch, wann eine TARA im Lebenszyklus eines Fahrzeugs durchgeführt werden muss, basierend auf unserer beruflichen Erfahrung und dem gesetzlichen Rahmen. Wir erörtern auch die Dauer und den technischen Detaillierungsgrad eines TARA-Projekts in Abhängigkeit von der Lebenszyklusphase. Der gesamte TARA-Prozess, der in diesem Buch behandelt wird, wird in den folgenden Kapiteln beschrieben.

In Kap. 5 definieren wir den Scope eines TARA-Projekts. Der Scope legt fest, wie die TARA durchgeführt werden soll. Zusätzlich zur Beschreibung der Item-Definition und der Betriebsumgebung werden in diesem Schritt technische Annahmen für die TARA beschrieben, z. B. über bestehende Maßnahmen, bestehende Schwachstellen, Cybersecurity-Ziele oder Cybersecurity-Aussagen. Etwaige Besonderheiten des TARA-Projekts werden im Scope beschrieben. Darüber hinaus beschreiben wir das Angreifer-Modell und seine Fähigkeiten. Im Rahmen des Scopes definieren wir auch die Schadenskategorien für die Schadensszenarien. In diesem Kapitel stellen wir auch die praktischen Fallstudien vor, die im Laufe des Buches präsentiert werden.

In Kap. 6 legen wir den Grundstein für eine TARA, indem wir die Assets des zu analysierenden Systems oder Items identifizieren. Wir geben praktische Einblicke in die Identifikation von Assets und diskutieren relevante Cybersecurity-Eigenschaften zusätzlich zur CIA-Triade. Darüber hinaus stellen wir eine wertvolle Liste gemeinsamer Assets für eingebettete und IT-/OT-Systeme im Automobilbereich zur Verfügung. Nach der Identifikation von Assets gehen wir zur Identifikation von Schadensszenarien über. Wir analysieren die Schadensszenarien, die sich auf den Verkehrsteilnehmer auswirken, und liefern praktische Beispiele für die Bewertung der Auswirkungen in den vom Standard geforderten Katego-

rien. In Anlehnung an den Standard ISO/SAE 21434 zeigen wir, wie wir die Sichtweise auf das Schadensszenario erweitern können, um die Auswirkungen auf eine Organisation als Ganzes zu analysieren. Für die geschäftlichen Auswirkungen beschreiben wir neue Kategorien, wie z. B. geistiges Eigentum und Image/Reputation. Am Ende des Kapitels stellen wir eine vollständige Asset-Identifikation für drei praktische Fallstudien bereit.

In Kap. 7 befassen wir uns mit der Identifikation von Bedrohungsszenarien. Die Identifikation von Bedrohungsszenarien und die Zuweisung einer Eintrittswahrscheinlichkeit (Machbarkeit) ist die Quintessenz einer TARA. In diesem Kapitel befassen wir uns mit mehreren zentralen Herausforderungen bei der Durchführung von TARA. Wir beschreiben, wie man eine Bedrohungsidentifikation durchführt und diskutieren die verschiedenen gängigen Ansätze zur Bedrohungsmodellierung. Wir erörtern auch, welche Bedrohungskataloge zu verwenden sind und wie sie zu nutzen sind. Wir gehen auch auf die Angriffspfade ein und erörtern die erforderliche technische Tiefe sowie die Bewertung der Angriffsmachbarkeit. Wir schließen das Kapitel mit unseren drei Fallstudien aus der Praxis ab.

In Kap. 8 befassen wir uns mit der Berechnung des Risikos. Das Risiko ergibt sich aus der Kombination des Machbarkeitsratings der Bedrohungsszenarien und der Auswirkung des tatsächlichen Eintretens der Bedrohungsszenarien. Wir führen die Zuordnung von Asset-Bedrohungsszenarien zu Schadensszenarien durch und berechnen das Risiko jeder Kombination. Wir geben praktische Hinweise, wie die Risikomatrix angepasst werden kann. Wir zeigen auch, wie statistische Darstellungen nützlich sein können, um die wichtigsten Ergebnisse einer TARA besser darzustellen und zu verstehen. Schließlich liefern wir Beispiele auf der Grundlage unserer drei Fallstudien.

In Kap. 9 schließen wir den TARA-Prozess mit der Entscheidung über die Risikobehandlung ab. Nach Abschluss der Risikobewertung wird im nächsten Schritt entschieden, welche Maßnahmen zu ergreifen sind, um die daraus resultierenden Risiken zu behandeln. In diesem Schritt entscheidet das Cybersecurity-Team⁶ in Übereinstimmung mit ISO/SAE 21434 und den Unternehmensrichtlinien, ob die Risiken vermieden, reduziert, geteilt oder akzeptiert werden können. Jedes einzelne Risiko, das über einem Mindestwert liegt, muss analysiert werden. Wenn Cybersecurity-Maßnahmen zur Risikominderung eingesetzt werden, werden die neuen Risikowerte berechnet. In diesem Schritt von TARA werden Cybersecurity-Ziele und Cybersecurity-Aussagen definiert, wenn Risiken akzeptiert oder geteilt werden oder wenn Cybersecurity-Maßnahmen angewendet werden. Wir fahren mit unseren Fallstudien fort und geben Beispiele für verschiedene Entscheidungen zur Risikobehandlung, einschließlich der Zuordnung von Cybersecurity-Maßnahmen. Obwohl dies der letzte formale Schritt der TARA ist, beschreiben wir, dass die TARA eigentlich ein sich entwickelndes Dokument ist und der Prozess so oft wie nötig wiederholt werden kann.

⁶ Im weiteren Verlauf dieses Buches verwenden wir den Begriff „Cybersecurity-Team“, um die Rollen und Personen zu bezeichnen, die für die Planung, Umsetzung und Bewertung von Cybersecurity-Aktivitäten verantwortlich sind – insbesondere im Kontext der TARA. Eine ausführlichere Beschreibung dieser Rolle folgt in den späteren Kapiteln.

1.4 Namenskonvention

In diesem Buch orientieren wir uns an den Begrifflichkeiten der ISO/SAE 21434:2021 [8], haben diese jedoch in fachlich angemessener deutscher Sprache übersetzt. Beispiele hierfür sind: *Cybersecurity Claim* → *Cybersecurity-Aussage*, *Cybersecurity Goal* → *Cybersecurity-Ziel*, *Operational Environment* → *Betriebsumgebung*, *Attack Path* → *Angriffspfad* und *Threat Scenario* → *Bedrohungsszenario*. Die Terminologie wurde konsistent eingedeutscht, um die Lesbarkeit zu verbessern und die Integration in den deutschsprachigen Fachkontext zu erleichtern.

Wo es sinnvoll oder notwendig ist, nennen wir zusätzlich den Originalbegriff aus der ISO/SAE 21434 – entweder in Klammern oder als direkte Referenz. Dies gilt insbesondere dann, wenn eine klare Abgrenzung zu anderen Standards erforderlich ist oder eine präzise Begriffsbestimmung notwendig wird. Für offizielle Definitionen empfehlen wir grundsätzlich die direkte Konsultation der ISO/SAE 21434.

Begriffe aus anderen Standards kennzeichnen wir bei ihrer Einführung entsprechend und versehen sie mit einer Quellenangabe. Begriffe wie *Sicherheit*, *Informationssicherheit*, *IT-Sicherheit* und *Cybersecurity* werden häufig synonym verwendet – auch in diesem Buch, sofern der jeweilige Kontext keine genaue Unterscheidung erfordert, wie sie etwa in normativen Vorgaben vorkommt.

Literatur

1. Regulation (EU) 2016/679 of the European Parliament and of the Council of 27 April 2016 on the protection of natural persons with regard to the processing of personal data and on the free movement of such data, and repealing Directive 95/46/EC (general data protection regulation) (2016). <https://eur-lex.europa.eu/eli/reg/2016/679/oj>
2. European Union: Directive 2014/53/EU of the European Parliament and of the Council of 16 April 2014 on the harmonisation of the laws of the Member States relating to the making available on the market of radio equipment and repealing Directive 1999/5/EC, Dokumentnummer: 02014L0053-20241228 (2014). <http://data.europa.eu/eli/dir/2014/53/2024-12-28>
3. European Union: Regulation (EU) 2019/2144 of the European Parliament and of the Council of 27 November 2019 on type-approval requirements for motor vehicles and their trailers, and systems, components and separate technical units intended for such vehicles, as regards their general safety and the protection of vehicle occupants and vulnerable road users, amending Regulation (EU) 2018/858 of the European Parliament and of the Council and repealing Regulations (EC) No 78/2009, (EC) No 79/2009 and (EC) No 661/2009 of the European Parliament and of the Council and Commission Regulations (EC) No 631/2009, (EU) No 406/2010, (EU) No 672/2010, (EU) No 1003/2010, (EU) No 1005/2010, (EU) No 1008/2010, (EU) No 1009/2010, (EU) No 19/2011, (EU) No 109/2011, (EU) No 458/2011, (EU) No 65/2012, (EU) No 130/2012, (EU) No 347/2012, (EU) No 351/2012, (EU) No 1230/2012 and (EU) 2015/166, Dokumentnummer: PE/82/2019/REV/1 (2019). <https://eur-lex.europa.eu/eli/reg/2019/2144/oj>
4. European Union: Commission Delegated Regulation (EU) 2022/30 of 29 October 2021 supplementing Directive 2014/53/EU of the European Parliament and of the Council with regard to the application of the essential requirements referred to in Article 3(3), points (d), (e) and (f),

- of that Directive, Dokumentnummer: 02022R0030-20231027 (2021). http://data.europa.eu/eli/reg_del/2022/30/2023-10-27
5. European Union: Directive (EU) 2022/2555 of the European Parliament and of the Council of 14 December 2022 on measures for a high common level of cybersecurity across the Union, amending Regulation (EU) No 910/2014 and Directive (EU) 2018/1972, and repealing Directive (EU) 2016/1148 (NIS 2 Directive), Dokumentnummer: PE/32/2022/REV/2 (2022). <https://eur-lex.europa.eu/eli/dir/2022/2555>
 6. European Union: Regulation (EU) 2023/1230 of the European Parliament and of the Council of 14 June 2023 on machinery and repealing Directive 2006/42/EC of the European Parliament and of the Council and Council Directive 73/361/EEC, Dokumentnummer: 02023R1230-20230629 (2023). <http://data.europa.eu/eli/reg/2023/1230/2023-06-29>
 7. European Union: Regulation (EU) 2024/2847 of the European Parliament and of the Council of 23 October 2024 on horizontal cybersecurity requirements for products with digital elements and amending Regulations (EU) No 168/2013 and (EU) 2019/1020 and Directive (EU) 2020/1828 (Cyber Resilience Act), Dokumentnummer: 02024R2847-20241120 (2024). <http://data.europa.eu/eli/reg/2024/2847/2024-11-20>
 8. ISO/SAE 21434:2021 Road vehicles – Cybersecurity engineering. Standard, International Organization for Standardization/Society of Automotive Engineers, Geneva, CH (2021). <https://www.iso.org/standard/70918.html>
 9. United Nations: Agreement Concerning the Adoption of Harmonized Technical United Nations Regulations for Wheeled Vehicles, Equipment and Parts which can be Fitted and/or be Used on Wheeled Vehicles and the Conditions for Reciprocal Recognition of Approvals Granted on the Basis of these United Nations Regulations, Dokumentnummer: E/ECE/TRANS/WP.29/2016/2 (2017). <https://unece.org/trans/main/wp29/wp29regs>
 10. United Nations: UN Regulation No. 155 – Cyber security and cyber security management system, Dokumentnummer: E/ECE/TRANS/505/Rev.3/Add.154 (2021). <https://unece.org/transport/documents/2021/03/standards/un-regulation-no-155-cyber-security-and-cyber-security>
 11. United Nations: UN Regulation No. 156 – Software update and software update management system, Dokumentnummer: E/ECE/TRANS/505/rev.3/add.155 (2021). <https://unece.org/transport/documents/2021/03/standards/un-regulation-no-156-software-update-and-software-update>

Standards für die Herstellungs- und Automobilbranche

2

Zusammenfassung

In diesem Kapitel geben wir einen Überblick über Standards für die verarbeitende Industrie und speziell die Automobilindustrie, die für die Einhaltung und Umsetzung der zuvor vorgestellten Rechtsnormen relevant sind. Wir befassen uns mit etablierten und neu entwickelten Standards, die nicht nur in der Automobilindustrie, sondern im gesamten verarbeitenden Gewerbe angewendet werden können und in einigen Fällen auch müssen, darunter ISO/SAE 21434, ISO/IEC 27001, IEC 62443 und TISAX®. Diese Standards sind im Zusammenhang mit der zunehmenden Vernetzung und Automatisierung in Fahrzeugen und dem allgemeinen Trend zu intelligenten Fabriken und Produkten von Bedeutung, um Cybersecurity zu etablieren und aufrechtzuerhalten.

Die im ersten Kapitel aufgeführten Rechtsnormen weisen viele Gemeinsamkeiten auf; sie verfolgen vergleichbare und teilweise sich überschneidende Ziele und stellen vergleichbare Anforderungen. Um die größten Synergieeffekte zu erzielen, sollten die für eine Organisation geltenden Rechtsnormen im Kontext betrachtet und umgesetzt werden.

Für die Automobilindustrie gehört die kontinuierliche Weiterentwicklung mit vergleichsweise regelmäßigen Entwicklungszyklen und Innovationen zum Alltag. In den letzten zwei Jahrzehnten konnten wir einen stetigen und zuletzt rasanten Anstieg der Vernetzung und Automatisierung in Fahrzeugen erleben. Dies hat dazu geführt, dass Standards zur Harmonisierung und Regulierung geschaffen wurden, die sich mit Aspekten wie der funktionalen Sicherheit von Fahrzeugen oder der Cybersecurity befassen. Dies gilt auch für die gesamte Fertigungsindustrie, die in Deutschland mit dem Begriff „Industrie 4.0“ beschrieben wird. Man könnte allgemein von „intelligenten“ Fabriken und Produkten sprechen.

In diesem Kapitel zeigen wir auf, welche Standards in der Industrie zur Umsetzung der Rechtsnormen verwendet werden können und zum Teil auch müssen. Wir geben einen kurzen Überblick über etablierte und neu entwickelte Standards für die verarbeitende Industrie, wobei der Schwerpunkt auf der Automobilbranche liegt.

2.1 ISO/SAE 21434

ISO/SAE 21434 [21] ist ein internationaler Standard, der speziell im Hinblick auf die Cybersecurity von Straßenfahrzeugen entwickelt wurde und die zunehmende Digitalisierung und Vernetzung von Fahrzeugen sowie die damit verbundenen Cybersecurity-Risiken berücksichtigt¹. Der Standard vereinheitlicht Sprache, Ziele, Anforderungen und Vorschriften in Bezug auf Cybersecurity und soll bei der internationalen Harmonisierung helfen.

Der Standard bietet eine Grundlage für die Entwicklung sicherer Fahrzeuge und vernetzter Systeme durch einen strukturierten Ansatz zur Identifikation und Minderung von Cybersecurity-Risiken über den gesamten Lebenszyklus und die Lieferkette hinweg, vom Entwurf über die Entwicklung und Produktion bis hin zum Betrieb und zur Stilllegung. Durch die Einhaltung dieses Standards können Automobilhersteller und -zulieferer die Cybersecurity ihrer Produkte und Dienstleistungen systematisch und nachhaltig aufbauen, erhalten und verbessern. Der Standard bezieht sich auf die UN-Regelung Nr. 155 und unterstützt Organisationen bei deren Umsetzung, um die gesetzlichen und regulatorischen Anforderungen zur EU-Typgenehmigung zu erfüllen. Der Standard definiert Anforderungen an ein organisationsweites Managementsystem, aber nur das Management von Cybersecurity-Risiken in Straßenfahrzeugen ist verbindlich. Die Anwendung des Standards ist daher ein wichtiger Baustein für die Umsetzung der UN-Regelung Nr. 155, deckt jedoch bei Weitem nicht alle Anforderungen ab.

2.2 IEC 62443

IEC 62443 [1, 2, 4–7, 10, 11, 15] ist eine Reihe von Standards, die speziell für die Sicherheit von industriellen Automatisierungs- und Steuerungssystemen und Netzwerken (IACS) entwickelt wurden. Sie entstand aus der Erkenntnis, dass industrielle Systeme, die früher als isoliert betrachtet wurden, zunehmend vernetzt wurden und werden. Dies macht diesen Bereich auch anfälliger für Cyberangriffe. Ursprünglich von der International Society of Automation (ISA) unter dem Namen ISA99 entwickelt, wurde es später in IEC 62443 umgewandelt und von der International Electrotechnical Commission (IEC) weiterentwickelt und standardisiert.

Die Standardfamilie zielt darauf ab, einen strukturierten Ansatz für die Cybersecurity in industriellen Umgebungen zu bieten, die oft als Operational Technology (OT) bezeichnet werden. Dazu gehört der Schutz von Equipment und Systemen vor Cyberangriffen, die die Sicherheit von Equipment und Personal gefährden sowie Betriebsunterbrechungen und Datenverluste verursachen können. Die Standardfamilie gibt der Sicherheitseigenschaft der

¹ ISO/SAE 21434:2021 annulliert und ersetzt den Standard SAE J3061:2016.

Verfügbarkeit Vorrang vor Integrität und Vertraulichkeit. Sie beschreibt ein CSMS², das eine Risikoanalyse, die Implementierung von Gegenmaßnahmen sowie die Überwachung und Verbesserung umfasst. Die Standardfamilie richtet sich nicht nur an Betreiber, sondern auch an Integratoren, Wartungsingenieure von Industriemaschinen und Lieferanten oder Hersteller.

Die Standardfamilie ist in vier Hauptkategorien oder „Säulen“ unterteilt, die sich mit verschiedenen Aspekten der industriellen Cybersecurity befassen. Diese Säulen sind nicht als separate Einheiten zu verstehen, sondern als Teil eines übergreifenden Rahmens, der die Sicherheit während des gesamten Lebenszyklus eines industriellen Automatisierungssystems, von der Herstellung über die Integration bis zum Betrieb, gewährleisten soll.

Die erste Säule (IEC 62443-1) befasst sich mit dem allgemeinen Prozess der Cybersecurity. Es werden Rahmenbedingungen, Terminologie und Konzepte definiert. Außerdem werden die Grundlagen für eine Sicherheitspolitik und das Management der Cybersecurity festgelegt. In diesem Bereich geht es um die Etablierung einer Cybersecurity-Kultur, die die Grundlage für alle weiteren Maßnahmen bildet.

Die zweite Säule (IEC 62443-2) konzentriert sich auf Richtlinien und Verfahren, d. h. auf die Prozesse, mit denen Cybersecurity erreicht und aufrechterhalten werden soll. Sie enthält Richtlinien für Risikobewertungen, Systemklassifizierungen und Sicherheitsstufen. Die Säule unterstreicht die Bedeutung eines methodischen Ansatzes.

Die dritte Säule (IEC 62443-3) befasst sich mit dem Konzept der Systeme. Ein System besteht typischerweise aus einer Kombination von Hardware und Software und soll Steuerungs- und Automatisierungsaufgaben in industriellen Umgebungen erfüllen. Dies beinhaltet Anforderungen, die während des Entwurfs, der Entwicklung, der Integration und des Betriebs erfüllt werden müssen. Mit Hilfe von Risikoanalysen werden Maßnahmen festgelegt, darunter auch die zu erreichenden Sicherheitsstufen. Die Safety-Niveaus sind ebenfalls im Standard IEC 62443 definiert.

Die vierte und letzte Säule (IEC 62443-4) befasst sich mit den Anforderungen an die Komponenten eines industriellen Automatisierungs- und Steuerungssystems. Sie richtet sich insbesondere an die Hersteller solcher Elemente und trägt dazu bei, die Entwicklungsprozesse und die funktionale Sicherheit der Komponenten zu gewährleisten. Komponenten sind z. B. eingebettete Geräte, Host-Geräte, Network-Komponenten oder Software-Produkte. Ziel ist es, sicherzustellen, dass die einzelnen Komponenten, die in einem industriellen System verwendet werden, über die erforderlichen Sicherheitsmerkmale verfügen und so gestaltet sind, dass sie einen wirksamen Schutz gegen Cyber-Bedrohungen bieten.

Insgesamt stellt die Standardreihe einen ganzheitlichen Ansatz zur Gewährleistung einer angemessenen und wirksamen Cybersecurity für industrielle Systeme und Netzwerke über die gesamte Lieferkette und während des kompletten Lebenszyklus dar. Mehrere Standards

² Das Konzept des CSMS wurde in der zweiten Ausgabe der IEC 62443-2-1 (August 2024) aus der IEC 62443 entfernt. Der Standard fordert nun, das Sicherheitsprogramm mit dem ISMS der Organisation zu koordinieren oder einen geeigneten Prozess einzuführen, wenn kein ISMS existiert.

aus der Familie sind zertifizierbar, sodass eine wirksame Umsetzung nachgewiesen werden kann, von der Organisation über Prozesse bis hin zu Systemen und Komponenten.

2.3 ISO/IEC 27001

ISO/IEC 27001 [13] ist ein international anerkannter Standard für das Management der Informationssicherheit. Der Standard spezifiziert die Anforderungen zur Einrichtung, Umsetzung, Aufrechterhaltung und kontinuierlichen Verbesserung eines Informationssicherheits-Managementsystems (ISMS). Ein ISMS ist ein systematischer Ansatz zum Schutz von Informationen durch deren Klassifizierung, die Identifikation und Bewertung von Risiken, die die beteiligten Assets bedrohen, und die Implementierung und Prüfung geeigneter Sicherheitsziele und daraus abgeleiteter Maßnahmen.

Der Standard besteht aus zwei Teilen, dem Normkörper oder Normrahmen und Anhang A³. Der Hauptteil des Standards umfasst die Kap. 4 bis 10 und beschreibt in Form von Anforderungen einen prozessorientierten Ansatz zur Gestaltung, Integration und Verwaltung eines ISMS. Dazu gehören Aspekte wie Asset Management, Risikobewertung, Risikobehandlung, Überwachung und Verbesserung. Anhang A enthält eine Liste von Cybersecurity-Maßnahmen, die zur Reduzierung bestimmter Risiken eingesetzt werden können. Eine wesentliche Stärke eines ISMS nach ISO/IEC 27001 ist der große Freiheitsgrad bei der konkreten Umsetzung. Im Wesentlichen sind Ziele vorgegeben und die Organisation kann die Art und Weise der Umsetzung selbst bestimmen. Es werden keine bestimmten Technologien oder Lösungen vorgeschrieben.

Organisationen können sich gemäß des Standards zertifizieren lassen und damit den Nachweis erbringen, dass sie ein angemessenes und wirksames Managementsystem aufgebaut haben und kontinuierlich weiterentwickeln.

2.4 ISO 26262

ISO 26262 [9] ist ein international anerkannter Standard mit dem Ziel, die funktionale Sicherheit von elektrischen und elektronischen Systemen in Kraftfahrzeugen zu definieren und zu gewährleisten.

Ein zentrales Element des Standards ist die Definition von Sicherheitszielen und die Einführung von Automotive Safety Integrity Levels (ASIL). Die ASILs kategorisieren Risiken und werden durch eine Risikoanalyse potenzieller Gefährdungen auf der Grundlage von drei Variablen bestimmt: Schweregrad, Wahrscheinlichkeit der Exposition und Kontrollierbarkeit durch den Fahrer. Der Standard berücksichtigt den gesamten Lebenszyklus sicherheitsrelevanter Systeme, von der ersten Konzeption bis zur Stilllegung. Es werden

³ Der Standard ISO/IEC 27002 enthält Empfehlungen und Anleitungen für die Umsetzung der Cybersecurity-Maßnahmen aus Anhang A der ISO/IEC 27001.

spezifische Anforderungen an die Organisation gestellt, um sicherzustellen, dass die Ziele der funktionalen Sicherheit erreicht werden können. Dazu gehört die Definition von Rollen, Verantwortlichkeiten und notwendigen Qualifikationen. Während des Produktentwicklungsprozesses auf Systemebene legt die ISO 26262 Prozesse und Aktivitäten fest, die von der Sicherheitsanalyse über die Definition von Sicherheitszielen bis hin zur Entwicklung von Sicherheitskonzepten reichen. Darüber hinaus gibt es spezifische Anforderungen an die Hardware- und Softwareentwicklung, um sicherzustellen, dass diese Komponenten die definierten Sicherheitsziele erfüllen. Darüber hinaus legt der Standard Anforderungen für die Produktions- und Betriebsphase fest, um sicherzustellen, dass die Ziele der funktionalen Sicherheit während des gesamten Lebenszyklus eines Fahrzeugs eingehalten werden. Unterstützende Prozesse wie Konfigurations- und Änderungsmanagement, die Qualifizierung von Software-Tools und die Qualifizierung von Hardware-Komponenten sind ebenfalls Teil des Standards.

Insgesamt bietet dieser Standard einen umfassenden Rahmen, der Automobilherstellern und -zulieferern hilft, Produkte zu entwickeln, die ein akzeptables Risikoniveau in Bezug auf potenzielle Fehlfunktionen gewährleisten.

2.5 ISO/SAE PAS 8475

Der Standard wird in Zusammenarbeit zwischen der International Organization for Standardization (ISO) und der Society of Automotive Engineers (SAE) entwickelt, um die Sicherheit von Daten in automatisierten und vernetzten Fahrzeugsystemen zu behandeln.⁴ Das Konzept des Cybersecurity-Assurance-Level (CAL) aus ISO/SAE 21434 wird durch die Idee der Target Attack Feasibility (TAF) ergänzt und erweitert. CAL sind Bewertungsstufen, die verwendet werden können, um die Robustheit von Fahrzeugsystemen oder Fahrzeugen gegen Cyberangriffe anzugeben. TAF soll helfen zu beurteilen, wie realistisch und durchführbar ein Angriff auf Fahrzeugsysteme oder Fahrzeuge ist. Dazu gehören die Komplexität der Systeme, die Fähigkeiten der Angreifer und die Auswirkungen eines erfolgreichen Angriffs. Das TAF-Konzept unterstützt die Planung und Bewertung der Sicherheit der betrachteten Systeme. Beide Konzepte können als Teil des von ISO/SAE 21434 eingeführten TARA-Prozesses verwendet werden.

2.6 ISO PAS 5112

Die ISO PAS 5112 [14] ist ein Leitfaden für die Prüfung der Cybersecurity von Straßenfahrzeugen. Dieser ergänzt die ISO 19011 [8], einen Leitfaden für die Prüfung von Managementsystemen und legt allgemeine Anforderungen fest. ISO PAS 5112 legt Kriterien auf

⁴ Der Standard befindet sich derzeit in der Entwicklung. Der Status kann unter <https://www.iso.org/standard/83187.html> eingesehen werden.

der Grundlage des Standards ISO/SAE 21434 fest und ermöglicht so eine angemessene und wirksame Prüfung dieses Standards.

Der Standard befasst sich mit dem Management von Auditprogrammen, der Durchführung von Audits und Kompetenzanforderungen an Auditoren und deren Überprüfung. Der Standard unterstützt den Anwender bei internen Audits (1st party audits), Lieferantenaudits (2nd party audits) und Zertifizierungsaudits (3rd party audits). Der Verband der Automobilindustrie (VDA) hat im VDA-Band Automotive Cybersecurity Management System Audit (ACSMS) Dezember 2020 einen Fragebogen und ein Bewertungsschema veröffentlicht. Dieser kann zur Auditierung des CSMS eingesetzt werden (sowohl für OEM als auch für Vertragspartner).

2.7 ISO/SAE TR 8477

Der Standard wird im Rahmen der ISO/SAE 21434:2021 entwickelt und befasst sich mit technischen Überlegungen zur Planung und Umsetzung der Verifizierung und Validierung der Cybersecurity von Komponenten und Systemen in Straßenfahrzeugen⁵ ISO/SAE TR 8477 steht auch in engem Zusammenhang mit den Konzepten Cybersecurity-Assurance-Level (CAL) und Target-Attack-Feasibility (TAF), welche in ISO/SAE PAS 8475 verwendet werden.

2.8 ENX und TISAX®

ENX (European Network Exchange) ist eine von europäischen Automobilherstellern und -zulieferern gegründete Organisation. ENX zielt darauf ab, die Kommunikation und den Datenaustausch in der Automobilindustrie zu standardisieren und zu sichern. Durch die Bereitstellung eines sicheren Netzwerks soll die Zusammenarbeit erleichtert und die Datenintegrität gewährleistet werden.

TISAX® (Trusted Information Security Assessment Exchange) ist ein Standard für Informationssicherheit, der speziell für die Automobilindustrie entwickelt wurde. TISAX® ermöglicht es Unternehmen der Automobilindustrie, die Einhaltung von Sicherheitsstandards und -anforderungen zu bewerten und zu validieren. Die TISAX®-Bewertungen werden von akkreditierten Dienstleistern durchgeführt und sind unter den Teilnehmern des TISAX®-Austauschs anerkannt. Dies erleichtert die unternehmensübergreifende Zusammenarbeit und reduziert den Aufwand für individuelle Sicherheitsbewertungen.

Obwohl die Automobilindustrie in vielerlei Hinsicht mit den Anforderungen des Gesetzgebers vertraut ist, gibt es bislang nur vereinzelt daraus abgeleitete spezifische Regelungen zur Informations- oder Cybersecurity. So hat der Verband der Automobilindustrie

⁵ Der Standard befindet sich derzeit in der Entwicklung. Der Status kann unter <https://www.iso.org/standard/83188.html> eingesehen werden.

(VDA) einen Katalog für Informationssicherheits-Assessments (VDA-ISA) entwickelt, um dem Wunsch der OEM nach mehr Transparenz über das Informationssicherheitsniveau der Zulieferer nachzukommen. Mit dem auf diesem Katalog basierenden Modell TISAX® können OEM überprüfen, wie Zulieferer mit sensiblen Daten umgehen, zum Beispiel bei der Entwicklung von Prototypen. Zusätzlich zu den Aspekten der Informationssicherheit in TISAX® legt ISO/SAE 21434 nun Anforderungen an die Cybersecurity der Produkte selbst fest.

Wie beeinflussen die Vorschriften und Standards TARA? Der VDA hat eine aktualisierte Version seines Branchenstandards für die Bewertung der Informationssicherheit, den VDA-ISA-Katalog Version 6.0, veröffentlicht.

Um branchenweite Sicherheitsstandards zu gewährleisten, empfiehlt der VDA allen an der Wertschöpfungskette der Automobilindustrie beteiligten Unternehmen, ihre Informationssicherheit nach dem VDA-ISA zu entwickeln.

Der Standard TISAX® dient der unternehmensübergreifenden Bewertung, Anerkennung und Verfolgung der Ergebnisse des VDA Information Security Assessment. TISAX® ist damit der Goldstandard für die Zertifizierung der Informationssicherheit in Unternehmen, insbesondere in der Automobilindustrie. Aber auch außerhalb der Automobilindustrie kann die Erfüllung der Anforderungen von TISAX® dazu beitragen, wichtige Assets des Unternehmens in Form von Daten und Informationen zu schützen.

2.9 VDA Information Security Assessment

VDA Information Security Assessment (VDA-ISA) [20] ist ein integraler Bestandteil des TISAX® Standards. VDA-ISA bezieht sich auf die Bewertung der Informationssicherheit eines Unternehmens, um sicherzustellen, dass es die notwendigen Schutzmaßnahmen zum Schutz sensibler Informationen implementiert hat. Als Teil von TISAX® wird VDA-ISA nach einem standardisierten Verfahren durchgeführt, das auf dem VDA-ISA-Katalog basiert, einem vom VDA entwickelten Katalog von Sicherheitsanforderungen und Maßnahmen. Die Umsetzung der Anforderungen wird anhand von Reifegraden (Maturity Level 0 bis 5) bewertet. Aufbau und Inhalt orientieren sich an der ISO/IEC 27001, decken diese aber nicht vollständig ab und werden um automobilindustriespezifische Themen wie Prototypen und Datenschutz erweitert. Mit der VDA-ISA können Zulieferer ihre Eignung in Bezug auf Cybersecurity nachweisen.

2.10 ENX VCS

ENX hat mit dem Vehicle Cybersecurity (VCS) ein standardisiertes Auditschema [19] eingeführt. Das Schema richtet sich an Zulieferer der Automobilindustrie, welche E/E-Systeme entwickeln, produzieren oder warten. Ein CSMS nach ISO/SAE 21434, wie in ISO PAS 5112

definiert, kann durch Audits nach ENX VCS verifiziert werden. Die Zertifizierungen sind damit nicht automatisch international anerkannt, aber innerhalb der in ENX organisierten Organisationen.

2.11 Weitere Standards im Zusammenhang mit funktionaler Sicherheit und Cybersecurity

Einige der in diesem Abschnitt kurz skizzierten Standards befanden sich zum Zeitpunkt der Drucklegung dieses Buches noch im Prozess der Verabschiedung oder in der Entwicklung.

2.11.1 ISO/TS 5083

ISO/TS 5083 [18] beschreibt den Weg zur Entwicklung und Validierung von automatisierten Fahrsystemen auf der Grundlage grundlegender funktionaler Sicherheits- und Cybersecurity-Prinzipien, die aus einschlägigen Veröffentlichungen abgeleitet wurden. Funktionale Sicherheit und Cybersecurity-by-Design sowie Verifikations- und Validierungsmethoden für automatisierte Fahrsysteme werden betrachtet, wobei der Schwerpunkt auf Fahrzeugen mit Level-3- und Level-4-Funktionen liegt. Darüber hinaus werden Cybersecurity-Ziele zusammen mit den Zielen für funktionale Sicherheit für automatisierte Fahrsysteme vorgestellt.

2.11.2 ISO/PAS 8800

ISO/PAS 8800 [17] definiert geeignete sicherheitsrelevante Grundsätze, Methoden, Eigenschaften und risikobeeinflussende Faktoren der künstlichen Intelligenz (KI) in Bezug auf deren Einsatz in Fahrzeugen. Dies steht im Einklang mit den Anforderungen der Standards ISO 26262 [9] und ISO 21448 [12] und dient auch der Harmonisierung der Konzepte von ISO/TS 5083 und ISO 21448. Der Standard deckt alle Entwicklungs- und Einsatzphasen ab. Er beschreibt die Ableitung von Sicherheitsanforderungen, die Berücksichtigung von Datenqualität und -vollständigkeit, architektonische Maßnahmen zur Fehlerkontrolle, Werkzeuge zur Unterstützung der KI sowie Verifikations- und Validierungstechniken zur Gewährleistung der allgemeinen funktionalen Sicherheit des Systems. Es liefert auch Beweise für die formale Verifikation.

2.11.3 ISO/IEC TR 5469

Der technische Report befasst sich mit den Eigenschaften, potenziellen Risiken, Methoden und Prozessen für die Anwendung von künstlicher Intelligenz in Bezug auf die funktionale Sicherheit in sicherheitskritischen Operationen [16].

2.11.4 IEC 61508

IEC 61508 [3] ist eine international anerkannte Reihe von Standards für die funktionale Sicherheit von elektrischen, elektronischen und programmierbaren elektronischen Systemen. Der Standard definiert einen Rahmen für das Management der funktionalen Sicherheit bei der Entwicklung von Systemen, die das Risiko von technischen Fehlern oder zufälligen Ausfällen minimieren. Der Standard ist die Grundlage, auf der viele branchenspezifische Standards zur funktionalen Sicherheit basieren, wie z. B. ISO 26262 im Automobilbereich.

Literatur

1. IEC TR 62443-3-1:2009 Industrial communication networks – Network and system security – Part 3-1: Security technologies for industrial automation and control systems. Standard, International Electrotechnical Commission (2009). <https://webstore.iec.ch/publication/7031>
2. IEC TS 62443-1-1:2009 Industrial communication networks – Network and system security – Part 1-1: Terminology, concepts and models. Standard, International Electrotechnical Commission (2009). <https://webstore.iec.ch/publication/7029>
3. IEC 61508-1:2010 Functional safety of electrical/electronic/programmable electronic safety-related systems – Part 1: General requirements. Standard, International Electrotechnical Commission (2010). <https://webstore.iec.ch/publication/5515>
4. IEC 62443-2-1:2010 Industrial communication networks – Network and system security – Part 2-1: Establishing an industrial automation and control system security program. Standard, International Electrotechnical Commission (2010). <https://webstore.iec.ch/publication/7030>
5. IEC 62443-3-3:2013 Industrial communication networks – Network and system security – Part 3-3: System security requirements and security levels. Standard, International Electrotechnical Commission (2013). <https://webstore.iec.ch/publication/7033>
6. IEC TR 62443-2-3:2015 Security for industrial automation and control systems – Part 2-3: Patch management in the IACS environment. Standard, International Electrotechnical Commission (2016). <https://webstore.iec.ch/publication/22811>
7. IEC 62443-4-1:2018 Security for industrial automation and control systems – Part 4-1: Secure product development lifecycle requirements. Standard, International Electrotechnical Commission (2018). <https://webstore.iec.ch/publication/33615>
8. ISO 19011:2018 Guidelines for auditing management systems. Standard, International Organization for Standardization (2018). <https://www.iso.org/standard/70017.html>
9. ISO 26262:2018 Road vehicles – Functional safety, Part 1-12. Standard, International Organization for Standardization (2018)

10. IEC 62443-4-2:2019 Security for industrial automation and control systems – Part 4-2: Technical security requirements for IACS components. Standard, International Electrotechnical Commission (2019). <https://webstore.iec.ch/publication/34421>
11. IEC 62443-3-2:2020 Security for industrial automation and control systems – Part 3-2: Security risk assessment for system design. Standard, International Electrotechnical Commission (2020). <https://webstore.iec.ch/publication/30727>
12. ISO 21448:2022 Road vehicles – Safety of the intended functionality. Standard, International Organization for Standardization (2022). <https://www.iso.org/standard/77490.html>
13. ISO/IEC 27001:2022 Information security, cybersecurity and privacy protection – Information security management systems – Requirements. Standard, International Organization for Standardization/International Electrotechnical Commission (2022). <https://www.iso.org/standard/82875.html>
14. ISO/PAS 5112:2022 Road vehicles – Guidelines for auditing cybersecurity engineering. Standard, International Organization for Standardization (2022). <https://www.iso.org/standard/80840.html>
15. IEC TS 62443-1-5:2023 Security for industrial automation and control systems – Part 1-5: Scheme for IEC 62443 security profiles. Standard, International Electrotechnical Commission (2023). <https://webstore.iec.ch/publication/67461>
16. ISO/IEC TR 5469:2024 Artificial intelligence – Functional safety and AI systems. Standard, International Organization for Standardization/International Electrotechnical Commission (2024). <https://www.iso.org/standard/81283.html>
17. ISO/PAS 8800:2024 Road vehicles – Road vehicles – Safety and artificial intelligence. Standard, International Organization for Standardization (2024). <https://www.iso.org/standard/83303.html>
18. ISO/TS 5083:2025 Road vehicles – Safety for automated driving systems – Design, verification and validation. Standard, International Organization for Standardization (2025). <https://www.iso.org/standard/81920.html>
19. ENX: Introducing Vehicle Cybersecurity (VCS) Audit Scheme (2023). <https://portal.enx.com/en-us/news/Introducing-Vehicle-Cybersecurity-VCS-Audit-scheme/>
20. German Association of the Automotive Industry (VDA): VDA ISA Catalog Version 6.0.1 (2023). <https://www.vda.de/en/topics/digitization/data/information-security>
21. ISO/SAE 21434:2021 Road vehicles – Cybersecurity engineering. Standard, International Organization for Standardization/Society of Automotive Engineers, Geneva, CH (2021). <https://www.iso.org/standard/70918.html>

Integrierte Managementsysteme und integriertes Risikomanagement

3

Zusammenfassung

In diesem Kapitel untersuchen wir die Merkmale verschiedener Standards im Bereich der Cyber- und Informationssicherheit und des (Cyber-)Risikomanagements. Wir geben einen Überblick über die Risikomanagement-Methoden und -systeme der bisher betrachteten Standard mit dem Ziel, ihre grundsätzliche Eignung für die Integration in ein einheitliches (Risiko-)Managementsystem zu beurteilen. Wir gehen dabei nicht auf technische Details oder rechtliche Einschränkungen ein. Wir betrachten praktische Aspekte und mögliche Einschränkungen bei der Integration solcher Systeme.

Die beiden vorangegangenen Kapitel geben einen Überblick über die wichtigsten Rechtsnormen und technischen Standards der Cybersecurity für die produzierende Industrie. Dabei wird deutlich, dass es unterschiedliche rechtliche und technische Perspektiven für die Bereiche Cybersecurity, Informationssicherheit und Risikomanagement gibt. Während Standards, insbesondere diejenigen, die sich auf Managementsysteme beziehen, auf Organisationen blicken, konzentrieren sich technische Standards auf andere Aspekte oder Teilaspekte. So richtet sich der Standard ISO/IEC 27001 an Organisationen und legt die Anforderungen an ein wirksames Managementsystem fest, welches dann zur Einrichtung und Verbesserung der Informationssicherheit in allen Bereichen und auf allen Ebenen und für alle Aspekte einer Organisation verwendet werden kann. Dabei ist es unerheblich, welchen Zweck diese Organisation verfolgt. Lässt man externe Einflussfaktoren einmal außer Acht, so hängt es allein vom Willen der Organisation ab, an welchen Stellen der Standard umgesetzt wird, z. B. in welchen Organisationseinheiten, an welchen Standorten oder für welche Geschäftsprozesse. So kann die Informationssicherheit im Bereich der Produktentwicklung, in der Produktherstellung, im Service oder für den Betrieb der Produkte selbst oder eben überall dort etabliert

werden. Der abstrakte Charakter der ISO/IEC 27001 – der normative Teil des Standards umfasst nur etwa zehn Seiten – ermöglicht eine Umsetzung unabhängig von Größe, Branche oder Unternehmenskultur.

Auf der anderen Seite gibt es sehr spezifische, eher technisch ausgerichtete Standards mit genau beschriebenen Verfahren, wie z. B. ISO/SAE 21434 und die darin definierte TARA. Der Schwerpunkt liegt hier auf der verarbeitenden Industrie, genauer gesagt auf Herstellern von Straßenfahrzeugen. Je mehr branchenspezifische Merkmale, Anforderungen oder Ziele in einen solchen Standard einfließen, desto maßgeschneiderter kann das Ergebnis sein. Dies führt oft zu einer leichteren Umsetzbarkeit in den betroffenen Organisationen, da bei der Entwicklung versucht wurde, die Besonderheiten des Umfeldes zu berücksichtigen. Ein damit verbundener Nachteil kann sein, dass sich ein solcher Standard nur schwer oder gar nicht auf andere Bereiche übertragen lässt.

Steht eine Organisation vor der Herausforderung, aus regulatorischen Gründen oder aufgrund von Marktanforderungen mehrere Standards zugleich anwenden zu müssen, sollte zunächst geprüft werden, ob diese integriert umgesetzt und betrieben werden sollen. Ein Blick in die Praxis zeigt, dass Organisationen die Integration häufig vermeiden, weil es die Projektkomplexität erheblich erhöhen kann. Es heißt dann, dass dies einen erhöhten Einsatz von Ressourcen erfordert, dass das Projekt dann eine längere Laufzeit aufweisen wird oder dass bestimmte Teile der Organisation ohnehin schon zu stark ausgelastet sind. Die Integration kann jedoch, sinnvoll durchgeführt, eben genau dazu beitragen, die für den Betrieb erforderlichen Ressourcen zu reduzieren.

Betrachtet man Standards, welche Anforderungen an Managementsysteme definieren (z. B. ISO/IEC 27001 oder ISO 9001), so fällt auf, dass die meisten von ihnen in ihrem Umfang sehr knapp gehalten sind. Im Vergleich zu technischen Standards enthalten Managementsystemstandards in der Regel eher abstrakte Anforderungen. Um eine einfache Integration von Managementsystemen aus verschiedenen Disziplinen zu ermöglichen, wurde durch die ISO eine High-Level Structure (HLS) entwickelt, welche seit 2012 für die Entwicklung bzw. Weiterentwicklung aller ISO-Managementsystemstandards anzuwenden ist. Im Mai 2021 wurde aus der HLS die „harmonisierte Struktur“, die leichte Anpassungen mit sich bringt. Die neue Struktur wird in zukünftigen Ausgaben der Standards angewendet werden.

Im nächsten Abschnitt betrachten wir die bereits berücksichtigten Standards näher und konzentrieren uns dabei auf einen zentralen Aspekt, das Risikomanagement. Dazu werden die Risikomanagement-Standards und die wichtigsten Risikomanagement-Methoden aus den zuvor vorgestellten Standards aufgelistet, um ihre grundsätzliche Eignung für die Integration in bestehende Risikomanagement-Systeme zu bewerten.

3.1 Überblick über Risikomanagementmethoden und -systeme

Die in Kap. 2 behandelten Rechtsnormen stammen aus dem Bereich des europäischen Rechts bzw. aus nationalem Recht, sofern diese auf nationaler Ebene umgesetzt wurden. Diese Standards befassen sich im Allgemeinen nicht mit spezifischen technischen Fragestellungen oder Details. Die darin enthaltenen spezifischen Anforderungen an das Risikomanagement weisen keine einschränkenden oder miteinander unvereinbaren Aspekte auf. Beispielsweise wird eine Beurteilung sowie eine angemessene und wirksame Behandlung von Risiken gefordert. Die konkrete Ausgestaltung der hierfür verwendeten Prozesse wird jedoch häufig weder detailliert vorgeschrieben noch eingeschränkt. Die Ausgestaltung obliegt dann den Betroffenen oder ergibt sich aus der Anwendung einschlägiger Standards.

Im Folgenden werden die zentralen Anforderungen an das Risikomanagement aus den in Kap. 2 aufgeführten technischen Standards und Managementsystemstandards zusammengefasst und hinsichtlich ihrer gegenseitigen Kompatibilität betrachtet.

3.1.1 ISO/IEC 27001

ISO/IEC 27001 [10] verlangt im Kern die Definition, Implementierung und Verbesserung eines Risikomanagementprozesses und darin die Berücksichtigung von Wahrscheinlichkeiten und Schäden (Auswirkungen) von Risiken pro Asset oder Asset-Gruppe. Es ist ein Risikoakzeptanzniveau zu definieren. Die minimal zu berücksichtigenden Schutzziele sind die Verfügbarkeit, Integrität und Vertraulichkeit. Der Risikomanagementprozess muss zu angemessenen, wiederholbaren und nachvollziehbaren Ergebnissen führen.

3.1.2 BSI-Standard 200-1

Der BSI-Standard 200-1 [3] fordert die Definition und Umsetzung eines Risikomanagementprozesses. Dabei sind vordefinierte Risiken und Maßnahmenlisten pro Assetgruppe aus dem Grundschutz-Kompendium zu berücksichtigen, welche dazu dienen, das Grundschutz-niveau zu erreichen. Ist der Schutzbedarf erhöht, ist eine weitergehende Risikoanalyse und -behandlung durchzuführen. Hier kann eine ISO/IEC 27001-konforme Methode angewendet werden. Die mindestens zu berücksichtigenden Schutzziele sind Verfügbarkeit, Integrität und Vertraulichkeit. Der BSI-Standard 200-3 [4] bietet umfangreiche Hilfestellungen zur Ausgestaltung des Risikomanagements, ohne jedoch die anzuwendenden Prozess normativ einzuschränken.

3.1.3 ISO/IEC 27005

Ein allgemeiner Risikomanagementprozess wird im Standard ISO/IEC 27005 beschrieben [12], welcher auch im Rahmen der Implementierung der ISO/IEC 27001 verwendet werden kann. Dies bedeutet, dass das System vollständig kompatibel ist bzw. keine einschränkenden Anforderungen stellt.

3.1.4 ISO 31000

Der Standard ISO 31000 [5] beschreibt einen generischen Risikomanagementprozess und keinen speziell auf Informationssicherheitsrisiken ausgerichteten Prozess. Der beschriebene Prozess lässt sich jedoch problemlos beispielsweise im Rahmen der ISO/IEC 27001 anwenden, da er im Wesentlichen dem in der ISO/IEC 27005 beschriebenen Prozess entspricht. Es bestehen keine Zielkonflikte oder Inkompatibilitäten mit den zuvor genannten Standards.

3.1.5 ISO 22301

Einer der ersten Schritte bei der Einführung eines Business-Continuity-Management-Systems besteht darin, eine Business Impact Analysis (BIA) [7] durchzuführen. Diese Analyse untersucht die Folgen eines Ausfalls der betrachteten Geschäftsprozesse für den Geschäftsbetrieb. Dabei steht vor allem das Schutzziel Verfügbarkeit im Vordergrund. Ergänzend werden Risikoanalysen durchgeführt, die Risiken identifizieren und bewerten, denen die Assets oder Assetgruppen ausgesetzt sind, die zur Durchführung der zuvor betrachteten Geschäftsprozesse erforderlich sind. Auch hier liegt der Fokus auf dem Schutzziel der Verfügbarkeit. Der Prozess, bestehend aus der BIA und der nachfolgenden Risikoanalyse, lässt sich in ein Risikomanagementsystem, beispielsweise gemäß ISO/IEC 27001, integrieren. Obwohl die BIA formal nicht explizit in der ISO/IEC 27001 vorgesehen ist, bietet sie sich an, um ein vertieftes Verständnis der zu schützenden Geschäftsprozesse und der damit verbundenen Informationen zu erhalten. Die durch die BIA gewonnenen Analysedaten erlauben es also die Schutzbedarfe bzw. die Kritikalität der zu schützenden Informationen hinsichtlich der Verfügbarkeit präzise zu definieren. Die anschließende Risikoanalyse kann dann im Rahmen eines mit der ISO/IEC 27001 geteilten Risikomanagementprozesses erfolgen, wobei im BCMS häufig weitere, über die im ISMS benötigten, Assetgruppen einbezogen werden. Für solche Assetgruppen sind dann selbstverständlich nur die benötigten Schutzziele zu betrachten.

3.1.6 TISAX®

TISAX® (Trusted Information Security Assessment Exchange) wurde geschaffen, um eine einheitliche Methodik zur Bestimmung und Verbesserung des Informationssicherheitsniveaus einer Organisation zu etablieren. Die Anforderungen an das Risikomanagement entsprechen den Anforderungen der ISO/IEC 27001 und lassen sich daher leicht in ein gemeinsames System integrieren. Die zu berücksichtigenden Mindest-Schutzziele sind Verfügbarkeit, Integrität und Vertraulichkeit. Eine gegebenenfalls notwendige Berücksichtigung des Datenschutzes und weiterer Aspekte und die daraus resultierende Erweiterung der Schutzziele stehen nicht im Widerspruch zu den grundsätzlichen Anforderungen an ein Risikomanagementsystem z. B. gemäß ISO/IEC 27001.

3.1.7 IEC 62443

IEC 62443 ist eine Reihe von Standards, d. h. es sind mehrere Standards zu berücksichtigen, die aufgrund ihrer unterschiedlichen Anwendungsbereiche auch unterschiedliche Anforderungen an das Risikomanagement stellen.

IEC 62443-2-1 befasst sich mit den Anforderungen an ein CSMS¹, das sich an die Organisation richtet. Dieser Standard wurde bereits mit dem Ziel entwickelt, die Anforderungen mit ISO/IEC 27001 in Einklang zu bringen. Assets oder Asset-Gruppen werden nur in sehr abstrakten Kategorien als zu schützende Werte beschrieben, etwa in Form eines technischen oder logischen Objekts.

Die Standards der IEC 62443-Reihe fokussieren auf industrielle Überwachungs- und Steuerungssysteme, sodass es keine Einschränkungen oder gar unterschiedliche Sichtweisen zu den zuvor genannten Standards gibt (Anmerkung: Neben ISO/IEC 27001 definiert ISO/IEC 27019 spezielle Anforderungen für den Bereich der Energieversorgung und betrachtet deswegen ebenso industrielle Überwachungs- und Steuerungssysteme). Die Schutzziele (Objectives) können frei ergänzt werden; grundsätzlich werden Vertraulichkeit, Integrität und Verfügbarkeit berücksichtigt. Allerdings werden die Ziele je nach Anwendungsbereich unterschiedlich priorisiert. Der Risikomanagementprozess, der im Wesentlichen aus der Bewertung und Behandlung von Risiken besteht, entspricht den zuvor genannten Systemen. Die Organisation kann die Risikotoleranz (in ISO/IEC 27001 z. B. als Risikoakzeptanzniveau bezeichnet) dabei selbst festlegen.

¹ Das Konzept des CSMS wurde mit der zweiten Ausgabe der IEC 62443-2-1 (August 2024) entfernt. Der Standard fordert nun, das Sicherheitsprogramm mit dem ISMS der Organisation zu koordinieren oder einen geeigneten Prozess einzuführen, wenn kein ISMS existiert.

IEC 62443-3-2 hingegen befasst sich mit der Cybersecurity von industriellen Automatisierungs- und Steuerungssystemen sowie deren Auswirkungen auf die Organisation. Der Standard verwendet ein Prozessmodell, das auf dem Konzept von Sicherheitszonen und Conduits basiert. Das darauf definierte Risikomanagementsystem ist umfassender und detaillierter definiert als in den zuvor betrachteten Standards.

Es baut jedoch auf den schon bekannten Elementen auf, wie beispielsweise Asset-Gruppen, Definitionen von Schutzbedarfsanforderungen (Zielsicherheitsniveau) oder Brutto- und Nettorisikobewertungen².

Die Risikobehandlung kann durch Übertragung, Akzeptanz oder Minderung von Risiken erfolgen. Die Organisation legt das tolerierbare Risikoniveau selbst fest. Der Risikowert wird durch die Bewertung von Wahrscheinlichkeit und Auswirkungen bestimmt.

Auch wenn die Vorgehensweise zunächst stark von den einfacheren Modellen aus ISO/IEC 27001, ISO/IEC 27005 oder ISO 31000 abzuweichen scheint, ist der allgemeine Prozess vergleichbar. Die Modelle lassen sich konsistent zueinander gestalten und implementieren.

3.1.8 ISO/SAE 21434

Der Standard ISO/SAE 21434 [16] beschreibt ein Cybersecurity-Managementsystem sowie die Anforderungen an ein solches System. Der Standard beschreibt ein Managementsystem aus einer Governance-Perspektive, betrachtet aber nicht die gesamte Organisation und ihren Kontext, sondern konzentriert sich auf Straßenfahrzeuge und ihre Komponenten für deren gesamten Lebenszyklus. Dabei ist entsprechend nur die Betrachtung von Cybersecurity-Risiken für Straßenfahrzeuge erforderlich. Das Risikomanagementsystem erfordert die Identifikation von Bedrohungsszenarien auf Asset-Ebene, die Bewertung der Auswirkungen, die Analyse von Angriffspfaden, die Bewertung der Machbarkeit von Angriffen und die Ermittlung des Risikowertes. Zu diesem Zweck wird ein geeignetes Verfahren definiert, bekannt als TARA (Threat Analysis and Risk Assessment).

Die typischerweise berücksichtigten Schutzziele (Cybersecurity-Properties) sind Vertraulichkeit, Verfügbarkeit und Integrität. Die Betrachtung darf um weitere Ziele ergänzt werden. Soll ein Risiko beibehalten werden (risk retaining), müssen Cybersecurity-Aussagen (Cybersecurity-Claims) spezifiziert werden, um die Angemessenheit des Vorgehens zu begründen. Dies entspricht dem Konzept der Risikoakzeptanz. Es ist außerdem möglich bei Bedrohungsszenarien mit einem Risikowert von 1 auf eine weitere Behandlung zu verzichten.

² Das Bruttorisiko entspricht dem unverminderten Risiko, das Nettorisiko entspricht dem Restrisiko.

Wie bei IEC 62443-3-2 unterscheidet sich das Vorgehen stark von den einfachen Modellen, das Grundprinzip ist jedoch auch hier vergleichbar. Das bedeutet, dass die Risikomanagementprozesse und -verfahren durchgängig konsistent zueinander konzipiert und implementiert werden können. Es ist zu beachten, dass eine Risikobeurteilung, wie sie IEC 62443-3-2 fordert, mithilfe einer TARA umgesetzt werden kann. In Organisationen, die Produkte für den Straßenfahrzeugsektor und auch andere Produkte herstellen, empfiehlt es sich, das TARA-Konzept zu verwenden und nicht unterschiedliche Verfahren anzuwenden. Im Idealfall werden dieses Verfahren und ein unternehmensweites CSMS oder ISMS aufeinander abgestimmt und integriert betrieben.

ISO/SAE 21434 konzentriert sich in erster Linie auf die Entwicklung im Bereich der Cybersecurity aus der Perspektive eines einzelnen Items oder einer Komponente, die Teil eines Fahrzeugs sein kann, beispielsweise eines elektronischen Steuergeräts (ECU), oder auf das gesamte Fahrzeug, d. h. die Analyse seiner E/E-Architektur. In Bezug auf die Produktion eines Items, also die Produktion eines Embedded Devices durch einen Zulieferer oder die Produktion des gesamten Fahrzeugs, gibt es im Wesentlichen zwei Hauptziele, die der Standard in Kap. 12 *Production* im Zusammenhang mit der Herstellungsphase und der Post-Produktionsphase anspricht. Diese Ziele sind:

1. die Erstellung von Cybersecurity-Anforderungen für Post-Development, und
2. die Vermeidung der Einführung von Schwachstellen während der Produktion.

ISO/SAE 21434 fordert, dass ein Produktionskontrollplan existiert, der Cybersecurity-Maßnahmen enthält, um unbefugte Veränderungen des Items während der Produktion zu verhindern. Beispiele für Cybersecurity-Maßnahmen sind laut des Standards physische Maßnahmen, die den physischen Zugang zu Produktionsservern verhindern, oder logische Maßnahmen, bei denen kryptografische Techniken und Zugriffskontrollen verwendet werden. Um diese Ziele zu erreichen, muss ein umfassendes Risikomanagement des Produktionsprozesses wirksam sein.

Eine Produktionsanlage kann als komplexe Umgebung sowohl von Informationstechnik-(IT) als auch von Operational-Technology-Systemen (OT) betrachtet werden.

Um das Verständnis und die Integration von Risikomanagementsystemen zu erleichtern, stellen wir in Tab. 3.1, 3.2 und 3.3 einen Vergleich zentraler Begriffe aus den Standards vor.

Tab. 3.1 Vergleich der Schlüsselbegriffe aus verschiedenen Standards für Risikomanagementsysteme

ISO/IEC 27001 ^a [6]	BSI-Standard 200-1 ^b [4]	ISO/IEC 27005 ^c [6]	ISO 31000 [5]	ISO 22301 ^c [9]	TISAX ^d	IEC 62443 ^d	ISO/SAE 21434 [16]
Risk	Risk	Risk	Risk	Risk	Information Security Risk [14]	Risk [1]	Risk
Risk Assessment	Risk Assessment	Risk Determination	Risk Assessment	Risk Assessment	Risk Assessment [13]	Risk Assessment [1]	Threat Analysis and Risk Assessment
Risk Identification	Drawing up of a Threat Overview	Risk Identification	Risk Identification	Risk Identification	Risk Identification [17]	Identify Threats ^e [8]	Threat Scenario Identification ^e
Risk Analysis	Risk Assessment	Risk Analysis	Risk Analysis	Risk Analysis	Risk Analysis [17]	Risk Assessment [1]	Threat Analysis and Risk Assessment
Risk Evaluation	Risk Evaluation	Risk Evaluation	Risk Evaluation	Risk Evaluation	Risk Evaluation [17]	Determine Unmitigated Cyber Security Risk [8]	Risk Value Determination
Consequence	Extent of Damage, Effects of Damage	Risk Identification	Risk Analysis	Consequence	Impact, Potential Damage [14]	Consequence [1, 8], Impact [8]	Impact
Likelihood	Frequency of Occurrence	Risk Analysis	Risk Evaluation	Likelihood	Probability of Occurrence, Frequency of Occurrence [17]	Likelihood [8]	Attack Feasibility

^a ISO/IEC 27001 und ISO/IEC 27005 beziehen sich auf die Definitionen aus ISO/IEC 27000 (Kap. 3)^b Risikomanagement wird durch den BSI-Standard 200-3 definiert^c ISO 22301 bezieht sich auf die Definitionen von ISO 22300 (Kap. 3)^d Die Zitate stammen aus verschiedenen Quellen; sie sind daher bei den Begriffen aufgeführt^e Weniger abstrakt, aber das gleiche Konzept wird verwendet

Tab. 3.2 (Fortsetzung) Vergleich von Schlüsselbegriffen aus verschiedenen Standards für Risikomanagementsysteme

ISO/IEC 27001^a [6]	BSI-Standard 200-1^b [4]	ISO/IEC 27005^a [6]	ISO 31000 [5]	ISO 22301^c [9]	TISAX^d	IEC 62443^d	ISO/SAE 21434 [16]
Risk Acceptance Criteria	Risk Acceptance Criteria	Risk Evaluation	Risk Criteria	Es existiert kein präziser Begriff, aber das Konzept wird im Rahmen der Risikobewertung angewendet	Threshold [17]	Risk Tolerance Level [1], Tolerable Risk [8]	Ein präziser Begriff existiert nicht, aber das Konzept wird in [PM-06-08] [16] angewendet
Risk Acceptance	Risk Acceptance	Risk Retention	Retaining the Risk	Risk Acceptance	Risk Acceptance [17]	Accept the Risk [1]	Retaining the Risk
Risk Treatment	Risk Treatment	Risk Treatment	Risk Treatment	Risk Treatment	Risk Treatment [17]	Risk Response [1], vergleiche Unmitigated Risk mit Tolerable Risk [8]	Risk Treatment Decision
— ^e	Risk Avoidance	Risk Avoidance	Risk Avoidance	Avoiding the Risk	Risk Avoidance [17]	Design the Risk out [1]	Avoiding the Risk
— ^e	Risk Reduction, Risk Modification	Risk Modification	Changing the Likelihood, Changing the Consequences	Risk Mitigation, Risk Reduction	Risk Mitigation [17]	Reduce the Risk [1], Mitigate the Risk [8]	Reducing the Risk
— ^e	Risk Transfer, Risk Sharing	Risk Sharing	Sharing the Risk	Risk Sharing	Risk Transfer [17]	Transfer or Share the Risk [1]	Sharing the Risk

^a ISO/IEC 27001 und ISO/IEC 27005 beziehen sich auf die Definitionen aus ISO/IEC 27000 (Kap. 3)^b Risikomanagement wird durch den BSI-Standard 200-3 definiert^c ISO 22301 bezieht sich auf die Definitionen von ISO 22300 (Kap. 3)^d Die Zitate stammen aus verschiedenen Quellen; sie sind daher bei den Begriffen aufgeführt^e Der Begriff wird in ISO/IEC 27001 nicht direkt verwendet; es wird auf das Konzept von ISO 31000 verwiesen

Tab. 3.3 (Fortsetzung) Vergleich von Schlüsselbegriffen aus verschiedenen Standards für Risikomanagementsysteme

ISO/IEC 27001 ^a [6]	BSI-Standard 200-1 ^b [4]	ISO/IEC 27005 ^a [6]	ISO 31000 [5]	ISO 22301 ^c [9]	TISAX ^d	IEC 62443 ^d	ISO/SAE 21434 [16]
Residual Information Security Risk	Residual Risk, Remaining Risk	Residual Risk	Remaining Risk	Residual Risk	Residual Risk [17]	Residual Risk [1]	–
Level of Risk	Risk Category	Level of Risk	Level of Risk	Level of Risk	Level of Risk [17]	Level of Risk [1]	Risk Value
Asset	Asset	Asset	Asset	Asset	Information Asset [17]	Asset [1]	Asset
System	–	–	–	–	–	System under Consideration [8]	Item, Component (nicht dieselbe Bedeutung)
Control	Safeguard	Control	Control	Control	Measure [17]	Countermeasure [1]	Cybersecurity Control
Security Objective	Security Objective	Security Objective	–	–	Protection Objective [17]	Security Objective [1]	Cybersecurity Property

^a ISO/IEC 27001 und ISO/IEC 27005 verweisen auf die Definitionen aus ISO/IEC 27000 (Kap. 3)

^b Risikomanagement wird durch den BSI-Standard 200-3 definiert

^c ISO 22301 bezieht sich auf die Definitionen von ISO 22300 (Kap. 3)

^d Die Zitate stammen aus verschiedenen Quellen; sie sind daher bei den Begriffen aufgeführt

^e Der Begriff wird in ISO/IEC 27001 nicht direkt verwendet; es wird auf das Konzept von ISO 31000 verwiesen

3.2 Harmonisierung und Integration von Managementsystemen

In der Praxis werden Managementsysteme häufig nebeneinander und unabhängig voneinander betrieben. Die einzelnen Managementsysteme unterscheiden sich in ihrer Aufbau- und Ablauforganisation. Die Verantwortung für die Systeme ist an unterschiedlichen Stellen in der Organisation angesiedelt, und die Systeme haben häufig auch einen unterschiedlichen Anwendungsbereich. Dies führt regelmäßig zu deutlich höheren Kosten für die Organisation, da Strukturen, Prozesse, Verfahren, Berichtswege und Abläufe stark redundant sind. Im schlimmsten Fall sind Aspekte der Systeme untereinander nicht kompatibel, oder einzelne Ziele widersprechen sich direkt oder indirekt.

Ein integriertes Managementsystem (IMS) hilft Ordnung zu schaffen. Es fasst die verschiedenen Managementsysteme eines Unternehmens in einem System mit einheitlicher Struktur zusammen. Auf diese Weise können verschiedene Bereiche wie Qualitätsmanagement, Arbeits- und Gesundheitsschutz sowie Informationssicherheit in einer gemeinsamen Organisations- und Prozessstruktur zusammengeführt werden. Integrierte Managementsysteme werden selten direkt in einer Organisation eingeführt. In der Regel werden zuvor isolierte Systeme zu einem späteren Zeitpunkt zusammengeführt.

Idealerweise steht eine gemeinsame Informations- und Datenplattform zur Verfügung. Auf dieser Basis könnte dann zum Beispiel das Risikomanagement integriert durchgeführt werden und so zu vergleichbaren, kohärenten und konsistenten Ergebnissen über verschiedene Bereiche und Abstraktionsebenen hinweg führen. Negative Auswirkungen könnten minimiert oder sogar ausgeschlossen werden.

So sinnvoll die spätere Integration von Einzelsystemen in ein integriertes Managementsystem ist, so schwierig kann deren Umsetzung sein. Ein integriertes Managementsystem ist in seiner Struktur und Umsetzung komplexer als ein einzelnes, isoliertes System. Daher erfordern Planung und Betrieb mehr Weitsicht und Erfahrung. Selbst mit der vollen Unterstützung der obersten Führungsebene fällt es Organisationen oft schwer, dann redundante und damit überflüssige Strukturen abzubauen. Etablierte Organisationsformen und Machtstrukturen neigen häufig dazu solche Integrationsprojekte auszubremsen oder führen gar zur Aufgabe.

Aufgrund der Harmonisierung der ISO-Managementsystemstandards lassen sich diese in der Theorie leicht integrieren. Welche Aspekte sollten beachtet werden und welche Herausforderungen existieren in der Praxis bei der Integration solcher Systeme und insbesondere des Risikomanagements?

Unterschiedliche Anwendungsbereiche innerhalb eines integrierten Managementsystems führen in der Regel nicht zu Widersprüchen oder Problemen. Die Komplexität des Systems nimmt jedoch mit der Anzahl der verschiedenen Anwendungsbereiche zu. Daher sollte das Ziel sein, diese Zahl möglichst gering zu halten. Jedes Managementsystem bedient einen bestimmten Bereich und verfolgt unterschiedliche Ziele. Diese oft abstrakten Ziele sollten harmonisiert werden. Auf dieser Betrachtungsebene bestehen dabei in der Regel

keine Widersprüche. Was zunächst nach Zielkonflikten aussieht, lässt sich häufig leicht auflösen.

So wird beispielsweise die Arbeitssicherheit als Ziel eines Managementsystems – also der Schutz von Leib und Leben – naturgemäß höher priorisiert sein als etwa das Verfügbarkeitsziel eines anderen Systems.

Ein Beispiel, das auf den ersten Blick konstruiert wirkt, ist der Not-Aus-Schalter. Dieser kann aufgrund von Arbeits- und Betriebssicherheitsanforderungen vorgeschrieben sein. Gleichzeitig kann ein solcher Not-Aus-Schalter aus Sicht der Betriebsfortführung ein Risiko darstellen. Je nach Ausführung kann das Betätigen ganze Produktionsanlagen oder Serverräume abschalten. Ist der Not-Aus-Schalter jedoch durch eine Klappe gegen unbeabsichtigtes Betätigen geschützt, wird das potenzielle Risiko reduziert. Der scheinbare Widerspruch ist damit aufgelöst.

Ein etwas weniger direktes Beispiel ist das Folgende aus dem Bereich des Datenschutzes und der Datensparsamkeit. IT-Betrieb ist darauf angewiesen (Meta-)Daten auszuwerten oder Log-Daten vorzuhalten, um Vorfälle nachträglich analysieren und aufklären zu können. Dadurch ist es beispielsweise möglich umfassende und langfristig vorbereitete Angriffe besser nachvollziehen und wirksamere Gegenmaßnahmen ergreifen zu können. Datenschutz wiederum verfolgt das Ziel, dass auch hierzu relevante Daten gar nicht erst erhoben oder gespeichert werden.

Chancen und Risiken sowie Kosten und Nutzen werden einander gegenübergestellt. Aus der Sicht eines Managementsystems stellt dies aktives Risikomanagement dar. Das Thema wird aus verschiedenen Blickwinkeln betrachtet, Auswirkungen werden bewertet und mögliche Handlungsoptionen gegeneinander abgewogen. Bei der Integration von Risikomanagementsystemen oder -methoden ist darauf zu achten, dass Definitionen wie Schadenskategorien, Schwellenwerte oder Metriken und die verwendeten Methoden aufeinander abgestimmt sind oder – noch besser – voneinander abgeleitet sind. Risiken werden häufig auf unterschiedlichen Unternehmensebenen bewertet und müssen dann zu einem kohärenten Gesamtbild der Unternehmensrisiken zusammengefasst werden.

Werden beispielsweise Risiken einem einzelnen Produkt zugeordnet, können sie zu einem Gesamtbeitrag für die produzierende Geschäftseinheit aggregiert werden. Daraus lässt sich wiederum der Beitrag in Bezug auf das Gesamtgeschäft des Unternehmens ableiten. Eine weitere Herausforderung ist, dass Risikobewertungen häufig nicht „exakt“ bewertet werden oder werden können und stattdessen nur eine Auswertung in Form von Rangfolgen oder Prioritäten, vorgenommen werden.

Im Hinblick auf das Cybersecurity-Risikomanagement in Produktionsanlagen – also das Risikomanagement für IT- und OT-Systeme – existieren zwei große und etablierte Familien internationaler Standards: die ISO/IEC-27000-Reihe [6, 10, 11] für IT-Systeme und die IEC 62443-Reihe [1, 2] für OT-Systeme.

In größeren Unternehmen oder Produktionsstätten besteht eine gute Chance, dass das Unternehmen und die Produktionsstätten nach ISO/IEC 27001 und/oder IEC 62443 zertifiziert sind. Eine Zertifizierung nach einem dieser Standards kann ein stichhaltiges Argument

sein, um die durch ISO/SAE 21434 geforderten Ziele zu erreichen. Es ist aber zu prüfen, ob die Zertifizierung auch die Produktionsanlagen umfasst. Beispielsweise kann ein Unternehmen und die intern genutzten IT-Systeme zertifiziert sein, ohne jedoch die Produktion und die damit verbundene IT und OT betrachtet zu haben. Daher kann es sinnvoll sein, das Risikomanagement für Produktionsanlagen in den Geltungsbereich einer TARA nach ISO/SAE 21434 aufzunehmen. Eine einheitliche Sichtweise und ein einheitliches Bewusstsein für die verschiedenen Risikomanagement-Ansätze im gesamten Unternehmen zu schaffen, ist eine Herausforderung.

In diesem Buch möchten wir dieses Verständnis für die TARA-Methode vermitteln. Wir wollen die Vorteile der etablierten Standards für IT und OT nutzen und einige ihrer Methoden, wie Bedrohungen und Cybersecurity-Maßnahmen, auf unsere ISO/SAE 21434-konforme TARA anwenden. Das Dilemma, ob besser ISO/IEC 27001 oder IEC 62443 in einem gemischten IT-/OT-System angewendet werden soll, ist in der Branche nicht neu. Ein Ansatz für die Kombination dieser beiden Standards wurde in [15] formalisiert, und wir lassen uns davon für die Anwendung auf die Cybersecurity in der Automobilindustrie inspirieren, zusätzlich zu unserer beruflichen Erfahrung mit ähnlichen TARA-Projekten. In Abb. 3.1 zeigen wir die übergeordnete Überschneidung zwischen den verschiedenen Standards für die unterschiedlichen Phasen des Produktlebenszyklus.

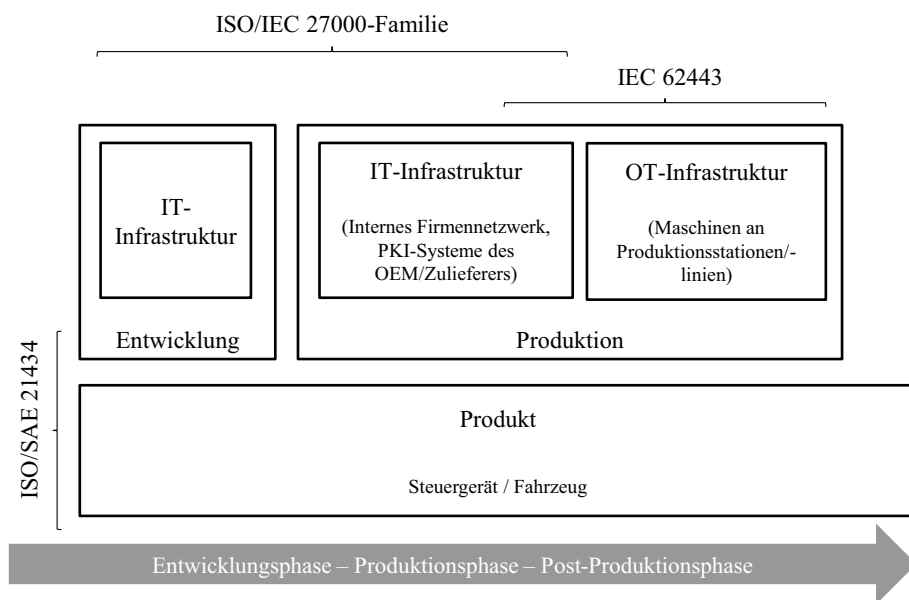


Abb. 3.1 High-level Abdeckung der ISO/SAE 21434 während des Fahrzeug-/Produktlebenszyklus und der Standards für IT und OT

3.3 Ein ISO/SAE 21434 TARA für IT-/OT-Systeme

Das Ziel der ISO/SAE 21434 in Bezug auf die Produktion besteht darin, das Item (z. B. ECU oder Fahrzeug) gegen Vulnerabilities zu schützen, die während der Produktion und in der Post-Development Phase eingeführt werden könnten.

So muss beispielsweise sichergestellt sein, dass keine Schadsoftware in das Steuergerät eingeschleust werden kann – weder durch einen böswilligen Bediener noch aufgrund eines ungeschützten, über das Internet erreichbaren Dienstes. In der Post-Produktionsphase muss beispielsweise sichergestellt sein, dass die Backend-Server, die Authentifizierungsmaterial für die Steuergeräte bereitstellen, nicht kompromittiert werden und somit keinen Zugriff auf die im Einsatz befindlichen Steuergeräte ermöglichen. Die Kombination von IT und OT mit ISO/SAE 21434 ergibt sich aus der Tatsache, dass eine Bedrohungsanalyse und Risikobewertung auf Produktionsebene die Risiken für das Item während der Produktion identifizieren und Maßnahmen zu deren Minderung bereitstellen muss (unter der Annahme, dass Minderung als Behandlungsentscheidung gewählt wird).

Wir nutzen die in den Standards der ISO/IEC 27000- und der IEC 62443-Reihe beschriebenen Maßnahmen und das darin eingeflossene Wissen und integrieren dieses in die TARA. [15] verfolgt einen ähnlichen Ansatz zur Kombination dieser Standards. Wir heben hervor, dass eine TARA nach ISO/SAE 21434 darauf abzielt, die ECU oder das Fahrzeug zu schützen. Die Kombination der Cybersecurity-Maßnahmen und Anforderungen der Standards der ISO/IEC 27000-Reihe und der IEC 62443³ bedeutet nicht, dass diese Standards auch eingehalten werden. Wenn man jedoch von Risiken ausgeht, die sich aus einer ungeschützten Umgebung ergeben, kann die Einhaltung von Cybersecurity-Maßnahmen und Anforderungen aus etablierten Standards in den Bereichen IT und OT von großem Nutzen sein.

Literatur

1. IEC TS 62443-1-1:2009 Industrial communication networks – Network and system security – Part 1-1: Terminology, concepts and models. Standard, International Electrotechnical Commission (2009). <https://webstore.iec.ch/publication/7029>
2. IEC 62443-2-1:2010 Industrial communication networks – Network and system security – Part 2-1: Establishing an industrial automation and control system security program. Standard, International Electrotechnical Commission (2010). <https://webstore.iec.ch/publication/7030>
3. BSI Standard 200-1: Information Security Management Systems (ISMS). Standard, Bundesamt für Sicherheit in der Informationstechnik (2017). <https://www.bsi.bund.de/dok/10027834>
4. BSI Standard 200-3: Risk Analysis based on IT Grundschutz. Standard, Bundesamt für Sicherheit in der Informationstechnik (2017). <https://www.bsi.bund.de/dok/10027834>
5. ISO 31000:2018 Risk management – Guidelines. Standard, International Organization for Standardization (2018). <https://www.iso.org/standard/65694.html>

³ Das Konzept des CSMS wurde in der zweiten Ausgabe der IEC 62443-2-1 (August 2024) aus der IEC 62443 entfernt. Der Standard fordert nun, das Sicherheitsprogramm mit dem ISMS der Organisation zu koordinieren oder einen geeigneten Prozess einzuführen, wenn kein ISMS existiert.

6. ISO/IEC 27000:2018 information technology – security techniques – information security management systems – overview and vocabulary. Standard, International Organization for Standardization/International Electrotechnical Commission (2018). <https://www.iso.org/standard/73906.html>
7. ISO 22301:2019 Security and resilience – Business continuity management systems – Requirements. Standard, International Organization for Standardization (2019). <https://www.iso.org/standard/75106.html>
8. IEC 62443-3-2:2020 Security for industrial automation and control systems – Part 3-2: Security risk assessment for system design. Standard, International Electrotechnical Commission (2020). <https://webstore.iec.ch/publication/30727>
9. ISO 22301:2021 Security and resilience – Vocabulary. Standard, International Organization for Standardization (2021). <https://www.iso.org/standard/77008.html>
10. ISO/IEC 27001:2022 Information security, cybersecurity and privacy protection – Information security management systems – Requirements. Standard, International Organization for Standardization/International Electrotechnical Commission (2022). <https://www.iso.org/standard/82875.html>
11. ISO/IEC 27002:2022 Information security, cybersecurity and privacy protection – Information security controls. Standard, International Organization for Standardization/International Electrotechnical Commission (2022). <https://www.iso.org/standard/75652.html>
12. ISO/IEC 27005:2022 Information security, cybersecurity and privacy protection – Guidance on managing information security risks. Standard, International Organization for Standardization/International Electrotechnical Commission (2022). <https://www.iso.org/standard/80585.html>
13. ENX: TISAX® Participant Handbook Version 2.7. Standard, ENX (2023). <https://www.enx.com/handbook/tisax-participant-handbook.html>
14. German Association of the Automotive Industry (VDA): VDA ISA Catalog Version 6.0.1 (2023). <https://www.vda.de/en/topics/digitization/data/information-security>
15. International Society of Automation: Applying ISO/IEC 27001/2 and the ISA/IEC 62443 Series for Operational Technology Environments (2021). <https://www.isa.org/news-press-releases/2021/july/new-white-paper-applying-iso-iec-27001-2-and-the-i>
16. ISO/SAE 21434:2021 Road vehicles – Cybersecurity engineering. Standard, International Organization for Standardization/Society of Automotive Engineers, Geneva, CH (2021). <https://www.iso.org/standard/70918.html>
17. VDA: Information Security Risk Management – Protection objectives: confidentiality, integrity, availability – Version 1.1. White paper, German Association of the Automotive Industry (VDA) (2021)



Zusammenfassung

In diesem Kapitel geben wir eine tiefer gehende Einführung in den Prozess der Bedrohungsanalyse und Risikobewertung. Wir stellen die Bedeutung der TARA für die Automobilindustrie dar und erläutern ihren Zweck und die Notwendigkeit ihrer Anwendung. Wir beschreiben, basierend auf unserer beruflichen Erfahrung und dem gesetzlichen Rahmen, wann eine TARA im Lebenszyklus eines Fahrzeugs durchzuführen ist. Wir erörtern typische Umfänge und technische Detaillierungsgrade von TARA-Projekten in Abhängigkeit der Lebenszyklusphase. Der gesamte TARA-Prozess, der in diesem Buch behandelt wird, wird in den folgenden Kapiteln beschrieben.

Eine Bedrohungsanalyse und Risikobewertung (Threat Analysis and Risk Assessment, TARA) ist eine systematische, analytische Analyse zur Ermittlung potenzieller Bedrohungen, die für ein bestimmtes System ein Risiko darstellen können. Das Hauptziel einer TARA besteht darin, diese Risiken zu bewerten und wirksame Gegenmaßnahmen zu formulieren, um sie auf ein akzeptables Niveau zu reduzieren. Eine TARA ist ein hochtechnischer und anspruchsvoller Prozess, bei dem das zu bewertende System sorgfältig und gründlich analysiert wird. Eine TARA erfordert eine genaue Kenntnis des zu bewertenden Systems in Kombination mit Cybersecurity-spezifischem Wissen, um alle möglichen Bedrohungen zu identifizieren. Bei der Durchführung einer TARA muss domänenspezifisches Wissen über das zu bewertende System mit spezialisiertem Fachwissen im Bereich der Cybersecurity kombiniert werden. Diese Kombination ermöglicht die Erkundung verschiedener Angriffsvektoren und Schwachstellen (Vulnerabilities), die von Angreifern ausgenutzt werden könnten.

Ergänzende Information Die elektronische Version dieses Kapitels enthält Zusatzmaterial, auf das über folgenden Link zugegriffen werden kann https://doi.org/10.1007/978-3-662-72358-6_4.

Eine TARA ist ein generischer Prozess, der auf jedes System in jedem Bereich angewendet werden kann. In [6] nutzen die Autoren zum Beispiel Konzepte aus ISO/SAE 21434, um TARA auf medizinische Geräte anzuwenden. Gerade im Automotive-Sektor existiert das Konzept der TARA (Threat Analysis and Risk Assessment) seit vielen Jahren. Frühere, bekannte Ansätze sind beispielsweise EVITA [3] und HEAVENS [5]. Andere populäre TARA-Ansätze, die nicht ausdrücklich für die Automobilindustrie entwickelt wurden, aber ebenfalls in der Automobilindustrie verwendet werden, sind ETSI TVRA [2], PASTA [7], die international anerkannten Standards für Informationssicherheitsmanagement aus der ISO/IEC 27000-Familie [1], und andere. Mit dem Aufkommen von Vorschriften und Standards in den letzten Jahren, wie z. B. der UN-Regelung Nr. 155 und dem Standard ISO/SAE 21434, wurde der TARA-Prozess für die Automobilindustrie zunehmend stärker angewendet und standardisiert.

Der primäre Fokus von TARA nach ISO/SAE 21434 [4], dem dieses Buch für alle beschriebenen Fälle folgt, ist das Fahrzeug und dessen Komponenten. Zur Entwicklung, der Produktion und dem weiteren Lebenszyklus von Fahrzeugen wird ein komplexes Ökosystem aus IT-Systemen, Fertigungs- und OT-Systemen, E/E-Komponenten, die im Fahrzeug verbaut werden und weiteren fahrzeugfremden Geräten benötigt. Anzumerken ist, dass diese Komponenten und Systeme in verschiedener Form miteinander kommunizieren und funktionieren müssen. Aus diesem Grund behandeln wir in diesem Buch zwei große Gruppen von Systemen. Zunächst analysieren wir eingebettete Geräte, d. h. elektronische Steuergeräte (ECUs) im Fahrzeug, sowie E/E-Architekturen auf Fahrzeugebene. Diese Arten von TARAs sind unserer Erfahrung nach die am häufigsten nachgefragten Analysen, da sie explizit im Scope des Standards ISO/SAE 21434 liegen. Zudem analysieren wir Systeme außerhalb des Fahrzeugs, wie z. B. Fertigungsanlagen und Backend-Systeme. Beide Sichtweisen sind Bausteine einer umfassenden Cybersecurity-Strategie.

- **Was ist eine TARA nicht?** Es ist wichtig, klarzustellen, insbesondere für Leser, die mit dem Risikomanagement in der Cybersecurity und der automobilen TARA nicht vertraut sind, dass eine TARA nicht mit einem praktischen Sicherheitstest wie einem Penetrationstest verwechselt werden sollte. Während ein Penetrationstest die tatsächliche Durchführung von Angriffen beinhaltet, um Schwachstellen zu identifizieren, verfolgt eine TARA einen anderen Zweck. Eine TARA konzentriert sich darauf, potenzielle Bedrohungen systematisch und strukturiert zu analysieren und die damit verbundenen Risiken zu bewerten. Ziel ist es, die verschiedenen Bedrohungen, denen ein System ausgesetzt sein könnte, zu identifizieren und zu verstehen, ihre potenziellen Auswirkungen zu bewerten und Strategien zur Risikominderung vorzuschlagen. Im Gegensatz zu einem praktischen Sicherheitstest beinhaltet eine TARA nicht das aktive Testen oder Angreifen des Systems. Darüber hinaus ist es wichtig zu beachten, dass die Durchführung von TARA keinen endgültigen Nachweis dafür liefern kann, dass ein System sicher ist. TARA trägt jedoch erheblich dazu bei, Schwachstellen und Sicherheitslücken aufzudecken. TARA liefert wertvolle Einblicke in potenzielle

Risiken und unterstützt fundierte Entscheidungen zur Verbesserung der Cybersecurity und infolgedessen auch zum Schutz der Insassen und anderer Verkehrsteilnehmer.

4.1 Warum ist es notwendig?

Es gibt gute Gründe, warum Bedrohungsanalysen und Risikobewertungen in der Automobilindustrie und allgemein durchgeführt werden sollten. Erstens ist das *Risikomanagement* entscheidend, um die Produktion sicherer Fahrzeuge zu gewährleisten, mit dem ultimativen Ziel, Menschenleben zu schützen. Die Automobilindustrie erkennt an, dass Cybersecurity genauso wichtig ist wie funktionale Sicherheit, um das Wohlbefinden von Kunden und Straßenverkehrsteilnehmern zu gewährleisten. Darüber hinaus ist die Wahrnehmung sicherer Produkte heutzutage ein grundlegender Aspekt der Produktqualität. Kunden erwarten, dass ein Produkt genauso sicher ist, wie sie erwarten, dass es zuverlässig funktioniert und den vorgesehenen Zweck erfüllt. Zusätzlich haben die Hersteller selbst ein großes Interesse daran, ihre Geschäftsabläufe vor Bedrohungen zu schützen. Potenzielle Risiken wie Datenlecks und Denial-of-Service-Angriffe können schwerwiegende Konsequenzen haben, einschließlich Rufschädigung, finanziellen Verlusten und Vertrauensverlust bei Kunden. Durch die proaktive Identifikation und Minderung dieser Risiken können Hersteller die Kontinuität ihres Geschäfts schützen und sich einen Wettbewerbsvorteil auf dem Markt sichern.

Zweitens ist die *Einhaltung von Vorschriften* von entscheidender Bedeutung in der Automobilindustrie. Branchenspezifische Standards und Vorschriften, wie die UN-Regelung Nr. 155 und ISO/SAE 21434, bieten Leitlinien und Anforderungen zur Gewährleistung der Cybersecurity in Fahrzeugen. Die Durchführung einer TARA wird zur Notwendigkeit, um diese Vorschriften einzuhalten und branchenspezifische sowie rechtliche Vorgaben zu erfüllen. Durch die Integration von TARA in den Produktentwicklungszyklus können Hersteller die Einhaltung der regulatorischen Rahmenbedingungen nachweisen und ihr Engagement für Cybersecurity-Governance stärken.

Abschließend ist anzumerken, dass eine systematische Bewertung der Risiken eines Produkts dazu beiträgt, dieses Produkt kosteneffizienter zu entwickeln. Durch die frühzeitige Identifikation und Behebung potenzieller Schwachstellen und Bedrohungen im Entwicklungsprozess können Hersteller spätere Fehlerbehebungen und teure Neugestaltungen vermeiden.

4.2 Wann findet es im Lebenszyklus eines Fahrzeugs statt?

Gemäß ISO/SAE 21434 sind die TARA-Schritte oder -Methoden generische Module, die systematisch und von jedem Punkt im Lebenszyklus eines Items oder einer Komponente aus aufgerufen werden können [4]. Wir kombinieren die Flexibilität des Standards mit unserer Erfahrung in der Industrie und geben einen Überblick über die Phasen im Lebenszyklus, in

denen die Durchführung von TARA sinnvoll ist. Wir beschreiben verschiedene Abstraktionsebenen für TARA in den verschiedenen Phasen.

Es gibt vier Schlüsselphasen im Lebenszyklus eines Fahrzeugs, in denen die Durchführung von TARA unabdingbar ist. Dabei werden die Aspekte des Aufbaus und der Pflege eines sicheren Produkts, der kosteneffizienten Entwicklung des Produkts und der Einhaltung von Vorschriften und Standards berücksichtigt. Die verschiedenen Arten von TARA entsprechen den im Standard ISO/SAE 21434 beschriebenen Lebenszyklusphasen. Es ist wichtig zu beachten, dass die verschiedenen Abstraktionsebenen von TARA einem praktischen Ansatz folgen und als Orientierungshilfe dienen können. Die Differenzierung von TARA in verschiedene Phasen hat mehrere Vorteile. Erstens ermöglicht sie die Optimierung des TARA-Prozesses selbst. So kann eine erste TARA, die in der Konzeptphase durchgeführt wird, relativ kurz sein, da eine detaillierte Analyse der Angriffspfade zu diesem Zeitpunkt möglicherweise noch nicht möglich ist. Sie dient jedoch immer noch dazu, hohe Risiken zu ermitteln und eine Grundlage für spätere Bewertungen zu schaffen. Zweitens trägt die Durchführung von TARA in verschiedenen Phasen zur Aufrechterhaltung der Kosteneffizienz während der Produktentwicklung bei. Durch die Durchführung einer umfassenden TARA während der Entwicklungsphase können neue Cybersecurity-Maßnahmen, die ursprünglich nicht eingeplant waren, in das Produktdesign integriert werden. Auf diese Weise werden umfangreiche Neukonstruktionen und teure Änderungen in späteren Phasen vermieden. Wird die TARA erst am Ende der Entwicklungsphase durchgeführt, sind die technischen Kosten für die Umgestaltung des Produkts zur Risikominderung in aller Regel wesentlich höher. Die verschiedenen TARA-Ansätze werden in Abb. 4.1 anhand der verschiedenen Phasen eines typischen Fahrzeuglebenszyklus veranschaulicht.

4.2.1 Initiale TARA

Das Hauptziel der frühen bzw. anfänglichen TARA ist die Unterstützung der Konzeptphase durch die Identifikation hoher Risiken. In diesem Stadium, in dem nur der operationelle Kontext des Items bekannt ist bzw. angenommen wird, ist es nicht möglich, eine detaillierte technische Analyse durchzuführen. Es ist jedoch unerlässlich, High-Level-Risiken zu identifizieren und zu betrachten, um die Grundlage für das Cybersecurity-Konzept und den Produktentwurf zu schaffen. Betrachten wir zum Beispiel ein Szenario, in dem externe Konnektivität für das Item geplant ist, aber das spezifische Konnektivitätssystem, wie WLAN oder Bluetooth, noch nicht festgelegt wurde. In diesem Fall kann eine erste TARA beide Konnektivitätssysteme analysieren und High-Level Cybersecurity-Ziele und Cybersecurity-Aussagen (Cybersecurity-Claims) liefern. Diese Ergebnisse unterstützen das Cybersecurity-Konzept des Items und helfen bei der Festlegung der erforderlichen Sicherheitsanforderungen. Während des Entwurfsprozesses kann das Entwicklungsteam dann auf der Grundlage der TARA-Ergebnisse entscheiden, nur die WLAN-Konnektivität einzubeziehen. Diese Entscheidung könnte aus Gründen der Kosteneffizienz getroffen werden, da die gewünschten

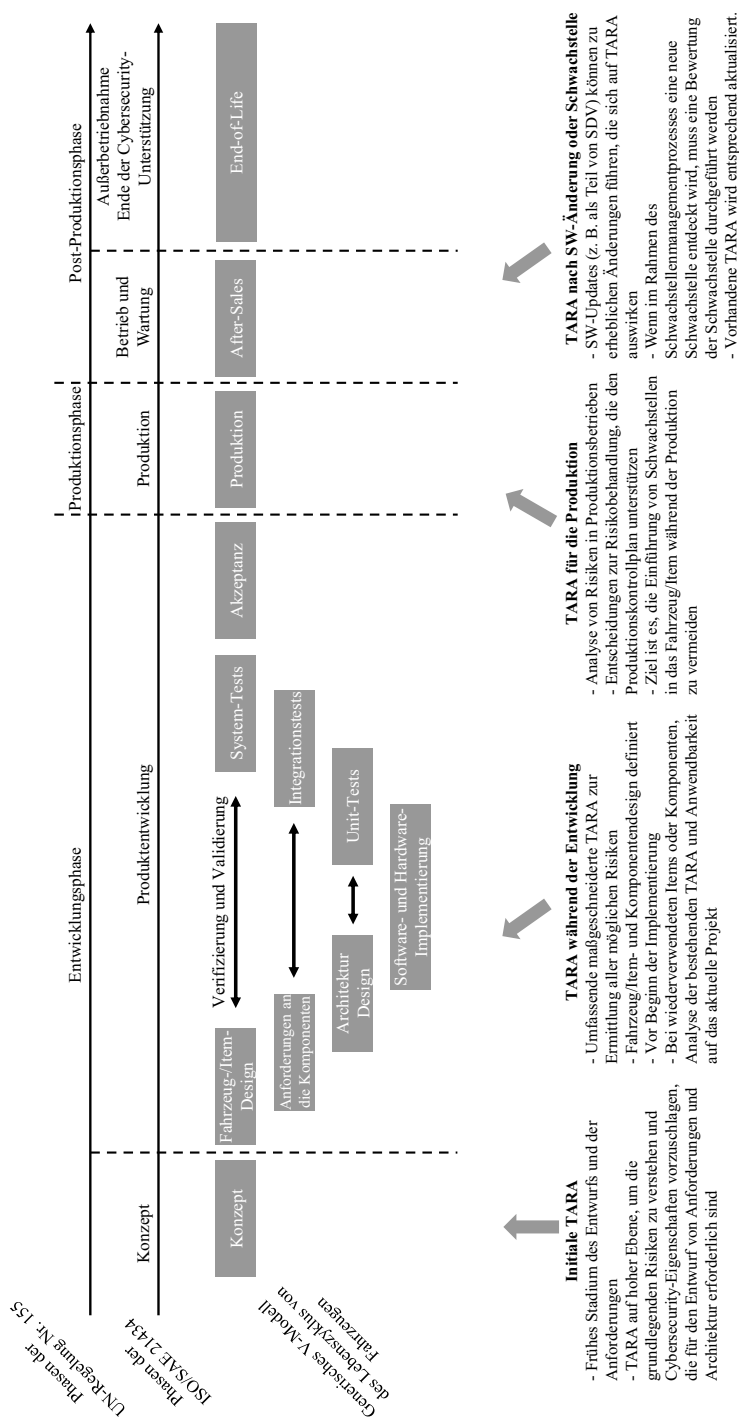


Abb. 4.1 TARA in den verschiedenen Phasen des Fahrzeuglebenszyklus

Cybersecurity-Ziele mit der Bluetooth-Technologie möglicherweise nicht erreicht werden können. Es ist wichtig, darauf hinzuweisen, dass dieses Beispiel vereinfacht ist, um die Vorteile einer frühzeitigen TARA zu veranschaulichen, und nicht bedeutet, dass ein Konnektivitätssystem aus Prinzip besser oder schlechter ist als ein anderes.

Die frühzeitige Durchführung einer TARA ermöglicht es Cybersecurity-Teams potenzielle Risiken proaktiv zu erkennen und fundierte Entscheidungen über die Auswahl von Cybersecurity-Maßnahmen und -Technologien zu treffen. Dieser Ansatz stellt sicher, dass Cybersecurity-Aspekte von Anfang an in den Entwurf des Items integriert werden, was eine kosteneffiziente und robuste Cybersecurity-Struktur während des gesamten Entwicklungsprozesses ermöglicht.

4.2.2 TARA während der Entwicklung

Die TARA während der Entwicklungsphasen stellt die typische, umfassende TARA für das Item dar. Diese TARA erfordert akribische technische Strenge. Die Entwicklungsphase selbst ist von Natur aus komplex und kann in verschiedene Unterphasen unterteilt werden, von denen jede mögliche Änderungen und zusätzliche Anforderungen an die Konstruktion des Items mit sich bringt. Während der Entwicklungsphase können geringfügige Änderungen an den Entwurfselementen des Items vorgenommen werden, neue Anforderungen können auftauchen und Schwachstellen können durch Schwachstellen-Analysen oder andere Mittel entdeckt werden. Folglich wird die TARA zu einem Instrument mit lebender Dokumentation, das sich mit der Entwicklungsphase weiterentwickelt. Das durchführende Cybersecurity-Team hat die Flexibilität, den geeigneten Zeitpunkt für die Initiierung der TARA während der Entwicklungsphase zu bestimmen. Nach der Initiierung ist das Cybersecurity-Team dafür verantwortlich, die TARA regelmäßig zu aktualisieren, um Änderungen des Designs des Items, neue Schwachstellen oder die sich entwickelnde Bedrohungslandschaft zu berücksichtigen.

4.2.3 TARA für die Produktion

Die TARA für die Produktion unterscheidet sich leicht von der TARA für die Entwicklung von Items. Der Zweck der TARA für die Produktion ist nicht die Analyse des zu produzierenden Items, sondern die Analyse der Risiken für das Item in den Produktions- und Nachproduktionsprozessen. In der Produktionsphase ist der Entwurf des Items, ob es sich nun um ein Fahrzeug oder ein Teil handelt, bereits abgeschlossen und kann nicht mehr geändert werden. In der Produktionsphase berücksichtigt die TARA die Produktionsumgebung. So wird beispielsweise sichergestellt, dass keine bösartige Software durch einen böswilligen Bediener oder durch einen ungeschützten, dem Internet ausgesetzten Dienst in das Steuergerät eingeschleust werden kann. In der Post-Produktionsphase muss beispiels-

weise sichergestellt werden, dass die Backend-Server, die Authentifizierungsmaterial für die Steuergeräte enthalten, nicht kompromittiert werden können, um Zugang zu den Steuergeräten im Feld zu erhalten. Die Integration von IT- und OT-Aspekten in die Methodik der ISO/SAE 21434 beruht auf der Notwendigkeit, bereits auf Produktionsebene Bedrohungen für das Item systematisch zu identifizieren und geeignete Gegenmaßnahmen zu definieren – vorausgesetzt, es wird entschieden, das Risiko aktiv zu behandeln.

4.2.4 TARA nach Software-Änderung oder Schwachstelle

Im Zeitalter der Software Defined Vehicles (SDV), in dem Fahrzeuge immer mehr Software enthalten und zentrale Funktionen ähnlich wie bei modernen Smartphones aktualisiert werden können, stellt sich die Frage, wie das Cybersecurity-Management in einem dynamischen Umfeld organisiert werden muss. Jedes Software-Update – unabhängig von seinem Umfang oder Bedeutung – verändert das Fahrzeug und damit auch die bestehenden TARA. Das zuständige Cybersecurity-Team muss daher bewerten, welche Auswirkungen ein geplantes Update auf die Sicherheit des Systems haben könnte.

Ein möglicher Ansatz ist, die geplanten Softwareänderungen mit einer Software Bill of Materials (SBOM) zu verknüpfen und dem TARA-Team sowohl die SBOM als auch eine Beschreibung der funktionalen Änderungen bereitzustellen. Auf dieser Basis kann geprüft werden, ob durch die geplanten Änderungen neue oder erhöhte Risiken entstehen. Werden solche Risiken identifiziert, kann das Projektteam noch vor der Auslieferung des Software-Updates entsprechende Maßnahmen ergreifen.

Auch nach der Auslieferung müssen TARA aktualisiert werden, wenn neue Schwachstellen im Feld entdeckt werden. Dieser Prozess ist ein wesentlicher Bestandteil der Reaktion auf Vorfälle und des Managements von Schwachstellen, wie es die ISO/SAE 21434 fordert.

Dabei handelt es sich jedoch nicht um eine vollständige Neuerstellung der ursprünglichen TARA aus der Konzept- und Entwicklungsphase. Vielmehr müssen die Auswirkungen der neu entdeckten Schwachstellen auf das Item, seine Assets und Bedrohungsszenarien sorgfältig analysiert werden. Auf Basis dieser Schwachstellen-Analyse können Änderungen am Item oder an einzelnen Komponenten erforderlich sein, um die identifizierten Risiken wirksam zu adressieren – beispielsweise durch zusätzliche Cybersecurity-Maßnahmen, Software- oder Firmware-Updates oder durch das Einspielen von Patches und Fixes.

4.3 Detailstufe gemäß den verfügbaren Informationen

Selbst wenn eine TARA einem klar definierten, schrittweisen Ansatz mit einer eindeutigen Methodik folgt, gibt es ein hohes Maß an Freiheit hinsichtlich des Abstraktionsgrads bestimmter Schritte. Wir beobachten immer wieder Diskussionen und Meinungsverschiedenheiten über den Detaillierungsgrad und die daraus resultierende Dauer und den Aufwand eines TARA-Projekts. In diesem Abschnitt erläutern wir drei Abstraktionsebenen der

TARA, die je nach den Anforderungen des Projekts unterschiedliche Durchführungszeiten aufweisen.

Die folgenden Ansätze sind lediglich Vorschläge, die auf unseren bisherigen Erfahrungen beruhen. Die vorgeschlagene Dauer der TARA dient als Faustregel, insbesondere dann, wenn das Cybersecurity-Team noch keine ausreichende Erfahrung mit der Durchführung von TARA hat. Die vorgeschlagene Dauer ist als Größenordnung zu verstehen. Die *3-Tage-TARA* kann bei einigen Projekten in einem Tag durchgeführt werden, bei anderen in fünf oder zehn Tagen. Der *30-Tage-TARA* kann beispielsweise ein *15-Tage-TARA* oder ein *40-Tage-TARA* sein, um ein Beispiel zu nennen. Es ist wichtig zu betonen, dass der Begriff „*Detailstufe*“ nicht mit einer Abnahme der technischen Qualität und Strenge verbunden sein sollte. Das Cybersecurity-Team sollte jedoch in der Lage sein, kritisch über bestimmte Schritte der TARA nachzudenken, die im Rahmen des TARA-Projekts kein besseres Ergebnis liefern, unabhängig davon, wie viel Aufwand in sie investiert wurde. Insbesondere bei größeren TARAs stellen wir fest, dass sehr detaillierte TARAs, z. B. durch die Analyse jeder einzelnen Kommunikationsnachricht an jeder einzelnen Schnittstelle, kein besseres Ergebnis (d. h. bessere Cybersecurity-Maßnahmen oder Ziele) liefern als weniger detaillierte TARAs. Es ist wichtig zu verstehen, dass TARA kein einmaliges Ereignis sein darf, sondern ein fortlaufender Prozess, der in verschiedenen Phasen des Lebenszyklus eines Items durchgeführt werden sollte. Dieser Ansatz ermöglicht notwendige Änderungen und Verbesserungen, wenn sich das Item, seine Betriebsumgebung (Operational Environment) und die Bedrohungslandschaft im Bereich der Cybersecurity weiter verändern. Daher ist es vorteilhafter, einen TARA-Prozess zu haben, der sowohl überschaubar als auch wiederholbar ist und regelmäßige Aktualisierungen ermöglicht, als eine einmalige, zu detaillierte Analyse.

4.3.1 „Die 3-Tage-TARA“ – Initiale TARA

Die erste TARA ganz am Anfang eines Projekts ist eine eher kurze TARA. Nehmen wir an, das Item ist eine ECU für ein Fahrzeug. In der Konzeptphase des Items wird wahrscheinlich die grobe Architektur des Items definiert. Es ist bereits bekannt, welche Funktionen das Steuergerät bereitstellen muss, und es gibt eine Vorstellung von den Kommunikationsschnittstellen, die auf dem Steuergerät vorhanden sind. Handelt es sich bei dem Zielfahrzeug für die Steuergeräte-Applikation um eine neue, in der Entwicklung befindliche Plattform, sind die Anforderungen des OEM an das Steuergerät wahrscheinlich noch nicht vollständig definiert. Das Ziel einer TARA zu diesem Zeitpunkt ist es, die Basis für Cybersecurity-Ziele, Cybersecurity-Aussagen und Cybersecurity-Maßnahmen für hochgradige Risiken zu schaffen. Wenn das Steuergerät beispielsweise eine direkte Verbindung zum Internet haben

soll, wird die TARA wahrscheinlich viel mehr Risiken identifizieren als ein Steuergerät, das keine Internetverbindung hat und nur über eine Kommunikationsschnittstelle zu einem nicht sicherheitsrelevanten CAN-Bus im Fahrzeug verfügt. Eine TARA auf dieser Ebene ist kurz, weil der Entwurf des Items noch nicht abgeschlossen ist und es daher nicht möglich ist, die Bedrohungsszenarien mit einem hohen Maß an technischen Details zu definieren. Das Cybersecurity-Team muss die aktuellen Spezifikationen des Items analysieren und mit den Ingenieuren zusammenarbeiten, um die relevanten Assets zu identifizieren und ihre Cybersecurity-Eigenschaften zu definieren. Die Schritte zur Identifikation und Bewertung von Bedrohungen nehmen nicht so viel Zeit und Mühe in Anspruch wie eine fortgeschrittene TARA. Die anfängliche TARA kann beispielsweise auf einem Katalog von Bedrohungen basieren und den auf Angriffsvektoren basierenden Ansatz für die Bedrohungsbewertung verwenden, der sehr schnell ist, da er auf nur einem Parameter basiert.

4.3.2 „Die 30-Tage-TARA“ – TARA während der Entwicklung und Wiederverwendung

Diese TARA wird während der Entwicklung des Items durchgeführt. In diesem Stadium ist die Betriebsumgebung des Items klar, ebenso wie die Anforderungen an das Item. Ziel der TARA ist die Durchführung einer strengen technischen Analyse zur Ermittlung der Cybersecurity-Risiken unter Berücksichtigung aller technischen Details des Items. Die Ergebnisse der TARA werden wahrscheinlich einen nützlichen Einblick in die technischen Cybersecurity-Maßnahmen geben, die für das Item empfohlen werden, um die Risiken zu mindern. Handelt es sich bei der TARA um eine TARA auf System- oder Fahrzeugebene, liefern die Ergebnisse wahrscheinlich High-Level-Maßnahmen für alle Komponenten des Systems und Cybersecurity-Ziele, die an alle Komponentenentwickler weitergegeben werden müssen. Da die TARA in Übereinstimmung mit dem Entwicklungszeitplan des Items durchgeführt werden muss, muss das Cybersecurity-Team seine technischen Kriterien anwenden und entscheiden, wann es aufhört, wenn eine technische Ebene erreicht ist, die genügend Informationen liefert, die nicht weiter verbessert werden können.

Bei dieser TARA kann es sich auch um ein Wiederverwendungsprojekt (Reuse) handeln. Bei einem Wiederverwendungsprojekt kann eine frühere TARA vorhanden sein, sodass der Aufwand geringer ist als bei einer TARA, die von Grund auf neu erstellt wird. Allerdings müssen alle Unterschiede im Item und seiner Betriebsumgebung sorgfältig analysiert werden, und man darf sich nicht nur auf frühere Ergebnisse verlassen.

Wir geben einige Beispiele für Fragen, die das Cybersecurity-Team bei der Abwägung zwischen Detaillierungsgrad und erforderlichem Aufwand berücksichtigen kann:

- *Ist es möglich, Gruppen von Assets zu erstellen?* Ja, und es sogar sehr sinnvoll. Gut durchdachte Vertrauensgrenzen reduzieren die Komplexität von TARA und erleichtern die Konzentration auf das Wesentliche. Ein typischer Fall für die Gruppierung von Assets

ist die Analyse von Kommunikationsschnittstellen und -protokollen. Anstatt jede einzelne Nachricht als Asset zu analysieren, können sie nach ihrer Funktionalität oder sogar nach ihrer Sicherheitsrelevanz gruppiert werden. Eines der Ziele dieses TARA-Typs ist die Bereitstellung technischer Cybersecurity-Maßnahmen. Die Cybersecurity-Maßnahmen betreffen in der Regel die gesamte Schnittstelle, und daher ist es nicht relevant, genau zu wissen, welche spezifische Nachricht für das hohe Risiko verantwortlich ist (z. B. die Bremsnachricht), sondern überhaupt zu wissen bzw. zu erkennen, dass es z. B. sicherheitsrelevante Nachrichten gibt, die manipuliert werden können. Natürlich kann es Fälle geben, in denen ein technisches Interesse daran besteht, die Details zu verstehen (z. B. die Überlegung, SecOC nur auf bestimmte Nachrichten anzuwenden, um Berechnungen zu sparen). In einem solchen Fall kann das Cybersecurity-Team beschließen, die Gruppierung zu belassen und später nur die relevanten Nachrichten einer tieferen Analyse zu unterziehen oder die Gruppierung überhaupt nicht vorzunehmen.

- *Können die Schadensszenarien¹ gruppiert werden?* Wir empfehlen, die Schadensszenarien so weit wie möglich zu gruppieren. Dies kann viel Aufwand bei der Wirkungsanalyse, einschließlich Kommentaren und Begründungen, für jeden Stakeholder und jede Wirkungskategorie der Schadensszenarien einsparen, ohne dass es zu Einbußen in der TARA-Qualität kommt. Ein wesentliches Kriterium für die Gruppierung von Schadensszenarien ist die sich daraus ergebende nachteilige Auswirkung auf den Verkehrsteilnehmer, insbesondere wenn die gleichen oder vergleichbare Wirkungsketten vom Bedrohungsszenario zum Schadensszenario verlaufen. Gibt es beispielsweise zwei Schadensszenarien, *Name des Fahrers an Unbefugte weitergegeben* und *Adresse des Fahrers an Unbefugte weitergegeben*, können sie zu einem Schadensszenario *Personendaten gestohlen* zusammengefasst werden. Die spezifischen Details gehen in der TARA dabei nicht verloren, da die jeweiligen Bedrohungsszenarien den *Namen des Fahrers* und die *Adresse des Fahrers* enthalten.
- *Sind genügend Bedrohungsszenarien identifiziert?²* Der Schritt der Bedrohungsidentifikation sollte so gründlich wie möglich durchgeführt werden, da er den Kern von TARA darstellt. Wenn die Bedrohungskataloge jedoch erst einmal durchgesehen und viel Zeit in Brainstorming-Sitzungen investiert worden ist, kann es schwierig sein, weitere Bedrohungen zu finden. Wenn die bereits identifizierten Bedrohungsszenarien zu Cybersecurity-Risiken führen, die gemindert/reduziert werden müssen, kann es außerdem ausreichend sein, diese Bedrohungen in der TARA zu belassen und sich auf die Anwendung von Cybersecurity-Maßnahmen auf das Item zu konzentrieren. Da es sich bei der TARA um ein lebendes Dokument handelt, kann sie jederzeit aktualisiert werden, beispielsweise wenn bei weiteren technischen Diskussionen neue Bedrohungen oder neue Schwachstellen festgestellt werden. Auch nach der Anwendung der Cybersecurity-Maßnahmen kann die TARA neu bewertet werden.

¹ Siehe Definition von *Schadensszenario* in Abschn. 6.4.

² Siehe Definition von *Bedrohungsszenario* in Kap. 7.

- Ist das technische Niveau der Angriffspfade ausreichend? Die Angriffspfade müssen genau genug sein, damit das Cybersecurity-Team eine möglichst genaue Bewertung der Angriffsmachbarkeit vornehmen kann. Wenn die erreichte technische Ebene für eine genaue Bewertung der Angriffsmachbarkeit ausreicht, kann es sinnvoll sein, nicht tiefer in die technische Ebene einzusteigen. Wenn beispielsweise der Schritt *Durchführen von Fuzzing auf UDS von DID 0x0 bis DID 0xFFFF auf CAN unter Verwendung von SID 0x2E* eines Angriffspfad ausreicht, um eine Bewertung durchzuführen, können die Zwischenschritte wie *Anschließen eines CAN-Debuggers* oder *Entwickeln eines Fuzzing-Tools* weggelassen werden.

4.3.3 „Die 300-Tage-TARA“ – Die ineffiziente oder aufgeblasene TARA

Eine große TARA kann notwendig sein, wenn man auf einer sehr detaillierten Ebene arbeitet. Zum Beispiel bei der Analyse von Hunderten von Einzelsignalen an mehreren ECUs oder für das gesamte Fahrzeug. Es kann auch vorkommen, dass der insgesamt hohe Aufwand mit dem TARA-Prozess als Ganzem zusammenhängt, jedoch einige Teile deutlich mehr Aufwand verursachen als andere. Betrachten wir zum Beispiel ein Szenario, in dem das Cybersecurity-Team die Aufgabe hat, die Rückverfolgbarkeit jeder Nachricht oder jedes Assets zu den entsprechenden Systemanforderungen zu gewährleisten, indem es ein spezielles Tool einsetzt. In solchen Fällen kann der Aufwand, der in die Rückverfolgbarkeit investiert wird, andere Aspekte des TARA-Prozesses überwiegen.

Aufgrund unserer Erfahrung sind wir der Meinung, dass eine allzu ausführliche TARA in den meisten Fällen nicht notwendig ist. Die bloße Erhöhung des Detaillierungsgrads an einem bestimmten Punkt führt nicht notwendigerweise zu einer Verbesserung des Gesamtergebnisses einer TARA, da eine zu komplexe Struktur mehr Probleme hervorruft als eine schlankere, klarere TARA lösen kann. Es ist wichtig, ein Gleichgewicht zu wahren und sich auf die Aspekte zu konzentrieren, die den größten Einfluss auf das Ergebnis haben. Dieser pragmatische Ansatz gewährleistet, dass die Ressourcen effizient zugewiesen werden und unnötige Anstrengungen vermieden werden, die nicht wesentlich zur Wirksamkeit der TARA beitragen.

Im Wesentlichen geht es darum, ein Gleichgewicht zwischen Gründlichkeit und Zweckmäßigkeit herzustellen. Es ist zwar wichtig, Bedrohungen umfassend zu identifizieren und zu bewerten, aber ebenso wichtig ist es, dafür zu sorgen, dass der Prozess überschaubar und auf die Ressourcen und den Zeitplan des Projekts abgestimmt ist. Zu umfangreiche TARAs können zu einer *Analyse-Paralyse* führen, bei der die schiere Menge an Informationen und die Komplexität des Prozesses den Fortschritt und die Entscheidungsfindung behindern. Darüber hinaus ist es wichtig, sich daran zu erinnern, dass TARA keine einmalige Aktivität ist, sondern ein kontinuierlicher Prozess sein sollte, der während des gesamten Lebenszyklus des Produkts immer wieder überprüft werden sollte. So können Anpassungen und Verfeinerungen vorgenommen werden, wenn sich das Produkt, seine Umgebung

und die Bedrohungslandschaft weiterentwickeln. Daher ist ein überschaubarer und wiederholbarer TARA-Prozess, der regelmäßig aktualisiert wird, vorteilhafter als eine übermäßig umfangreiche einmalige Analyse.

4.4 Übersicht über den TARA-Prozess

Dieses Buch versteht sich als umfassender und praxisnaher Leitfaden zur Durchführung der TARA im automobilen Umfeld. Es basiert auf langjähriger praktischer Erfahrung und orientiert sich konsequent am Standard ISO/SAE 21434. Während wir die Vorgaben des Standards strikt einhalten, gehen wir gezielt auf einzelne Schritte des TARA-Prozesses ein und erläutern das in der ISO/SAE 21434 beschriebene Rahmenwerk im Detail.

Die formalen Schritte der Bedrohungsanalyse und Risikobewertung (auch Methoden genannt) und Arbeitsprodukte gemäß ISO/SAE 21434 sind:

- Asset identification
 - [WP-15-01] Damage scenarios
 - [WP-15-02] Assets with cybersecurity properties
- Threat scenario identification
 - [WP-15-03] Threat scenarios
- Impact rating
 - [WP-15-04] Impact ratings with associated impact categories
- Attack path analysis
 - [WP-15-05] Attack paths
- Attack feasibility rating
 - [WP-15-06] Attack feasibility ratings
- Risk value determination
 - [WP-15-07] Risk values
- Risk treatment decision
 - [WP-15-08] Risk treatment decisions

In Tab. 4.1 fassen wir die TARA-Schritte zusammen, wie sie im Standard ISO/SAE 21434 beschrieben sind, einschließlich der Voraussetzungen, weiterführender unterstützender Informationen und Arbeitsergebnisse gemäß dem Standard.

Wir nähern uns der Bedrohungsanalyse und Risikobewertung auf eine allgemeinere Art und Weise, gehen aber dennoch auf jedes Arbeitsprodukt des Standards ISO/SAE 21434 ein. Wir gliedern die in der ISO/SAE 21434 beschriebenen TARA-Methoden in fünf übergeordnete Schritte: *Scope*, *Assets*, *Bedrohungsszenarien*, *Risikobewertung*, und *Entscheidung*

Tab. 4.1 ISO/SAE 21434 TARA-Schritte einschließlich Voraussetzungen, weiterer unterstützender Informationen und resultierender Arbeitsprodukte

TARA-Schritt	Voraussetzungen	Weitere unterstützende Informationen	Arbeitsprodukte
15.3 Asset identification	Item definition [WP-09-01]	Cybersecurity specifications [WP-10-01]	[WP-15-01] Damage scenarios, [WP-15-02] Assets with cybersecurity properties
15.4 Threat scenario identification	Item definition [WP-09-01]	Cybersecurity specifications [WP-10-01], Damage scenarios [WP-15-01], Assets with cybersecurity properties [WP-15-02]	[WP-15-03] Threat scenarios
15.5 Impact rating	Damage scenarios [WP-15-01]	Item definition [WP-09-01], Assets with cybersecurity properties [WP-15-02]	[WP-15-04] Impact ratings with associated impact categories
15.6 Attack path analysis	Item definition [WP-09-01] or cybersecurity specifications [WP-10-01]	Weaknesses from cybersecurity events [WP-08-04], Threat scenarios [WP-15-03], Weaknesses found during product development [WP-10-05], Architectural design, Previously identified attack paths [WP-15-05], if available, Vulnerability analysis [WP-08-05]	[WP-15-05] Attack paths
15.7 Attack feasibility rating	Attack paths [WP-15-05]	Architectural design, Vulnerability analysis [WP-08-05]	[WP-15-06] Attack feasibility ratings
15.8 Risk value determination	Threat scenarios [WP-15-03], Impact ratings with associated impact categories [WP-15-04], Attack feasibility ratings [WP-15-06]	Keine	[WP-15-07] Risk values
15.9 Risk treatment decision	Item definition [WP-09-01], Threat scenarios [WP-15-03], Risk values [WP-15-07]	Cybersecurity specifications [WP-10-01], Previous risk treatment decisions of the item or component, or of similar items or components, Impact ratings with associated impact categories [WP-15-04], Attack paths [WP-15-05], Attack feasibility ratings [WP-15-06]	[WP-15-08] Risk treatment decisions

über die Risikobehandlung. Die folgenden Kapitel dieses Buches widmen sich jeweils einem dieser fünf Schritte. Der Schritt „Scope“ umfasst alle Informationen, die erforderlich sind, um ein praxisorientiertes TARA-Projekt zu starten – beispielsweise das Verständnis der Item-Definition, die Beschreibung relevanter Annahmen sowie gegebenenfalls die Erstellung eines Angreifer-Modells. Der Schritt „Scope“ ist in der ISO/SAE 21434 in dieser Form nicht explizit enthalten, da die Item-Definition inklusive zugrunde liegender Annahmen als Voraussetzung für den Einstieg in die TARA-spezifischen Kapitel des Standards betrachtet wird. Der generische Prozess und die Zuordnung zu den Arbeitsprodukten des Standards sind in Tab. 4.2 dargestellt.

Der gesamte TARA-Prozess, der in diesem Buch verfolgt wird, ist in Abb. 4.2 dargestellt.

- **Reihenfolge der TARA-Schritte** ISO/SAE 21434 definiert TARA als einen modularen Prozess, bei dem die einzelnen TARA-Methoden in beliebiger Reihenfolge durchge-

Tab. 4.2 Generischer TARA-Prozess und Abbildung auf die Arbeitsprodukte der ISO/SAE 21434

Generischer TARA-Prozess	Vorgabenkonformer Arbeitsnachweis gemäß ISO/SAE 21434
Scope der TARA, einschließlich: • Item-Definition • Betriebsumgebung • Annahmen • Angreifer-Modell	[WP-09-01] Item definition
Assets, einschließlich der Schritte: • Asset-Identifikation • Cybersecurity-Eigenschaften • Schadensszenarien • Bewertung des Schadens	[WP-15-01] Damage scenarios [WP-15-02] Assets with cybersecurity properties [WP-15-04] Impact ratings with associated impact categories
Bedrohungsszenarien, einschließlich der Schritte: • Identifikation von Bedrohungen • Angriffspfade • Bewertung der Angriffsmachbarkeit	[WP-15-03] Threat scenarios [WP-15-05] Attack paths [WP-15-06] Attack feasibility ratings
Risikobewertung	[WP-15-07] Risk values
Entscheidung über die Risikobehandlung, einschließlich der Schritte: • Behandlungsentscheidung • Cybersecurity-Maßnahmen • Cybersecurity-Ziele • Cybersecurity-Aussagen	[WP-15-08] Risk treatment decisions [WP-09-03] Cybersecurity goals [WP-09-04] Cybersecurity claims

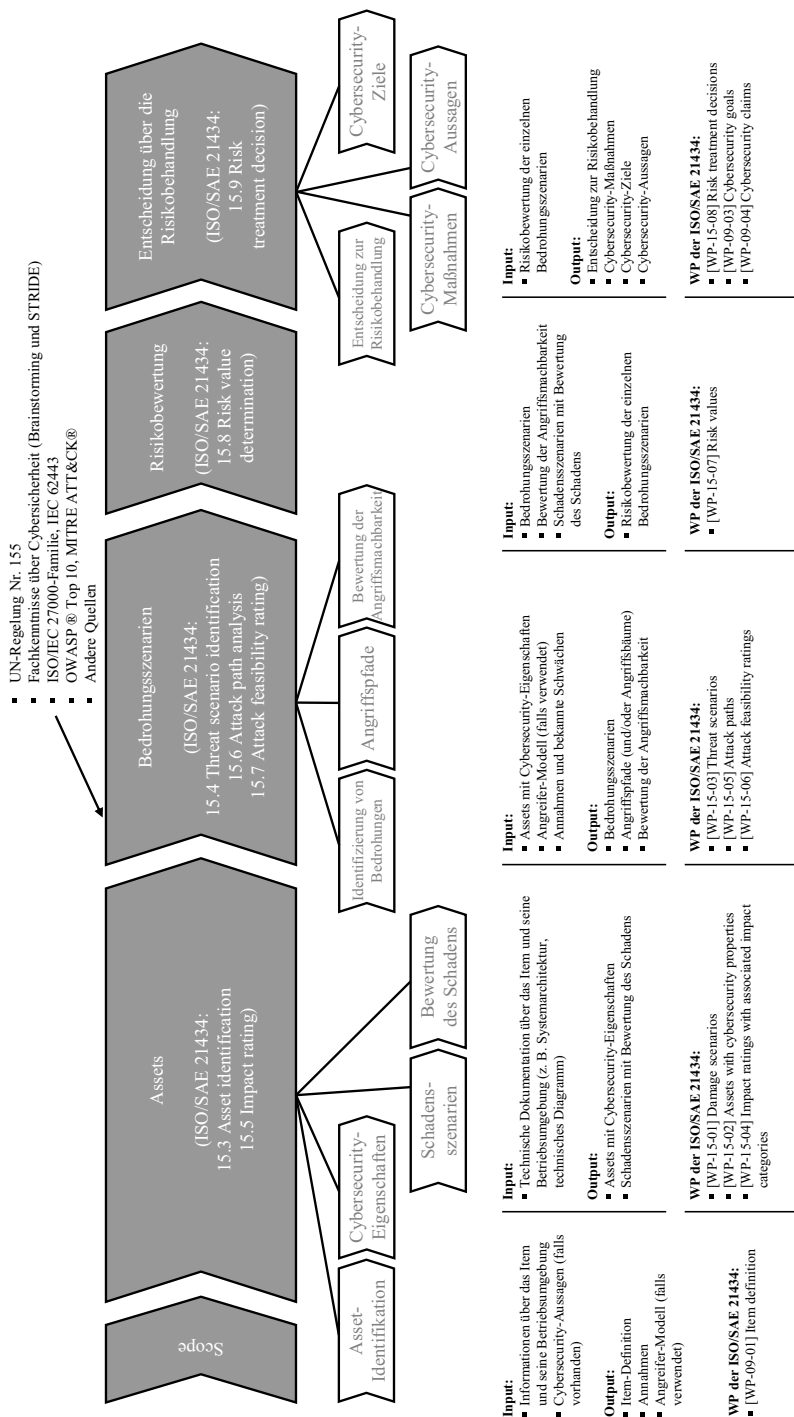


Abb. 4.2 Gesamtprozess der Bedrohungsanalyse und Risikobewertung

führt werden können. Die in Abb. 4.2 dargestellte Reihenfolge folgt einem natürlichen TARA-Prozess, bei dem jeder Schritt die notwendigen Informationen für den nächsten Schritt liefert. Bei bestimmten Projekten kann es jedoch durchaus sinnvoll sein, mit einem anderen Schritt zu starten. Zum Beispiel kann mit der Definition von Schadensszenarien und Bewertung des Schadens begonnen werden, gefolgt von der Identifikation von Bedrohungsszenarien und der anschließenden Identifikation von Assets.

4.5 Tooling

Jede Organisation hat die Freiheit, das Werkzeug zu wählen, das ihren spezifischen Bedürfnissen am besten entspricht. Ein Risikomanagement-Tool kann den Gesamtprozess durch die Bereitstellung einer standardisierten Methodik im gesamten Unternehmen erheblich optimieren. So können beispielsweise Kataloge von Assets, Bedrohungen und Gegenmaßnahmen im Tool gespeichert und im gesamten Unternehmen gemeinsam genutzt werden, was einen einheitlichen Ansatz für das Risikomanagement fördert. Wenn der TARA-Prozess ordnungsgemäß in den Entwicklungsprozess integriert ist, kann das TARA-Tool darüber hinaus die Rückverfolgbarkeit zu den Anforderungen und Spezifikationen für das analysierte System gewährleisten. Diese Integration kann den Prozess rationalisieren und die Verfolgung und Verwaltung von Risiken während des gesamten Produktlebenszyklus erleichtern.

Wir haben mit einer Vielzahl kommerzieller Tools gearbeitet, die ausdrücklich für TARA für OT-Systeme und die Automobilindustrie entwickelt wurden, sowie mit intern entwickelten Tools, basierend auf einer Tabellenkalkulation. Obwohl wir in diesem Buch kein bestimmtes kommerzielles Tool empfehlen möchten, ist es erwähnenswert, dass kommerzielle Tools sehr praktisch sein können und die Gesamteffizienz des TARA-Prozesses erheblich verbessern können. Diese Tools erfordern jedoch einen anfänglichen Aufwand, um ihre Funktionsweise zu verstehen und vor allem, um sie so zu konfigurieren, dass sie den spezifischen Anforderungen des Unternehmens entsprechen. Das Tool sollte genau auf die Bedürfnisse der Experten und die Unternehmensrichtlinien zugeschnitten sein. Andererseits können Tabellenkalkulationstools aufgrund ihrer inhärenten Flexibilität sehr vorteilhaft sein. Sie lassen sich individuell anpassen und auf spezifische Bedürfnisse abstimmen. Tabellenkalkulationen sind weit verbreitet und häufig verständlich, was die Einarbeitung für die Teammitglieder verkürzen hilft. Außerdem lassen sie sich leicht gemeinsam nutzen und aktualisieren, was sie für viele Unternehmen zu einer praktischen Wahl macht.

Es ist wichtig, daran zu denken, dass die Auswahl des Tools nur ein Aspekt des TARA-Prozesses ist. Unabhängig vom verwendeten Tool ist der Schlüssel zu einem effektiven Risikomanagement ein gut definierter Prozess, ein klares Verständnis der Risikotoleranz des Unternehmens und die Verpflichtung zu kontinuierlicher Überwachung und Verbesserung. Das Tool sollte diese Ziele unterstützen, nicht diktieren.

- **Tipp** Für Leser, die noch kein TARA-Tool besitzen, stellen wir eine TARA-Tabellenvorlage zur Verfügung. Der Zugriff auf dieses Zusatzmaterial erfolgt über den zu Beginn dieses Kapitels angegebenen Link.

Literatur

1. ISO/IEC 27001:2022 Information security, cybersecurity and privacy protection – Information security management systems – Requirements. Standard, International Organization for Standardization/International Electrotechnical Commission (2022). <https://www.iso.org/standard/82875.html>
2. ETSI: ETSI TS 102 165-1 V5.2.5 – CYBER; Methods and protocols; Part 1: Method and pro forma for Threat, Vulnerability, Risk Analysis (TVRA). Standard (2022). https://www.etsi.org/deliver/etsi_ts/102100_102199/10216501/05.02.05_60/ts_10216501v050205p.pdf
3. EVITA Project: E-safety vehicle intrusion protected applications (EVITA). <https://www.evita-project.org/>
4. ISO/SAE 21434:2021 Road vehicles – Cybersecurity engineering. Standard, International Organization for Standardization/Society of Automotive Engineers, Geneva, CH (2021). <https://www.iso.org/standard/70918.html>
5. Lautenbach, A., Mafijul Islam, C.: HEAling vulnerabilities to ENhance software security and safety (HEAVENS) – deliverable d2 – security models (2016). https://autosec.se/wp-content/uploads/2018/03/HEAVENS_D2_v2.0.pdf
6. Puder, A., Henle, J., Sax, E.: Threat assessment and risk analysis (TARA) for interoperable medical devices in the operating room inspired by the automotive industry. Healthcare (Basel), Band: 11 (6) (2023). <https://www.ncbi.nlm.nih.gov/pmc/articles/PMC10048460/>
7. VerSprite: PASTA Threat Modeling: The Process for Attack Simulation and Threat Analysis (eBook) (2022). <https://versprite.com/cybersecurity-listings/offsec/pasta-threat-modeling/>

Definieren des Scopes eines TARA-Projekts

5

Zusammenfassung

Mit der Definition des Scopes legen wir das Fundament für ein TARA-Projekt. Der Scope legt fest, wie die TARA durchgeführt wird. Neben der Beschreibung der Item-Definition und der Betriebsumgebung werden in diesem Schritt auch technische Annahmen für die TARA beschrieben, z. B. zu bestehenden Cybersecurity-Maßnahmen, vorhandenen Schwachstellen, Cybersecurity-Ziele oder Cybersecurity-Aussagen. Etwaige Besonderheiten des TARA-Projekts werden im Scope beschrieben. Darüber hinaus beschreiben wir das Angreifer-Modell sowie dessen Fähigkeiten. Im Rahmen des Scopes definieren wir auch die Schadenskategorien für die Schadensszenarien. In diesem Kapitel stellen wir auch die praktischen Fallstudien vor, die im Laufe des Buches präsentiert werden.

In diesem Kapitel geht es um den allerersten Schritt einer TARA. Wir definieren den Scope eines TARA-Projekts, d. h. die Grenzen des zu analysierenden Systems, einschließlich aller wesentlichen Informationen für die Durchführung einer TARA, wie z. B. Annahmen, Details aus bestehenden Projekten oder bekannte Schwachstellen, zusammen mit der Definition des Angreifer-Modells. Ein Kernelement des Scopes einer TARA ist die Beschreibung des zu analysierenden Systems. Die Beschreibung des zu analysierenden Systems entspricht der *Item-Definition*, oder Komponentenspezifikation, gemäß ISO/SAE 21434. In anderen Rahmenwerken für das Risikomanagement wird das zu analysierende System gewöhnlich als *Target of Evaluation (ToE)* oder *System under Consideration (SUC)* bezeichnet. Die Festlegung des Scopes ist eine kritische Aufgabe, die nicht unterschätzt werden sollte, da sie die Grundlage für den gesamten TARA-Prozess bildet. Die Festlegung eines klaren Scopes kann im späteren Verlauf des Projekts Zeit und Aufwand sparen, da dieser eine klare Richtung für die TARA-Analyse vorgibt. Aus unserer Erfahrung mit zahlreichen TARA-Projekten wissen wir, dass Fehler regelmäßig auf unzureichend definierte Scopes zurückzuführen sind.

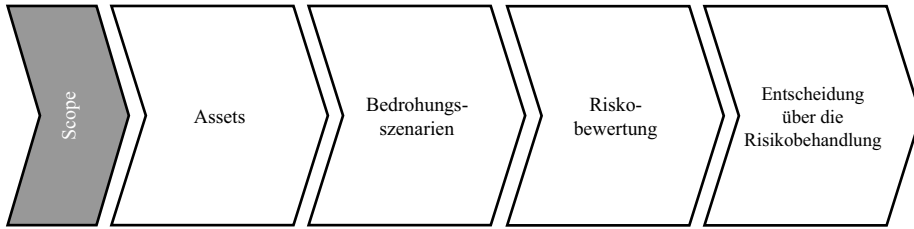


Abb. 5.1 Der Scope-Schritt im gesamten TARA-Prozess

Diese führen später oft zu grundlegenden Änderungen in späteren Phasen des Projekts. In Abb. 5.1 ist der Scope in Bezug auf den gesamten TARA-Prozess dargestellt.

In diesem Kapitel befassen wir uns mit den Schlüsselaspekten der Scope-Definition und betonen dabei die Bedeutung einer klaren Beschreibung und des Verständnisses der Betriebsumgebung, in der das zu analysierende System arbeitet. Wir erläutern die Bedeutung von Annahmen und heben die Vorteile einer expliziten Definition von Out-of-Scope-Elementen hervor, die wesentlich zur Optimierung der nachfolgenden Analyse beitragen können. Wir betrachten die Definition des Scopes auch aus einer praktischen Perspektive und untersuchen typische Szenarien für verschiedene Systemtypen. Wir untersuchen Überlegungen zum Scope bei eingebetteten Geräten sowie bei nicht eingebetteten Systemen, wie z. B. IT-Infrastrukturen und Fertigungsumgebungen. Durch die Vermittlung praktischer Einblicke und Anleitungen sollen die Leser mit dem notwendigen Wissen ausgestattet werden, um den Scope für eine Vielzahl von TARA-Projekten effektiv zu definieren. Zur praktischen Veranschaulichung der besprochenen Konzepte werden in diesem Kapitel auch die praktischen Fallstudien vorgestellt, die im Laufe des Buches präsentiert werden. Diese Fallstudien dienen als wertvolle Illustrationen, die die in den einzelnen Kapiteln behandelten Prinzipien und Techniken auf reale Szenarien anwenden und so das Verständnis und die Fähigkeit des Lesers zur effektiven Anwendung des TARA-Prozesses verbessern.

Item-Definition nach ISO/SAE 21434 Im Kontext von ISO/SAE 21434 ist ein *Item* ein System, das eine Funktion auf Fahrzeugebene implementiert und aus *Komponenten* besteht. TARA kann sowohl auf der Item-Ebene als auch auf der Komponenten-Ebene durchgeführt werden. Es ist wichtig zu beachten, dass die explizite Identifikation des Items oder der Komponente nicht als Teil des TARA-Prozesses beschrieben wird, der in Kap. 15 des Standards beschrieben ist. Stattdessen dient sie als Voraussetzung für den TARA-Prozess selbst. Im Falle eines Items wird seine Definition als separater Schritt im Standard mit der Bezeichnung *Item-Definition* behandelt und als das Arbeitsprodukt [WP-09-01] *Item Definition* bezeichnet. Eine Komponente wird mit Cybersecurity-Spezifikationen definiert. Wir verfolgen einen umfassenderen Ansatz, indem wir die Item-Definition als integralen Bestandteil des TARA-Prozesses einbeziehen. Auf diese Weise wollen wir einen umfassenderen und anpassungsfähigeren TARA-Prozess vorstellen, der auf verschiedene Systeme angewendet

werden kann. Es ist erwähnenswert, dass in vielen auf ISO/SAE 21434 basierenden TARA-Projekten bestimmte wichtige Aspekte nicht konsequent betont werden, wie z. B. eine klare Beschreibung der Betriebsumgebung, in dem das Item betrieben wird. Darüber hinaus müssen kritische Annahmen, wie z. B. die Frage, ob Cybersecurity-Maßnahmen als Prämisse einbezogen werden sollen, als Teil des Scopes gründlich diskutiert werden. Wir sind uns dieser Lücken bewusst und versuchen, diese Aspekte im Rahmen des TARA-Prozesses zu behandeln, um eine umfassende Analyse zu gewährleisten.

- **Die Durchführung von TARA auf Item-Ebene oder auf Komponenten-Ebene?**
Eine TARA kann gemäß ISO/SAE 21434 auf *Item-Ebene* und auf *Komponenten-Ebene* durchgeführt werden. Der Prozess der Durchführung einer TARA für ein Item und für eine Komponente ist bis auf minimale Unterschiede identisch. Aus diesem Grund behandeln wir in diesem Buch Item und Komponente nicht als getrennte Systeme. Auch wenn es minimale Unterschiede zwischen den beiden TARA-Ansätzen gibt, wie z.B. das Fehlen einer expliziten *Item-Definition* für Komponenten, achten wir darauf, diese Unterschiede bei Bedarf ausdrücklich zu erwähnen. Ansonsten verwenden wir den Begriff *Item* im gesamten Buch in einem allgemeinen Sinne, der sowohl Items als auch Komponenten umfasst.

Erforderliche Eingabe für dieses Kapitel:

- Informationen über das Item und seine Betriebsumgebung
- Cybersecurity-Aussagen (falls vorhanden)

Das Ergebnis dieses Kapitels ist der Scope von TARA, einschließlich:

- Item-Definition
- Annahmen
- Angreifer-Modell (falls verwendet)

5.1 Wie man den Scope definiert

Zu Beginn eines TARA-Projekts kann das gesamte Zielsystem oder die *Item-Definition* bereits klar vorliegen. Es ist jedoch ebenso möglich, dass die Item-Definition entweder noch nicht verfügbar oder nicht klar genug beschrieben ist. Um TARA so effizient wie möglich durchzuführen, müssen alle Funktionen und Komponenten des Gesamtsystems sorgfältig analysiert und beschrieben werden. Auch Teile, die außerhalb des Items liegen, d. h. mit der Betriebsumgebung zusammenhängen und im Kontext der Cybersecurity relevant sein können, sollten analysiert werden. Gemäß den Anforderungen [RQ-09-01] und [RQ-09-02] der ISO/SAE 21434 muss die Item-Definition folgende Dinge umfassen:

- *Itemgrenze:* Das Item muss klar von seiner Betriebsumgebung abgegrenzt werden, einschließlich der Schnittstellen zu anderen Items innerhalb des Fahrzeugs und zu E/E-Systemen außerhalb des Fahrzeugs.
- *Funktionen des Items:* Beschreibung des beabsichtigten Verhaltens des Items während der Lebenszyklusphasen, z. B. Produktentwicklung und -erprobung, Produktion und Post-Produktion, sowie der durch das Item realisierten Fahrzeugfunktionen.
- *Vorläufige Architektur:* Eine Beschreibung, die die internen Komponenten des Items und ihre Verbindungen sowie alle externen Schnittstellen des Items umfassen kann.
- *Cybersecurity-relevante Informationen:* Beschreibung aller für die Cybersecurity relevanten Informationen über die Betriebsumgebung, wie z. B. die Interaktion der Betriebsumgebung mit dem Item, die bei der Bedrohungsmodellierung hilfreich sein kann. Annahmen über die Cybersecurity können ebenfalls einbezogen werden.

Wir empfehlen, mit einem Gesamtdiagramm des von der TARA zu analysierenden Items zu beginnen, das dessen Interaktion mit der übrigen Umgebung zeigt. Bei eingebetteten Geräten, wie z. B. einem Steuergerät, kann dies ein E/E-Diagramm sein, das die High-Level-Schnittstellen des Items, High-Level-Informationen über wichtige Funktionsblöcke oder Software-Komponenten zeigt. Wir empfehlen außerdem, dass der Cybersecurity-Analyst oder das Cybersecurity-Team, das die TARA durchführt, zu diesem Zeitpunkt eine ausreichende technische Dokumentation erhält, um allgemeine Kenntnisse über das zu analysierende Item zu haben. Das Cybersecurity-Team und die mit dem Item befassten Fachleute (z. B. Systemarchitekten, Softwareexperten, Projektmanager und Cybersecurity-Ingenieure) müssen die Grenzen des Items ermitteln. Wir haben eine Gruppe von Elementen identifiziert, die unserer Erfahrung nach Teil jeder TARA Item-Definition sein sollten: Item und Im Scope¹, Betriebsumgebung, Out-of-Scope-Systeme oder -Komponenten, Schadenskategorien, Angreifer-Modell und Annahmen. Wir beschreiben sie im Folgenden im Detail.

Item und Im Scope Die Item-Definition, insbesondere die klare Beschreibung ihrer Grenzen und Funktionen, muss für die Ausführung von TARA verfügbar sein. Aus Dokumentationsgründen und zum besseren Verständnis des gesamten TARA-Projektteams halten wir es für sinnvoll, Elemente explizit zu erwähnen, z. B. Details zu Funktionalitäten, Details zu E/E-Systemen, Details zu externen Systemen, die im Scope der TARA liegen müssen.

Betriebsumgebung Ein für eine TARA zu analysierendes System, wie z. B. ein Bremssteuergerät, wird in der Regel nicht als eigenständiges, vom Rest des Fahrzeugs abgekoppeltes Gerät eingesetzt. Dies mag für sehr einfache Geräte, wie z. B. kleine Sensoren, zutreffen, aber in der Regel interagiert das zu analysierende Item mit vielen anderen Geräten, die mit

¹ Mit dem Element „Im Scope“ möchten wir das Cybersecurity-Team dazu anregen, sich intensiver damit auseinanderzusetzen, welche Aspekte zusätzlich in den Geltungsbereich (Scope) aufgenommen werden sollten. Aus unserer Erfahrung erfordert dieser Schritt besondere Sorgfalt und eine genaue Abwägung.

diesem verbunden sind, mit anderen Worten, mit dessen Betriebsumgebung (Operational Environment). Aus diesem Grund ist es von größter Bedeutung, die Betriebsumgebung zu beschreiben und ihre operativen Funktionen zum Zeitpunkt der Durchführung von TARA zu kennen. So kann beispielsweise ein Bremssteuergerät so ausgelegt werden, dass es sicher arbeitet, indem die wichtigsten CAN-Signale zum Rest des Fahrzeugs vor Manipulationen geschützt werden. Im Zusammenhang mit dem autonomen Fahren könnte es aus Sicht der Cybersecurity möglich sein, gültige, korrekt signierte Signale an das Bremssteuergerät zu senden, indem das Steuergerät für autonomes Fahren kompromittiert wird. In diesem vereinfachten Beispiel können die Signale eines Steuergeräts für autonomes Fahren in den Scope der TARA des Bremssteuergeräts fallen, auch wenn das Steuergerät für autonomes Fahren selbst nicht in den Scope fällt. Wie in ISO/SAE 21434 beschrieben, kann die Beschreibung der Betriebsumgebung und ihrer Wechselwirkungen mit dem Item die Identifikation und Analyse relevanter Bedrohungsszenarien und Angriffspfade beeinflussen [6]. Im Beispiel des Bremssteuergeräts kann die Betrachtung der Bedrohung durch die Imitation eines Steuergeräts für autonomes Fahren zu einer Empfehlung führen, die gegenseitige Authentifizierung von Steuergeräten als Cybersecurity-Maßnahme am Ende der TARA zu implementieren. Angenommen, es gibt ein neues Projekt für dieselbe Bremssteuergeräte-Plattform und das Bremssteuergerät wird nicht in einem autonom fahrenden Fahrzeug verwendet. Im Fall der Analyse der Wiederverwendung von Bremssteuergeräten hat sich die Betriebsumgebung erheblich verändert und muss sorgfältig analysiert werden. Die gegenseitige Authentifizierungskontrolle ist in diesem neuen Kontext des Bremssteuergeräts möglicherweise nicht mehr erforderlich. Darüber hinaus kann die neue Betriebsumgebung verschiedene Funktionen einführen, die im vorherigen Projekt nicht vorhanden waren (z. B. neue Debugging-Funktionen).

Out-of-Scope Es ist wichtig, Teile des analysierten Items, Funktionen oder Elemente, die sich auf die Betriebsumgebung beziehen und aus verschiedenen Gründen außerhalb des Scopes des TARA-Projekts liegen, explizit zu beschreiben. So können beispielsweise Hardware-Debugging-Schnittstellen wie JTAG in einem frühen Stadium der Entwicklung des Items vorhanden sein. Wenn jedoch sichergestellt ist, dass diese Schnittstellen für die Serienproduktion entfernt werden, können sie aus dem Scope der TARA herausgenommen werden. Da es sich bei einer TARA um ein lebendiges Dokument handelt, das wahrscheinlich während des gesamten Lebenszyklus des Items überprüft wird, ist es wichtig, die Komponenten, die nicht in den Scope fallen, zu beschreiben, um spätere Fragen zu vermeiden, warum sie nicht einbezogen wurden. Dies gilt insbesondere im Falle der Wiederverwendung, wenn eine bestehende TARA des wiederzuverwendenden Items als Grundlage für eine neue Analyse verwendet wird. Darüber hinaus kann eine gut dokumentierte Beschreibung von Out-of-Scope-Merkmalen im Falle einer Bewertung oder eines Audits unangenehme Situationen vermeiden. Wir betonen, dass gute Dokumentation eine wesentliche Anforderung an eine TARA ist.

Schadenskategorien Die Schadenskategorien werden auf die Schadensszenarien angewandt, um deren Auswirkungen zu bewerten. Auch wenn die Identifikation der Schadensszenarien ein Schritt ist, der später in der TARA im Zusammenhang mit der Identifikation der Assets erfolgt, können wir die Schadenskategorien als Teil der Definition des Scopes festlegen. Die Definition der Schadenskategorien führt zu einem tieferen Verständnis der Ziele der TARA und kann bei der Definition des Scopes selbst helfen. ISO/SAE 21434 verlangt beispielsweise, dass Schadensszenarien für die Schadenskategorien Safety, Finanzen (Financial), Betrieb (Operational) und Privatsphäre (Privacy) im Hinblick auf mögliche negative Folgen für den Verkehrsteilnehmer bewertet werden. Andere Kategorien, auch für andere Interessengruppen als den Verkehrsteilnehmer, sind jedoch zulässig. Beispielsweise kann eine TARA für das Steuergerät eines Fahrzeugs aus der Perspektive des Verkehrsteilnehmers durchgeführt werden, um den Standard zu erfüllen, aber auch aus der Perspektive des Zulieferers, was Kategorien wie den Verlust von geistigem Eigentum, finanziellen Verlust oder Imageverlust betrifft. Am Beispiel des geistigen Eigentums können Teile der Daten oder der kompilierten Software im Steuergerät anders bewertet werden, z. B. durch die Durchsetzung der Vertraulichkeit als Cybersecurity-Eigenschaft, als wenn die TARA nur aus der Perspektive des Verkehrsteilnehmers durchgeführt würde. Der Verkehrsteilnehmer ist überhaupt nicht betroffen, wenn das geistige Eigentum des Lieferanten kompromittiert wird.

Angreifer-Modell Die Definition des Angreifer-Modells hilft dabei, die geeigneten Bedrohungen zu identifizieren und ihre Durchführbarkeit später im TARA-Prozess zu bewerten. Wir erörtern dieses Thema ausführlich in Abschn. 5.6 dieses Kapitels.

Annahmen Annahmen jeglicher Art gehören in den ersten Schritt von TARA, da sie das Fundament bilden, auf dem der gesamte TARA-Prozess aufgebaut ist. Wir erörtern dieses Thema ausführlich in Abschn. 5.2 dieses Kapitels.

Eine Gesamtübersicht über den Scope einer TARA, wie er in diesem Buch vorgeschlagen wird, ist in Abb. 5.2 dargestellt. Ein Beispiel für die in der Scope-Definition definierten Elemente findet sich in Tab. 5.1. Bei der Durchführung einer TARA empfiehlt es sich, die Tab. 5.1 direkt als Vorlage für den Scope zu verwenden. Hilfreich ist auch ein Diagramm, in dem der Scope auf einen Blick zu erkennen ist (z. B. durch Markierung des Blocks des Items und seiner Schnittstellen mit grüner Farbe und Out-of-Scope-Elemente mit roter Farbe).

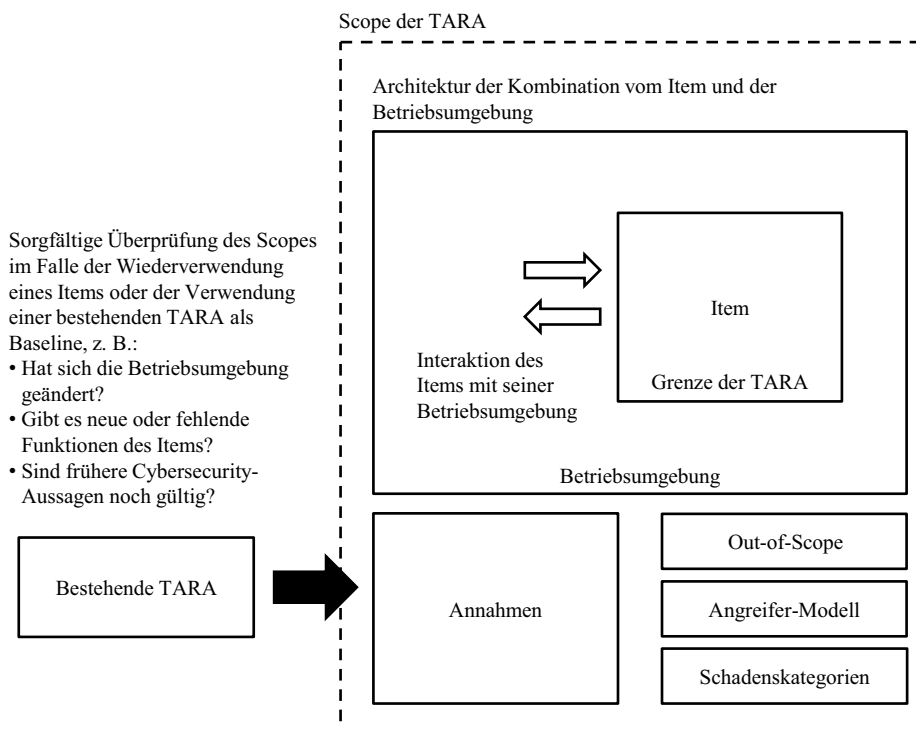


Abb. 5.2 Scope einer TARA

5.2 Annahmen

Annahmen sind ein wesentlicher Bestandteil des Scope – nicht nur, weil sie grundlegende Aspekte der TARA definieren, sondern auch, weil sie das gesamte Dokumentationsniveau des TARA-Projekts verbessern. Aus unserer Sicht gibt es grundsätzlich keinen „schlechten“ Ansatz für die Durchführung einer TARA – mit Ausnahme einer schlechten oder fehlenden Dokumentation. Annahmen ermöglichen es den Beteiligten, ihre Erwartungen an den TARA-Prozess und seine Ergebnisse aufeinander abzustimmen. Indem man die Annahmen klar formuliert, kann man die Erwartungen der Beteiligten steuern und spätere Missverständnisse oder Konflikte vermeiden.

Annahmen können unterschiedlichster Art sein. Zum Beispiel kann sich das Item in der Entwicklung befinden und der aktuelle Entwicklungsstand ist, dass ein anderes Kommunikationsprotokoll für die Serienproduktion integriert wird. In diesem Fall kann davon ausgegangen werden, nur das endgültige Kommunikationsprotokoll in der TARA zu berücksichtigen. Auch bei den Assets können Annahmen getroffen werden. So kann es sein, dass das zu analysierende Steuergerät in anderen Projekten personenbezogene und personenbe-

Tab. 5.1 Beispiel für eine Tabelle, die die relevanten Elemente der Scope-Definition einer TARA enthält

Allgemeine Beschreibung	
Item:	Beschreibung des Items (oder der Komponente im Falle einer Komponente TARA)
Im Scope:	Details über einen Teil des Items oder der Komponente, die es wert sind, als explizit im Scope erwähnt zu werden
Betriebs- umgebung:	Beschreibung der Betriebsumgebung des Items
Out-of- Scope:	Beispiele könnten Debugging-Schnittstellen sein, die in der Produktion entfernt werden, oder handelsübliche Komponenten, die mit dem Item im Scope interagieren
Schadens- kategorien:	Obligatorisch für Verkehrsteilnehmer: Safety, Finanzen, Betrieb, Privatsphäre Optional für OEM/Lieferanten: Geistiges Eigentum, Finanzen, Image
Angreifer-Modell	
Bedrohungs- stufe:	Angreifer haben eine Bedrohungsstufe <i>Schwerwiegend</i>
Im Scope:	Falls erforderlich, können hier Änderungen am generischen Angreifer-Modell beschrieben werden, indem der Scope explizit erweitert wird
Out-of- Scope:	Das Angreifer-Modell kann für ein bestimmtes Projekt maßgeschneidert werden, z. B. durch Entfernen einiger Bedrohungsakteure
Annahmen	
Beschreibung der Annahme Nummer 1	
Beschreibung der Annahme Nummer 2	

ziehbare Daten speichert, aber nicht für das spezielle Projekt, das für die TARA verwendet wird. Auch Annahmen zum Ablauf des TARA-Prozesses können dokumentiert werden. Beispielsweise kann festgehalten werden, dass die TARA von einem externen Dienstleister durchgeführt wird, der – wie in unserem Prozess dargestellt – alle Schritte der TARA übernimmt, mit Ausnahme der Entscheidung über die Risikobehandlung. Ein weiteres Beispiel für eine Annahme auf Prozessebene kann die Begrenzung der angewandten Cybersecurity-Eigenschaften sein. Die TARA kann mithilfe einer Vorlage realisiert werden, in der sechs Cybersecurity-Eigenschaften wie Vertraulichkeit, Integrität, Verfügbarkeit, Authentizität, Nichtabstreitbarkeit und Rechenschaftspflicht enthalten sind. Für ein bestimmtes TARA-Projekt kann es ausreichend sein, nur drei dieser Eigenschaften zu berücksichtigen, z. B. Vertraulichkeit, Integrität und Verfügbarkeit, und die anderen Cybersecurity-Eigenschaften leer zu lassen.

Cybersecurity-Aussagen Ein wichtiges Element im Bereich der Annahmen sind die Cybersecurity-Aussagen (Cybersecurity-Claims). Cybersecurity-Aussagen sind in ISO/SAE 21434 als Aussagen über Risiken definiert und werden angegeben, wenn die Entscheidung über die Risikobehandlung bei einem hohen Risiko darin besteht, das Risiko zu akzeptieren (oder zu behalten) oder zu teilen. Wenn es eine bereits bestehende TARA oder eine Risikobewertung mit Cybersecurity-Aussagen gibt, müssen diese bei der aktuellen TARA berücksichtigt werden. Ein wichtiger Nebeneffekt der Berücksichtigung von Cybersecurity-Aussagen ist die Vermeidung der Analyse von Kombinationen aus Assets und Bedrohungsszenarien, bei denen Cybersecurity-Aussagen bereits zur Anwendung kommen.

5.2.1 Wichtige Annahme: Sollen bestehende oder geplante Cybersecurity-Maßnahmen für das Item in der TARA berücksichtigt werden?

Es gibt zwei grundlegende Ansätze für die Cybersecurity-Maßnahmen eines Items, die in der Regel mit dem Entwicklungsstadium zusammenhängen, in dem die TARA durchgeführt wird. Zum einen die TARA, die zu Beginn des Entwicklungsprozesses eines Produkts durchgeführt wird. Zu diesem Zeitpunkt können die allgemeinen Cybersecurity-Ziele definiert sein, aber es sind oft nur wenige oder gar keine konkreten, technischen Cybersecurity-Maßnahmen geplant. Zum anderen gibt es die TARA, die in einem fortgeschrittenen Stadium der Produktentwicklung durchgeführt wird, und zumindest einige Cybersecurity-Maßnahmen wurden bereits in den Systementwurf integriert. Wir betonen die Wichtigkeit dieser Annahme, weil wir bei fast jedem TARA-Projekt eine Diskussion darüber beobachten konnten, ob Cybersecurity-Maßnahmen eingebaut werden sollen oder nicht.

Es sind keine Cybersecurity-Maßnahmen geplant In den frühen Phasen der Produktentwicklung sind in der Regel nur wenige oder gar keine konkreten Cybersecurity-Maßnahmen geplant. Tatsächlich besteht einer der Hauptgründe für die Durchführung einer TARA darin, die Cybersecurity-Anforderungen, die Architektur, die Cybersecurity-Maßnahmen und den Gesamtbedarf auf der Grundlage der identifizierten Risiken zu definieren. Aus diesem Grund empfehlen wir, zunächst davon auszugehen, dass keine technischen Cybersecurity-Maßnahmen im System implementiert sind. Auf diese Weise wird eine unbeeinflusste Identifikation der Bedrohungen ermöglicht, bei der potenzielle Angriffsszenarien nicht vorschnell durch angenommene Schutzmechanismen ausgeblendet werden. Dieser Ansatz gilt auch für eine TARA, die in einem fortgeschrittenen Stadium durchgeführt wird, jedoch zu Zwecken der nachträglichen Dokumentation (z. B. weil zuvor keine TARA durchgeführt wurde).

Es sind Cybersecurity-Maßnahmen geplant Wenn es sich um Cybersecurity-Maßnahmen handelt, die bereits für das Item oder die Komponente geplant sind, können sie bei

der Durchführung der TARA berücksichtigt werden. Der Vorteil der Berücksichtigung von Cybersecurity-Maßnahmen besteht darin, dass viele Bedrohungen bereits durch die Cybersecurity-Maßnahmen gemildert werden, sodass der Umfang dieser TARAs tendenziell geringer ist als derjenige ohne Cybersecurity-Maßnahmen. Wir empfehlen jedoch, bei diesem Ansatz alle möglichen Bedrohungen zu berücksichtigen, um das Risiko zu minimieren, dass Bedrohungen übersehen werden. Auch für Dokumentationszwecke, z. B. bei der Bewertung von Vorschriften wie der UN-Regelung Nr. 155, kann es sinnvoll sein, die vom Katalog dieser Regelung abgedeckten Bedrohungen ausdrücklich zu erwähnen.

5.3 Scope für Automotive Embedded Devices

Die elektrische und elektronische (E/E-)Architektur eines Fahrzeugs definiert die elektrische Versorgung der verschiedenen Steuergeräte im Fahrzeug sowie deren elektronische Integration untereinander. Eine typische E/E-Architektur eines Fahrzeugs beschreibt, wie und über welche Kommunikationsbusse die Steuergeräte miteinander verbunden sind. Die Steuergeräte sind typischerweise in Domänen aufgeteilt, zum Beispiel in eine Body-Controller-Domäne, eine Powertrain-Domäne und eine Infotainment-Domäne. Das gängigste Kommunikationsprotokoll, das seit mehreren Jahrzehnten in Fahrzeugen verwendet wird, ist das Controller Area Network (CAN), heute in seiner modernen Variante CAN Flexible Data-Rate (CAN FD). Local Interconnect Network (LIN) und FlexRay sind ebenfalls gängige Kommunikationsprotokolle. Für Anwendungen mit hohen Datenraten, z. B. für Infotainmentsysteme oder fortschrittliche bzw. autonome Fahrsysteme, sind MOST und Ethernet ebenfalls gängige Protokolle. Für die Analyse von TARA werden typischerweise zwei verschiedene Ansätze betrachtet: a) TARA für eigenständige Steuergeräte, b) TARA auf Fahrzeugebene. Steuergeräte werden von Zulieferern hergestellt und normalerweise als eigenständiges Produkt entwickelt, zumindest für denselben OEM oder dieselbe Fahrzeugplattform. Dies bedeutet, dass Fahrzeugplattformen desselben OEMs typischerweise viele Steuergeräte gemeinsam haben, aber auch mit Fahrzeugen anderer OEMs. Der Zulieferer hat in diesem Fall ein Interesse an der Durchführung einer TARA, entweder für das Steuergerät als plattformunabhängige Baseline oder für das Steuergerät, das für ein bestimmtes Projekt eingesetzt wird. Andererseits ist der OEM, der die Gesamtverantwortung für das Fahrzeug trägt, auch an einer Analyse der Risiken für die gesamte Architektur interessiert.

5.3.1 TARA für eigenständige Steuergeräte oder Funktionssysteme

Der typische Scope für ein einzelnes Steuergerät oder eine Kombination von Steuergeräten, die ein geschlossenes Funktionssystem bilden, ist die Analyse der Kommunikationsschnittstellen zum Steuergerät und seiner internen Architektur. Kommunikationsschnittstellen können als Angriffsvektoren genutzt werden, entweder für Bedrohungen, die aus

dem fahrzeuginternen Netzwerk oder aus Netzwerken außerhalb des Fahrzeugs stammen. Interne Komponenten des Steuergeräts gelten ebenfalls als Angriffsvektoren oder zumindest als verwundbare Elemente, wie etwa ein ungeschützter Speicherblock oder ein Debugging-Anschluss. Bei einfachen Steuergeräten können sich die Kommunikationsschnittstellen auf einen einzigen CAN-Bus und On-Board-Debugging-Schnittstellen wie JTAG beschränken. Beispiele für einfache Steuergeräte sind Tür- oder Schiebedachsteuerungen, Sitzheizungssteuerungen, Regensensoren oder Steuergeräte, die kleinere Sensoren wie Temperatur und Druck steuern. Bei komplexeren Steuergeräten, wie z. B. einer Telematikeinheit, können die Kommunikationsschnittstellen mehrere CAN-, CAN FD- und FlexRay-Schnittstellen zum Fahrzeug, Verbindungen zwischen Steuergeräten und externe Schnittstellen zu Bluetooth, WLAN, USB oder fahrzeuginternen Technologien wie Apple CarPlay oder Android Auto umfassen. Der Schwerpunkt des Scopes liegt zwar in der Regel auf den physischen Grenzen des Items, es ist jedoch zulässig, in den Scope Details über die oberen Schichten und Dienste aufzunehmen, die über die Schnittstellen kommunizieren. Diese Informationen sind für die Analyse des Assets nützlich. Beispiele für typische Dienste der oberen Schicht können die weit verbreiteten Unified Diagnostic Services (UDS) sein, die über CAN-, FlexRay-, LIN- oder MOST-Busse laufen, proprietäre Diagnoseprotokolle oder sogar moderne Ansätze wie die Scalable Service-Oriented Middleware over IP (SOME/IP), die eine dienstorientierte Architektur ähnlich wie Internet-Webdienste ermöglicht.

5.3.1.1 Scope einer *generischen TARA* und verteilte Verantwortung zwischen OEM und Zulieferern

Insbesondere bei einzelnen Steuergeräten oder Systemen, die von Zulieferern geliefert werden, wird häufig diskutiert, die Verantwortung für die Durchführung einer TARA zwischen OEM und Zulieferer (oder zwischen Zulieferern) aufzuteilen. Die Durchführung einer TARA ist eine mühsame Aufgabe, die ein tiefes technisches Wissen über das Item und seine Betriebsumgebung erfordert. Zulieferer können es als praktisch erachten, eine *generische TARA* durchzuführen, die z. B. auf mehrere Projekte für denselben Produkttyp oder dieselbe Produktfamilie aufgeteilt werden kann. Diese Art von generischer TARA entspricht sicherlich nicht den Erwartungen an eine TARA gemäß ISO/SAE 21434, da sie die Betriebsumgebung und die spezifischen technischen Details eines Projekts nicht berücksichtigen kann. Es kann jedoch eine generische TARA erstellt werden, die Annahmen über die Betriebsumgebung trifft. Der OEM kann später die generische TARA vom Lieferanten übernehmen und die TARA mit den Details der Betriebsumgebung und des Systems, in dem das Item eingesetzt werden soll, ergänzen. Mit anderen Worten: Der OEM bräuchte dann nur noch die Lücke zwischen der generischen TARA, die das Item in einer fiktiven Betriebsumgebung betrachtet, und dem Item, wie es im aktuellen Projekt des OEMs eingesetzt wird, zu schließen. Auch hier kann es zu Fehlern kommen, wenn falsche Annahmen getroffen werden, inwieweit der Zulieferer bestimmte Faktoren schon berücksichtigt hat oder auf welche Weise dies geschehen ist.

Der Verband der Automobilindustrie (VDA) schlägt eine Empfehlung für ein Cybersecurity-Interface-Agreement (CSIA) [1], in dem verschiedene Arten von TARA zwischen dem OEM und dem Zulieferer (Tier 1) vorgeschlagen werden. Der OEM ist für die Durchführung der TARA vollständig verantwortlich (d. h. TARA gemäß ISO/SAE 21434), während der Zulieferer die Tätigkeit lediglich unterstützt. Die Interface-Vereinbarung sieht jedoch vor, dass für die gelieferte Komponente, Software oder Hardware eine Out-of-Context- bzw. Komponenten -TARA durch den Lieferanten (Tier 1) erstellt wird, um die Cybersecurity-Ziele und -Anforderungen des OEM zu verifizieren.

5.3.2 TARA auf Fahrzeugebene (E/E-Architektur)

Der Scope einer TARA auf Fahrzeugebene (auch *System-Level-TARA* oder *E/E-Architecture-Level-TARA* genannt) folgt grundsätzlich demselben Prinzip wie bei einem einzelnen Gerät, d. h. alle potenziellen Angriffsvektoren sind von Interesse. Allerdings sind bei der Festlegung der Systemgrenzen – also des „Items“ – zwei zentrale Aspekte zu beachten. Erstens sind Bedrohungen, die von ungeschützten internen Komponenten (z. B. internen Steuergeräten) ausgehen, typischerweise im Scope enthalten. Die TARA beschränkt sich jedoch auf deren Kommunikation – die internen Komponenten selbst werden als „Black Boxes“ behandelt, d. h. sie werden nicht weiter im Detail analysiert. Zweitens ist die Kommunikation mit der Außenwelt typischerweise Teil des Scopes, da sie einen der kritischsten Angriffsvektoren und damit interessantesten Aspekt einer solchen TARA darstellt. Allerdings beschränkt sich der Scope auf die konkreten Kommunikationsdaten, also die Protokolle und Schnittstellen zur E/E-Architektur – nicht jedoch auf die ursprüngliche Quelle eines Angriffs, wie z. B. ein kompromittierter Backend-Server oder ein infiziertes Mobiltelefon. Es ist zu beachten, dass bösartige Nachrichten, die infolge manipulierter interner Komponenten oder kompromittierter externer Systeme im Fahrzeugnetzwerk auftauchen und Fahrzeug-Assets bedrohen, im Scope berücksichtigt werden müssen. Die TARA auf Fahrzeugebene unterscheidet jedoch nicht, auf welche Weise ein Angreifer z. B. Zugriff auf einen Backend-Server erlangt hat – ob über einen *Bad USB* oder durch Root-Zugriff. Das Ziel der TARA auf Fahrzeugebene ist es, Cybersecurity-Ziele für diese externen Systeme abzuleiten, um identifizierte Risiken auf Fahrzeugebene zu mitigieren.

Typische Elemente, die im Scope einer modernen E/E-Architektur liegen können, sind beispielsweise:

- Vollständige fahrzeuginterne E/E-Architektur, die mit allen Fahrzeugdomänen kommuniziert
- Fahrzeuginterne Kommunikationsarchitektur, -protokolle und -dienste
- Sensoren und Aktoren
- Mobiltelefonanwendungen (OEM oder Drittanbieter)
- Mobiltelefonplattformen wie Apple CarPlay oder Android Auto

- OEM, Zulieferer oder Fernbedienungsdienste von Dritten
- Standortdienste (GNSS)
- Mobilfunk-, WLAN- und Bluetooth-Kommunikation
- eCall und Concierge-Dienste
- Mikrofone
- Over-the-Air-Software-Updates und Anwendungen von Drittanbietern
- Schlüsselloser Zugang und Schlüsselanhänger
- Werkstatt-Diagnosewerkzeuge und Fehlerbehebungswerkzeuge
- OBD-II

5.4 Scope für IT-/OT-Systeme für Fahrzeug-Backend-Architekturen

Ein modernes vernetztes Auto kann mit einem Mobiltelefon auf Rädern verglichen werden [5]. Tatsächlich verfügt eine moderne Head-Unit eines vernetzten Fahrzeugs über mindestens die gleichen Fähigkeiten wie ein modernes Mobiltelefon, wie z.B. eine oder mehrere eSIM-Schnittstellen für die Mobilfunkkommunikation, WLAN-Fähigkeiten, leistungsstarke Rechenkapazitäten, die in der Lage sind, Linux-Betriebssysteme auszuführen und große Datenmengen zu verarbeiten, z. B. zur Nutzung von Echtzeit-Navigationsdiensten. Ein modernes Fahrzeug kann direkt mit Mobiltelefonen über Bluetooth oder WLAN kommunizieren und darüber hinaus mit entfernten Diensten, die von Mobiltelefonanwendungen genutzt werden. So kann eine Anwendung beispielsweise den Standort des Fahrzeugs abfragen, die Türen ver- oder entriegeln, technische Informationen wie den Ladezustand der Batterie liefern und sogar Adressen an das Navigationssystem senden. In naher Zukunft wird auch die sogenannte Fahrzeug-zu-Alles-Kommunikation (V2X-Kommunikation) Teil des vernetzten Autos sein. Die V2X-Technologie ermöglicht es dem Auto z. B. mit anderen Fahrzeugen zu interagieren, um beispielsweise Fahrzeugposition und Geschwindigkeit auszutauschen und so Kollisionen zu vermeiden. All diese hochgradig vernetzten Funktionen beruhen auf einem komplexen Ökosystem von Akteuren, die wir bei der Durchführung einer TARA auf der Backend-Ebene des Fahrzeugs sorgfältig analysieren müssen.

- **Was wollen wir mit einer TARA auf System-/Fahrzeugebene erreichen?** Der Hauptgrund für die Implementierung von TARA auf Systemebene, d.h. auf der Kommunikationsebene zwischen Fahrzeug und Backend, besteht darin, die Risiken des gesamten Systems zu verstehen und *Cybersecurity-Ziele* für die Elemente abzuleiten, aus denen dieses System besteht. Auf Architektur- bzw. Systemebene wird ein Element im Wesentlichen durch seine Schnittstellen und Kommunikationspfade nach außen charakterisiert. Es wird dabei gewissermaßen wie eine Black Box betrachtet, bei der vor allem die extern sichtbaren Schnittstellen im Fokus stehen. So können beispielsweise der Kommunikationskanal zwischen einem Fahrzeug und einem Mobiltelefon und die ausgetausch-

ten Daten unterschiedliche Assets sein, die den beiden Elementen (Mobiltelefon und Fahrzeug) gehören. In einer TARA auf dieser Ebene betrachten wir beispielsweise nicht die Elektronik des Mobiltelefons. Wenn ein daraus resultierendes Cybersecurity-Ziel der TARA darin besteht, persönliche Daten, die das Mobiltelefon vom Fahrzeug empfängt, auf dem Weg zur Anwendung und zum Backend-Server vor unbefugtem Zugriff zu schützen, kann es im Scope einer spezifischen TARA für das Mobiltelefon liegen, die internen Cybersecurity-Risiken des Mobiltelefons zu analysieren, um dieses Ziel zu erreichen. Beim vernetzten Fahrzeug können bestimmte besonders relevante interne Komponenten – also zentrale Steuergeräte (ECUs) wie die Head-Unit – weiterhin als Bestandteil der betrachteten Systemkomponenten in der TARA berücksichtigt werden. Dabei werden sie jedoch als Black Boxes behandelt.

5.5 Scope für Produktionsanlagen

In diesem Buch betrachten wir die Lieferkette als Teil eines IT-/OT-Systems und wenden dabei dieselben Prinzipien an wie bei einer TARA für Fahrzeuge. Industrie 4.0 transformiert klassische, unverbundene Produktionsanlagen in ein hochautomatisiertes und stark vernetztes Ökosystem. Viele heutige und zukünftige Produktionsanlagen sind vernetzt und greifen auf Cloud-Dienste wie Amazon[®] Web Services oder Microsoft[®] Azure zu. Hochentwickelte Technologien wie künstliche Intelligenz (KI) in der Fertigung sind keine Science Fiction mehr; tatsächlich wird erwartet, dass der Markt für KI in der Fertigung in den nächsten Jahren auf 16,3 Mrd. US\$ anwachsen wird [2]. Gleichzeitig verfolgen wir in diesem Buch einen generischen und ganzheitlichen Ansatz für den TARA-Prozess, um die Anforderungen der UN-Regelung Nr. 155 sowie der ISO/SAE 21434 zu erfüllen. Die UN-Regelung Nr. 155 verpflichtet OEMs, die Fähigkeiten ihres CSMS in allen Phasen des Produktlebenszyklus nachzuweisen, d. h. in der Entwicklungs-, Produktions- und Post-Produktionsphase. Der Standard ISO/SAE 21434, der auf den Betrieb eines CSMS zur Einhaltung der UN-Regelung Nr. 155 abzielt, verlangt über Anforderung [RQ-12-02] die Erstellung eines Produktionskontrollplans. Dieser soll sicherstellen, dass die Cybersecurity-Anforderungen, die nach Abschluss der Entwicklung gelten, auf das betreffende Item oder die Komponente angewendet werden – und dass während der Produktion keine neuen Schwachstellen eingeführt werden.

Der Produktionskontrollplan umfasst die Schritte, die für die Anwendung der Anforderungen an die Post-Produktion erforderlich sind, die verwendeten Produktionswerkzeuge und -geräte, Cybersecurity-Maßnahmen zur Verhinderung unbefugter Änderungen während der Produktion sowie Validierungsmethoden zur Bestätigung der Einhaltung der Anforderungen an die Post-Produktion [6]. Herkömmliche Ansätze für das Risikomanagement in Produktionsanlagen orientieren sich in der Regel an der internationalen Standardreihe für OT-Systeme IEC 62443 und an der bekannten Reihe internationaler Standards für Informationssicherheit, der ISO/IEC 27000-Familie.

5.6 Definition des Angreifer-Modells

Es gibt eine Reihe guter Gründe, im Rahmen einer TARA ein Angreifer-Modell zu verwenden. Einer der zentralen Gründe für die Modellierung des Angreifers im Rahmen einer TARA ist, dass er dem gesamten Team, einschließlich Management und technischen Experten, hilft, die Gesamtziele des TARA-Projekts besser zu verstehen. Zudem ermöglicht die Definition eines Angreifer-Modells eine gezielte Eingrenzung von Bedrohungen auf Basis spezifischer Merkmale des angenommenen Angreifers. In komplexen Systemen mit Items, die sich aus mehreren Geräten zusammensetzen, komplexen Mikrocontrollern, die viele Arten von sensiblen Assets verwalten, und starken Cybersecurity-Zielen, wie dem Schutz persönlicher Daten, ist das Konzept der Bedrohungsbegrenzung möglicherweise gar nicht sinnvoll. In diesen Fällen sollten idealerweise so viele Bedrohungen wie möglich berücksichtigt werden, unabhängig vom Angreifertyp. In anderen Fällen hingegen, etwa bei weniger komplexen Systemen, kann eine Einschränkung sinnvoll sein. Beispielsweise bei einem kleinen Gerät, das nur wenige nicht-sicherheitsrelevante Signale verarbeitet, mit nur einem einzigen CAN-Interface, das nicht Teil des Safety-CAN ist, und bei dem das einzige Cybersecurity-Ziel darin besteht, die Signale vor Manipulationen zu schützen. Hier kann es hilfreich sein, den Angreifer so zu modellieren, dass z. B. Bedrohungen der Vertraulichkeit gezielt nicht berücksichtigt werden.

Darüber hinaus ist die Dokumentation des Angreifer-Modells auch im Hinblick auf zukünftige Analysen – etwa zur Wiederverwendung – von Bedeutung. Für das Cybersecurity-Team ist es wichtig nachvollziehen zu können, auf welcher Grundlage bestimmte Bedrohungen berücksichtigt oder ausgeschlossen wurden, und welches grundsätzliche Sicherheitsverständnis der jeweiligen TARA zugrunde lag. Liegt beispielsweise keine Dokumentation des Angreifer-Modells vor und die TARA lässt alle Bedrohungen durch bestimmte Angreifertypen aus, könnte ein Auditor infrage stellen, ob die TARA korrekt durchgeführt wurde oder ob die Bedrohungen schlicht vergessen wurden.

- **Angreifer-Modelle sind nicht Teil der ISO/SAE 21434** Der Standard ISO/SAE 21434 sieht kein Angreifer-Modell vor und stellt deshalb keine Anforderungen an ein solches Modell. Es wird lediglich implizit berücksichtigt – durch die Identifikation von Bedrohungsszenarien, bei der unterschiedliche Methoden zum Einsatz kommen können. Es ist vollkommen in Ordnung, diesen Abschnitt zu überspringen und das Angreifer-Modell nicht in ein TARA-Projekt aufzunehmen. Die Definition des Angreifers bietet jedoch einige Vorteile. So fällt es insbesondere E/E- und Software-Experten, die den TARA-Prozess begleiten, leichter, Bedrohungen zu verstehen, wenn sie sich konkrete menschliche Akteure wie Skript-Kiddies, Fahrzeugtuner, Diebe oder Terroristen vorstellen. Dies ist vor allem in Gesprächen mit Management-Teams hilfreich, da abstrakte Risiken durch konkrete Angreiferbilder greifbarer werden. Dabei folgen wir jedoch keinem angreiferzentrierten Modell. Wir beschränken uns darauf, ein Angreifer-Modell zu defi-

nieren und ihm Fähigkeiten zuzuordnen, die uns später bei der Identifikation von Bedrohungen helfen werden (vgl. Kapitel *Focusing on Attackers* S.40, in [9]). Für die Modellierung des Angreifers orientieren wir uns hier an der in ETSI TVRA [3] beschriebenen Methode – einem in der ISO/SAE 21434 ebenfalls genannten Ansatz zur Bedrohungsmodellierung. Dabei nehmen wir gezielte Anpassungen vor, um die Methode mit ISO/SAE 21434 kompatibel zu machen und sie im weiteren Verlauf gezielt für die Bedrohungsauswahl innerhalb der TARA nutzen zu können.

5.6.1 Wer sind die Angreifer?

Bevor wir in die formale Analyse des Bedrohungsakteurs für die Zwecke von TARA einsteigen, beschreiben wir, wer die Angreifer eines vernetzten Fahrzeugs oder einer IT-/OT-Infrastruktur tatsächlich sein können. Wir definieren die folgenden typischen Angreifer und verwenden sie für unseren Ansatz zur Angreifer-Modellierung.

Skript-Kiddie Der Begriff „Skript-Kiddie“ wird in der Cybersecurity-Community verwendet, um einen nicht professionellen Angreifer zu beschreiben, der eine Software aus dem Internet herunterlädt und sie einfach ausführt, um zu sehen, was passiert. Der Angreifer ist wie ein Kind, das einfach nur Dinge ausprobieren will, ohne zu verstehen, was es tut. Der Angreifer verfügt über keine tiefgreifenden technischen Kenntnisse, die verwendeten Tools sind in der Regel gut bekannt und im Internet leicht zu finden [8]. Die Hauptmotivation ist Neugierde oder ein kleiner finanzieller Gewinn (z. B. um eine geschützte Funktion im Auto zu aktivieren).

Tuner Einer der innerhalb der Automobilwelt wohl bekanntesten Angreifer ist der Tuner. Hot Rods zum Beispiel sind getunte Autos aus der frühen Zeit der Automobile. Bei den Tunern kann es sich um Hobbyisten handeln, die versuchen, das Aussehen und die Leistung ihrer Autos zu verbessern, oder um professionelle Teams, die solche Änderungen gegen Geld vornehmen. Seit der Zunahme von Elektronik und Software in Fahrzeugen hat sich der Tuner von einem Mechaniker zu einem Hacker gewandelt. Der Tuner muss nicht unbedingt über tiefgreifende Kenntnisse in der Informatik verfügen. Tuner verstehen möglicherweise nur die Kommunikationsprotokolle von Fahrzeugen besonders gut und kennen die Grundlagen der Diagnose über UDS. Aber Tuner verlassen sich noch immer stark auf Tools, die frei im Internet oder auf dem Schwarzmarkt zu finden sind.

Datensammler Daten zählen heute zu den wichtigsten und wertvollsten Assets in einer zunehmend vernetzten Welt. Tatsächlich waren zuletzt rund 40 % aller gemeldeten Cybersecurity-Vorfälle mit Daten- oder Datenschutzverletzungen verbunden [11]. Vom geistigen Eigentum – etwa Teilen des Quellcodes einer ECU-Software – bis hin zu personen-

bezogenen Daten von Fahrzeughaltern oder Fahrzeugnutzern: Nahezu jede Art von Daten kann Ziel eines Diebstahls sein. Dabei ist es schwer, den Typ eines „Datenräubers“ zu verallgemeinern, da sowohl die Art der gestohlenen Daten als auch die dahinterstehende Motivation stark variieren können. Kriminelle mit kurzfristigen Gewinnabsichten könnten beispielsweise an privaten Informationen interessiert sein – etwa an den gefahrenen Routen der letzten Jahre – um diese im Internet zu veröffentlichen und Fahrer zu erpressen. Professionellere Angreifer hingegen könnten sich auf geschäftsbezogene Daten konzentrieren, etwa Verkaufszahlen, Kundendaten oder Versandinformationen, um finanzielle Vorteile zu erlangen [5]. Aus diesem Grund haben wir uns entschieden, den Bedrohungsakteur in diesem Beispiel als opportunistischen Hacker zu definieren, dessen Ziel allein der finanzielle Gewinn ist – etwa durch den Verkauf gestohlener Daten auf illegalen Plattformen wie dem Darknet.

Einbrecher Autodiebstahl und Einbrüche in Fahrzeuge sind so alt wie die Autos selbst. Mit modernen Technologien zum Entriegeln von Türen und Starten von Motoren, wie z. B. schlüssellosen Fernbedienungssystemen, sind Autodiebstahl und Einbrüche auch zu einem Problem der Cybersecurity geworden. Laut [11] sind sie die zweithäufigste Ursache aller öffentlich gemeldeten Cybersecurity-Vorfälle im Automobilbereich und machen 27,9 % der jüngsten Vorfälle aus.

Haktivisten Haktivisten zählen in den letzten Jahren zu den auffälligsten und zugleich umstrittensten Akteuren im Bereich der IT-Sicherheit [4]. Ihr Ziel ist es, auf eine bestimmte – meist politische – Sache aufmerksam zu machen. Oft verfügen sie über sehr fähige Experten, die gezielt technische Mittel einsetzen, um Aufmerksamkeit und Wirkung zu erzeugen. Ein weiteres Beispiel für gezielte Sabotage ist der Einsatz von Angreifern durch konkurrierende Unternehmen: Diese könnten Forschungsteams beauftragen und gezielt dazu anleiten, durch sogenannte White-Hat-Angriffe oder Penetrationstests die Fahrzeuge oder Steuergeräte eines Wettbewerbers zu analysieren – mit dem Ziel, Schwachstellen publik zu machen und so dem Ruf des Konkurrenten zu schaden.

Motivierter White-Hat-Hacker Dieser Angreifer hat zwar keine böswilligen Absichten, aber der motivierte White-Hat-Hacker kann dem Ruf von Fahrzeugherstellern oder Zulieferern erheblichen Schaden zufügen. Es handelt sich um hoch motivierte Experten, z. B. Universitätsforscher, die Angriffe als Teil ihrer Forschungsarbeit designen und durchführen. Arbeiten werden in der Regel publiziert und häufig auch auf großen Cybersecurity-Konferenzen wie der DEFCON oder BlackHat präsentiert. Es kann sich auch um IT-Sicherheitsexperten handeln, die ihren Bekanntheitsgrad auf dem Cybersecurity-Markt erhöhen wollen.

Angestellte oder ehemalige Angestellte Insider sind ein wichtiger Bedrohungsakteur in der IT-Cybersecurity und natürlich auch in der Automobilbranche. Der Insider ist ein Angrei-

fer, der gegen ein ihm bekanntes Unternehmen arbeitet und Zugang zu bzw. Zugriff auf streng vertraulichen Informationen hat, wie z. B. Konstruktionsdaten eines Steuergeräts oder sogar Credentials für kritische Dienste. Der Insider kann durch Geld, Ideologie, Rache oder Zwang motiviert sein [5].

Auftragshacker Hacking-as-a-Service ist eine weitere in letzter Zeit zu beobachtende Hacking-Methode. Auftragshacker sind Unternehmen, die aus verschiedenen Gründen offensive Cybersecurity-Kapazitäten bereitstellen, z. B. zur Erforschung und Ausnutzung von Schwachstellen, zur Entwicklung von Malware, zur technischen Steuerung und Kontrolle, zum Betriebsmanagement oder zur Schulung und Unterstützung [4].

Cyberkrimineller/Terrorist Während der Begriff „Cyberkriminelle“ auf eine Vielzahl von Bedrohungsakteuren, wie z. B. Tuer, zutreffen kann, konzentrieren wir uns in dieser Kategorie auf hochqualifizierte Hacking-Teams, die zumeist aus dem Bereich der organisierten Kriminalität stammen und sehr kontrolliert arbeiten. Terroristen oder Cyberterroristen haben die Zerstörung von Eigentum, den Verlust von Menschenleben und die Verbreitung von Terror zum Ziel [5].

State-Sponsored Actor Diese Angreifer arbeiten in hochqualifizierten Teams, verfügen über enorme Ressourcen und werden entweder direkt von einem Staat kontrolliert oder sind durch diesen beauftragt. Staaten können verschiedene Motive für die Durchführung von Cyberangriffen haben, z. B. nachrichtendienstliche Tätigkeiten und Spionage oder kriegsmotivierte Sabotage der Infrastruktur eines anderen Staates [5] im Rahmen einer hybriden Kriegsführung. Advanced Persistent Threats (APT) sind ein Beispiel für staatlich gesponserte Bedrohungen.

5.6.2 Angriffsmodellierungsansatz nach ETSI TVRA

ETSI Threat, Vulnerability, and Risk Analysis (TVRA) [3] ist eine umfassende und bekannte Methode zur Bedrohungsanalyse und Risikobewertung. Ursprünglich wurde sie auf Telekommunikationssysteme angewandt. Vor ISO/SAE 21434 war die TVRA-Methode in der Automobilindustrie weit verbreitet. HEAVENS beispielsweise enthält mehrere Verweise und Vergleiche zu TVRA in [7]. Wir folgen nicht der vollständigen Bedrohungsmodellierungsmethodik von TVRA, sondern befassen uns in diesem Kapitel nur mit der Definition des Angreifer-Modells. Aufgrund der breiten Akzeptanz in der Branche nutzen wir das Angreifer-Modellierungskonzept von TVRA. TVRA führt das Konzept des *Angreifers* (Threat Agent) für die Angreifer-Modellierung ein. Ein Angreifer ist eine Entität, die in der Lage ist, Assets negativ zu beeinflussen oder zu gefährden. Jedem Angreifer ist eine *Bedrohungsstufe* zugeordnet. Die Bedrohungsstufe ist ein interessantes, von TVRA eingeführtes Konzept, das die Fähigkeit und Motivation eines Angreifers, ein Asset anzugreifen, kombiniert.

Tab. 5.2 enthält die Motivationsstufen (Motivation Levels), wie in TVRA beschrieben. In Tab. 5.3 beschreiben wir die Fähigkeitsstufen (Capability Levels) gemäß TVRA, und wir modifizieren die Angriffspotenzialzuordnung, um die von ISO/SAE 21434 geforderten Angriffspotenzialwerte abzudecken. An dieser Stelle ist es wichtig, sich daran zu erinnern, dass das Angriffspotenzial eigentlich die Fähigkeiten beschreibt, die ein Angreifer haben muss, um den Angriffspfad für ein bestimmtes Asset in dem analysierten Kontext auszuführen. Die Zuordnung in Tab. 5.3 gibt die Fähigkeiten an, die die aufgeführten Bedrohungsakteure erreichen können. Das bedeutet zum Beispiel, dass ein Skript-Kiddie nicht mehr Wissen erlangen kann als eine nicht fachkundige Person (falls doch, ist es kein Skript-Kiddie mehr), oder dass es keine vertraulichen Informationen über das Zielsystem erhalten kann. Wir konzentrieren uns auf den Wert der Bedrohungsstufe, um unseren Angreifer zu modellieren, und verwenden das Modell in den folgenden Schritten des TARA-Prozesses.

Tab. 5.4 beschreibt die endgültige Zuordnung zwischen der Motivation und den Fähigkeiten des Bedrohungsakteurs gemäß TVRA. Die Beschreibung der Fähigkeiten des Bedrohungsakteurs in TVRA ist unserer Meinung nach im automobilen Kontext immer noch schwierig anzuwenden, da die Beschreibung der Fähigkeiten eher subjektiv ist und bei der praktischen Umsetzung von TARA wahrscheinlich zu Diskussionen führen wird. Wir schlagen in Tab. 5.5 und 5.6 vor, diese Lücke zu schließen, indem wir die Klassifizierung der Bedrohungsstufen aus TVRA auf verschiedene Bedrohungsakteure in der Automobilindustrie abbilden.

Tab. 5.2 Motivationsstufen nach TVRA

Motivationsstufen	Beschreibung
Sehr gering (gleichgültig)	Das System wird vom Angreifer als wenig bis gar nicht wertvoll eingeschätzt; daher ist es sehr unwahrscheinlich, dass ein Angriff auf das System erfolgt
Gering (neugierig)	Das System hat für den Angreifer nur einen minimalen Wert. Ein Angriff könnte aus Neugier oder opportunistischer Motivation erfolgen. Abschreckungen außerhalb des Systems können ausreichen, um den Angreifer von einem Angriff abzuhalten (z. B. mögliche Konsequenzen bei Rückverfolgbarkeit)
Mittel (interessiert)	Das System hat für den Angreifer einen mittleren Wert. Der Angreifer wird regelmäßig versuchen, das System anzugreifen. Es ist zudem unwahrscheinlich, dass Abschreckungen außerhalb des Systems den Angriff verhindern können
Hoch (entschlossen)	Das System hat für den Angreifer einen hohen Wert. Der Angreifer wird das System beharrlich und regelmäßig angreifen. Es ist sehr unwahrscheinlich, dass Abschreckungen außerhalb des Systems ihn davon abhalten können
Sehr hoch (fokussiert)	Der Angreifer verfolgt primär das Ziel, das System anzugreifen

Tab.5.3 Fähigkeitsstufen aus TVRA mit Angriffspotenzialzuordnung angepasst an ISO/SAE 21434

Fähigkeitsstufen	Beschreibung
Sehr gering	Der Angreifer verfügt über nahezu keine Fähigkeiten oder Ressourcen Beispielhafte Zuordnung zum Angriffspotenzial (Fachwissen, Wissen über das Item, Ausrüstung): Laie, Öffentlich, Standard
Gering	Der Angreifer verfügt über sehr begrenzte Fähigkeiten und Ressourcen Beispielhafte Zuordnung zum Angriffspotenzial (Fachwissen, Wissen über das Item, Ausrüstung): Kompetent/Experte, Öffentlich, Standard
Begrenzt	Der Angreifer verfügt über mäßige Fähigkeiten und Ressourcen Beispielhafte Zuordnung zum Angriffspotenzial (Fachwissen, Wissen über das Item, Ausrüstung): Laie/Experte, Eingeschränkt, Standard/Spezialisiert
Erheblich	Der Angreifer ist kompetent und verfügt über erhebliche Ressourcen Beispielhafte Zuordnung zum Angriffspotenzial (Fachwissen, Wissen über das Item, Ausrüstung): Experte, Eingeschränkt/Vertraulich, Spezialisiert/Maßgeschneidert
Erheblich hoch	Der Angreifer ist äußerst fähig und sehr gut ausgestattet Beispielhafte Zuordnung zum Angriffspotenzial (Fachwissen, Wissen über das Item, Ausrüstung): Mehrfach-Experten, Streng vertraulich, Mehrfach maßgeschneidert

Tab.5.4 Bedrohungsgrad als Kombination aus der Motivation und der Fähigkeit nach TVRA

Motivation	Fähigkeit				
	Sehr gering	Gering	Begrenzt	Erheblich	Erheblich hoch
Sehr gering (gleichgültig)	Vernachlässigbar	Vernachlässigbar	Niedrig	Niedrig	Niedrig
Gering (neugierig)	Vernachlässigbar	Vernachlässigbar	Niedrig	Niedrig	Moderat
Mittel (interessiert)	Vernachlässigbar	Niedrig	Moderat	Schwerwiegend	Schwerwiegend
Hoch (entschlossen)	Niedrig	Niedrig	Moderat	Schwerwiegend	Kritisch
Sehr hoch (fokussiert)	Niedrig	Moderat	Schwerwiegend	Kritisch	Kritisch

Wir ordnen den Bedrohungsakteur und das Zielsystem einem bestimmten Angriffspotenzial zu, das der Akteur realistischerweise erreichen kann. Diese Zuordnung wird später im Prozess zur Auswahl relevanter Bedrohungen verwendet. Die Liste der Bedrohungsakteure ist nicht erschöpfend oder endgültig, kann aber als Referenz verwendet werden.

Cybersecurity ist ein äußerst dynamisches Feld – einerseits, weil sich die Technologien stetig weiterentwickeln, und andererseits, weil menschliche Kreativität und Intelligenz eine zentrale Triebkraft in diesem Bereich darstellen. Der ENISA Threat Landscape Report zeigt eindrücklich, wie sich verschiedene Bedrohungsakteure von Jahr zu Jahr verändern oder neu auftauchen [4].

Zielsystem Neben der Beschreibung des Bedrohungsakteurs, seiner Motivation und Fähigkeiten berücksichtigen wir auch die Klassifizierung des Zielsystems – also die Frage, ob sich der Angreifer vorrangig auf das Fahrzeug selbst oder auf Backend-Server (einschließlich interner IT- und OT-Systeme) konzentriert. Die explizite Einbeziehung des Zielsystems kann besonders dann hilfreich sein, wenn an verschiedenen TARA-Projekten gearbeitet wird – etwa für unterschiedliche Systeme – und dabei eine gemeinsame Vorlage oder Datenbasis für Bedrohungsmodelle genutzt werden soll. Die Fähigkeiten eines Bedrohungsakteurs können sich je nach Zielsystem deutlich unterscheiden – insbesondere zwischen eingebetteten Systemen (Embedded Systems) und klassischen IT-/OT-Umgebungen. Aus unserer Sicht ist eine Trennung nach Zielsystemen sinnvoll, um eine bessere Klassifikation verschiedener technologischer Plattformen zu ermöglichen – etwa zur Unterscheidung zwischen einem leistungsstarken Backend-Server-Cluster und einer einzelnen Telematik-Einheit im Fahrzeug.

Angesichts der zunehmenden Konnektivität und Komplexität moderner Fahrzeuge erscheint uns eine stärkere Harmonisierung zwischen Fahrzeug- und Backend-Systemen im Rahmen der TARA sinnvoll. Tatsächlich enthält die UN-Regelung Nr. 155 bereits eine Liste von Bedrohungen, die sich explizit gegen Backend-Systeme richten – obwohl sich der Hauptfokus der Regelung auf das Fahrzeug selbst richtet [10]. Für die in diesem Buch vorgestellten Fallstudien verwenden wir dasselbe in diesem Kapitel beschriebene Angreifer-Modell – unabhängig davon, welches Zielsystem betrachtet wird.

5.6.3 Beziehung zwischen Angreifer-Modell und Bedrohungen

Die Angleichung der Angriffspotenzialwerte der ISO/SAE 21434 an die Bedrohungsstufen, wie sie in Tab. 5.5 und 5.6 dargestellt sind, bietet erhebliche Vorteile. Dieser Ansatz ermöglicht es, die Bewertung der Angriffsmachbarkeit entlang konkreter Angriffspfade in Bezug auf spezifische Assets zu bewerten. Dabei können wir den Fokus auf solche Angriffspfade legen, die ein höheres Angriffspotenzial und eine stärkere Motivation erfordern, als im Angreifer-Modell für die jeweilige Bedrohungsstufe definiert wurde. Beispielsweise können – wenn unser Angreifer-Modell ein maximales Bedrohungsniveau von *Schwerwiegend* vorsieht – alle Angriffspfade aus der Analyse ausgeschlossen werden, die ein Angriffspotenzial voraussetzen, das einer Kombination aus *Mehrfach-Experten*, *Vertraulich*, *Maßgeschneidert* sowie einem hochmotivierten Angreifer entspricht.

Tab. 5.5 Zuordnung der Bedrohungsstufen von TVRA zu Automobil-Bedrohungsakteuren, Zielsystemen und Angriffspotenzialen

Bedrohungs- grad	Angreifer (Threat Agent)	Beschreibung	Angriff auf Fahrzeug oder Backend?	Motivationsstufen (TVRA)	Angriffspotenzial des Angreifers		
					Fachwissen	Wissen über das Item oder die Komponente	Ausrüstung
Vernachlässigbar	Skript-Kiddie	Jemand mit mittlerem Fachwissen und Fähigkeiten, der in der Lage ist, Code und Anwendungen online zu finden oder zu kaufen und diese auf böswillige Weise einzusetzen	Fahrzeug	Sehr niedrig	Laie	Öffentlich	Standard
Vernachlässigbar	Skript-Kiddie	Jemand mit mittlerem Fachwissen und Fähigkeiten, der in der Lage ist, Code und Anwendungen online zu finden oder zu kaufen und diese auf böswillige Weise einzusetzen	Backend	Sehr niedrig	Laie	Öffentlich	Standard

(Fortsetzung)

Tab. 5.5 (Fortsetzung)

Bedrohungs- grad	Angreifer (Threat Agent)	Beschreibung	Angriff auf Fahrzeug oder Backend?	Motivationsstufen (TVRA)	Angriffspotenzial des Angreifers		
					Fachwissen	Wissen über das Item oder die Komponente	Ausrüstung
Niedrig	Tuner	Nicht vertrauenswürdige Werkstatt oder professioneller Tuner	Fahrzeug	Mittel	Kompetent	Öffentlich	Standard
Niedrig	Datensammler	Gelegenheits-Hacker mit dem Ziel des Datenverkaufs	Fahrzeug	Mittel	Experte	Öffentlich	Standard
Niedrig	Datensammler	Gelegenheits-Hacker mit dem Ziel des Datenverkaufs	Backend	Mittel	Experte	Öffentlich	Standard
Niedrig	Einbrecher	Autodiebstahl und -einbruch	Fahrzeug	Mittel	Laie	Öffentlich	Standard
Niedrig	Hacktivist	Saboteur, Konkurrent	Fahrzeug	Hoch	Experte	Öffentlich	Standard
Niedrig	Hacktivist	Saboteur, Konkurrent	Backend	Hoch	Experte	Öffentlich	Standard
Moderat	Motivierter White-Hat- Hacker	CCC-Mitglied, IT-Sicherheitsexperte oder Universitätsforscher	Fahrzeug	Hoch	Experte	Eingeschränkt	Spezialisiert

Tab. 5.6 Zuordnung der Bedrohungsstufen von TVRA zu Automobil-Bedrohungsakteuren, Zielsystemen und Angriffspotenzialen

Bedrohungsgrad	Angreifer (Threat Agent)	Beschreibung	Angriff auf Fahrzeug oder Backend?	Motivationsstufen (TVRA)	Angriffspotenzial des Angreifers		
					Fachwissen	Wissen über das Item oder die Komponente	Ausrüstung
Schwerwiegend	Angestellte oder ehemalige Angestellte	Verfügen über Insiderwissen und vertrauens- würdige Kontakte im Unternehmen	Fahrzeug	Hoch	Experte	Vertraulich	Spezialisiert
Schwerwiegend	Angestellte oder ehemalige Angestellte	Verfügen über Insiderwissen und vertrauens- würdige Kontakte im Unternehmen	Backend	Hoch	Experte	Vertraulich	Standard
Schwerwiegend	Auftragshacker	Hacking für den illegalen Markt	Fahrzeug	Sehr hoch	Experte	Eingeschränkt	Spezialisiert
Schwerwiegend	Auftragshacker	Hacking für den illegalen Markt	Backend	Sehr hoch	Experte	Eingeschränkt	Spezialisiert

(Fortsetzung)

Tab. 5.6 (Fortsetzung)

Bedrohungsgrad	Angreifer (Threat Agent)	Beschreibung	Angriff auf Fahrzeug oder Backend?	Motivationsstufen (TVRA)	Angriffspotenzial des Angreifers		
					Fachwissen	Wissen über das Item oder die Komponente	Ausrüstung
Kritisch	Cyberkrimineller/ Terrorist	Hochqualifizierte Cyberterroristen- Gruppen oder cyberkriminelle Organisationen	Fahrzeug	Hoch	Mehrfach- Experten	Vertraulich	Maßgeschneidert
Kritisch	Cyberkrimineller/ Terrorist	Hochqualifizierte Cyberterroristen- Gruppen oder cyberkriminelle Organisationen	Backend	Hoch	Mehrfach- Experten	Vertraulich	Maßgeschneidert
Kritisch	State-Sponsored Actor	APT, Geheimdienste	Fahrzeug	Sehr hoch	Mehrfach- Experten	Streng vertraulich	Mehrfach maßgeschneidert
Kritisch	State-Sponsored Actor	APT, Geheimdienste	Backend	Sehr hoch	Mehrfach- Experten	Streng vertraulich	Mehrfach maßgeschneidert

Die Ergänzung weiterer Klassifizierungsmerkmale, wie z.B. das Zielsystem, erlaubt zudem eine differenzierte Betrachtung zwischen Bedrohungen, die ausschließlich auf eingebettete Systeme abzielen (z.B. durch Brute-Force-Angriffe auf JTAG-Passwörter oder das Erlangen erweiterter Rechte über UDS), und solchen, die sich gegen IT-/OT-Systeme richten. Diese Unterscheidung verbessert die Aussagekraft und Effektivität der TARA-Analyse deutlich, da relevante Bedrohungen gezielter und systemabhängig bewertet werden können. Letztlich liegt ein wesentlicher Vorteil eines klar definierten Angreifer-Modells darin, dass es die Grundlage für ein systematisches und nachvollziehbar dokumentiertes Vorgehen bei der Durchführung einer TARA bildet.

5.7 Praktische Fallstudien

In diesem Buch stellen wir drei unterschiedliche Fallstudien vor, die typische und besonders praxisrelevante Analyseansätze im Rahmen einer Threat Analysis and Risk Assessment (TARA) abbilden.

In der ersten Fallstudie analysieren wir ein einzelnes Steuergerät (ECU). Dies entspricht dem klassischen TARA-Projekt für eingebetteten Fahrzeugsteuergeräte, da ECU-Hersteller verpflichtet sind, eine Cybersecurity-Bewertung durchzuführen – allerdings mit dem Fokus auf den Schutz ihres eigenen Produkts. Wie bereits erläutert und auch in der ISO/SAE 21434 festgelegt, muss dabei das Betriebsumfeld mit berücksichtigt werden.

In der zweiten Fallstudie erweitern wir den Blickwinkel und analysieren das vernetzte Fahrzeug innerhalb seines digitalen Ökosystems. Die interne Fahrzeugarchitektur wird dabei nicht im Detail betrachtet, allerdings berücksichtigen wir besonders relevante Steuergeräte, die als potenzielle Angriffsvektoren oder Zielobjekte dienen können. Der Scope der TARA ist in diesem Fall nicht auf eine bestimmte ECU beschränkt – wie in der ersten Fallstudie – sondern umfasst insbesondere die Interaktionen mit der Außenwelt, z.B. über mobile Anwendungen, Cloud-Dienste oder Standortdienste. In der dritten Fallstudie schließlich analysieren wir die Cybersecurity-Risiken innerhalb der Produktionsstätte eines Zulieferers.

5.7.1 Fallstudie 1: Eingebettetes Fahrzeugsteuergerät

Die erste unserer Fallstudien befasst sich mit einem eingebetteten Fahrzeugsteuergerät, konkret mit einer elektronischen Steuereinheit (ECU) eines Fahrzeugs. Wir haben uns entschieden, eine moderne Head Unit – auch bekannt als Infotainmentsystem – zu analysieren. Dabei betrachten wir eine weiterentwickelte Head Unit mit umfassenden Konnektivitätsfunktionen, die klassische Telematik-Steuergeräte ersetzt. Diese Head Unit ermöglicht es uns, ein klassisches Beispiel für eine ECU zu analysieren, das jedoch über moderne Schnittstellen wie USB, GNSS und WLAN verfügt und gleichzeitig leistungsstarke System-on-Chips für Konnektivitäts- und Videoverarbeitungsfunktionen integriert. Die in dieser Fall-

Tab. 5.7 Scope-Definition unserer Fallstudie 1

Allgemeine Beschreibung	
Item:	Head-Unit ECU
Im Scope:	Interne Komponenten des Steuergeräts und Schnittstellen nach außen
Betriebs- umgebung:	Die Head-Unit interagiert mit dem Rest des Fahrzeugs und mit der Außenwelt. Sie verfügt über eine Mobilfunkschnittstelle für den Internetzugang des Fahrzeugs sowie über WLAN- und Bluetooth-Schnittstellen für die Verbindung des Fahrzeugs mit einem Mobiltelefon oder einem anderen mobilen Gerät. (Siehe vollständige Beschreibung unten)
Out-of- Scope:	Externe Komponenten wie andere Steuergeräte oder Mobiltelefone sind nicht im Scope. Nur der Datenaustausch von und zu diesen ist im Scope
Schadens- kategorien:	Verkehrsteilnehmer: Safety, Finanzen, Betrieb, Privatsphäre OEM: Geistiges Eigentum, Image, Finanzen, Betrieb
Angreifer-Modell	
Bedrohungs- stufe:	Angreifer haben eine Bedrohungsstufe <i>Schwerwiegend</i>
Annahmen	
Es gibt keine frühere TARA für dieses Projekt	
Keine Cybersecurity-Maßnahmen geplant	

studie betrachtete Head Unit stellt selbstverständlich eine vereinfachte, generische Version eines realen Systems dar – konzipiert zu didaktischen Zwecken für dieses Buch. Moderne Head Units können mehrere Mikrocontroller und Mikroprozessoren enthalten, die unterschiedliche Aufgaben übernehmen – etwa im Bereich Audio- und Videoverarbeitung. Die Anbindung an das Fahrzeug erfolgt über mehrere Bussysteme, wie z.B. CAN, FlexRay und LIN. Zur Mensch-Maschine-Schnittstelle (HMI) gehören in der Regel Touchscreens, verschiedene Tasten und Displays. Darüber hinaus verfügen moderne Head Units häufig über zusätzliche Komfortelemente wie Umgebungslichtsensoren, Temperatursensoren oder Kamerasysteme. Der Scope dieser ersten Fallstudie ist in Tab. 5.7 zusammengefasst.

Item Die TARA konzentriert sich auf das einzelne Steuergerät. Im Scope sind die Schnittstellen zur Außenseite des Steuergeräts, d. h. der gesamte mögliche Datenverkehr, der in das und aus dem Steuergerät geht. Das Item ist definiert als die Head-Unit einschließlich der externen Schnittstellen, wie in Abb. 5.3 dargestellt.

Im Scope Im Scope befinden sich die internen Komponenten des Steuergeräts, wie z. B. Konnektivitätsmodule, verschiedene SoCs und Speichersteckplätze.

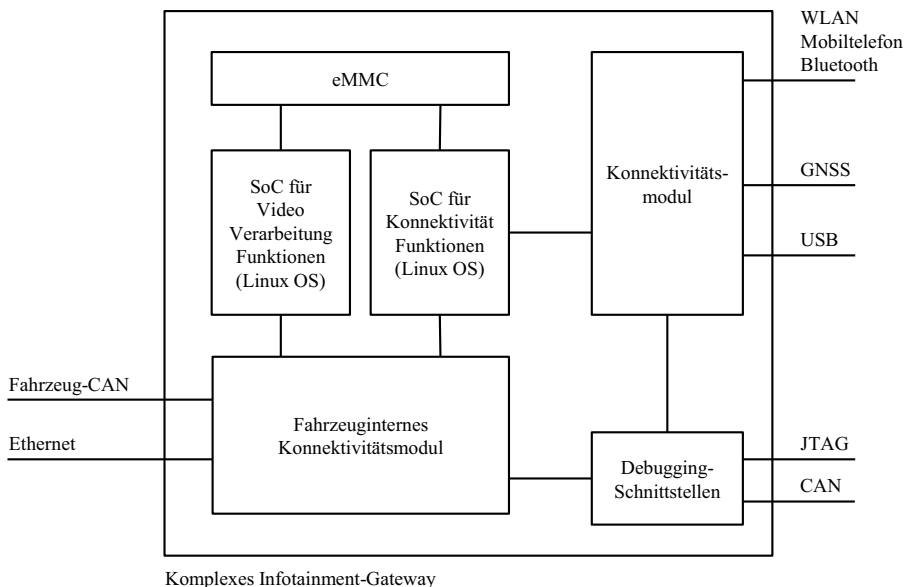


Abb. 5.3 Vereinfachtes E/E-Architekturdiagramm unserer beispielhaften Head-Unit

Betriebsumgebung Die Head-Unit interagiert mit dem Rest des Fahrzeugs und mit der Außenwelt. Sie verfügt über eine Mobilfunkschnittstelle für den Internetzugang des Fahrzeugs sowie über WLAN- und Bluetooth-Schnittstellen, um das Fahrzeug mit einem Mobiltelefon oder einem anderen mobilen Gerät zu verbinden. Anwendungen, die auf dem Steuergerät laufen, können auf das Internet zugreifen, um zum Beispiel Unterhaltungs- oder fahrzeugbezogene Dienste vom OEM anzufordern. Zudem gibt es eine GNSS-Schnittstelle, um dem Fahrzeug Standortdienste zur Verfügung zu stellen. Der Fahrer oder Beifahrer können Navigationsdienste nutzen, und die anderen Steuergeräte können bei Bedarf Standortdienste anfordern. Eine USB-Schnittstelle ermöglicht die Aktualisierung der Steuergerätesoftware und den Anschluss externer Festplatten zum Auslesen von Daten zu Unterhaltungszwecken. Die Head-Unit verfügt über eine JTAG-Schnittstelle und einen eigenen CAN-Bus für Diagnosezwecke. Der Rest des Fahrzeugs ist mit der Head-Unit über ein fahrzeuginternes Ethernet-Netzwerk und ein CAN-Netzwerk verbunden. Die Head-Unit kann Daten von anderen Steuergeräten im Fahrzeug abfragen und Diagnosedienste einschließlich Software-Updates bereitstellen. Die Head-Unit empfängt Echtzeit-Videodaten von Kameras außerhalb des Fahrzeugs, um im Falle eines Unfalls Videodaten aufzuzeichnen. Darüber hinaus kann der Benutzer mit einer speziellen Anwendung von einem Mobiltelefon aus auf die Kameras des Fahrzeugs zugreifen.

Out-of-Scope Komponenten außerhalb des Steuergeräts liegen außerhalb des Scopes. Nur der Datenaustausch von und mit diesen ist im Scope. Wir analysieren beispielsweise die

Dienste, die externen Mobiltelefonen und Anwendungen zur Verfügung gestellt werden, aber wir analysieren nicht die interne Funktionsweise des Mobiltelefons oder der Backend-Server innerhalb dieser TARA.

Schadenskategorien Neben den vier von der ISO/SAE 21434 geforderten Kategorien im Hinblick auf den Straßenverkehrsteilnehmer betrachten wir auch Auswirkungen aus Sicht des OEM. Diese betreffen die Kategorien *geistiges Eigentum*, *Image* (im Sinne von Reputationsschäden), *Finanzen* und *Betrieb*.

Angreifer-Modell Wir beschränken das Angreifer-Modell auf die Bedrohungsstufe *Schwerwiegend*, wie in Tab. 5.5 und 5.6 beschrieben.

Annahmen Wir gehen für diese TARA davon aus, dass es keine frühere TARA gegeben hat und dass zum System zumindest zum Zeitpunkt der Analyse noch keine Cybersecurity-Maßnahmen geplant wurden.

5.7.2 Fallstudie 2: Fahrzeug-Backend-Architektur

In unserer zweiten Fallstudie analysieren wir das gesamte Konnektivitätsökosystem eines vernetzten Fahrzeugs. Anders als in Fallstudie 1, in der wir das Innenleben einer einzelnen ECU untersucht haben, betrachten wir hier das Fahrzeug als Ganzes. Dabei modellieren wir ein Fahrzeug mit einer vereinfachten In-Vehicle-Architektur. Die Architektur selbst wird jedoch nicht im Detail analysiert – im Fokus stehen vielmehr die Angriffspfade, die zu einer Kompromittierung von Steuergeräten im Fahrzeug führen können.

Zu diesem Zweck reduzieren wir die Architektur auf eine Head Unit, die hauptsächlich externe Konnektivität bereitstellt – etwa über das Internet – und über ein Gateway mit den übrigen klassischen Steuergeräten sowie dem OBD-II-Anschluss verbunden ist. Das Fahrzeug ist zudem mit Cloud-Diensten vernetzt, über die sowohl OEM-spezifische als auch Dienste von Drittanbietern genutzt werden.

Ein Mobiltelefon kann ebenfalls auf diese Cloud-Dienste zugreifen und zusätzlich direkt mit dem Fahrzeug kommunizieren. Auch Standortdienste sind Bestandteil des Szenarios. Der Scope dieser Fallstudie ist in Tab. 5.8 zusammengefasst.

Item Das Fahrzeug als vernetztes Gerät und alle potenziell damit verbundenen Geräte – wie Mobiltelefone oder Diagnosewerkzeuge – einschließlich der Backend-Server (d. h. Cloud-Dienste) sind Teil des Scopes dieser TARA. Besonderes Augenmerk liegt dabei auf den Daten selbst sowie deren Verarbeitung und Umgang. Mobilanwendungen, die vom OEM oder von Drittanbietern entwickelt wurden und Daten mit dem Fahrzeug austauschen, sind ebenfalls im Scope enthalten. Nicht im Scope sind die Mobiltelefone und Server als physische Geräte – also deren Hardware oder spezifische Risiken. Trotzdem können wir

Tab. 5.8 Scope-Definition unserer Fallstudie 2

Allgemeine Beschreibung	
Item:	Architektur des vernetzten Autos, einschließlich Cloud-Dienste und Handy-Anwendungen
Im Scope:	Standortdienste, Backend-Dienste des OEM und von Drittanbietern, Anwendungen des OEM und von Drittanbietern sowie Diagnosewerkzeuge sind im Scope
Betriebsumgebung:	Diagnosedienste einschließlich Nutzungsdaten; Navigation; Unterhaltungsdienste wie Musik und soziale Medien; Dienste von Drittanbietern, die im Fahrzeug installiert werden können, wie z. B. eine Musik- oder Hörbuchanwendung. Zahlungsdienste für OEM- und Drittanbieteranwendungen sind vorhanden und werden über Benutzerprofile verwaltet
Out-of-Scope:	Die interne Funktionsweise der kommunizierenden Systeme ist nicht im Scope
Schadenskategorien:	Verkehrsteilnehmer: Safety, Finanzen, Betrieb, Privatsphäre OEM: Geistiges Eigentum, Image, Finanzen, Betrieb Drittanbieter: Geistiges Eigentum, Image, Finanzen, Betrieb
Angreifer-Modell	
Bedrohungsstufe:	Angreifer haben eine Bedrohungsstufe <i>Schwerwiegend</i>
Annahmen	
Es gibt keine frühere TARA für dieses Projekt	
Keine Cybersecurity-Maßnahmen geplant	

Cybersecurity-Ziele und Anforderungen definieren, die diese Geräte erfüllen müssen, um den sicheren Umgang mit unseren Daten zu gewährleisten. Die Architektur des Elements ist in Abb. 5.4 dargestellt.

Im Scope Im Scope sind Standortdienste, Backend-Dienste und Anwendungen von OEM und Drittanbietern, sowie Diagnosewerkzeuge enthalten.

Betriebsumgebung Wir betrachten die folgenden Remote-Dienste für das Fahrzeug: Diagnosedienste, die vom Fahrzeug bereitgestellt werden und aus der Ferne angefordert werden können, z. B. um den aktuellen Kilometerstand, Fahrzeugfehlercodes und andere Nutzungsdaten zu erhalten; Navigation; Unterhaltungsdienste wie Musik und soziale Medien; und Dienste von Drittanbietern, die im Fahrzeug installiert werden können, wie eine Musik- oder Hörbuchanwendung. Das gesamte System basiert auf Benutzerprofilen, die vom OEM verwaltet werden und für Drittanbieterdienste genutzt werden können. Zahlungsdienste sind vorhanden und werden vom Benutzerprofil verwaltet, sodass ein OEM oder eine Anwen-

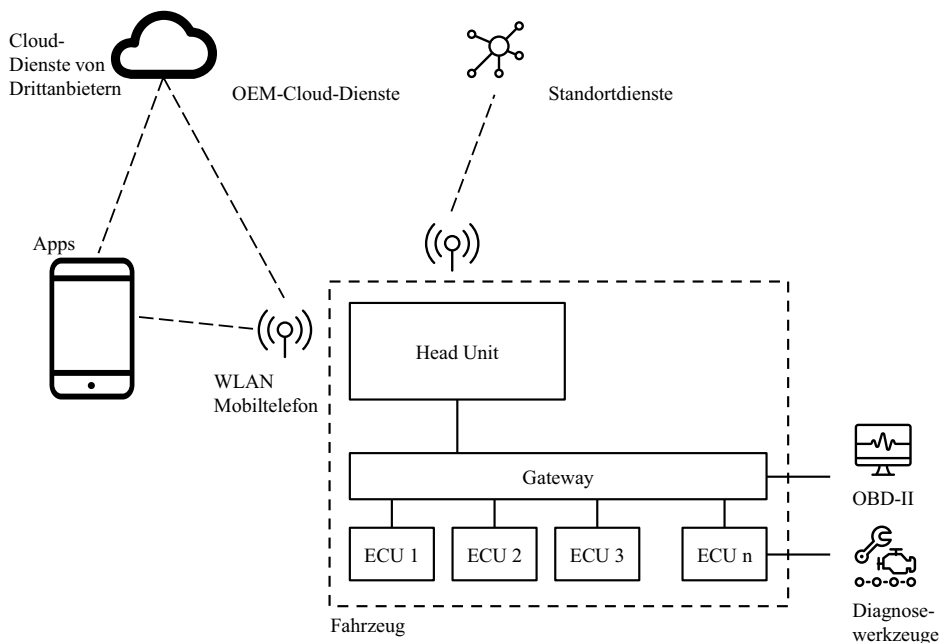


Abb. 5.4 High-Level-Konnektivitätsdiagramm einer Fahrzeug-Backend-Architektur

dung eines Drittanbieters sie nutzen kann, um auf Anfrage des Benutzers Dienste on-the-fly zu erwerben.

Out-of-Scope Im Allgemeinen werden die kommunizierenden Elemente wie das Mobiltelefon, das Fahrzeug und die Backend-Server im Rahmen von TARA als Black Boxes behandelt, deren interne Funktionsweise nicht in den Scope fällt.

Schadenskategorien Neben den vier von der ISO/SAE 21434 geforderten Kategorien im Hinblick auf den Straßenverkehrsteilnehmer betrachten wir auch neue Kategorien aus Sicht des OEM und dritter Parteien. Die Kategorien für die letzten beiden Gruppen sind *Geistiges Eigentum*, *Image* (in Bezug auf Rufschädigung), *Finanzen* und *Betrieb*.

Angreifer-Modell Wir beschränken das Angreifer-Modell auf die Bedrohungsstufe *Schwerwiegend*, wie in Tab. 5.5 und 5.6 beschrieben.

Annahmen Ähnlich wie bei unserer ersten Fallstudie gehen wir davon aus, dass es keine vorherige TARA und keine geplanten Cybersecurity-Maßnahmen gibt.

5.7.3 Fallstudie 3: Automobilproduktionsanlage

In der dritten Fallstudie führen wir eine TARA gemäß den Vorgaben der ISO/SAE 21434 für eine Produktionsumgebung durch. Die betrachtete Produktionsanlage ist ein hybrides IT-/OT-Umfeld. Wir wenden dabei sowohl Konzepte aus der ISO/IEC 27000-Standardsreihe für Informationssicherheitsmanagement als auch aus der IEC 62443-Standardsreihe für OT-Cybersecurity-Management an.

Die Produktionsanlage dient beispielhaft zur Herstellung der Head Unit aus Fallstudie 1. Ziel der TARA ist es, Risiken zu identifizieren, die zur Einführung von Schwachstellen während der Produktion oder in der Post-Produktionsphase führen können – insbesondere durch Bedrohungen, die aus dem Backend oder der Produktionsumgebung selbst entstehen. Abb. 5.5 zeigt die High-Level-Architektur unserer Produktionsanlage. Es handelt sich um eine vereinfachte Darstellung einer modernen Fertigungsanlage mit internen und externen Verbindungen. Die Produktionslinie umfasst verschiedene Maschinen, darunter auch eine Software-Flashing-Station, die über einen lokalen Server die zu installierenden Software-Binärdateien bezieht.

Zusätzlich ist diese Station mit einer Public Key Infrastructure (PKI) verbunden, um digitale Signaturen zu verifizieren und Zertifikate sowie Schlüsselmateriale zu installieren. Über eine lokale Überwachungs- und Konfigurationsschnittstelle können Bediener den Status der Produktionslinie vor Ort einsehen und gegebenenfalls Anpassungen vornehmen – auch ein Fernzugriff über das Internet ist möglich.

Der lokale Server steht außerdem in Verbindung mit Cloud- bzw. Backend-Diensten, um Softwarepakete vom R&D-Bereich außerhalb des Werks oder direkt vom OEM herunterzuladen. Der PKI- bzw. Key-Management-Server kommuniziert mit dem OEM-Key-Server, um OEM-Zertifikate und -Schlüsselmateriale zu beziehen sowie den Status der während der Produktion verwendeten Zertifikate und Schlüssel zu synchronisieren. Der Scope ist in Tab. 5.9 zusammengefasst und wie folgt beschrieben.

Item Das Item der TARA ist die Produktionsanlage mit ihren Produktionslinien, einschließlich interner und externer Server und Dienste. Das Ziel der TARA ist der Schutz des Steuergeräts, also des herzustellenden Produkts, vor Schwachstellen, die während der Produktion eingeführt oder ausgenutzt werden. Die Produktionslinie befindet sich in einem fortgeschrittenen oder endgültigen Produktionsstadium, d.h. das Steuergerät ist physisch gebaut und bereit, die endgültige Software zu erhalten.

Im Scope Die Analyse wird ähnlich wie in Fallstudie 2 auf architektonischer Ebene durchgeführt, d.h. wir konzentrieren uns auf die in der Produktionsanlage laufenden Dienste, nicht aber auf die interne Funktionsweise jeder einzelnen Komponente. Im Scope ist natürlich der ungeschützte direkte physische Zugang zu Servern und Schnittstellen, nicht aber z.B. das Öffnen eines Servergehäuses und das direkte Auslesen von Daten aus den RAM-Blöcken des Servers. Das zu bauende Steuergerät ist im Scope. Relevante Bedrohungen sind solche,

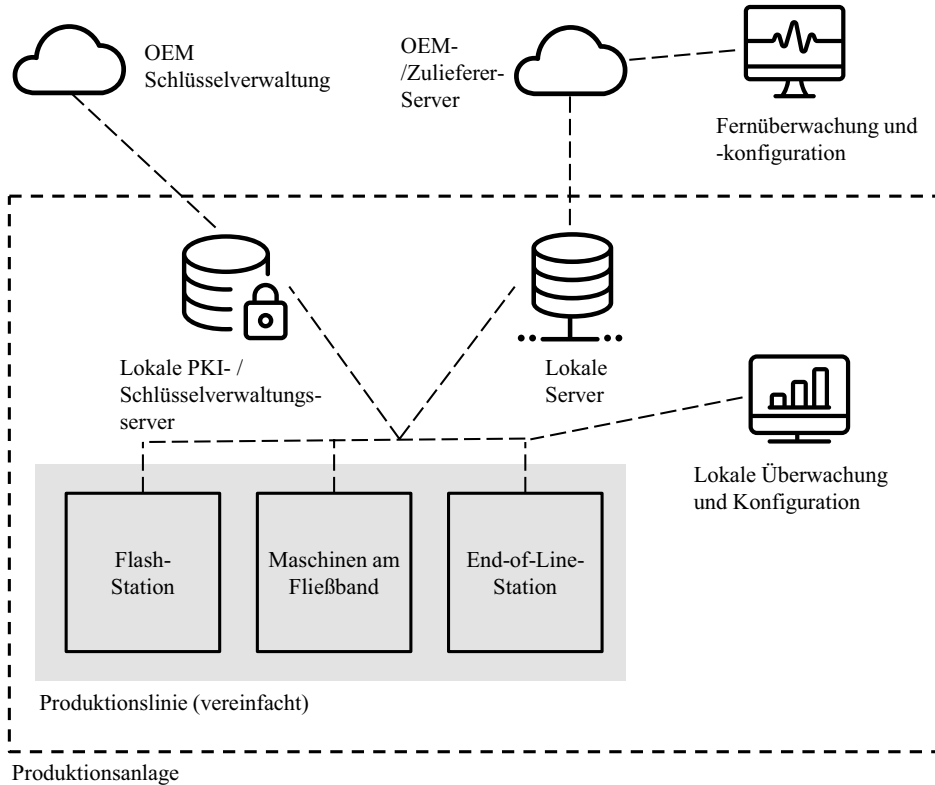


Abb. 5.5 Produktionsanlage mit einer Produktionslinie und diversen Backend-Kommunikationssystemen

die direkt mit der Fertigungsanlage zusammenhängen. Andere Bedrohungen, wie z. B. die Kompromittierung des Steuergeräts über angeschlossene CAN-Busse, fallen nicht in den Scope, da sie von der Fallstudie 1 abgedeckt werden.

Betriebsumgebung Das zu produzierende Steuergerät wird mit verschiedenen Maschinen für unterschiedliche Anwendungsfälle, wie z. B. elektrische oder thermische Tests, zur Produktionslinie gebracht. Die erste Station ist in der Lage, die Software in Binärdateien zu schreiben, welche von einem lokalen Server bezogen werden. Der lokale Server hat eine Verbindung zur R&D-Abteilung des Zulieferers und zum Backend-Server des OEM, um die Informationen und Softwarepakete zu erhalten, die in das Steuergerät geflasht werden sollen. Ein lokales PKI- oder Schlüsselverwaltungssystem wird verwendet, um Zertifikate und Schlüssel zu validieren und in das Steuergerät zu schreiben. Das PKI- oder Schlüs-

Tab. 5.9 Scope-Definition unserer Fallstudie 3

Allgemeine Beschreibung	
Item:	Fertigungsanlage (IT-/OT-System) einer Head-Unit (ECU)
Im Scope:	ECU, welche produziert wird, und der Produktionsplan, einschließlich der Maschinen der Produktionslinie sowie der internen und externen Server
Betriebsumgebung:	Das zu produzierende Steuergerät (ECU) wird an der Produktionslinie mit verschiedenen Anlagen für unterschiedliche Anwendungsfälle, wie z. B. elektrische oder thermische Tests, geprüft. Die erste Station ist in der Lage, die Software in Binärdateien zu schreiben, die von einem lokalen Server bezogen werden. Der lokale Server hat eine Verbindung zur R&D-Abteilung des Zulieferers und zum Backend-Server des OEM, um die Informationen und Softwarepakete zu erhalten, die in das Steuergerät geflashed werden sollen. Ein lokales PKI- oder Schlüsselverwaltungssystem wird verwendet, um Zertifikate und Schlüssel zu validieren und in das Steuergerät zu schreiben. Das PKI- oder Schlüsselverwaltungssystem stellt eine Verbindung zum Schlüsselverwaltungssystem des OEM her, um Zertifikate und Schlüssel vom OEM zu erhalten, sie zu validieren und relevante Informationen zu synchronisieren. Es sind sowohl lokale als auch Fernüberwachungs- und Konfigurationsdienste verfügbar
Out-of-Scope:	Interne Bedrohungen für Maschinen und Server, insbesondere Hardware-Bedrohungen, sind nicht im Scope
Schadenskategorien:	Verkehrsteilnehmer: Safety, Finanzen, Betrieb, Privatsphäre
	Supplier: Geistiges Eigentum, Image, Finanzen, Betrieb
Angreifer-Modell	
Bedrohungsstufe:	Angreifer haben die Bedrohungsstufe <i>Schwerwiegend</i>
Annahmen	
Es gibt keine frühere TARA für dieses Projekt	
Es sind keine Cybersecurity-Maßnahmen geplant	

selverwaltungssystem stellt eine Verbindung zum Schlüsselverwaltungssystem des OEMs her, um Zertifikate und Schlüssel vom OEM zu erhalten, sie zu validieren und relevante Informationen zu synchronisieren. Es stehen sowohl lokale als auch Fernüberwachungs- und Konfigurationsdienste zur Verfügung.

Out-of-Scope Bedrohungen gegen den internen Hardware-Betrieb der Maschinen in der Produktionsanlage liegen außerhalb des Scopes. Der Grund für diese Entscheidung ist, dass TARA in der Lage sein sollte, Cybersecurity-Ziele für die Produktionsmaschinen oder Server bereitzustellen, die das Steuergerät bedrohen. Wenn beispielsweise eines der Ziele darin besteht, dass die Software während der Produktionslinie nicht manipuliert werden darf,

dann muss das Team oder der Lieferant, das bzw. der die Maschinen für die Produktionslinie bereitstellt, dieses Ziel berücksichtigen und die Maschinen gegen jegliche Manipulationen schützen, die das Software-Binary auf dem Weg zum Steuergerät bedrohen könnten.

Schadenskategorien Ähnlich wie bei unseren vorherigen Fallstudien analysieren wir die vier Kategorien, die von ISO/SAE 21434 für den Straßenverkehrsteilnehmer gefordert werden, zusammen mit neuen Kategorien für die Perspektive des Zulieferers: *Geistiges Eigentum*, *Image* (in Bezug auf Rufschädigung), *Finanzen* und *Betrieb*.

Angreifer-Modell Wir beschränken das Angreifer-Modell auf die Bedrohungsstufe *Schwerwiegend*, wie in Tab. 5.5 und 5.6 beschrieben.

Annahmen Wir gehen davon aus, dass es keine vorherige TARA gibt und keine Cybersecurity-Maßnahmen geplant sind.

Literatur

1. Position – Automotive Cyber Security – Recommendation for Cyber Security Interface Agreement (CSIA), with reference to ISO/SAE 21434. Position paper, German Association of the Automotive Industry (VDA) (2021). https://www.vda.de/dam/jcr:8864645a-5dd8-4c16-b81c-708b0fc86b5c/VDA_Positionspapier%20CSS%202021_FINAL.pdf
2. Markets and Markets (2022). https://www.marketsandmarkets.com/Market-Reports/artificial-intelligence-manufacturing-market-72679105.html?gclid=CjwKCAjwu5yYBhAjEiwAKXk_eEGyyDDyDGxj4w6aVmo0tRh6CgBicWFUL8ZhVU1RjvkRGkAKZpIfBoCKyUQAvD
3. ETSI: ETSI TS 102 165-1 V5.2.5 – CYBER; Methods and protocols; Part 1: Method and pro forma for Threat, Vulnerability, Risk Analysis (TVRA). Standard (2022). https://www.etsi.org/deliver/etsi_ts/102100_102199/10216501/05.02.05_60/ts_10216501v050205p.pdf
4. European Union Agency for Cybersecurity (ENISA): ENISA Threat Landscape 2022 (2022). <https://www.enisa.europa.eu/publications/enisa-threat-landscape-2022>
5. Hug, N., Gibson, C., Kropotov, V., Vosseler, R.: Cybersecurity for Connected Cars (2021). https://documents.trendmicro.com/assets/white_papers/wp-cybersecurity-for-connected-cars-exploring-risks-in-5g-cloud-and-other-connected-technologies.pdf
6. ISO/SAE 21434:2021 Road vehicles – Cybersecurity engineering. Standard, International Organization for Standardization/Society of Automotive Engineers, Geneva, CH (2021). <https://www.iso.org/standard/70918.html>
7. Lautenbach, A., Mafijul Islam, C.: HEALing vulnerabilities to ENhance software security and safety (HEAVENS) – deliverable d2 – security models (2016).
8. Mead, N.R., Hough, E.D., Stehney, I., R., T.: Security quality requirements engineering (SQUARE) methodology. Tech. rep. (2005). https://insights.sei.cmu.edu/documents/751/2005_005_001_14594.pdf
9. Shostack, A.: Threat Modeling: Designing for Security, 1st edn. Wiley Publishing (2014)
10. United Nations: UN Regulation No. 155 – Cyber security and cyber security management system, Dokumentnummer: E/ECE/TRANS/505/Rev.3/Add.154 (2021). <https://unece.org/transport/documents/2021/03/standards/un-regulation-no-155-cyber-security-and-cyber-security>
11. Upstream: Upstream 2022 Global Automotive Cybersecurity Report (2022). <https://upstream.auto/2022report/>

Zusammenfassung

In diesem Kapitel wird der Grundstein für eine TARA gelegt, indem die Assets des zu analysierenden Systems oder Items identifiziert werden. Wir geben praktische Einblicke in die Identifikation von Assets und diskutieren relevante Cybersecurity-Eigenschaften zusätzlich zur CIA-Triade. Darüber hinaus stellen wir eine wertvolle Liste gemeinsamer Assets für eingebettete und IT-/OT-Systeme im Automobilbereich zur Verfügung. Nach der Identifikation von Assets gehen wir zur Identifikation von Schadensszenarien über. Wir analysieren die Schadensszenarien, die sich auf den Verkehrsteilnehmer auswirken, und liefern praktische Beispiele für die Bewertung der Auswirkungen in den von dem Standard geforderten Kategorien. In Anlehnung an den Standard ISO/SAE 21434 zeigen wir, wie die Sichtweise auf das Schadensszenario erweitert werden kann, um die Auswirkungen auf eine Organisation als Ganzes zu analysieren. Für die geschäftlichen Auswirkungen beschreiben wir neue Kategorien, wie z. B. geistiges Eigentum und Image/Reputation. Am Ende des Kapitels stellen wir eine vollständige Asset-Identifikation für drei praktische Fallstudien zur Verfügung.

Nach der Festlegung des Scopes der TARA, d. h. der Konfiguration der TARA und der Informationen über das Item, fahren wir mit der Identifikation der Assets fort. Die Analyse der Assets kann in vier High-Level-Aufgaben unterteilt werden. Erstens, die *Identifikation der Assets* des Items im Scope der TARA, die für die Risikoanalyse verwendet wird. Zweitens die Zuordnung der *Cybersecurity-Eigenschaften* zu den Assets, was praktisch die Analyse der Cybersecurity-Eigenschaften bedeutet, die im Falle eines Angriffs relevant sind. Drittens die Identifikation der *Schadensszenarien*, wie in dem Standard ISO/SAE 21434 festgelegt, und viertens die Bewertung der *Auswirkungen* (eines erfolgreichen Angriffs, der zu Schadensszenarien führt) auf verschiedene Kategorien oder High-Level-Schutzziele (z. B. Safety,

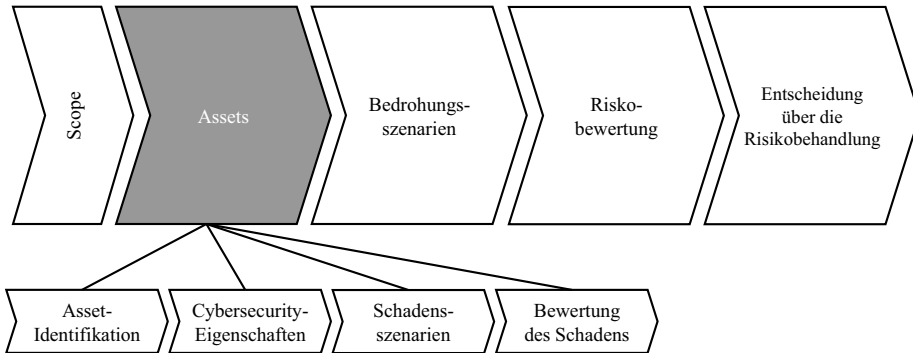


Abb. 6.1 High-Level-Schritte zur Definition der Assets des gesamten TARA-Prozesses

Finanzen, Betrieb und Privatsphäre). Diese High-Level-Schritte sind in Abb. 6.1 zusammengefasst.

► **Welcher Schritt zuerst: Asset-Identifikation oder Schadensszenarien?**

ISO/SAE 21434 behandelt die Identifikation von Assets (siehe [RQ-15-02] von [27]) unmittelbar nach der Definition von Schadensszenarien (siehe [RQ-15-01] von [27]). Dies ist jedoch nicht als starre Reihenfolge zu verstehen, da beide Tätigkeiten miteinander verbunden sind. Darüber hinaus bietet *Anhang H* des Standards ISO/SAE 21434 sogar ein Beispiel, bei dem die Reihenfolge der TARA-Schritte oder -Methoden vertauscht werden kann. Es ist möglich, mit der Identifikation von Assets zu beginnen und dann zur Identifikation der entsprechenden Schadensszenarien überzugehen. Oder man kann mit der Auswahl von Schadensszenarien aus Katalogen beginnen und dann zur Identifikation von Assets übergehen. In realen Projekten haben wir festgestellt, dass die Diskussion der Assets und ihrer Cybersecurity-Eigenschaften mit dem Engineering-Team zu einer besseren Definition der Schadensszenarien führt. Die Notwendigkeit, ein Asset zu definieren, ist nur dann sinnvoll, wenn es gefährdet werden kann, was letztlich dazu führt, dass man sich Gedanken über Schadensszenarien macht. In der Regel geschieht dies parallel, und die Schadensszenarien können definiert werden, während über die Assets nachgedacht wird.

Erforderliche Eingaben für dieses Kapitel:

- Technische Dokumentation über das Item und seine Betriebsumgebung (z. B. Systemarchitektur, technisches Diagramm)

Das Ergebnis dieses Kapitels ist:

- Assets mit Cybersecurity-Eigenschaften
- Schadensszenarien mit Bewertung des Schadens

6.1 Definition des Assets

Die Definition eines Assets kann so einfach sein wie ein Objekt, das einen Wert hat, wie in [27] definiert. Für eine TARA nach ISO/SAE 21434 ist das Asset etwas, das einen Wert hat und dem Cybersecurity-Eigenschaften zugeordnet sind, wie Vertraulichkeit, Integrität und Verfügbarkeit. Die Beeinträchtigung einer Cybersecurity-Eigenschaft eines Assets als Folge eines Cyberangriffs kann zu einem oder mehreren Schadensszenarien führen. Im Prinzip kann jedes physische Objekt oder logische Artefakt wie Daten als Asset betrachtet werden. Der Standard ISO/SAE 21434 enthält weder einen Katalog von Assets noch schränkt sie ein, was ein Asset sein kann. Abhängig vom Scope einer TARA kann das Asset von unterschiedlicher Natur sein. Bei der Analyse von eingebetteten Geräten können typische Assets etwa Kommunikationsschnittstellen wie CAN oder Ethernet, Debugging-Schnittstellen, interne Speicherblöcke, Software-Komponenten wie der Bootloader oder Software-Anwendungen, persönliche oder sensible Daten, die im Gerät gespeichert sind, Sensoren, Aktoren und andere umfassen. Bei der Durchführung einer TARA in einer Fahrzeug-Backend-Architektur oder einer Fertigungsanlage können zu den Assets auch Software-Anwendungen, Daten auf Mobiltelefonen, Datenbanken auf Backend-Servern, Zahlungsinformationen usw. gehören.

6.2 Asset-Identifikation

Gemäß ISO/SAE 21434 kann die Asset-Identifikation auf einer Vielzahl von Aktivitäten oder Quellen basieren, wie z. B. der Analyse der Item-Definition, der Durchführung einer Bewertung des Schadens, der Ableitung von Assets aus Bedrohungsszenarien oder der Verwendung vordefinierter Kataloge (siehe [RQ-15-02] auf [27]). In diesem Abschnitt konzentrieren wir uns auf die detaillierte Analyse der Item-Definition, die die umfassendste und natürlichste Methode zur Identifikation von Assets darstellt. Es ist jedoch wichtig zu beachten, dass sich diese Aktivitäten und Quellen nicht gegenseitig ausschließen und neue Assets während der nachfolgenden Schritte des TARA-Prozesses identifiziert werden können, z. B. bei der Kartierung von Bedrohungen oder der Definition von Schadensszenarien. Letztendlich ist es das Ziel, eine vollständige und gründliche TARA zu erstellen, die alle relevanten Assets, Bedrohungen und Risiken umfasst.

Unserer Erfahrung nach lassen sich Assets am effektivsten durch Gespräche mit dem technischen Team und die gemeinsame Analyse eines Systemarchitekturdiagramms des

Items identifizieren. Die Analyse kann mit einem funktionsbasierten Ansatz beginnen. Die wichtigsten Funktionen des Items können zusammen mit ihren Komponenten identifiziert werden, und die Analyse kann im Wesentlichen mit der Beantwortung der folgenden Fragen beginnen *was könnte passieren, wenn die Funktion oder Komponente beeinträchtigt wird?* und *wie kann die Funktion/Komponente beeinträchtigt werden?*. Einer Arbeitsgruppe zur Identifikation von Assets gehören in der Regel Vertreter aus den folgenden Bereichen an:

- *Cybersecurity*: Das Cybersecurity-Team, das sich aus einem oder mehreren Cybersecurity-Architekten (oder Cybersecurity-Ingenieuren oder ähnlichen Bezeichnungen für Cybersecurity-Rollen) zusammensetzt, koordiniert die TARA-Aktivitäten und liefert Fachwissen zur Identifikation von Assets. Das Cybersecurity-Team ist der Hauptakteur, der an der Diskussion darüber beteiligt ist, ob ein Asset aus Sicht der Cybersecurity und für den Scope der TARA wichtig ist oder nicht (z. B. ob es, wie angenommen, kompromittiert werden kann, ob es Schadensszenarien gibt, ob das Asset und die Cybersecurity-Eigenschaft im Scope der TARA liegen).
- *Systementwicklung*: Bei der Cybersecurity-Analyse ist es wichtig, das Gesamtbild zu verstehen, d. h. wie alle Teile des betrachteten Items zusammenwirken. Ein Systemingenieur kann nützliche Informationen über die Betriebsumgebung des Items beisteuern. Dies ist besonders wichtig für wiederverwendbare Items, bei denen ein generisches Item oder ein Item aus einem anderen Projekt auf ein neues Projekt angewendet wird.
- *Hardwarearchitektur*: Bei der Durchführung von TARA für eingebettete Geräte können Hardware-Design-Ingenieure nützliche Einblicke in das Gesamt-Hardware-Design und die Schnittstellen des Geräts liefern.
- *Netzwerkentwicklung*: Bei den vernetzten Fahrzeugen von heute oder bei der Analyse von IT-/OT-Systemen in einer Fertigungsanlage spielt das Netzwerk-Ökosystem eine sehr wichtige Rolle. Netzwerkarchitekten können dabei helfen, Datenflüsse und relevante Netzwerkgeräte im Fahrzeug oder im Werk zu identifizieren.
- *Softwarearchitektur*: Das Softwareteam muss in eine TARA einbezogen werden, um Informationen über die Softwareteile des Items zu liefern. Wir betonen, dass eine eingehende Analyse der internen Softwareentwicklung möglicherweise nicht erforderlich ist, da wir im Bereich der Cybersecurity-Systeme analysieren, die bereits in der Praxis eingesetzt werden. Das bedeutet, dass die Software bereits kompiliert ist und auf dem System läuft. Typische relevante Informationen für eine TARA sind die High-Level-Architektur und die Verteilung der Software-Komponenten, z. B. ob es Konfigurationsdateien gibt, die getrennt von den Binärdateien gespeichert werden, ob ein oder mehrere Bootloader laufen, ob Virtualisierungstechnologien verwendet werden oder wie die Software-Updates funktionieren.

Ein sinnvoller Ansatz bei der Einbeziehung verschiedener Bereiche und Teams ist die Aufteilung der Analyse in Expertengruppen, da in der Regel nicht alle Komponenten in den Händen derselben Personen liegen. Wenn etwa ein eingebettetes Gerät wie eine Head-Unit

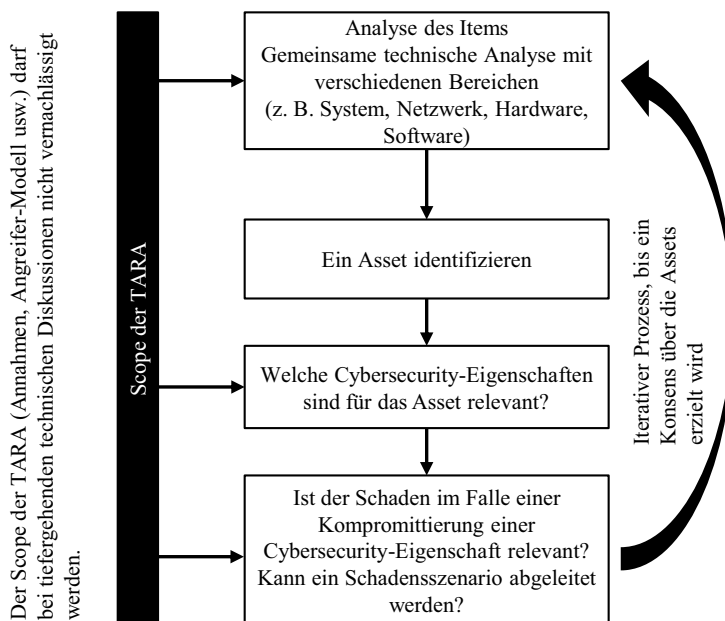


Abb. 6.2 Schritte des Asset-Identifikationsprozesses

analysiert wird, kann das Cybersecurity-Team, das die TARA leitet, relevante funktionale Komponenten wie allgemeine Schnittstellen, SoC für die Kommunikation, SoC für die Videoanalyse usw. identifizieren und die verantwortlichen Personen zu verschiedenen Interviewsitzungen einladen. Die Schritte zur Identifikation der Assets mit dem Support-Team sind ein iterativer Prozess, bis ein Konsens zwischen dem Cybersecurity-Team und dem gesamten Team erzielt wird. Diese Schritte sind in Abb. 6.2 dargestellt¹.

► **Tipp** Das Cybersecurity-Team kann die Diskussion über die Identifikation von Assets mit Hilfe von Standardfragen beginnen. Die folgenden Fragen sind Beispiele für die Durchführung von TARA für ein eingebettetes Fahrzeugsteuerggerät:

- Welche Schnittstellen hat das Gerät, z.B. Ethernet oder CAN?
- Hat das Gerät drahtlose Schnittstellen, wie z.B. WLAN oder Bluetooth?
- Gibt es Debugging-Schnittstellen, wie z.B. JTAG?

¹ Falls sich der Leser an dieser Stelle fragt, was genau mit Cybersecurity-Eigenschaften und Schadensszenarien gemeint ist, liegt das daran, dass diese Begriffe zwar bereits verwendet, aber noch nicht definiert wurden. Sie sind jedoch integrale Bestandteile des gesamten Prozesses der Asset-Identifikation und lassen sich nicht isoliert davon betrachten. Eine ausführliche Erläuterung dieser Begriffe folgt im weiteren Verlauf dieses Kapitels.

- Wenn Debugging-Schnittstellen vorhanden sind, sind diese in der Produktion verfügbar? Wie sind diese geschützt?
- Welche Diagnoseprotokolle werden verwendet? Handelt es sich um Standard-Diagnoseprotokolle wie UDS oder um proprietäre Protokolle?
- Ist das Gerät mit dem Internet verbunden? Ist das Gerät aus der Ferne zugänglich?
- Sind irgendwelche Sensoren oder Aktoren direkt an das Gerät angeschlossen? Wenn ja, über welches Protokoll kommunizieren sie (z.B. LIN, CAN, analoge E/A)?
- Werden personenbezogene Daten in dem Gerät verarbeitet und gespeichert?
- Welche Daten werden vom Gerät verarbeitet? Werden Logfiles erzeugt? Werden Produktions-/Logistikdaten auf dem Gerät gespeichert?
- Welche Softwareelemente sind vorhanden? Kann die Software aktualisiert werden? Wie werden Software-Updates geplant und über welche Schnittstellen werden sie durchgeführt?
- Speichert das Gerät sicherheitsrelevante Daten oder Artefakte, wie z.B. Zertifikate und Schlüssel?
- Wer sind die Kommunikationspartner des Geräts (z.B. andere Geräte im Fahrzeug)?
- Verarbeitet das Gerät sicherheitsrelevante Daten im Sinne der funktionalen Sicherheit (Safety)?

Asset-Kataloge Die gemeinsame Überprüfung kann durch Asset-Kataloge unterstützt werden. Die Assets für eine TARA hängen ganz von den Bedürfnissen des jeweiligen Projekts ab. Ein Asset-Katalog kann bereits zu Beginn des Asset-Identifikationsprozesses als Inspirationsquelle verwendet werden. Das Cybersecurity-Team kann die Assets aus mehreren Katalogen analysieren und mit dem Item vergleichen. Wenn das Cybersecurity-Team nicht sicher ist, ob ein Asset auf das Item zutrifft, kann das Asset zu einem späteren Zeitpunkt in der gemeinsamen Diskussion mit dem gesamten Team erörtert werden. Asset-Kataloge können in der Organisation vorhanden sein, zum Beispiel als Sammlung älterer Projekte. ENISA bietet eine umfassende Asset-Taxonomie für Smart Cars in [23]. Zusätzlich stellen wir in diesem Kapitel einen Katalog der wichtigsten Assets für verschiedene Systeme zur Verfügung.

6.2.1 Typische Assets für Automotive Embedded Devices

Wir gruppieren die typischen Assets für Automotive ECU in die folgenden Kategorien: *Kommunikationsschnittstellen/-protokolle*, *sicherheitsrelevante Daten*, *persönliche Daten*,

andere Daten bei vernetzten Fahrzeugen, Softwarekomponenten und Hardwarekomponenten.

Gruppierung von Assets nach ihrer Abstraktionsebene Wir möchten darauf hinweisen, dass es eine gute Praxis ist, Assets einer TARA nach ihrer funktionalen Abstraktionsebene zu gruppieren. Dies ist zum Beispiel bei der Analyse von Kommunikationsprotokollen der Fall. Es ist möglich, CAN als einzelnes Asset zu behandeln, trotz seiner Anwendungen, wenn der Scope der TARA sich auf den gesamten CAN-Bus konzentrieren soll. Eine andere Möglichkeit ist es, die über CAN übertragenen Dienste oder Nachrichten, wie UDS oder Safety-Nachrichten, als einzelne Assets zu behandeln. In diesem Fall können diese einzelnen Dienste separat analysiert werden, und schließlich können Cybersecurity-Eigenschaften und Cybersecurity-Ziele für diese separat definiert werden. Die folgende Liste beschreibt im Sinne einer Referenz typische Assets, die in eingebetteten Systemen im Automobilbereich zu finden sind. Selbstverständlich müssen nicht alle in jedem Fall zusammen verwendet werden.

6.2.1.1 Kommunikationsschnittstellen/-protokolle

CAN Das Controller Area Network (CAN), oder einfach CAN-Bus, ist das beliebteste Kommunikationsprotokoll in aktuellen Fahrzeugen. Es handelt sich um ein serielles Zweidraht-Kommunikationsbusprotokoll, dessen Entwicklung 1983 begann und das durch ISO 11898 [4, 10] standardisiert ist. CAN wird verwendet, um die meisten Steuergeräte des Fahrzeugs miteinander zu verbinden, oder zumindest diejenigen, die zu einer bestimmten Gruppe gehören, wie z. B. Antriebsstrang- oder Karosseriesteuerung, und Daten werden zwischen allen teilnehmenden Steuergeräten übertragen. CAN Flexible Data Rate (CAN FD) ist der moderne Nachfolger von CAN für höhere Datenraten. ISO-Transport Layer (ISO-TP) ist eine Erweiterung zum Senden von Datenpaketen über CAN [12]. Typische Anwendungen von CAN sind der Austausch von Fahrzeugdaten wie Geschwindigkeit, Temperatur, Kollisionserkennung. Der Austausch von sicherheitsrelevanten Nachrichten zwischen Steuergeräten, Sensoren und Aktoren sowie Diagnosedienste. Wenn das Steuergerät im Scope von TARA über eine CAN-Schnittstelle verfügt, müssen die eingehenden Daten sorgfältig analysiert werden.

FlexRay FlexRay ist ein weiteres beliebtes Kommunikationsprotokoll, das in modernen Fahrzeugen für schnellere Datenraten als CAN verwendet wird, es sind Datenraten bis zu 10 Mbit/s pro Kanal möglich. Es ist durch ISO 17458-1:2013 [8] genormt. Es wird für zeitkritische Systeme wie ADAS, Lenk- und Bremssysteme oder Infotainment-Kommunikation verwendet. FlexRay ist teurer als CAN und LIN, daher wird es für High-End-Systeme eingesetzt [43].

LIN Das Local Interconnect Network (LIN) ist das kostengünstigste der Kfz-Protokolle mit einer Höchstgeschwindigkeit von 20 Kbps [43]. Es handelt sich um ein serielles Eindrahtprotokoll, das für unkritische Anwendungen mit niedriger Datenrate verwendet wird, wie z. B. kleine Sensoren, Schiebedachsteuerung, Sitzsteuerung, Türverriegelung oder -steuerung, Beleuchtung und andere. Es ist durch ISO 17987-1 [13] genormt.

MOST Das Media Oriented Systems Transport (MOST)-Protokoll wurde für High-Speed-Multimedia-Anwendungen in Kraftfahrzeugen entwickelt. Die langsamste MOST-Variante, MOST25, verwendet optische Kunststofffasern als physikalische Schicht und unterstützt Geschwindigkeiten bis zu 25 Mbit/s. Die schnellste Variante, MOST150, unterstützt bis zu 150 Mbit/s und ist auf Ethernet implementiert [25]. MOST ist für TARA möglicherweise nicht von Interesse, da es in der Regel keinen Zugriff auf das Fahrzeugmikrofon, das Mobilfunksystem oder Verkehrsinformationen ermöglicht [43].

Ethernet Moderne Fahrzeuge bewegen sich weg von Protokollen wie MOST und FlexRay für die High-Speed-Kommunikation hin zu Ethernet. Ethernet besteht aus verschiedenen Protokollen für unterschiedliche Zwecke, die auf verschiedenen OSI-Schichten laufen. Es bietet Geschwindigkeiten von bis zu 10 Gbit/s unter Verwendung von nicht proprietären Protokollen und einer beliebigen Topologie [43]. Diagnostics over IP (DoIP) [17], Scalable Service-Oriented Middleware over IP (SOME/IP) [9] und Audio Video Bridging (AVB)/Time Sensitive Networking (TSN) für Multimedia-Anwendungen sind typische Automotive Ethernet-Protokolle, die auf den Schichten 5 bis 7 laufen.

OBD/OBD-II Der On-Board-Diagnose-Stecker (OBD), auch bekannt als Diagnostic Link Connector (DLC), ist ein externer Stecker, der in vielen Fahrzeugen zu finden ist und mit dem internen Netzwerk des Fahrzeugs kommuniziert [43]. OBD wird heutzutage auch als OBD-II bezeichnet. Es handelt sich dabei um die aktuelle Version, die in vielen Ländern seit einigen Jahrzehnten vorgeschrieben ist. In diesem Buch wird nicht zwischen OBD und OBD-II unterschieden. Aus Sicht der Cybersecurity ist es ein wichtiges Asset, da es Ports für verschiedene Protokolle wie CAN und KWP2000/K-Line bietet, die auch für Standarddiagnosen und Software-Updates verwendet werden. Das durch ISO 14230 [11] genormte Keyword Protocol 2000 (KWP2000) bietet Diagnosedienste. Die europäische Variante ist die durch ISO 9141-2 [3] genormte K-Line.

JTAG Dies ist ein kritisches Asset, da es ein Protokoll ist, das Low-Level-Debugging-Funktionen sowie das Herunter- und Hochladen von Firmware auf einen Chip ermöglicht. JTAG-Anschlüsse befinden sich normalerweise auf den Chips. JTAG kann durch eFuses deaktiviert werden. Tools wie JTAGulator können sogar helfen, versteckte oder defekte freiliegende Pads für JTAG zu finden [43].

WLAN Es ist eine enorme Erleichterung, wenn im Fahrzeug WLAN-Verbindungen zu Mobiltelefonen hergestellt werden können, um auf das Internet oder Multimediadienste zuzugreifen, oder sogar zu externen Geräten, wie z. B. dem Home Access Point, um Over-the-Air-Updates herunterzuladen [26]. WLAN-Verbindungen könnten jedoch ausgenutzt werden und eine erhebliche Angriffsfläche bieten, die Hackern Zugang zu allen Fahrzeugsystemen, einschließlich sicherheitsrelevanter Buskommunikation wie CAN, verschaffen könnte [47]. WLAN birgt auch Risiken für die Privatsphäre. So kann das Fahrzeug beispielsweise durch das Ausspähen der Service Set Identifier (SSID) verfolgt werden, oder es können persönliche Daten kompromittiert werden, wenn der WLAN-Router des Fahrzeugs manipuliert wird [19].

Bluetooth Wie WLAN ist es eine leistungsfähige Schnittstelle für die Verbindung des Infotainmentsystems mit mobilen Geräten. Im schlimmsten Fall könnte sich ein Angreifer Zugang zu persönlichen Daten verschaffen oder sogar bösartigen Code auf dem Infotainment-Gerät ausführen [26, 43].

USB Jeder USB-Anschluss an einem beliebigen Gerät im Fahrzeug kann potenziell ausgenutzt werden und sollte sorgfältig analysiert werden. Eine USB-Verbindung zum Infotainmentsystem kann ausgenutzt werden, um Root-Shell-Zugriff auf das System zu erhalten und nicht autorisierte Software zu installieren, wie dies bereits bei einem der großen OEM [1] geschehen ist.

eSIM Wenn das Fahrzeug oder System über eine eingebettete SIM-Karte (eSIM) verfügt, müssen die übertragenen Dienste oder Daten als Asset für die Cybersecurity analysiert werden. In modernen Fahrzeugen verfügt eine Telematikeinheit in der Regel über eine oder mehrere eSIM, um das Fahrzeug über Mobilfunkverbindungen wie 4G, LTE und 5G mit dem Internet zu verbinden. Moderne Dienste umfassen Echtzeit-Verkehrsinformationen sowie cloudbasierte Backend-Serveranwendungen wie die Fernsteuerung von Fahrzeugen. [26].

Digital/Analog I/O Es kann verschiedene digitale oder analoge E/A-Schnittstellen für unterschiedliche Zwecke geben, z. B. für das Lesen von Sensordaten und die Steuerung von Aktoren. Solche Schnittstellen können in den Scope einer TARA fallen und daher als Assets betrachtet werden. Bedrohungen für solche Schnittstellen können minimale Auswirkungen haben.

GPIO, I2C, SPI Wenn Bedrohungen auf dem Chip in den Scope der TARA fallen, können Allzweck-Eingangs-/Ausgangsanschlüsse (GPIO) für die Identifikation von Assets in Betracht gezogen werden. Inter-Integrated Circuit (I2C)-Busse sind wahrscheinlich auf Chips zu finden, um Komponenten wie verschiedene Prozessoreinheiten oder Speicher-

blöcke miteinander zu verbinden. Serielle Peripherie-Schnittstellen (SPI) finden sich auch an GPIO-Anschlüssen oder auf der Platine selbst.

- **Physikalische Schnittstelle oder „Daten“ als Asset?** Eine interessante Diskussion, die sich bei Schnittstellen ergibt, insbesondere bei TARA für eingebettete Geräte, ist die Frage, ob zwischen den physischen Schnittstellen und den durch sie fließenden Daten unterschieden werden soll. Der Grund dafür ist in der Regel, dass bei der Analyse von E/E-Diagrammen die Asset-Definition von einer High-Level-Perspektive ausgeht und die Analysten dazu neigen, die Schnittstellen als einen ganzen Funktionsblock zu behandeln. In diesem Fall wird z. B. CAN als ein mehrdeutiges Asset identifiziert, das oft den physischen Anschluss oder die Drähte und die Datenflüsse meint. Unserer Meinung nach ist es sinnvoll, physische und logische Assets als eine Einheit zu behandeln. Durch die Zuordnung der Bedrohungen wird schließlich klar, welcher Teil des Assets gefährdet ist. Es kann Projekte geben, bei denen eine Differenzierung erforderlich ist, z. B. um eine strikte Unterscheidung zwischen physischen und logischen Bedrohungen zu treffen. In diesem Fall ist es möglich, zwei Assets für CAN zu haben: *CAN-Schnittstelle* für die physische Schnittstelle und *CAN-Daten* für die logische Schicht.

6.2.1.2 Sicherheitsrelevante Daten

Öffentliche Schlüssel und Zertifikate Bei der Identifikation von Cybersecurity-relevanten Daten sind öffentliche Schlüssel und Zertifikate typische Beispiele für Daten, die als Asset definiert werden müssen, da sie andere Cybersecurity-Eigenschaften aufweisen als beispielsweise private Schlüssel und ein attraktives Ziel für Bedrohungen darstellen. Aus diesem Grund kann die Betrachtung dieser Daten als Assets helfen, später im TARA-Prozess spezifische Cybersecurity-Maßnahmen zuzuweisen. Öffentliche Schlüssel und Zertifikate sind in der Regel nicht gegen Verlust der Vertraulichkeit geschützt, da sie per Definition öffentlich sind, aber sie sind gegen Bedrohungen der Integrität und Authentizität geschützt.

Private Schlüssel und Passwörter Mit Sicherheitsgeheimnissen wie symmetrischen Schlüsseln und Passwörtern (z. B. JTAG-Passwörtern) muss sorgfältig umgegangen werden, da ihre Offenlegung oft zu schädlichen Konsequenzen führt.

Zugangsdaten Ähnlich wie bei privaten Schlüsseln können auch Credentials von Konten, wenn sie im Item vorhanden sind, separat als Assets analysiert werden. Im Gegensatz zu Schlüsseln und Passwörtern ändern sich die Credentials von Konten im Laufe der Zeit, z. B. durch den Wechsel von Treibern, und können mit anderen Arten von Bedrohungen und Cybersecurity-Maßnahmen verbunden sein.

Einzigartige IDs OEM und Zulieferer können verschiedene Arten von Identifikationsnummern verwenden, um Teile des Fahrzeugs und in diesem Fall Sicherheitsartefakte zu identifizieren. Daher müssen sie bei der Bedrohungsanalyse berücksichtigt werden.

Sichere Zeitübertragung im Fahrzeugnetzwerk Die Übertragung von Zeitsynchronisationsnachrichten innerhalb des Fahrzeugs kann ebenfalls ein interessantes Asset und ein Ziel verschiedener Bedrohungen darstellen.

6.2.1.3 Persönliche Daten

Personenbezogene und personenbeziehbare Daten des Fahrers/Passagiers Personenbezogene und personenbeziehbare Daten, wie z. B. Name, Adresse, Geburtstag, biometrische Daten oder alle Daten, die mit einer natürlichen Person in Verbindung gebracht, verarbeitet und in dem Item gespeichert werden können, sind ein typisches Beispiel für ein wichtiges datenschutzrelevantes Asset. Autohersteller müssen strenge Datenschutzgesetze einhalten, wie z. B. die Datenschutz-Grundverordnung (DSGVO) in Europa. Personenbezogene Daten gehören heute zu den wertvollsten Informationen, an denen ein Angreifer oder eine angreifende Gruppe interessiert sein könnte. Das Bekanntwerden personenbezogener Daten kann dem Einzelnen und dem Hersteller schweren Schaden zufügen [47].

Zahlungsinformationen Wenn das Fahrzeug oder Item Zahlungsinformationen verarbeitet, können diese offengelegt oder manipuliert werden, weshalb empfohlen wird, sie als separates Asset zu erfassen. Zahlungsinformationen können dem Eigentümer finanziellen Schaden zufügen, z. B. durch die Preisgabe von Kreditkartennummern oder nicht autorisierte Transaktionen. Darüber hinaus können sie mit personenbezogenen Daten verknüpft werden und erhebliche Auswirkungen auf die Privatsphäre haben (z. B. durch Offenlegung von Namen, Adresse oder Kaufgewohnheiten).

Standortdaten Die Geolokalisierung des Fahrzeugs ist ein Asset, das in die Analyse einer TARA einbezogen werden sollte, da sie Aufschluss über die Fahrgewohnheiten einer Person geben kann. Wenn die Fahrten des Fahrzeugs verfolgt und gespeichert werden, können sie missbraucht werden, um sensible Informationen wie Religion, sexuelle Orientierung oder andere Gewohnheiten durch die besuchten Orte zu enthüllen [19].

Fahrzeugidentifikationsnummer Die Fahrzeug-Identifikationsnummer (VIN) kann ein Fahrzeug mit einer natürlichen Person verknüpfen und ist daher ein datenschutzrelevantes Asset [19].

Videodaten Moderne vernetzte Fahrzeuge können aus unterschiedlichen Gründen verschiedene Kameras haben. Zum Beispiel autonome oder fortschrittliche Fahrsysteme, die

Kameras zur Navigation verwenden, oder Dashboard-Kameras, die Autounfälle aufzeichnen. Es gibt sogar Fahrzeuge mit Kameras in der Kabine, die automatisierte Taxidienste anbieten. Der genaue Umfang des Schutzes und der Anforderungen an Videodaten kann zwar von den Vorschriften des Landes abhängen, in dem das Fahrzeug betrieben wird, aber im Allgemeinen können Videodaten als personenbezogene und personenbeziehbare Daten und damit als datenschutzrelevantes Asset für eine TARA betrachtet werden.

6.2.1.4 Andere Daten bei vernetzten Fahrzeugen

Diagnostic Trouble Codes (DTC) Fehlercodes sind fünfstellige alphanumerische Codes, die von den elektronischen Steuergeräten des Fahrzeugs gespeichert werden, um Diagnoseinformationen zu liefern. Sie können im RAM (Random Access Memory) und im nicht-flüchtigen Speicher abgelegt werden, um einen Stromausfall zu überstehen. Auch wenn die DTC nur Fehlerinformationen liefern, kann eine Manipulation negative Folgen für das Fahrzeug haben. So kann ein manipuliertes Steuergerät beispielsweise verhindern, kritische DTC zu schreiben, wie z. B. einen Motorausfall, und der Fahrer kann weiterfahren, ohne von dem Problem zu wissen. DTC können auch gefälscht werden, sodass der Fahrer oder der Fahrzeughalter falsche Informationen erhält [43].

Kalibrierungsdaten Einige Steuergeräte können variable Daten speichern, die für Kalibrierungszwecke oder zur Variantencodierung verwendet werden. Diese Daten dürfen nicht von Unbefugten verfälscht werden und müssen daher geschützt werden.

Logs Jede Art von Log-Daten muss zumindest vor unbefugter Manipulation geschützt werden. Es kann Fälle geben, in denen Logs auch persönliche Informationen speichern. In diesem Fall müssen Logs als datenschutzrelevantes Assets betrachtet werden.

Kilometerzähler Das Abklemmen, Zurücksetzen oder Verändern des Kilometerzählers eines Kraftfahrzeugs, in der Regel um einen niedrigeren Kilometerstand anzuzeigen, wird als Tacho-Manipulation bezeichnet und stellt eine schwere Straftat dar. Allein in Deutschland werden jedoch jedes Jahr zwei Millionen Fahrzeuge manipuliert [2].

Benutzerprofilaten Benutzerprofilaten können in einigen Steuergeräten zu verschiedenen Zwecken vorhanden sein, z. B. zur Speicherung von Sitzpositionen, Fahrzeugtemperatur oder anderen Infotainment-Einstellungen. In einigen Fällen können sie auch persönliche Daten enthalten.

Lebenszykluszustand Steuergeräte, insbesondere Steuergeräte-Mikrocontroller, speichern Daten, die den Entwicklungszustand des Produkts darstellen. Diese Informationen, die üblicherweise als Gerätelebenszyklus bezeichnet werden, können zur Unterscheidung zwischen

dem Entwicklungs-, dem Produktions- und dem Feldstatus eines Produkts verwendet werden. Sicherheitsfunktionen wie der Schutz von Debugging-Schnittstellen oder die Verwendung von generischen Passwörtern und Schlüsseln können mit dem Gerätelebenszyklus verknüpft werden.

Daten im RAM Daten im Arbeitsspeicher von eingebetteten Geräten können durch einen Angreifer, der eine physische Verbindung zum Steuergerät herstellt, oder durch Malware, die den Arbeitsspeicher ausliest, ausspioniert werden. Je nach Sensibilität der im RAM gespeicherten Daten, wie z. B. personenbezogene Daten, kann es erforderlich sein, RAM-Daten als Asset der TARA zu behandeln.

Fernüberwachungsdaten Die Sammlung von Daten zur Überwachung von Angriffen, Bedrohungen und Schwachstellen im Bereich der Cybersecurity ist in der UN-Regelung Nr. 155 vorgeschrieben (siehe z. B. Absatz 7.2.2.2 in [45]). Der Schutz dieser Daten ist von entscheidender Bedeutung, da der Angreifer die Daten verändern könnte, um einen Angriff zu verbergen und zu verhindern, dass der OEM ihn entdeckt. Der Angreifer könnte auch eine Fehlfunktion simulieren, um dem OEM vorzugaukeln, dass ein bestimmter Angriff stattfindet, um die Aufmerksamkeit für andere Zwecke abzulenken, z. B. für einen größeren, flottenweiten Angriff.

Event Data Recorder (EDR) Daten für die Unfalluntersuchung, z. B. um die Umstände eines Unfalls zu verstehen oder einen Unfall zu rekonstruieren. Diese Daten werden vor, während und unmittelbar nach der Kollision auf dem Event Data Recorder gespeichert und können gesetzlichen Beschränkungen in Bezug auf die Privatsphäre (d. h. gegen unbefugtes Auslesen) und den Schutz vor Manipulationen unterliegen. So verbietet die EU-Verordnung 2019/2144 [18] die Speicherung von Daten, die zur Identifikation des einzelnen Fahrzeugs, seines Eigentümers oder Halters verwendet werden könnten, wie z. B. die vollständige Fahrzeugidentifikationsnummer (VIN).

Data Storage System for Automated Driving (DSSAD) Mit dem Aufkommen hochautomatisiert fahrender Fahrzeuge ist es nicht nur wichtig, technische Informationen über den Zustand des Fahrzeugs vor, während und nach einem Unfall zu speichern, sondern auch festzustellen, wer das Fahrzeug zum Zeitpunkt des Unfalls gelenkt hat. Das Datenspeichersystem für automatisiertes Fahren (DSSAD) ist darauf ausgelegt, diese Informationen zu erfassen, einschließlich der GPS-Position und Zeit, der Aktivierung automatisierter Fahrfunktionen, der Übernahme der Fahraufgabe durch den Fahrer sowie weiterer Informationen [29]. Aufgrund des Datenschutzes und des rechtlichen Charakters des DSSAD kann es notwendig sein, es als Asset zu analysieren, wenn es zu diesem Zeitpunkt vorhanden ist.

6.2.1.5 Softwarekomponenten

Bootloader Steuergeräts oder eines Teils davon wird typischerweise in einem anderen Speicherbereich als der Rest der Software gespeichert und kann anfällig für Sicherheitsangriffe sein. Es gibt viele Bedrohungen im Zusammenhang mit der Manipulation von Bootloadern in Kraftfahrzeugen. Beispielsweise können einige Teile von Anwendungen, wie z. B. die Diagnose, manipuliert werden, um Authentifizierungsmechanismen für Diagnosezwecke zu deaktivieren. Der Angreifer kann Schreibzugriff auf sensible Informationen wie den Kilometerzähler erhalten. Andere Bedrohungen können darin bestehen, Überwachungs- und Sicherheitsfunktionen zu deaktivieren und dabei falsche Funktionen auszulösen und das Fahrzeug in einen sicherheitskritischen Zustand zu versetzen [50]. Um spezifische Bedrohungen und spezifische Cybersecurity-Maßnahmen auf Bootloader zu bewerten, kann es hilfreich sein, sie als Asset von der übrigen Software zu unterscheiden.

OEM-Anwendungen Teile der Software auf eingebetteten Geräten können vom OEM mit ihren Binärdateien und bestimmten Speicherplätzen bereitgestellt werden. Je nach dem Scope der TARA und den Schutzziele für die Software können OEM-Anwendungen ein relevantes Asset sein. Die Cybersecurity-Eigenschaften sind in der Regel Integrität und Authentizität, sodass das Steuergerät nur Software ausführen darf, die wirklich vom OEM stammt und natürlich nicht manipuliert wurde. Vertraulichkeit kann erforderlich sein, um geistiges Eigentum zu schützen, z. B. durch die Verhinderung von Reverse-Engineering-Techniken.

Zuliefereranwendungen Mehr als 80 % eines Fahrzeugs stammen von Automobilzulieferern [44]. Wenn die ECU einzelne Softwarekomponenten enthält, die ausschließlich vom Lieferanten stammen, kann sie im Rahmen der TARA als Asset betrachtet werden. Besondere Beachtung sollte der Tatsache geschenkt werden, dass die Software des Zulieferers auf niedrigeren Ebenen des Steuergeräts läuft, um eine HW-Abstraktion zu ermöglichen. Spezielle Debugging-Fähigkeiten für die Aftermarket-Analyse beim Zulieferer müssen ebenfalls sorgfältig analysiert werden.

Anwendungen von Drittanbietern Besonders in Bezug auf Infotainment-Systeme sind Anwendungen von Drittanbietern ein wichtiges Asset, da sie offensichtlich eine große Angriffsfläche bieten. Eine kompromittierte Anwendung kann im Grunde das gesamte Fahrzeug gefährden.

Software-Updates Die Software-Updates für die Steuergeräte des Fahrzeugs müssen geschützt und als Asset betrachtet werden. Handelt es sich bei dem Item der TARA um ein typisches eingebettetes Steuergerät, könnte das Asset beispielsweise aus den Software-Binärdateien bestehen, die über seine Schnittstellen zur Aktualisierung empfangen werden. Schließlich müsste das Asset Software-Update über Cybersecurity-Maßnahmen verfü-

gen, um seine Authentizität und Integrität nachzuweisen. Auf Fahrzeugebene kann TARA Cybersecurity-Ziele für das Backend-Ökosystem des Fahrzeugs ableiten, das den Software-Aktualisierungsprozess abwickelt. Software-Updates und Cybersecurity sind voneinander abhängig. Einerseits entwickelt sich die Cybersecurity im Laufe der Zeit weiter, wenn neue Schwachstellen gefunden werden. Diese Schwachstellen werden in der Regel in Form von Software-Updates behoben und gepatcht. Andererseits muss auch die Softwareaktualisierung selbst sicher sein. Aus diesem Grund wurde die UN-Regelung Nr. 156 [46] parallel zur UN-Regelung Nr. 155 über Cybersecurity erlassen und verlangt von den OEMs die Einrichtung eines Software-Update-Management-Systems (SUMS) für den gesamten Lebenszyklus eines Fahrzeugs.

6.2.1.6 Hardwarekomponenten

ECU Gehäuse Das komplette Steuergerät kann auf Hardware-Ebene zur Analyse der physischen Arten von Angriffen auf das System nützlich sein. Das Asset ist natürlich recht allgemein gehalten. Die spezifischen Bedrohungen hängen von der Analyse des untersuchten Systems ab. Wenn der Schwerpunkt der TARA jedoch nicht auf der physischen Ebene liegt, sondern lediglich einige grundlegende Bedrohungen berücksichtigt werden müssen, kann ein generisches Hardware Asset sinnvoll sein.

Sensoren Ein Fahrzeug verfügt in der Regel über Dutzende verschiedener Sensoren zur Überwachung unterschiedlicher Bereiche, darunter Kühlmitteltemperatur, Öldruck, Fahrzeuggeschwindigkeit, Sauerstoffgehalt im Auspuff, Kraftstoffstand, Parkhindernisse, Regen, Reifendruck und so weiter. Die Beeinträchtigung vieler dieser Sensoren kann schwerwiegende Folgen für das Fahrzeug und den Fahrer haben. Sogar die Sensoren des Reifendrucküberwachungssystems (TPMS) können beeinträchtigt werden, wie in [43] und in [40] beschrieben. TPMS-Signale können abgehört werden, um Fahrzeuge zu verfolgen, oder es können gefälschte TPMS-Pakete an ein Fahrzeug gesendet werden, die gefährliche Druck- und Temperaturzustände vortäuschen. Im schlimmsten Fall kann die Batterie eines Fahrzeugs entladen werden, indem die Sensoren mit Aktivierungsanforderungen überflutet werden [43].

Aktoren Ähnlich wie bei den Sensoren können auch Aktoren, die sich im Scope des Systems befinden, je nach Scope der TARA und den Auswirkungen, die eine Manipulation haben könnte, als Assets betrachtet werden.

Nichtflüchtiger Speicher In diesem Kapitel haben wir die Assets beschrieben, die mit den in einem Fahrzeug gespeicherten oder verarbeiteten Daten zusammenhängen. Im Mittelpunkt von Bedrohungen und TARA können auch die Hardware-Elemente stehen, auf denen die Daten gespeichert sind, typischerweise als nichtflüchtiger Speicher (NVM) für persis-

tente Daten. Es können verschiedene Bedrohungen auftreten, die von Seitenkanalangriffen oder Fehlerinjektion bis hin zum einfachen Anschluss an die physischen Schnittstellen der Speicherelemente reichen. Daher kann die Einbeziehung des nichtflüchtigen Speichers als Asset nützlich sein, um diese Bedrohungen aufzuzeigen und möglicherweise spezifische Cybersecurity-Maßnahmen zu planen.

Stromversorgung Der Stromversorgungsstecker oder die Kabel können aufgrund einfacher Angriffsvektoren wie dem Durchschneiden der Kabel einbezogen werden. Bei eingebetteten Geräten auf der erforderlichen Ebene können sich jedoch komplexe Angriffe auf die Stromversorgung des eingebetteten Geräts oder Teile seiner Komponenten, wie z. B. Mikrocontroller, beziehen. Ein leistungsfähiger Angriff ist der Fault-Injection-Angriff, auch bekannt als Voltage/Power-Glitching-Angriff [28, 35].

6.2.2 Typische Assets für IT-/OT-Systeme

Wir stellen eine Liste allgemeinerer Assets vor, die typischerweise sowohl in Fahrzeug-Backend-Architekturen als auch in Fertigungsanlagen zu finden sind.

Debug/Diagnose-Schnittstellen Ähnlich wie bei eingebetteten Geräten können auch IT-Geräte und Fertigungsmaschinen über verschiedene Arten von Schnittstellen verfügen, die zur Diagnose des Geräts verwendet werden. Bei der Schnittstelle kann es sich um eine Standardschnittstelle wie USB handeln, die zusammen mit anderen Diensten verwendet wird, oder es kann sich um eine spezielle Schnittstelle handeln, die vielleicht einer proprietären Hardwareschnittstelle und/oder einem Kommunikationsprotokoll folgt.

USB USB-Geräteschnittstellen können verschiedenen Zwecken dienen. In der Regel werden sie für den Anschluss von Peripheriegeräten, wie z. B. einer Tastatur oder Maus, verwendet, sie können aber auch für Wartungszwecke eingesetzt werden, z. B. zum Booten von einem externen USB-Laufwerk für Firmware-Aktualisierungen. Es wird empfohlen, die USB-Schnittstellen in TARA sorgfältig zu analysieren.

WLAN Es kann viele Gründe für den Einsatz von WLAN in IT-/OT-Systemen geben. Aufgrund ihrer Beliebtheit und Allgegenwärtigkeit sind WLAN-Schnittstellen ein naheliegendes Asset, das es im Detail zu analysieren gilt.

Feldbus Industrielle Computer und Produktionsmaschinen, wie Sensoren, Aktoren und SPS (Speicherprogrammierbare Steuerungen), sind häufig über Feldbusprotokolle miteinander verbunden. Feldbus besteht aus einer Familie von Protokollen, die als Profile klassifiziert und durch die internationale Standardfamilie IEC 61158 standardisiert sind [16]. Gängige Feldbusprotokolle sind zum Beispiel MODBUS [31], ControlNet [36] und PROFIBUS [39].

Laut [38] ist PROFIBUS mit zuletzt 65,9 Mio. installierten Geräten der erfolgreichste Feldbus der Welt. Dennoch sind PROFIBUS und andere Feldbusprotokolle nicht sicher vor Bedrohungen im Bereich Cybersecurity, wie in [49] bewertet.

Ethernet Ethernet-Schnittstellen sind, ebenso wie WLAN, leistungsstark und äußerst beliebt, und sie sind ein offensichtliches Asset, das in jeder TARA analysiert werden sollte. In industriellen Systemen kann Ethernet für viele Zwecke eingesetzt werden, z. B. zur Übertragung von Produktions- und Logistikdaten, zum Betrieb von ICS-Geräten wie SPS oder zur Übertragung von Software-Paketen und sicherheitsrelevanten Daten an das Produkt in der Produktionslinie. Industrielle Systeme haben in der Regel einen langen Lebenszyklus, und Maschinen laufen über Jahrzehnte unter der Anforderung minimaler Ausfallzeiten. Deswegen ist es heutzutage noch üblich, dass veraltete oder unsichere Protokolle, wie SMBv1, auf Industriesystemen eingesetzt werden.

Benutzeroberfläche Jede Art von HMI kann als Angriffsvektor genutzt werden. Es gibt viele Arten von gängigen Schnittstellen, wie z. B. Touchpanels, und ihre spezifische Verwendung und Bedeutung aus Sicht der Cybersecurity hängt vom jeweiligen Projekt und dem zu analysierenden Gerät ab.

Fernzugriff IT-/OT-Systeme können aus verschiedenen Gründen eine externe Konnektivität über das Internet haben. Hersteller und Administratoren von industriellen Geräten können über einen Ferndiagnosezugang verfügen, um Probleme schnell zu beheben oder Software-Updates bereitzustellen. Externer Zugriff kann auch für operative Zwecke genutzt werden, z. B. für die Übertragung von Softwarepaketen zwischen Standorten, von Logistikdaten für die Produktion oder sogar von sicherheitsrelevanten Daten mit dem Hersteller und dem Kunden. Neben der administrativen und operativen Konnektivität für die Produktionsanlage kann auch das Büronetzwerk des Unternehmens mit dem Produktionsnetzwerk verbunden werden, wodurch die Anlagen klassischen IT-Bedrohungen wie Malware über infizierte E-Mails oder Dateien, Phishing, Social Engineering und anderen ausgesetzt werden. Laut [20] ist die Infektion von ICS-Systemen mit Malware über das Internet und das Intranet in letzter Zeit eine häufig auftretende Schwachstelle.

Betriebssystem Der Zugang zu administrativen Teilen des Betriebssystems, das auf OT-Geräten läuft, kann die Tür für eine Vielzahl unterschiedlicher Bedrohungen öffnen. Klassische Schwachstellen von Betriebssystemen für ICS-Geräte sind mangelhafte Verwaltungsprozesse, d. h. normale Benutzer, die für ihre reguläre Arbeit vollen Zugriff auf Anwendungen haben, schlecht gewählte Passwörter, unsicheres Update-Management oder ungeschützte Dienste [5]. Für die Zwecke von TARA wird empfohlen, das Betriebssystem ausdrücklich zu erwähnen, da es möglicherweise anderen Bedrohungen und Cybersecurity-Maßnahmen unterliegt als der Rest der Anwendungssoftware.

Anwendungen Die Anwendungen, die auf IT-/OT-Systemen laufen, können für verschiedene Zwecke verwendet werden und können mit erheblichen Cybersecurity-Risiken verbunden sein. Zu den Anwendungen können Steuerungssoftware für Produktionsmaschinen, die Verwaltung von Produktions- und Logistikdaten, Datenbanken und viele andere gehören.

Software-Updates Das Aktualisierungssoftwarepaket und der Aktualisierungsprozess selbst können eine Quelle für starke Angriffe sein. Wenn die Integrität und Authentizität eines Software-Updates nicht gewährleistet ist, kann ein böswartiges Software-Update direkten Zugriff auf Software haben, die Daten und physische Systeme steuert. Sogar Ransomware kann in der gesamten Produktionsanlage verteilt werden, wenn sie ein Software-Update infizieren kann.

Logistikdaten In Fertigungsanlagen werden beispielsweise Logistikdaten, die zur Identifikation von Hardware- und Softwareteilen oder zur Bereitstellung von Überwachungs- und Rückverfolgungsinformationen verwendet werden, zwischen verschiedenen Produktionslinien und IT-Systemen übertragen. Böswillige Änderungen an den Logistikdaten könnten zu falsch produzierten Produkten führen, z. B. zu Software im Entwicklungsmodus anstelle von produktionsreifer Software, oder sogar die Produktion zum Stillstand bringen.

Bill of Materials (BOM) Die Bill of Materials (Stückliste) kann als Teil der Logistikdaten eines Assets betrachtet werden. Wir behandeln sie als separates Asset, um ihre Bedeutung und Kritikalität zu unterstreichen. Eine Manipulation der Stückliste in der Produktion kann beispielsweise dazu führen, dass die falsche Software auf dem Montageband geflasht wird oder dass die Montagelinien das Produkt (z. B. ein Steuergerät) mit falschen oder fehlenden Teilen bauen.

Software Bill of Materials (SBOM) Die Software Bill of Materials ist ein formaler Datensatz, der die Details der Softwarekomponenten enthält, die in einem Software-Build für ein Produkt verwendet werden. Bei diesen Komponenten kann es sich z. B. um Open-Source-Bibliotheken, proprietäre Bibliotheken, Module, Konfigurationsparameter, Abhängigkeiten und andere Elemente handeln. Die SBOM spielt eine wichtige Rolle bei der Cybersecurity, z. B. bei der Erkennung und Vermeidung bekannter Schwachstellen. Mit einer SBOM ist es für OEMs, Zulieferer und Anbieter von Automobilsoftware einfacher, den Überblick über Schwachstellen zu behalten, die in bereits in Fahrzeugen eingesetzter Software entdeckt wurden, und einen Patch bereitzustellen. Die Integrität und Authentizität einer SBOM muss über die gesamte Lieferkette hinweg gewährleistet sein.

Sicherheitsrelevante Daten Wenn für das herzustellende Produkt Cybersecurity-Artefakte wie Certificate Signing Requests (CSR), symmetrische Schlüssel oder Passwörter erforderlich sind, befinden sich diese Daten im industriellen Netzwerk der Fertigungsanlage. Es ist wahrscheinlich, dass interne Repliken von Servern des Schlüsselverwaltungssystems

innerhalb der Anlage laufen und Informationen mit externen Parteien austauschen, z. B. mit dem Netzwerk des Herstellers oder dem Netzwerk des Kunden. Mit sicherheitssensiblen Daten muss sorgfältig umgegangen werden, um Manipulationen und unbefugten Zugriff zu verhindern.

Sensoren/Aktoren Während der Datenfluss zu Sensoren und Aktoren, welche mittels Netzwerken wie Feldbus oder Ethernet verbunden sind, innerhalb einer Produktionslinie von den Assets abgedeckt werden kann, kann die Beeinträchtigung der physischen Integrität von Sensoren und Aktoren für TARA von besonderem Interesse sein und in den Scope von TARA als individuelle Assets fallen.

Server Ein generisches Asset, das Server in der Produktionsanlage abdeckt, z. B. für die Übertragung von Betriebsdaten oder sicherheitsrelevanten Daten, kann für die Abbildung von Bedrohungen der HW und Software klassischer IT-Systeme nützlich sein.

Netzwerkkomponenten Netzwerkgeräte wie Switches und Router sind von Natur aus Bedrohungen im Bereich Cybersecurity ausgesetzt, insbesondere durch interne Angreifer. Systeme können von außen kompromittiert werden, wenn der Fernzugriff nicht ordnungsgemäß konfiguriert ist und die Netzwerke nicht ordnungsgemäß getrennt sind.

End-Produkt/PCB Das ultimative Ziel einer TARA aus Sicht der ISO/SAE 21434 ist der Schutz der Produktion von Fahrzeugen und deren Komponenten. Innerhalb einer Fertigungsanlage kann das Endprodukt durch unbefugten Zugriff oder direkte physische Manipulation bedroht sein. Eine direkte Verbindung zu einer Leiterplatte (PCB) kann es einem böswilligen Bediener an der Produktionslinie ermöglichen, die Hardware oder Software zu kompromittieren.

Stromversorgung Die Stromversorgung ist ein wichtiges Asset für den Gesamtbetrieb einer Produktionsanlage. Während eine Kompromittierung der Stromversorgung am ehesten durch physische Sabotage durchführbar ist, kann für eine TARA analysiert werden, ob es intelligente Energieverwaltungssysteme gibt, die Bedrohungen im Bereich Cybersecurity ausgesetzt sein könnten.

6.2.3 Sicherheitsrelevante Assets

Funktionale Sicherheit ist eine Kerndisziplin in der Automobilindustrie. Obwohl es Harmonisierungsbestrebungen zur Integration von Cybersecurity und funktionaler Sicherheit gibt, werden sie heute in den Unternehmen in der Regel immer noch getrennt voneinander behandelt. Der Standard ISO/SAE 21434 weist insbesondere im Hinblick auf Definitionen einige Gemeinsamkeiten mit dem Standard ISO 26262 für funktionale Sicherheit auf. So

ist beispielsweise der Begriff *Cybersecurity-Ziel* mit dem Begriff *Safety Goal* verwandt, und die Begriffe *Item* und *Item-Definition* haben sogar fast denselben Namen. Sogar der im Standard ISO 26262 verwendete Prozess zur Identifikation und Kategorisierung von gefährlichen Ereignissen, genannt Hazard Analysis and Risk Assessment (HARA), weist Ähnlichkeiten mit TARA auf.

Bei der Betrachtung des Asset-Identifikationsprozesses in TARA ist es sinnvoll, Sicherheitsexperten zu konsultieren, die an demselben Projekt arbeiten. Wenn beispielsweise bereits eine HARA existiert, kann das Cybersecurity-Team analysieren, ob die Elemente der Item-Definition nach ISO 26262 als Assets verwendet werden können. Darüber hinaus können die in einer HARA identifizierten Gefahren als Inspirationsquelle für die Identifikation von Assets genutzt werden. Wenn beispielsweise die Gefahr besteht, dass *Beschleunigung statt Bremsen aufgrund von Fehlern in Bussignalen*, kann das Cybersecurity-Team *Bussignale* oder *Sicherheitsbezogene Bussignale* als Teil der Assets aufnehmen. Letztlich müssen sicherheitsrelevante Bussignale unabhängig von einem elektromechanischen Ausfall oder einem Cyberangriff ordnungsgemäß funktionieren. Der Standard ISO/SAE 21434 verlangt sogar, dass Organisationen Kommunikationskanäle zwischen den relevanten Disziplinen, einschließlich der funktionalen Sicherheit, einrichten und aufrechterhalten (vgl. [RQ-05-05] unter [27]). Sicherheitsparameter werden auch später in der TARA bei der Bewertung der Auswirkungen von Schadensszenarien verwendet (siehe Abschn. 6.4.2.1).

Eine weitere relevante Disziplin ist die Sicherheit der beabsichtigten Funktionalität (Safety Of The Intended Functionality, SOTIF), wie im internationalen Standard ISO 21448 [21] definiert. SOTIF unterscheidet sich von der funktionalen Sicherheit dadurch, dass sie sich auf Gefahren konzentriert, die sich aus funktionalen Unzulänglichkeiten der beabsichtigten Funktionalität oder ihrer Implementierung ergeben (und nicht auf Gefahren, die sich aus Fehlfunktionen solcher Systeme ergeben). SOTIF ist mit dem Aufkommen von autonomen Fahrzeugen besonders relevant geworden. Ein typisches Beispiel für eine von SOTIF analysierte Situation ist die Fehlinterpretation von Verkehrssignalen durch ein autonomes Fahrzeug, z. B. die Fehlinterpretation einer Lichtsignalanlage. So könnte der Algorithmus zur korrekten Interpretation der roten Farbe einer Lichtsignalanlage falsch implementiert sein, oder der Sensor könnte aufgrund ungünstiger Lichtverhältnisse ein unklares Bild liefern. Das Cybersecurity-Team, das die TARA durchführt, kann auch eine gemeinsame Überprüfung der vom SOTIF ermittelten relevanten Gefahren durchführen, um Assets für eine Cybersecurity-Analyse abzuleiten.

6.3 Cybersecurity-Eigenschaften

Gemäß ISO/SAE 21434 sind Cybersecurity-Eigenschaften die Attribute eines Assets, die (aus Sicht der Cybersecurity) bedroht sein können und bei einer Kompromittierung zu einem Schadensszenario führen können. Das Konzept der Modellierung von Sicherheitsattributen eines Assets zur Formalisierung des Cybersecurity-Risikomanagements ist nicht

neu. Tatsächlich handelt es sich bei den von ISO/SAE 21434 verwendeten Attributen um die bekannte Triade aus Vertraulichkeit, Integrität und Verfügbarkeit. Dasselbe Konzept der Cybersecurity-Eigenschaften findet sich in der Literatur für verschiedene Bereiche mit unterschiedlichen Bezeichnungen, wie z. B. Sicherheitsattribute in HEAVENS [30] oder Cybersecurity-Ziele. Der Standard IEC 62443 bezeichnet Vertraulichkeit, Integrität und Verfügbarkeit als Sicherheitsziele [6].

Die Zuweisung von Cybersecurity-Eigenschaften zu den in diesem Kapitel identifizierten Assets ist ein wesentlicher Schritt in einer TARA. Nicht alle Cybersecurity-Eigenschaften sind für alle Assets relevant. Die im nächsten Schritt der TARA identifizierten Bedrohungen werden den Assets zugewiesen. Die Cybersecurity-Eigenschaften, die durch die Bedrohungen beeinträchtigt werden, müssen mit den Cybersecurity-Eigenschaften übereinstimmen, die für die Assets wichtig sind. Ein triviales Beispiel: Die beiden relevanten Cybersecurity-Eigenschaften für den von einem Steuergerät gespeicherten Kilometerzähler könnten Integrität und Verfügbarkeit sein. Es ist zwingend erforderlich, dass der Kilometerzähler nicht absichtlich manipuliert wird, um z. B. einen Kilometerzählerbetrug zu verhindern. Und für den operativen Einsatz muss er bei Bedarf verfügbar sein. In diesem Fall werden nur Bedrohungen, die die Integrität und Verfügbarkeit des Kilometerzählers gefährden, für TARA berücksichtigt. Wenn ein Asset nicht über eine bestimmte Cybersecurity-Eigenschaft verfügt, besteht im Grunde keine Bedrohung für dieses Asset. Dies mag offensichtlich klingen, aber es ist wichtig, diese Konzepte bei der Durchführung von TARA im Hinterkopf zu behalten, insbesondere wenn man mit vorausgefüllten Katalogen wie Bedrohungskatalogen arbeitet.

6.3.1 CIA-Triade: Vertraulichkeit, Integrität, Verfügbarkeit

Die Cybersecurity-Eigenschaften der CIA-Triade, Vertraulichkeit, Integrität und Verfügbarkeit, werden gemäß dem Standard ISO/SAE 21434 verwendet. Diese Eigenschaften sind in der InfoSec-Gemeinschaft gut etabliert und sind daher als Standard-Set von Cybersecurity-Eigenschaften für ein TARA-Projekt anzusehen.

6.3.1.1 Vertraulichkeit

Vertraulichkeit bezeichnet den Schutz von Informationen vor unberechtigt Zugriff. In ISO/IEC 27000 wird Vertraulichkeit als die Eigenschaft definiert, dass Informationen nicht für unbefugte Personen, Einrichtungen oder Prozesse zugänglich gemacht oder offengelegt werden [15]. Typische Assets, die vertraulich behandelt werden müssen, sind solche, die mit dem Betrieb von Schutzmaßnahmen der Cybersecurity zusammenhängen, wie private Schlüssel und Passwörter, sowie Assets, die mit sensiblen und persönlichen Daten zusammenhängen, wie Zahlungsinformationen oder Fahrernamen und Wohnadressen.

Wir empfehlen, sorgfältig zu analysieren, ob Vertraulichkeit eine relevante Cybersecurity-Eigenschaft für ein Asset ist oder ob sie weggelassen werden kann. Eine gängige Maßnahme zum Schutz der Vertraulichkeit von Daten im Ruhezustand und bei der Übertragung ist die Verschlüsselung. Die Verschlüsselung von Daten kann für bestimmte kleinere Steuergeräte mit begrenzten Ressourcen sehr aufwändig sein, und für Systeme, die auf Echtzeitreaktionen angewiesen sind, wie z. B. für Anwendungen im Antriebsstrang, kann sie sogar unpraktikabel sein (d. h. ohne eine deutliche Verbesserung der HW). Selbst bei schnelleren symmetrischen Algorithmen besteht immer noch die technische Herausforderung, die erforderlichen Schlüssel zu verteilen und sie geschützt zu halten. Aus diesem Grund sollte die Verschlüsselung nur dann in Betracht gezogen werden, wenn sie wirklich notwendig ist, und nicht in inflationärer Weise für Assets, die z. B. nur einen Integritätsschutz benötigen.

6.3.1.2 Integrität

Integrität ist die Eigenschaft der Unversehrtheit und Vollständigkeit von Informationen [15], was bedeutet, dass es möglich sein sollte, zu überprüfen und zu erkennen, ob Informationen während der Übertragung von unbefugten Stellen verändert worden sind [42]. Die Veränderung von Daten muss nicht immer absichtlich erfolgen. Es ist möglich, dass Daten in einem beschädigten Bereich des Speichers gespeichert werden oder dass Daten aufgrund von Interferenzproblemen bei bestimmten Übertragungsprotokollen verändert werden.

6.3.1.3 Verfügbarkeit

Verfügbarkeit ist die Eigenschaft eines Assets, im Bedarfsfall verfügbar, zugänglich und nutzbar zu sein. Aufgrund ihres betrieblichen Charakters ist die Verfügbarkeit eine Eigenschaft, die auf viele Assets angewendet wird. In einer High-Level-Systembetrachtung müssen z. B. die Steuerelemente eines Fahrzeugs, wie das Lenkrad und die Bremsen, jederzeit verfügbar sein, um den ordnungsgemäßen und sicheren Betrieb des Fahrzeugs zu gewährleisten. Angewandt auf eingebettete Systeme muss beispielsweise die Software, die die sicherheitsrelevanten Meldungen eines elektronischen Bremssystems steuert, hoch verfügbar sein. Diese Einheiten treffen innerhalb von Millisekunden Entscheidungen, die die Dynamik des Fahrzeugs beeinflussen. Aber nicht nur für sicherheitskritische Komponenten ist die Verfügbarkeit wichtig. Jede Art von Information, die zu irgendeinem Zeitpunkt verwendet wird, muss verfügbar sein, wenn der Benutzer oder eine interessierte Stelle sie benötigt. Beispiele hierfür sind Benutzerprofilinformationen für das Infotainmentsystem, Internetzugang für Verkehrsinformationen in Echtzeit oder Fehlercodes für die Diagnoseauswertung in der Werkstatt. In der Produktion kann beispielsweise die Verfügbarkeit von industriellen Steuerungssystemen und verarbeiteten Informationen eine höhere Bedeutung und Priorität haben als andere Eigenschaften, wie in [6] beschrieben.

6.3.2 Andere Cybersecurity-Eigenschaften

Neben der CIA-Triade gibt es in der Literatur noch viele andere Cybersecurity-Eigenschaften. Parker [37] schlug beispielsweise drei neue Eigenschaften vor, um die CIA-Triads zu erweitern: Besitz oder Kontrolle, Authentizität und Nutzen (Utility). HEAVENS schlägt acht Cybersecurity-Eigenschaften vor: Vertraulichkeit, Integrität, Verfügbarkeit, Authentizität, Autorisierung, Nichtabstreitbarkeit, Privatsphäre und Freshness [30]. Für die Zwecke der TARA gemäß ISO/SAE 21434 kann die Analyse der CIA-Triade ausreichend sein, aber es gibt keine Einschränkung, weitere Cybersecurity-Eigenschaften in die TARA aufzunehmen. Auf der Grundlage unserer professionellen Erfahrung in diesem Bereich und zur Veranschaulichung von Beispielen für andere Eigenschaften als CIA nehmen wir in unsere Methodik die zusätzlichen Cybersecurity-Eigenschaften *Authentizität*, *Nichtabstreitbarkeit* und *Rechenschaftspflicht* auf. Dabei ist die Eigenschaft Authentizität in der Praxis weiter verbreitet als die Eigenschaften Nichtabstreitbarkeit und Rechenschaftspflicht.

6.3.2.1 Authentizität

Authentizität kann definiert werden als die Eigenschaft von Informationen oder Assets, echt, überprüfbar und vertrauenswürdig zu sein [33]. Mit anderen Worten, Authentizität ist die Fähigkeit, sicher zu sein, dass die Daten vom erwarteten Absender oder Eigentümer stammen. Der Begriff ist nicht zu verwechseln mit *Authentifizierung*, der die Überprüfung der Identität eines Benutzers oder einer Entität bezeichnet. Authentizität ist eine wichtige Eigenschaft in den heutigen Systemen. In eingebetteten Geräten für Fahrzeuge kann das Steuergerät beispielsweise überprüfen, ob der im Steuergerät installierte Code vom OEM oder einem anderen zulässigen Anbieter erzeugt wurde. Dies kann mit Hilfe von öffentlichen Zertifikaten und digitalen Signaturen erreicht werden. Das Steuergerät kann auch die Authentizität von Software-Updates überprüfen, die vom Steuergerät empfangen werden, bevor diese installiert werden.

6.3.2.2 Nichtabstreitbarkeit

Nichtabstreitbarkeit ist eine klassische Eigenschaft im Bereich der Informationssicherheit und der Kryptographie und besteht darin, dass es für eine Person oder Einrichtung unmöglich ist, fälschlicherweise zu leugnen, eine Aktion durchgeführt zu haben [34]. Einfacher ausgedrückt: Sie verhindert, dass ein Absender später abstreiten kann, eine Nachricht gesendet oder eine bestimmte Aktivität ausgeführt zu haben [42]. Nichtabstreitbarkeit ist eine wichtige Cybersecurity-Eigenschaft im Zusammenhang mit modernen vernetzten Fahrzeugen. Nehmen wir das Beispiel der V2X-Kommunikation, bei der Fahrzeuge kritische Nachrichten wie Geschwindigkeitsinformationen, Verkehrsbedingungen oder Geschwindigkeitsbegrenzungsdaten austauschen. In solchen Szenarien ist es von entscheidender Bedeutung, über einen Mechanismus zu verfügen, der den Absender der Nachricht eindeutig identifiziert und

die Nichtabstreitbarkeit gewährleistet. Durch die Einführung von Maßnahmen zur Nichtabstreitbarkeit wird es möglich, den Absender für seine Handlungen zur Rechenschaft zu ziehen und ein gewisses Maß an Vertrauen in das Kommunikationssystem zu schaffen. Wenn ein Absender eindeutig identifiziert wird und seine Handlungen nicht vorhersehbar sind, kann er für die von ihm übermittelten Informationen rechtlich zur Verantwortung gezogen werden. Dies ist besonders wichtig in Situationen, in denen kritische Entscheidungen, wie z. B. der Betrieb autonomer Fahrzeuge oder sicherheitskritische Benachrichtigungen, von einem genauen und vertrauenswürdigen Datenaustausch abhängen [50].

6.3.2.3 Rechenschaftspflicht

Rechenschaftspflicht ist die Eigenschaft, die sicherstellt, dass Informationen oder Handlungen einer Entität, z. B. einer Person oder eines Systems, eindeutig zu der Entität zurückverfolgt werden können, die für diese Informationen oder Handlungen verantwortlich gemacht werden kann [6, 32]. Im Kontext der Cybersecurity wird die Rechenschaftspflicht häufig mit Richtlinien auf Unternehmensebene verknüpft, wie sie in Standards wie IEC 62443 [6] definiert sind. Diese Richtlinien umreißen die Verantwortungsbereiche innerhalb einer Organisation, z. B. IT und Anlagenbetrieb, und weisen spezifische Rollen und Pflichten zu, um die Rechenschaftspflicht zu gewährleisten. Durch eine klare Definition dieser Zuständigkeiten können Organisationen einen Rahmen für die Rechenschaftspflicht schaffen und korrekte Handlungen und Verhaltensweisen durchsetzen.

Bei autonomen oder hochautomatisierten Fahrzeugen beispielsweise wird die Rechenschaftspflicht zu einer großen rechtlichen Herausforderung. Unfälle mit solchen Fahrzeugen werfen die Frage auf, wer haftbar und verantwortlich gemacht werden sollte. Die Festlegung der Rechenschaftspflicht in diesem Zusammenhang erfordert die Definition der Rollen und Zuständigkeiten der verschiedenen Beteiligten, einschließlich der Fahrzeughersteller, der Technologieanbieter und der Aufsichtsbehörden.

6.4 Schadensszenarien

Im Kontext von ISO/SAE 21434 stellt ein *Schadensszenario* (Damage-Scenario) eine nachteilige Folge für einen Verkehrsteilnehmer (Road User) als Ergebnis eines Cyberangriffs dar. Ein Schadensszenario tritt ein, wenn eine Cybersecurity-Eigenschaft eines Assets erfolgreich durch einen Angriff kompromittiert wird. Das bedeutet, dass die Bedrohungsszenarien mit ihren individuellen Angriffspfade für die verschiedenen Cybersecurity-Eigenschaften der Assets zu Schadensszenarien konvergieren. Viele Kombinationen von Bedrohungsszenarien und Assets können zu denselben Schadensszenarien führen. Beispielsweise kann die Manipulation verschiedener Arten von Nachrichten oder Signalen über unterschiedliche Kommunikationskanäle, wie CAN und Ethernet, zu demselben Schadensszenario führen, das als *das Fahrzeug beschleunigt ohne Eingriff des Fahrers* definiert ist. Wir empfehlen,

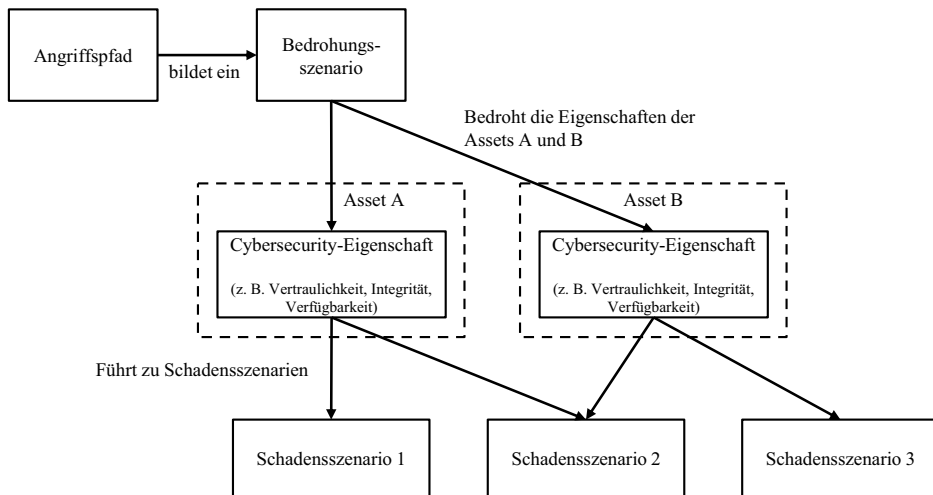


Abb. 6.3 Beziehung zwischen Angriffspfad, Bedrohungsszenario, Assets und Schadensszenarien. Ein und dasselbe Bedrohungsszenario kompromittiert zwei Assets, Asset A und Asset B, was zu unterschiedlichen Schadensszenarien führt

die Schadensszenarien zu kombinieren und die Anzahl der Schadensszenarien klein zu halten. Dies ist besonders praktisch, um eine überschaubare Liste von Schadensszenarien für den Verkehrsteilnehmer zu erhalten, während gleichzeitig viele mögliche Kombinationen von Bedrohungsszenarien und Assets mit ihnen verbunden sind. In diesem Schritt werden die Auswirkungen eines erfolgreichen Angriffs für jedes Schadensszenario bewertet. Die Beziehung zwischen Angriffspfaden, Bedrohungsszenarien, Assets und Schadensszenarien ist in Abb. 6.3 dargestellt.

Fehlender Gesamtüberblick Schadensszenarien stellen letztlich negative Folgen für die Verkehrsteilnehmer auf Fahrzeug- oder Systemebene dar. Dies bedeutet, dass Schadensszenarien das Gesamtbild eines Fahrzeugs umfassen. Bei der Durchführung von TARAs auf Komponentenebene ist es manchmal schwierig, eine direkte Verbindung von der Komponente zum Fahrzeug herzustellen und daraus ein Schadensszenario abzuleiten. In Fällen, in denen Zulieferer und OEM gemeinsam verantwortlich sind, z. B. wenn der Zulieferer nur eine *generische TARA* für eine generische Out-of-Context-Komponente bereitstellt, sind dem Zulieferer die Schadensszenarien möglicherweise nicht bekannt (vgl. Abschn. 5.3.1.1). Items sind per Definition mit Fahrzeugfunktionen verknüpft, und die Verbindung zu Schadensszenarien ist eindeutig (z. B. sendet das Steuergerät Nachrichten direkt in ein sicherheitsrelevantes Fahrzeug-CAN). Allerdings beobachten wir auch, dass Zulieferer, die für die Durchführung von TARA verantwortlich sind, nicht immer in der Lage sind, Cyberangriffe mit einem Item mit High-Level-Schadensszenarien direkt in Verbindung zu bringen. Darüber hinaus kann das Gesamtbild auch Mechanismen umfassen, die mit der Betriebsumgebung

des Items zusammenhängen. So ist es beispielsweise unwahrscheinlich, dass sicherheitsrelevante Nachrichten von einem Steuergerät, das die Bremsen oder die Lenkung steuert, akzeptiert werden, sodass das Fahrzeug eine Aktion ausführt, ohne andere Sicherheitsbedingungen zu berücksichtigen. In solchen Fällen, wenn TARA für Items auf generische Weise oder für Komponenten ohne direkte Verbindung zu Fahrzeugfunktionen durchgeführt wird, kann die TARA dennoch durchgeführt werden, indem Schadensszenarien auf Fahrzeugebene bewertet und die schlimmstmöglichen Bedingungen angenommen werden. Beispielsweise könnte die Manipulation einer Komponente zu einer bösartigen Funktion des Items führen (unter der Annahme, dass keine anderen Gegenmaßnahmen vorhanden sind), was letztlich eine Funktion auf Fahrzeugebene beeinträchtigen kann.

6.4.1 Identifikation von Schadensszenarien

Die Identifikation von Schadensszenarien kann mit Hilfe derselben Brainstorming-Methode erfolgen, die zur Identifikation von Assets verwendet wurde, wie in Abb. 6.2 gezeigt. Das Kompromittieren einer der Cybersecurity-Eigenschaften der für die TARA definierten Assets führt zu einem oder mehreren Schadensszenarien. Diese Szenarien können durch eine Brainstorming-Sitzung mit dem Expertenteam identifiziert werden, bei der jede Cybersecurity-Eigenschaft jedes einzelnen Assets auf potenzielle Bedrohungen hin bewertet wird.

Darüber hinaus haben die Cybersecurity-Experten, die die TARA unterstützen, möglicherweise bereits Erfahrung mit den betreffenden Assets, und die Listen von Schadensszenarien könnten bereits verfügbar sein, z. B. aus früheren TARAs. Die Verwendung eines Katalogs von Schadensszenarien kann eine nützliche Grundlage für einen Vergleich bieten, insbesondere wenn für dasselbe Item bereits ähnliche TARAs existieren. Allerdings ist bei der Verwendung dieser Kataloge Vorsicht geboten. Sie können zwar eine wertvolle Ressource sein, aber wenn man sich ausschließlich auf sie verlässt, könnte man Schadensszenarien übersehen, die für das Item und seine identifizierten Assets spezifisch sind. Daher ist es entscheidend, solche Kataloge als Ausgangspunkt zu verwenden, aber auch ein gründliches Brainstorming und eine Analyse vorzunehmen, um alle einzigartigen oder itemspezifischen Schadensszenarien zu identifizieren.

Die UN-Regelung Nr. 155 [45] enthält in *Anhang 5* eine beispielhafte Liste möglicher Angriffswirkungen. Diese Angriffswirkungen können bei der Erörterung von Schadensszenarien als Inspirationsquelle dienen, da sie eine breite Palette möglicher Auswirkungen in Betracht ziehen. Wie bei der Verwendung von Katalogen sollten diese jedoch eher als Orientierungshilfe denn als abschliessende Liste dienen, und die spezifischen Merkmale und der Kontext des Items sollten stets berücksichtigt werden.

- **Angriffswirkungen aus der UN-Regelung Nr. 155** Die folgenden Angriffswirkungen sind in Anhang 5 der UN-Regelung Nr. 155 [45] aufgeführt:

- Beeinträchtigung des sicheren Betriebs eines Fahrzeugs
- Ausfall von Fahrzeugfunktionen
- Modifizierung der Software, veränderte Leistung
- Änderung der Software, doch ohne Auswirkungen auf den Betrieb
- Verletzung der Datensicherheit
- Verletzung des Datengeheimnisses
- Verlust der Verfügbarkeit von Daten
- Sonstiges, einschließlich Kriminalität

Es ist anzumerken, dass diese nicht direkt als „Schadensszenarien“ bezeichnet werden und auch nicht auf den Verkehrsteilnehmer bezogen sind, wie in ISO/SAE 21434, aber sie können bei der Formulierung von Schadensszenarien berücksichtigt werden.

6.4.2 Bewertung des Schadens

ISO/SAE 21434 legt fest, dass die Bewertung des Schadens (Impact Rating) der Schadensszenarien mindestens anhand der Kategorien *Safety*, *Finanzen* (Financial), *Betrieb* (Operational) und *Privatsphäre* (Privacy) bewertet werden muss (siehe [RQ-15-04] von [27]). Zusätzliche Kategorien sind zulässig, und wir analysieren weitere Kategorien in diesem Kapitel. Die Bewertung hat vier Stufen für jede Kategorie: *Vernachlässigbar* (Negligible), *Moderat* (Moderate), *Erheblich* (Major), und *Schwerwiegend* (Severe). Die Bewertungskriterien können von der Organisation festgelegt werden. In diesem Fall ist es wichtig, die Kriterien und die ihnen zugrunde liegenden Überlegungen sorgfältig zu dokumentieren. In diesem Abschnitt folgen wir dem Beispiel der Auswirkungskriterien, die in *Anhang F* der ISO/SAE 21434 für Verkehrsteilnehmer angegeben sind.

6.4.2.1 Safety

Die in Tab. 6.1 dargestellten Werte und Kriterien für die Bewertung des Schadens für die Sicht des Verkehrsteilnehmers sind dem etablierten internationalen Standards ISO 26262 [14] für die funktionale Sicherheit von Straßenfahrzeugen entnommen. Es wird nicht erwartet, dass das Sicherheitsteam, das die Bewertung des Schadens durchführt, mit den Standards und Verfahren der funktionalen Sicherheit im Unternehmen vertraut ist. So kann beispielsweise eine gemeinsame Überprüfung mit Experten für funktionale Sicherheit sinnvoll sein, um ein tieferes Verständnis dafür zu erlangen, welche Bewertung des Schadens besser zur aktuellen Analyse des Schadensszenarien passt. Andere Details zur funktionalen Sicherheit, wie z. B.

Tab. 6.1 Kriterien für die Bewertung des Schadens für die funktionale Sicherheit für Verkehrsteilnehmer (wie in Tabelle F.1 von [27])

Bewertung des Schadens	Bewertungskriterien für Bewertung des Schadens für die funktionale Sicherheit
Schwerwiegend	S3: Lebensbedrohliche Verletzungen (Überleben ungewiss), tödliche Verletzungen
Erheblich	S2: Schwere und lebensbedrohliche Verletzungen (Überlebenswahrscheinlichkeit)
Moderat	S1: Leichte und mittelschwere Verletzungen
Vernachlässigbar	S0: Keine Verletzungen

die Parameter für Beherrschbarkeit und Exposition aus ISO 26262, können ebenfalls in die Kriteriendefinition einbezogen werden.

6.4.2.2 Finanzen

Die Beispiele für die Kriterien der finanziellen Auswirkungen für Verkehrsteilnehmer aus ISO/SAE 21434 sind in Tab. 6.2 dargestellt. Die Definitionen sind natürlich recht allgemein gehalten. Die Unterscheidung bzw. Anwendung praktischer Beispiele zwischen unangenehmen, erheblichen und katastrophalen Folgen für die Kategorien Moderat, Erheblich und Schwerwiegend hängt von dem jeweiligen Projekt und den unternehmensspezifischen Bewertungsbeschreibungen ab. Ein moderater Schaden könnte beispielsweise ein Fahrzeug sein, das nicht voll funktionsfähig ist, wodurch der Fahrer oder Beifahrer Zeit und Geld verliert. Der Fahrer oder Fahrgast könnte sich entscheiden, das Fahrzeug nicht zu benutzen und ein Taxi zu nehmen, um zu seinem Termin zu gelangen. Eine moderate Auswirkung könnte

Tab. 6.2 Kriterien für die Bewertung des finanziellen Schadens für Verkehrsteilnehmer (wie in Tabelle F.2 der [27])

Bewertung des Schadens	Bewertungskriterien für Bewertung des finanziellen Schadens
Schwerwiegend	Der finanzielle Schaden führt zu katastrophalen Folgen, die der betroffene Verkehrsteilnehmer möglicherweise nicht bewältigen kann
Erheblich	Der finanzielle Schaden führt zu erheblichen Folgen, die der betroffene Verkehrsteilnehmer gerade noch bewältigen kann
Moderat	Der finanzielle Schaden führt zu unangenehmen Folgen, die der betroffene Verkehrsteilnehmer jedoch mit begrenzten Mitteln bewältigen kann
Vernachlässigbar	Der finanzielle Schaden führt zu keinen Auswirkungen, vernachlässigbaren Folgen oder ist für den Verkehrsteilnehmer irrelevant

der Verlust von sensiblen Daten des Verkehrsteilnehmers sein, wie z. B. Bankkontodaten und Zahlungsinformationen. Schwere Folgen könnten die Verletzung von Fußgängern sein, die von einem Fahrzeug angefahren werden, sowie Krankenhauskosten oder der Verlust des Arbeitsplatzes.

6.4.2.3 Betrieb

Tab. 6.3 zeigt die Kriterienbeispiele für operative Auswirkungen auf den Verkehrsteilnehmer. ISO/SAE 21434 enthält einige Beispiele für die Stufen Moderat, Erheblich und Schwerwiegend. Eine „Moderat“ Auswirkung kann z. B. eine negative Auswirkung auf die Benutzerzufriedenheit sein. Eine „Erheblich“ Auswirkung kann z. B. ein erhebliches Ärgernis für den Fahrer darstellen. Und die höchste Stufe, „Schwerwiegend“, kann z. B. ein vollständiger Verlust der Funktionalität einer Komponente oder des gesamten Fahrzeugs sein.

6.4.2.4 Privatsphäre

Die Kriterien für die Bewertung der Auswirkungen auf die Privatsphäre (Privacy) der Verkehrsteilnehmer sind in der Tab. 6.4 aufgeführt. Einige Definitionen in den Kriterienstufen sind dem Standard ISO/IEC 29100 [22] entnommen. Insbesondere die folgenden Definitionen sind für das Verständnis der Tabelle von Bedeutung.

Personenbezogene Daten: Sämtliche Informationen, die (a) verwendet werden können, um die natürliche Person, auf die sich solche Informationen beziehen, zu identifizieren, oder die (b) im direkten oder indirekten Zusammenhang mit einer natürlichen Person stehen oder stehen könnten [22].

Betroffene Person: Die natürliche Person, auf die sich die personenbezogenen Daten beziehen [22].

Tab. 6.3 Kriterien für die Bewertung des operativen Schadens für Verkehrsteilnehmer (wie in Tabelle F.3 der [27])

Bewertung des Schadens	Bewertungskriterien für Bewertung des operativen Schadens
Schwerwiegend	Der operationelle Schaden führt zum Verlust oder zur Beeinträchtigung einer Kernfunktion des Fahrzeugs
Erheblich	Der operationelle Schaden führt zum Verlust oder zur Beeinträchtigung einer wichtigen Fahrzeugfunktion
Moderat	Der operationelle Schaden führt zu einer teilweisen Beeinträchtigung einer Fahrzeugfunktion
Vernachlässigbar	Der operationelle Schaden führt zu keiner oder einer nicht wahrnehmbaren Beeinträchtigung einer Fahrzeugfunktion

Tab.6.4 Bewertungskriterien für Bewertung des Schadens der Privatsphäre von Verkehrsteilnehmers (wie in Tabelle F.4 von [27])

Bewertung des Schadens	Bewertungskriterien für Bewertung des Schadens der Privatsphäre
Schwerwiegend	Die Beeinträchtigung der Privatsphäre führt zu erheblichen oder sogar irreversiblen Auswirkungen für den Verkehrsteilnehmer Die Informationen über den Verkehrsteilnehmer sind hochsensibel und lassen sich leicht mit einer Betroffene Person verknüpfen
Erheblich	Die Beeinträchtigung der Privatsphäre führt zu schwerwiegenden Folgen für den Verkehrsteilnehmer Die Informationen über den Verkehrsteilnehmer sind: a) hoch sensibel und schwer mit einer Betroffene Person zu verknüpfen; oder b) sensibel und leicht mit einer Betroffene Person zu verknüpfen
Moderat	Die Beeinträchtigung der Privatsphäre führt zu unangenehmen Konsequenzen für den Verkehrsteilnehmer Die Informationen über den Verkehrsteilnehmer sind: a) sensibel, aber schwer mit einer Betroffene Person zu verknüpfen; oder b) nicht sensibel, aber leicht mit einer Betroffene Person zu verknüpfen
Vernachlässigbar	Der Schaden für die Privatsphäre hat keine oder nur vernachlässigbare Folgen oder ist für den Verkehrsteilnehmer irrelevant Die Informationen über den Verkehrsteilnehmer sind nicht sensibel und lassen sich nur schwer mit einer Betroffene Person in Verbindung bringen

Beispiele für personenbezogene Daten sind: Name, Geschlecht, Geburtsdatum, Krankengeschichte, biometrische Identifikatoren, sexuelle Orientierung, Kreditkartenabrechnungen, Wohnadresse, GPS-Standort, GPS-Trajektorie, Arbeitsadresse, persönliches oder Verhaltenprofil, persönliche Interessen, die aus der Nachverfolgung der Nutzung von Internetseiten abgeleitet werden, und strafrechtliche Untersuchungsberichte. Eine vollständige Liste finden Sie in [22].

6.4.3 Zusätzliche Stakeholder

Die Analyse der Auswirkungen auf andere Interessengruppen als den Verkehrsteilnehmer ist in ISO/SAE 21434 nicht vorgesehen. Es kann jedoch sinnvoll sein, neben dem Verkehrsteilnehmer auch die Auswirkungen auf andere Personen zu analysieren, um einen ganzheitlichen Ansatz für TARA und Risikomanagement zu erhalten. In praktischen TARA-Projekten ist es in der Regel interessant, die Folgen von Schadensszenarien auf den OEM oder den Lieferanten zu analysieren. Die Schadensszenarien, die den OEM oder den Zulieferer betreffen,

können dieselben sein wie die, die den Verkehrsteilnehmer betreffen. Darüber hinaus kann es Schadensszenarien geben, die nur den OEM oder den Zulieferer betreffen. In diesem Fall wird empfohlen, diese Schadensszenarien zu beschreiben oder ihnen einen speziellen Namen zu geben, um sie aus Gründen der Konformität vom Rest der TARA zu trennen.

Nicht alle Kategorien, die für Verkehrsteilnehmer gelten, sind bei der Analyse der Auswirkungen auf OEMs oder Zulieferer sinnvoll. So können beispielsweise die Auswirkungen auf die funktionale Sicherheit für die Analyse von OEMs und Zulieferern als Unternehmen insgesamt irrelevant sein. Wenn sich die Analyse beispielsweise auf Produktionsanlagen konzentriert und die Sicherheit des Personals, das in der Produktionsumgebung arbeitet, berücksichtigt werden muss, dann wird die Kategorie *Safety* relevant. In den folgenden Beispielen für Auswirkungskategorien analysieren wir OEMs und Zulieferer als ganzes Unternehmen oder als Einheit, daher verwenden wir nicht die Kategorien *Safety* und *Privatsphäre*. Stattdessen schlagen wir die Kategorien *Geistiges Eigentum* und *Image oder Reputation* vor. Wir behalten die Kategorien *Finanzen* und *Betrieb* bei, passen aber die Kriterien an, um sie besser an unseren Anwendungsfall anzupassen. Die Kriterien beruhen auf unseren Erfahrungen. Darüber hinaus haben wir uns von der IEC 62443-2-1 [7] inspirieren lassen.

6.4.3.1 Geistiges Eigentum

Wir beziehen geistiges Eigentum in unsere Wirkungsanalyse ein, weil es eines der wertvollsten Assets heutiger Unternehmen ist. In der Tat kann das geistige Eigentum bis zu 80 % des Wertes eines einfachen Unternehmens ausmachen [24]. Es ist möglich und sinnvoll, geistiges Eigentum als Asset gemäß der TARA-Asset-Definition zu definieren und ihm dann Bedrohungen zuzuordnen. Der Vorteil der Verwendung von geistigem Eigentum als Kategorie für die Auswirkungsanalyse besteht darin, dass es einfacher sein kann, die tatsächlichen Bedrohungen für geistiges Eigentum zu identifizieren, da die Kategorie für jede Kombination von Bedrohungs- und Schadensszenario orthogonal bewertet werden muss. Darüber hinaus wird die Bedeutung des geistigen Eigentums hervorgehoben, wenn es eine Auswirkungskategorie ist. In der Tab. 6.5 beschreiben wir die verschiedenen Kriterien zur Bewertung der Auswirkungen von geistigem Eigentum, die wir in diesem Buch vorschlagen.

6.4.3.2 Image/Reputation

Cyberangriffe auf große bzw. bedeutende Unternehmen werden wahrscheinlich in den Mainstream-Medien landen. In der heutigen vernetzten Welt können solche Nachrichten praktisch sofort über das Internet in der ganzen Welt verbreitet werden. In der Automobilindustrie werden die Autohersteller den größten Imageschaden davontragen. Zumindest in der Öffentlichkeit. Große Zulieferer können ebenfalls einen erheblichen Imageschaden erleiden, und zwar nicht durch den Endverbraucher, der das Auto kauft, sondern durch ihre eigenen Kunden und Automobilhersteller. Auch wenn Angriffe auf Fahrzeugkomponenten nicht immer in den Mainstream-Medien landen, können sie doch auf Sicherheitskonferen-

Tab. 6.5 Kriterien für die Bewertung des Schadens (geistiges Eigentum) für OEM oder Zulieferer

Bewertung des Schadens	Kriterien für die Bewertung des Schadens (geistiges Eigentum)
Schwerwiegend	Katastrophale Auswirkungen für das Unternehmen, die zu kostspieligen Investitionen in Forschung und Entwicklung sowie zu Umsatzeinbußen führen
Erheblich	Die Offenlegung dieser Daten könnte dem Unternehmen erheblichen Schaden zufügen. Konkurrenten könnten sich diese Informationen zunutze machen. Zum Beispiel technische Details über den Systementwurf, die Systemarchitektur oder sogar interne organisatorische Informationen
Moderat	Geheime Daten für das Unternehmen, aber mit geringen Auswirkungen im Falle einer Offenlegung. Beispiele sind Konfigurations- oder Kalibrierungsdaten
Vernachlässigbar	Kein wesentlicher Schaden

Tab. 6.6 Kriterien zur Bewertung des Schadens am Image für OEM oder Zulieferer

Bewertung des Schadens	Kriterien für Bewertung des Schadens am Image
Schwerwiegend	Nachrichtenberichterstattung in den Mainstream-Medien, viele Menschen sind besorgt, einschließlich Kunden. Erhebliche Investitionen erforderlich, um den Ruf zu verbessern. Abkündigung des Produkts möglich. Verlust des Markenimages
Erheblich	Berichterstattung in Fachkreisen, z. B. in Fachzeitschriften oder auf wissenschaftlichen Konferenzen. Verlust des Kundenvertrauens
Moderat	Keine Nachrichtenberichterstattung, nur wenige Betroffene, aber möglicherweise eine öffentliche Meldung von Kunden
Vernachlässigbar	Keine nennenswerten Schäden

zen vorgestellt und unter Experten verbreitet werden. Wir beschreiben die verschiedenen Kriterien für Image-Schäden in Tab. 6.6.

6.4.3.3 Finanzen

Bei der Analyse der Auswirkungen von Cyberangriffen auf Unternehmen wie OEM und ihre Zulieferer wird deutlich, dass die finanziellen Auswirkungen gegenüber den Schäden für Menschenleben zweitrangig sind. In einer allgemeineren, abstrakteren Form konvergieren alle anderen Auswirkungskategorien zum finanziellen Schaden. Mit der finanziellen Kategorie für die TARA wollen wir jedoch ausdrücklich die direkten Auswirkungen eines Cybersecurity-Problems beschreiben. Wir entscheiden uns für eine generische und quali-

tative Beschreibung. Jedes Unternehmen kann, wenn es dies wünscht, den übrigen Auswirkungskriterien einen quantitativen Wert, z. B. in Millionen Dollar, zuweisen. Dies ist zum Beispiel in der IEC 62443 der Fall. Die vorgeschlagenen Kriterien zur Bewertung der finanziellen Auswirkungen auf OEM oder Zulieferer sind in Tab. 6.7 beschrieben.

6.4.3.4 Betrieb

Im Kontext einer Produktionsumgebung kann ein betrieblicher Schaden in einen Produktionslinienstillstand übersetzt werden. Ein Produktionsausfall infolge eines Cybersecurity-Problems kann als Worst-Case-Szenario betrachtet werden. In Tab. 6.8 beschreiben wir verschiedene Ausfallsituationen für die verschiedenen Stufen für die Bewertung des Schadens. Die Werte beruhen auf der Standardfamilie IEC 62443.

6.4.4 Skalierbarkeit

Der Begriff *Skalierbarkeit* wird im Zusammenhang mit Schadensszenarien verwendet, um zu bewerten, ob ein Schadensszenario einen einzelnen Verkehrsteilnehmer oder mehrere Ver-

Tab. 6.7 Kriterien zur Bewertung des finanziellen Schadens für OEM oder Zulieferer

Bewertung des Schadens	Kriterien für Bewertung des finanziellen Schadens
Schwerwiegend	Teure Entschädigungen und eventueller Rückkauf von Produkten
Erheblich	Rückruf der betroffenen Fahrzeuge, um die betroffene Software zu patchen oder Teile auszutauschen
Moderat	Das durch die Bedrohung verursachte Cybersecurity-Problem kann mit einem Software-Patch gelöst werden
Vernachlässigbar	Kein signifikanter Schaden

Tab. 6.8 Kriterien zur Bewertung des operativen Schadens für OEM oder Zulieferer

Bewertung des Schadens	Kriterien für Bewertung des operativen Schadens
Schwerwiegend	Mehr als sieben Tage Produktionsausfall an einem Standort, oder mehr als ein Tag Produktionsausfall an mehreren Standorten
Erheblich	Mehr als zwei Tage Produktionsausfall an einem Standort, oder mehr als eine Stunde Produktionsausfall an mehreren Standorten
Moderat	Weniger als ein Tag Produktionsausfall an einem Standort, oder weniger als eine Stunde Produktionsausfall an mehreren Standorten
Vernachlässigbar	Keine signifikanten Schäden

kehrsteilnehmer gleichzeitig betrifft. ISO/SAE 21434 enthält keine spezifischen Beispiele für Skalierbarkeit, erlaubt aber die Einbeziehung der Skalierbarkeit in organisationsspezifische Bewertungskriterien.

EVITA [41] beispielsweise nimmt das Konzept der Skalierbarkeit (ohne diesen Begriff zu verwenden) in die Beschreibung der Auswirkungskriterien für die Kategorien auf. Wir stellen die EVITA-Klassifizierung in Tab. 6.9 vor. Der Inhalt, der sich auf die Skalierbar-

Tab. 6.9 Schweregradklassifizierung aus Tab. 4 von EVITA D2.3 [41]

Sicherheits- bedrohung Schweregrad	Aspekte der Sicherheitsbedrohungen			
	Safety	Privatsphäre	Finanzen	Betrieb
0	Keine Verletzungen	Kein unbefugter Zugriff auf Daten	Kein finanzieller Verlust	Keine Auswirkung auf die operative Leistung
1	Leichte oder mäßige Verletzungen	Nur anonyme Daten (keine spezifischen Daten über den Fahrer des Fahrzeugs)	Niedriger Verlust (~ 10)	Für den Fahrer nicht erkennbare Auswirkungen
2	Schwere Verletzungen (Überleben wahrscheinlich) Leichte/ mittelschwere Verletzungen für mehrere Fahrzeuge	Identifikation des Fahrzeugs oder des Fahrers Anonyme Daten für mehrere Fahrzeuge	Moderater Schaden (~ 100) Geringe Verluste für mehrere Fahrzeuge	Fahrer ist sich der Leistungsver-schlechterung bewusst Nicht wahrnehmbare Auswirkungen für mehrere Fahrzeuge
3	Lebensbedrohliche (Überleben ungewiss) oder tödliche Verletzungen Schwere Verletzungen bei mehreren Fahrzeugen	Verfolgung des Fahrers oder des Fahrzeugs Identifikation des Fahrers oder des Fahrzeugs, für mehrere Fahrzeuge	Schwerer Schaden (~ 1000) Moderate Schäden bei mehreren Fahrzeugen	Erhebliche Auswirkungen auf die Leistung Spürbare Auswirkungen für mehrere Fahrzeuge
4	Lebensbedrohliche oder tödliche Verletzungen bei mehreren Fahrzeugen	Fahrer- oder Fahrzeugverfolgung bei mehreren Fahrzeugen	Schwere Verluste bei mehreren Fahrzeugen	Erhebliche Auswirkungen bei mehreren Fahrzeugen

keit bezieht, in diesem Fall, wenn mehrere Fahrzeuge betroffen sind, findet sich in den Schweregraden zwei und drei. Wir haben diese hervorgehoben. Beachten Sie, dass der Text, der die Auswirkungen auf mehrere Fahrzeuge beschreibt, der unten stehenden Schweregradklasse entspricht. Bei der Einstufung des Schweregrads wird eine Bedrohung, die sich auf mehrere Fahrzeuge auswirkt, nach der nächsthöheren Schweregradklasse eingestuft. Hat die Bedrohung beispielsweise den Privatsphäre-Wert *Nur anonyme Daten*, wird sie mit dem Schweregrad eins eingestuft. Hätte die Bedrohung jedoch die Privatsphäre-Rate *Nur anonyme Daten*, beträfe aber mehrere Fahrzeuge statt nur einem Fahrzeug, dann würde die Bedrohung einen Schweregrad von zwei statt von eins haben.

Trotz der oben genannten Beispiele von EVITA gibt es unseres Wissens weder einen allgemeinen Konsens noch sind praktische Ansätze für die Anwendung der Skalierbarkeit auf die Risikobewertung in der Automobilindustrie bekannt. Aus diesem Grund verfolgen wir dieses Konzept nicht weiter. Skalierbarkeit kann jedoch bei der Modellierung von Bedrohungen für die IT-/OT-Analyse angewendet werden. Wir haben in Tab. 6.8 gezeigt, wie der betriebliche Schaden (basierend auf IEC 62443) für eine Produktionsanlage durch das Ausmaß des Angriffs beeinflusst werden kann (z. B. wenn nur ein Standort betroffen ist oder wenn mehrere Standorte betroffen sind).

Die Anwendung der Skalierbarkeit bei der Analyse des Verkehrsteilnehmers kann zum Beispiel eine Diskussion darüber auslösen, ob es akzeptabel oder sogar sinnvoll ist, die Auswirkungen zu bewerten, wenn ein oder mehrere Verkehrsteilnehmer betroffen sind. Bei Schäden für Unternehmen könnte es beispielsweise sinnvoll sein, die Auswirkungen auf den Ruf zu berücksichtigen. Während ein ferngesteuerter Angriff auf ein einzelnes Fahrzeug wahrscheinlich nicht über die lokalen Medien hinaus wahrgenommen wird, kann ein flottenweiter Angriff schnell in den globalen Medien veröffentlicht werden. Andererseits sind die Auswirkungen auf die Verkehrsteilnehmer möglicherweise nicht direkt von der Skalierbarkeit betroffen. So ist beispielsweise das menschliche Leben das wichtigste Gut, das es zu schützen gilt. In diesem Fall könnte es vertretbar sein, die Kriterien für die Auswirkungen auf die funktionale Sicherheit im Hinblick auf die Skalierbarkeit des Angreifers zu ändern.

6.5 Praktische Fallstudien

Wir fahren mit denselben Fallstudien fort, die in Kap. 5 beschrieben wurden. Wir haben den Scope jeder Fallstudie bereits in Kap. 5 definiert, und in diesem Abschnitt identifizieren wir die relevanten Assets und Schadensszenarien für jede Fallstudie. Die Liste der Assets und Schadensszenarien ist aus Platzgründen nicht erschöpfend. Vielmehr werden Beispiele aus der Praxis für die häufigsten Assets und Schadensszenarien angeführt.

6.5.1 Fallstudie 1: Eingebettetes Fahrzeugsteuergerät

Im Abschn. 5.7.1 haben wir den Scope unserer TARA-Fallstudie definiert, einschließlich einer Beschreibung der Betriebsumgebung der Head-Unit ECU. Auf der Grundlage der Analyse der Schnittstellen der Head-Unit in Kombination mit der Betriebsumgebung können mehrere Assets identifiziert werden. Wie in Abb. 6.2 dargestellt, folgen wir den interaktiven Schritten des Asset-Identifikationsprozesses. In diesem Buch können wir nicht alle Schritte simulieren, aber wir gehen davon aus, dass der Prozess eine gemeinsame Analyse mit verschiedenen Experten beinhaltet, die die Details der Head-Unit kennen. Der Asset-Identifikationsprozess umfasst auch die Berücksichtigung möglicher Bedrohungen und Schadensszenarien. Unser Head-Unit-Steuergerät verfügt beispielsweise über High-Connectivity-Fähigkeiten, wie den direkten Zugang zum Internet, und tauscht Daten mit dem Rest des Fahrzeugs aus. Außerdem verfügt es über Diagnoseschnittstellen. Ein Ausgangspunkt für die Identifikation von Assets könnte sein, zu untersuchen, welche negativen Folgen es für den Verkehrsteilnehmer haben könnte, wenn es jemandem gelingt, über eine Diagnoseschnittstelle manipulierte Software einzuschleusen. Oder noch schlimmer: Was wäre, wenn manipulierte Software-Updates über das Internet eingespielt werden könnten? Ausgehend von diesen beiden trivialen Fragen lassen sich bereits einige Assets identifizieren, wie z. B. das Software-Update (als Softwarepaket oder als Update-System) oder die Diagnoseschnittstellen. Die Liste der Assets und ihrer relevanten Cybersecurity-Eigenschaften ist in Tab. 6.10 und 6.11 dargestellt.

Zusammen mit der Identifikation der relevanten Assets müssen an dieser Stelle auch die Schadensszenarien für unsere TARA-Fallstudie identifiziert und beschrieben werden. In Tab. 6.12 stellen wir eine Liste von beispielhaften Schadensszenarien für den Verkehrsteilnehmer vor. Einige Schadensszenarien wurden möglicherweise bereits bei der Betrachtung der Assets und möglicher Bedrohungen im Bereich der Cybersecurity identifiziert. Der Vollständigkeit halber könnte ein praktischer Ansatz zur Ableitung der Schadensszenarien folgender sein: Für jedes in Tab. 6.10 und 6.11 identifizierte Asset analysieren wir, welche Schadensszenarien identifiziert werden können, wenn die Cybersecurity-Eigenschaften des Assets irgendwie kompromittiert werden. An dieser Stelle ist es nicht klar und auch nicht wichtig, genau zu wissen, welche Bedrohungen und Angriffspfade tatsächlich möglich sind. Die entscheidende Frage lautet: Welcher Schaden kann dem Verkehrsteilnehmer entstehen, wenn die Cybersecurity-Eigenschaften des Assets in irgendeiner Weise beeinträchtigt werden? Die durch die Asset-Identifikation bereits identifizierten Schadensszenarien sowie Schadensszenarien aus Katalogen und älteren TARA-Projekten können durchaus analysiert und in die aktuelle TARA aufgenommen werden.

Tab. 6.10 Liste der Assets und Cybersecurity-Eigenschaften für unsere Fallstudie 1

Asset [WP-15-02]	Kommentar/Relevante Cybersecurity-Eigenschaft für das Asset und Begründung der Relevanz
CAN für Diagnosezwecke	Angenommen, ein CAN-Bus wird in der Werkstatt nur für Diagnosezwecke verwendet. Software-Updates sind über diesen Bus möglich Verfügbarkeit: Die Dienste müssen bei Bedarf verfügbar sein, insbesondere für Diagnosezwecke Authentizität: Aufgrund leistungsfähiger Diagnosefunktionen wie Software-Updates muss das Werkzeug, das eine Kommunikation initiiert, seine Authentizität nachweisen
JTAG	Authentizität: Ähnlich wie bei der CAN-Diagnose bietet eine JTAG-Schnittstelle leistungsstarke Debugging-Funktionen. Daher soll der Zugriff auf JTAG authentifiziert sein
USB	Authentizität: Die Head-Unit kann einige Komfortfunktionen über eine USB-Schnittstelle ermöglichen, z. B. das Übertragen von Musik und Videos von einem externen Gerät. Auch Software-Updates über USB sind möglich. In diesem Fall muss das Steuergerät der Head-Unit die Authentizität des Geräts überprüfen, bevor es den Schreibzugriff erlaubt
WLAN/Cellular/ Bluetooth	Diese Schnittstellen bieten Internet-Konnektivität und ermöglichen Komfortfunktionen für die Fahrgäste im Fahrzeug Vertraulichkeit: Sie ist aufgrund der Offenheit von RF-Signalen wichtig. Darüber hinaus ist zu erwarten, dass sensible Daten wie personenbezogene und personenbeziehbare Daten oder Software-Updates über diese Schnittstellen übertragen werden Integrität: Die Datenübertragung darf nicht manipuliert werden, oder zumindest müssen Manipulationen erkennbar sein Verfügbarkeit: Der Zugang zum Internet und zu Backend-Diensten ist eine Kernfunktion einer modernen Head-Unit. Die Verfügbarkeit der drahtlosen Konnektivität muss gewährleistet sein Authentizität: Auch wenn Authentizität auf verschiedenen Kommunikationsebenen erforderlich sein kann, ist sie eine wesentliche Eigenschaft, die mit anderen Eigenschaften wie der Vertraulichkeit zusammenhängt
Ethernet	Die Ethernet-Schnittstelle stellt Dienste von der Head-Unit-ECU für den Rest des Fahrzeugs bereit. So werden beispielsweise Software-Updates oder Diagnosedienste über Ethernet übertragen Vertraulichkeit: Einige Dienste erfordern den Schutz der Datenvertraulichkeit Integrität: Die Datenintegrität muss gewährleistet sein, zumindest bei kritischen Diensten wie Software-Updates Verfügbarkeit: Die Schnittstelle stellt wichtige Funktionen für den Rest des Fahrzeugs bereit, wie z. B. die Positionsbestimmung über GNSS, und daher muss eine hohe Verfügbarkeit gewährleistet sein Authentizität: Ähnlich wie bei der Vertraulichkeit und Integrität ist bei kritischen Diensten Authentizität erforderlich

Tab. 6.11 (Fortsetzung) Liste der Assets und Cybersecurity-Eigenschaften für unsere Fallstudie 1

Asset [WP-15-02]	Kommentar/Relevante Cybersecurity-Eigenschaft für das Asset und Begründung der Relevanz
Anwendungs- software	Software, die im SoC für die Videoverarbeitung und im SoC für Konnektivitätsfunktionen verwendet wird Integrität: Die Integrität von Software ist entscheidend, um verschiedene Arten von Bedrohungen zu verhindern Verfügbarkeit: Die Software stellt die Kernfunktionalität der Head-Unit bereit, daher ist die Verfügbarkeit entscheidend Authentizität: Nicht nur der Schutz der Integrität ist entscheidend, sondern das Steuergerät muss auch garantieren, dass die Software, die es ausführt, authentisch ist
Software- Updates	Integrität: Es darf nicht möglich sein, ein Software-Update zu verändern Authentizität: Es ist wichtig, dass Software-Updates vom tatsächlichen Ersteller des Updates stammen, d. h. von der Softwareabteilung des OEM oder des Lieferanten Nichtabstreitbarkeit: Software-Updates führen zu erheblichen Änderungen der Funktionen der Head-Unit, z. B. zu einer anderen Handhabung von personenbezogenen Daten. Daher muss nachprüfbar sein, dass eine Softwareaktualisierung mit Zustimmung des Benutzers durchgeführt wurde und wer die Aktualisierung veranlasst hat Rechenschaftspflicht: Der Anbieter des Software-Updates muss im Falle einer Fehlfunktion der neuen Software mitverantwortlich sein
Geheime Schlüssel	Vertraulichkeit: Geheime Schlüssel, insbesondere private und symmetrische Schlüssel, müssen per Definition vertraulich sein Integrität: Die Head-Unit-ECU verlässt sich für verschiedene Zwecke auf Schlüssel, z. B. zur Überprüfung der Software-Authentizität und zur Verschlüsselung der Kommunikation. Daher ist die Integrität für den ordnungsgemäßen Betrieb unerlässlich Verfügbarkeit: Ähnlich wie die Integrität ist auch die Verfügbarkeit der Schlüssel für den korrekten Betrieb verschiedener Funktionen unerlässlich Authentizität: Die Authentizität der Schlüssel muss gewährleistet sein, insbesondere wenn Schlüsselaktualisierungen geplant sind
Konfigurations- parameter	Annahme von Konfigurationsparametern, wie z. B. Variantencodierung, die während der Ersteinrichtung des Steuergeräts durchgeführt werden Integrität: Die vom OEM oder Lieferanten bereitgestellte Konfiguration darf nicht verändert werden, um Betrug zu verhindern
Kameradaten	Die Head-Unit verarbeitet Videodaten von verschiedenen Kameras rund um das Fahrzeug Vertraulichkeit: Videosequenzen können personenbezogene und personenbeziehbare Daten oder andere sensible Informationen enthalten und müssen vor dem Verlust der Vertraulichkeit geschützt werden Integrität: Die Integrität von Videodaten ist wichtig, um verschiedene Arten des Missbrauchs zu verhindern, wie z. B. das Löschen oder Verändern von Teilen von Videosequenzen Verfügbarkeit: Dienste, die auf Kameras angewiesen sind, erfordern volle Verfügbarkeit Authentizität: Die Authentizität kann sich z. B. darauf beziehen, dass sichergestellt ist, dass die Daten von der Head-Unit verarbeitet wurden

Neben den Schadensszenarien für den Verkehrsteilnehmer sind wir auch daran interessiert, die negativen Auswirkungen von Bedrohungen für die OEMs zu analysieren, die Fahrzeuge mit dem Steuergerät im Scope produzieren. Aus diesem Grund präsentieren wir in Tab. 6.13 eine Liste von Schadensszenarien für den OEM. Wir betonen, dass die Analyse von Schadensszenarien, die nicht den Verkehrsteilnehmer betreffen, nicht Bestandteil des Standards ISO/SAE 21434 ist. Wie bei vielen realen Projekten ist es jedoch wichtig, die Risiken für den OEM oder Zulieferer aus geschäftlicher Sicht zu kennen. Die Harmonisierung der nachteiligen Auswirkungen auf die Cybersecurity eines Verkehrsteilnehmers bei gleichzeitiger Zulassung der TARA gemäß ISO/SAE 21434 mit den nachteiligen Auswirkungen auf das Unternehmen zielt auf eine Verbesserung der allgemeinen Cybersecurity-Governance ab. In beiden Fällen erfolgte die Bewertung der Folgenabschätzung anhand der im Abschn. 6.4.2 beschriebenen Kriterien. Die in diesem Abschnitt aufgeführten Schadensszenarien sind Beispiele aus der Praxis. Aus Platzgründen ist die Liste jedoch nicht erschöpfend. Eine vollständigere Liste von Schadensszenarien findet sich im Anhang A.2.

6.5.2 Fallstudie 2: Fahrzeug-Backend-Architektur

Unsere zweite Fallstudie betrachtet die Interaktion eines vernetzten Fahrzeugs mit seinem Ökosystem. Wir folgen der in Abschn. 5.7.2 beschriebenen Definition des Scopes. Die Fallstudie zielt darauf ab, nachteilige Situationen für das gesamte Fahrzeug-Backend-System zu analysieren, insbesondere aber Bedrohungen für Daten. Die Identifikation der Assets folgt den gleichen allgemeinen Schritten wie in Abb. 6.2 dargestellt. Eine Reihe von Assets in Form von Diensten und Daten lässt sich leicht aus der Betriebsumgebung ableiten. Zum Beispiel Dienste für Ferndiagnose und Unterhaltung. Diese Dienste stützen sich auf sensible Daten, die im Fahrzeug gespeichert sind, wie z. B. Zahlungsinformationen. Wir identifizieren und listen die Assets einschließlich ihrer Cybersecurity-Eigenschaften in Tab. 6.14 und 6.15 auf.

Wie tief geht die Identifikation von Assets? Es ist wichtig zu beachten, dass sich die Assets in dieser Fallstudie auf der Systemebene befinden. In diesem Fall betrachten wir z. B. die internen Elemente des Fahrzeugs nicht als Assets. Sensible Daten sind ein Asset, und zwar in zwei Formen: 1) sensible Daten, die im Fahrzeug gespeichert sind, und 2) sensible Daten, die sich auf dem Weg vom Fahrzeug zum Backend und umgekehrt befinden. Das Ziel der TARA in diesem Beispiel ist es, Systemziele für das Fahrzeug bereitzustellen. Für das Beispiel der sensiblen Daten legen wir in der Asset-Identifikation fest, dass diese sensiblen Daten vor unbefugter Manipulation geschützt gespeichert werden müssen. Im nächsten Schritt der TARA, dem Mapping von Bedrohungsszenarien, wird es sicherlich Bedrohungen mit Angriffspfaden geben, die ihren Ursprung in der Manipulation eines fahrzeuginternen Elements haben. Das Ergebnis der Analyse dieses Fallbeispiels kann zum Beispiel ein Cybersecurity-Ziel sein, das den Schutz sensibler Daten bei der Speicherung

Tab. 6.13 Liste der Schadensszenarien und Bewertung des Schadens, bezogen auf die OEM Sicht, für unsere Fallstudie 1

Schadensszenario [WP-15-01]		Bewertung des Schadens [WP-15-04]						
		OEM-Ansicht						
		Geistiges Eigentum	Kommentar	Image/ Reputation	Kommentar	Finanzen	Kommentar	Betrieb
Fahrzeug oder Komponente (z. B. ECU) wird beschädigt	Vernachlässigbar	Keine Auswirkung	Moderat	Keine schwerwiegenden Auswirkungen auf das Image	Moderat	Software-Patch	Vernachlässigbar	Produktion nicht betroffen
Sensoren/ Warnsysteme liefern falsche Informationen	Vernachlässigbar	Keine Auswirkung	Erheblich	Öffentliche Meldung	Moderat	Rückerstattung in einigen Fällen	Vernachlässigbar	Produktion nicht betroffen
Offenlegung personenbezogener Daten	Vernachlässigbar	Keine Auswirkung	Schwerwiegend	Problem muss gemeldet werden, es wird öffentlich	Erheblich	Hoher Schaden, wenn mehrere Fahrzeuge betroffen sind	Moderat	Kurzer Stopp der Softwareaktualisierung möglich
Nichtverfügbarkeit von nicht sicherheitsrelevanten Informationen (z. B. Verkehrsinformationen, Musik, Adressbuch)	Vernachlässigbar	Keine Auswirkung	Moderat	Keine schwerwiegenden Auswirkungen auf das Image	Moderat	Software-Patch	Vernachlässigbar	Produktion nicht betroffen
Veröffentlichung der Schwachstelle	Moderat	Code könnte zurückentwickelt werden	Erheblich	Präsentation in öffentlichem Bericht/ Konferenz	Moderat	Software-Patch	Moderat	Kurzer Stopp zur Aktualisierung der Software möglich

Tab. 6.14 Liste der Assets und Cybersecurity-Eigenschaften für unsere Fallstudie 2

Asset [WP-15-02]	Kommentar/Relevante Cybersecurity-Eigenschaft für das Asset und Begründung der Relevanz
Diagnosewerkzeuge/ Daten	Integrität: Die Manipulation von Diagnosemeldungen kann negative Folgen haben, insbesondere bei Schreibvorgängen. Eine Manipulation sollte nicht möglich sein, oder zumindest erkannt werden Authentizität: Das Steuergerät muss sicher sein, dass das Diagnosewerkzeug, das versucht, mit ihm zu kommunizieren, eine autorisierte Einheit ist
Ferndiagnose	Vertraulichkeit: Diagnosemeldungen können personenbezogene oder technische Daten enthalten, die für Außenstehende aus verschiedenen Gründen von Interesse sein können. Ein unbefugter Zugriff auf diese Daten, insbesondere während der Übertragung, muss jedoch verhindert werden Integrität: Die Manipulation von Diagnosemeldungen kann nachteilige Folgen haben, insbesondere bei Schreibvorgängen. Eine Manipulation sollte unmöglich sein oder zumindest erkannt werden können Verfügbarkeit: Die Ferndiagnose muss vom System aus verfügbar sein, was eine operative Anforderung darstellt Authentizität: Aufgrund seines Ferncharakters darf das Steuergerät Diagnosedienste nur für vertrauenswürdige Bediener zulassen
Standortdienste	Integrität: Das Steuergerät bietet genaue Standortdienste und sollte nicht manipuliert werden. Die Ortung kann aus mehreren Quellen stammen, und Manipulationen müssen erkannt werden Verfügbarkeit: Standortdienste müssen für Anwendungen, die auf sie angewiesen sind, verfügbar sein. Die Verfügbarkeit kann z. B. dadurch sichergestellt werden, dass mehrere Quellen zur Bestimmung der Fahrzeugposition zur Verfügung stehen
OEM-Cloud-Dienste	Vertraulichkeit: Es ist eine gute Praxis, bei der Übertragung sensibler Daten eine Ende-zu-Ende-Vertraulichkeit zu gewährleisten. Dies ist besonders bei der drahtlosen Kommunikation wichtig Integrität: Übertragene Daten müssen vor unbefugter Manipulation geschützt werden Verfügbarkeit: Auch wenn die OEM-Cloud-Dienste nicht kritisch für den Betrieb der Head-Unit oder des Fahrzeugs sind, erwartet der Nutzer die volle Verfügbarkeit der Komfortdienste Authentizität: Wesentliche Eigenschaft zur Vermeidung von Phishing oder Bedrohungen im Zusammenhang mit der Adressierung bössartiger Server Nichtabstreitbarkeit: In unserem Beispiel eine notwendige Eigenschaft aus rechtlichen oder kommerziellen Gründen (z. B. wenn der Benutzer Funktionen aus der Ferne aktivieren kann.) Rechenschaftspflicht: ähnlich wie Nichtabstreitbarkeit, in unserem Beispiel eine notwendige Eigenschaft aus rechtlichen oder kommerziellen Gründen (z. B. wenn der Nutzer Funktionen aus der Ferne aktivieren kann)

Tab. 6.15 (Fortsetzung) Liste der Assets und Cybersecurity-Eigenschaften für unsere Fallstudie 2

Asset [WP-15-02]	Kommentar/Relevante Cybersecurity-Eigenschaft für das Asset und Begründung der Relevanz
Cloud-Dienste von Dritten	Vertraulichkeit: Es ist eine gute Praxis, bei der Übertragung sensibler Daten die Vertraulichkeit von Ende zu Ende zu gewährleisten. Dies ist besonders wichtig für die drahtlose Kommunikation Integrität: Übertragene Daten müssen vor unbefugter Manipulation geschützt werden Verfügbarkeit: Auch wenn die Cloud-Dienste von Drittanbietern nicht kritisch für den Betrieb der Head-Unit oder des Fahrzeugs sind, erwartet der Nutzer die volle Verfügbarkeit der Komfortdienste Authentizität: Ein wesentliches Merkmal, um Phishing oder Bedrohungen im Zusammenhang mit der Adressierung bösartiger Server zu vermeiden Nichtabstreitbarkeit: In unserem Beispiel eine notwendige Eigenschaft aus rechtlichen oder kommerziellen Gründen (z. B. wenn der Benutzer Funktionen aus der Ferne aktivieren kann.) Rechenschaftspflicht: Ähnlich wie die Nichtabstreitbarkeit, in unserem Beispiel eine notwendige Eigenschaft aus rechtlichen oder kommerziellen Gründen (z. B. wenn der Benutzer Funktionen aus der Ferne aktivieren kann)
Im Fahrzeug gespeicherte sensible Daten	Vertraulichkeit: Sensible Daten müssen vor unberechtigt Zugriff geschützt werden. Dies wird in der Regel durch eine Verschlüsselung der Daten erreicht, sodass bei einem physischen Zugriff auf das Speichergerät und die Speicherknödel die Daten geheim bleiben Integrität: Der Schutz der Integrität kann auf jede Art von Daten angewendet werden. Sensible Daten können für kritische Vorgänge verwendet werden und müssen daher vor Manipulationen geschützt werden
Sensible Daten bei der Übertragung	Authentizität: Je nach Daten kann es erforderlich sein, die Authentizität der Daten und ihres Besitzers nachzuweisen Vertraulichkeit: Sensible Daten müssen auch während des Transports vor unberechtigt Zugriff geschützt werden Integrität: Es muss möglich sein, Manipulationen von Daten während der Übertragung zu erkennen. Dies ist besonders wichtig für Daten, die für den Betrieb oder für den kommerziellen oder persönlichen Gebrauch kritisch sind Authentizität: Je nach Daten kann es erforderlich sein, die Authentizität der Daten und ihres Besitzers nachzuweisen

im Fahrzeug fordert. Die internen Elemente des Fahrzeugs, wie z. B. eine ECU oder ein CAN-Bus, sind keine Assets für den Scope dieser Fallstudie. Das Ziel einer TARA auf dieser Ebene ist es, High-Level Cybersecurity-Ziele für ein ganzes System festzulegen. Dies ist nützlich für komplexe Szenarien, wie in diesem Beispiel, in dem verschiedene Systeme von verschiedenen Anbietern dieselben Assets, wie z. B. *Daten*, nutzen. Ziele auf Systemebene können an die für die verschiedenen Elemente des Systems verantwortlichen Stellen weitergegeben werden, z. B. Backend-Anbieter, Mobiltelefonarchitekten und Automobilhersteller. Eine TARA auf niedrigerer Ebene, oder Elementebene, kann für jedes der einzelnen Elementen des Systems durchgeführt werden, wobei die zuvor definierten Cybersecurity-Ziele auf Systemebene berücksichtigt werden. Die Beziehung zwischen den Cybersecurity-Zielen auf Systemebene und den Elementen und dem Scope der TARA ist in Abb. 6.4 dargestellt.

Wir analysieren die Schadensszenarien für die dem Verkehrsteilnehmern entstandenen Schäden, wie es von ISO/SAE 21434 gefordert wird. Darüber hinaus werden in der TARA-Fallstudie die nachteiligen Folgen von Cybersecurity-Risiken aus denselben Schadensszenarien für das OEM und für den Drittanbieter dargestellt. Unser Ziel ist es zu zeigen, wie eine TARA, die in erster Linie zur Erfüllung von ISO/SAE 21434 verwendet wird, für die Analyse anderer Schäden und Bereiche einer Organisation äußerst nützlich sein kann. In Tab. 6.16 zeigen wir die Schadensszenarien und ihre Bewertung des Schadens für den Verkehrsteilnehmer. Wir analysieren die Bewertung des Schadens für die OEM-Sicht in Tab. 6.17 und

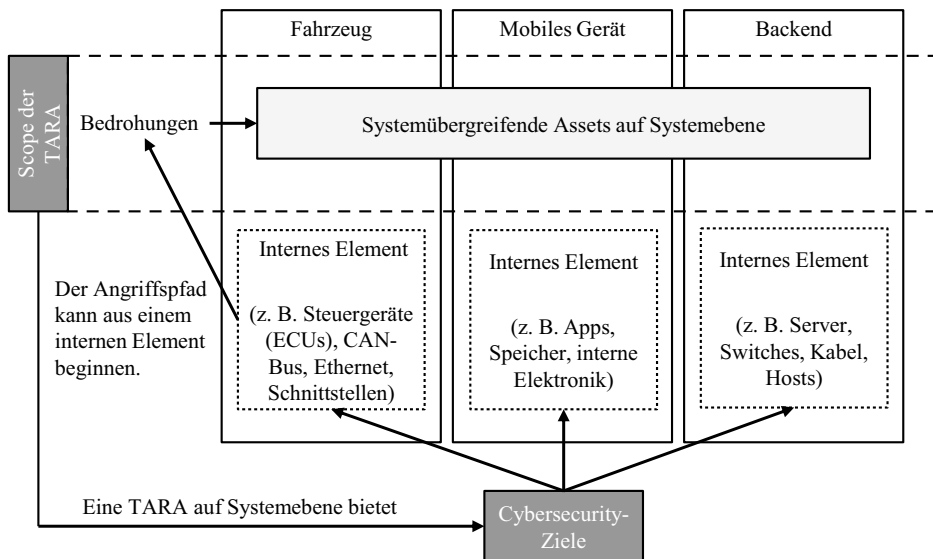


Abb. 6.4 Beziehung zwischen Assets auf Systemebene, Elementen des Systems und Cybersecurity-Ziele

Tab. 6.16 Liste der Schadensszenarien und Bewertung des Schadens aus der Sicht der Verkehrsteilnehmer für unsere Fallstudie 2

Schadensszenario [WP-15-01]	Bewertung des Schadens [WP-15-04]							
	Verkehrsteilnehmer-Ansicht							
	Sicherheit	Kommentar	Finanzen	Kommentar	Betrieb	Kommentar	Privatsphäre	Kommentar
Fahrzeug verlässt Fahrbahn oder eingeschränkte Manövrierfähigkeit	Schwer- wiegend	Kollisions- /Absturzgefahr	Erheblich	Hohe Kosten aufgrund von Infrastrukturschä- den und Krankenhausauf- enthalten	Schwerwiegend	Fahrzeug ist nicht betriebsbereit	Vernachlässigbar	Keine Auswirkung
Offenlegung von geschäftsfür- relevanten Daten	Vernachläs- sigbar	Keine Auswirkung	Vernachläs- sigbar	Keine Auswirkung	Vernachlässigbar	Keine Auswirkung	Vernachlässigbar	Keine Auswirkung
Inanspruchnahme von Dienstleistungen ohne gültige Lizenz	Vernachläs- sigbar	Keine Auswirkung	Moderat	Bußgelder, oder zu viel für die Dienstleistung bezahlen	Vernachlässigbar	Keine Auswirkung	Vernachlässigbar	Keine Auswirkung
Ferngesteuerte Dienstleistungen nicht verfügbar	Vernachläs- sigbar	Keine Auswirkung	Moderat	Reparaturen und Zeit	Erheblich	Dienste funktionieren nicht wie erwartet	Vernachlässigbar	Keine Auswirkung
Nicht autorisierte Software/Daten, die im Fahrzeug installiert sind	Erheblich	Software könnte Sicherheitsfunk- tionen des Fahrzeugs außer Kraft setzen	Moderat	Reparaturen und Zeit	Erheblich	Betrieb der Software beeinträchtigt	Vernachlässigbar	Keine Auswirkung

für den Drittanbieter in Tab. 6.18. Der Drittanbieter wird für Online-Dienste verwendet, die im Fahrzeug installiert werden können, wie z. B. eine Musik- oder Hörbuchanwendung. Im Folgenden finden Sie eine kurze Beschreibung unserer Schadensszenarien und ein Beispiel für einen möglichen Angriffspfad:

- Fahrzeug verlässt Fahrbahn oder eingeschränkte Manövrierfähigkeit: Das Fahrzeug lenkt automatisch und ignoriert das Lenkrad. Ein Angreifer überwindet das zentrale Gateway des Fahrzeugs und erhält Zugang zu den Steuergeräten für Lenkung und Bremsen. Der Angreifer kann speziell gestaltete CAN-Nachrichten an diese Steuergeräte senden.
- Offenlegung von geschäftsrelevanten Daten: Beispiele für geschäftsrelevante Daten können Verkaufsinformationen sein, wie die Anzahl der in einem bestimmten Monat produzierten Fahrzeuge. Diese Informationen können aus IDs oder Zählern abgeleitet werden, die während der Produktion im Fahrzeug gespeichert werden. Der Kilometerzähler könnte auch als Indikator verwendet werden.
- Nutzung von Diensten ohne gültige Lizenz: Eines der Geräte oder Anwendungen, die eine Verbindung zu externen Diensten herstellen, wurde kompromittiert, und der Angreifer kann ohne gültige Lizenz auf Dienste und Funktionen zugreifen.
- Ferngesteuerte Dienste nicht verfügbar: Dienste, die direkt von der Head-Unit im Fahrzeug, von anderen Komponenten des Fahrzeugs oder von einer externen Anwendung aufgerufen werden, sind teilweise oder vollständig nicht verfügbar.
- Nicht autorisierte Software/Daten, die im Fahrzeug installiert sind: Der Angreifer verschafft sich Zugang zu den Schreibdiagnosefunktionen des Fahrzeugs und ist in der Lage, manipulierte Software zu installieren. Die Installation erfolgt entweder aus der Ferne, über OEM- und Drittanbieterdienste, oder lokal.

6.5.3 Fallstudie 3: Automobilproduktionsanlage

In dieser Fallstudie konzentrieren wir uns auf Produktionsanlagen. Das Item von TARA sind die Fertigungsanlagen, einschließlich ihrer Maschinen und Produktionslinien. Ähnlich wie bei Fallstudie 2 liegt der Schwerpunkt dieser Fallstudie auf Komponenten auf Systemebene. Das Ziel der TARA ist es, Risiken in einer Produktionsanlage während des normalen Betriebs zu identifizieren und Cybersecurity-Ziele für die Komponenten, wie z. B. interne Server, Flash-Stationen oder das produzierte Steuergerät, zu erstellen. Daher betrachten wir die Assets auf Komponentenebene. Wir betrachten die Maschinen in der Produktionsanlage, einschließlich ihrer Schnittstellen, aber wir konzentrieren uns nicht weiter auf die Assets innerhalb der Maschinen. Die Definition des Scopes wird in Abschn. 5.7.3 beschrieben. Die für diese Fallstudie identifizierten Assets sind in Tab. 6.19, 6.20 und 6.21 zusammengefasst.

Tab. 6.18 Liste der Schadensszenarien und Bewertung des Schadens, die die Sichtweise des Drittanbieters betreffen, für unsere Fallstudie 2

Schadensszenario [WP-15-01]	Bewertung des Schadens [WP-15-04]						
	Drittanbieter-Ansicht						
	Geistiges Eigentum	Kommentar	Image/ Reputation	Kommentar	Finanzen	Kommentar	Betrieb
Fahrzeug verlässt Fahrbahn oder eingeschränkte Manövrierfähigkeit	Vernachlässigbar	Keine Auswirkung	Vernachlässigbar	Keine Auswirkung	Vernachlässigbar	Keine Auswirkung	Vernachlässigbar
Offenlegung von geschäftsrelevanten Daten	Erheblich	Anbieterdaten könnten offengelegt werden	Moderat	Anwendungs-patches könnten erforderlich sein	Vernachlässigbar	Keine Auswirkung	Vernachlässigbar
Nutzung von Dienstleistungen ohne gültige Lizenzen	Vernachlässigbar	Keine Auswirkung	Vernachlässigbar	Keine Auswirkung	Vernachlässigbar	Keine Auswirkung	Vernachlässigbar
Ferngesteuerte Dienste nicht verfügbar	Vernachlässigbar	Keine Auswirkung	Moderat	Unzufriedene Kunden Image des Drittanbieters beeinträchtigt	Moderat	Software-Patches	Vernachlässigbar
Nicht autorisierte Software/Daten, die im Fahrzeug installiert sind	Vernachlässigbar	Keine Auswirkung	Vernachlässigbar	Keine Auswirkung	Vernachlässigbar	Keine Auswirkung	Vernachlässigbar

Tab. 6.19 Liste der Assets und Cybersecurity-Eigenschaften für unsere Fallstudie 3

Asset [WP-15-02]	Kommentar/Relevante Cybersecurity-Eigenschaft für das Asset und Begründung der Relevanz
Debug-/Diagnoseschnittstellen an der Flash-Station, der Produktionslinie und am Ende der Linie	Integrität: Die Integrität des Datenaustauschs zwischen einem legitimen Client (lokal oder remote) und der Diagnoseschnittstelle muss gewährleistet sein, um Manipulationen zu verhindern oder zu erkennen Verfügbarkeit: Die Diagnosedienste müssen zuverlässig sein, um im Falle eines Ausfalls Ausfallzeiten zu verhindern Authentizität: Nur vertrauenswürdige Stellen sollten Zugang zu Diagnosediensten für Produktionsmaschinen haben Schnittstelle zur manuellen Aktualisierung der Software der Flash-Station
USB an Flash-Station	Integrität: Aufgrund der Kritikalität der übertragenen Daten muss eine Manipulation nachweisbar sein Authentizität: Modifikationen an der Software der Flash-Station dürfen nur von autorisiertem Personal vorgenommen werden. Eine manipulierte Flash-Station kann sogar Schadsoftware in das zu produzierende Steuergerät einschleusen
WLAN	Vertraulichkeit: Aufgrund der offenen Natur drahtloser Signale ist die Vertraulichkeit eine wesentliche Eigenschaft, um unbefugten Zugriff und verschiedene Arten von Bedrohungen zu verhindern. Selbst wenn die übertragenen Daten an sich nicht sensibel sind, wie z. B. Produktionsüberwachungsdaten, ist es notwendig, die Netzwerkpakete zu schützen Integrität: Der Schutz der Integrität von WLAN-Paketen erhöht die Robustheit und Zuverlässigkeit des Netzwerks und der Systeme, die darauf angewiesen sind Verfügbarkeit: WLAN-Netzwerke, die in Produktionsumgebungen eingesetzt werden, müssen hoch zuverlässig sein Authentizität: Die Authentifizierung der Kommunikationsteilnehmer in einem drahtlosen Netzwerk ist aufgrund seines offenen Charakters unerlässlich
Feldbus an allen Stationen	Integrität: Logistik- oder Produktionsdaten, die zwischen Maschinen ausgetauscht werden, dürfen nicht verfälscht werden Verfügbarkeit: Produktionsdaten, die zwischen Produktionsmaschinen ausgetauscht werden, sind unerlässlich und müssen in hohem Maße zuverlässig sein
Ethernet	Integrität: Obwohl dies stark von der Anwendungsschicht abhängt, sollten Produktionsdaten im Allgemeinen während der Übertragung nicht verfälscht werden Verfügbarkeit: Sie sind für die Produktion unabdingbar und müssen verfügbar sein Authentizität: Die Authentizität der Daten oder der Netzwerkgeräte, die eine Verbindung zum Netzwerk herstellen, muss gewährleistet sein, um Bedrohungen durch unbefugten Zugriff zu verhindern

Tab. 6.20 (Fortsetzung) Liste der Assets und Cybersecurity-Eigenschaften für unsere Fallstudie 3

Asset [WP-15-02]	Kommentar/Relevante Cybersecurity-Eigenschaft für das Asset und Begründung der Relevanz
Fernzugriff	Vertraulichkeit: Besonders wichtig für Daten im Transit. Der Fernzugriff zu Diagnosezwecken ist eine leistungsfähige Schnittstelle Integrität: Wesentliche Eigenschaft zur Verhinderung oder Erkennung von Manipulationen von Diagnosemeldungen während der Übertragung Verfügbarkeit: Der Fernzugriff kann genutzt werden, um bei Störungen an Produktionsmaschinen schnelle Unterstützung zu leisten. Daher ist es wichtig, eine hohe Verfügbarkeit zu gewährleisten Authentizität: Es darf nicht möglich sein, dass Unbefugte Fernzugriff auf die Produktionsanlage und die Produktionsmaschinen erhalten Nichtabstreitbarkeit: Bei kritischen Diensten wie Konfigurationsänderungen oder Softwareaktualisierungen an den Maschinen muss die Einheit, die den Fernzugriff nutzt, nachvollziehbar und eindeutig identifizierbar sein Rechenschaftspflicht: Ähnlich wie bei der Nichtabstreitbarkeit muss die Rückverfolgbarkeit zu der Einrichtung, die den Dienst nutzt, gewährleistet sein, um die Rechenschaftspflicht zu gewährleisten
Anwendungen auf Stationen und lokalen Servern	Integrität: Die Integrität der Software muss sichergestellt werden, um zu verhindern, dass Malware auf Produktionsrechnern läuft Verfügbarkeit: Für die Produktion unerlässlich Authentizität: Die auf Produktionsmaschinen installierte Software muss authentisch sein. Zumindest zum Zeitpunkt der Installation muss sichergestellt sein, dass die Software aus einer vertrauenswürdigen Quelle stammt
Software-Updates	Integrität: Der Schutz der Integrität von Software-Updates ist unerlässlich, um zu verhindern, dass Malware auf Produktionsrechnern installiert wird Authentizität: Software-Update-Pakete müssen aus vertrauenswürdigen Quellen stammen
Logistikdaten	Integrität: Der Austausch von Logistikdaten zwischen Produktionsmaschinen ist unerlässlich Verfügbarkeit: Logistikdaten müssen zuverlässig sein, denn sie sind für die Produktion unerlässlich
Lokale Server	Integrität: Die Software und Hardware lokaler Server darf nicht manipuliert werden Verfügbarkeit: Lokale Dienste, wie z. B. solche, die der ECU während der Produktion Software zur Verfügung stellen oder kritische Produktionsinformationen wie BOMs speichern, müssen hoch verfügbar sein Authentizität: Wichtig für die Software, die auf den Servern läuft, und für den Zugang zum Netzwerk

Tab. 6.21 (Fortsetzung) Liste der Assets und Cybersecurity-Eigenschaften für unsere Fallstudie 3

Asset [WP-15-02]	Kommentar/Relevante Cybersecurity-Eigenschaft für das Asset und Begründung der Relevanz
Netzwerk-Geräte	Integrität: Die Soft- und Hardware von Netzwerk-Geräten darf nicht manipuliert werden Verfügbarkeit: Netzwerk-Geräte sind für die Produktion unerlässlich und müssen verfügbar sein Authentizität: Die Erzwingung von Authentizitätsprüfungen für Geräte, die eine Verbindung zum Netzwerk herstellen, ist notwendig, um Bedrohungen im Zusammenhang mit unbefugtem Zugriff zu verhindern. Darüber hinaus muss der Zugriff auf die Geräte, z. B. zu Konfigurationszwecken, von vertrauenswürdigen Stellen erfolgen
Sicherheitsartefakte von Key Management Servern	Vertraulichkeit: Sicherheitsartefakte, wie z. B. private Schlüssel für SecOC Integrität: Sicherheitsartefakte sind für das ordnungsgemäße Funktionieren des Endprodukts erforderlich und dürfen nicht manipuliert werden Verfügbarkeit: Ein wesentlicher Bestandteil des Endprodukts. Die Verfügbarkeit muss gewährleistet sein Authentizität: Aufgrund ihrer Verwendung in der Cybersecurity müssen Sicherheitsartefakte aus vertrauenswürdigen Quellen stammen, wie z. B. der PKI des OEMs

Die Schadensszenarien in dieser Fallstudie konzentrieren sich auf den Schaden für den Verkehrsteilnehmer, wie in ISO/SAE 21434 gefordert, und für den Lieferanten. Wir beziehen uns auf den Zulieferer, aber nur als Beispiel. Eine ähnliche Analyse könnte auch für den OEM durchgeführt werden. Die Liste der Schadensszenarien ist aus Platzgründen nicht erschöpfend. Der Zweck der Fallstudie besteht darin, praktische Beispiele für reale Schadensszenarien zu liefern, um den Prozess besser zu verstehen. Die ausgewählten Schadensszenarien betreffen den Verkehrsteilnehmer und den Zulieferer auf unterschiedlichen Ebenen. Einige Schadensszenarien, wie z. B. das Einschleusen von Ransomware in Produktionsanlagen, werden den Verkehrsteilnehmer natürlich in keiner Weise direkt betreffen. Es ist jedoch eines der Ziele einer TARA, solche Szenarien zu berücksichtigen. Die Schadensszenarien für die Verkehrsteilnehmer sind obligatorisch, da wir die ISO/SAE 21434 erfüllen wollen. Die Schadensszenarien, die nur die Produktionsanlage betreffen, sind für die Cybersecurity-Governance relevant. Wir beschreiben die vorgeschlagenen Schadensszenarien wie folgt:

- Manipulierte Software, die in das Endprodukt (Steuergerät) eingeschleust wurde: Die Einführung von Schadsoftware in das fertige Steuergerät ist wahrscheinlich eines der schlimmsten Szenarien sowohl für den Hersteller als auch für den Verkehrsteilnehmer. Der Hersteller wird wahrscheinlich einen erheblichen finanziellen und rufschädigenden Schaden erleiden. Ransomware könnte in das Steuergerät eingeschleust werden und einige Jahre nach Produktionsbeginn ausgeführt werden, was zu massiven Rückrufaktionen führt. Der Verkehrsteilnehmer ist allen möglichen Folgen ausgesetzt, z. B. dem Verlust der Kontrolle über das Fahrzeug und dem Verlust der Privatsphäre aufgrund von Datenschutzverletzungen.
- Produktionsmaschinen und/oder lokale Server wurden mit Ransomware infiziert: Ransomware-Angriffe sind für Produktionsanlagen äußerst schädlich, da sie nicht nur zu einem erheblichen Produktionsstillstand führen, sondern auch die Privatsphäre verletzen können. Es hat mehrere Ransomware-Angriffe gegeben, bei denen bekannte Automobilunternehmen kompromittiert wurden (siehe [48]).
- Produktionsstopp länger als einen Tag: Ein längerer Produktionsausfall ist aufgrund der damit verbundenen finanziellen Verluste der Albtraum eines jeden Fertigungsunternehmens.
- Großflächige Datenpanne, einschließlich Cybersecurity-Artefakten und Logistikdaten: Großflächige Datenverletzungen können sowohl das produzierende Unternehmen als auch den Verkehrsteilnehmer betreffen. Im schlimmsten Fall werden personenbezogene Daten, einschließlich Kunden- und Mitarbeiterinformationen, und Cybersecurity-Artefakte aus der Produktionsumgebung gestohlen und von Angreifern für Erpressungen verwendet.
- Manipulierte Produktionsdaten oder Stücklisten führen zu fehlerhaften Endprodukten: Ein frustrierter Mitarbeiter oder ein Angreifer, der sich Zugang zum internen Netzwerk der Produktionsanlage verschafft, kann produktionsrelevante Informationen, z. B. in Datenbanken, manipulieren, was zur Herstellung einer fehlerhaften Produktion führt. Wenn die Manipulation sorgfältig durchgeführt wird, z. B. durch das Entfernen kleinerer Komponenten von einer Leiterplatte oder nur durch eine falsche Parametrierung einer Komponente, wird die Manipulation während der Produktion möglicherweise nicht entdeckt (Tab. 6.22 und 6.23).

Tab. 6.22 Liste der Schadensszenarien und Bewertung des Schadens, bezogen auf die Sicht der Verkehrsteilnehmer, für unsere Fallstudie 3

Schadensszenario [WP-15-01]	Bewertung des Schadens [WP-15-04]							
	Verkehrsteilnehmer-Ansicht							
	Sicherheit	Kommentar	Finanzen	Kommentar	Betrieb	Kommentar	Privatsphäre	Kommentar
Manipulierte Software, die in das Endprodukt (Steuergerät) eingeschleust wurde	Schwerwiegend	Angenommener Worst-Case und das Steuergerät übernimmt den Betrieb des Fahrzeugs, was zu einem Unfall mit Verletzungen	Erheblich	Krankenhauskosten, Reparaturkosten und Zeitverlust	Schwerwiegend	Im schlimmsten Fall funktionieren das Steuergerät und das Fahrzeug nicht wie erwartet	Vernachlässigbar	Keine Auswirkung
Produktionsmaschinen und/oder lokale Server wurden mit Ransomware infiziert	Vernachlässigbar	Keine Auswirkung	Vernachlässigbar	Keine Auswirkung	Vernachlässigbar	Keine Auswirkung	Vernachlässigbar	Keine Auswirkung
Produktionsstopp länger als einen Tag	Vernachlässigbar	Keine Auswirkung	Vernachlässigbar	Keine Auswirkung	Vernachlässigbar	Keine Auswirkung	Vernachlässigbar	Keine Auswirkung
Großflächige Datenpanne, einschließlich Cybersecurity-Artefakten und Logistikdaten	Vernachlässigbar	Keine Auswirkung	Vernachlässigbar	Keine Auswirkung	Moderat	Zeitverlust für Reparatur	Vernachlässigbar	Keine Auswirkung
Manipulierte Produktionsdaten oder Stücklisten führen zu fehlerhaften Endprodukten	Schwerwiegend	Worst-Case-Szenario, Fahrzeugunfälle mit Verletzungen	Erheblich	Krankenhauskosten, Reparaturkosten und Zeitverlust	Schwerwiegend	ECU und Fahrzeug funktionieren nicht wie erwartet	Vernachlässigbar	Keine Auswirkung

Literatur

1. Rooting Bosch lcn2kai Headunit. https://github.com/ea/bosch_headunit_root
2. Tagesschau, „Tachomanipulation bei jedem dritten Auto“ (2022). <https://www.tagesschau.de/wirtschaft/tachobetrug-autos-gebrauchtwagen-101.html>
3. ISO 9141-2:1994 Road vehicles – Diagnostic systems – Part 2: CARB requirements for interchange of digital information. Standard, International Organization for Standardization (1994). <https://www.iso.org/standard/16738.html>
4. ISO 11898-1:2015 Road vehicles- Controller area network (CAN)- Part 1: Data link layer and physical signalling. Standard, International Organization for Standardization (2005). <https://www.iso.org/standard/63648.html>
5. IEC TR 62443-3-1:2009 Industrial communication networks – Network and system security – Part 3-1: Security technologies for industrial automation and control systems. Standard, International Electrotechnical Commission (2009). <https://webstore.iec.ch/publication/7031>
6. IEC TS 62443-1-1:2009 Industrial communication networks – Network and system security – Part 1-1: Terminology, concepts and models. Standard, International Electrotechnical Commission (2009). <https://webstore.iec.ch/publication/7029>
7. IEC 62443-2-1:2010 Industrial communication networks – Network and systemsecurity – Part 2-1: Establishing an industrial automation and control system security program. Standard, International Electrotechnical Commission (2010). <https://webstore.iec.ch/publication/7030>
8. ISO 17458-1:2013 Road vehicles – FlexRay communications system – Part 1: General information and use case definition. Standard, International Organization for Standardization (2013). <https://www.iso.org/standard/59804.html>
9. AUTOSAR FO requirements on SOME/IP protocol (2016). https://www.autosar.org/fileadmin/standards/R20-11/FO/AUTOSAR_RS_SOMEIPProtocol.pdf
10. ISO 11898-2:2016 Road vehicles- Controller area network (CAN)- Part 2: High-speed medium access unit. Standard, International Organization for Standardization (2016). <https://www.iso.org/standard/67244.html>
11. ISO 14230-2:2016 Road vehicles – Diagnostic communication over K-Line (DoK-Line) - Part 2: Data link layer. Standard, International Organization for Standardization (2016). <https://www.iso.org/standard/69115.html>
12. ISO 15765-2:2016 Road vehicles – Diagnostic communication over Controller Area Network (Do-CAN) – Part 2: Transport protocol and network layer services. Standard, International Organization for Standardization (2016). <https://www.iso.org/standard/66574.html>
13. ISO 17987-1:2016 Road vehicles – Local Interconnect Network (LIN) – Part 1: General information and use case definition. Standard, International Organization for Standardization (2016). <https://www.iso.org/standard/61222.html>
14. ISO 26262:2018 Road vehicles – Functional safety, Part 1–12. Standard, International Organization for Standardization (2018)
15. ISO/IEC27000:2018 information technology – security techniques – information security management systems – overview and vocabulary. Standard, International Organization for Standardization/International Electrotechnical Commission(2018). <https://www.iso.org/standard/73906.html>
16. IEC 61158-1:2019 Industrial communication networks-Fieldbus specifications-Part 1: Overview and guidance for the IEC 61158 and IEC 61784 series. Standard, International Electrotechnical Commission (2019). <https://webstore.iec.ch/publication/59890>
17. ISO 13400-2:2019 Road vehicles – Diagnostic communication over Internet Protocol (DoIP) – Part 2: Transport protocol and network layer services. Standard, International Organization for Standardization (2019). <https://www.iso.org/standard/74785.html>

18. Regulation (EU) 2019/2144 of the european parliament and of the council of 27 november 2019 on type-approval requirements for motor vehicles and their trailers, and systems, components and separate technical units intended for such vehicles, as regards their general safety and the protection of vehicle occupants and vulnerable road users, amending regulation (EU) 2018/858 of the european parliament and of the council and repealing regulations (EC) no 78/2009, (EC) no 79/2009 and (EC) no 661/2009 of the european parliament and of the council and commission regulations (EC) no 631/2009, (EU) no 406/2010, (EU) no 672/2010, (EU) no 1003/2010, (EU) no 1005/2010, (EU) no 1008/2010, (EU) no 1009/2010, (EU) no 19/2011, (EU) no 109/2011, (EU) no 458/2011, (EU) no 65/2012, (EU) no 130/2012, (EU) no 347/2012, (EU) no 351/2012, (EU) no 1230/2012 and (EU) 2015/166 (text with EEA relevance) (2019). <https://eurlex.europa.eu/eli/reg/2019/2144/oj>
19. Guidelines 1/2020 on processing personal data in the context of connected vehicles and mobility related applications (2020). https://edpb.europa.eu/our-work-tools/documents/public-consultations/2020/guidelines-12020-processing-personal-data_en
20. BSI industrial control system security: Top 10 threats and countermeasures 2022 (2022). https://www.allianz-fuer-cybersicherheit.de/SharedDocs/Downloads/Webs/ACS/DE/BSI-CS/BSI-CS_005E.html
21. ISO 21448:2022 Road vehicles – Safety of the intended functionality. Standard, International Organization for Standardization (2022). <https://www.iso.org/standard/77490.html>
22. ISO/IEC 29100:2024 Information technology – Security techniques – Privacy framework. Standard, International Society of Automation/International Electrotechnical Commission (2024). <https://www.iso.org/standard/85938.html>
23. European Union Agency for Cybersecurity (ENISA): ENISA good practices for security of Smart Cars (2019). <https://www.enisa.europa.eu/publications/smart-cars>
24. Gelinne, J.P.: The hidden costs of an IP breach: Cyber theft and the loss of intellectual property (2016).
25. Grzempa, A.: The MOST System. Franzis Verlag GmbH (2011)
26. Hug, N., Gibson, C., Kropotov, V., Vosseler, R.: Cybersecurity for Connected Cars (2021).
27. ISO/SAE 21434:2021 Road vehicles – Cybersecurity engineering. Standard, International Organization for Standardization/Society of Automotive Engineers, Geneva, CH (2021). <https://www.iso.org/standard/70918.html>
28. Jullien, F.: Renes’hack (2021). https://www.collshade.fr/articles/reneshack/rx_glitch_article.html
29. Kreutner, M., Lauterwasser, C., Gwehenberger, J.: Investigating Accidents Involving Highly Automated Vehicles: Concept of a Data Trustee and Data Model for Future Homologation. p. 0035. National Highway Traffic Safety Administration (NHTSA) (2019). <https://www-esv.nhtsa.dot.gov/Proceedings/26/26ESV-000035.pdf>
30. Lautenbach, A., Mafijul Islam, C.: HEALing vulnerabilities to ENhance software security and safety (HEAVENS) – deliverable d2 – security models (2016).
31. MODBUS: MODBUS Application Protocol Specification. Technical Report.
32. NIST: NIST Special Publication 800-12 An Introduction to Information Security (2017). <https://csrc.nist.gov/publications/detail/sp/800-12/rev-1/final>
33. NIST: NIST Special Publication 800-37 Risk Management Framework for Information Systems and Organizations- A System Life Cycle Approach for Security and Privacy (2018). <https://doi.org/10.6028/NIST.SP.800-37r2>
34. NIST: NIST Special Publication 800-53 Security and Privacy Controls for Information Systems and Organizations (2020). <https://csrc.nist.gov/publications/detail/sp/800-53/rev-5/final>
35. NIST: CVE-2021-43327 (2021). <https://nvd.nist.gov/vuln/detail/CVE-2021-43327>
36. ODVA: Technology Overview Series: ControlNet (Pub 200) (2016). <https://www.odva.org/wp-content/uploads/2020/05/PUB00200R1-Tech-Series-ControlNet.pdf>

37. Parker, D.: Fighting Computer Crime. Scribner (1983)
38. PROFIBUS Nutzerorganisation e. V. (PNO): Profibus. <https://www.profibus.com/technologies/profibus>
39. PROFIBUS Nutzerorganisation e. V. (PNO) / PROFIBUS & PROFINET International (PI): PROFIBUS system description- technology and application (2016). <https://www.profibus.com/download/profibus-technology-and-application-system-description>
40. Roufa, I., Mustafaa, H., Taylora, T., Ohb, S., Xua, W., Gruteserb, M., Trappeb, W., Ses karb, I.: Security and privacy vulnerabilities of in-car wireless networks: A TirePressure monitoring system case study. pp. 11–13. USENIX Association (2010). https://www.usenix.org/legacy/events/sec10/tech/full_papers/Rouf.pdf
41. Ruddle, A., Ward, D., Weyl, B., Idrees, S., Roudier, Y., Friedewald, M., Leimbach, T., Fuchs, A., Gürgens, S., Henniger, O., Rieke, R., Ritscher, M., Broberg, H., Apvrille, L., Pacalet, R., Pedroza, G.: Security requirements for automotive on-board networks based on dark side scenarios (EVITA Deliverable 2.3) (2009). <https://doi.org/10.5281/zenodo.1188418>.
42. Schneier, B.: Applied Cryptography: Protocols, Algorithms and Source Code in C, 20 edn. Wiley, Indianapolis, IN (2015)
43. Smith, C.: The Car Hacker's Handbook: A Guide for the Penetration Tester, 1 edn. No Starch Press, San Francisco (2016)
44. statista: Wertschöpfungsanteil der Automobilzulieferer am welt-weiten Automobilbau in den Jahren 1985 bis 2015. <https://de.statista.com/statistik/daten/studie/162996/umfrage/wertschoepfungsanteil-der-automobilzulieferer-am-automobilbau-weltweit/>
45. United Nations: UN Regulation No. 155- Cyber security and cyber security management system, Dokumentnummer: E/ECE/TRANS/505/Rev.3/Add.154 (2021). <https://unece.org/transport/documents/2021/03/standards/un-regulation-no-155-cyber-security-and-cyber-security>
46. United Nations: UN Regulation No. 156– Software update and software up date management system, Dokumentnummer: E/ECE/TRANS/505/rev.3/add.155 (2021). https://unece.org/transport/documents/2021/03/standards/un-regulation-no-156-software_update-and-software-update
47. Upstream: Upstream 2022 Global Automotive Cybersecurity Report (2022). <https://upstream.auto/2022report/>
48. Upstream: Upstream 2023 Global Automotive Cybersecurity Report (2023). <https://upstream.auto/2023report/>
49. Watson, V., Lou, X., Gao, Y.: A review of PROFIBUS protocol vulnerabilities- considerations for implementing authentication and authorization controls. In: Proceedings of the 14th International Joint Conference on e-Business and Telecommunications, pp. 444–449. SCITE PRESS- Science and Technology Publications (2017). <https://doi.org/10.5220/0006426504440449>.
50. Wurm, M.: Automotive Cybersecurity: Security-Bausteine für Automotive Embedded Systeme. Springer Berlin Heidelberg, Berlin, Heidelberg (2022). <https://doi.org/10.1007/978-3-662-64228-3>.

Modellierung und Bewertung von Bedrohungsszenarien

7

Zusammenfassung

Die Identifikation von Bedrohungsszenarien und deren Bewertung hinsichtlich Eintrittswahrscheinlichkeit bildet den Kern einer TARA. In diesem Kapitel gehen wir auf zentrale Herausforderungen bei der Durchführung einer TARA ein. Wir erläutern, wie die Bedrohungsidentifikation praktisch umgesetzt wird, und stellen verschiedene etablierte Methoden zur Bedrohungsmodellierung vor. Darüber hinaus zeigen wir auf, welche Bedrohungskataloge sinnvoll eingesetzt werden können – und wie diese effizient genutzt werden. Ein weiterer Schwerpunkt liegt auf der Analyse von Angriffspfaden. Wir diskutieren dabei die erforderliche technische Tiefe sowie die methodische Durchführung zur Bewertung der Angriffsmachbarkeit. Abschließend führen wir die Erkenntnisse anhand unserer drei praxisnahen Fallstudien zusammen.

In diesem Schritt des TARA-Prozesses werden die möglichen Bedrohungen auf die Assets identifiziert. Die Zuordnung zwischen Bedrohungen und Assets wird durch die Cybersecurity-Eigenschaften eines Assets modelliert. Die zentrale Frage in diesem Schritt ist, ob eine Bedrohung das Potenzial hat, eine der Cybersecurity-Eigenschaften eines Assets zu gefährden. Die Zuordnung einer Bedrohung zu den betroffenen Cybersecurity-Eigenschaften eines Assets ist in ISO/SAE 21434 als Bedrohungsszenario (Threat Scenario) definiert. Bedrohungen stammen aus einer Vielzahl von Quellen: dem Fachwissen von Sicherheitsexperten, spezialisierten Internetseiten wie der OWASP® Top 10 [1], Industriestandards und andere. Es ist wichtig zu beachten, dass es keine einzige definitive Quelle für Bedrohungen gibt, und ein umfassender Ansatz erfordert die Berücksichtigung von Informationen aus mehreren zuverlässigen Quellen. Die Beschreibung eines Bedrohungsszenarios wird durch einen *Angriffspfad* ergänzt, der die genauen Schritte oder Aktionen beschreibt, die ein Angreifer zur Ausführung eines Bedrohungsszenarios benötigt. Die Angriffspfade werden in diesem Schritt der TARA für jedes Bedrohungsszenario beschrieben. Die Bewertung

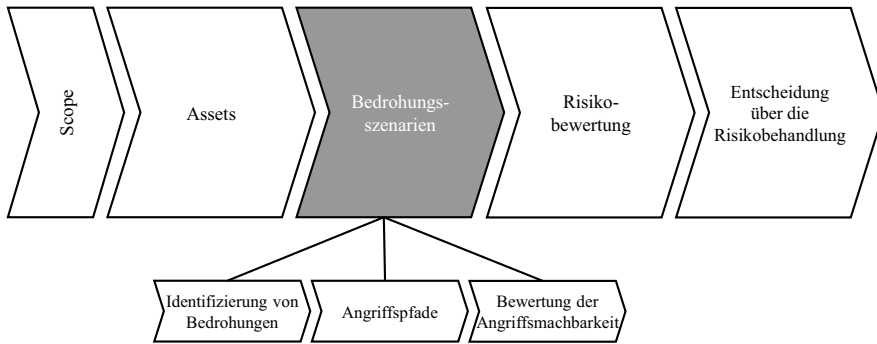


Abb. 7.1 Grundlegende Prozessschritte für die Bedrohungsdefinition des gesamten TARA-Prozesses

der Angriffsmachbarkeit schließlich bestimmt den Aufwand und die Fähigkeiten, die zur tatsächlichen Durchführung der Angriffe erforderlich sind. Der Prozess der Bedrohungsdefinition ist in Abb. 7.1 zusammengefasst.

Erforderliche Eingaben für dieses Kapitel:

- Assets und ihre Cybersecurity-Eigenschaften
- Angreifer-Modell (falls verwendet)
- Annahmen und bekannte Schwächen

Das Ergebnis dieses Kapitels ist:

- Bedrohungsszenarien
- Angriffspfade (oder Angriffsbäume)
- Bewertung der Angriffsmachbarkeit

7.1 Identifikation von Bedrohungen

Die Identifikation der Bedrohungsszenarien und der dazugehörigen Angriffspfade ist der zentrale Bestandteil der Erstellung einer TARA. Bedrohungen sind der Grund dafür, dass Assets kompromittiert werden – und damit die Ursache für Cybersecurity-Risiken überhaupt. Die Bedrohungsidentifikation ist nicht nur der wichtigste Schritt innerhalb der TARA, sondern auch der anspruchsvollste.

Die Herausforderung bei der Identifikation von Bedrohungen besteht aus zwei wesentlichen Gründen. Erstens gibt es keinen universellen Ansatz zur systematischen Identifikation von Bedrohungen. Traditionell erfolgt dieser Schritt häufig durch Brainstorming – es existieren jedoch auch mehrere strukturierte Methoden zur Bedrohungsmodellierung. Zweitens

erfordert die Identifikation relevanter Bedrohungen ein tiefes technisches Verständnis der Assets sowie fundierte Kenntnisse im Bereich Cybersecurity. Es handelt sich dabei um einen kreativen Prozess, bei dem sich das Cybersecurity-Team in die Denkweise eines potenziellen Angreifers hineinversetzen muss.

In den folgenden Abschnitten geben wir einen kurzen Überblick über die gängigsten Ansätze zur Bedrohungsmodellierung. Die Liste ist nicht vollständig, da unser Fokus auf dem Automotive-Sektor und insbesondere auf der ISO/SAE 21434 liegt. Vier Modellierungsansätze werden in der ISO/SAE 21434 explizit als mögliche Methoden zur Bedrohungsmodellierung genannt: EVITA, ETSI TVRA, PASTA und STRIDE (siehe *RQ-15-03* in [20]). Auf diese vier Modelle gehen wir im weiteren besonders ein. Darüber hinaus existieren weitere Bedrohungsmodellierungsansätze, die in diesem Kapitel nicht im Detail behandelt werden – wie etwa RACE [13], VAST [35], SAHARA [27], OCTAVE [12], LINDDUN [14]. Einen umfassenden Überblick über die Bedrohungsmodellierung im Kontext vernetzter Fahrzeuge bietet [26]. Die Beschreibung der ausgewählten Modelle halten wir bewusst knapp, da wir in diesem Buch den Schwerpunkt auf die praktische Umsetzung der TARA im Automotive-Bereich legen – auf Basis des internationalen Standards ISO/SAE 21434 und unserer eigenen Projekterfahrung.

Für detaillierte Informationen zu den einzelnen Modellierungsansätzen verweisen wir auf die umfangreiche Fachliteratur zum Thema Bedrohungsmodellierung, wie beispielsweise [31].

Was ist der beste Ansatz zur Identifikation von Bedrohungen? Wie Shostack [31] und das Threat Modeling Manifesto [2] erläutern, gibt es keinen universellen Ansatz für die Bedrohungsmodellierung. Ähnlich wie bei der Softwareentwicklung existiert auch hier keine „ideale“ Methode – so wie es keine perfekte Programmiersprache gibt. Eine Sprache lässt sich vielleicht einfacher schreiben, eine andere ist ressourcenschonender – ebenso bringt jedes Bedrohungsmodell bestimmte Stärken und Schwächen mit sich. Es wird daher empfohlen, sich nicht in festen Meinungen darüber zu verlieren, welches Bedrohungsmodell „richtig“ oder „falsch“ ist, sondern sich stattdessen auf die zentrale Frage zu konzentrieren: Welcher Modellierungsansatz passt am besten zum konkreten Anwendungsfall? Letztlich ist das „richtige“ Bedrohungsmodell jenes, das im Kontext des jeweiligen Projekts effizient dabei hilft, alle relevanten Bedrohungen zu identifizieren. Aus unserer Sicht hat sich ein praxisorientierter Ansatz bewährt, bei dem die Bedrohungsidentifikation als Team-Brainstorming im Rahmen der TARA erfolgt – unterstützt durch strukturierte Bedrohungskataloge und basierend auf dem STRIDE-Modell. Unser Ansatz zur Bedrohungsmodellierung ist in Abb. 7.2 dargestellt.

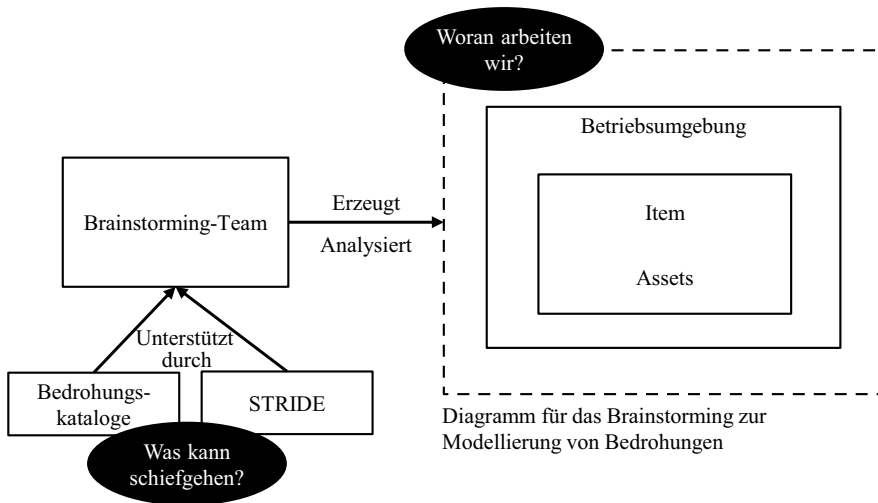


Abb. 7.2 Bedrohungsmodellierungsprozess unterstützt durch Brainstorming, Bedrohungskataloge und STRIDE

7.1.1 Brainstorming

Brainstorming ist ein wirkungsvoller und zugleich intuitiver Ansatz zur Bedrohungsmodellierung. Das Cybersecurity-Team, das die TARA durchführt, setzt sich dabei mit Fachexpertinnen und -experten aus relevanten Bereichen des zu analysierenden Assets zusammen und sammelt im Rahmen einer strukturierten Diskussion potenzielle Bedrohungen. Das Team für die Bedrohungsanalyse kann sich dabei aus denselben Mitgliedern zusammensetzen, die bereits bei der Asset-Identifikation in Abschn. 6.2 beteiligt waren. Ein guter Einstieg in die Brainstorming-Session ist die Analyse eines schematischen Diagramms des Assets und seines Betriebsumfelds. Grundsätzlich sollte der Prozess der Bedrohungsmodellierung die folgenden vier Schlüsselfragen beantworten [2, 31]:

- *Woran arbeiten wir?* Im Sinne der ISO/SAE 21434 steht hinter dieser Frage das grundlegende Verständnis des Items und seiner Betriebsumgebung. Das Verständnis des Items umfasst die Betrachtung seiner Hauptkomponenten und Schnittstellen. Wesentlich ist die Analyse der Systemgrenzen sowie der Art und Weise, wie das Item mit seiner Umgebung interagiert. Wird beispielsweise ein eingebettetes Gerät aus dem Automobilbereich untersucht, können die Systemgrenzen durch die Leiterplatte (PCB) und deren Schnittstellen zur Außenwelt – etwa CAN oder Ethernet – definiert sein. Auch die internen Komponenten des Items müssen berücksichtigt werden, wie z. B. Softwarekomponenten und Speicherbereiche. Diese können bereits als Assets im Sinne der TARA gelten (vgl. Abschn. 6.2.1). Für die Analyse des Items und seines Betriebsumfelds kann

die Verwendung grafischer Darstellungen – z. B. Architektur- oder Kontextdiagramme – besonders hilfreich sein.

- *Was kann schief laufen?* Sobald das Diagramm mit dem Item und seinem Betriebsumfeld erstellt wurde, beginnt die eigentliche Analyse möglicher Schwachstellen – also die Identifikation potenzieller Bedrohungen. Wir empfehlen, dabei systematisch alle im Diagramm dargestellten Elemente zu untersuchen. Diese Elemente umfassen in der Regel die Schnittstellen des Items sowie dessen interne Komponenten. Da Schnittstellen üblicherweise die Begrenzungen eines Items darstellen, bilden sie die sogenannten *Angriffsoberflächen* – also jene Punkte an der Systemgrenze, an denen ein Angreifer in das System eindringen oder es beeinflussen kann. Die Angriffsoberfläche eines Systems ist jedoch nicht zwingend auf externe Schnittstellen beschränkt. Auch interne Komponenten können Angriffsvektoren darstellen – etwa manipulierte Software, die nach einer bestimmten Zeit eine schädliche Aktion ausführt. Ein reines Brainstorming über Bedrohungen birgt das Risiko, relevante Szenarien zu übersehen. Um sicherzustellen, dass keine Bedrohung vergessen wird und um der Diskussion eine klare Struktur zu geben, empfehlen wir, die Analyse durch den Einsatz von Bedrohungskatalogen und das STRIDE-Modell zu unterstützen.
 - *Was unternehmen wir dagegen?* Die Frage, wie mit identifizierten Bedrohungen und den damit verbundenen Risiken umgegangen wird, wird in den TARA-Schritten Risikobewertung und Entscheidung zur Risikobehandlung adressiert.
 - *Haben wir die Aufgabe gut gelöst?* Bei der Bedrohungsmodellierung durch Brainstorming ist es wichtig, das resultierende Modell auf Vollständigkeit zu überprüfen. Ein Modell ist per Definition lediglich eine Abbildung eines realen Systems. Wie in [31] vorgeschlagen, kann der Prozess der Erstellung eines Diagramms zum Item und seinem Betriebsumfeld über mehrere Sitzungen hinweg erfolgen. Dabei sollte jeder relevante Stakeholder prüfen, ob das Modell vollständig und korrekt ist.
- **Gängige Angriffsvektoren** Obwohl die Modellierung von Bedrohungen von dem jeweiligen System abhängt, das analysiert wird, ist es keine schlechte Idee, den aktuellen Stand der gängigen Bedrohungsquellen und Angriffsvektoren zu berücksichtigen. Eine gute Zusammenfassung der häufigsten Angriffsvektoren aus den letzten Jahren findet sich in [38]. Wir führen diese im Folgenden auf. Der in Klammern angegebene Wert gibt die statistische Häufigkeitsverteilung an.
- Server (41,4 %)
 - Keyless Entry/Funkschlüssel (26,3 %)
 - ECU/TCU/Gateway (12,2 %)
 - Mobile App (7,3 %)
 - Infotainmentsystem (5,7 %)
 - OBD-Schnittstelle (5,4 %)
 - IT-Netzwerk (5,1 %)

- Sensoren (3,3 %)
- WLAN (2,9 %)
- Fahrzeuginterne Netzwerke (2,9 %)
- Bluetooth (2,7 %)

Diese Liste kann als Orientierungshilfe bei der Erstellung von Architekturdiagrammen und beim Brainstorming zu Bedrohungen herangezogen werden. Beispielsweise könnten sich aus den oben genannten Angriffsvektoren folgende Fragen ableiten: Kann ein kompromittierter externer Server das Item angreifen? Was passiert, wenn Daten, die vom Item an ein Mobiltelefon übertragen werden, abgefangen oder gestohlen werden? Kann eine manipulierte Infotainment-Anwendung Einfluss auf den Fahrzeugbus nehmen?

7.1.2 Bedrohungskataloge

Bedrohungskataloge sind ein nützliches Werkzeug zur Unterstützung des Bedrohungsmodellierungsprozesses. Der Nutzen eines solchen Katalogs besteht darin, dass sich viele TARA-Projekte in bestimmten Aspekten ähneln. Natürlich ist jedes konkrete Bedrohungsszenario nur auf ein spezifisches System anwendbar, da es exakte Schritte in Angriffspfaden beschreibt und sich auf ein bestimmtes Asset bezieht. Dennoch weisen viele Assets in unterschiedlichen Projekten ähnliche Merkmale auf – und genau hier können Bedrohungskataloge als erste Orientierungshilfe zu Beginn der Bedrohungsidentifikation dienen. Schnittstellen wie CAN, Ethernet, WLAN oder Bluetooth sind Teil vieler Systeme. Ein vorab befüllter Bedrohungskatalog erleichtert es, eine größere Anzahl typischer Bedrohungen für solche Schnittstellen auszuwählen. Darüber hinaus können Bedrohungskataloge eine Vielzahl vordefinierter Informationen enthalten – etwa zu typischerweise betroffenen Cybersecurity-Eigenschaften, zur STRIDE-Klassifizierung, zu typischen Angriffspfaden und mehr.

Die folgenden Abschnitte beschreiben die gebräuchlichsten öffentlich verfügbaren Bedrohungskataloge für Automotive- sowie IT-/OT-Systeme. Keiner der vorgestellten Kataloge ist jedoch darauf ausgelegt, alle Anforderungen der ISO/SAE 21434 vollständig abzudecken. In der Regel enthalten diese Kataloge eine allgemeine Beschreibung der Bedrohungen – in manchen Fällen auch eine technisch detaillierte Darstellung der Angriffsdurchführung auf bestimmten Plattformen. Bei der Übertragung solcher Bedrohungen in eine TARA nach ISO/SAE 21434 ist es jedoch weiterhin Aufgabe des Cybersecurity-Team, die Anforderungen der Norm zu erfüllen. So müssen beispielsweise die betroffenen Cybersecurity-Eigenschaften des jeweiligen Assets sowie der konkrete Angriffspfad im Kontext des betrachteten Assets detailliert beschrieben werden.

- **Verlassen Sie sich nicht nur auf Kataloge** Bedrohungskataloge sind in der Regel ein hilfreiches und zeitsparendes Werkzeug, das die Produktivität deutlich steigern kann. Wie in [2] beschrieben, ist der Einsatz unterstützender Toolkits für die Bedrohungsmodellierung grundsätzlich ein sinnvolles Vorgehen. Allerdings besteht beim Arbeiten mit Katalogen die Gefahr, dass sich das Cybersecurity-Team zu sehr auf vorgefertigte Inhalte verlässt – und dabei an methodischer Strenge und kreativer Tiefe z.B. beim Brainstorming verliert. Wir empfehlen den Einsatz von Katalogen ausdrücklich – jedoch nicht als alleinige Grundlage.

7.1.2.1 UN-Regelung Nr. 155 (Anhang 5)

Die UN-Regelung Nr. 155 [37] enthält in *Anhang 5* eine Liste von Bedrohungen und den jeweils zugehörigen Gegenmaßnahmen. Der Fokus dieser Bedrohungen liegt sowohl auf dem Fahrzeug selbst als auch auf Backend-Servern. Die Bedrohungen sind in Form von abstrakten Beschreibungen dargestellt und beinhalten jeweils ein Beispiel für eine damit verbundene Schwachstelle oder Angriffsmethode.

Wir empfehlen ausdrücklich, den Bedrohungskatalog der UN-Regelung Nr. 155 in die Analyse einzubeziehen. Die Bewertung dieser Bedrohungen – zumindest im Sinne einer Überprüfung ihrer Relevanz für das betrachtete Item – und die dokumentierte Begründung der jeweiligen Entscheidung ist verpflichtend, um die Konformität mit der UN-Regelung sicherzustellen. Unabhängig von regulatorischen Anforderungen bietet der in der UN-Regelung aufgeführte Bedrohungskatalog ein breites Spektrum aktueller Bedrohungen und Angriffsvektoren, die besonders für vernetzte Fahrzeuge von hoher Relevanz sind. Der Katalog umfasst unter anderem Angriffe auf Backend-Systeme durch Insider, einschließlich von Remote-Angriffen – etwa durch Backdoors oder ungepatchte Systeme – sowie lokale Angriffe. Auch Denial-of-Service-Angriffe auf Backend-Server sowie aktuelle Bedrohungen wie Datenschutzverletzungen in Cloud-Umgebungen sind enthalten. Zu den fahrzeuginternen Bedrohungen zählen unter anderem die Manipulation und das Spoofing von Kommunikationskanälen, unautorisierter Zugriff über die OBD-Schnittstelle sowie die Manipulation interner CAN-Nachrichten. Weitere Bedrohungen betreffen die Extraktion kryptografischer Schlüssel, die Manipulation von Diagnosedaten oder das Auslesen personenbezogener und personenbeziehbarer Daten von Fahrzeugnutzern. Auch die Kompromittierung von Over-the-Air-Updates und das Manipulieren von Software werden explizit aufgeführt.

7.1.2.2 MITRE ATT&CK®

MITRE ATT&CK® [33] ist ein sehr bekanntes, umfassendes Framework und eine Wissensdatenbank für Cybersecurity-Bedrohungen. Die Wissensbasis wird alle zwei Jahre aktualisiert und basiert auf realen Angriffen, die aus öffentlich verfügbaren Quellen für Threat Intelligence und Vorfallberichte stammen. Ursprünglich wurde MITRE ATT&CK® nicht für eingebettete Automobilgeräte entwickelt, dennoch empfehlen wir ausdrücklich, viele

der dort beschriebenen Bedrohungen zu evaluieren. Eingebettete Geräte in Fahrzeugen werden zunehmend leistungsfähiger und vernetzter. Moderne Infotainment-Systeme und Head Units verfügen bereits über Funktionen, die mit denen von Mobiltelefonen vergleichbar sind – viele basieren sogar auf Android™ oder iOS. In solchen Fällen lassen sich Bedrohungen aus dem MITRE ATT&CK® Framework direkt übertragen. Wird eine TARA für IT-/OT-Systeme durchgeführt, bietet MITRE ATT&CK® ebenfalls eine wertvolle Sammlung an Bedrohungsszenarien, die genau diese Bereiche abdeckt. Die Wissensbasis von MITRE ATT&CK® ist in drei große Technologiedomänen gegliedert:

- *Enterprise*: Fokussiert auf klassische IT-Netzwerke und Cloud-Technologien. Die Angriffe sind nach Plattformen klassifiziert, darunter Linux, macOS®, Microsoft Windows®, Amazon® Web Services, Microsoft® Azure, Google Cloud Platform™, Software-as-a-Service, Microsoft 365® sowie Microsoft® Azure Active Directory.
- *Mobile*: Bezieht sich auf Bedrohungen für mobile Endgeräte, insbesondere für die Plattformen Android und iOS.
- *Industrial Control Systems*: Fokussiert Bedrohungen auf industrielle Steuerungssysteme – z. B. Angriffe auf Leitsysteme, Feldsteuerungen, Mensch-Maschine-Schnittstellen oder Ein-/Ausgabe-Server gefährden.

Bedrohungen werden im MITRE ATT&CK® Framework durch sogenannte Taktiken und Techniken modelliert. Taktiken beschreiben das taktische Ziel des Angreifers – also den Grund, warum ein Angriff durchgeführt wird. Techniken (und gegebenenfalls Sub-Techniken) stellen die technische Umsetzung dar – also wie das jeweilige Ziel erreicht werden kann. Verfahren (Prozeduren) liefern eine noch tiefere technische Beschreibung konkreter Angriffsmethoden in Techniken und Sub-Techniken, oft mit Bezug auf reale Angriffe.

Die im MITRE ATT&CK® Framework dokumentierten Techniken, Sub-Techniken und Verfahren können besonders hilfreich sein, wenn es darum geht, einen Angriffspfad im Rahmen einer TARA nach ISO/SAE 21434 zu beschreiben.

Darüber hinaus stellt MITRE ATT&CK® auch Sicherheitskonzepte und Technologie-kategorien zur Verfügung, mit denen sich Bedrohungen erkennen und verhindern lassen [33].

7.1.2.3 OWASP® Top 10

Die OWASP® Foundation ist eine gemeinnützige Organisation, die von einer Online-Community aus Expertinnen und Experten getragen wird und sich der Verbesserung der Softwaresicherheit widmet. In regelmäßigen Abständen wird der bekannte Bericht *OWASP® Top 10* [1] veröffentlicht, der die aktuell zehn relevantesten Cybersecurity-Risiken für Softwareentwickler und Webanwendungen beschreibt.

Die zehn Risiken sind ausführlich beschrieben, inklusive praxisnaher Beispiele. Zudem werden präventive Maßnahmen aufgeführt. Die gelisteten Cybersecurity-Risiken basieren auf realen Beobachtungen – unter anderem aus Nutzerrückmeldungen und Befragungen von Fachleuten aus der Branche. Das OWASP[®] Expertenteam konsolidiert sämtliche gesammelten Daten, einschließlich hunderter CWEs (Common Weakness Enumerations), die jeweils den Risiken zugeordnet sind.

Auch wenn sich die identifizierten Schwachstellen primär auf Webdienste und deren Backend-Infrastruktur beziehen, empfehlen wir, diese Schwachstellen bei jeder Art von System im Rahmen einer TARA zu berücksichtigen. Viele der genannten Schwachstellen – wie *unsicheres Design*, *fehlerhafte Sicherheitskonfigurationen* oder *kryptografische Schwächen* – lassen sich technologieneutral formulieren und sind somit für nahezu alle Systeme relevant und anwendbar.

7.1.2.4 ENISA Threat Landscape (ETL)

Eine weitere verlässliche Quelle für Bedrohungsinformationen ist der ENISA Threat Landscape (ETL) [17]. ENISA veröffentlicht jährlich einen Bericht zum Stand der Cybersecurity-Bedrohungen – einschließlich der wichtigsten Bedrohungen, relevanter Trends, Bedrohungsakteure (z. B. staatlich gesponserte Akteure, cyberkriminelle Akteure, Hacktivisten) und Angriffsverfahren.

Jede Top-Bedrohung wird detailliert beschrieben – einschließlich fundierter Referenzen und praxisbezogener Daten (z. B. aus CWEs). Dabei wird beleuchtet, welche Motivation die Angreifer hinter der jeweiligen Bedrohung antreibt, welches Ziel sie verfolgen und welche Angriffsziele im Fokus stehen.

Zudem werden die wichtigsten Vorfälle innerhalb des jeweils analysierten Jahreszeitraums aufgeführt – inklusive Angaben zu betroffenen Organisationen und der geografischen Verbreitung der Vorfälle.

Der ENISA-Bericht über die Bedrohungslandschaft enthält eine Zuordnung zwischen den identifizierten Top-Risiken und den Techniken des MITRE ATT&CK[®] Frameworks. Darüber hinaus liefert der Bericht konkrete Handlungsempfehlungen zu den relevantesten Bedrohungen – abgestimmt auf etablierte internationale Standards wie ISO/IEC 27001 sowie das NIST Cybersecurity Framework (CSF).

7.1.2.5 ENISA Good Practices for Security of Smart Cars

Eine bedeutende Quelle für Bedrohungen im Bereich Smart Cars wurde von ENISA im Bericht *Good practices for security of Smart Cars* veröffentlicht [16]. In diesem Bericht werden Smart Cars als vernetzte, autonome und teilautonome Fahrzeuge definiert. Die darin aufgeführten Bedrohungen decken das gesamte Ökosystem autonomer Fahrzeuge ab – von klassischen physischen Bedrohungen auf das Fahrzeug bis hin zu modernen Cyberbedrohungen gegen Backend-Systeme und autonome Komponenten. Darüber hinaus enthält der Bericht eine Taxonomie der am häufigsten vorkommenden Assets in Smart Cars. Diese wer-

den den jeweiligen Bedrohungen zugeordnet. Für jede Bedrohungsgruppe werden zusätzlich geeignete Cybersecurity-Maßnahmen und Best Practices empfohlen.

7.1.2.6 Auto-ISAC Automotive Threat Matrix (ATM)

Das Automotive Information Sharing and Analysis Center (Auto-ISAC) [9] ist eine anerkannte Organisation, die sich der Förderung von Zusammenarbeit und Informationsaustausch im Bereich der automobilen Cybersecurity widmet.

Die Auto-ISAC-Plattform setzt sich aus Fahrzeugherstellern, Zulieferern und weiteren Akteuren der Branche zusammen und dient als vertrauenswürdige Schnittstelle für den Austausch und die Analyse von Cybersecurity-Bedrohungen, Schwachstellen und Best Practices. Die Mitglieder tragen aktiv dazu bei, indem sie neu auftretende Risiken und entdeckte Schwachstellen im Zusammenhang mit Fahrzeugen melden. Dies ermöglicht einen gemeinsamen, koordinierten Ansatz zur wirksamen Bewältigung und Minderung potenzieller Cyber Risiken. Die Auto-ISAC hat die Automotive Threat Matrix (ATM) [11] veröffentlicht – eine Auflistung von Bedrohungen, die auf realen Beobachtungen basieren. Die ATM stellt zudem eine einheitliche Taxonomie für Bedrohungen bereit. Diese umfasst unter anderem folgende Kategorien: Manipulation der Umgebung, Initialer Zugriff, Ausführung, Persistenz, Ausweitung der Berechtigungen, Umgehung von Schutzmechanismen, Zugriff auf Zugangsdaten, Informationsgewinnung, Laterale Bewegung, Sammlung, Kommando- und Kontrollkanäle, Exfiltration sowie Beeinflussung von Fahrzeugfunktionen. Einige dieser Taktiken (Bedrohungskategorien) wurden aus dem MITRE ATT&CK®-Framework übernommen bzw. daran angelehnt und entsprechend auf den Automotive-Kontext übertragen.

7.1.2.7 Automotive Security Research Group (ASRG)

Die Automotive Security Research Group (ASRG) [10] ist eine gemeinnützige, community-basierte Initiative zur Förderung der Entwicklung von Sicherheitslösungen für automobile Systeme. Die ASRG setzt sich aus führenden Expertinnen und Experten der Branche zusammen und betreibt gezielte Forschung zur Identifikation von Schwachstellen sowie zur Entwicklung wirksamer Schutzmaßnahmen für Fahrzeugkomponenten. Darüber hinaus fördert die Organisation den Wissensaustausch und die Zusammenarbeit durch Konferenzen und Workshops, setzt sich für robuste Cybersecurity-Praktiken ein und leistet aktive Beiträge zur Weiterentwicklung von Branchenstandards. Mitglieder der Community können sich über das Webportal der ASRG anmelden und auf einen Bedrohungskatalog zugreifen. Dieser wird gemeinschaftlich gepflegt und enthält zu jeder Bedrohung eine empfohlene Bewertung der Umsetzbarkeit (Feasibility) sowie Angaben zu den betroffenen Cybersecurity-Eigenschaften.

7.1.2.8 ISO/IEC 27000-Familie

Die ISO/IEC 27005 [8], ein Teil der ISO/IEC-27000-Standardsreihe für Informationssicherheits-Managementsysteme (ISMS), enthält ebenfalls eine informative Liste beispielhafter Bedrohungen und Schwachstellen (siehe *Anhang A* in [8]). Die im Standard aufgeführten Bedrohungen und Schwachstellen sind zwar nicht so technisch detailliert wie in anderen Quellen – etwa im MITRE ATT&CK®-Framework –, können aber dennoch als Inspirationsquelle für eine technische TARA dienen. Abhängig von den Anforderungen der jeweiligen Organisation kann es sinnvoll sein, diese Bedrohungen und Schwachstellen zu berücksichtigen oder zumindest mit Bedrohungen innerhalb der TARA zu verknüpfen. Dies ermöglicht es, eine gemeinsame Ausgangsbasis zu schaffen – insbesondere dann, wenn das Unternehmen bereits ein ISMS nach ISO/IEC 27001 implementiert.

7.1.3 STRIDE

STRIDE ist ein weit verbreiteter Ansatz zur Bedrohungsmodellierung, der von Loren Kohnfelder und Praerit Garg bei Microsoft® entwickelt wurde [23, 31]. Der Begriff STRIDE ist ein Akronym, das sich aus den Anfangsbuchstaben der folgenden Bedrohungskategorien zusammensetzt:

- *Spoofing (Manipulation, Täuschung)*: Der Angreifer gibt sich als eine andere Entität aus. In eingebetteten Fahrzeugsystemen kann dies bedeuten, dass eine Komponente oder ein Subsystem vorgibt, ein anderes zu sein. Beispielsweise könnte ein Angreifer ein Steuergerät imitieren und falsche Signale an das Bremssystem senden. Ebenso denkbar ist das Nachahmen der Kommunikation zwischen Fahrzeugkomponenten oder zwischen Fahrzeug und externen Systemen. Ein weiteres Beispiel ist das Spoofing von Funkschlüsselsignalen, um ein Fahrzeug zu entriegeln oder gar aus der Ferne zu starten.
- *Tampering (Manipulation)*: Hierunter fallen unautorisierte Veränderungen an Daten oder Systemfunktionen. Im automobilen Kontext kann dies das Modifizieren der Firmware einer Fahrzeugkomponente, das Verfälschen von Sensorsignalen oder das Verändern der Software eines Infotainmentsystems beinhalten – etwa um eine Backdoor zu schaffen.
- *Repudiation (Abstreitbarkeit)*: Der Angreifer sorgt dafür, dass seine Aktionen nicht nachvollziehbar sind. Wenn z. B. Protokollierungs- oder Auditierungsfunktionen eines Fahrzeugs manipuliert oder deaktiviert wurden, kann es unmöglich werden, nachzuweisen, dass eine bestimmte Aktion – etwa die Übermittlung eines Befehls – überhaupt stattgefunden hat.
- *Information Disclosure (Offenlegung von Informationen)*: Der Angreifer erlangt unautorisierten Zugriff auf Daten – häufig personenbezogene Informationen. Dies kann beispielsweise Datenlecks oder ungewollte Preisgaben umfassen.
- *Denial-of-Service*: Der Angreifer stört gezielt die Funktion eines Systems oder Dienstes. Ein typisches Beispiel ist ein DoS-Angriff auf den CAN-Bus, bei dem durch gezieltes

Überfluten mit Nachrichten legitime Kommunikationsvorgänge blockiert werden – was im Extremfall zu Fehlfunktionen sicherheitsrelevanter Systeme führen kann.

- *Elevation of privilege (Rechteauserweiterung)*: Der Angreifer verschafft sich höhere Berechtigungen als ursprünglich vorgesehen. Im Fahrzeugbereich könnte dies etwa bedeuten, dass über eine weniger privilegierte Komponente – wie das Infotainmentsystem – eine Sicherheitslücke ausgenutzt wird, um Zugriff auf ein sicherheitskritisches Steuergerät zu erlangen.

Die zentrale Idee hinter STRIDE besteht darin, dass das Cybersecurity-Team während des Bedrohungsmodellierungsprozesses systematisch alle sechs Bedrohungskategorien berücksichtigt. Dabei stehen die STRIDE-Kategorien jeweils in Bezug zu zentralen Schutzeigenschaften der Informationssicherheit. Die Bedrohungskategorien und die jeweils verletzten Cybersecurity-Eigenschaften sind in Tab. 7.1 dargestellt.

STRIDE ist eine hilfreiche Methode zur Identifikation von Bedrohungen, da sie die grundlegende Frage stellt: Was kann schief laufen? Es ist jedoch wichtig zu betonen, dass STRIDE keine Bedrohungskategorisierung im eigentlichen Sinne darstellt. STRIDE war ursprünglich nicht als Bedrohungstaxonomie gedacht – auch wenn es häufig fälschlicherweise so verwendet wird. Das Ziel von STRIDE besteht vielmehr darin, das Denken über mögliche Angriffe anzuregen, die ein System im Rahmen der TARA kompromittieren könnten. Wie in [31] erläutert wird, ist es nicht zielführend, STRIDE zur nachträglichen Kategorisierung bereits identifizierter Bedrohungen zu verwenden – denn die eigentliche Stärke von STRIDE liegt in der strukturierten Identifikation von Bedrohungen, etwa im Rahmen eines Brainstormings. Noch problematischer ist, dass viele Bedrohungen nicht eindeutig einer einzigen STRIDE-Kategorie zugeordnet werden können, was eine nachträgliche Kategorisierung oft frustrierend und wenig hilfreich macht.

STRIDE-LM Eine häufig in der Risikobewertung verwendete Erweiterung des STRIDE-Modells ist die Kategorie *lateral Movement*. Diese ist besonders im Netzwerkumfeld relevant und beschreibt den Fall, in dem ein Angreifer nach dem initialen Zugriff weitergehende

Tab. 7.1 STRIDE Bedrohungskategorien

Bedrohungskategorie	Verletzte Cybersecurity-Eigenschaft
Spoofing (Manipulation, Täuschung)	Authentizität
Tampering (Manipulation)	Integrität
Repudiation (Abstreitbarkeit)	Nichtabstreitbarkeit
Information Disclosure (Offenlegung von Informationen)	Vertraulichkeit
Denial-of-Service	Verfügbarkeit
Elevation of privilege (Rechteauserweiterung)	Autorisierung

Kontrolle über das Zielnetzwerk erlangt. Dabei bewegt sich der Angreifer seitlich durch das System, um Zugriff auf weitere Komponenten oder Daten zu erhalten. Lateral Movement verletzt die Cybersecurity-Eigenschaft *Containment* (oder *Segmentation*) [28].

7.1.4 EVITA

E-Safety Vehicle Intrusion Protected Applications (EVITA) ist ein Pionierprojekt zur Risikobewertung im Bereich der automobilen Cybersecurity [18]. Mehrere einschlägige Cybersecurity-Standards – wie SAE J3061 [21] – sowie später entwickelte Risikobewertungsverfahren wie HEAVENS basieren auf EVITA oder haben zumindest einzelne Konzepte daraus übernommen. Die Veröffentlichung *Deliverable D2.3: Security requirements for automotive on-board networks Based on dark-side scenarios* [29] aus dem Jahr 2009 enthält sicherheitsrelevante Anforderungen, die auf einer risikobasierten Analyse beruhen. Der methodische Ansatz von EVITA basiert auf dem internationalen Standard ISO/IEC 18045:2008 [3], die eine Methodik zur Bewertung von IT-Sicherheit spezifiziert. Zudem orientiert sich EVITA in seiner Gefahren- und Risikobewertung an der Methodik des funktionalen Sicherheitsstandards ISO 26262¹ [4]. Die in EVITA verwendete Klassifikation der Auswirkung von Bedrohungen entspricht weitgehend der heutigen Bewertung von Schadensszenarien im Rahmen der ISO/SAE 21434. EVITA hat dabei die aus der funktionalen Sicherheit (siehe Standard ISO 26262) bekannte Klassifikation übernommen und um drei zusätzliche Kategorien erweitert: *Privatsphäre*, *Finanzen*, und *Betrieb*. Die Identifikation von Bedrohungen erfolgt in EVITA anhand sogenannter *Dark-Side-Szenarien* sowie mithilfe von Angriffsbäumen. Die Dark-Side-Szenarien bestehen aus folgenden Komponenten: der Identifikation und Klassifizierung möglicher Angriffsmotive, der Bewertung der Fähigkeiten potenzieller Angreifer sowie der Modellierung konkreter Angriffe. Die Angriffsmodellierung wird dabei strukturiert durch den Einsatz von Angriffsbaum-Diagrammen (Attack Trees) unterstützt. Im Angriffsbaum steht an der Wurzel das sogenannte Attack Goal – also das angestrebte Ziel bzw. der Vorteil, den der Angreifer durch die Kompromittierung eines bestimmten Use Cases erlangen möchte (vgl. [22]). Die zweite Ebene im Angriffsbaum stellt die Attack Objectives dar, also die angestrebten Angriffsziele, durch die das übergeordnete Angriffsziel erreicht werden kann. Diese Angriffsziele stehen für den potenziellen Schaden an Stakeholdern wie Straßenverkehrsteilnehmern, Diensteanbietern, OEMs oder Zulieferern. Die dritte Ebene umfasst die konkreten Attack Methods, also die möglichen Angriffsmethoden, mit denen ein Angriffsziel umgesetzt werden kann. Die weiteren Ebenen beschreiben die kompromittierten Assets sowie die dazugehörigen Zwischenschritte im Angriffspfad. Das Angriffspotenzial wird dabei den Einstiegspunkten (Entry Points) zu den jeweiligen Assets auf der untersten Ebene des Baums zugeordnet.

Die Methodik der Bedrohungsmodellierung von EVITA ist in der Automobilindustrie gut bekannt und akzeptiert. Es kann durchaus sinnvoll sein, EVITA in Betracht zu ziehen –

¹ Zum Zeitpunkt von EVITA befand sich dieser Standard noch im DIS-Stadium.

insbesondere durch die Anwendung des Attack-Tree-Ansatzes und als Inspirationsquelle für die Ableitung konkreter Bedrohungen. Ein weiterer Vorteil der Nutzung von EVITA besteht in der Rückwärtskompatibilität, insbesondere wenn innerhalb der Organisation bereits eine umfangreiche Datenbasis an TARA-Analysen auf Basis von EVITA vorliegt. Ein offensichtlicher Nachteil beim Einsatz von EVITA liegt jedoch in der Abstimmung und Kompatibilität mit der ISO/SAE 21434. Die Überführung der Ergebnisse der Bedrohungsmodellierung aus EVITA in eine TARA-Struktur nach ISO/SAE 21434 führt bisweilen zu zusätzlichem Aufwand und methodischen Abweichungen.

7.1.5 HEAVENS

HEALing Vulnerabilities to ENhance Software Security and Safety (HEAVENS) ist ein Risikobewertungsmodell, das 2016 von der Automobilindustrie entwickelt wurde [25]. Ziel von HEAVENS war es, bestimmte Schwächen älterer Modelle – insbesondere von EVITA – zu überwinden. So kritisiert HEAVENS beispielsweise, dass EVITA angriffszentriert sei und den Fokus stark auf die Identifikation sämtlicher potenzieller Angriffe gegen ein Bewertungssystem legt. HEAVENS hingegen verfolgt einen bedrohungszentrierten Ansatz, der durch das STRIDE-Modell unterstützt wird. Dadurch konzentriert sich HEAVENS auf eine geringe Anzahl generischer Bedrohungskategorien, anstatt auf eine Vielzahl konkreter Angriffstechniken, die mit einem Asset verknüpft sein könnten. Ein weiterer wesentlicher Aspekt von HEAVENS ist die direkte Zuordnung von Sicherheitsattributen zu den jeweiligen Bedrohungen (beispielsweise Vertraulichkeit, Integrität und Verfügbarkeit). Neben den bereits etablierten Zielgrößen Safety, Finanzen, Betrieb und Privatsphäre führt HEAVENS zudem gesetzliche/regulatorische Anforderungen (Legislation) als zusätzliches Sicherheitsziel ein.

Die Bedrohungsanalyse im HEAVENS-Modell basiert auf STRIDE und wurde auf automobiler E/E-Systeme erweitert. Bedrohungen aus anderen Sicherheitsmodellen – wie z. B. EVITA – werden im Rahmen von HEAVENS analysiert (vgl. *Tab. 4-1* in [25]) und den STRIDE-Kategorien zugeordnet. Ein interessanter Aspekt von HEAVENS ist die klare Unterscheidung zwischen Bedrohungen und Schwachstellen. Das Modell argumentiert, dass Bedrohungen grundsätzlich vor Schwachstellen betrachtet werden sollten. Wenn eine TARA bereits in der Konzeptphase durchgeführt wird, lassen sich Bedrohungen gegenüber den Assets häufig leichter identifizieren – insbesondere, weil technische Umsetzungsdetails zu diesem Zeitpunkt noch nicht vorliegen. Die im weiteren Verlauf der Produktentwicklung entstehenden Schwachstellen (z. B. durch fehlerhafte Implementierung) werden im HEAVENS-Modell ebenfalls berücksichtigt. Die Entwickler von HEAVENS haben inzwischen eine neue Version des Risikomodells vorgeschlagen – HEAVENS 2.0 –, das auf dem ursprünglichen HEAVENS-Modell basiert und vollständig konform mit der ISO/SAE 21434 ist (vgl. [24]).

7.1.6 ETSI TVRA

Das ETSI Threat, Vulnerability, and Risk Analysis (TVRA)-Modell haben wir bereits im Rahmen der Angreifermodellierung in Abschn. 5.6.2 eingeführt. TVRA ist ein bekanntes und weithin anerkanntes Risikobewertungsmodell. Es wurde ursprünglich für die Telekommunikationsbranche entwickelt, ist jedoch grundsätzlich auch auf andere Anwendungsgebiete übertragbar. Tatsächlich hat sich TVRA mittlerweile auch in der Automobilindustrie etabliert. Das HEAVENS-Modell analysiert TVRA ausführlich in [25], und ISO/SAE 21434 benennt TVRA als möglichen Rahmen zur Bedrohungsmodellierung.

Zur Bedrohungsmodellierung definiert TVRA eine Reihe von Bedrohungsgruppen, die für Telekommunikationssysteme relevant sind. Dazu zählen: *Abhören* (Interception), *unautorisierter Zugriff* (Unauthorized Access), *Maskerade* (Masquerade), *Fälschung* (Forgery), *Verlust oder Veränderung von Informationen* (Loss or corruption of information), *Abstreitbarkeit* (Repudiation) sowie *Denial-of-Service*. Die in TVRA betrachteten Cybersecurity-Eigenschaften sind: Vertraulichkeit (Confidentiality), Integrität (Integrity), Verfügbarkeit (Availability), Authentizität (Authenticity) und Rechenschaftspflicht (Accountability). Im Rahmen der Risikobewertung nach TVRA ist der erste Schritt die Identifikation von Schwachstellen und Angriffsmöglichkeiten im zu bewertenden System. Diese Schwachstellen stellen potenzielle Angriffspunkte für einen Angreifer (im TVRA-Kontext: *Threat Agent*) dar. Wenn konkrete Bedrohungen gegenüber einer Schwachstelle bestehen und diese realistisch ausgenutzt werden können, spricht man im TVRA-Modell von einer tatsächlichen Schwachstellen.

Wir empfehlen, Bedrohungen gemäß TVRA zu formulieren, wenn eine Organisation eine Rückwärtskompatibilität zu bestehenden TARA-Projekten sicherstellen muss. Für neue TARA-Projekte sehen wir jedoch nur begrenzten Mehrwert in der Anwendung von TVRA, da die dort beschriebenen Bedrohungen stark auf Telekommunikationssysteme ausgerichtet sind. Zwar lassen sich diese prinzipiell auf Automotive-Systeme übertragen, jedoch bietet STRIDE in der Praxis eine direktere und effizientere Anwendung. Zudem ist der zusätzliche Aufwand zur Einarbeitung und Adaption von TVRA auf Automotive-TARA nicht zu unterschätzen.

7.1.7 PASTA

Process for Attack Simulation and Threat Analysis (PASTA) ist eine risikoorientierte, evidenzbasierte Methode zur Bedrohungsmodellierung mit einem besonderen Fokus auf Geschäftsprozesse. Ziel von PASTA ist es, jene Bedrohungen zu identifizieren und zu bewerten, die negative geschäftliche, finanzielle und betriebliche Ziele in Bezug zur zu analysierenden Anwendung haben können. Bereits in den ersten Schritten der PASTA-Methodik werden die geschäftlichen Zielsetzungen der betrachteten Anwendung, Dienstleistung oder Infrastruktur definiert sowie die wichtigsten geschäftskritischen Anwendungsfälle identifi-

ziert. PASTA hat sich weltweit etabliert – insbesondere im wirtschaftlichen Umfeld, aber auch in anderen großen Branchen und Organisationen, etwa bei *GitLab* [19].

PASTA (Process for Attack Simulation and Threat Analysis) besteht aus sieben aufeinander aufbauenden Phasen: 1. *Festlegen der Ziele (Define Objectives)*, 2. *Definition des technischen Scopes (Define Technical Scope)*, 3. *Zerlegung und Analyse der Anwendung (Application Decomposition and Analysis)*, 4. *Bedrohungsanalyse (Threat Analysis)*, 5. *Analyse von Verwundbarkeiten und Schwachstellen (Weakness and Vulnerability Analysis)*, 6. *Angriffsmodellierung und Simulation (Attack Modeling and Simulation)* und 7. *Risikobewertung und Risikomanagement (Risk Analysis and Management)*.

Die Bedrohungen werden aus externen Quellen wie OWASP abgeleitet und anschließend Angreifern (Threat Agents) sowie konkreten Angriffsvektoren zugeordnet – häufig unter Einsatz von Angriffsbäumen [39]. Jede identifizierte Bedrohung wird mit einem Wahrscheinlichkeitswert (Feasibility Rating) versehen. Dieser ergibt sich unter Berücksichtigung folgender Kriterien: Zugriffsmöglichkeiten (Access), Gelegenheitsfenster (Window of Opportunity), Möglichkeit zur Abstreitbarkeit (Ability to Repudiate), Nutzen-Risiko-Verhältnis für den Angreifer (Risk Reward) und Einfachheit der Durchführung (Simplicity of the Threat) [36]. Eine zentrale Phase innerhalb von PASTA ist die Verwundbarkeitsanalyse, bei der gezielt Schwachstellen des zu analysierenden Systems getestet werden. Nach Abschluss dieser Analyse werden die Angriffsszenarien konsolidiert und abschließend der Risikowert bestimmt.

7.2 Angriffspfade

Ein Angriffspfad (Attack Path) beschreibt die konkreten Schritte oder Handlungen, die ein Angreifer durchführen muss, um ein Bedrohungsszenario umzusetzen. Die Identifikation solcher Pfade wird in der ISO/SAE 21434 als *Attack Path Analysis* bezeichnet. Angriffspfade sind ein wesentlicher Bestandteil der TARA, da sie aufzeigen, wie ein Bedrohungsszenario für ein bestimmtes Asset realisiert werden kann – nicht was passieren kann, sondern wie es passieren kann. Für jedes identifizierte Bedrohungsszenario muss mindestens ein Angriffspfad vorhanden sein. Andernfalls gilt das Bedrohungsszenario im Kontext des analysierten Items oder der betrachteten Komponente als nicht realisierbar.

7.2.1 Wie werden Angriffspfade identifiziert?

Die Identifikation von Angriffspfaden ist keine einfache Aufgabe und kann einen erheblichen Zeitaufwand erfordern. Für eine präzise und realistische Beschreibung der Angriffspfade ist sowohl technisches Detailwissen über das betrachtete Item oder die Komponente als auch fundiertes Know-how im Bereich Cybersecurity erforderlich. Unzureichend beschriebene Angriffspfade können zu fehlerhaften Risikobewertungen führen. Aus diesem Grund emp-

fehlt es sich, die Angriffspfade im Rahmen einer gemeinsamen Analyse zwischen den Fachexperten des Items und dem Cybersecurity-Team zu erarbeiten. Ähnlich wie bei der Bedrohungsidentifikation haben sich auch hier strukturierte Brainstorming-Sitzungen als sehr hilfreich erwiesen.

Angriffspfade können entweder mithilfe eines Top-down- oder eines Bottom-up-Ansatzes identifiziert werden. Beim Top-down-Ansatz beginnt die Analyse mit einem konkreten Bedrohungsszenario. Ausgehend davon wird überlegt, wie dieses technisch umgesetzt werden könnte. In diesem Zusammenhang kommen typischerweise Angriffsbäume (Attack Trees) zum Einsatz. Der Bottom-up-Ansatz hingegen startet mit bekannten Schwachstellen. Diese Schwachstellen können im Rahmen einer Schwachstellenanalyse gemäß ISO/SAE 21434 identifiziert worden sein, während der Produktentwicklung aufgetreten sein oder durch externe Cybersecurity-Vorfälle bekannt geworden sein. Die Schwachstellen werden analysiert, und es wird ermittelt, welche Angriffspfade daraus entstehen könnten. Dabei können auch neue Bedrohungsszenarien identifiziert werden, die bislang nicht Teil der TARA waren. Solche neu erkannten Bedrohungsszenarien sollten in die TARA aufgenommen werden.

- **Detaillierungsgrad der Angriffspfade** In der Praxis wird häufig darüber diskutiert, wie detailliert Angriffspfade beschrieben werden sollten. Eine eindeutige Vorgabe zur Darstellung der Angriffspfade existiert nicht. Der eigentliche Zweck der Definition von Angriffspfaden besteht jedoch darin, die Wahrscheinlichkeit eines tatsächlichen Angriffs bewerten zu können. Letztlich suchen wir nach Risiken – und Risiko wird in seiner einfachsten Form als das Produkt aus Auswirkung und Eintrittswahrscheinlichkeit eines Ereignisses definiert. Die Beschreibung eines Angriffspfad sollte daher so gestaltet sein, dass sie eine realistische Abschätzung der Machbarkeit (Feasibility) eines Angriffs ermöglicht. In diesem Zusammenhang kann bereits eine kurze technische Beschreibung ausreichend sein – etwa: *Fuzzing auf UDS von DID 0x0 bis DID 0xFFFF über CAN unter Verwendung des SID 0x2E*. – sofern diese Beschreibung eine fundierte Bewertung der Durchführbarkeit erlaubt.

7.2.2 Beschreibung von Angriffspfaden

Angriffspfade werden als Liste von Einzelschritten beschrieben, die zur Durchführung eines Angriffs notwendig sind. Diese Unterteilung in Schritte erleichtert nicht nur das Verständnis und die Lesbarkeit, sondern ist auch erforderlich, um die Machbarkeit (Feasibility) jedes einzelnen Schritts bewerten zu können – wie in Abschn. 7.3 näher erläutert. Jeder Schritt eines Angriffspfad ist zwingend notwendig, um den vollständigen Pfad auszuführen. Gibt es Alternativen oder optional ersetzbare Schritte, müssen separate Angriffspfade abgeleitet und entsprechend beschrieben werden, um jede mögliche Variante nachvollziehbar zu dokumentieren. Der folgende Angriffspfad beschreibt ein Szenario, bei dem ein *unautorisierter*

Zugriff auf Informationen auf Backend-Servern über eine Head-Unit-ECU erreicht werden soll:

1. Ein Fahrzeug mit gefälschtem Ausweis und Kreditkarte mieten
2. Fahrzeug öffnen und Head-Unit-ECU ausbauen
3. Recherche, wie ein Diagnosezugriff auf die ECU erlangt werden kann
4. Beschaffung der erforderlichen Debugging-Tools und Anschließen an das Steuergerät (z. B. über UDS oder ungeschützten JTAG-Port)
5. Dump des Speicherbereichs, in dem der Anwendungscode gespeichert ist, und Reverse Engineering des Codes
6. Analyse, welcher Teil des Codes die Kommunikation mit dem Backend-Server herstellt und Anfragen an eine Datenbank sendet
7. Die Binärdatei so manipulieren, dass eine einfache SQL-Injektionszeichenfolge zur Datenbankabfrage hinzugefügt werden kann

Ähnliche Beispiele finden sich in *Anhang H, Abschnitt H.2.5* des Standards ISO/SAE 21434 [20].

7.2.3 Angriffsbäume

Angriffsbäume (Attack Trees) sind ein beliebter Ansatz zur Modellierung, Identifikation und Beschreibung verschiedenster Angriffspfade. Im Kern handelt es sich bei Angriffsbäumen lediglich um eine Datenstruktur – in grafischer Form dargestellt sind sie jedoch besonders intuitiv und hilfreich. Gerade in Brainstorming-Sitzungen erweisen sich Angriffsbäume als äußerst praktikables Werkzeug, um Ideen zu visualisieren und gemeinsam zu diskutieren. Angriffsbäume sind seit vielen Jahren fester Bestandteil in der Bedrohungsmodellierung. Eine der frühesten Beschreibungen von Angriffsbäumen im Bereich der IT-Sicherheit stammt von Bruce Schneier ([30]). Schneier beschreibt Angriffsbäume als formalen und methodischen Ansatz, um die Sicherheit von Systemen auf Basis unterschiedlicher Angriffsvarianten darzustellen. In einem Angriffsbaum stellt das Angriffsziel den Wurzelknoten dar. Die unterschiedlichen Wege, mit denen dieses Ziel erreicht werden kann, werden als Blattknoten dargestellt [30]. Eine detaillierte Diskussion dieses Themas findet sich unter anderem auch in [31].

Zur Identifikation von Angriffspfaden kann die Struktur einfacher Angriffsbäume verwendet werden, wie sie in [30] beschrieben ist. Am oberen Ende des Baums – also im Wurzelknoten – wird ein Bedrohungsszenario (Threat Scenario) definiert. Die nachfolgenden Blattknoten des Baums beschreiben die Schritte, die erforderlich sind, um das Bedrohungsszenario durch konkrete Angriffspfade umzusetzen. Ein Angriffspfadbaum kann mehrere Angriffspfade enthalten, die sich bestimmte Schritte teilen. Diese Kombination ist möglich, weil in Angriffsbäumen sowohl ODER-Knoten als auch UND-Knoten verwendet werden:

ODER-Knoten stehen für alternative Wege zur Erreichung eines übergeordneten Ziels. Ein Angriff könnte beispielsweise *Abfangen von OTA-Daten in Transit* lauten und die untergeordneten ODER-Knoten *Abfangen von Mobilfunkkommunikation* und *Abfangen von WLAN-Kommunikation* enthalten.

UND-Knoten stehen für zwingend erforderliche Teilschritte, die alle erfüllt sein müssen, um das übergeordnete Ziel zu erreichen. Um beispielsweise den Schritt *Abfangen der WLAN-Kommunikation* zu erreichen, muss der Angreifer die beiden untergeordneten Schritte *Sich in der Nähe des Fahrzeugs befinden* und *Sniffer-Tool auf dem Laptop aktivieren* ausführen. Ein Beispiel für einen Angriffspfadbaum ist in Abb. 7.2.2 dargestellt. Er visualisiert den Angriffspfad, den wir in Abschn. 7.3 in Textform beschrieben haben – basierend auf dem Bedrohungsszenario *Unautorisierter Zugriff auf Informationen auf Backend-Servern* mittels einer Head-Unit-ECU.

Effizienz von Angriffsbäumen Angriffsbäume sind zwar sehr beliebt und in der Praxis äußerst nützlich, bringen jedoch potenzielle Nachteile mit sich – insbesondere im Hinblick auf den zeitlichen Aufwand für die grafische Darstellung. Ein weiteres häufig auftretendes Problem besteht darin, dass die einzelnen Schritte eines Angriffspfads aus dem genutzten Angriffsb Baum-Tool in ein anderes Tool oder eine Tabelle übertragen werden müssen, in der die eigentliche TARA durchgeführt wird. Dies ist zum Beispiel notwendig, um die Machbarkeitsbewertung (Feasibility Evaluation) der Angriffsschritte durchzuführen. Natürlich gibt es mittlerweile moderne Werkzeuge, die Angriffsbäume und TARA-Funktionalität integrieren. Sollte dies jedoch im jeweiligen Projekt nicht der Fall sein, ist es wichtig abzuwägen, ob der Einsatz von Angriffsbäumen innerhalb des vorgesehenen Zeitrahmens für die TARA realistisch umsetzbar ist.

7.3 Machbarkeitsbewertung

Die Bewertung der Angriffsmachbarkeit (Attack Feasibility Evaluation) besteht in der Ermittlung des Grads der Angriffsmachbarkeit (Attack Feasibility Rating). Dieser beschreibt den Aufwand, der erforderlich ist, um einen Angriff umzusetzen – einschließlich aller nötigen Schritte und Ressourcen. Im Rahmen der Risikoberechnung stellt die Angriffsmachbarkeit die Wahrscheinlichkeit dar, mit der ein Angriff tatsächlich durchgeführt werden kann. Der Angriffsmachbarkeitsgrad wird für jeden Angriffspfad ermittelt, der ein bestimmtes Bedrohungsszenario realisiert. Die ISO/SAE 21434 definiert dazu vier Bewertungsstufen, die in Tab. 7.2 näher beschrieben sind. Je geringer der erforderliche Aufwand zur Durchführung eines Angriffspfads, desto höher ist seine Angriffsmachbarkeit.

Die ISO/SAE 21434 beschreibt drei mögliche Ansätze zur Ermittlung der Bewertung der Angriffsmachbarkeit:

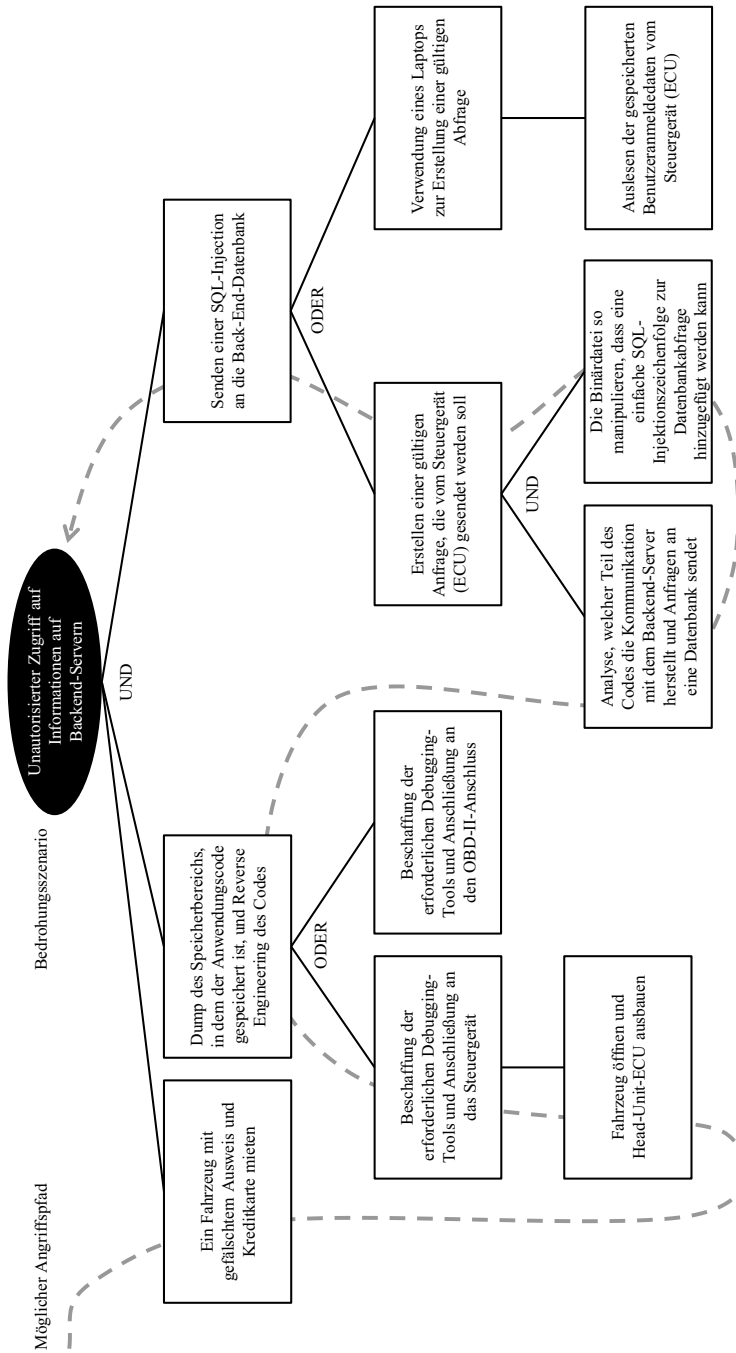


Abb. 7.3 Beispiel für einen Angriffsbaum für mögliche Angriffspfade zur Umsetzung eines Bedrohungsszenarios an einer Head-Unit-ECU

Tab. 7.2 Bewertung der Angriffsmachbarkeit nach ISO/SAE 21434

Bewertung der Angriffsmachbarkeit	Beschreibung
Hoch (High)	Die Umsetzung des Angriffspfads erfordert einen geringen Aufwand
Mittel (Medium)	Die Umsetzung des Angriffspfads erfordert einen mittleren Aufwand
Niedrig (Low)	Die Umsetzung des Angriffspfads erfordert einen hohen Aufwand
Sehr niedrig (Very low)	Die Umsetzung des Angriffspfads erfordert einen sehr hohen Aufwand

- *Angriffspotenzial-basierter Ansatz* (Attack Potential-based Approach): Dies ist ein weit verbreiteter und anerkannter Ansatz zur Bewertung des Angriffspotenzials. Ein wesentlicher Vorteil besteht in der Flexibilität, da verschiedene Kategorien und Bewertungsstufen berücksichtigt werden können. Darüber hinaus wird dieser Ansatz in etablierten Modellen und Frameworks der Cyber- und Informationssicherheit verwendet – etwa in Common Criteria [6], im ETSI TVRA-Modell [15], in EVITA [29] und im HEAVENS-Modell [25] –, häufig mit identischen oder sehr ähnlichen Bewertungsparametern.
- *CVSS-basierter Ansatz*: Der CVSS-basierte Ansatz ist ebenfalls ein bekanntes Framework, insbesondere zur Bewertung von Schwachstellen. Die Angriffsmachbarkeit wird über den Exploitability-Parameter modelliert, der ähnlich wie beim Angriffspotenzial anhand verschiedener Bewertungskategorien berechnet wird. Ein Vorteil des CVSS-Ansatzes liegt in der einfacheren Handhabbarkeit der Kategorien sowie in der Möglichkeit, Schwachstellen über den CVSS-Score vergleichbar zu machen. Allerdings kann die Bewertung weniger genau sein als beim Angriffspotenzial-Ansatz, da weniger Kategorien zur Verfügung stehen und einige davon nur wenige Bewertungsstufen bieten [40].
- *Angriffsvektor-basierter Ansatz* (Attack Vector-based Approach): Dies ist der einfachste Ansatz zur Bewertung der Angriffsmachbarkeit, da er nur auf einem einzigen Parameter basiert – dem Angriffsvektor. Dieser beschreibt den Kontext, in dem ein Angriff durchgeführt wird, z. B. ob der Angriff lokal oder von remote erfolgt. Der Angriffsvektor (Attack Vector) ist auch Bestandteil des CVSS-Modells. Laut ISO/SAE 21434 eignet sich dieser Ansatz besonders für frühe Entwicklungsphasen, da in dieser Phase häufig noch nicht alle Informationen vorliegen (z. B. keine Implementierungsdetails, fehlende Architekturentscheidungen oder noch offene Schnittstellendefinitionen). Eine erste TARA kann auf Basis des Angriffsvektor-Ansatzes erstellt und zu einem späteren Zeitpunkt durch eine detaillierte Analyse auf Basis des Angriffspotenzials ersetzt werden.

Die folgenden Abschnitte beschreiben diese drei Ansätze im Detail.

7.3.1 Ansatz basierend auf Angriffspotenzial

Der Angriffspotenzial-basierte Ansatz stützt sich auf den internationalen Standard ISO/IEC 18045 [3, 7] und bestimmt den Grad der Bewertung der Angriffsmachbarkeit anhand von fünf Bewertungskategorien: *Abgelaufene Zeit* (Elapsed Time), *Fachwissen* (Specialist Expertise), *Wissen über das Item oder die Komponente* (Knowledge of the Item or Component), *Zugriffsgelegenheiten* (Window of Opportunity), und *Ausrüstung* (Equipment). Die in der ISO/SAE 21434 verwendeten Bewertungskategorien und Werte sind an ISO/IEC 18045 angelehnt. Sie können jedoch an unternehmensspezifische Anforderungen und Richtlinien angepasst werden. Im Folgenden werden die einzelnen Kategorien beschrieben.

- **Zur Unsicherheit bei der Bewertung der Angriffsmachbarkeit** Die Auswahl der Bewertungsstufen für jede Kategorie erfolgt in der Praxis überwiegend theoretisch und basiert auf der subjektiven Einschätzung der Bewertenden. Dennoch sollte die Bewertung möglichst realitätsnah erfolgen. Tatsächlich erlaubt ISO/IEC 18045, für jedes Angriffsszenario Penetrationstests durchzuführen, um die theoretische Analyse zu bestätigen oder zu widerlegen (siehe *Abschnitt B.6.2.4 Calculation of attack potential* in [7]). Natürlich wäre die praktische Überprüfung jeder Angriffspfad-Variante der Idealfall, ist aber in der Regel nicht realisierbar. Daher ist es entscheidend, dass das Bewertungsteam über eine ausreichende technische Fachkenntnis verfügt. Wenn praktische Erfahrung fehlt, kann die Nutzung von Katalogen und Erfahrungswerten hilfreich sein. Dennoch ist jeder Angriffspfad systemspezifisch, selbst wenn er auf den ersten Blick einem bereits bekannten Exploit ähnelt. Beispielsammlungen für Bewertungen der Angriffsmachbarkeit verschiedener Angriffsszenarien und Assets finden sich u.a. in [40]. Im Idealfall wird die Bewertung durch ein Automotive Penetrationstest-Team unterstützt oder validiert, z.B. durch Brainstorming oder Review.

Für jede der fünf Kategorien wird ein numerischer Wert vergeben. Das Angriffspotenzial ergibt sich durch die Aufsummierung dieser Einzelwerte – gemäß der Methodik von ISO/IEC 18045. Die ISO/SAE 21434 schlägt eine angepasste Zuordnung der Werte und Parameter aus ISO/IEC 18045 vor (siehe *Tabelle G.6* und *Tabelle G.7* in [20]). Die Bewertungsstufen der fünf Kategorien werden in Tab. 7.3 dargestellt, und die Zuordnung des resultierenden Angriffspotenzials zum Grad der Angriffsmachbarkeit erfolgt gemäß Tab. 7.4.

7.3.1.1 Abgelaufene Zeit

Die Kategorie *Abgelaufene Zeit* (Elapsed Time) beschreibt, wie viel Zeit ein Angreifer insgesamt aufbringen muss, um: eine Schwachstelle zu identifizieren, eine geeignete Angriffsmethode (z. B. einen Exploit) zu entwickeln und den Angriff tatsächlich umzuset-

Tab. 7.3 Berechnung des Angriffspotenzials (*Tabelle G.6* von ISO/SAE 21434 [20])

Abgelaufene Zeit		Fachwissen		Wissen über das Item oder die Komponente		Zugriffsebenen		Ausrüstung	
Stufe	Wert	Stufe	Wert	Stufe	Wert	Stufe	Wert	Stufe	Wert
≤ 1 Tag	0	Laie	0	Öffentlich	0	Unbegrenzt	0	Standard	0
≤ 1 Woche	1	Kompetent	3	Eingeschränkt	3	Einfach	1	Spezialisiert	4
≤ 1 Monat	4	Experte	6	Vertraulich	7	Moderat	4	Maßgeschneidert	7
≤ 6 Monate	17	Mehrfach-Experten	8	Streng vertraulich	11	Schwierig/Keine	10	Mehrfach maßgeschneidert	9
> 6 Monate	19	—	—	—	—	—	—	—	—

Tab. 7.4 Zuordnung von Angriffsmachbarkeitsgrad und Angriffspotenzial

Angriffsmachbarkeitsgrad	Angriffspotenzial
Hoch	0–9
	10–13
Mittel	14–19
Niedrig	20–24
Sehr niedrig	≥ 25

zen. Der Standard ISO/SAE 21434 übernimmt hierfür eine angepasste Bewertungsskala aus ISO/IEC 18045, um einheitlich die erforderliche Zeitspanne in Bezug zur Machbarkeit (Feasibility) zu setzen. Wir veranschaulichen die Bewertungsskala und geben praxisnahe Beispiele wie folgt:

- ≤ 1 Tag: Der Angriff ist einfach durchzuführen, und der Angreifer verfügt bereits über das nötige Wissen und die passenden Methoden. Zum Beispiel kann eine bekannte Schwachstelle mit allgemein verfügbaren Tools aus dem Internet ausgenutzt werden. Ein weiteres Beispiel ist ein Enumerationsangriff, etwa durch Anschluss eines Scanners (z. B. ein PC mit CAN-Dongle) an die OBD-II-Schnittstelle eines Fahrzeugs.
- ≤ 1 Woche: Ein Angreifer mit Penetrationstest-Erfahrung kann Zugang zu einem lokal verfügbaren Steuergerät erlangen, wenn diese nicht über ausreichende Absicherung verfügt. So kann beispielsweise ein Bootloader-Passwort per Brute-Force mit einem Python-Skript geknackt werden. Viele solcher Beispiele sind in [32] dokumentiert.
- ≤ 1 Monat: Weniger als ein Monat kann die Zeitspanne sein, die benötigt wird, um ein Exploit auf Basis einer bekannten Schwachstelle zu entwickeln. Der Angreifer weiß beispielsweise, dass das Item oder die Komponente eine bestimmte Schwachstelle aufweist, muss jedoch zunächst ein Tool programmieren, etwa ein Skript, das CAN-Nachrichten sendet und interpretiert.
- ≤ 6 Monate: Der Angreifer benötigt unter Umständen nicht viel Zeit, plant jedoch gezielt den Angriff auf ein bestimmtes Fahrzeug.
- > 6 Monate: Typisches Beispiel für APT-Angriffe (Advanced Persistent Threat) oder Angriffe, die eine aufwendige Planung und komplexe Logistik erfordern. Dies kann auch Forschungsarbeit einschließen, um eine Schwachstelle in einem spezifischen System zu finden.

7.3.1.2 Fachwissen

Das Kriterium *Fachwissen* (Specialist Expertise) bezieht sich auf das Maß an Fachwissen, welches ein Angreifer benötigt, um den Angriff durchzuführen. Dabei kann es sich um allgemeines Wissen zu zugrunde liegenden Prinzipien handeln, um Spezialkenntnisse in

bestimmten Bereichen oder um detailliertes Wissen über spezifische Angriffsmethoden. Die von ISO/SAE 21434 vorgeschlagene Bewertungsskala mit Beispielen lässt sich wie folgt darstellen:

- *Laie* (Layman): Verfügt über kein oder nur sehr geringes technisches Wissen im Vergleich zu Fachleuten. Ein typisches Beispiel ist das sogenannte Script Kiddie – eine Person ohne tiefergehende Kenntnisse, die mit im Internet frei verfügbaren Tools und Schritt-für-Schritt-Anleitungen experimentiert. Ein Laie kann aber auch ein Autodieb sein, der handelsübliche Werkzeuge nutzt, um Funksignale von Schlüsselanhängern abzufangen oder weiterzuleiten (Relay-Angriffe).
- *Kompetent* (Proficient): Verfügt über grundlegende Sachkenntnisse hinsichtlich des sicherheitsrelevanten Verhaltens eines Produkts oder Systemtyps. Solche Personen könnten erfahrene Fahrzeughalter, Werkstattmitarbeiter oder Tuner sein, die in der Lage sind, gängige Manipulationen wie Manipulation von Tachometern oder die Installation gefälschter Komponenten durchzuführen.
- *Experte* (Expert): Besitzt tiefgehendes Verständnis der eingesetzten Algorithmen, Protokolle, Hardware, Architekturen, Sicherheitsmechanismen und ingenieurtechnischen Konzepte, wie sie im Fahrzeugdesign verwendet werden. Darüber hinaus beherrschen Experten Methoden zur Entwicklung neuer Angriffe, Kryptografie, klassische Angriffstechniken für den betreffenden Produkttyp sowie bekannte Schwachstellen. Typische Vertreter dieser Kategorie sind Entwicklungsingenieure (z. B. aus dem OEM- oder Zuliefererbereich), motivierte Hacker, IT-Sicherheitsfachkräfte oder akademische Forscher.
- *Mehrfach-Experten* (Multiple Experts): Ein Angriff erfordert die Zusammenarbeit mehrerer Fachleute mit jeweils spezialisiertem Wissen auf Expertenniveau. Solche Teams sind etwa in Forschungseinrichtungen, spezialisierten Laboren, kriminellen Organisationen oder staatlich unterstützten Stellen (z. B. Nachrichtendiensten) zu finden.

7.3.1.3 Wissen über das Item oder die Komponente

Wissen über das Item oder die Komponente (Knowledge of the Item or Component) beschreibt, wie viel spezifisches Wissen über das Zielsystem erforderlich ist, um einen Angriff erfolgreich durchzuführen. Die Bewertung nach ISO/SAE 21434 erfolgt in vier Stufen. Im Folgenden sind diese Bewertungsstufen mit passenden Beispielen dargestellt:

- *Öffentlich zugängliche Informationen* (Public Information): Informationen über das Item oder die Komponente, die frei verfügbar sind (z. B. aus dem Internet). Beispiele hierfür sind öffentlich zugängliche Produktdokumentationen, Internetforen, Fachliteratur oder Spezifikationen von eingesetzten Standards und Protokollen (z. B. CAN, Ethernet, AUTOSAR).
- *Eingeschränkt zugängliche Informationen* (Restricted Information): Informationen über das Item oder die Komponente, deren Verfügbarkeit kontrolliert ist (z. B. Wissen, das

innerhalb einer Entwicklungsorganisation verwaltet und nur unter Geheimhaltungsvereinbarungen mit Dritten geteilt wird). Beispiele sind interne Dokumentationen, die zwischen Hersteller und Zulieferer ausgetauscht werden, etwa Anforderungs- oder Design-Spezifikationen.

- *Vertrauliche Informationen* (Confidential Information): Vertrauliche Informationen über das Item oder die Komponente (z. B. Informationen, die nur innerhalb bestimmter Teams der Entwicklungsorganisation zugänglich sind). Beispiele hierfür sind Informationen zu Wegfahrsperrern, Quellcode oder andere sicherheitskritische Designdetails. Auch sicherheitsrelevante Unterlagen wie Penetrationstest-Berichte oder Schwachstellenanalysen gehören hierzu – vorausgesetzt, sie wurden noch nicht adressiert oder enthalten Details, die zur Aufdeckung weiterer Schwachstellen oder zur direkten Kompromittierung genutzt werden könnten.
- *Streng vertrauliche Informationen* (Strictly Confidential Information): Streng vertrauliche Informationen über das Item oder die Komponente (z. B. Informationen, die nur einem sehr kleinen Personenkreis bekannt sind, deren Zugriff äußerst streng kontrolliert und ausschließlich nach dem Need-to-know-Prinzip sowie individueller Verpflichtung gewährt wird). Beispiele sind herstellerspezifische Kalibrierdaten oder Speicherabbildungen (Memory Maps), die ausschließlich intern beim Hersteller oder Zulieferer dokumentiert sind.

7.3.1.4 Zugriffsgelegenheiten

Die Kategorie *Zugriffsgelegenheiten* (Window of Opportunity) beschreibt den Umfang des Zugriffs, den ein Angreifer auf das zu analysierende Element oder die Komponente benötigt, um einen Angriff auszuführen. Es kombiniert die Art des Zugriffs (z. B. lokal oder physisch) mit der Zugriffszeit (z. B. begrenzt oder unbegrenzt). Die Bewertung erfolgt gemäß ISO/SAE 21434 und lässt sich anhand der folgenden Kategorien und Beispiele erläutern:

- *Unbegrenzt* (Unlimited): Das Zielsystem ist jederzeit über ein öffentliches bzw. unsicheres Netzwerk erreichbar, ohne zeitliche Einschränkung. Dies umfasst sowohl Fernzugriff ohne physische Präsenz als auch unbegrenzten physischen Zugang. Beispielsweise ein vollständig remote durchführbarer Angriff ohne Vorbedingungen; uneingeschränkter physischer Zugriff des Fahrzeugbesitzers zur Durchführung eines Chiptunings.
- *Einfach* (Easy): Das Zielsystem ist gut erreichbar, jedoch nur für einen begrenzten Zeitraum verfügbar. Der Zugriff erfolgt von remote und erfordert keine physische Präsenz. Beispielsweise Bluetooth-Kopplung innerhalb eines begrenzten Zeitfensters, Remote-Software-Updates, oder Fernangriffe, die voraussetzen, dass das Fahrzeug steht.
- *Moderat* (Moderate): Eingeschränkte Verfügbarkeit des Zielsystems. Der Zugriff ist physisch oder logisch limitiert, aber möglich, ohne Spezialwerkzeuge einzusetzen. Beispielsweise Zugriff auf ein unverschlossenes Fahrzeug, um eine offene Schnittstelle wie den

OBD-II-Port zu erreichen; drahtlose Angriffe aus kurzer Distanz wie Replay-Angriffe oder Angriffe auf Funksignale des Schlüssels oder WLAN im Fahrzeug.

- *Schwierig* (Schwierig): Sehr geringe Verfügbarkeit des Zielsystems. Die Zugangsmöglichkeiten sind in der Praxis schwer oder nicht durchführbar. Beispielsweise Dekapselung eines ICs oder das Brechen eines kryptografischen Schlüssels per Brute-Force in kürzerer Zeit als die Schlüsselrotation erfolgen kann.

7.3.1.5 Ausrüstung

Die Kategorie *Ausrüstung* (Equipment) beschreibt die technische Ausstattung, die ein Angreifer benötigt, um eine Schwachstelle zu identifizieren und den Angriff durchzuführen. Die Bewertung gemäß ISO/SAE 21434 erfolgt wie folgt:

- *Standard* (Standard): Die Ausrüstung ist für den Angreifer leicht verfügbar. Diese kann entweder bereits im Produkt enthalten sein (z. B. ein Debugger im Betriebssystem) oder problemlos beschafft werden (z. B. über das Internet verfügbare Tools oder einfache Angriffsskripte). Beispielsweise ein handelsüblicher Laptop, ein CAN-Dongle, Standardsoftware wie Kali Linux oder frei verfügbare Protokollanalysatoren.
- *Spezialisiert* (Specialized): Die Ausrüstung ist nicht unmittelbar verfügbar, kann aber mit vertretbarem Aufwand beschafft oder selbst entwickelt werden. Dies kann den Kauf spezieller Geräte (z. B. zur Seitenkanalanalyse) oder die Nutzung umfangreicher Ressourcen (z. B. Botnetze) beinhalten. Ebenso zählt hierzu die Entwicklung fortgeschrittener Angriffswerkzeuge. Beispielsweise kommerzielle Debugging-Hardware, spezielle Fahrzeugelektronik-Tools, professionelle Testsysteme oder chemische Substanzen.
- *Maßgeschneidert* (Bespoke): Die Ausrüstung muss eigens entwickelt oder aufwendig beschafft werden. Sie ist nicht öffentlich verfügbar oder wird über den Schwarzmarkt gehandelt. Gegebenenfalls unterliegt sie gesetzlichen Beschränkungen oder ist extrem kostspielig. Beispielsweise vom Hersteller geschützte Tools, Elektronenmikroskope, speziell entwickelte Exploit-Software mit Zugangsbeschränkungen.
- *Mehrfach maßgeschneidert* (Multiple Bespoke): Für verschiedene Schritte des Angriffs sind unterschiedliche maßgeschneiderte Ausrüstungen erforderlich.

7.3.2 CVSS-basierter Ansatz

Das Common Vulnerability Scoring System (CVSS) ist ein weithin anerkanntes, offenes Rahmenwerk zur Bewertung der Schwere von Software- und Hardware-Schwachstellen. Wir folgen in diesem Buch der CVSS-Version 3.1 [5].

Der CVSS besteht aus drei Metrikgruppen: *Base* (Basis), *Temporal* (Zeit) und *Environmental* (Umwelt). Der *Basis-Score* (Basisbewertung) ist die am häufigsten verwendete Kennzahl und gibt den Schweregrad einer Schwachstelle anhand ihrer intrinsischen Eigen-

schaften an. Diese Eigenschaften gelten als zeitlich konstant und die Bewertung basiert auf dem Worst-Case-Effekt in den verschiedenen Umgebungen, in denen die Schwachstelle auftreten kann. Die *Temporal Metrics* (Zeitmetriken) modifizieren die Basisbewertung, indem sie Eigenschaften berücksichtigen, die sich im Laufe der Zeit ändern können – wie z. B. die Verfügbarkeit eines Exploits oder der Stand der Behebung (Remediation Level). Die *Environmental Metrics* (Umweltmetriken) passen schließlich sowohl die Basis- als auch die Zeitbewertung an die spezifischen Gegebenheiten der betrachteten Umgebung an. Die Kombination aller angewendeten Metrikgruppen ergibt den endgültigen Schweregrad, dargestellt als numerischer Wert, der als *CVSS-Score* bezeichnet wird.

Einschränkung auf Exploitability-Metriken Das CVSS-Bewertungsframework wurde entwickelt, um verschiedene Aspekte einer Schwachstelle zu bewerten, die ein Risiko darstellen. Innerhalb der Basismetriken werden die Eigenschaften einer Schwachstelle durch die sogenannten *Exploitability-Metriken* bewertet. Darüber hinaus umfasst die Basismetrik auch die *Score-* und *Impact Metriken*. Die Scope-Metrik beschreibt den Einflussbereich der Schwachstelle über den ursprünglichen Sicherheitskontext hinaus. Die Impact-Metrik wiederum bewertet die Auswirkungen der Schwachstelle auf die Cybersecurity-Eigenschaften: Vertraulichkeit, Integrität und Verfügbarkeit. Die ISO/SAE 21434 schlägt vor, die Bewertung des Angriffspotenzials ausschließlich auf die Exploitability-Metriken zu beschränken. Die Scope- und Impact-Metriken sind im Zusammenhang mit der Ermittlung des Angriffspotenzials nicht geeignet. Beispielsweise wird die Auswirkung einer Schwachstelle in der ISO/SAE 21434 durch ein separates Verfahren auf Basis von Schaden-Szenarien modelliert (vgl. *Anhang G, Abschn. G.3* in [20]). Ebenso sind die Temporal (zeitlichen) und Environmental (umgebungsbezogenen) Metriken nicht geeignet zur Bestimmung des Angriffspotenzials eines Angriffspfads und werden daher in diesem Ansatz nicht berücksichtigt. Es ist zu beachten, dass durch die ausschließliche Betrachtung der Exploitability-Metriken der berechnete Wert nicht dem vollständigen CVSS-Score gemäß dem CVSS-Framework entspricht. Aus diesem Grund bezeichnet ISO/SAE 21434 diesen Wert als *CVSS-Ausnutzbarkeit-Wert*.

Die *Exploitability-Metriken* umfassen *Angriffsvektor (AV)*, *Angriffskomplexität (AC)*, *Erforderliche Privilegien (PR)* und *Benutzereinwirkung (UI)*. Wir beschreiben jede dieser Kategorien im Folgenden kurz. Eine ausführliche Beschreibung sowie ein entsprechender Rechner sind in [5] zu finden.

7.3.2.1 Angriffsvektor (AV)

Die möglichen Bewertungsstufen für den *Angriffsvektor (AV)* (Attack Vector) sind:

- *Netzwerk (N)*: Das Zielsystem (verwundbare Komponente) kann aus der Ferne über Netzwerke mit einem oder mehreren Hops Abstand ausgenutzt werden. Dies ist der klassische Fall eines Zugriffs über das Internet. Numerischer Wert: 0,85

- *Angrenzend (A)*: Der Angreifer muss sich im gleichen logischen oder physischen Netzwerk wie das Zielsystem befinden. Beispiele hierfür sind ein gemeinsames WLAN oder Bluetooth-Netzwerk, oder ein logisches IP-Netzwerk, z. B. über ein VPN. Numerischer Wert: 0,62
- *Lokal (L)*: Das Zielsystem muss nicht mit einem Netzwerk verbunden sein, damit die Schwachstelle ausgenutzt werden kann. Die Ausnutzung erfolgt entweder durch physischen Zugriff auf das System oder durch Handlungen einer anderen Person, die zur erfolgreichen Ausnutzung notwendig sind. In letzterem Fall ist zusätzlich der Wert für Benutzereinwirkung (UI) zu berücksichtigen. Numerischer Wert: 0,55
- *Physisch (P)*: Der Angreifer muss kurzzeitig oder dauerhaft physischen Kontakt mit dem Zielsystem herstellen. Numerischer Wert: 0,20

7.3.2.2 Angriffskomplexität (AC)

Die möglichen Bewertungsstufen für die Kategorie *Angriffskomplexität (AC)* (Attack Complexity) sind:

- *Niedrig (L)*: Der Angreifer benötigt keine besonderen Bedingungen auf dem Zielsystem, um die Schwachstelle auszunutzen. Der Angriff wird mit hoher Wahrscheinlichkeit bei jedem Versuch erfolgreich sein. Numerischer Wert: 0,77
- *Hoch (H)*: Der Erfolg des Angriffs hängt von Bedingungen ab, die außerhalb der Kontrolle des Angreifers liegen. Das Zielsystem muss vorbereitet oder manipuliert werden, bevor die Schwachstelle ausgenutzt werden kann. Beispiele hierfür sind das Sammeln von Informationen über das Zielsystem (z. B. Konfigurationsdaten oder gemeinsame Geheimnisse) oder das Eindringen in ein bestimmtes Netzwerk. Numerischer Wert: 0,44

7.3.2.3 Erforderliche Privilegien (PR)

Die möglichen Bewertungsstufen für die Kategorie *Erforderliche Privilegien (PR)* (Privileges Required) sind:

- *Keine (N)*: Der Angreifer benötigt keine Autorisierung auf dem Zielsystem, um die Schwachstelle auszunutzen. Numerischer Wert: 0,85
- *Niedrig (L)*: Es sind einfache Benutzerrechte erforderlich, z. B. Einstellungen und Dateien, die nur den Benutzer selbst betreffen. Numerischer Wert: 0,62 (bei unverändertem Scope)
- *Hoch (H)*: Der Angreifer muss über erhöhte Berechtigungen verfügen, die über die eines normalen Benutzers hinausgehen. Numerischer Wert: 0,27 (bei unverändertem Scope)

7.3.2.4 Benutzereinwirkung (UI)

Die möglichen Bewertungsstufen für die Kategorie *Benutzereinwirkung (UI)* (User Interaction) sind:

- *Keine (N)*: Die Schwachstelle kann ohne jegliche Benutzerinteraktion ausgenutzt werden. Numerischer Wert: 0,85
- *Erforderlich (R)*: Eine Benutzeraktion ist erforderlich, bevor die Schwachstelle erfolgreich ausgenutzt werden kann. Numerischer Wert: 0,62

7.3.2.5 CVSS-Ausnutzbarkeit-Wert und Bewertung der Angriffsmachbarkeit

Der CVSS-Ausnutzbarkeit-Wert (CVSS Exploitability Value) liegt im Bereich von 0,12 bis 3,89 und wird durch Multiplikation der numerischen Werte der jeweiligen Bewertungskategorien wie folgt berechnet:

$$\text{Ausnutzbarkeit (Exploitability)} = 8,22 \times \text{AV} \times \text{AC} \times \text{PR} \times \text{UI}$$

Die abschließende Bewertung der Bewertung der Angriffsmachbarkeit (Angriffswahrscheinlichkeit) für einen Angriffspfad erfolgt durch eine Zuordnung des berechneten CVSS-Ausnutzbarkeit-Werts zu einem Bewertungsniveau. Die ISO/SAE 21434 stellt hierfür ein Beispiel-Mapping zur Verfügung, das in Tab. 7.5 dargestellt ist.

- **Anwendbarkeit von CVSS im Rahmen der TARA** Die praktische Anwendbarkeit von CVSS für TARAs im Automobilbereich ist nach unserer Erfahrung sehr begrenzt. Der Hauptgrund dafür ist, dass sich Angriffspfade in der Regel aus Handlungen zusammensetzen, die sich nicht ohne Weiteres als Schwachstellen modellieren lassen – was jedoch die Grundidee von CVSS ist. Betrachten wir zum Beispiel den in Abschn. 7.2.2 beschriebenen Angriffspfad. Viele der darin enthaltenen Schritte lassen sich nicht eindeutig einer CVSS-Exploitability-Kategorie zuordnen. Nehmen wir den Schritt *Ein Fahrzeug mit gefälschtem Ausweis und Kreditkarte mieten*: Welcher Wert soll hier für den Angriffsvektor vergeben werden? Da es sich um eine physische Handlung in der realen Welt handelt, wäre *Physisch* die naheliegende Wahl. Damit ergibt sich jedoch ein erhebliches Problem: Der CVSS-Wert für *Physisch* ist 0,20 – ein sehr

Tab. 7.5 Zuordnung der Bewertung der Angriffsmachbarkeit zum CVSS-Ausnutzbarkeit-Wert (gemäß Tabelle G.8 in [20])

Bewertung der Angriffsmachbarkeit	CVSS-Ausnutzbarkeit-Wert
Hoch	2,96–3,89
Mittel	2,00–2,95
Niedrig	1,06–1,99
Sehr niedrig	0,12–1,05

niedriger Exploitability-Wert. Das bedeutet, dass selbst bei günstiger Bewertung der übrigen Kategorien der resultierende CVSS-Exploitability-Wert unter 1 liegt, was laut ISO/SAE 21434 der Angriffswahrscheinlichkeit *Sehr niedrig* entspricht. Eine solche Bewertung wäre in diesem Fall eindeutig falsch, da das *Ein Fahrzeug mit gefälschtem Ausweis und Kreditkarte mieten* mit geringem Aufwand möglich ist – auch wenn gefälschte Dokumente verwendet werden. Um diesen Widerspruch zu lösen, müsste der Bewertende einen höheren Wert wie *Netzwerk* ansetzen – was jedoch keine natürliche oder sachgerechte Verbindung zur tatsächlichen Handlung darstellt. Aus diesem Grund ist die Anwendung von CVSS auf vollständige Angriffspfade oder reale physische Aktionen oft nicht praktikabel. Jedoch kann CVSS sinnvoll eingesetzt werden, um einzelne Schritte eines Angriffspfads zu bewerten, sofern diese tatsächlich als Schwachstellen betrachtet und anhand der CVSS-Kategorien bewertet werden können. In der Praxis kann daher eine Mischform der Bewertungsansätze hilfreich sein – etwa die Kombination des Angriffspotenzial-basierten Ansatzes mit dem CVSS-basierten Ansatz, je nach Art des zu bewertenden Angriffsschritts. Dabei muss jedoch sichergestellt sein, dass die resultierenden Bewertungen vergleichbar gemacht werden können und das verwendete TARA-Tool eine gemischte Methodik unterstützt.

7.3.3 Angriffsvektor-basierter Ansatz

Der Angriffsvektor-basierte Ansatz berechnet die Bewertung der Angriffsmachbarkeit ausschließlich anhand eines einzigen Parameters: des CVSS-*Angriffsvektors* (AV). Dieser Ansatz wird empfohlen, wenn die TARA zu einem sehr frühen Zeitpunkt der Entwicklung eines Items oder einer Komponente durchgeführt wird und noch nicht genügend technische Informationen vorliegen, um detailliertere Bewertungsmethoden anzuwenden. Mit dem Angriffsvektor-basierten Ansatz ist es zumindest möglich, eine erste TARA durchzuführen, die relevanten Assets und Bedrohungen zu identifizieren und die Bewertung auf dem Kontext zu basieren, in dem der Angriffspfad ausgenutzt werden kann. Sobald die Produktentwicklung eine gewisse Reife erreicht hat, kann die ursprünglich auf dem Angriffsszenario basierende TARA verfeinert und neu bewertet werden, beispielsweise mithilfe des Attack-Potential-basierten Ansatzes. Ein Beispiel für die Zuordnung zwischen der Bewertung der Angriffsmachbarkeit und dem jeweiligen Angriffsvektor ist in Tab. 7.6 dargestellt.

7.3.4 Bestimmung der Bewertung der Angriffsmachbarkeit durch Angriffspfade (Attack Paths) mit mehreren Schritten

Ein Angriffspfad besteht in der Regel aus mehreren Einzelschritten, wie in unserem Beispiel in Abschn. 7.2.2 gezeigt. Die Bewertung der Angriffsmachbarkeit erfolgt jedoch für den gesamten Angriffspfad, d. h., am Ende steht ein einziger Wert, unabhängig davon, wie viele

Tab. 7.6 Zuordnung der Bewertung der Angriffsmachbarkeit zum Angriffsvektor (Attack Vector) von CVSS (basierend auf *Tabelle G.9* aus [20])

Bewertung der Angriffsmachbarkeit	Angriffsvektor
Hoch	Netzwerk
Mittel	Angrenzend
Niedrig	Lokal
Sehr niedrig	Physisch

Schritte zur Durchführung des Angriffs notwendig sind. Zwar ist es grundsätzlich möglich, die Angriffswahrscheinlichkeit pauschal für den gesamten Pfad zu beurteilen – insbesondere durch erfahrene Cybersecurity-Teams, die auf fundierte Annahmen zurückgreifen können –, jedoch ist es oft genauer und nachvollziehbarer, die Bewertung für jeden Schritt separat durchzuführen. Am Ende ergibt sich der Angriffswahrscheinlichkeitswert für den gesamten Pfad aus der Kombination der maximalen (also am wenigsten umsetzbaren) Werte jeder Kategorie aus allen beteiligten Schritten.

In unserem Beispiel in Abschn. 7.2.2 zeigen wir, wie die Bewertung des Angriffspotenzials bei mehreren Schritten durchgeführt werden kann. Die Ergebnisse werden in Tab. 7.7 dargestellt, basierend auf dem Angriffspotenzial-basierten Ansatz. Die höchsten Werte jeder Bewertungskategorie (z. B. Abgelaufene Zeit, Fachwissen, Kenntnisse über das Item usw.) sind hervorgehoben. Daran lässt sich erkennen, dass die ersten beiden Schritte – *Ein Fahrzeug mit gefälschtem Ausweis und Kreditkarte mieten* sowie *Fahrzeug öffnen und Head-Unit-ECU extrahieren* – identische Werte in allen Bewertungskategorien aufweisen. In einem solchen Fall kann das Cybersecurity-Team prüfen, ob beide Schritte unverzichtbar sind oder in einem zusammengefasst werden können. Diese Konsolidierung kann zu einer einfacheren und transparenteren Bewertung führen.

Die Kategorien *Wissen über das Item oder die Komponente* sowie *Zugriffsgelegenheiten* sind in unserem Beispiel für alle Schritte gleich. Daher übernimmt die finale Bewertung der Angriffsmachbarkeit für diese beiden Kategorien die jeweiligen Werte *Öffentlich* (Public) und *Unbegrenzt* (Unlimited). Die Kategorie *Abgelaufene Zeit* (Elapsed Time) weist den höchsten Wert – also die geringste Machbarkeit – beim Schritt *Speicherbereich auslesen, in dem der Anwendungscode gespeichert ist, und Reverse Engineering durchführen* auf. Für diesen Schritt wird der Wert ≤ 6 Monate verwendet und somit für die finale Bewertung übernommen. Auch beim *Fachwissen* (Specialist Expertise) hat dieser Schritt den höchsten Wert, nämlich *Experte*. Zu beachten ist, dass dabei der erste auftretende Maximalwert pro Kategorie gewertet wird. Dass in anderen Schritten ebenfalls *Experte* vorkommt, ändert nichts an der Bewertung. Die Kategorie *Ausrüstung* (Equipment) erreicht ihren höchsten Wert *Spezialisiert* erstmals beim Schritt *Analysieren, welcher Teil des Codes die Kommunikation mit dem Backend-Server aufbaut und Anfragen an eine Datenbank sendet*. Die letzte Spalte der Tab. 7.7 zeigt die individuell berechneten Bewertungen der Angriffswahrscheinlichkeit

pro Schritt. Die Kombination der höchsten Einzelwerte jeder Kategorie, einschließlich der Berechnung der finalen Angriffswahrscheinlichkeit für den gesamten Angriffspfad, ist in der letzten Zeile der Tabelle zusammengefasst.

Es ist ersichtlich, dass die finale Bewertung der Angriffsmachbarkeit deutlich niedriger ausfällt (*sehr gering*), als es die einzelnen Schritte des Angriffs vermuten lassen. Als Beispiel zeigen wir in Tab. 7.8 die CVSS-basierte Bewertung für dasselbe Beispiel. Wie in Abschn. 7.3.2 erläutert, können nicht alle Schritte tatsächlich mit dem CVSS-Modell bewertet werden.

Effizienz der Bewertung mehrerer Schritte Wie im Beispiel in Tab. 7.7 ersichtlich, ist die Bewertung der Angriffsmachbarkeit (Attack Feasibility) für jeden einzelnen Schritt eines möglichen Angriffspfads ein zeitaufwändiger Prozess. Dennoch stellt diese Bewertung einen der wichtigsten Bestandteile einer TARA dar und muss sorgfältig durchgeführt werden, um fehlerhafte Risikowerte am Ende der Analyse zu vermeiden. Nach unserer Erfahrung steigt die Effizienz dieser Bewertung jedoch mit der Erfahrung des Cybersecurity-Teams, das die TARA durchführt. Die einzelnen Schritte eines Angriffspfads sind spezifisch für das jeweilige Item oder die jeweilige Komponente und nicht verallgemeinerbar über unterschiedliche Projekte hinweg. Ein hochqualifiziertes Team kann jedoch in der Lage sein, die Bewertung der Angriffswahrscheinlichkeit für den gesamten Angriffspfad effizient durchzuführen.

Beispielsweise kann das Team bei der Analyse des Schrittes: *Speicherbereich auslesen, in dem der Anwendungscode gespeichert ist, und Reverse Engineering durchführen* direkt abschätzen, dass der Gesamtwert für die Kategorie *vergangene Zeit* (Elapsed Time) auf ≤ 6 Monate gesetzt werden muss. Beim Durchsehen der weiteren Schritte kommt das Team zum Schluss, dass kein anderer Schritt einen höheren (also weniger wahrscheinlichen) Wert in dieser Kategorie aufweist. Dieses Vorgehen kann auf die übrigen Kategorien analog angewendet werden.

7.3.5 Beziehung zum Angreifer-Modell

Wir haben die Beziehung zwischen dem Angreifer-Modell und Bedrohungen bereits bei der Definition des Angreifer-Modells im Rahmen der Scope-Festlegung in Abschn. 5.6.3 eingeführt. Dabei wurde eine *Bedrohungsstufe* (Threat Level) definiert, das sich an ETSI TVRA orientiert und die Fähigkeiten mit der Motivation eines Angreifers kombiniert. Die Angreiferfähigkeiten repräsentieren das Maß an Fähigkeiten bzw. Angriffspotenzial, das ein Angreifer erreichen kann. Diese Fähigkeiten werden anhand der Kategorien des Angriffspotenzial-basierten Bewertungsansatzes bestimmten Angriffspotenzialwerten zugeordnet.

Tab. 7.7 Beispiel für die Bewertung der Angriffsmachbarkeit für einen Angriffspfad (Attack Path) mit mehreren Schritten (Angriffspotenzialbasierter Ansatz)

Schritte für den Angriffspfad	Abgelaufene Zeit	Fachwissen	Wissen über das Item oder die Komponente	Zugriffsgelegenheiten	Ausrüstung	Bewertung der Angriffsmachbarkeit
Ein Fahrzeug mit gefälschtem Ausweis und Kreditkarte mieten	≤ 1 Tag	Laie	Öffentlich	Unbegrenzt	Standard	Hoch
Fahrzeug öffnen und Head-Unit-ECU ausbauen	≤ 1 Tag	Laie	Öffentlich	Unbegrenzt	Standard	Hoch
Recherchieren, wie man Diagnosezugriff auf das Steuergerät erhält	≤ 1 Woche	Kompetent	Öffentlich	Unbegrenzt	Standard	Hoch
Beschaffung der erforderlichen Debugging-Tools und Anschließung an das Steuergerät (z. B. mit UDS oder ungeschütztem JTAG)	≤ 1 Woche	Laie	Öffentlich	Unbegrenzt	Standard	Hoch
Dump des Speicherbereichs, in dem der Anwendungscode gespeichert ist, und Reverse Engineering des Codes	≤ 6 Monate	Experte	Öffentlich	Unbegrenzt	Standard	Niedrig
Analyse, welcher Teil des Codes die Kommunikation mit dem Backend-Server herstellt und Anfragen an eine Datenbank sendet	≤ 1 Monat	Experte	Öffentlich	Unbegrenzt	Spezialisiert	Mittel
Die Binärdatei so manipulieren, dass eine einfache SQL-Injektionszeichenfolge zur Datenbankabfrage hinzugefügt werden kann	≤ 1 Monat	Experte	Öffentlich	Unbegrenzt	Spezialisiert	Mittel
Gesamtbewertung für den Angriffspfad	≤ 6 Monate	Experte	Öffentlich	Unbegrenzt	Spezialisiert	Sehr niedrig¹

¹ Der Wert *Sehr niedrig* wird aus allen Kategorien der Zeile „Gesamtbewertung für den Angriffspfad“ neu berechnet.

Tab. 7.8 Beispiel für die Bewertung der Angriffsmachbarkeit für einen Angriffspfad (Attack Path) mit mehreren Schritten (CVSS-basierter Ansatz)

Schritte für den Angriffspfad Bewertung der Angriffsmachbarkeit	Angriffsvektor	Angriffskomplexität	Erforderliche Privilegien	Benutzereinwirkung	Ausrüstung
Ein Fahrzeug mit gefälschtem Ausweis und Kreditkarte mieten	—	—	—	—	—
Fahrzeug öffnen und Head-Unit-ECU ausbauen	—	—	—	—	—
Recherchieren, wie man Diagnosezugriff auf das Steuergerät erhält	—	—	—	—	—
Beschaffung der erforderlichen Debugging-Tools und Anschließung an das Steuergerät (z. B. mit UDS oder ungeschütztem JTAG)	—	—	—	—	—
Dump des Speicherbereichs, in dem der Anwendungscode gespeichert ist, und Reverse Engineering des Codes	Physisch	Hoch	Hoch	Keine	Sehr niedrig
Analyse, welcher Teil des Codes die Kommunikation mit dem Backend-Server herstellt und Anfragen an eine Datenbank sendet	Physisch	Niedrig	Keine	Keine	Sehr niedrig
Die Binärdatei so manipulieren, dass eine einfache SQL-Injektionszeichenfolge zur Datenbankabfrage hinzugefügt werden kann	Netzwerk	Hoch	Keine	Keine	Mittel
Gesamtbewertung für den Angriffspfad	Netzwerk	Hoch	Hoch	Keine	Sehr niedrig

Ein Beispiel: Eine Bedrohungsstufe *Vernachlässigbar* kann entweder einen Angreifer mit sehr hoher Motivation, aber sehr geringen Fähigkeiten darstellen, oder umgekehrt einen Angreifer mit sehr hohen Fähigkeiten, aber geringer Motivation (vgl. Tab. 5.4). Der Nutzen der Definition eines Angreifer-Modells und der Zuordnung von Angriffspotenzialwerten ist zweifach. Zum einen Konzentration auf realistische Angriffsvektoren: Das Cybersecurity-Team erhält ein besseres Verständnis für die relevanten Bedrohungen und möglichen Angriffspfade während der Brainstorming-Phase. Dadurch wird sichergestellt, dass der Fokus auf solchen Bedrohungsszenarien liegt, die für das jeweilige TARA-Projekt auch tatsächlich relevant und machbar sind. Außerdem systematische Bewertbarkeit: Die Definition erlaubt eine systematische Herangehensweise, die direkt mit der Bewertung der Angriffsmachbarkeit (Attack Feasibility) verglichen werden kann. Wenn zum Beispiel im Angreifer-Modell eine Bedrohungsstufe *Vernachlässigbar* definiert ist (wie in Tab. 5.5) und in Tab. 5.6 konkretisiert wird, dass Angriffsvektoren mit einem höheren Aufwand als *Fachwissen = Experte*, *Wissen über das Item = Öffentlich* und *Ausrüstung = Standard* nicht verfolgt werden, können solche Angriffspfade bereits im Vorfeld ausgeschlossen werden. Ein solcher Ansatz wird auch in [40] vorgeschlagen und trägt wesentlich zur Effizienz und Nachvollziehbarkeit des gesamten TARA-Prozesses bei.

Beachte, dass der in Tab. 5.5 und Tab. 5.6 beschriebene Ansatz zur Definition von Bedrohungsstufen und Angreifern nur eine mögliche Herangehensweise an die Modellierung von Angreifern darstellt. So wurde beispielsweise die Kategorie *Abgelaufene Zeit* (Elapsed Time) bewusst nicht in das Angreifer-Modell integriert. Auch ist die dargestellte Liste nicht vollständig und dient in erster Linie didaktischen Zwecken, da davon ausgegangen wird, dass die konkrete Ausgestaltung des Angreifer-Modells unternehmensspezifisch erfolgt. Zum Beispiel sind in Tab. 5.3 nicht alle denkbaren Kombinationen von Angriffspotenzialen dargestellt. Eine sinnvolle Überlegung wäre: *Was passiert, wenn ein Angriffspfad mehrere Experten erfordert, aber auf öffentlich zugänglichem Wissen und Standardausrüstung basiert?* Solche Fälle sind realistisch, etwa wenn eine Schwachstelle gut dokumentiert ist, deren Ausnutzung jedoch sehr spezialisiertes Know-how verlangt. In diesem Fall könnte eine solche Kombination in die Bedrohungsstufe *Sehr gering* (limited capability) eingeordnet werden. Daraus ergibt sich: Tab. 5.3 kann erweitert werden, um verschiedene Variationen und Zwischentöne der Angriffsfähigkeit abzubilden. Diese Flexibilität ist notwendig, um eine realistische und auf das jeweilige System abgestimmte Bedrohungsmodellierung zu ermöglichen.

7.4 Praktische Fallstudien

In Kap. 5 haben wir die drei Fallstudien eingeführt und den Anwendungsbereich der TARA definiert. Kap. 6 befasste sich mit der Identifikation relevanter Assets, einschließlich der zugehörigen Schadensszenarien (Damage-Scenarios) für jede Fallstudie. In diesem Abschnitt führen wir die Fallstudien weiter. Basierend auf den identifizierten Assets wäh-

len wir jeweils ein repräsentatives Asset aus und führen Brainstorming-Sitzungen durch, unterstützt durch STRIDE, um Bedrohungen zu identifizieren. Aufgrund von Platzbeschränkungen beschränken wir uns auf ein Asset und zwei Bedrohungsszenarien pro Fallstudie. Wir erachten dies jedoch als ausreichend, um den Ablauf zu erklären und verständlich darzustellen. Die Bedrohungen werden den entsprechenden Schadensszenarien zugeordnet. Abschließend bestimmen wir den Angriffspfad (Attack Path) für ein exemplarisches Bedrohungsszenario und bewerten die Angriffsmachbarkeit (Angrifferschwernis).

7.4.1 Fallstudie 1: Eingebettetes Fahrzeugsteuergerät

Wir beginnen die Brainstorming-Sitzung mit dem Fokus auf einem der Assets. Wir wählen das Asset *Anwendungssoftware*. Wie in Tab. 6.11 beschrieben, ist die Anwendungssoftware verantwortlich für die Videofunktionen auf einem SoC und die Konnektivitätsfunktionen auf dem anderen SoC. Die identifizierten Cybersecurity-Eigenschaften für dieses Asset sind *Integrität*, *Verfügbarkeit*, und *Authentizität*. Wie in Abschn. 7.1 erläutert, erfolgt unser Threat-Modeling-Ansatz auf Basis von STRIDE und Bedrohungskatalogen. In diesem Beispiel verwenden wir den Bedrohungskatalog aus der UN-Regelung Nr. 155. Die Anwendung der Bedrohungen aus dieser Regelung ist ein guter Ansatz zur Erfüllung von Compliance-Anforderungen. Die Bedrohungen in der UN-Regelung Nr. 155 bieten eine Grundlage für den Vergleich und die Auditierung von TARAs.

Da wir uns nicht ausschließlich auf Kataloge verlassen, führen wir zusätzlich eine Analyse nach STRIDE durch, um weitere Bedrohungen zu identifizieren, die nicht im Bedrohungskatalog enthalten sind.

Um Bedrohungen aus dem Katalog zu identifizieren, die auf unser Item zutreffen, gehen wir nach folgenden Schritten vor:

1. Beginnen Sie mit der ersten Bedrohung im Katalog. Im Fall der UN-Regelung Nr. 155 lautet die erste Bedrohung *1.1 Missbrauch von Berechtigungen durch Personal (Insider-Angriff)*. Diese gehört zur übergeordneten Bedrohung *4.3.1 Bedrohungen für Back-End-Server bezüglich Fahrzeugen auf der Straße*, sowie zur Unterkategorie *1 Backend-Server werden zum Angriff auf ein Fahrzeug oder zum Extrahieren von Daten genutzt*. Es ist wichtig zu beachten, dass wir uns nicht an der exakten Wortwahl aufhalten. Der Katalog bezeichnet diese als *Beispiel für die Schwachstelle bzw. Angriffsmethode*, aber sie können jeweils als eigenständige Bedrohungen betrachtet werden. Tatsächlich entspricht die ausgenutzte Schwachstelle oder Angriffsmethode dem, was wir in unserer TARA als Angriffspfad definieren – und Angriffspfade müssen ohnehin für jede im Katalog ausgewählte Bedrohung beschrieben werden. Die Beschreibung in der Regelung (in der Spalte

Beispiel für die Schwachstelle bzw. Angriffsmethode) ist einerseits zu abstrakt, um direkt als Angriffspfad zu gelten, andererseits ist der Angriffspfad individuell auf das jeweilige Asset und Item bezogen.

2. Ist die Bedrohung technisch im Kontext des Assets und Items umsetzbar? Zum Beispiel: Die Bedrohung bezieht sich auf Cloud-Schwachstellen, aber wir analysieren eingebettete Systeme (Embedded Systems).
3. Liegt die Bedrohung im Geltungsbereich der TARA? Zum Beispiel: Backend-Server liegen beispielsweise außerhalb des betrachteten Scopes.
4. Wird durch die Bedrohung eine Cybersecurity-Eigenschaft des Assets verletzt? Notieren Sie den Grund, warum eine Cybersecurity-Eigenschaft des Assets kompromittiert wird.
5. Wenn alle oben genannten Fragen mit „Ja“ beantwortet werden, sollte die Bedrohung in die TARA aufgenommen werden.
6. Leiten Sie abschließend den Angriffspfad ab und führen Sie eine Bewertung der Angriffsmachbarkeit (Feasibility-Bewertung) durch.

Die folgenden Bedrohungen aus dem Katalog der UN-Regelung Nr. 155 sind Beispiele, die zu unserem Asset *Anwendungssoftware* passen:

- 5.1 Kommunikationskanäle ermöglichen Code-Injektion, z. B. können manipulierte Softwarebinärdateien in den Kommunikationsstrom injiziert werden
- 5.2 Kommunikationskanäle ermöglichen die Manipulation von Fahrzeugdaten/-code
- 5.3 Kommunikationskanäle ermöglichen das Überschreiben von Fahrzeugdaten/-code
- 5.4 Kommunikationskanäle ermöglichen die Löschung von Fahrzeugdaten/-code
- 5.5 Kommunikationskanäle ermöglichen die Einspeisung von Daten/Code in das Fahrzeug (Schreiben von Datencode)
- 6.1 Akzeptieren von Informationen aus einer unzuverlässigen oder nicht vertrauenswürdigen Quelle
- 12.1 Beeinträchtigung von drahtlosen Softwareaktualisierungsverfahren; dazu gehört auch die Fälschung des Programms oder der Firmware zur Systemaktualisierung
- 12.2 Beeinträchtigung von lokalen/physischen Softwareaktualisierungsverfahren; dazu gehört auch die Fälschung des Programms oder der Firmware zur Systemaktualisierung
- 12.3 Die Software wird vor dem Aktualisierungsprozess manipuliert (und daher beschädigt), obwohl dieser intakt ist
- 19.3 Extraktion kryptografischer Schlüssel
- 22.2 Einspeisung von Schadsoftware oder Schadsoftwareaktivitäten
- 23.1 Fälschung der Software des Fahrzeugsteuerungs- oder -informationssystems

- 26.2 Unzureichender Einsatz kryptografischer Algorithmen zum Schutz sensibler Systeme
- 26.3 Verwendung kryptografischer Algorithmen, die bereits veraltet sind oder es bald sein werden

Zum Zwecke des Beispiels analysieren wir nur eine der oben genannten Bedrohungen im Detail:

- *Bedrohung:* 12.3 Die Software wird vor dem Aktualisierungsprozess manipuliert (und daher beschädigt), obwohl dieser intakt ist
- *Angriffspfad:*
 1. Der Angreifer kompromittiert den Backend-Server des OEM/Zulieferer (z. B. durch einen Insider-Angreifer)
 2. Ein manipuliertes Software-Update wird auf den Backend-Server hochgeladen. Die Software verfügt über keine kryptografische Signatur.
 3. Das manipulierte Softwareupdate wird durch den regulären Update-Prozess auf dem Fahrzeug installiert (keine Überprüfung der kryptografischen Signatur)
- *Beeinträchtigte Cybersecurity-Eigenschaften:* Integrität, Verfügbarkeit
- *Begründung für die Beeinträchtigung der Cybersecurity-Eigenschaften:*
 - Integrität: beeinträchtigt durch die Manipulation der Software vor dem Update-Prozess
 - Verfügbarkeit: beeinträchtigt, da ein manipuliertes Update installiert wird und das originale, legitime Update somit nicht zur Verfügung steht
- *Bewertung der Angriffsfähigkeit:* Mittel (gemäß Tab. 7.9)

Angenommen, die zuvor aufgelisteten Bedrohungen stellen alle identifizierten Bedrohungen aus dem Katalog dar, führen wir die Analyse unter Anwendung von STRIDE fort. Das betrachtete Asset weist drei zugeordnete Cybersecurity-Eigenschaften auf: *Integrität*, *Verfügbarkeit*, und *Authentizität*. Entsprechend wählen wir die STRIDE-Kategorien aus, die direkt mit diesen Eigenschaften in Zusammenhang stehen: Spoofing (Authentizität), Tampering (Integrität) und Denial-of-Service (Verfügbarkeit).

Der nächste Schritt erfordert Brainstorming und Fachkenntnis des Cybersecurity-Teams, das die TARA durchführt. Für jede der drei Eigenschaften stellt sich die grundlegende Frage: *Wie kann Authentizität/Integrität/Verfügbarkeit kompromittiert werden?* Im Folgenden zeigen wir ein Beispiel für Verletzungen der Eigenschaften Integrität und Authentizität:

Tab. 7.9 Bewertung der Angriffsfähigkeit für Bedrohungsszenario 12.3 Die Software wird vor dem Aktualisierungsprozess manipuliert (und daher beschädigt), obwohl dieser intakt ist

Schritte für den Angriffspfad	Abgelaufene Zeit	Fachwissen	Wissen über das Item oder die Komponente	Zugriffs- gelegenheiten	Ausrüstung	Bewertung der Angriffsmach- barkeit
Der Angreifer kompromittiert den Backend-Server des OEM/Zulieferer (z. B. durch einen Insider-Angreifer)	≤ 1 Monat	Kompetent	Eingeschränkt	Unbegrenzt	Standard	Hoch
Ein manipuliertes Software-Update wird auf den Backend-Server hochgeladen. Die Software verfügt über keine kryptografische Signatur.	≤ 1 Monat	Experte	Eingeschränkt	Einfach	Standard	Mittel
Das manipulierte Softwareupdate wird durch den regulären Update-Prozess auf dem Fahrzeug installiert (keine Überprüfung der kryptografischen Signatur)	≤ 1 Tag	Laie	Öffentlich	Unbegrenzt	Standard	Hoch
Gesamtbewertung für den Angriffspfad	≤ 1 Monat	Experte	Eingeschränkt	Einfach	Standard	Mittel

- *Bedrohung*: Umgehung der Software-Signaturprüfung durch einen Seitenkanalangriff
- *Angriffspfad*:
 1. Der Angreifer entnimmt das Steuergerät (ECU) aus dem Fahrzeug und schließt es an einen lokalen Prüfstand mit Debugging-Funktionen an
 2. Der Angreifer startet Seitenkanalangriffe auf der Basis von Power Glitching
 3. Der Prozess zur Überprüfung der Softwaresignatur wird umgangen, und der Angreifer kann eine modifizierte Software auf dem Steuergerät installieren
- *Kompromittierte Cybersecurity-Eigenschaft*: Integrität, Authentizität
- *Grund für kompromittierte Cybersecurity-Eigenschaft*:
 - Integrität: Manipuliertes Softwareupdate wird auf das Steuergerät installiert
 - Authentizität: Der Signaturprüfprozess wird umgangen
- *Bewertung der Angriffsmachbarkeit*: Sehr gering (siehe Tab. 7.10)

Beachten Sie, dass die oben dargestellten Beispiele – nämlich die Bedrohung *12.3 Die Software wird vor dem Aktualisierungsprozess manipuliert (und daher beschädigt)*, obwohl dieser intakt ist sowie die Bedrohung *Umgehung der Software-Signaturprüfung durch einen Seitenkanalangriff* – auf unterschiedlichen Annahmen basieren. Im ersten Fall gehen wir davon aus, dass keinerlei Schutzmechanismen vorhanden sind, wie es im Rahmen der TARA-Definition (siehe Tab. 5.7) festgelegt wurde. Das Steuergerät (ECU) verfügt über keinen Signaturprüfprozess und ist daher nicht in der Lage zu verifizieren, ob die Software manipuliert wurde. Im zweiten Beispiel hingegen nehmen wir an, dass ein Signaturprüfprozess im Steuergerät vorhanden ist, dieser jedoch kompromittiert wurde. Dieses Beispiel wurde ausgewählt, um die Methodik von STRIDE zu veranschaulichen. Selbstverständlich kann das Cybersecurity-Team an diesem Punkt im TARA-Projekt entscheiden, diese Bedrohung (noch) nicht zu berücksichtigen, da laut Ausgangsannahme der TARA keine Schutzmaßnahmen vorgesehen sind. Andererseits sollte die Bedrohung nicht verworfen werden, da sie für eine spätere TARA im selben Projekt hilfreich sein kann.

7.4.2 Fallstudie 2: Fahrzeug-Backend-Architektur

Wir verwenden dieselbe Brainstorming-Methodik, wie sie zuvor in diesem Kapitel beschrieben wurde, um die Bedrohungen in dieser Fallstudie zu identifizieren. Die Brainstorming-Sitzung beginnt mit der Auswahl des ersten zu analysierenden Assets. Wir wählen das Asset *Sensible Daten bei der Übertragung* aus der Asset-Liste dieses Falls (siehe Tab. 6.15). Die zugehörigen Cybersecurity-Eigenschaften dieses Assets sind *Vertraulichkeit*, *Integrität* und *Authentizität*.

Tab. 7.10 Bewertung der Angriffsmachbarkeit für Bedrohungsszenario *Umgehung der Software-Signaturprüfung durch einen Seitenkanalangriff*

Schritte für den Angriffspfad	Abgelaufene Zeit	Fachwissen	Wissen über das Item oder die Komponente	Zugriffsgelegenheiten	Ausrüstung	Bewertung der Angriffsmachbarkeit
Der Angreifer entnimmt das Steuergerät (ECU) aus dem Fahrzeug und schließt es an einen lokalen Prüfstand mit Debugging-Funktionen an	≤ 1 Tag	Kompetent	Öffentlich	Unbegrenzt	Standard	Hoch
Der Angreifer startet Seitenkanalangriffe auf der Basis von Power Glitching	≤ 1 Monat	Experte	Öffentlich	Unbegrenzt	Spezialisiert	Mittel
Der Prozess zur Überprüfung der Softwaresignatur wird umgangen, und der Angreifer kann eine modifizierte Software auf dem Steuergerät installieren	≤ 6 Monate	Experte	Öffentlich	Unbegrenzt	Spezialisiert	Sehr niedrig
Gesamtbewertung für den Angriffspfad	≤ 6 Monate	Experte	Öffentlich	Unbegrenzt	Spezialisiert	Sehr niedrig

Zudem nutzen wir dieselbe Kombination aus Bedrohungskatalog und STRIDE-Methode, die bereits in Fallstudie 1 in Abschn. 7.4.1 angewendet wurde. In diesem Beispiel starten wir mit der STRIDE-Analyse, die auf den Katalog der UN-Regelung Nr. 155 angewendet wird. Unser Hauptziel in den Fallstudien ist es, durch Beispiele ein besseres Verständnis für die Methodik zur Identifikation von Bedrohungen im Rahmen eines TARA-Projekts zu vermitteln. Daher zeigen wir, wie die STRIDE-Methodik angewendet werden kann, und geben einige Beispiele. In einem realen Projekt, in dem sich das durchführende Team dazu entscheidet, STRIDE auf einen Bedrohungskatalog anzuwenden – wie in dieser Fallstudie demonstriert – empfehlen wir, sich nicht auf einen spezifischen Katalog zu beschränken. Das Team kann STRIDE auf einen oder mehrere Kataloge anwenden, um die relevantesten Bedrohungen schneller zu identifizieren und den Bedrohungsidentifikationsprozess anschließend in einer Brainstorming-Sitzung weiterzuführen.

Das analysierte Asset *Sensible Daten bei der Übertragung* bezieht sich auf Daten, die vom Dateninhaber als sensitiv klassifiziert wurden. Diese Daten können beispielsweise personenbezogene Informationen wie Namen oder Kreditkartendaten sein, die vom Fahrzeug an ein Backend-System übertragen werden. Die Übertragung kann über eine direkte Internetverbindung zum Backend erfolgen. Alternativ können die Daten auch per Bluetooth an ein lokal gekoppeltes, vertrauenswürdigen Mobiltelefon gesendet werden, das die Daten mithilfe einer vom Backend-Betreiber bereitgestellten App (z. B. eine OEM-App für iPhone®) an den Server weiterleitet. Wir haben explizit entschieden, sensitive Daten in zwei Assets zu unterteilen – gespeicherte Daten und Daten während der Übertragung –, um die Bedeutung unterschiedlicher Cybersecurity-Betrachtungen für beide Zustände hervorzuheben. Im Kontext dieser Fallstudie bedeutet „während der Übertragung“ die Ende-zu-Ende-Kommunikation vom Fahrzeug bis zum Backend-System. Es wäre allerdings ebenfalls zulässig, beide Assets zu einem einzigen Asset zusammenzufassen und daraus ganzheitliche Cybersecurity-Ziele und Maßnahmen abzuleiten.

Die Cybersecurity-Eigenschaften des Assets *Sensible Daten bei der Übertragung* sind – wie bereits erwähnt – *Vertraulichkeit*, *Integrität* und *Authentizität*. Wie in Tab. 7.1 beschrieben, stehen die STRIDE-Kategorien *Information Disclosure*, *Tampering* und *Spoofing* diesen Eigenschaften jeweils entgegengesetzt gegenüber. Ein praktischer Ansatz zur Anwendung von STRIDE auf den Bedrohungskatalog der UN-Regelung Nr. 155 besteht darin, die dort gelisteten Bedrohungen durchzugehen und sich bei jeder Bedrohung zu fragen: *Kann diese Bedrohung grundsätzlich mit Information Disclosure, Tampering oder Spoofing in Verbindung gebracht werden?* Wenn die Antwort „ja“ lautet, kann die Bedrohung detaillierter analysiert und – sofern sie als plausibel angesehen wird – in die TARA aufgenommen werden. Die folgenden Bedrohungen aus dem Katalog der UN-Regelung Nr. 155 wurden unter Anwendung der STRIDE-Methode für das Asset *Sensible Daten bei der Übertragung* identifiziert:

- 3.1 Missbrauch von Berechtigungen durch Personal (Insider-Angriff)
- 3.2 Verlust von Informationen in der Cloud. Sensible Daten, die durch Drittanbieter von Cloud-Diensten gespeichert werden, können durch Angriffe oder Pannen verloren gehen
- 3.3 Unbefugter Internetzugriff auf den Server (z. B. durch Backdoors, nicht gepatchte Systemsoftwareschwachstellen, SQL-Angriffe oder andere Mittel)
- 3.4 Unbefugter physischer Zugriff auf den Server (z. B. mittels USB-Sticks oder anderer Medien, die sich mit dem Server verbinden)
- 5.1 Kommunikationskanäle ermöglichen Code-Injektion, z. B. können manipulierte Softwarebinärdateien in den Kommunikationsstrom injiziert werden
- 5.2–5.4 Kommunikationskanäle ermöglichen die Manipulation/das Überschreiben/die Löschung von Fahrzeugdaten/-code
- 6.2 Man-in-the-Middle-Angriff/Session Hijacking
- 6.3 Replay-Angriff, z. B. ein Angriff auf ein Kommunikations-Gateway, der es dem Angreifer ermöglicht, die Software eines elektronischen Steuergeräts oder die Firmware des Gateways herabzustufen
- 7.2 Erlangen von unbefugtem Zugriff auf Dateien oder Daten
- 9.1 Ein unprivilegierte Benutzer kann Sonderzugriffsrechte erhalten, z. B. Root-Zugriff
- 17.1 Manipulierte oder unsichere Anwendungen, die zum Angriff auf Fahrzeugsysteme genutzt werden
- 18.1 Externe Schnittstellen wie USB-Anschlüsse oder andere als Angriffspunkte genutzte Anschlüsse, z. B. für Code-Injektion
- 19.3 Extraktion kryptografischer Schlüssel
- 23.1 Fälschung der Software des Fahrzeugsteuerungs- oder -informationssystems
- 26.1 Eine Kombination aus kurzen Verschlüsselungscodes und langen Gültigkeitszeiträumen ermöglicht es dem Angreifer, die Verschlüsselung zu knacken
- 29.1 Überflüssige, offen gelassene Internetanschlüsse bieten Zugang zu Netzwerksystemen
- 31.1 Informationssicherheitslücken. Personenbezogene Daten können bei einem Wechsel des Fahrzeugnutzers (z. B. durch Verkauf oder Neuvermietung) in die falschen Hände geraten
- 32.1 Manipulation elektronischer Hardware, z. B. wenn in einem Fahrzeug unzulässige elektronische Hardware hinzugefügt wird, um einen Man-in-the-Middle-Angriff zu ermöglichen Austausch zulässiger elektronischer Hardware (z. B. Sensoren) durch unzulässige elektronische Hardware Manipulation der von einem Sensor erfassten Daten (z. B. wenn mittels eines Magneten der am Getriebe angebrachte Hall-Sensor manipuliert wird)

Nachdem die Bedrohungen in der Brainstorming-Sitzung identifiziert wurden (d.h. nach mehreren Diskussionsrunden unter Anwendung von STRIDE und Bedrohungskatalogen), werden die Bedrohungsszenarien im Detail beschrieben. Dabei wird insbesondere erläutert, welche Cybersecurity-Eigenschaften des Assets kompromittiert wurden und welcher Angriffspfad beteiligt ist. Nachfolgend wird eine der identifizierten Bedrohungen beschrieben:

- *Bedrohung*: 6.2 Man-in-the-Middle-Angriff/Session Hijacking
- *Angriffspfad*:
 1. Es wird angenommen, dass die Bluetooth-Verbindung zwischen Mobiltelefon und Fahrzeug Schwachstellen aufweist (d.h. nicht ausreichend abgesichert ist)
 2. Der Angreifer verfügt über Kenntnisse zur Bluetooth-Konfiguration einer bestimmten Fahrzeugplattform und kauft oder mietet ein entsprechendes Fahrzeug, um ausreichend Tests und Recherchen durchzuführen
 3. Der Angreifer entwickelt ein eigenes, leicht transportierbares Gerät, das für einen Man-in-the-Middle-Angriff auf die Bluetooth-Verbindung eingesetzt werden kann
 4. Der Angreifer nähert sich ausreichend einem verwundbaren Fahrzeug und führt den Angriff aus
- *Kompromittierte Cybersecurity-Eigenschaft*: Vertraulichkeit
- *Begründung für die kompromittierte Cybersecurity-Eigenschaft*:
 - Vertraulichkeit: Der Angreifer hört sensible Daten ab
- *Bewertung der Angriffsrealisierbarkeit*: Mittel (siehe Tab. 7.11)

7.4.3 Fallstudie 3: Automobilproduktionsanlage

Zur Identifikation der Bedrohungen für die Automobilproduktionsanlage verwenden wir denselben Ansatz aus Brainstorming-Sitzungen, unterstützt durch STRIDE und Bedrohungskataloge, wie in den vorherigen Fallstudien. Die Identifikation beginnt mit der Analyse der in Tab. 6.19 bereits identifizierten Assets. Als Beispiel für unseren Bedrohungsidentifikationsprozess wählen wir das Asset *Software-Updates*. Die diesem Asset zugewiesenen Cybersecurity-Eigenschaften sind *Integrität* und *Authentizität*.

Das Asset *Software-Updates* steht in unserer Fallstudie für Updates der Produktionsmaschinen. Eine typische Fertigungsanlage in der Automobilbranche kann Roboter, Förderbänder, Leiterplatten-Bestückungsmaschinen (PCB), CNC-Maschinen, Lötstationen, Materialmischanlagen, Kompressoren, Pumpen, Reinigungsanlagen, Verpackungsmaschinen, Funktionstests, thermomechanische Tests, EOL-Tests und andere Komponenten umfassen.

Tab. 7.11 Bewertung der Angriffsrealisierbarkeit (Attack Feasibility Rating) für Bedrohungsszenario 6.2 *Man-in-the-Middle-Angriff/Session Hijacking*

Schritte für den Angriffspfad	Abgelaufene Zeit	Fachwissen	Wissen über das Item oder die Komponente	Zugriffsgelegenheiten	Ausrüstung	Bewertung der Angriffsrealisierbarkeit
Der Angreifer verfügt über Kenntnisse zur Bluetooth-Konfiguration einer bestimmten Fahrzeugplattform und kauft oder mietet ein entsprechendes Fahrzeug, um ausreichend Tests und Recherchen durchzuführen	≤ 1 Monat	Kompetent	Öffentlich	Unbegrenzt	Spezialisiert	Hoch
Der Angreifer entwickelt ein eigenes, leicht transportierbares Gerät, das für einen Man-in-the-Middle-Angriff auf die Bluetooth-Verbindung eingesetzt werden kann	≤ 1 Woche	Kompetent	Öffentlich	Unbegrenzt	Spezialisiert	Hoch
Der Angreifer nähert sich ausreichend einem verwundbaren Fahrzeug und führt den Angriff aus	≤ 1 Tag	Kompetent	Öffentlich	Moderat	Spezialisiert	Hoch
Gesamtbewertung für den Angriffspfad	≤ 1 Monat	Kompetent	Öffentlich	Moderat	Spezialisiert	Mittel

In unserer Fallstudie analysieren wir eine Fertigungsanlage, bestehend aus einer Produktionslinie mit mehreren Stationen, z. B. einer Flash-Station, einigen Maschinen dazwischen und einer EOL-Station. Wir gehen davon aus, dass jede Maschine der Produktionslinie in gewissem Umfang über eine Software-Update-Fähigkeit verfügt, sodass das Asset Software-Updates alle diese Maschinen umfasst.

An dieser Stelle ist es wichtig zu betonen, dass diese Fallstudie darauf abzielt, Risiken auf architektonischer oder Systemebene zu identifizieren. Selbstverständlich nehmen wir in unserem Beispiel gewisse Vereinfachungen vor. Auf Systemebene konzentriert sich das Brainstorming-Team auf mögliche Bedrohungen und Angriffsvektoren, die für die Maschinen als Gesamtsystem realistisch sind. Wenn zum Beispiel keine der Maschinen über eine Fernaktualisierungsfunktion verfügt, sind Bedrohungsvektoren im Zusammenhang mit Ethernet-Angriffen nicht anwendbar. In diesem Fall beziehen sich die Bedrohungen auf Angriffe, die physischen Zugriff auf die Maschinen erfordern (z. B. das Einführen von USB-Sticks, Social-Engineering-Angriffe, Zugriff auf Konfigurationsschnittstellen). Natürlich kann – sofern das TARA-Projekt detaillierte Erkenntnisse zu einzelnen Maschinen verlangt – das Asset *Software-Updates* für jede einzelne Maschine separat spezifiziert werden.

Die Brainstorming-Sitzung beginnt mit der Analyse der Bedrohungskataloge, die durch STRIDE unterstützt werden. Das Cybersecurity-Team startet mit der Bewertung der Cybersecurity-Eigenschaft *Integrität*. In der Sitzung sind ausreichend Fachexperten anwesend, die die Maschinen zumindest aus betrieblicher Sicht gut kennen. Die Experten können z. B. bestätigen, ob die Maschinen per Fernzugriff über Ethernet aktualisiert werden können – etwa via *HTTP*, *SMB*, *FTP*, *SSH* oder *telnet* – oder ob Updates ausschließlich durch physischen Zugriff möglich sind. Der Analyseprozess kann beginnen, indem der Katalog der UN-Regelung Nr. 155 durchgegangen und geprüft wird, ob die dort aufgeführten Bedrohungen auf das Asset anwendbar sind. Nach dem gleichen Vorgehen wie in Fallstudie 2 hilft STRIDE dabei zu erkennen, ob es sich bei den Bedrohungen um Manipulationsbedrohungen (Tampering) handelt, die die Integrität des Assets gefährden. Da es sich in diesem Fall um ein OT-Umfeld handelt, bezieht das Cybersecurity-Team außerdem die Bedrohungen für industrielle Kontrollsysteme ein, wie sie im MITRE ATT&CK®-Framework dokumentiert sind. Nach Abschluss der Kataloganalyse führt das Cybersecurity-Team die STRIDE-Methodik weiter, indem es basierend auf der Erfahrung und Vorstellungskraft der Experten jede denkbare Manipulationsbedrohung identifiziert. Dieser Prozess wird anschließend für die Cybersecurity-Eigenschaft *Authentizität* wiederholt.

Da die Maschinen in der Produktionsanlage sowohl lokale als auch Updates von remote unterstützen, wurden unter anderem die folgenden Bedrohungen aus der UN-Regelung Nr. 155 identifiziert:

- 3.1 Missbrauch von Berechtigungen durch Personal (Insider-Angriff)
- 3.3 Unbefugter Internetzugriff auf den Server (z. B. durch Backdoors, nicht gepatchte Systemsoftwareschwachstellen, SQL-Angriffe oder andere Mittel)

- 3.4 Unbefugter physischer Zugriff auf den Server (z. B. mittels USB-Sticks oder anderer Medien, die sich mit dem Server verbinden)
- 5.1 Kommunikationskanäle ermöglichen Code-Injektion, z. B. können manipulierte Softwarebinärdateien in den Kommunikationsstrom injiziert werden
- 12.2 Beeinträchtigung von lokalen/physischen Softwareaktualisierungsverfahren; dazu gehört auch die Fälschung des Programms oder der Firmware zur Systemaktualisierung
- 22.2 Einspeisung von Schadsoftware oder Schadsoftwareaktivitäten
- 29.1 Überflüssige, offen gelassene Internetanschlüsse bieten Zugang zu Netzwerksystemen
- 29.2 Umgehung der Netzwerktrennung, um Kontrolle zu erlangen. Ein spezifisches Beispiel ist die Nutzung ungeschützter Gateways oder Zugangspunkte (wie z. B. LKW-Anhänger-Gateways), um Schutzmaßnahmen zu umgehen und Zugang zu anderen Netzwerksegmenten zu erhalten und schädliche Aktionen durchzuführen, wie z. B. willkürliche CAN-Bus-Nachrichten zu senden

Beachten Sie, dass sich die Angriffspfade für Bedrohungen aus der UN-Regelung Nr. 155, wenn sie auf ein OT-Gerät angewendet werden, erheblich von den Angriffspfaden unterscheiden, die bei einem Steuergerät (ECU) wie im ersten Fallbeispiel auftreten.

Die folgenden Bedrohungen sind Beispiele aus dem ICS-Katalog (Industrial Control Systems) des MITRE ATT&CK®-Frameworks (aus [33] entnommen):

- Command Line Interface (T0807): Angreifer können Kommandozeilenschnittstellen (Command Line Interfaces, CLIs) nutzen, um mit Systemen zu interagieren und Befehle auszuführen. CLIs stellen ein gängiges Mittel zur Interaktion mit Computersystemen dar und sind in vielen Plattformen und Geräten innerhalb von OT-Umgebungen vorhanden. Angreifer können CLIs auch verwenden, um neue Software zu installieren und auszuführen, einschließlich bösartiger Tools, die im Verlauf eines Angriffs nachgeladen werden. CLIs werden typischerweise lokal aufgerufen, können jedoch auch über Dienste wie SSH, Telnet oder RDP erreichbar sein. Befehle, die in der CLI ausgeführt werden, erfolgen mit den aktuellen Berechtigungen des Prozesses, der das Terminal betreibt, es sei denn, der Befehl fordert explizit einen Wechsel des Berechtigungskontexts an. Viele Steuergeräte verfügen über CLI-Schnittstellen zu Verwaltungszwecken.
- Standardpasswörter (Default Credentials – T0812): Angreifer können auf von Hersteller oder Lieferant voreingestellte Zugangsdaten auf Geräten industrieller Steuerungssysteme zurückgreifen. Diese Standardzugangsdaten besitzen häufig administrative Berechtigungen und sind oft für die Erstkonfiguration notwendig. Es gilt als bewährte Praxis, diese Passwörter so früh wie möglich zu ändern. Allerdings bieten manche Hersteller Geräte an, bei denen Passwörter oder Benutzernamen nicht geändert werden können.

- **Ausnutzung von Remote-Diensten (Exploitation of Remote Services – T0866):** Angreifer können Software-Schwachstellen ausnutzen, um Programmierfehler in Anwendungen, Diensten oder direkt im Betriebssystem bzw. Kernel zu missbrauchen. Ziel ist häufig der initiale Zugriff auf das System sowie die laterale Bewegung innerhalb der ICS-Umgebung, um Zugang zu gezielt ausgewählten Systemen zu erhalten.
- **System-Firmware (T0857):** Moderne Systeme verfügen häufig über eine Firmware mit integrierter Update-Funktion. Bei älteren Geräten ist die Firmware werksseitig installiert und erfordert ggf. spezielle Programmiergeräte. Firmware-Updates erlauben es dem Hersteller, Fehlerbehebungen oder Upgrades bereitzustellen – oftmals als Benutzeraufgabe mit einem Softwarepaket oder über das Netzwerk. Angreifer könnten diese Update-Funktion ausnutzen, um bösartige oder veraltete Firmware aufzuspielen. Da die Firmware eine der untersten Abstraktionsebenen ist, könnte ein Angreifer so Root-Zugriff auf ein Gerät erlangen.
- **Remote-Dienste (Remote Services – T0886):** Angreifer können Remote-Dienste nutzen, um sich zwischen Geräten und Netzsegmenten zu bewegen. Diese Dienste dienen normalerweise dazu, dass Bediener remote auf Systeme zugreifen können. Typische Beispiele sind RDP, SMB, SSH oder ähnliche Mechanismen.
- **Hartcodierte Zugangsdaten (Hardcoded Credentials – T0891):** Angreifer können fest in Software oder Firmware integrierte Zugangsdaten ausnutzen, um eine nicht autorisierte, interaktive Benutzersitzung auf einem Asset zu initiieren. Zu den hartcodierten Zugangsdaten zählen unter anderem Benutzername/Passwort-Kombinationen, kryptografische Schlüssel/Zertifikate und API-Tokens. Diese Anmeldedaten sind so tief im System verankert, dass sie vom Besitzer des Assets entweder gar nicht oder nur mit unverhältnismäßig großem Aufwand geändert werden können – etwa, weil eine Änderung den Betrieb des Steuerungssystems erheblich beeinträchtigen würde. Solche Zugangsdaten werden häufig über ganze Produktlinien oder Gerätemodelle hinweg wiederverwendet und sind in vielen Fällen dem Eigentümer oder Betreiber nicht bekannt. Angreifer können diese hartcodierten Zugangsdaten nutzen, um sich innerhalb der ICS-Umgebung lateral zu bewegen oder ihren Tools dauerhaft zuverlässigen Zugriff auf industrielle Assets zu ermöglichen.

Abschließend beschreiben wir alle Bedrohungsszenarien für das ausgewählte Asset, einschließlich des Angriffspfads. Ein Beispiel beschreiben wir wie folgt:

- *Bedrohung:* System Firmware (T0857)
- *Angriffspfad:*
 1. Der Angreifer ist ein Insider, der den Hersteller und die Modellversion der in der Fertigungsanlage des Opfers verwendeten Safety-related-SPS kennt

2. Der Angreifer bereitet USB-Sticks vor, die die Malware *Triton* [34] enthalten. Der USB-Stick ist sorgfältig beschriftet, sodass ein ahnungsloses Opfer glauben könnte, es handle sich um einen regulären USB-Stick mit Informationen zu einem Standardprozessschritt in der Produktion
 3. Der Angreifer verteilt die USB-Sticks innerhalb der Abteilung, die normalerweise für die Wartung der Systeme zuständig ist
 4. Ein ahnungsloser Bediener steckt den USB-Stick in dasselbe Netzwerk wie die SPS ein, und die Schadsoftware wird ausgeführt (z. B. durch Einbettung in ein Autostart-Skript)
 5. Die Schadsoftware installiert eine manipulierte Firmware auf den Ziel-SPS
- *Kompromittierte Cybersecurity-Eigenschaft:* Integrität, Authentizität
 - *Begründung für die kompromittierten Cybersecurity-Eigenschaften:*
 - Integrität: Kompromittiert aufgrund einer Manipulation der Software
 - Authentizität: Die Malware auf dem USB-Stick wurde ohne jegliche Authentizitätsprüfung ausgeführt. Zudem konnte die Malware auf die SPS zugreifen.
 - *Bewertung der Angriffsmachbarkeit:* Mittel (siehe Tab. 7.12)

Tab. 7.12 Bewertung der Angriffsmachbarkeit für Bedrohungsszenario *System Firmware (T0857)*

Schritte für den Angriffspfad	Abgelaufene Zeit	Fachwissen	Wissen über das Item oder die Komponente	Zugriffs-gelegenheiten	Ausrüstung	Bewertung der Angriffsmachbarkeit
Der Angreifer ist ein Insider, der den Hersteller und die Modellversion der in der Fertigungsanlage des Opfers verwendeten Safety-related-SPS kennt	≤ 1 Tag	Experte	Vertraulich	Unbegrenzt	Standard	Hoch
Der Angreifer bereitet USB-Sticks vor, die die Malware <i>Triton</i> [34] enthalten. Der USB-Stick ist sorgfältig beschriftet, sodass ein ahnungsloses Opfer glauben könnte, es handle sich um einen regulären USB-Stick mit Informationen zu einem Standardprozessschritt in der Produktion	≤ 1 Monat	Experte	Öffentlich	Unbegrenzt	Standard	Hoch
Der Angreifer verteilt die USB-Sticks innerhalb der Abteilung, die normalerweise für die Wartung der Systeme zuständig ist	≤ 1 Tag	Laie	Eingeschränkt	Moderat	Standard	Hoch
Ein ahnungsloser Bediener steckt den USB-Stick in dasselbe Netzwerk wie die SPS ein, und die Schadsoftware wird ausgeführt (z. B. durch Einbettung in ein Autostart-Skript)	≤ 1 Tag	Kompetent	Eingeschränkt	Moderat	Standard	Hoch
Die Schadsoftware installiert eine manipulierte Firmware auf den Ziel-SPS	≤ 1 Tag	Laie	Öffentlich	Moderat	Standard	Hoch
Gesamtbewertung für den Angriffspfad	≤ 1 Monat	Experte	Eingeschränkt	Moderat	Standard	Mittel

Literatur

1. OWASP Top Ten – OWASP Foundation. <https://owasp.org/www-project-top-ten/>
2. Threat Modeling Manifesto. <http://www.threatmodelingmanifesto.org/>
3. ISO/IEC 18045:2008 Information technology – Security techniques – Methodology for IT security evaluation. Standard, International Organization for Standardization/International Electrotechnical Commission (2008). <https://www.iso.org/standard/46412.html>
4. ISO 26262:2018 Road vehicles – Functional safety, Part 1–12. Standard, International Organization for Standardization (2018)
5. Common Vulnerability Scoring System (CVSS) v3.1 Specification Document – Revision 1. Specification document, Forum of Incident Response and Security Teams (FIRST) (2019). https://www.first.org/cvss/v3-1/cvss-v31-specification_r1.pdf
6. Common Methodology for Information Technology Security Evaluation – Evaluation methodology. CEM:2022, Revision 1, CCMB-2022-11-006. Common Criteria. Standard, CCRA Members (2022). <https://www.commoncriteriaportal.org/files/ccfiles/CEM2022R1.pdf>
7. ISO/IEC 18045:2022 Information security, cybersecurity and privacy protection – Evaluation criteria for IT security – Methodology for IT security evaluation. Standard, International Organization for Standardization/International Electrotechnical Commission (2022). <https://www.iso.org/standard/72889.html>
8. ISO/IEC 27005:2022 Information security, cybersecurity and privacy protection – Guidance on managing information security risks. Standard, International Organization for Standardization/International Electrotechnical Commission (2022). <https://www.iso.org/standard/80585.html>
9. Automotive Information Sharing and Analysis Center (Auto-ISAC) (2023). <https://automotiveisac.com>
10. Automotive Security Research Group (ASRG) (2023). <https://asrg.io>
11. Auto-ISAC Automotive Threat Matrix (ATM) (2024). <https://atm.automotiveisac.com/>
12. Alberts, C., Behrens, S., Pethia, R., Wilson, W.: Operationally Critical Threat, Asset, and Vulnerability Evaluation (OCTAVE) Framework, Version 1.0. Tech. Rep. CMU/SEI-99-TR 017, Software Engineering Institute, Carnegie Mellon University, Pittsburgh, PA (1999). <http://resources.sei.cmu.edu/library/asset-view.cfm?AssetID=13473>
13. Boudguiga, A., Boulanger, A., Chiron, P., Klaudel, W., Labiod, H., Seguy, J.C.: RACE: Risk analysis for cooperative engines. In: 2015 7th International Conference on New Technologies, Mobility and Security (NTMS), pp. 1–5 (2015). <https://doi.org/10.1109/NTMS.2015.7266516>
14. Deng, M., Wuyts, K., Scandariato, R., Preneel, B., Joosen, W.: A Privacy Threat Analysis Framework: Supporting the Elicitation and Fulfillment of Privacy Requirements. *Requir. Eng.* (1), 3–32 (2011). <https://doi.org/10.1007/s00766-010-0115-7>
15. ETSI: ETSI TS 102 165-1 V5.2.5 – CYBER; Methods and protocols; Part 1: Method and proforma for Threat, Vulnerability, Risk Analysis (TVRA). Standard (2022). https://www.etsi.org/deliver/etsi_ts/102100_102199/10216501/05.02.05_60/ts_10216501v050205p.pdf
16. European Union Agency for Cybersecurity (ENISA): ENISA good practices for security of Smart Cars (2019). <https://www.enisa.europa.eu/publications/smart-cars>
17. European Union Agency for Cybersecurity (ENISA): ENISA Threat Landscape 2022 (2022). <https://www.enisa.europa.eu/publications/enisa-threat-landscape-2022>
18. EVITA Project: E-safety vehicle intrusion protected applications (EVITA). <https://www.evita-project.org/>
19. GitLab: Threat Modeling. <https://handbook.gitlab.com/handbook/security/product-security/application-security/threat-modeling/>

20. ISO/SAE 21434:2021 Road vehicles – Cybersecurity engineering. Standard, International Organization for Standardization/Society of Automotive Engineers, Geneva, CH (2021). <https://www.iso.org/standard/70918.html>
21. SAE J3061 – Cybersecurity Guidebook for Cyber-Physical Vehicle Systems. Standard, Society of Automotive Engineers (2021). https://www.sae.org/standards/content/j3061_202112/?src=j3061_201601
22. Kelling, E., Friedewald, M., Leimbach, T., Menzel, M., Säger, P., Seudié, H., Weyl, B.: Specification and evaluation of e-security relevant use cases (EVITA Deliverable 2.1) (2018). <https://doi.org/10.5281/zenodo.1188415>.
23. Kohnfelder, L., Garg, P.: The threats to our products. Microsoft Interface, Microsoft Corporation (1999)
24. Lautenbach, A., Almgren, M., Olovsson, T.: Proposing HEAVENS 2.0 – an Automotive Risk Assessment Model. In: Proceedings of the 5th ACM Computer Science in Cars Symposium, CSCS’21. Association for Computing Machinery, New York, NY, USA (2021). <https://doi.org/10.1145/3488904.3493378>.
25. Lautenbach, A., Mafijul Islam, C.: HEALing vulnerabilities to ENhance software security and safety (HEAVENS) – deliverable d2 – security models (2016). https://autosec.se/wp-content/uploads/2018/03/HEAVENS_D2_v2.0.pdf
26. Luo, F., Jiang, Y., Zhang, Z., Ren, Y., Hou, S.: Threat analysis and risk assessment for connected vehicles: A survey. Security and Communication Networks pp. 1–19 (2021). <https://doi.org/10.1155/2021/1263820>.
27. Macher, G., Sporer, H., Berlach, R., Armengaud, E., Kreiner, C.: SAHARA: A security-aware hazard and risk analysis method. In: 2015 Design, Automation & Test in Europe Conference & Exhibition (DATE), pp. 621–624 (2015). <https://doi.org/10.7873/DATE.2015.0622>
28. Muckin, M., Fitch, S.C.: A Threat-Driven Approach to Cyber Security. White paper, Lockheed Martin Corporation (2019). <https://www.lockheedmartin.com/content/dam/lockheed-martin/rms/documents/cyber/LM-White-Paper-Threat-Driven-Approach.pdf>
29. Ruddle, A., Ward, D., Weyl, B., Idrees, S., Roudier, Y., Friedewald, M., Leimbach, T., Fuchs, A., Gürgens, S., Henniger, O., Rieke, R., Ritscher, M., Broberg, H., Aprville, L., Pacalet, R., Pedroza, G.: Security requirements for automotive on-board networks based on dark-side scenarios (EVITA Deliverable 2.3) (2009). <https://doi.org/10.5281/zenodo.1188418>
30. Schneier, B.: Attack Trees, Dr. Dobbs’s Journal (1999). https://www.schneier.com/academic/archives/1999/12/attack_trees.html
31. Shostack, A.: Threat Modeling: Designing for Security, 1st edn. Wiley Publishing (2014)
32. Smith, C.: The Car Hacker’s Handbook: A Guide for the Penetration Tester, 1 edn. No Starch Press, San Francisco (2016)
33. The MITRE Corporation: MITRE ATT&CK®. <https://attack.mitre.org/>
34. The MITRE Corporation: Triton, Software S1009 – MITRE ATT&CK®. <https://attack.mitre.org/versions/v12/software/S1009/>
35. ThreatModeler: Threat Modeling Methodologies: What is VAST? <https://threatmodeler.com/threat-modeling-methodologies-vast/>
36. Tony UcedaVelez: Real World Threat Modeling Using the PASTA Methodology, OWASP AppSec EU 2012 (2012). https://wiki.owasp.org/images/a/aa/AppSecEU2012_PASTA.pdf
37. United Nations: UN Regulation No. 155 – Cyber security and cyber security management system, Dokumentnummer: E/CEC/TRANS/505/Rev.3/Add.154 (2021). <https://unece.org/transport/documents/2021/03/standards/un-regulation-no-155-cyber-security-and-cyber-security>
38. Upstream: Upstream 2022 Global Automotive Cybersecurity Report (2022). <https://upstream.auto/2022report/>
39. VerSprite: PASTA Threat Modeling: The Process for Attack Simulation and Threat Analysis (eBook) (2022). <https://versprite.com/cybersecurity-listings/offsec/pasta-threat-modeling/>

40. Zelle, D., Plappert, C., Rieke, R., Scheuermann, D., Krauß, C.: ThreatSurf: A method for automated Threat Surface assessment in automotive cybersecurity engineering. *Microprocessors and Microsystems*, Band: 90 p. 104461 (2022). <https://doi.org/10.1016/j.micpro.2022.104461>.

Zusammenfassung

Dieses Kapitel befasst sich mit der Risikobewertung. Das Risiko ergibt sich aus der Kombination der Bewertung der Angriffsmachbarkeit (Feasibility Rating) von Bedrohungsszenarien und der Auswirkung (Impact), die durch das tatsächliche Eintreten eines Bedrohungsszenarios verursacht wird. Wir führen die Zuordnung von Asset-Bedrohungsszenarien zu Schadensszenarien durch und berechnen das Risiko für jede dieser Kombinationen. Darüber hinaus geben wir praxisorientierte Hinweise zur Anpassung der Risikomatrix. Es wird zudem gezeigt, wie statistische Darstellungen hilfreich sein können, um die zentralen Ergebnisse einer TARA (Threat Analysis and Risk Assessment) anschaulicher und verständlicher zu präsentieren. Abschließend stellen wir Beispiele auf Basis unserer drei Fallstudien vor.

In diesem Kapitel widmen wir uns der zentralen Aufgabe der Bedrohungsanalyse und Risikobewertung – der Risikoberechnung. Das Risiko ergibt sich aus der Kombination der Bewertung der Angriffsmachbarkeit (Feasibility Rating) der Bedrohungsszenarien mit den Bewertungen des Schadens (Impact Rating), die das tatsächliche Eintreten eines Bedrohungsszenarios verursacht. Die ISO/SAE 21434 ordnet dem Risiko einen numerischen Wert zu – dieser reicht von eins (minimales Risiko) bis fünf – und kann mithilfe einer Risikomatrix oder einer Risikoberechnungsformel bestimmt werden. Der Schritt der Risikobewertung im Gesamtprozess der TARA ist in Abb. 8.1 dargestellt.

Erforderliche Eingaben für dieses Kapitel:

- Bedrohungsszenarien (Threat Scenarios)
- Bewertung der Angriffsdurchführbarkeit (Attack Feasibility Evaluation)
- Schadensszenarien mit Bewertungen des Schadens (Damage-Scenarios mit Impact Rating)

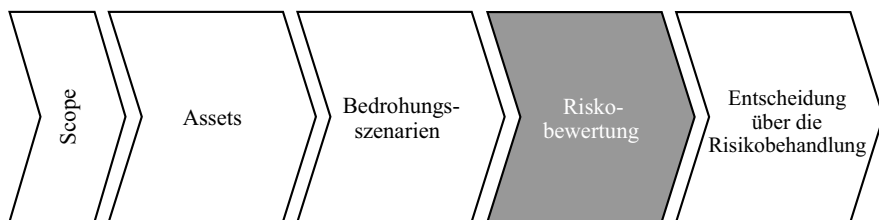


Abb. 8.1 Der Schritt der Risikobewertung im gesamten TARA-Prozess

Das Ergebnis dieses Kapitels ist:

- Risikowert für jede Kombination aus Assets (Schadensszenarien), Bedrohungen und Angriffspfaden

8.1 Risikobewertung

Sobald die Bedrohungsszenarien hinsichtlich ihrer Durchführbarkeit bewertet und die Auswirkungen der jeweiligen Schadensszenarien quantifiziert wurden, ist die Bestimmung des Risikowerts ein klar definierter Schritt. In diesem Schritt werden die Bedrohungsszenarien mit den resultierenden Schadensszenarien kombiniert. Unabhängig vom eingesetzten TARA-Tool muss eine vollständige Kombination aus Assets, Bedrohungsszenarien (einschließlich unterschiedlicher Angriffspfade) und den daraus resultierenden Schadensszenarien erstellt werden. Wird diese Kombination in eine Matrixform gebracht, ergibt sich eine TARA-Struktur wie in Abb. 8.2 dargestellt. Jedes Asset innerhalb eines Items ist dabei einem oder mehreren Bedrohungsszenarien zugeordnet.

Wie in Kap. 7 erläutert, wird die Beziehung zwischen Asset und Bedrohung primär über die jeweiligen Cybersecurity-Eigenschaften modelliert. Anschließend wird jedem Bedrohungsszenario mindestens ein Angriffspfad zugeordnet, der das Bedrohungsszenario im Kontext des jeweiligen Assets umsetzbar macht. In Abb. 8.2 zeigen wir explizit unterschiedliche Angriffspfade für dasselbe *Bedrohungsszenario 1*, um die Denkweise des Verfahrens nachvollziehbar darzustellen. Die ISO/SAE 21434 erlaubt, alle Angriffspfade eines Bedrohungsszenarios durch Aggregation der Bewertung der Angriffsmachbarkeit zu kombinieren. In anderen Worten: Die höchste (also am wenigsten machbare) Bewertung der Angriffsmachbarkeit aller Angriffspfade wird dem Bedrohungsszenario zugeordnet. Dies wird in der Abbildung für *Bedrohungsszenario 2* dargestellt, bei dem ein kombinierter Angriffspfad verwendet wird. Abschließend wird der Risikowert für jede Kombination aus Asset $\Leftrightarrow$ Bedrohungsszenarien $\Leftrightarrow$ Schadensszenarien bestimmt.

Informationen über Assets		Informationen über Bedrohungsszenarien					Informationen über Schadensszenarien			Risikobewertung	
Asset [WP-15-02]	Cybersecurity- Eigenschaft	Bedrohungs- szenario [WP-15-03]	Angriffspfad[WP-15-05]	Kompromitierte Cybersecurity- Eigenschaft [RQ-15-03]	Ursache für die Verletzung der Cybersecurity- Eigenschaft [RQ-15-03]	Bewertung der Angriffs- machbarkeit [WP-15-06]	Schadensszenario [WP-15-01]	Bewertung des Schadens für den Verkehrs- teilnehmer [WP-15-04]	Bewertung des Schadens für OEM oder Zulieferer	Risikowert für den Verkehrs- teilnehmer [WP-15-07]	Risikowert für OEM oder Zulieferer
Beziehung Assets → Angriffspfad → Bedrohungsszenario	Vertraulichkeit, Integrität, Verfügbarkeit	Bedrohungs- szenario 1	Angriffspfad 1	Integrität, Verfügbarkeit	...	...	Schadensszenario 1	Safety: ... Finanzen: ... Betrieb: ... Privatsphäre: ...	Safety: ... Finanzen: ... Betrieb: ... Privatsphäre: ...	...	...
			Angriffspfad 2	Integrität, Verfügbarkeit	...	...	Schadensszenario 2	Safety: ... Finanzen: ... Betrieb: ... Privatsphäre: ...	Safety: ... Finanzen: ... Betrieb: ... Privatsphäre: ...	...	...
		Bedrohungs- szenario 2	Angriffspfad (einfachster)	Vertraulichkeit	...	...	Schadensszenario 2	Safety: ... Finanzen: ... Betrieb: ... Privatsphäre: ...	Safety: ... Finanzen: ... Betrieb: ... Privatsphäre: ...	Safety: ... Finanzen: ... Betrieb: ... Privatsphäre: ...	...
Asset 1	Vertraulichkeit, Integrität, Verfügbarkeit	Bedrohungs- szenario 2	(Maximale Machbarkeits- bewertung über alle möglichen Angriffspfade)	Vertraulichkeit	...	...	Schadensszenario 3	Safety: ... Finanzen: ... Betrieb: ... Privatsphäre: ...	Safety: ... Finanzen: ... Betrieb: ... Privatsphäre: ...	...	...
							Schadensszenario 1	Safety: ... Finanzen: ... Betrieb: ... Privatsphäre: ...	Safety: ... Finanzen: ... Betrieb: ... Privatsphäre: ...	Safety: ... Finanzen: ... Betrieb: ... Privatsphäre: ...	...

Abb. 8.2 Darstellung der Risikobewertung in Form einer Matrix unter Einbeziehung der Beziehung zu Assets, Bedrohungsszenarien und Angriffspfaden

Die ISO/SAE 21434 spezifiziert, dass der Risikowert eine numerische Bewertung von eins bis fünf erhalten soll. Organisationen haben jedoch die Flexibilität, eigene Risikomatrizen oder Berechnungsformeln zu definieren, um den Risikowert basierend auf ihren spezifischen Anforderungen und Präferenzen zu bestimmen.

► **Verwechseln Sie Angriffspfade nicht mit den Schritten eines Angriffspfad** Wenn ein Bedrohungsszenario durch mehrere Angriffspfade realisiert werden kann, erfolgt die Risikoberechnung auf Basis des einfachsten Angriffspfad, d.h. jenem Pfad mit der höchsten Bewertung der Angriffsmachbarkeit (Attack Feasibility Rating). Der Ansatz ist wie folgt begründet: das Risiko, das sich aus einem Bedrohungsszenario ergibt, muss unabhängig davon behandelt werden, welcher Angriffspfad letztlich genutzt wird. Der einfachste Angriffspfad stellt das größte Risiko dar. Das Vorgehen zur Auswahl des einfachsten Angriffspfad ist vergleichbar mit der Methode zur Bewertung von Angriffspfaden mit mehreren Schritten (siehe Abschn. 7.3.4). Es handelt sich jedoch um unterschiedliche Verfahren, die nicht miteinander verwechselt werden sollten:

- Mehrere Angriffspfade = unterschiedliche Wege, ein Bedrohungsszenario zu realisieren
- Schritte eines Angriffspfad = aufeinanderfolgende Aktionen innerhalb eines bestimmten Pfads

Die Unterscheidung und das Zusammenspiel zwischen beiden Aspekten werden in Abb. 8.3 dargestellt.

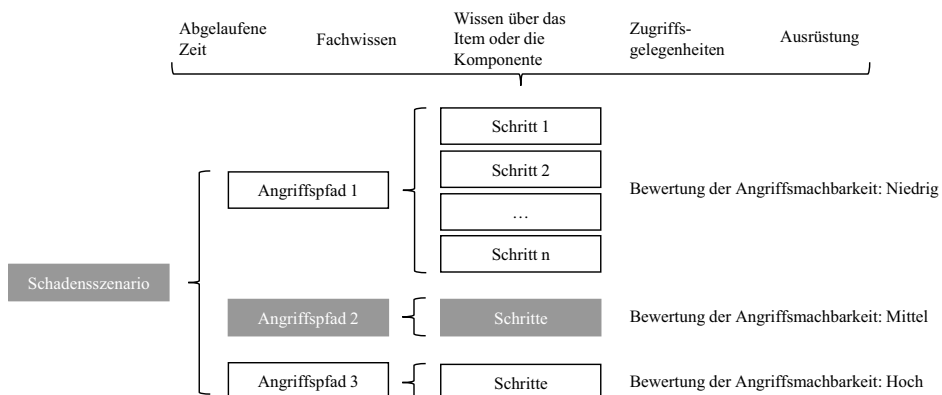


Abb. 8.3 Unterschied zwischen mehreren Angriffspfaden und mehreren Schritten eines Angriffspfad. Die drei Angriffspfade bestehen aus mehreren Schritten. Angriffspfad 2 hat die höchste Bewertung der Angriffsmachbarkeit und wird für die Risikobewertung ausgewählt

8.1.1 Risikomatrix

Der Risikowert kann mithilfe einer Risikomatrix berechnet werden, wie diese in Tab. 8.1 dargestellt ist. Wenn beispielsweise ein bestimmtes Schadensszenario eine Impact-Bewertung von *Moderat* aufweist und das zugehörige Bedrohungsszenario eine Bewertung der Angriffsmachbarkeit von *Hoch* hat, ergibt sich daraus ein Risikowert von drei.

8.1.1.1 Anpassungen an der Risikomatrix

Die Organisation kann die verwendete Risikomatrix (oder -formel) anpassen. Wenn wir das Beispiel der Risikomatrix in Tab. 8.1 analysieren, erkennen wir leicht, dass Risiken, die aus einer *vernachlässigbaren* Auswirkung resultieren, stets den minimalen Risikowert Eins erhalten. Diese Zuordnung ist sinnvoll, wenn die Bewertungskategorie *vernachlässigbar* stets eine irrelevante Konsequenz darstellt – wie bereits in Tab. 6.3 beschrieben. Verwendet die Organisation jedoch eigene Bewertungskriterien für Schäden (Impact Ratings), bei denen *Vernachlässigbar* eine höhere Auswirkung bedeutet als eine völlig irrelevante Konsequenz, kann es sinnvoll sein, die Risikomatrix so anzupassen, dass Bedrohungen mit *vernachlässigbarer* Auswirkung, aber hoher Eintrittswahrscheinlichkeit, ein höheres Risiko zugewiesen wird. Wenn beispielsweise das Kriterium *Vernachlässigbar* beim finanziellen Schaden für den Verkehrsteilnehmer bedeutet, dass pro Vorfall \$ 1 Verlust entsteht, ist das Risiko sehr gering, wenn die Durchführbarkeit des Angriffs ebenfalls sehr gering ist – also kaum eintritt. Selbst wenn es zum Angriff kommt, verliert der Nutzer nur \$ 1. Anders ist es, wenn die Bedrohung eine hohe Durchführbarkeit hat – also sehr wahrscheinlich eintritt. In diesem Fall ist das Risiko deutlich höher. Wird der Angriff z. B. 10.000 Mal ausgeführt, verliert der Nutzer \$ 10.000.

Ein ähnliches Problem ergibt sich, wenn das Bedrohungsszenario mit einer sehr hohen Auswirkung (beispielsweise Schwerwiegend) verknüpft ist, aber nur eine sehr geringe Wahrscheinlichkeit besteht. Das Problem in diesem Fall ist, dass sich das Risiko nicht auf ein Minimalniveau reduzieren lässt. Selbst bei einem Extrembeispiel der Angriffsdurchführbarkeit – etwa wenn eine Gruppe mehrerer Experten AES-256 per Brute-Force angreifen

Tab. 8.1 Beispiel einer Risikomatrix (wie in Tab. H.8 in [1])

Impact-Bewertung	Bewertung der Angriffsmachbarkeit			
	Sehr niedrig	Niedrig	Mittel	Hoch
Schwerwiegend (Severe)	2	3	4	5
Erheblich (Major)	1	2	3	4
Moderat (Moderate)	1	2	2	3
Vernachlässigbar (Negligible)	1	1	1	1

Tab. 8.2 Beispiel für eine Risikomatrix. Vernachlässigbare Auswirkungen werden zu einem höheren Risikowert, wenn die Risikowahrscheinlichkeit höher ist. Angriffe mit einer sehr niedrigen Wahrscheinlichkeit stellen kein erhebliches Risiko dar

Bewertung des Schadens	Bewertung der Angriffsmachbarkeit			
	Sehr niedrig	Niedrig	Mittel	Hoch
Schwerwiegend (Severe)	1	3	4	5
Erheblich (Major)	1	3	4	5
Moderat (Moderate)	1	2	3	4
Vernachlässigbar (Negligible)	1	1	2	3

müsste – ergibt sich mit der Risikomatrix aus Tab. 8.1 immer noch ein Risikowert von zwei. Ein Beispiel für eine angepasste Risikomatrix wird in Tab. 8.2 gezeigt.

8.1.2 Risikoformel

Die Berechnung des Risikowertes kann mit Hilfe einer Formel durchgeführt werden. Der Standard ISO/SAE 21434 verwendet das folgende Beispiel:

$$R = 1 + I \times F$$

wobei R der Risikowert, I ein numerischer Wert für die Bewertung des Schadens und F ein numerischer Wert für die Bewertung der Angriffsmachbarkeit ist. Die Übersetzung der Bewertung des Schadens und der Bewertung der Angriffsmachbarkeit in numerische Werte ist in Tab. 8.3 bzw. in Tab. 8.4 dargestellt.

Tab. 8.3 Beispiel für die Übersetzung der Bewertung des Schadens in numerische Werte (wie in Tab. H.10 in [1])

Bewertung des Schadens	I
Vernachlässigbar	0
Moderat	1
Erheblich	1,5
Schwerwiegend	2

Tab.8.4 Beispiel für die Übersetzung der Bewertung der Angriffsmachbarkeit in numerische Werte (wie in *Tab.H.10* in [1])

Bewertung der Angriffsmachbarkeit	<i>F</i>
Sehr niedrig	0
Niedrig	1
Mittel	1,5
Hoch	2

8.2 Daten verstehen und mit Statistik arbeiten

Jedes identifizierte Einzelrisiko ist wichtig und muss behandelt werden. Dennoch ist es oft hilfreich, mit statistischen Methoden zu arbeiten, um das Gesamtbild zu verstehen. Die einzelnen Ergebnisse der Risikoanalyse sind vor allem dann nützlich, wenn man tiefer in den Entwicklungsprozess einsteigt und beispielsweise Risiken gezielt auf entsprechende Schutzmaßnahmen zurückführt. In realen Projekten muss das Cybersecurity-Team die Ergebnisse der TARA in der Regel gegenüber dem Projektmanagement oder der Geschäftsleitung präsentieren. Dabei ist es erforderlich, die relevantesten Ergebnisse der TARA hervorzuheben – etwa die bedeutendsten Risiken, am stärksten betroffenen Assets oder am häufigsten vorkommenden Bedrohungsszenarien.

Der Hauptgrund für den Einsatz statistischer Auswertungen liegt darin, dass eine TARA in der Regel eine Vielzahl an Risiken umfasst. Die in Abb.8.2 dargestellte Risikomatrix ist lediglich ein minimales Beispiel dafür, wie Risiken in einer TARA durch die Kombination der jeweiligen Assets und Bedrohungsszenarien abgebildet werden. Jede Zeile in der TARA mit einem zugeordneten Risiko entspricht dabei einer Kombination aus Asset, Bedrohungsszenario und Schadensszenario.

Anzahl der Assets $\times$ Anzahl der Bedrohungsszenarien $\times$ Anzahl der Schadensszenarien

(die Formel ist vereinfacht, die Bedrohungsszenarien und Schadensszenarien je Asset variieren können). Eine TARA, die ein Produkt mit 20 Assets, durchschnittlich zehn Bedrohungsszenarien pro Asset und durchschnittlich fünf Schadensszenarien pro Bedrohungsszenarien enthält, hat beispielsweise 1000 Risikozeilen.

8.2.1 Bedrohungsszenarien

Ein Beispiel für eine statistische Analyse von Bedrohungsszenarien aus einer TARA ist in Abb.8.4 dargestellt. Die Analyse zeigt die Anzahl an Asset $\Leftrightarrow$ Bedrohungsszenario $\Leftrightarrow$

Statistiken zu Bedrohungsszenarien								
Bedrohungsszenario	Anzahl der Vorkommen <i>Asset</i> ↔ <i>Bedrohungsszenario</i> ↔ <i>Schadensszenario</i>							
	Gesamt	Vorkommen pro Risikolevel						Risikow. > 2
		5	4	3	2	1		
16.2 Manipulation der Fahrzeugtelematik	469	0	60	189	220	0		249
12.3 Die Software wird vor dem Aktualis. [...]	453	200	178	63	12	0		441
12.2 Beeinträchtigung von lokalen/physisch. [...]	448	210	160	70	8	0		440
5.1 Kommunikationskanäle ermög. Code-Inj. [...]	380	187	124	66	0	3		377
23.1 Fälschung der Software des Fahrzeugs. [...]	362	223	104	20	7	8		347
29.1 Überflüssige, offen gelassene Internetans. [...]	278	122	98	30	23	5		250
18.3 Ein Diagnosezugang wird zur Begünstigung [...]	259	102	98	54	5	0		254
18.2 Mit einem Virus infizierte Datenträger [...]	245	10	35	168	30	2		213
8 Denial-of-Service-Attacken über Kommunik. [...]	195	5	63	78	36	13		146
18.1 Externe Schnittstellen wie USB-Ansch. [...]	185	98	45	30	12	0		173
4.1 Spoofing von Nachrichten durch Identitäts. [...]	167	104	63	0	0	0		167
11.3 Schädliche Diagnosesemeldungen	163	89	74	0	0	0		163
11.4 Schädliche proprietäre Nachrichten	148	63	53	32	0	0		148
6.1 Akzeptieren von Info. aus einer unzuverläss. [...]	127	89	36	0	0	2		125
16.3 Interferenzen mit drahtlosen Systemen [...]	114	10	87	0	12	5		97
16.1 Manipulation von Fernbedienungsfunkt. [...]	112	89	23	0	0	0		112
20.5 Unbefugte Änderungen von Systemdiag. [...]	109	56	43	0	10	0		99
13.1 Denial-of-Service-Attacke gg. den Aktual. [...]	47	0	47	0	0	0		47
19.3 Extraktion kryptografischer Schlüssel	42	30	8	4	0	0		42
17.1 Manipulierte oder unsichere Anwendungen [...]	36	24	12	0	0	0		36

Abb. 8.4 Beispiel für Statistiken für Bedrohungsszenarien

Schadensszenario-Kombinationen für alle in der TARA betrachteten Bedrohungsszenarien. Die Häufigkeiten sind nach Risikowert aufgeschlüsselt, wodurch sich kritische Bedrohungen leicht identifizieren lassen. Die Gesamtanzahl der Vorkommnisse ist selbstverständlich ein interessanter Parameter, um zu verstehen, welche Bedrohungen besonders häufig auftreten. Die absolute Anzahl allein bedeutet jedoch nicht zwangsläufig ein hohes Risiko. So weist beispielsweise das erste Bedrohungsszenario in Abb. 8.4 mit 469 die höchste Anzahl an Vorkommnissen auf, erreicht jedoch kein Risikoniveau der Stufe fünf.

Die verschiedenen Risikowerte eignen sich zudem hervorragend, um rasch zu erkennen, wo sich kritische Bedrohungsszenarien befinden – und umgekehrt, welche Bedrohungsszenarien ein eher geringes Risiko darstellen. Falls beispielsweise die Cybersecurity-Richtlinie des Unternehmens vorsieht, Risiken mit einem Wert von zwei oder weniger zu akzeptieren, lässt sich damit einfach ermitteln, welche Risiken darüber liegen und folglich behandelt werden müssen.

8.2.2 Schadensszenarien

Ähnlich wie bei der statistischen Auswertung von Bedrohungsszenarien kann auch eine Statistikübersicht für Schadensszenarien erstellt werden. Ein Beispiel hierfür ist in Abb. 8.5 dargestellt. Das Diagramm zeigt auf einen Blick, welche Schadensszenarien in der TARA am häufigsten auftreten und mit welchen Risikolevels die einzelnen Schadensszenarien verknüpft sind.

Statistiken zu Schadensszenarien							
Schadensszenarien	Anzahl der Vorkommen Asset ⇔ Bedrohungsszenario ⇔ Schadensszenario						
	Gesamt	Vorkommen pro Risikolevel					
		5	4	3	2	1	Risikow. > 2
ECU wird beschädigt	1094	324	625	108	30	7	1057
Fahrzeug außer Betrieb oder mit eingeschr. Funktionalität [...]	860	435	288	30	102	5	753
Fahrerablenkung, keine Verletzungen	678	600	45	33	0	0	678
Offenlegung personenbezogener Daten [...]	497	154	112	228	3	0	494
Nichtverfüg. von nicht-sicherheitsrel. Informationen [...]	465	0	204	231	20	10	435
Reverse Engineering von Software, Produktpiraterie	398	0	89	109	184	16	198
Unbefugte Software/Daten im Fahrzeug installierte	347	198	48	65	36	0	311

Abb. 8.5 Beispielhafte Statistik für Schadensszenarien

8.2.3 Assets

Eine interessante statistische Auswertung ist die Verteilung des Risikos über die verschiedenen Assets. Ein Beispiel hierfür ist in Abb. 8.6 dargestellt. In diesem Diagramm lässt sich erkennen, welche Assets mit den höchsten Risiken verbunden sind. Diese Information kann im weiteren Entwicklungsprozess hilfreich sein. Beispielsweise können höher eingestufte Risiken bei der Definition von Schutzmaßnahmen priorisiert werden. Betrachtet man die in Abb. 8.6 dargestellten Ergebnisse, könnte das Cybersecurity-Team dem Projektmanagement vorschlagen, den Cybersecurity-Entwurf vorrangig auf die Assets *Bootloader*, *CAN*, *Software-Updates* und *OEM-Anwendungen* auszurichten. Darüber hinaus wird das Diagramm noch aussagekräftiger, wenn die Statistik nach der Zuordnung von Cybersecurity-Maßnahmen zu den Risiken und einer erneuten Risikobewertung durchgeführt wird. Wie in Abb. 8.6 zu erkennen ist, zeigen die Risikowerte auf der rechten Seite der Abbildung die verbleibenden Restrisiken nach Anwendung der Cybersecurity-Maßnahmen.

Statistiken zu Assets													
Asset	Anzahl der Vorkommen Asset ⇔ Bedrohungsszenario ⇔ Schadensszenario												
	Gesamt	Ohne Maßnahmen						Mit Maßnahmen					
		5	4	3	2	1	Risikow. > 2	5	4	3	2	1	
Bootloader	789	412	163	106	78	30	681	0	0	0	205	384	
CAN	657	503	88	33	20	13	624	0	0	0	304	353	
Software-Updates	625	344	178	67	25	11	589	0	0	0	200	425	
OEM-Anwendungen	506	304	128	55	19	0	487	0	0	0	128	378	
OBD-II	354	26	104	105	63	56	235	0	0	0	171	183	
Private Schlüssel und Passwörter	320	254	46	20	0	0	320	0	0	0	21	299	
Ethernet (DoIP)	286	189	70	24	0	3	283	0	0	0	80	206	
Ethernet (SOME/IP)	186	102	56	28	0	0	186	0	0	0	65	121	
FlexRay	143	77	48	14	4	0	139	0	0	0	88	55	
JTAG	130	12	89	18	11	0	119	0	0	0	30	100	
Zahlungsinformationen	105	15	66	20	4	0	101	0	0	0	5	100	
Zugangsdaten	103	44	22	22	10	5	88	0	0	0	22	81	
Benutzerprofildaten	103	45	40	18	0	0	103	0	0	0	23	80	
Kalibrierungsdaten	32	0	5	20	7	0	25	0	0	0	0	32	
Gesamtanzahl	4339	2327	1103	550	241	118	3980	0	0	0	1342	2997	
Prozent	100%	54%	25%	13%	6%	3%	100%	0%	0%	0%	34%	75%	

Abb. 8.6 Beispielhafte Statistik für Assets

8.3 Praktische Fallstudien

In diesem Kapitel setzen wir die praxisbezogenen Fallstudien fort, die im Verlauf des Buches entwickelt wurden. Dabei greifen wir auf die in Kap. 6 definierten Schadensszenarien und die in Kap. 7 beschriebenen Bedrohungsszenarien zurück. Zur Berechnung der Risikowerte wenden wir die Risikomatrix in Tab. 8.1 an.

8.3.1 Fallstudie 1: Eingebettetes Fahrzeugsteuergerät

Wir bewerten die beiden Bedrohungsszenarien für das Asset *Anwendungssoftware*, die wir in Abschn. 7.4.1 identifiziert haben, nämlich die Bedrohungsszenarien *12.3 Die Software wird vor dem Aktualisierungsprozess manipuliert (und daher beschädigt)*, obwohl dieser intakt ist sowie *Umgehung der Signaturprüfung der Software durch einen Seitenkanalangriff*. Dabei wenden wir die Schadensszenarien an, die wir in Tab. 6.12 und 6.13 in Abschn. 6.5.1 bewertet haben. Die in Tab. 6.12 definierten Schadensszenarien stellen beispielsweise die vollständige Liste der im Projekt identifizierten Schadensszenarien dar. Bei der Analyse spezifischer Bedrohungsszenarien für einzelne Assets ist jedoch nicht jedes Schadensszenario auf jedes Bedrohungsszenario anwendbar. So wurde in beiden Bedrohungsszenarien dieses Beispiels das Schadensszenario *Offenlegung personenbezogener Daten* ausgeschlossen. Die Risikobewertung für beide Bedrohungsszenarien sowie für die unterschiedlichen Stakeholder-Perspektiven (d. h. Verkehrsteilnehmer, OEM) ist in den Tab. 8.5, 8.6, 8.7 und 8.8 dargestellt.

8.3.2 Fallstudie 2: Fahrzeug-Backend-Architektur

In unserer zweiten Fallstudie zur Fahrzeug-Backend-Architektur haben wir das Asset *Sensible Daten bei der Übertragung* ausgewählt und das Bedrohungsszenario *6.2 Man-in-the-Middle-Angriff/Session Hijacking* in Abschn. 7.4.2 identifiziert und bewertet. Die zugehörigen Schadensszenarien wurden für drei verschiedene Stakeholder – nämlich Verkehrsteilnehmer, OEM und Drittanbieter – in den Tab. 6.16, 6.17 und 6.18 beschrieben. Wir bewerten das Risiko aus der Perspektive jedes Stakeholders und stellen die Ergebnisse in den Tab. 8.9, 8.10 und 8.11 dar.

8.3.3 Fallstudie 3: Automobilproduktionsanlage

In dieser Fallstudie wird das Bedrohungsszenario *System Firmware (T0857)* bewertet, das das Asset *Software-Updates* einer Fertigungsanlage betrifft. Die Bewertung erfolgt im Hinblick auf verschiedene Schadensszenarien für die Stakeholder Verkehrsteilnehmer und

Tab.8.5 Risikobewertung der Auswirkungen auf den Verkehrsteilnehmer zu Fallstudie 1

Asset: Anwendungssoftware

Bedrohungsszenario: 12.3 Die Software wird vor dem Aktualisierungsprozess manipuliert (und daher beschädigt), obwohl dieser intakt ist

Bewertung der Angriffsmachbarkeit: Mittel

Schadensszenario [WP-15-01]	Risikowert für jede Kategorie [WP-15-07]				Maximaler Risikowert [WP-15-07]
	Verkehrsteilnehmer-Ansicht				
	Safety	Finanzen	Betrieb	Privatsphäre	
Fahrzeug oder Komponente (z. B. ECU) wird beschädigt	1	2	4	1	4
Sensoren/Warnsysteme liefern falsche Informationen	3	3	3	1	3
Nichtverfügbarkeit von nicht sicherheitsrelevanten Informationen (z. B. Verkehrsinformationen, Musik, Adressbuch)	1	2	4	1	4
Veröffentlichung der Schwachstelle	1	1	1	1	1

Tab.8.6 Risikobewertung der Auswirkungen auf den OEM zu Fallstudie 1

Asset: Anwendungssoftware

Bedrohungsszenario: 12.3 Die Software wird vor dem Aktualisierungsprozess manipuliert (und daher beschädigt), obwohl dieser intakt ist

Bewertung der Angriffsmachbarkeit: Mittel

Schadensszenario [WP-15-01]	Risikowert für jede Kategorie [WP-15-07]				Maximaler Risikowert [WP-15-07]
	OEM-Ansicht				
	Geistiges Eigentum	Image/ Reputation	Finanzen	Betrieb	
Fahrzeug oder Komponente (z. B. ECU) wird beschädigt	1	2	2	1	2
Sensoren/Warnsysteme liefern falsche Informationen	1	3	2	1	3
Nichtverfügbarkeit von nicht sicherheitsrelevanten Informationen (z. B. Verkehrsinformationen, Musik, Adressbuch)	1	2	2	1	2
Veröffentlichung der Schwachstelle	2	3	2	2	3

Tab. 8.7 Risikobewertung der Auswirkungen auf den Verkehrsteilnehmer zu Fallstudie 1

Asset: Anwendungssoftware					
Bedrohungsszenario: Umgehung der Software-Signaturprüfung durch einen Seitenkanalangriff					
Bewertung der Angriffsmachbarkeit: Sehr niedrig					
Schadensszenario [WP-15-01]	Risikowert für jede Kategorie [WP-15-07]				Maximaler Risikowert [WP-15-07]
	Verkehrsteilnehmer-Ansicht				
	Safety	Finanzen	Betrieb	Privatsphäre	
Fahrzeug oder Komponente (z.B. ECU) wird beschädigt	1	1	2	1	2
Sensoren/Warnsysteme liefern falsche Informationen	1	1	1	1	1
Nichtverfügbarkeit von nicht sicherheitsrelevanten Informationen (z.B. Verkehrsinformationen, Musik, Adressbuch)	1	1	2	1	2
Veröffentlichung der Schwachstelle	1	1	1	1	1

Tab. 8.8 Risikobewertung der Auswirkungen auf den OEM zu Fallstudie 1

Asset: Anwendungssoftware					
Bedrohungsszenario: Umgehung der Software-Signaturprüfung durch einen Seitenkanalangriff					
Bewertung der Angriffsmachbarkeit: Sehr niedrig					
Schadensszenario [WP-15-01]	Risikowert für jede Kategorie [WP-15-07]				Maximaler Risikowert [WP-15-07]
	OEM-Ansicht				
	Geistiges Eigentum	Image/ Reputation	Finanzen	Betrieb	
Fahrzeug oder Komponente (z. B. ECU) wird beschädigt	1	1	1	1	1
Sensoren/Warnsysteme liefern falsche Informationen	1	1	1	1	1
Nichtverfügbarkeit von nicht sicherheitsrelevanten Informationen (z. B. Verkehrsinformationen, Musik, Adressbuch)	1	1	1	1	1
Veröffentlichung der Schwachstelle	1	1	1	1	1

Tab.8.9 Risikobewertung der Auswirkungen auf den Verkehrsteilnehmer zu Fallstudie 2

Asset: Sensible Daten bei der Übertragung					
Bedrohungsszenario: 6.2 Man-in-the-Middle-Angriff/Session Hijacking					
Bewertung der Angriffsmachbarkeit: Mittel					
Schadensszenario [WP-15-01]	Risikowert für jede Kategorie [WP-15-07]				Maximaler Risikowert [WP-15-07]
	Verkehrsteilnehmer-Ansicht				
	Safety	Finanzen	Betrieb	Privatsphäre	
Offenlegung von geschäftsrelevanten Daten	1	1	1	1	1
Nutzung von Dienstleistungen ohne gültige Lizenzen	1	2	3	1	3

Tab.8.10 Risikobewertung der Auswirkungen auf den OEM zu Fallstudie 2

Asset: Sensible Daten bei der Übertragung					
Bedrohungsszenario: 6.2 Man-in-the-Middle-Angriff/Session Hijacking					
Bewertung der Angriffsmachbarkeit: Mittel					
Schadensszenario [WP-15-01]	Risikowert für jede Kategorie [WP-15-07]				Maximaler Risikowert [WP-15-07]
	OEM-Ansicht				
	Geistiges Eigentum	Image/Reputation	Finanzen	Betrieb	
Offenlegung von geschäftsrelevanten Daten	3	3	1	1	3
Nutzung von Dienstleistungen ohne gültige Lizenzen	1	1	2	1	2

Zulieferer. Die entsprechenden Schadensszenarien sind in den Tab.6.22 und 6.23 dargestellt. Das Bedrohungsszenario und sein Angriffsweg werden ausführlich in Abschn. 7.4.3 analysiert. Die Ergebnisse der Risikobewertung für beide Stakeholder sind in den Tab.8.12 und 8.13 dargestellt.

Tab. 8.11 Risikobewertung der Auswirkungen auf den Drittanbieter zu Fallstudie 2

Asset: Sensible Daten bei der Übertragung					
Bedrohungsszenario: 6.2 Man-in-the-Middle-Angriff/Session Hijacking					
Bewertung der Angriffsmachbarkeit: Mittel					
Schadensszenario [WP-15-01]	Risikowert für jede Kategorie [WP-15-07]				Maximaler Risikowert [WP-15-07]
	Drittanbieter-Ansicht				
	Geistiges Eigentum	Image/Reputation	Finanzen	Betrieb	
Offenlegung von geschäftsrelevanten Daten	3	2	1	1	3
Nutzung von Dienstleistungen ohne gültige Lizenzen	1	1	1	1	1

Tab. 8.12 Risikobewertung der Auswirkungen auf den Verkehrsteilnehmer zu Fallstudie 3

Asset: Software-Updates					
Bedrohungsszenario: System Firmware (T0857)					
Bewertung der Angriffsmachbarkeit: Mittel					
Schadensszenario [WP-15-01]	Risikowert für jede Kategorie [WP-15-07]				Maximaler Risikowert [WP-15-07]
	Verkehrsteilnehmer-Ansicht				
	Safety	Finanzen	Betrieb	Privatsphäre	
Manipulierte Software, die in das Endprodukt (Steuergerät) eingeschleust wurde	4	3	4	1	4
Produktionsmaschinen und/oder lokale Server wurden mit Ransomware infiziert	1	1	1	1	1
Produktionsstopp länger als einen Tag	1	1	1	1	1
Manipulierte Produktionsdaten oder Stücklisten führen zu fehlerhaften Endprodukten	4	3	4	1	4

Tab. 8.13 Risikobewertung der Auswirkungen auf den Lieferanten zu Fallstudie 3

Asset: Software-Updates

Bedrohungsszenario: System Firmware (T0857)

Bewertung der Angriffsmachbarkeit: Mittel

Schadensszenario [WP-15-01]	Risikowert für jede Kategorie [WP-15-07]				Maximaler Risikowert [WP-15-07]
	Lieferantensicht				
	Geistiges Eigentum	Image/ Reputation	Finanzen	Betrieb	
Manipulierte Software, die in das Endprodukt (Steuergerät) eingeschleust wurde	1	3	2	1	3
Produktionsmaschinen und/oder lokale Server wurden mit Ransomware infiziert	1	4	3	3	4
Produktionsstopp länger als einen Tag	1	4	3	3	4
Manipulierte Produktionsdaten oder Stücklisten führen zu fehlerhaften Endprodukten	1	4	4	2	4

Literatur

1. ISO/SAE 21434:2021 Road vehicles – Cybersecurity engineering. Standard, International Organization for Standardization/Society of Automotive Engineers, Geneva, CH (2021). <https://www.iso.org/standard/70918.html>

Zusammenfassung

Sobald die Risikobewertung abgeschlossen ist, folgt im nächsten Schritt die Entscheidung darüber, welche Maßnahmen zur Behandlung der identifizierten Risiken ergriffen werden sollen. In diesem Schritt entscheidet das Cybersecurity-Team – im Einklang mit ISO/SAE 21434 und der unternehmensinternen Richtlinie –, ob Risiken vermieden, reduziert, übertragen oder akzeptiert werden können. Jedes einzelne Risiko, das einen bestimmten Mindestwert überschreitet, muss analysiert werden. Wenn Cybersecurity-Maßnahmen zur Risikominderung angewendet werden, werden neue Risikowerte berechnet. In diesem Schritt der TARA (Threat Analysis and Risk Assessment) werden Cybersecurity-Ziele und Cybersecurity-Aussagen definiert – sei es bei Akzeptanz oder Übertragung von Risiken oder beim Einsatz von Maßnahmen zur Risikominderung. Wir führen unsere Fallstudien weiter und geben Beispiele für verschiedene Entscheidungen zur Risikobehandlung, einschließlich der Zuordnung von Cybersecurity-Maßnahmen. Auch wenn dies der letzte formale Schritt der TARA ist, erläutern wir, dass die TARA in der Praxis ein sich weiterentwickelndes Dokument ist und der Prozess beliebig oft iteriert werden kann.

Wir sind beim letzten formalen Schritt des TARA-Prozesses angekommen: der Entscheidung über die identifizierten Risiken. Für jedes identifizierte Risiko – also für jedes Bedrohungsszenario – muss eine Entscheidung getroffen werden. Sowohl in der Fachliteratur als auch in dem Standard ISO/SAE 21434 werden im Wesentlichen vier Strategien zur Risikobehandlung beschrieben: *Risikovermeidung*, *Risikominderung*, *Risikoverteilung* und *Risikoakzeptanz*. Darüber hinaus gibt es zwei zentrale Elemente, die im Kontext der automobilen TARA gemäß ISO/SAE 21434 in diesem Schritt berücksichtigt werden: die Definition von *Cybersecurity-Zielen* und *Cybersecurity-Aussagen* (Cybersecurity-Claims). Der Schritt der Risikobehandlungsentscheidung im gesamten TARA-Prozess ist in Abb. 9.1 dargestellt.

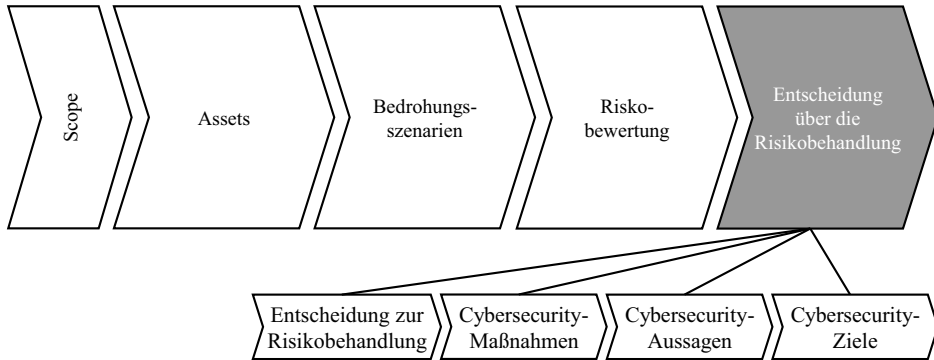


Abb. 9.1 Die Risikobehandlungsentscheidung im TARA-Prozess

Erforderliche Eingaben für dieses Kapitel:

- Risikobewertung der Bedrohungsszenarien

Ergebnisse dieses Kapitels:

- Entscheidung zur Risikobehandlung
- Cybersecurity-Maßnahmen
- Cybersecurity-Ziele
- Cybersecurity-Aussagen

9.1 Entscheidung zur Risikobehandlung und Risikotoleranz

Der Zweck der Erstellung einer TARA besteht darin, die Risiken eines Items zu identifizieren und etwas gegen diese Risiken zu unternehmen. Typischerweise trifft das TARA-Projektteam Entscheidungen auf Basis der vordefinierten Risikomanagementrichtlinien der Organisation. ISO/SAE 21434 legt fest, dass bei Bedrohungsszenarien mit einem Risikowert von eins diese Risiken gemäß der Norm nicht behandelt werden müssen (siehe [PM-06-08] in [6]). Nur wenn diese Risiken Auswirkungen auf die Cybersecurity haben, müssen sie behandelt werden – jedoch mit weniger Strenge als in der Norm vorgesehen. Für Risikowerte größer als eins muss eine Risikobehandlungsentscheidung getroffen werden.

9.2 Risikovermeidung

Risikovermeidung beruht darauf, das Design eines Items so zu ändern, dass die Ursache des Risikos beseitigt wird. Wenn zum Beispiel das Risiko besteht, dass die Software eines Steuergeräts (ECU) über ein Debugging-Protokoll auf der JTAG-Schnittstelle manipuliert werden kann, kann das Risiko vermieden werden, indem die JTAG-Schnittstelle entfernt wird. Eine andere Möglichkeit wäre, die JTAG-Schnittstelle im Hardwaredesign beizubehalten, aber das Debugging-Protokoll aus dem Software-Build zu entfernen. Der Ansatz der Risikovermeidung ist besonders in der Konzeptphase eines Items sinnvoll, etwa bei der Durchführung einer ersten TARA. In dieser frühen Phase können grundlegende Entscheidungen über das Software- oder Hardwaredesign getroffen und architektonische Änderungen vorgenommen werden, ohne dass hohe Kosten entstehen.

9.3 Risikoreduzierung

Risiko ist eine Kombination aus Auswirkung (Impact) und Wahrscheinlichkeit (Machbarkeit bzw. Attack-Feasibility). Theoretisch könnte eine Risikoreduzierung entweder durch die Verringerung der Auswirkung oder der Wahrscheinlichkeit erfolgen. Die Verringerung der Auswirkung eines Bedrohungsszenarios ist jedoch nicht sinnvoll, da diese nicht vom Bedrohungsszenario selbst abhängt, sondern im TARA-Prozess durch Schadensszenarien modelliert wird. Daher können Risiken nur durch die Verringerung ihrer Wahrscheinlichkeit reduziert werden, das heißt durch die Erhöhung des Wertes der Machbarkeit. In der Praxis bedeutet ein größerer Machbarkeitswert eines Angriffs, dass das Bedrohungsszenario schwieriger umzusetzen ist.

Die Risikoreduzierung wird durch technische Gegenmaßnahmen am Item erreicht, sogenannte *Cybersecurity-Maßnahmen* (Cybersecurity Controls). Zusätzlich zur Zuweisung von Cybersecurity-Maßnahmen müssen bei der Entscheidung zur Risikoreduktion auch *Cybersecurity-Ziele* (Cybersecurity Goals) festgelegt werden.

- **Cybersecurity-Maßnahmen und Konzeptdesign** Die Zuweisung von Cybersecurity-Maßnahmen (Controls) in einem TARA-Projekt hat typischerweise den Hauptzweck, eine Empfehlung des Cybersecurity-Teams an das Systemdesign auszusprechen, um die identifizierten Risiken zu mindern. Die Cybersecurity-Maßnahmen sind in der Regel konzeptuelle Gegenmaßnahmen aus Standards oder unternehmensspezifischen Katalogen, wie z.B. *Secure Boot*, *Secure Update*, Einsatz von *Firewalls* und andere. Die TARA ist ein lebendes Dokument, und die in der TARA vorgeschlagenen Cybersecurity-Maßnahmen müssen im Verlauf des Design- und Entwicklungsprozesses weiter verfeinert werden. Dabei müssen Cybersecurity-Aussagen, unter Berücksichtigung des spezifischen Items und seines Einsatzumfelds, den Maßnahmen

zugewiesen werden. Die Vollständigkeit, Korrektheit und Konsistenz der Cybersecurity-Maßnahmen im Hinblick auf die Cybersecurity-Ziele und -Aussagen (Claims) muss überprüft werden. Diese weiterführende Analyse der Cybersecurity-Maßnahmen geht über den eigentlichen TARA-Prozess hinaus und ist Bestandteil der Entwicklung des Cybersecurity-Konzepts des Items (siehe *Abschn. 9.5 Cybersecurity Concept* in [6]).

9.3.1 Cybersecurity-Ziele

Cybersecurity-Ziele sind konzeptuelle Cybersecurity-Anforderungen, die einem oder mehreren Bedrohungsszenarien zugeordnet sind. Sie beschreiben die Anforderungen zum Schutz von Assets gegenüber Bedrohungsszenarien. Insbesondere in der Konzeptphase unterstützen Cybersecurity-Ziele das Verständnis für die Entscheidung, Cybersecurity-Maßnahmen auf ein Item anzuwenden, und dienen als Grundlage für architektonische Designentscheidungen. Darüber hinaus sind sie wichtig für Entscheidungen über die Eignung von Zulieferern (siehe *Abschn. 7.4.1* in [6]). In einer Ausschreibung zur Entwicklung eines Items muss der OEM oder Zulieferer die relevanten Cybersecurity-Ziele angeben, die von potenziellen Zulieferern erfüllt werden müssen. Beispielhafte Cybersecurity-Ziele können sein:

- Personenbezogene und personenbeziehbare Daten, die im Item gespeichert sind, sollen vor unbefugtem Zugriff geschützt werden.
- Die Integrität und Authentizität sensibler Nachrichten soll sichergestellt werden.
- Die Diagnoseschnittstellen sollen vor unbefugtem Zugriff geschützt werden.
- Zertifikate dürfen nicht durch unbefugte Nutzer verändert werden.

9.3.2 Cybersecurity-Maßnahmen

Cybersecurity-Maßnahmen sind in der Regel technische Gegenmaßnahmen, die dazu dienen, ein Bedrohungsszenario zu verhindern. Es können jedoch auch organisatorische oder prozessuale Maßnahmen eingesetzt werden. Bei der Diskussion zum Prozess der Bedrohungsidentifikation wurde betont, dass es sich dabei um einen kreativen Prozess handelt, der vom Cybersecurity-Team ein tiefes technisches Verständnis des Items sowie die Fähigkeit verlangt, „wie ein Angreifer zu denken“. Aus diesem Grund wird empfohlen, die Bedrohungsidentifikation in Form von Brainstorming-Sitzungen durchzuführen, anstatt sich ausschließlich auf Standardkataloge zu verlassen. Im Gegensatz dazu wird bei der Zuweisung von Cybersecurity-Maßnahmen empfohlen, auf Standardkataloge zurückzugreifen. In der Industrie stehen bereits viele etablierte Cybersecurity-Maßnahmen zur Verfügung, einschließlich bekannter konzeptioneller Ansätze wie Secure Boot, sodass die Wahrchein-

lichkeit hoch ist, geeignete und praxiserprobte Maßnahmen für ein bestimmtes Bedrohungsszenario zu finden. Gemäß dem bewährten Schichtenprinzip der Cybersecurity (Defense-in-Depth) sind oft mehrere Schutzebenen sinnvoll oder notwendig, um ein Risiko wirksam zu mindern. Daher können mehrere Cybersecurity-Maßnahmen aus Standardkatalogen gleichzeitig auf ein Bedrohungsszenario angewendet werden. Der Einsatz bekannter Maßnahmen hat zudem den Vorteil, dass er den Designprozess des Items erleichtert und sich gut in bestehende Entwicklungsprozesse integrieren lässt.

Es gibt zahlreiche Quellen für Cybersecurity-Maßnahmen (Controls). Die bereits zuvor erwähnten Bedrohungskataloge enthalten ebenfalls Cybersecurity-Maßnahmen, die in den meisten Fällen direkt mit den jeweiligen Bedrohungen verknüpft sind. Beispiele hierfür:

- Die UN-Regelung Nr. 155 [9] enthält eine Liste von Gegenmaßnahmen, die den in *Anhang* aufgeführten Bedrohungen zugeordnet sind.
- Das MITRE ATT&CK® Framework [8] ist ebenfalls eine sehr empfehlenswerte Quelle für Gegenmaßnahmen. Es bietet verschiedene Maßnahmen zur Abschwächung der beschriebenen Bedrohungstechniken.
- Die OWASP® Top 10 [1] stellt eine umfassende Liste von Gegenmaßnahmen zur Verhinderung der beschriebenen Bedrohungen bereit. Eine Analyse der OWASP® Top 10 wird für alle Arten von Items empfohlen (z. B. eingebettete Systeme oder IT-/OT-Systeme), da viele der Maßnahmen grundlegender Natur und universell anwendbar sind (siehe z. B. die Maßnahmen zu A02:2021 – *Kryptografische Fehler* in [1]).

Weitere Quellen für Cybersecurity-Maßnahmen sind internationale Standards wie beispielsweise die ISO/IEC 27000-Serie [3], der Standard IEC 62443-4-2 [2], NIST SP 800-53 [7] sowie ENISA Threat Landscape (ETL) [5]. Für den automobilen Bereich sind (weitere) Cybersecurity-Maßnahmen zudem ausführlich in [4] und [10] beschrieben.

9.3.2.1 Kategorisierung von Cybersecurity-Maßnahmen

Es gibt verschiedene Ansätze zur Taxonomie von Cybersecurity-Maßnahmen. In diesem Buch wird keine detaillierte Klassifikation behandelt, da dies den Rahmen des TARA-Prozesses übersteigt. Kurz gesagt, lassen sich Cybersecurity-Maßnahmen klassisch in *präventive*, *detektive* und *korrektive* Maßnahmen einteilen. Präventive Maßnahmen zielen darauf ab, Cyberangriffe von vornherein zu verhindern. Die meisten technischen Cybersecurity-Maßnahmen im Rahmen von TARAs sind präventiv. Detektive Maßnahmen dienen dem Erkennen von Cyberangriffen. Korrektive Maßnahmen greifen in der Regel nach einem erfolgreichen Cyberangriff. Andere Klassifizierungsansätze basieren auf spezifischen Sicherheitsattributen der Maßnahmen, wie physische und logische Maßnahmen, Maßnahmen zur Zugriffskontrolle, Schulung, Konfigurationsmanagement, Verarbeitung personenbezogener Daten und andere.

Das Cybersecurity-Team und die Organisation sind frei darin, ein Klassifizierungsschema zu verwenden oder selbst zu entwerfen. Für den TARA-Prozess ist es jedoch erforderlich, die Cybersecurity-Maßnahmen mit den spezifischen Bedrohungsszenarien zu verknüpfen, bei denen ein Risiko gemindert werden soll. Da die TARA auf Cybersecurity-Eigenschaften basiert, ist es wichtig zu verstehen und zu dokumentieren, wie die ausgewählten Cybersecurity-Maßnahmen mit der jeweiligen Cybersecurity-Eigenschaft des vom Bedrohungsszenario betroffenen Assets zusammenhängen. Ein einfaches Beispiel: Eine Cybersecurity-Maßnahme, die ausschließlich das Ziel *Vertraulichkeit* schützt, sollte nicht auf ein Bedrohungsszenario angewendet werden, das ausschließlich die *Verfügbarkeit* des Assets beeinträchtigt. Aus diesem Grund kann es bei der Erstellung eigener Kataloge durch das Cybersecurity-Team sehr hilfreich sein, für jede Maßnahme im Katalog die betroffene Cybersecurity-Eigenschaft zu dokumentieren. In Tab. 9.1 geben wir Beispiele typischer Maßnahmen für eingebettete Systeme im Automobilbereich an, und in Tab. 9.2 für IT-/OT-Systeme.

9.3.2.2 Bewertung der Angriffsmachbarkeit

Die Cybersecurity-Maßnahmen sollen die Bewertung der Angriffsmachbarkeit für das Bedrohungsszenario verringern, für das die jeweilige Maßnahme vorgesehen ist. Die Methodik zur Bewertung der Angriffsmachbarkeit entspricht der in Abschn. 7.3 beschriebenen Vorgehensweise. Wurde das Bedrohungsszenario ursprünglich mithilfe des Angriffspotenzialbasierten Ansatzes bewertet, erhöhen die Cybersecurity-Maßnahmen in der Regel den Bewertungsgrad mindestens einer der folgenden Kategorien: *Abgelaufene Zeit* (Elapsed Time), *Fachwissen* (Specialist Expertise), *Wissen über das Item oder die Komponente* (Knowledge of the Item or Component), *Zugriffsgelegenheiten* (Window of Opportunity) und *Ausrüstung* (Equipment).

► Restrisiko kann *hoch* bleiben

Restrisiko, auch bekannt als *vermindertes oder mitigiertes Risiko*, bezeichnet das verbleibende Risiko eines Assets nach der Umsetzung von Maßnahmen. Es beschreibt das Risiko, das besteht, wenn ein Angreifer versucht, den Angriffsweg trotz implementierter technischer Maßnahme umzusetzen – vereinfacht gesagt: der Angreifer versucht, die Maßnahme zu umgehen oder zu durchbrechen. Die Höhe des Restrisikos kann – abhängig von der verwendeten Risikomatrix – unterschiedlich ausfallen (unter der Annahme, dass eine Matrix verwendet wird). Es ist möglich, dass das Restrisiko in bestimmten Fällen weiterhin größer als eins bleibt. So liegt beispielsweise bei der in Tab. 8.1 von Abschn. 8.1.1 dargestellten Risikomatrix das minimale erreichbare Restrisiko bei zwei, wenn die Auswirkungsbewertung des betroffenen Schadensszenarios als *schwerwiegend* eingestuft ist. Einige Cybersecurity-Maßnahmen können den Angriffsweg jedoch so erschweren, dass seine Umsetzung nahezu unmöglich wird – etwa

Tab. 9.1 Typische Cybersecurity-Maßnahmen für eingebettete Systeme im Automobilbereich, einschließlich einer beispielhaften Zuordnung zu den zugehörigen Cybersecurity-Eigenschaften.

Cybersecurity-Maßnahme	Bezogen auf Cybersecurity-Eigenschaft ^a					
	C	I	Av	Au	NR	Acc
Secure Boot		X	X	X		
Sicheres Flashen (sichere Programmierung)	X	X		X	X	X
Nachrichtenauthentifizierung		X		X	X	X
Secure Onboard Communication (SecOC)		X				
Sichere Aktualisierung	X	X		X	X	X
Sichere Zugriffsdiagnose				X		
Sicheres Lebenszyklusmanagement ^b	n/a	n/a	n/a	n/a	n/a	n/a
Schutz/Deaktivierung von Debug-Schnittstellen	X	X	X	X		
Sichere Speicherung von Daten	X	X		X		
Verschlüsselung von Daten bei der Übertragung	X	X				
Trennung von Netzwerken	X	X	X			
Hardware-Sicherheitsmodul (HSM)	X	X	X	X		
Firewall		X	X			
Intrusion Detection (und Prevention) System		X	X			
Schutz gegen Angriffe durch Spannungsstörungen		X	X			
Redundante Kommunikationssysteme		X				
Plausibilitätsprüfungen aus verschiedenen Quellen		X	X			

^a C: Vertraulichkeit, I: Integrität, Av: Verfügbarkeit, Au: Authentizität, NR: Nichtabstreitbarkeit, Acc: Rechenschaftspflicht

^b Einige Cybersecurity-Maßnahmen können nicht direkt mit einer Cybersecurity-Eigenschaft in Verbindung gebracht werden

durch die Kombination mehrerer technischer Maßnahmen oder durch den Einsatz modernster Kryptografie. In solchen Fällen kann das Cybersecurity-Team entscheiden, das Restrisiko zu akzeptieren, indem eine Cybersecurity-Aussage mit einer gut begründeten Argumentation dokumentiert wird. Wenn die Maßnahme die genutzte Schwachstelle im Angriffsweg de facto eliminiert, kann es auch gerechtfertigt sein, den Angriffsweg nicht weiter zu verfolgen. In diesem Fall gilt das Bedrohungsszenario als nicht mehr anwendbar. Dieser Fall muss als Cybersecurity-Aussage sorgfältig dokumentiert werden, wobei insbesondere der Einfluss der Maßnahme auf das Bedrohungsszenario hervorzuheben ist.

Tab. 9.2 Typische Cybersecurity-Maßnahmen für IT-/OT-Systeme, einschließlich einer beispielhaften Zuordnung zu den entsprechenden Cybersecurity-Eigenschaften

Cybersecurity-Maßnahme	Bezogen auf Cybersecurity-Eigenschaft ^a					
	C	I	Av	Au	NR	Acc
Zugangskontrolle	X			X	X	X
Sichere Speicherung sensibler Daten	X	X				
Verschlüsselung von Daten während der Übertragung (z. B. mit TLS)	X	X				
Überprüfung kryptografischer Algorithmen, Konfigurationen und Funktionen ^b	n/a	n/a	n/a	n/a	n/a	n/a
Serverseitige Eingabevalidierung	X	X	X			
Sicherer Pfadverwaltungsprozess	X	X	X			
Physikalische Erkennung von Manipulationen		X				
Hardware-Sicherheitsmodul (HSM)	X	X	X	X		
Firewall		X	X			
Intrusion Detection (und Prevention) System		X	X			
Notstromversorgung			X			
Durchsetzung von Befugnissen und geringste Rechte	X	X		X	X	X
Minimierung der WLAN-Ausbreitung	X	X	X	X		
Multifaktorielle Authentifizierung				X		
Datensicherung			X			
Einsatz von Kryptographie	X	X		X	X	X
Trennung von Netzwerken	X	X	X			
Logs ^b	n/a	n/a	n/a	n/a	n/a	n/a

^a C: Vertraulichkeit, I: Integrität, Av: Verfügbarkeit, Au: Authentizität, NR: Nichtabstreitbarkeit, Acc: Rechenschaftspflicht

^b Einige Cybersecurity-Maßnahmen können nicht direkt mit einer Cybersecurity-Eigenschaft in Verbindung gebracht werden

9.4 Risikoverteilung und Risikoakzeptanz

Risikoverteilung (Risk Sharing) bezeichnet die Aufteilung des Risikos mit anderen Stakeholdern durch Verträge (z. B. Lizenzvereinbarungen oder Geschäftsbedingungen) oder den Risikotransfer über Versicherungen. Eine Begründung (Cybersecurity-Aussage) für die Risikoverteilung muss bereitgestellt werden. In Situationen mit einem niedrigen Risiko-level ist es eine vertretbare Entscheidung, das Risiko zu akzeptieren. Das Risiko gilt als niedrig, wenn die Auswirkung oder die Eintrittswahrscheinlichkeit des Bedrohungsszenarios (Bewertung der Angriffsmachbarkeit) gering ist. Die Risikoakzeptanz bedeutet jedoch nicht, das Risiko vollständig zu ignorieren. Eine Begründung (Cybersecurity-Aussage) muss

bereitgestellt werden, um die Risikoakzeptanz zu rechtfertigen. Wird die TARA nach dem Bekanntwerden einer neuen Schwachstelle erneut durchgeführt, können zuvor akzeptierte Risiken jetzt einen höheren Risikowert erreichen und somit jetzt nicht mehr akzeptabel sein. Aus diesem Grund müssen akzeptierte Risiken in der TARA dokumentiert werden und dürfen nicht entfernt werden. Die Rechenschaftspflicht muss gegeben sein.

9.4.1 Cybersecurity-Aussagen

Im Kontext von ISO/SAE 21434 wird eine Cybersecurity-Aussage (Cybersecurity Claim) als eine Aussage über ein Risiko definiert [6]. Diese Cybersecurity-Aussagen dienen als Begründung für Entscheidungen zur Risikoteilung oder Risikoakzeptanz. Sie spielen eine zentrale Rolle im Cybersecurity-Monitoring, da sie bei der Entdeckung neuer Schwachstellen erneut bewertet werden müssen. Neue Schwachstellen können Risikowerte verändern und zuvor akzeptierte oder geteilte Risiken unter Umständen unzulässig machen. Beispielsweise könnte ein Bedrohungsszenario im operativen Bereich für den Verkehrsteilnehmer einen Risikowert von drei aufweisen (unter der Annahme, dass andere Kategorien niedrigere Werte haben). In diesem Fall könnte sich der OEM dafür entscheiden, das Risiko mit einer Versicherung zu teilen, die im Schadensfall eine Entschädigung an den Verkehrsteilnehmer leistet. Die zugehörige Cybersecurity-Aussage würde in diesem Fall erläutern, dass der Risikowert aufgrund der hohen Auswirkung (z. B. hohe Kosten für den Verkehrsteilnehmer) auf drei festgelegt wurde, die Wahrscheinlichkeit des Eintretens des Szenarios jedoch als gering eingeschätzt wird. Auf dieser Grundlage akzeptiert die Versicherung den Vertrag mit dem OEM. Wird jedoch eine neue Schwachstelle entdeckt, die den Risikowert auf vier oder fünf anhebt, ist der bestehende Vertrag mit der Versicherung nicht mehr gültig, da diese nur Schäden bis zu einem Risikowert von drei gedeckt hat. In einem solchen Fall ist eine neue Risikobehandlungsentscheidung erforderlich, die eine Neubewertung der Cybersecurity-Aussage sowie gegebenenfalls eine Neuverhandlung der Bedingungen mit der Versicherung notwendig macht.

9.5 Nach der TARA ist vor der TARA – Risikoneubewertung

Der letzte Schritt in einem klassischen TARA-Prozess besteht darin, nach Anwendung der Cybersecurity-Maßnahmen eine neue Risikobewertung der Bedrohungsszenarien durchzuführen. Das bedeutet jedoch nicht, dass der Prozess damit abgeschlossen ist. Tatsächlich kann die Schleife aus Risikobewertung und Risikobehandlung beliebig oft wiederholt werden, was den Begriff „letzter Schritt einer TARA“ etwas irreführend macht. Eine TARA ist als lebendes Dokument konzipiert, das sich über den gesamten Produktlebenszyklus hinweg weiterentwickelt. Das bedeutet, dass die Risikobewertung kein einmaliges Ereignis ist, sondern ein kontinuierlicher Prozess, der bei der Entdeckung neuer Schwachstellen

oder bei wesentlichen Änderungen am System oder dessen Umgebung erneut durchgeführt werden muss. Geht man davon aus, dass es sich um die erste TARA für ein bestimmtes Projekt handelt, so besteht die Risikoneubewertung darin, die Risikobewertung unter Berücksichtigung der neuen Bewertung der Angriffsmachbarkeit für jene Bedrohungsszenarien durchzuführen, auf welche Cybersecurity-Maßnahmen angewendet wurden. Diese Neubewertung ist entscheidend, um sicherzustellen, dass die implementierten Maßnahmen wirksam sind und das Risiko auf ein akzeptables Niveau gesenkt wurde. Obwohl es im Kontext der ISO/SAE 21434 keinen spezifischen Begriff für die Risikoneubewertung gibt, wird das neu bewertete Risiko in anderen Rahmenwerken oder Standards in der Regel als *Restrisiko* oder *vermindertes oder mitigiertes Risiko* bezeichnet. Diese Begriffe beziehen sich auf das Risiko, das nach Anwendung der Maßnahmen zur Risikobehandlung weiterhin besteht.

9.5.1 Statistik

Ähnlich der statistischen Auswertung der Assets, Bedrohungsszenarien und Schadensszenarien in Abschn. 8.2 können auch für die Cybersecurity-Maßnahmen statistische Analysen durchgeführt werden. Ein Beispiel für eine Statistik zu Cybersecurity-Maßnahmen wird in Abb. 9.2 dargestellt.

Wir können beobachten, dass die Häufigkeit, mit der einer Cybersecurity-Maßnahme Bedrohungsszenarien zugeordnet wurde, ein interessanter Indikator für die Effizienz oder Bedeutung dieser Maßnahme sein kann. Betrachtet man den kumulativen Wert in der letzten Spalte, zeigt sich, dass die ersten fünf Maßnahmen 80 % aller Zuordnungen – oder anders gesagt: 80 % aller Risiken – abdecken. Dabei ist jedoch zu betonen, dass der kumulative Wert und allgemein die Statistik zu Cybersecurity-Maßnahmen nicht falsch interpretiert werden dürfen. Jede Maßnahme wurde aus einem bestimmten Grund zugeordnet. Wenn wir uns die verbleibenden 20 % des kumulativen Werts ansehen, erkennen wir, dass auch darin viele Risiken mit hohem Risikowert durch die entsprechenden Cybersecurity-Maßnahmen abge-

Statistiken zu Cybersecurity-Maßnahmen									
Maßnahme	Anzahl der Vorkommen der Cybersecurity-Maßnahmen je Risikolevel								
	Gesamt	Vorkommen pro Risikolevel						Maßnahmenanteil in %	Kumulierte Maßnahmenanzahl
		5	4	3	2	1	Risikow. > 2		
Hardware-Sicherheitsmodul (HSM)	1787	965	563	120	119	20	1648	41,18%	41,18%
Secure Boot	678	410	210	34	24	0	654	15,63%	56,81%
Sichere Speicherung von Daten	367	16	81	250	20	0	347	8,46%	65,27%
Intrusion Detection (und Prevention) System	348	0	128	180	40	0	308	8,02%	73,29%
Sichere Aktualisierung	248	100	48	65	35	0	213	5,72%	79,00%
Secure Onboard Communication (SecOC)	230	68	86	13	63	0	167	5,30%	84,31%
Sichere Zugriffsdiagnose	203	43	88	40	22	10	171	4,68%	88,98%
Firewall	134	23	87	10	6	8	120	3,09%	92,07%
Schutz/Deaktivierung von Debug-Schnittstellen	124	32	45	40	7	0	117	2,86%	94,93%
Sicheres Flashen (sichere Programmierung)	123	26	40	22	35	0	88	2,83%	97,76%
Trennung von Netzwerken	63	20	23	20	0	0	63	1,45%	99,22%
Verschlüssel. von Daten bei der Übertragung	34	8	12	10	4	0	30	0,78%	100,00%

Abb. 9.2 Beispielhafte Statistik zu Cybersecurity-Maßnahmen

deckt werden. Gleichwohl kann diese Statistik sinnvoll genutzt werden. Betrachtet man zum Beispiel die letzte Maßnahme in Abb. 9.2, *Verschlüsselung von Daten während der Übertragung*, könnte das Management feststellen, dass mit dieser Maßnahme nur eine geringere Anzahl an Risiken (34) verknüpft ist. In einem solchen Fall kann eine fundierte Diskussion darüber entstehen, ob die Datenverschlüsselung in der Übertragung für das konkrete Projekt zu kostenintensiv ist. Das Management kann gemeinsam mit dem Cybersecurity-Team analysieren, ob sich die Risiken auch auf andere Weise mindern lassen – etwa durch den Einsatz anderer Cybersecurity-Maßnahmen, die ebenfalls zum Bedrohungsszenario passen, oder durch Änderungen am Design des Items.

9.6 Praktische Fallstudien

Wir setzen unsere drei praxisbezogenen Fallstudien fort und führen die Risikobehandlungsentscheidung durch. Dabei zeigen wir Beispiele für die Behandlungsentscheidung sowie die Neubewertung im Zusammenhang mit der Umsetzung bestimmter Cybersecurity-Maßnahmen. Im Beispiel der Statistik zu Assets in Abb. 8.6 haben wir bereits einen ersten Einblick in die Maßnahmen gegeben. Dort wurde gezeigt, dass es sehr hilfreich sein kann, darzustellen, wie sich der Risikowert eines Assets nach Anwendung von Cybersecurity-Maßnahmen verringert.

9.6.1 Fallstudie 1: Eingebettetes Fahrzeugsteuergerät

Für unsere erste Fallstudie haben wir zwei Bedrohungsszenarien beschrieben, nämlich 12.3 *Die Software wird vor dem Aktualisierungsprozess manipuliert (und daher beschädigt), obwohl dieser intakt ist und Umgehung der Signaturprüfung der Software durch einen Seitenkanalangriff*. Den Risikowert für das Beispiel-Asset *Anwendungssoftware* haben wir in Abschn. 8.3.1 berechnet. Das erste Bedrohungsszenario hat eine Angriffsmachbarkeitsbewertung von mittel. Da diesem Bedrohungsszenario Risikowerte größer als eins zugeordnet sind, können wir Maßnahmen anwenden, um die Angriffsmachbarkeit – und damit letztlich die Risikowerte – zu reduzieren. Das zweite Bedrohungsszenario *Umgehung der Signaturprüfung der Software durch einen Seitenkanalangriff* weist hingegen bereits eine sehr niedrige Angriffsmachbarkeit auf. Dies ist der niedrigste erreichbare Wert, sodass hierfür keine weiteren Cybersecurity-Maßnahmen angewendet werden können. Wir betrachten die daraus resultierenden Risikowerte für dieses Bedrohungsszenario im Detail und treffen eine Risikobehandlungsentscheidung. In Tab. 9.4 zeigen wir die Risikobewertung für den Stakeholder Verkehrsteilnehmer, die wir bereits in Abschn. 8.3.3 berechnet haben. Wir ergänzen die Tabelle um die jeweilige Risikobehandlungsentscheidung für jedes Schadensszenario. Unsere Unternehmensrichtlinie verlangt eine Risikominderung für Risikowerte größer als zwei. Ein Risikowert von zwei kann unter bestimmten Bedingungen akzeptiert

werden (z. B. wenn keine Auswirkungen auf die funktionale Sicherheit bestehen). Da für einige Schadensszenarien Risikowerte größer als zwei vorliegen, haben wir entschieden, Maßnahmen auf das Bedrohungsszenario anzuwenden. Angenommen, wir wenden einige der in Tab. 9.1 und 9.2 aufgeführten Maßnahmen an. Die Cybersecurity-Maßnahmen führen zu einer neuen Bewertung der Angriffsmachbarkeit für den Angriffsweg. Die neue Bewertung der Angriffsmachbarkeit ist in Tab. 9.3 dargestellt. Die hervorgehobenen Werte zeigen die Bewertungskategorien, die sich durch die Umsetzung der Maßnahmen verändert haben (vgl. Tab. 7.9). Die neue Risikobewertung erfolgt durch Kombination der Auswirkungsbewertung aus Tab. 6.12 mit der neuen Bewertung der Angriffsmachbarkeit. Die Ergebnisse sind in Tab. 9.4 dargestellt. Aus Platzgründen wurde auf die Darstellung der Einzelberechnungen der Risikowerte pro Auswirkungskategorie in Tab. 9.4 verzichtet. Die *neuen Risikowerte* nach Anwendung der Cybersecurity-Maßnahmen entsprechen dem Maximalwert aus allen betrachteten Bewertungskategorien (z. B. Safety, Finanzen, Betrieb, Privatsphäre).

Wir geben anschließend Beispiele für Cybersecurity-Ziele und Cybersecurity-Aussagen nach Umsetzung der Risikobehandlungsentscheidung in beiden Bedrohungsszenarien.

- *Cybersecurity-Ziel:* Software-Updates müssen vor unbefugter Manipulation geschützt werden, bevor sie das Fahrzeug erreichen.
- *Cybersecurity-Ziel:* Die Debugging-Schnittstellen müssen gegen unbefugten Zugriff geschützt sein.
- *Cybersecurity-Ziel:* Das Steuergerät muss Gegenmaßnahmen gegen Power-Glitching-Angriffe implementieren.
- *Cybersecurity-Ziel:* Das Steuergerät muss die Authentizität der Software während des Bootvorgangs verifizieren.
- *Cybersecurity-Aussage:* Der Risikowert zwei für das Schadensszenario *Fahrzeug oder Komponente (z. B. ECU) wird beschädigt* (Tab. 9.4) wird akzeptiert, da der Grund für den Risikowert zwei auf die Auswirkungskategorie Betrieb zurückzuführen ist. Die Auswirkungskategorie Safety hat einen resultierenden Risikowert von eins.
- *Cybersecurity-Aussage:* Der Risikowert zwei für das Schadensszenario *Nichtverfügbarkeit von nicht sicherheitsrelevanten Informationen* (Tab. 9.4) wird akzeptiert, da kein Sicherheitsrisiko besteht.
- *Cybersecurity-Aussage:* Der Risikowert zwei für das Schadensszenario *Fahrzeug oder Komponente (z. B. Steuergerät) wird beschädigt* (Tab. 8.7) wird akzeptiert, da der Grund für den Risikowert zwei auf die Auswirkungskategorie Betrieb zurückzuführen ist. Die Auswirkungskategorie Safety hat einen resultierenden Risikowert von eins.
- *Cybersecurity-Aussage:* Der Risikowert zwei in Bezug auf das Schadensszenario *Nichtverfügbarkeit nicht sicherheitsrelevanter Informationen* (Tab. 8.7) wird akzeptiert, da kein Sicherheitsrisiko impliziert ist.

Tab. 9.3 Neue Bewertung der Angriffsmachbarkeit für Bedrohungsszenario 12.3 Die Software wird vor dem Aktualisierungsprozess manipuliert (und daher beschädigt), obwohl dieser intakt ist nach Anwendung von Cybersecurity-Maßnahmen

Schritte für den Angriffspfad	Abgelaufene Zeit	Fachwissen	Wissen über das Item oder die Komponente	Zugriffsgelegenheiten	Ausrüstung	Bewertung der Angriffsmachbarkeit
Der Angreifer kompromittiert den Backend-Server des OEM / Zulieferer (z. B. Insider-Angreifer)	≤ 6 Monate	Proficient	Vertraulich	Unbegrenzt	Standard	Sehr niedrig
Ein manipuliertes Software-Update wird auf den Backend-Server hochgeladen. Die Software verfügt über keine kryptografische Signatur.	≤ 6 Monate	Experte	Vertraulich	Einfach	Maßgeschneidert	Sehr niedrig
Das manipulierte Softwareupdate wird durch den regulären Update-Prozess auf dem Fahrzeug installiert (keine Überprüfung der kryptografischen Signatur)	≤ 1 Tag	Laie	Öffentlich	Unbegrenzt	Standard	Hoch
Gesamtbewertung für den Angriffspfad	≤ 6 Monate	Experte	Vertraulich	Einfach	Maßgeschneidert	Sehr niedrig

Tab.9.4 Neubewertung des Risikos der Auswirkung auf den Verkehrsteilnehmer zu Fallstudie 1

Asset: Anwendungssoftware

Bedrohungsszenario: 12.3 Die Software wird vor dem Aktualisierungsprozess manipuliert (und daher beschädigt), obwohl dieser intakt ist

Bewertung der Angriffsmachbarkeit (nach Anwendung von Cybersecurity-Maßnahmen): Mittel

Schadensszenario [WP-15-01]	Maximaler Risikowert [WP-15-07]	Entscheidung zur Risikobehandlung [WP-15-08]	Neuer maximaler Risikowert [WP-15-07]
Fahrzeug oder Komponente (z. B. ECU) wird beschädigt	4	Reduktion	2
Sensoren/Warnsysteme liefern falsche Informationen	3	Reduktion	1
Nichtverfügbarkeit von nicht sicherheitsrelevanten Informationen (z. B. Verkehrsinformationen, Musik, Adressbuch)	4	Reduktion	2
Veröffentlichung der Schwachstelle	1	Akzeptanz	1

9.6.2 Fallstudie 2: Fahrzeug-Backend-Architektur

Für unsere Fallstudie zur Connected-Car-Architektur haben wir denselben Prozess der Risikobehandlungsentscheidung und Risikoneubewertung durchgeführt wie bei unserer ersten Fallstudie. Da unser Ziel darin besteht, den TARA-Prozess zu erläutern, überspringen wir einige Zwischenschritte und stellen die Ergebnisse direkt dar. Wir zeigen die Analyse der Risikowerte für den Stakeholder *OEM*. Die ursprüngliche Risikobewertung ist in Tab. 8.10 dargestellt.

Die Ergebnisse der Risikobehandlungsentscheidung sind in Tab.9.5 enthalten. Unter der Annahme, dass Cybersecurity-Maßnahmen auf das Item angewendet wurden und der Bewertungsprozess der Angriffsmachbarkeit für das betroffene Bedrohungsszenario wiederholt wurde, zeigen wir in Tab.9.5 die neue Berechnung des maximalen Risikowerts. In diesem Beispiel gibt es keine Cybersecurity-Aussagen, da alle Risiken auf das Mindestniveau reduziert wurden. Die abgeleiteten Cybersecurity-Ziele lauten wie folgt:

- *Cybersecurity-Ziel:* Daten im Transit müssen (durch Verschlüsselung) vor unbefugtem Zugriff geschützt werden.
- *Cybersecurity-Ziel:* Geschäftsrelevante Daten müssen identifiziert und Zugangskontrollmechanismen müssen angewendet werden.

Tab. 9.5 Neubewertung des Risiko der Auswirkung auf den OEM zu Fallstudie 2

Asset: Sensible Daten bei der Übertragung

Bedrohungsszenario: 6.2 Man-in-the-Middle-Angriff/Session Hijacking

Bewertung der Angriffsmachbarkeit (nach Anwendung von Cybersecurity-Maßnahmen): Sehr niedrig

Schadensszenario [WP-15-01]	Maximaler Risikowert [WP-15-07]	Entscheidung zur Risikobehandlung [WP-15-08]	Neuer maximaler Risikowert [WP-15-07]
Offenlegung von geschäftsrelevanten Daten	3	Reduktion	1
Nutzung von Dienstleistungen ohne gültige Lizenzen	2	Reduktion	1

9.6.3 Fallstudie 3: Automobilproduktionsanlage

Die Risikowerte für unsere dritte Fallstudie wurden bereits in Tab. 8.12 für den Verkehrsteilnehmer und in Tab. 8.13 für den Zulieferer dargestellt. Wir folgen demselben Vorgehen wie in den Fallstudien eins und zwei: Wir treffen die Risikobehandlungsentscheidung für alle Risikowerte und wenden Cybersecurity-Maßnahmen auf jene Risiken an, die mitigiert werden müssen. Die Ergebnisse dieser Schritte sind in Tab. 9.6 für den Verkehrsteilnehmer und in Tab. 9.7 für den Zulieferer dargestellt.

Wie in Tab. 9.6 und 9.7 zu erkennen ist, lassen sich nicht alle Risiken auf ein Minimum reduzieren. Daher muss das Cybersecurity-Team jedes verbleibende Risiko einzeln analysieren und eine neue Risikobehandlungsentscheidung treffen. In den vorherigen Fallstudien haben wir verbleibende Risiken mit dem Risikowert zwei einfach akzeptiert. Dabei wurde eine Cybersecurity-Aussage erstellt und begründet, dass bei diesem Risikoniveau keine Auswirkungen auf die funktionale Sicherheit bestehen, weshalb sich die Organisation zur Akzeptanz des Restrisikos entschieden hat. In dieser Fallstudie besteht jedoch die Herausforderung darin, dass der Risikowert zwei im Zusammenhang mit dem Schadensszenario *Manipulierte Software, die in das Endprodukt (Steuergerät) eingeschleust wurde* auftritt – und zwar aufgrund der Kategorie „Safety“ für den Verkehrsteilnehmer.

In diesem speziellen Fall muss das Cybersecurity-Team entweder versuchen, das Risiko zu vermeiden, indem es die Ursache des Risikos eliminiert (z. B. keine Software-Updates für die Produktionsanlagen bereitstellt), oder gemeinsam mit dem Engineering- und Safety-Team weiter analysieren, ob das Bedrohungsszenario korrekt bewertet wurde. Es könnte sich herausstellen, dass aufgrund anderer technischer Cybersecurity-Maßnahmen, des Systemdesigns oder vorhandener Safety-Sicherheitsfunktionen das Schadensszenario *Manipulierte*

Tab. 9.6 Neubewertung des Risikos der Auswirkung auf den OEM zu Fallstudie 3

Asset: Software-Updates

Bedrohungsszenario: System Firmware (T0857)

Bewertung der Angriffsmachbarkeit (nach Anwendung von Cybersecurity-Maßnahmen): Sehr niedrig

Schadensszenario [WP-15-01]	Maximaler Risikowert [WP-15-07]	Entscheidung zur Risikobehandlung [WP-15-08]	Neuer maximaler Risikowert [WP-15-07]
Manipulierte Software, die in das Endprodukt (Steuergerät) eingeschleust wurde	4	Reduktion	2
Produktionsmaschinen und/oder lokale Server wurden mit Ransomware infiziert	1	Akzeptanz	1
Produktionsstopp länger als einen Tag	1	Akzeptanz	1
Manipulierte Produktionsdaten oder Stücklisten führen zu fehlerhaften Endprodukten	4	Reduktion	1

Software, die in das Endprodukt (Steuergerät) eingeschleust wurde in der Praxis gar nicht möglich ist.

- *Cybersecurity-Ziel:* Es soll nicht möglich sein, manipulierte Software in die Produktionsmaschinen einzubringen.
- *Cybersecurity-Ziel:* Firmware, einschließlich Updates, muss in einer vertrauenswürdigen Umgebung entwickelt werden, und es darf nicht möglich sein, die Firmware während ihrer Entwicklung zu manipulieren.
- *Cybersecurity-Aussage:* Hinsichtlich des Risikos in Bezug auf die Schadensszenarien *Produktionsmaschinen und/oder lokale Server wurden mit Ransomware infiziert sind, Produktionsstopp länger als einen Tag* und *Manipulierte Produktionsdaten oder Stücklisten führen zu fehlerhaften Endprodukten* für die Risikoanalyse des Lieferanten beschließt der Lieferant, die Risikostufe zwei zu akzeptieren, da die Kategorien Image und Finanzen von der Risikostufe zwei betroffen sind, und es sich um eine Stufe handelt, die das Unternehmen handhaben kann.

Tab. 9.7 Neubewertung des Risikos der Auswirkung auf den Zulieferer zu Fallstudie 3

Asset: Software-Updates

Bedrohungsszenario: System Firmware (T0857)

Bewertung der Angriffsmachbarkeit (nach Anwendung von Cybersecurity-Maßnahmen): Sehr niedrig

Schadensszenario [WP-15-01]	Maximaler Risikowert [WP-15-07]	Entscheidung zur Risikobehandlung [WP-15-08]	Neuer maximaler Risikowert [WP-15-07]
Manipulierte Software, die in das Endprodukt (Steuergerät) eingeschleust wurde	3	Reduktion	1
Produktionsmaschinen und/oder lokale Server wurden mit Ransomware infiziert	4	Reduktion	2
Produktionsstopp länger als einen Tag	4	Reduktion	2
Manipulierte Produktionsdaten oder Stücklisten führen zu fehlerhaften Endprodukten	4	Reduktion	2

Literatur

1. OWASP Top Ten – OWASP Foundation. <https://owasp.org/www-project-top-ten/>

2. IEC 62443-4-2:2019 Security for industrial automation and control systems- Part 4-2: Technical security requirements for IACS components. Standard, International Electrotechnical Commission (2019). <https://webstore.iec.ch/publication/34421>

3. ISO/IEC 27002:2022 Information security, cybersecurity and privacy protection- Information security controls. Standard, International Organization for Standardization/International Electrotechnical Commission (2022). <https://www.iso.org/standard/75652.html>

4. European Union Agency for Cybersecurity (ENISA): ENISA good practices for security of Smart Cars (2019). <https://www.enisa.europa.eu/publications/smart-cars>

5. European Union Agency for Cybersecurity (ENISA): ENISA Threat Landscape 2022 (2022). <https://www.enisa.europa.eu/publications/enisa-threat-landscape-2022>

6. ISO/SAE 21434:2021 Road vehicles – Cybersecurity engineering. Standard, International Organization for Standardization/Society of Automotive Engineers, Geneva, CH (2021). <https://www.iso.org/standard/70918.html>

7. NIST: NIST Special Publication 800-53 Security and Privacy Controls for Information Systems and Organizations (2020). <https://csrc.nist.gov/publications/detail/sp/800-53/rev-5/final>

8. The MITRE Corporation: MITRE ATT&CK®. <https://attack.mitre.org/>

9. United Nations: UN Regulation No. 155 – Cyber security and cyber security management system, Dokumentnummer: E/ECE/TRANS/505/Rev.3/Add.154 (2021). <https://unece.org/transport/documents/2021/03/standards/un-regulation-no-155-cyber-security-and-cyber-security>
10. Wurm, M.: Automotive Cybersecurity: Security-Bausteine für Automotive Embedded Systeme. Springer Berlin Heidelberg, Berlin, Heidelberg (2022). <https://doi.org/10.1007/978-3-662-64228-3>.

A.1 Asset-Katalog

In diesem Abschnitt stellen wir eine Liste von Assets vor, die als allgemeine Referenz und für Beispielpzwecke verwendet werden können. Aus diesem Grund gibt es Assets, die in anderen Assets enthalten sein können, wie z. B. CAN als generisches Asset, während die einzelnen Protokolle, die über CAN laufen, separate Assets sind. Wie die Assets gruppiert werden, d. h. die Abstraktionsebene oder die funktionale Gruppierung, muss von dem Sicherheitsteam entschieden werden, das die TARA durchführt. Das Format der Tabelle ist für reale TARA-Projekte nützlich. Wir haben die Gruppen in Assets für eingebettete Kfz-Geräte und Assets für IT-/OT-Systeme unterteilt. Die Spalte *Asset [WP-15-02]* beschreibt den Namen des Assets. Die Kennzeichnung *[WP-15-02]* ist ein schriftlicher Verweis auf das entsprechende ISO/SAE 21434 Arbeitsprodukt. Dies erleichtert den Nachweis der Konformität mit dem Standard, z. B. bei einem Audit. In der letzten Spalte wird beschrieben, warum die ausgewählten Cybersecurity-Eigenschaften für das Asset relevant sind. Diese Beschreibung ist zu Dokumentationszwecken nützlich. In realen TARA-Projekten empfehlen wir eine Spalte mit der Bezeichnung *Anmerkungen/Beschreibung* hinzuzufügen, um jede Art von Information festzuhalten, die für die Assets innerhalb eines bestimmten Projekts wichtig ist. Wir haben diese Spalte aus Platzgründen und weil sie bei Projekten nicht immer wichtig ist, weggelassen.

Wichtiger Hinweis zu den Cybersecurity-Eigenschaften: Die in diesem Abschnitt gezeigte Bewertung ist nur beispielhaft, und die Cybersecurity-Eigenschaften sind generisch ausgewählt. Obwohl die Auswahl für viele reale Projekte geeignet sein kann, muss das Cybersecurity-Team, das die TARA durchführt, diese Fall für Fall neu bewerten.

A.1.1 Eingebettete Geräte für die Automobilindustrie

(Siehe Tab. [A.1](#), [A.2](#), [A.3](#), [A.4](#), [A.5](#), [A.6](#), [A.7](#) und [A.8](#)).

Tab. A.1 Katalog der Assets mit Cybersecurity-Eigenschaften

Asset [WP-15-02]	Relevante Cybersecurity-Eigenschaft für das Asset und Begründung der Relevanz
A. Kommunikationsschnittstellen und -protokolle	
CAN (Generischer CAN-Bus, Nachrichten können für verschiedene Zwecke verwendet werden)	Integrität: Während CAN für viele Zwecke verwendet werden kann, können wir in diesem Beispiel diese Eigenschaft bestimmten sicherheitskritischen Nachrichten zuordnen Verfügbarkeit: Für den ordnungsgemäßen Betrieb des Fahrzeugs muss die Verfügbarkeit des CAN-Busses gewährleistet sein
UDS	Integrität: Es muss sichergestellt sein, dass die Diagnosenachrichten nicht manipuliert werden Verfügbarkeit: Die UDS-Dienste müssen verfügbar sein Authentizität: Speziell für Dienste, die Software- und Speicherbereiche modifizieren, ist es wichtig, die Authentizität zu gewährleisten
XCP	Integrität: Es muss sichergestellt werden, dass die Diagnosemeldungen nicht manipuliert werden Authentizität: Ähnlich wie bei UDS ist die Authentizität beim Schreiben von Speicherbereichen relevant
FlexRay	Integrität: Ähnlich wie bei anderen Kommunikationsprotokollen muss die Integrität zumindest einiger Nachrichten gewährleistet sein Verfügbarkeit: Je nach Verwendung des Kommunikationsprotokolls muss die Verfügbarkeit gewährleistet sein
LIN	Integrität: Ähnlich wie bei anderen Kommunikationsprotokollen muss die Integrität zumindest einiger Nachrichten gewährleistet sein Verfügbarkeit: Je nach Verwendung des Kommunikationsprotokolls muss die Verfügbarkeit gewährleistet sein
MOST	Integrität: Ähnlich wie bei anderen Kommunikationsprotokollen muss die Integrität zumindest einiger Nachrichten gewährleistet sein Verfügbarkeit: Je nach Verwendung des Kommunikationsprotokolls muss die Verfügbarkeit gewährleistet sein
OBD-II	Integrität: Zumindest für Dienste, die für Software-Aktualisierungen über OBD verwendet werden, sind Integrität und Authentizität relevant Authentizität: Zumindest für Dienste, die für Software-Aktualisierungen über OBD verwendet werden, wenn Integrität und Authentizität von Bedeutung sind

Tab. A.2 (Fortsetzung) Katalog der Assets mit Cybersecurity-Eigenschaften

Asset [WP-15-02]	Relevante Cybersecurity-Eigenschaft für das Asset und Begründung der Relevanz
A. Kommunikationsschnittstellen und -protokolle	
Ethernet	Vertraulichkeit/Integrität/Verfügbarkeit/Authentizität: Der besondere Schutz hängt von dem Dienst und dem Protokoll ab, die über Ethernet laufen. Aus diesem Grund wird der Schutz der Vertraulichkeit, Integrität, Verfügbarkeit und Authentizität in diesem Fall als Beispiel belassen. Natürlich können auch Schutzmechanismen auf niedrigeren Ebenen angewendet werden, wie MACsec oder IPsec
DoIP	Integrität: Es muss sichergestellt werden, dass zumindest bestimmte Diagnosemeldungen nicht manipuliert werden Verfügbarkeit: Ähnlich wie bei UDS müssen die DoIP-Dienste verfügbar sein Authentizität: Speziell für Dienste, die Software und Speicherbereiche verändern, ist es wichtig, die Authentizität zu gewährleisten
SOME/IP	Integrität: Ist stark abhängig von der Verwendung, aber die Integrität könnte für viele Dienste kritisch sein Verfügbarkeit: Aufgrund der operativen Relevanz muss die Verfügbarkeit sichergestellt werden Authentizität: Je nach Dienst muss möglicherweise die Authentizität sichergestellt werden
JTAG	Integrität: Es muss sichergestellt werden, dass zumindest bestimmte Diagnosemeldungen nicht manipuliert werden Authentizität: Es muss sichergestellt werden, dass die Authentizität nicht verletzt wird, weil es eine leistungsfähige Diagnose-/Debugging-Schnittstelle ist
WLAN	Vertraulichkeit: Aufgrund seiner RF-Natur ist Sniffing bei WLAN einfach und eine Kompromittierung weiterer Eigenschaften möglich Integrität: Ähnlich wie bei anderen Kommunikationsprotokollen hängt es vom Dienst ab, aber die Integrität ist höchstwahrscheinlich erforderlich Verfügbarkeit: Die Verfügbarkeit ist wahrscheinlich nicht wesentlich für den Betrieb des Fahrzeugs, könnte aber für den Fahrer oder Beifahrer von Bedeutung sein
Bluetooth	Vertraulichkeit: Da es sich um RF handelt, kann die Gewährleistung der Vertraulichkeit die Offenlegung von Daten und weitere Bedrohungen verhindern Integrität: Nachrichten dürfen nicht manipuliert werden Verfügbarkeit: Die Verfügbarkeit von Bluetooth darf nicht verletzt werden, da Bluetooth für den Betrieb z. B. eines Infotainmentsystems relevant ist
USB	Integrität: Nachrichten dürfen nicht manipuliert werden Verfügbarkeit: Je nach Anwendungsfall kann eine zuverlässige Verfügbarkeit erwartet werden
eSIM	Vertraulichkeit: Aufgrund der RF-Natur ist die Vertraulichkeit der Nachrichten von größter Bedeutung Integrität: Die Integrität ist relevant, um QoS zu gewährleisten Verfügbarkeit: Die Verfügbarkeit ist relevant, aufgrund der Konnektivitätsquelle für Infotainment Authentizität: Die Authentizität von Internetanbietern und -diensten muss sichergestellt werden

Tab. A.3 (Fortsetzung) Katalog der Assets mit Cybersecurity-Eigenschaften

Asset [WP-15-02]	Relevante Cybersecurity-Eigenschaft für das Asset und Begründung der Relevanz
A. Kommunikationsschnittstellen und -protokolle	
Digitale/Analoge E/A	Integrität: Wird meist für Sensoren und Aktoren verwendet, Integrität wird erwartet (auch wenn die Steuerungen der funktionalen Sicherheit diese erreichen) Verfügbarkeit: Ist relevant aufgrund ihrer operationalen Natur
GPIO, I2C, SPI	Integrität: Nachrichten dürfen nicht manipuliert werden Verfügbarkeit: In betrieblichen Fällen (z. B. Zusammenschaltung von Boards innerhalb eines Steuergeräts) ist die Verfügbarkeit wichtig
Proprietäre Debug-Schnittstelle	Integrität: Wird für leistungsfähiges Debugging verwendet, Nachrichten dürfen nicht manipuliert werden Authentizität: Die Authentizität von proprietären Tools und laufenden Protokollen muss gewährleistet sein
B. Sicherheitsrelevante Daten	
Öffentliche Schlüssel und Zertifikate	Integrität: Ist wesentlich für die Verwendung Verfügbarkeit: Verschiedene Dienste können auf öffentliche Schlüssel (Public Keys) und Zertifikate angewiesen sein, und diese müssen verfügbar sein Authentizität: Laut Definition muss die Authentizität gewährleistet sein (z. B. durch den Einsatz einer PKI)
Private Schlüssel und Passwörter	Vertraulichkeit: Sicherheitsgeheimnisse müssen laut Definition vertraulich sein Integrität: Die Integrität von Sicherheitsgeheimnissen ist für den Betrieb unerlässlich Verfügbarkeit: Die Verfügbarkeit ist erforderlich, da sich viele Dienste auf Sicherheitsgeheimnisse stützen können Authentizität: Per Definition muss die Authentizität gewährleistet sein (zumindest durch das anfängliche Schreiben von Sicherheitsgeheimnissen)
Account Credentials	Vertraulichkeit: Credentials für verschiedene Dienste müssen geheim gehalten werden Integrität: Die Integrität ist für den Betrieb unerlässlich Verfügbarkeit: Ähnlich wie Schlüssel werden Credentials zum Betrieb der Dienste benötigt Authentizität: Die Authentizität muss sichergestellt werden (z. B. durch den Einsatz einer PKI)
Eindeutige IDs	Vertraulichkeit: Je nach Verwendung müssen einige eindeutige IDs geheim gehalten werden (z. B. Sitzungs-IDs) Integrität: Die Integrität ist für die Nutzung des Assets unerlässlich Verfügbarkeit: Als Sicherheitsartefakt muss die Verfügbarkeit von Diensten sichergestellt werden
Sichere Zeitübertragung im Fahrzeugnetzwerk	Integrität: Die Integrität von sicheren Daten muss gewährleistet sein, d. h. Manipulationen müssen nachweisbar sein Verfügbarkeit: Da viele Dienste im Fahrzeug von der realen, sicheren Zeit abhängen können, muss die Verfügbarkeit gewährleistet sein Authentizität: Zumindest die an der sicheren Zeit teilnehmende Steuergeräte müssen sich gegenseitig authentifizieren und vertrauen

Tab. A.4 (Fortsetzung) Katalog der Assets mit Cybersecurity-Eigenschaften

Asset [WP-15-02]	Relevante Cybersecurity-Eigenschaft für das Asset und Begründung der Relevanz
B. Sicherheitsrelevante Daten	
Zufallszahlen	Integrität: Zufallszahlen, die in der Regel zur Erzeugung von Hashes und kryptografischen Operationen verwendet werden, müssen in einer geschützten Umgebung verwendet werden, um Kryptoanalyse oder Angriffe auf Algorithmen zu verhindern [55] Verfügbarkeit: Für kryptografische Dienste ist Verfügbarkeit per se erforderlich
MAC und Signaturen	Integrität: Die Integrität von MAC und digitalen Signaturen muss unbedingt gewährleistet sein Verfügbarkeit: Da sie für Dienste verwendet werden, wie z. B. die unterschiedliche Authentizität von Softwarecode, ist die Verfügbarkeit wichtig Authentizität: Die Authentizität muss gewährleistet sein, zumindest durch anfängliches Schreiben in geschützten Bereichen
Backend-Konfiguration	Vertraulichkeit: Jede wichtige Konfiguration, die für die Kommunikation mit Backend-Systemen benötigt wird, muss möglicherweise vertraulich behandelt werden (z. B. um die Offenlegung von IP-Adressen, Benutzernamen usw. zu verhindern) Integrität: Die Integrität ist für den Betrieb unerlässlich Verfügbarkeit: Die Verfügbarkeit ist für den Betrieb unerlässlich
C. Personenbezogene und personenbeziehbare Daten	
Persönliche Informationen von Fahrern/Passagieren	Vertraulichkeit: Personenbezogene und personenbeziehbare Daten müssen vertraulich behandelt werden Integrität: Die Datenintegrität muss gut geschützt werden, um Manipulationen erkennen zu können Verfügbarkeit: Die Relevanz der Verfügbarkeit kann von der jeweiligen Anwendung oder dem Dienst abhängen, der auf die Daten angewiesen ist Nichtabstreitbarkeit: Anwendungen, die personenbezogene und personenbeziehbare Daten speichern, könnten Mechanismen zur Nichtabstreitbarkeit implementieren (z. B. indem die Person einen Vertrag physisch unterschreiben muss) Rechenschaftspflicht: Dienste, die solche Daten verarbeiten, können mit der Verantwortung für die Verarbeitung in Verbindung gebracht werden
Zahlungsinformationen	Vertraulichkeit: Sensible Daten, wie z. B. Kreditkarteninformationen, müssen vertraulich behandelt werden Integrität: Die Datenintegrität ist wichtig, um Manipulationen aufzudecken Verfügbarkeit: Die Relevanz der Verfügbarkeit hängt von der jeweiligen Anwendung oder dem Dienst ab, der auf die Daten angewiesen ist Authentizität: Es muss sichergestellt werden, dass diese Daten aus einer vertrauenswürdigen Quelle stammen

Tab. A.5 (Fortsetzung) Katalog der Assets mit Cybersecurity-Eigenschaften

Asset [WP-15-02]	Relevante Cybersecurity-Eigenschaft für das Asset und Begründung der Relevanz
C. Personenbezogene und personenbeziehbare Daten	
Geolokalisierungsdaten	Vertraulichkeit: Generell darf es nicht möglich sein, die Geolokalisierung mit einer Person in Verbindung zu bringen; daher muss die Behandlung von Geolokalisierungsdaten möglicherweise vertraulich erfolgen Integrität: Für den korrekten Betrieb von Diensten relevant, die sich auf diese Daten stützen Verfügbarkeit: Die Relevanz kann von der jeweiligen Anwendung oder dem jeweiligen Dienst abhängen, die bzw. der auf die Daten angewiesen ist Authentizität: Die Quelle, die Geolokalisierungsdaten bereitstellt, muss als vertrauenswürdig validiert werden Nichtabstreitbarkeit: Die Nichtabstreitbarkeit kann bei Geolokalisierungsdaten, die von externen Geräten bereitgestellt werden, wichtig sein Rechenschaftspflicht: Dienste, die Geolokalisierungsdaten bereitstellen, können für falsche Informationen haftbar gemacht werden
Fahrzeugidentifikationsnummer (VIN)	Vertraulichkeit: Vertraulichkeit ist erforderlich, um ein unbefugtes Auslesen der VIN zu verhindern Integrität: Die VIN darf nicht manipuliert werden
Videodaten	Vertraulichkeit: Videosequenzen können personenbezogene und personenbeziehbare Daten oder andere sensible Informationen enthalten und müssen daher gegen den Verlust der Vertraulichkeit geschützt werden Integrität: Integrität ist je nach Verwendung wichtig Verfügbarkeit: Dienste, die auf Kameras angewiesen sind, benötigen volle Verfügbarkeit Authentizität: Es kann wichtig sein die Eigenschaft der Authentizität von Geräten, die Videos speichern bzw. der Videodaten zu betrachten Nichtabstreitbarkeit: Anwendungen, die personenbezogene und personenbeziehbare Daten speichern, könnten Schutzmaßnahmen zur Nichtabstreitbarkeit implementieren (z. B. indem die Person einen Vertrag physisch unterschreibt) Rechenschaftspflicht: Das System, das Daten verarbeitet, kann mit Verantwortlichkeiten im Umgang mit Daten verbunden werden
D. Andere Daten über angeschlossene Fahrzeuge	
DTC	Integrität: Diagnosecode dürfen nicht manipuliert werden Verfügbarkeit: DTC müssen für die Analyse von Fehlern am Fahrzeug verfügbar sein
Kalibrierungsdaten	Integrität: Die Kalibrierungskonfiguration von Steuergeräten wird typischerweise bei der Produktion geschrieben, um das Steuergerät an den Fahrzeugtyp anzupassen. Änderungen durch den Benutzer sind nicht vorgesehen, und diese muss gegen unbefugte Manipulationen geschützt werden Authentizität: Es kann vorkommen, dass die Kalibrierungsdaten in der Werkstatt absichtlich verändert werden, z. B. nach einem Austausch, und das Steuergerät muss das Werkstatt-Tool verifizieren, um unautorisierte Änderungen zu vermeiden

Tab. A.6 (Fortsetzung) Katalog der Assets mit Cybersecurity-Eigenschaften

Asset [WP-15-02]	Relevante Cybersecurity-Eigenschaft für das Asset und Begründung der Relevanz
D. Weitere Daten über vernetzte Fahrzeuge	
Logdaten	Integrität: Logdaten können im Allgemeinen nützliche technische Informationen für die Diagnose liefern. Daher ist es notwendig, ihre Integrität zu schützen Nichtabstreitbarkeit: In einigen Fällen kann es notwendig sein, zu garantieren, dass Logs von bestimmten Anwendungen geschrieben wurden, und es muss ein Mechanismus zur Nichtabstreitbarkeit vorhanden sein
Kilometerzähler	Integrität: Der Kilometerstand muss vor Manipulationen geschützt werden
Benutzerprofildaten	Integrität: Benutzerprofildaten können einige sensible Informationen für die Verbindung mit anderen Diensten enthalten. Daher muss die Integrität gewährleistet sein Authentizität: Es muss sichergestellt werden, dass die Daten vom Benutzer oder einer anderen autorisierten Einheit stammen
Lebenszyklusstatus	Integrität: Steuergeräte können einen Lebenszyklusstatus haben, um eine bessere Fehlersuche und Entwicklung zu ermöglichen. Einmal gesetzt, darf es nicht möglich sein, ihn ohne Genehmigung zu ändern
Daten im RAM	Vertraulichkeit: In Extremfällen, z. B. beim Betrieb mit geheimen Schlüsseln oder mit personenbezogenen und personenbeziehbaren Daten, muss sichergestellt werden, dass auf diese Daten im RAM nicht unbefugt zugegriffen werden kann
EDR/DSSAD	Vertraulichkeit: Ist von der Gesetzgebung abhängig, doch gehen wir von der strengsten Anforderung aus. Diese Daten müssen vor unbefugtem Zugriff geschützt werden Integrität: Diese Daten werden für die Analyse nach einem Unfall verwendet; daher muss die Integrität gewährleistet sein Verfügbarkeit: Da die Daten z. B. von Versicherungen benötigt werden, muss ihre Verfügbarkeit gewährleistet sein Authentizität: Ein Mechanismus zum Schutz der Authentizität kann zum Beispiel sicherstellen, dass diese Daten von einem vertrauenswürdigen EDR/DSSAD-Steuergerät aus dem Fahrzeug stammen Nichtabstreitbarkeit/Rechenschaftspflicht: Aufgrund ihrer rechtlichen Verwendung müssen Nichtabstreitbarkeit und Rechenschaftspflicht zum Schutz berücksichtigt werden

Tab. A.7 (Fortsetzung) Katalog der Assets mit Cybersecurity-Eigenschaften

Asset [WP-15-02]	Relevante Cybersecurity-Eigenschaft für das Asset und Begründung der Relevanz
E. Software Komponenten	
Bootloader	Integrität: Wesentliche Komponente des Bootvorgangs und der Vertrauenskette. Manipulationen müssen nachweisbar sein Verfügbarkeit: Essentiell für den Betrieb, und die Ausführung des Betriebssystems mit seinen Anwendungen Authentizität: Zumindest zum Zeitpunkt der Installation muss die Quelle der Software überprüft werden, um sicherzustellen, dass es sich um eine vertrauenswürdige Quelle handelt
OEM-Anwendungen	Integrität: Die Anwendung, die die Kernfunktionen des eingebetteten Geräts bereitstellt, darf nicht manipuliert werden Verfügbarkeit: Wesentlich für den Hauptbetrieb des eingebetteten Geräts Authentizität: Zumindest zum Zeitpunkt der Installation muss die Quelle der Software überprüft werden, um sicherzustellen, dass es sich um eine vertrauenswürdige Quelle handelt
Lieferantenanwendungen	Integrität: Lieferantenanwendungen können Kernfunktionen bereitstellen und dürfen nicht manipuliert werden Verfügbarkeit: Wesentlich für den Hauptbetrieb des eingebetteten Geräts Authentizität: Zumindest zum Zeitpunkt der Installation muss die Quelle der Software überprüft werden, um sicherzustellen, dass es sich um eine vertrauenswürdige Quelle handelt
Anwendungen von Drittanbietern	Integrität: Anwendungen von externen Anbietern dürfen nicht manipuliert werden. Diese Anwendungen bieten erweiterte Funktionen, und wenn sie kompromittiert werden, könnten sie Zugriff auf Kernfunktionen und wichtige Daten des eingebetteten Geräts erhalten Verfügbarkeit: Abhängig von der bereitgestellten Funktionalität sind Anwendungen von externen Anbietern möglicherweise nicht kritisch. Es wird jedoch erwartet, dass sie bei Bedarf einsatzbereit sind Authentizität: Zumindest zum Zeitpunkt der Installation muss die Quelle der Software überprüft werden, um sicherzustellen, dass es sich um eine vertrauenswürdige Quelle handelt
Software-Updates	Integrität: Software-Updates dürfen nicht manipuliert werden, um das Einschleusen von Malware in das eingebettete Gerät zu verhindern Verfügbarkeit: Software-Updates müssen hoch verfügbar sein, insbesondere wenn sie Sicherheits-Patches enthalten Authentizität: Zumindest zum Zeitpunkt der Installation muss die Quelle der Software überprüft werden, um sicherzustellen, dass es sich um eine vertrauenswürdige Quelle handelt
IP-relevante Daten	Vertraulichkeit: Sensible Teile der Software-Binärdateien, Dateien oder Konfigurationsdaten müssen vor unbefugtem Zugriff geschützt werden

Tab. A.8 (Fortsetzung) Katalog der Assets mit Cybersecurity-Eigenschaften

Asset [WP-15-02]	Relevante Cybersecurity-Eigenschaft für das Asset und Begründung der Relevanz
F. Hardware Komponenten	
Steuergeräte- gehäuse	Integrität: Das physische eingebettete Gerät, einschließlich seiner Platine, Schnittstellen und seines Gehäuses, darf nicht manipuliert werden. Dies gilt insbesondere für kritische Schnittstellen, die auf physische Weise deaktiviert werden (z. B. entfernte PINs, überbrückte Verbindungen) Verfügbarkeit: Physikalische Komponenten, die für den Betrieb kritisch sind, müssen hoch verfügbar sein
Sensoren	Integrität: Sensoren können Daten für Komfortfunktionen und für sicherheitsrelevante Funktionen liefern. Die Integrität der Sensoren muss gewährleistet sein Verfügbarkeit: Sensoren, die kritische Daten liefern, müssen hoch verfügbar sein
Aktoren	Integrität: Aktoren, die kritische Funktionalitäten bereitstellen, müssen gegen Manipulationen geschützt sein, oder Manipulationen müssen erkennbar sein Verfügbarkeit: Aktoren, die kritische Funktionalitäten bereitstellen, sind für den Betrieb unerlässlich
Speicher	Vertraulichkeit: Es kann erforderlich sein, Speicherkomponenten physisch auf der Platine zu verbergen, um den Zugriff auf sie zu erschweren Integrität: Die Integrität der Speicherblöcke ist für den Betrieb entscheidend Verfügbarkeit: Speicher ist eine wesentliche Komponente eines eingebetteten Geräts und muss verfügbar sein
Stromversorgung	Integrität: Die physische Integrität von Steckern und Kabeln ist für den Betrieb unerlässlich Verfügbarkeit: Die Verfügbarkeit ist für den Betrieb unerlässlich

A.1.2 IT-/OT-Systeme

In diesem Abschnitt stellen wir Assets vor, die üblicherweise in Produktionsanlagen vorhanden sind. Wir verallgemeinern die Assets, indem wir sie als *Assets für IT-/OT-Systeme* bezeichnen, da sie generisch auf jedes System angewendet werden können. In diesem Buch legen wir jedoch den Schwerpunkt auf die ISO/SAE 21434 für Automobilsysteme, und es ist von besonderem Interesse und von dem Standard gefordert, Fertigungsanlagen von Fahrzeugen und Komponenten (ECU) eines Fahrzeugs zu behandeln. Aus diesem Grund beziehen wir uns oft auf Fertigungsanlagen, wenn wir Beispiele für die Relevanz der Cybersecurity-Eigenschaften geben (Tab. [A.9](#), [A.10](#), [A.11](#) und [A.12](#)).

Tab. A.9 Katalog der Assets mit Cybersecurity-Eigenschaften

Asset [WP-15-02]	Relevante Cybersecurity-Eigenschaft für das Asset und Begründung der Relevanz
Debug/Diagnose-Schnittstellen	Integrität: Die Integrität des Datenaustauschs zwischen einem legitimen Client (lokal oder remote) und der Diagnoseschnittstelle muss gewährleistet sein, um Manipulationen zu verhindern oder zu erkennen Verfügbarkeit: Diagnosedienste müssen zuverlässig sein, um Ausfallzeiten im Störfall zu vermeiden Authentizität: Nur vertrauenswürdige Stellen dürfen Zugang zu den Diagnosediensten der Produktionsmaschinen haben
USB	Integrität: Aufgrund der Kritikalität der übertragenen Daten (z. B. Software-Updates, Produktionsdaten) müssen Manipulationen nachweisbar sein Authentizität: Der Zugriff auf ein Gerät über USB darf nur von autorisiertem Personal durchgeführt werden
WLAN	Vertraulichkeit: Aufgrund des offenen Charakters drahtloser Signale ist die Vertraulichkeit eine wesentliche Eigenschaft, um unbefugten Zugriff und verschiedene Arten von Bedrohungen zu verhindern. Selbst wenn die übertragenen Daten an sich nicht vertraulich sind, wie z. B. Produktionsüberwachungsdaten, ist der Schutz von Netzwerkpaketen erforderlich Integrität: Der Schutz der Integrität der WLAN-Pakete erhöht die Robustheit und Zuverlässigkeit des Netzwerks und der Systeme, die sich auf dieses Netzwerk verlassen Verfügbarkeit: WLAN-Netzwerke, die in Produktionsumgebungen eingesetzt werden, müssen hoch zuverlässig sein Authentizität: Die Authentifizierung der Kommunikationspartner in einem drahtlosen Netzwerk ist aufgrund seiner offenen Natur unerlässlich
Feldbus	Integrität: Logistik- oder Produktionsdaten, die zwischen den Maschinen ausgetauscht werden, dürfen nicht manipuliert werden Verfügbarkeit: Produktionsdaten, die zwischen den Produktionsmaschinen ausgetauscht werden, sind wesentlich und müssen eine hohe Zuverlässigkeit aufweisen
Ethernet	Integrität: Produktionsdaten dürfen während der Übertragung nicht manipuliert werden Verfügbarkeit: Sie sind für die Produktion unerlässlich und müssen verfügbar sein Authentizität: Die Authentizität der Daten oder der Netzwerkgeräte, die dem Netzwerk beitreten, muss gewährleistet sein, um Bedrohungen durch unbefugten Zugriff zu verhindern
Benutzerschnittstelle (HMI)	Integrität: Die Integrität einer HMI muss durchgesetzt werden, um Angriffe zu verhindern, die u. a. mit dem Zugriff auf Systeme und dem Abfluss von Daten zusammenhängen Verfügbarkeit: Benutzerschnittstellen in OT-Systemen werden in der Regel zur Konfiguration und Überwachung verwendet und sind daher für den Betrieb unerlässlich Authentizität: Der Zugriff auf kritische Funktionen innerhalb einer HMI darf nur von autorisiertem Personal durchgeführt werden

Tab. A.10 (Fortsetzung) Katalog der Assets mit Cybersecurity-Eigenschaften

Asset [WP-15-02]	Relevante Cybersecurity-Eigenschaft für das Asset und Begründung der Relevanz
Fernzugriff	Vertraulichkeit: Besonders relevant für Daten bei der Übertragung. Fernzugriff zu Diagnosezwecken ist eine wichtige Schnittstelle Integrität: Wesentliche Eigenschaft, um die Manipulation von Diagnosemeldungen während der Übertragung zu verhindern oder zu erkennen Verfügbarkeit: Der Fernzugriff kann genutzt werden, um bei einer Störung einer Produktionsmaschine schnell Unterstützung zu ermöglichen. Daher ist es wichtig, eine hohe Verfügbarkeit zu gewährleisten Authentizität: Es darf nicht möglich sein, dass Unbefugte Fernzugriff auf die Produktionsanlage und die Produktionsmaschinen erhalten Nichtabstreitbarkeit: Bei kritischen Diensten, wie Konfigurationsänderungen oder Software-Updates an den Maschinen, muss die Einheit, die den Fernzugriff nutzt, zurückverfolgt und eindeutig identifiziert werden können Rechenschaftspflicht: Ähnlich wie beim Prinzip der Nichtabstreitbarkeit muss eine eindeutige Rückverfolgbarkeit der Dienste nutzenden Entität gewährleistet sein, um einen Missbrauch zu verhindern
Betriebssystem	Integrität: Die Integrität der Software muss sichergestellt werden, um die Ausführung von Malware auf Produktionsmaschinen zu verhindern Verfügbarkeit: Das Betriebssystem ist für die Produktion unerlässlich Authentizität: Das Betriebssystem selbst muss von einer vertrauenswürdigen Quelle bereitgestellt werden. Administrative Funktionen (z. B. Root-User für ein UNIX-System) müssen vor unberechtigtem Zugriff geschützt werden
Anwendungen	Integrität: Die Integrität der Software muss sichergestellt werden, um die Ausführung von Malware auf Produktionsmaschinen zu verhindern Verfügbarkeit: Anwendungen sind für die Produktion unerlässlich Authentizität: Die auf Produktionsmaschinen installierte Software muss authentisch sein. Zumindest zum Zeitpunkt der Installation muss sichergestellt sein, dass die Software aus einer vertrauenswürdigen Quelle stammt
Datenbanken	Vertraulichkeit: Datenbanken können jede Art von sensiblen Daten enthalten. Der Schutz der Daten vor unbefugtem Zugriff, z. B. auf den Servern, die die Daten speichern, ist von größter Bedeutung Integrität: Daten dürfen nicht verändert werden und Manipulationen müssen erkannt werden Verfügbarkeit: Die Verfügbarkeit von Datenbanken ist wichtig, da diese in Produktionsanlagen und anderen produktiven IT-/OT-Umgebungen eingesetzt werden Authentizität: Der Zugriff auf Datenbanken darf nur durch autorisierte Stellen erfolgen
Software-Updates	Integrität: Der Schutz der Integrität von Software-Updates ist unerlässlich, um die Installation von Malware auf Produktionsrechnern zu vermeiden Authentizität: Software-Update-Pakete müssen aus vertrauenswürdigen Quellen stammen
Logistikdaten	Integrität: Logistikdaten, sind Steuerungs- und Kontrolldaten, die zwischen den Produktionsmaschinen ausgetauscht werden. Diese sind wesentlich Verfügbarkeit: Logistikdaten müssen zuverlässig sein, denn sie sind für die Produktion unerlässlich

Tab. A.11 (Fortsetzung) Katalog der Assets mit Cybersecurity-Eigenschaften

Asset [WP-15-02]	Relevante Cybersecurity-Eigenschaft für das Asset und Begründung der Relevanz
Bill of Materials (BOM)	Integrität: Die BOM ist ein kritisches Asset für die korrekte Herstellung eines Produkts. Die Integrität muss gewährleistet sein Verfügbarkeit: Die Verfügbarkeit der BOM ist wesentlich für die Produktion Authentizität: Es muss sichergestellt werden, dass die an einem bestimmten Punkt des Fertigungsprozesses erhaltene Stückliste von einer vertrauenswürdigen Stelle erstellt wurde. Wenn z. B. der Projektleiter für die Erstellung und Bereitstellung der Stückliste für die Produktion verantwortlich ist, könnte ein digitales Unterschriftensystem eingesetzt werden
Software Bill of Materials (SBOM)	Integrität: Die SBOM darf während des Herstellungsprozesses nicht manipuliert werden. Die SBOM wird für den Umgang mit Vulnerabilities verwendet. Ein Angreifer könnte die in der SBOM aufgeführten Softwareversionen absichtlich verändern, um die Bereitstellung von Software-Patches zu erschweren, wenn eine Schwachstelle entdeckt wird Authentizität: Die SBOM wird für Cybersecurity-Zwecke verwendet und muss daher authentisch sein
Sicherheitsrelevante Daten	Vertraulichkeit: Die Vertraulichkeit muss gewahrt werden, dass es sich um Sicherheitsartefakte, wie z. B. private Schlüssel für SecOC handelt Integrität: Sicherheitsartefakte werden für den korrekten Betrieb des Endprodukts benötigt und dürfen daher nicht manipuliert werden Verfügbarkeit: Sicherheitsrelevante Daten sind ein wesentlicher Bestandteil des Endprodukts. Die Verfügbarkeit muss sichergestellt werden Authentizität: Aufgrund der Art der Verwendung müssen die Sicherheitsartefakte aus vertrauenswürdigen Quellen stammen, z. B. aus der PKI des Herstellers
Sensoren/Aktoren	Integrität: Sensoren und Aktoren können in OT-Umgebungen für viele Zwecke vorhanden sein. Produktionsentscheidungen und sogar sicherheitskritische Funktionen können von Daten abhängen, die zwischen Sensoren ausgetauscht werden. Daher ist die Integrität eine wichtige Eigenschaft Verfügbarkeit: Es muss eine hohe Verfügbarkeit gewährleistet sein, da Sensoren und Aktoren wesentlich für den Betrieb sind Authentizität: Die Authentizität ist wichtig, sodass den Sensoren und Aktoren selbst und den Daten, die sie liefern und empfangen, vertraut werden kann
Server	Integrität: Daten auf Servern dürfen nicht verändert werden, oder Manipulationen müssen erkannt werden Verfügbarkeit: Server sind in der Regel wesentlich für den Betrieb, daher muss die Verfügbarkeit sichergestellt sein Authentizität: Der Zugriff auf Server darf nur von autorisierten Stellen erfolgen
RFID-Karten	Integrität: Der Schutz des RFID-Systems gegen Bedrohungen wie das Klonen von Tags oder Replay-Angriffe muss verhindert werden

Tab. A.12 (Fortsetzung) Katalog der Assets mit Cybersecurity-Eigenschaften

Asset [WP-15-02]	Relevante Cybersecurity-Eigenschaft für das Asset und Begründung der Relevanz
Firewall-Konfigurationen	Vertraulichkeit: Das Verständnis von Firewall-Konfigurationen kann einem Angreifer helfen, die Firewall zu umgehen. Daher muss der Zugriff auf Konfigurationsdateien geschützt werden Integrität: Eine Firewall-Konfiguration darf nur autorisierten Administratoren zugänglich sein Verfügbarkeit: Die Firewall-Konfiguration ist unerlässlich für den korrekten und sicheren Betrieb eines Netzwerks Authentizität: Der Zugriff auf Konfigurationsdateien darf nur autorisierten Administratoren gestattet sein
Netzwerk-Geräte	Integrität: Die Soft- und Hardware von Netzwerk-Geräten darf nicht manipuliert werden Verfügbarkeit: Netzwerk-Geräte sind für die Produktion unerlässlich und müssen verfügbar sein Authentizität: Die Durchsetzung von Authentizitätsprüfungen für Geräte, die eine Verbindung zum Netzwerk herstellen, ist erforderlich, um Bedrohungen durch unbefugten Zugriff zu verhindern. Außerdem muss der Zugriff auf die Geräte, z. B. zu Konfigurationszwecken, durch vertrauenswürdige Stellen erfolgen
Speichersysteme	Vertraulichkeit: Speichersysteme können jede Art von sensiblen Daten enthalten. Der Schutz der Daten vor unberechtigttem Zugriff ist von größter Bedeutung Integrität: Daten auf Speichersystemen dürfen nicht verändert werden, oder Manipulationen müssen erkannt werden Verfügbarkeit: Speichersysteme sind wesentlich für den Betrieb Authentizität: Der Zugriff auf Speichersysteme darf nur durch autorisierte Stellen erfolgen
Endprodukt/PCB	Integrität: In Produktionsumgebungen muss sichergestellt werden, dass die in Produktion befindlichen Platinen nicht in irgendeinem Schritt des Produktionsprozesses manipuliert werden
Stromversorgung	Integrität: Die physische Unversehrtheit von Steckern und Kabeln ist für den Betrieb unerlässlich Verfügbarkeit: Die Verfügbarkeit ist für den Betrieb unerlässlich

A.2 Schadensszenarien-Katalog

Wir präsentieren eine Liste allgemeiner, aber realistischer Schadensszenarien, die als Inspiration für reale Projekte dienen können. Welche Schadensszenarien in einem realen Projekt verwendet werden, hängt vom konkreten Projekt und der Item-Definition ab. Aus diesem Grund ist es nicht möglich, die Schadensszenarien so zu verallgemeinern, dass sie universell anwendbar sind. Einige Schadensszenarien, wie z. B. der Ausfall des Steuergeräts oder das Verlassen der Fahrbahn eines Fahrzeugs, bei dem Personen verletzt werden, werden jedoch in der Regel von mehreren Projekten verwendet. Wir beschreiben die Schadensszenarien in [Tab. A.13](#) und [A.14](#), und wir fassen die Bewertung des Schadens für den Verkehrsteilnehmer

Tab. A.13 Katalog der generischen Schadensszenarien

Schadensszenario [WP-15-01]	Bewertung des Schadens [WP-15-04]									
	Verkehrsteilnehmer-Ansicht					OEM-Ansicht/Lieferantensicht				
	Safety	Finanzen	Betrieb	Privatsphäre	Geistiges Eigentum	Image/Reputation	Finanzen	Betrieb		
Ablenkung des Fahrers, keine Verletzungen	Vernachlässigbar	Vernachlässigbar	Erheblich	Vernachlässigbar	Vernachlässigbar	Vernachlässigbar	Vernachlässigbar	Vernachlässigbar		
ECU außer Betrieb	Vernachlässigbar	Moderat	Erheblich	Vernachlässigbar	Vernachlässigbar	Moderat	Moderat	Vernachlässigbar		
Fahrzeug außer Betrieb oder mit eingeschränkter Funktionalität	Vernachlässigbar	Erheblich	Schwerwiegend	Vernachlässigbar	Vernachlässigbar	Moderat	Moderat	Vernachlässigbar		
Fahrzeug verlässt Fahrbahn und verursacht Verletzungen	Schwerwiegend	Erheblich	Schwerwiegend	Vernachlässigbar	Vernachlässigbar	Erheblich	Moderat	Vernachlässigbar		
Fahrzeug wird gestohlen	Vernachlässigbar	Erheblich	Schwerwiegend	Moderat	Vernachlässigbar	Vernachlässigbar	Vernachlässigbar	Vernachlässigbar		
Nichtverfügbarkeit nicht sicherheitsrelevanter Informationen (z. B. Verkehrsinformationen, Musik, Adressbuch)	Vernachlässigbar	Moderat	Erheblich	Vernachlässigbar	Vernachlässigbar	Moderat	Vernachlässigbar	Vernachlässigbar		
Im Fahrzeug installierte nicht autorisierte Software/Daten	Erheblich	Moderat	Moderat	Vernachlässigbar	Vernachlässigbar	Moderat	Moderat	Vernachlässigbar		
Betrug (z. B. Nutzung einer Lizenz für eine Dienstleistung, ohne dafür bezahlt zu haben)	Vernachlässigbar	Erheblich	Vernachlässigbar	Vernachlässigbar	Vernachlässigbar	Moderat	Moderat	Vernachlässigbar		
Offenlegung von personenbezogenen und personenbeziehbaren Daten (z. B. Standortverfolgung eines oder mehrerer Fahrzeuge)	Vernachlässigbar	Moderat	Vernachlässigbar	Erheblich	Vernachlässigbar	Erheblich	Erheblich	Vernachlässigbar		

Tab. A.14 (Fortsetzung) Katalog der generischen Schadensszenarien

Schadensszenario [WP-15-01]	Bewertung des Schadens [WP-15-04]									
	Verkehrsteilnehmer-Ansicht					OEM-Ansicht/Lieferantensicht				
	Safety	Finanzen	Betrieb	Privatsphäre	Geistiges Eigentum	Image/Reputation	Finanzen	Betrieb		
Offenlegung geschäftsrelevanter Daten	Vernachlässigbar	Vernachlässigbar	Vernachlässigbar	Vernachlässigbar	Moderat	Moderat	Erheblich	Vernachlässigbar		
Sensoren/Warnsysteme liefern falsche Informationen	Erheblich	Moderat	Erheblich	Vernachlässigbar	Vernachlässigbar	Moderat	Moderat	Vernachlässigbar		
Software-Reverse-Engineering, Produktpiraterie	Vernachlässigbar	Vernachlässigbar	Vernachlässigbar	Vernachlässigbar	Erheblich		Erheblich	Vernachlässigbar		
Manipulierte Software im Endprodukt (ECU)	Schwerwiegend	Erheblich	Schwerwiegend	Vernachlässigbar	Vernachlässigbar	Erheblich	Moderat	Vernachlässigbar		
Produktionsrechner oder lokale Server, die mit Ransomware infiziert sind	Vernachlässigbar	Vernachlässigbar	Vernachlässigbar	Vernachlässigbar	Schwerwiegend	Erheblich				
Produktionsstopp länger als einen Tag	Vernachlässigbar	Vernachlässigbar	Vernachlässigbar	Vernachlässigbar	Vernachlässigbar	Erheblich	Erheblich			
Groß angelegter Datenbruch, einschließlich Cybersecurity-Artefakten und Logistikdaten	Vernachlässigbar	Vernachlässigbar	Moderat	Vernachlässigbar	Erheblich	Schwerwiegend	Erheblich	Moderat		
Manipulierte Produktionsdaten oder Stücklisten führen zu fehlerhaften Endprodukten	Schwerwiegend	Erheblich	Schwerwiegend	Vernachlässigbar	Vernachlässigbar	Schwerwiegend	Schwerwiegend	Schwerwiegend		

und für den OEM oder Lieferanten in derselben Tabelle zusammen. Wir verzichten auf die Kommentierung neben der Bewertung des Schadens, da diese nur bei realen Projekten von Bedeutung ist. Wir führen die Bewertung des Schadens nach den in Kap. 6 beschriebenen Kriterien durch.

A.3 Bedrohungskatalog

Wir geben einen detaillierten Überblick über den Bedrohungskatalog aus der UN-Regelung Nr. 155. Der Katalog deckt zwar nicht alle möglichen Bedrohungen ab, wir empfehlen jedoch, ihn als solide Grundlage zu verwenden und ihn dann durch die Aufnahme zusätzlicher Bedrohungen in den TARA-Prozess zu erweitern. Der Katalog umfasst verschiedene Bedrohungsgruppen, die sich mit verschiedenen Aspekten moderner vernetzter Fahrzeuge befassen, z. B. mit der Kommunikation mit Backend-Servern, V2X und mehr. Wir zählen jede der im Katalog vorgestellten Bedrohungen auf und fügen die folgenden Informationen hinzu:

1. Zuordnung eines Angriffsvektors zu jeder Bedrohung, in Übereinstimmung mit dem CVSS-Schema, das in Abschn. 7.3.2.1 besprochen wird.
2. Bereitstellung eines illustrativen Angriffspaths als Beispiel.
3. Eine Beschreibung der Cybersecurity-Eigenschaften eines Assets, das durch die identifizierte Bedrohung gefährdet werden kann.

Die nachstehende Bewertung bezieht sich auf einen einzigen möglichen Angriffspfad und dient lediglich der Veranschaulichung. Die von uns angeführten Beispiele basieren auf unseren Erfahrungen und realen Fällen. Aufgrund des allgemeinen Charakters der Beschreibung der Bedrohungen und des Fehlens eines spezifischen Ziel-Assets sind diese Beispiele jedoch nicht unbedingt auf jedes Item, jede Komponente, jedes Asset oder jedes TARA-Projekt übertragbar. Unser Ziel ist es jedoch, Anhaltspunkte für die Bewertung dieser signifikanten Bedrohungen im Kontext realer Projekte zu geben und bei ihrer umfassenden Analyse und ihrem Verständnis zu helfen (Tab. A.15, A.16, A.17, A.18, A.19, A.20, A.21, A.22, A.23, A.24, A.25, A.26, A.27, A.28, A.29, A.30, A.31, A.32, A.33, A.34, A.35, A.36, A.37 und A.38).

Tab. A.15 Bedrohungskatalog aus der UN-Regelung Nr. 155, einschließlich unserer Beispiele für Angriffspfad, Cybersecurity-Eigenschaften und Angriffsvektor

1 Backend-Server werden zum Angriff auf ein Fahrzeug oder zum Extrahieren von Daten genutzt	
Beschreibung der Bedrohung (Schwachstelle/Angriffsmethode)	1.1 Missbrauch von Berechtigungen durch Personal (Insider-Angriff)
Angriffsvektor:	Netzwerk
Beispiel eines Angriffspfads [WP-15-05]: 1. Ein Insider stiehlt Authentifizierungs-Credentials von einem Kollegen, um dessen Identität vorzutäuschen, oder um zwei Konten zu verwenden, falls ein Vier-Augen-Prinzip aktiviert ist. 2. Der Angreifer loggt sich in das Backend-System ein, das die Kommunikation mit den Fahrzeugen verwaltet. 3. Der Angreifer sendet gültige Anfragen an ein (durch die Fahrgestellnummer identifiziertes) Fahrzeug, um kostenpflichtige Funktionen zu aktivieren oder sensible Daten abzurufen.	
Kompromitierte Cybersecurity-Eigenschaft und Ursache [RQ-15-03]: <i>Vertraulichkeit:</i> Die Extraktion von fahrzeugsensiblen Daten durch Fernabfrage. <i>Integrität:</i> Ein Angriff kann zur Manipulation von Daten genutzt werden. <i>Verfügbarkeit:</i> Ein Angriff kann verwendet werden, um einen Denial-of-Service zu provozieren (z. B. Deaktivierung von Funktionen bei Fahrzeugen).	
Beschreibung der Bedrohung (Schwachstelle/Angriffsmethode)	1.2 Unbefugter Internetzugriff auf den Server (z. B. durch Backdoors, nicht gepatchte Systemsoftwareschwachstellen, SQL-Angriffe oder andere Mittel)
Angriffsvektor:	Netzwerk
Beispiel eines Angriffspfads [WP-15-05]: 1. Der Angreifer nutzt eine Schwachstelle des Backend-Servers aus. 2. Auf dem Backend-Server können durch einen Impersonation-Angriff gültige Anfragen an Fahrzeuge gesendet werden.	
Kompromitierte Cybersecurity-Eigenschaft und Ursache [RQ-15-03]: <i>Vertraulichkeit:</i> Extraktion von fahrzeugsensiblen Daten durch Fernabfrage. <i>Integrität:</i> Ein Angriff kann zur Manipulation von Daten genutzt werden. <i>Verfügbarkeit:</i> Ein Angriff kann verwendet werden, um Denial-of-Service zu provozieren (z. B. Deaktivierung von Funktionen auf Fahrzeugen).	
Beschreibung der Bedrohung (Schwachstelle/Angriffsmethode)	1.3 Unbefugter physischer Zugriff auf den Server (z. B. mittels USB-Sticks oder anderer Datenträger, die sich mit dem Server verbinden)
Angriffsvektor:	Physisch
Beispiel eines Angriffspfads [WP-15-05]: 1. Der Angreifer präpariert Malware auf einem defekten USB-Stick (z. B. als Tastatur getarnt) und schafft es, diesen an einen kritischen Backend-Server anzuschließen. 2. Die Malware wird in den Server eingeschleust.	
Kompromitierte Cybersecurity-Eigenschaft und Ursache [RQ-15-03]: <i>Vertraulichkeit:</i> Eine Extraktion vertraulicher Daten durch vollständigen Zugriff auf den Server. <i>Integrität:</i> Ein Angriff kann zur Manipulation von Daten genutzt werden. <i>Verfügbarkeit:</i> Ein Angriff kann verwendet werden, um einen Denial-of-Service zu provozieren.	

Tab. A.16 (Fortsetzung) Bedrohungskatalog aus der UN-Regelung Nr. 155, einschließlich unserer Beispiele für Angriffspfad, Cybersecurity-Eigenschaften und Angriffsvektor

2 Backend-Serverdienste werden unterbrochen und der Fahrzeugbetrieb dadurch beeinträchtigt	
Beschreibung der Bedrohung (Schwachstelle/Angriffsmethode)	2.1 Ein Angriff auf einen Backend-Server führt zu dessen Ausfall; dadurch wird z. B. die Interaktion mit Fahrzeugen und die Bereitstellung von Diensten, auf die diese angewiesen sind, verhindert
Angriffsvektor:	Netzwerk
Beispiel eines Angriffspfads [WP-15-05]:	
1. Der Angreifer verfügt über spezifische Kenntnisse über die Backend-Dienste, wie z. B. verwendete Protokolle, IP-Adressen und grundlegende Schutzmechanismen.	
2. Der Angreifer bereitet einen groß angelegten DDoS-Angriff gegen das Backend vor.	
Kompromittierte Cybersecurity-Eigenschaft und Ursache [RQ-15-03]:	
<i>Verfügbarkeit:</i> Die vom Backend-Server bereitgestellten Dienste sind vorübergehend gestört.	
3 Verlust oder Gefährdung von Fahrzeugdaten auf Backend-Servern („Datenpanne“)	
Beschreibung der Bedrohung (Schwachstelle/Angriffsmethode)	3.1 Missbrauch von Berechtigungen durch Personal (Insider-Angriff)
Angriffsvektor:	Lokal
Beispiel eines Angriffspfads [WP-15-05]:	
1. Ein Insider stiehlt Authentifizierungs-Credentials von einem Kollegen, um dessen Identität vorzutäuschen, oder um zwei Konten zu verwenden, falls ein Vier-Augen-Prinzip aktiviert ist.	
2. Der Angreifer meldet sich am Backend-System mit ausreichenden Rechten an.	
3. Der Angreifer erhält Daten von Kunden.	
Kompromittierte Cybersecurity-Eigenschaft und Ursache [RQ-15-03]:	
<i>Vertraulichkeit:</i> Extraktion von sensiblen Kundeninformationen gefährdet die Vertraulichkeit.	
Beschreibung der Bedrohung (Schwachstelle/Angriffsmethode)	3.2 Verlust von Informationen in der Cloud. Sensible Daten, die durch Drittanbieter von Cloud-Diensten gespeichert werden, können durch Angriffe oder Pannen verloren gehen
Angriffsvektor:	Netzwerk
Beispiel eines Angriffspfads [WP-15-05]:	
1. Ein Angreifer nutzt eine Schwachstelle aus und verschafft sich Zugriff auf das Cloud-Speichersystem.	
2. Der Angreifer führt Malware aus oder löscht Dateien und Sicherungsdaten manuell.	
Kompromittierte Cybersecurity-Eigenschaft und Grund [RQ-15-03]:	
<i>Integrität:</i> Die Integrität der gespeicherten Daten ist direkt beeinträchtigt (Daten werden gelöscht oder verändert).	
<i>Verfügbarkeit:</i> Die Verfügbarkeit wird durch einen Datenverlust verletzt.	

Tab. A.17 (Fortsetzung) Bedrohungskatalog aus der UN-Regelung Nr. 155, einschließlich unserer Beispiele für Angriffspfad, Cybersecurity-Eigenschaften und Angriffsvektor

3 Verlust oder Gefährdung von Fahrzeugdaten auf Backend-Servern („Datenpanne“)	
Beschreibung der Bedrohung (Schwachstelle/Angriffsmethode)	3.3 Unbefugter Internetzugriff auf den Server (z. B. durch Backdoors, nicht gepatchte Systemsoftwareschwachstellen, SQL-Angriffe oder andere Mittel)
Angriffsvektor:	Netzwerk
Beispiel eines Angriffspfads [WP-15-05]:	
1. Der Angreifer nutzt eine Schwachstelle des Backend-Servers aus.	
2. Der Angreifer kann Daten auf dem Server löschen oder nutzt Fuzzing, um die gespeicherten Daten zu beschädigen.	
Kompromittierte Cybersecurity-Eigenschaft und Ursache [RQ-15-03]:	
<i>Integrität:</i> Die Integrität der gespeicherten Fahrzeugdaten wird durch Veränderung oder Löschen verletzt.	
<i>Verfügbarkeit:</i> Die Daten sind aufgrund von Löschung nicht verfügbar oder die Daten sind korumpiert.	
Beschreibung der Bedrohung (Schwachstelle/Angriffsmethode)	3.4 Unbefugter physischer Zugriff auf den Server (z. B. mittels USB-Sticks oder anderer Medien, die sich mit dem Server verbinden)
Angriffsvektor:	Physisch
Beispiel eines Angriffspfads [WP-15-05]:	
1. Der Angreifer präpariert Malware über einen falschen USB-Anschluss (z. B. als Tastatur getarnt) und schafft es, diesen an einen kritischen Backend-Server anzuschließen.	
2. Die Malware wird in den Server eingeschleust.	
Kompromittierte Cybersecurity-Eigenschaft und Ursache [RQ-15-03]:	
<i>Vertraulichkeit:</i> Die Extraktion vertraulicher Daten durch vollständigen Zugriff auf den Server.	
<i>Integrität:</i> Ein Angriff kann zur Manipulation von Daten genutzt werden.	
<i>Verfügbarkeit:</i> Ein Angriff kann verwendet werden, um Denial-of-Service zu provozieren.	
Beschreibung der Bedrohung (Schwachstelle/Angriffsmethode)	3.5 Informationssicherheitslücken durch unbeabsichtigte Weitergabe von Daten (z. B. durch Administratorfehler)
Angriffsvektor:	Netzwerk
Beispiel eines Angriffspfads [WP-15-05]:	
1. Aufgrund mangelhafter Richtlinien und Cybersecurity-Maßnahmen sendet ein Administrator sensible Daten im Klartext-format über das Internet.	
Kompromittierte Cybersecurity-Eigenschaft und Ursache [RQ-15-03]:	
<i>Vertraulichkeit:</i> Sensible Daten werden offengelegt und damit wird die Vertraulichkeit verletzt.	

Tab. A.18 (Fortsetzung) Bedrohungskatalog aus der UN-Regelung Nr. 155, einschließlich unserer Beispiele für Angriffspfad, Cybersecurity-Eigenschaften und Angriffsvektor

4 Spoofing von Nachrichten oder Daten, die vom Fahrzeug empfangen werden

Beschreibung der Bedrohung (Schwachstelle/Angriffsmethode)	4.1 Spoofing von Nachrichten durch Identitätswechsel (z. B. 802.11p V2X beim Platooning, GNSS-Nachrichten usw.)
Angriffsvektor:	Angrenzend

Beispiel eines Angriffspfads [WP-15-05]:

1. Der Angreifer bereitet Störsender vor und verteilt sie in der Stadt.
2. Die Störeinrichtungen verfügen über LTE-Konnektivität und hören einen vom Angreifer betriebenen Dienst ab.
3. Der Angreifer startet eine verteilte Störaktion, um einen bestimmten Dienst des Fahrzeugs zu stören (z. B. eine Autovermietung, die einen Remote-Dienst zum Entriegeln von Fahrzeugen nutzt).

Kompromittierte Cybersecurity-Eigenschaft und Ursache [RQ-15-03]:

Integrität: Die Nachrichten zwischen den Fahrzeugen und den Backend-Servern sind nicht zuverlässig.

Verfügbarkeit: Dienste, die auf ungestörte Signale angewiesen sind, werden beeinträchtigt.

Beschreibung der Bedrohung (Schwachstelle/Angriffsmethode)	4.2 Sybil-Attacke (um für andere Fahrzeuge vorzutäuschen, es seien viele Fahrzeuge auf der Straße)
Angriffsvektor:	Angrenzend

Beispiel eines Angriffspfads [WP-15-05]:

1. Der Angreifer bereitet Sender vor und verteilt diese über das Stadtgebiet.
2. Die Sender täuschen die Anwesenheit von Fahrzeugen vor, indem sie gültige Nachrichten an andere Fahrzeuge und die Infrastruktur senden.

Kompromittierte Cybersecurity-Eigenschaft und Ursache [RQ-15-03]:

Integrität: Ein V2X-Netzwerk ist aufgrund von gefälschten Identitäten gestört.

Verfügbarkeit: Die Dienste des V2X-Netzwerks könnten vorübergehend gestört werden.

5 Kommunikationskanäle werden für die unerlaubte Manipulation, Löschung oder sonstige Änderung von Fahrzeugcode/-daten genutzt

Beschreibung der Bedrohung (Schwachstelle/Angriffsmethode)	5.1 Kommunikationskanäle ermöglichen Code-Injektion, z. B. können manipulierte Softwarebinärdateien in den Kommunikationsstrom injiziert werden
Angriffsvektor:	Angrenzend

Beispiel eines Angriffspfads [WP-15-05]:

1. Der Angreifer stellt über eine ungeschützte Diagnose- oder Debugging-Schnittstelle eine Verbindung zum Steuergerät her.
2. Die Firmware des Steuergeräts wird extrahiert und reverse-engineered.
3. Ein Angreifer mit ausreichenden Fähigkeiten (z. B. ein ehemaliger Mitarbeiter oder ein sehr erfahrener Software-Ingenieur) baut eine Malware in die extrahierte Firmware ein.
4. Die Malware wird mittels der manipulierten Firmware in das Steuergerät eingeschleust.

Kompromittierte Cybersecurity-Eigenschaft und Ursache [RQ-15-03]:

Vertraulichkeit: Die Malware kann verwendet werden, um Schutzmaßnahmen zu umgehen und so das Auslesen sensibler Daten ermöglichen.

Integrität: Die Software des Steuergeräts wird verändert.

Verfügbarkeit: Die Malware kann Funktionen des Steuergeräts in ihrer Verfügbarkeit stören.

Authentizität: Der Angreifer kann die Malware als Mittel zur Umgehung von Authentifizierungsmethoden verwenden (z. B. das Steuergerät umgeht die SecOC-Verifikation).

Tab. A.19 (Fortsetzung) Bedrohungskatalog aus der UN-Regelung Nr. 155, einschließlich unserer Beispiele für Angriffspfad, Cybersecurity-Eigenschaften und Angriffsvektor

5 Kommunikationskanäle werden für die unerlaubte Manipulation, Löschung oder sonstige Änderung von Fahrzeugcode/-daten genutzt

Beschreibung der Bedrohung (Schwachstelle/Angriffsmethode)	5.2–5.5 Kommunikationskanäle ermöglichen die Manipulation/das Überschreiben/die Löschung/die Einspeisung von Fahrzeugdaten/-code
Angriffsvektor:	Angrenzend

Beispiel eines Angriffspfads [WP-15-05]:

1. Der Angreifer nutzt den OBD-II-Port als Angriffsvektor.
2. Der Angreifer ist in der Lage, die Authentifizierungsmechanismen der Diagnose zu umgehen und erhält erweiterte Rechte auf dem Zielsteuergerät.
3. Diagnosenachrichten werden genutzt, um Daten zu lesen und zu schreiben.

Kompromitierte Cybersecurity-Eigenschaft und Ursache [RQ-15-03]:

Vertraulichkeit: Sensible Daten sind nicht ausreichend geschützt und können gelesen werden.

Integrität: Die direkte Manipulation von Daten des Steuergeräts ist möglich.

Verfügbarkeit: Das Steuergerät kann komplett gestört werden.

6 Kommunikationskanäle ermöglichen den Empfang nicht vertrauenswürdiger/unzuverlässiger Nachrichten oder sind anfällig für Session Hijacking oder Replay-Angriffe

Beschreibung der Bedrohung (Schwachstelle/Angriffsmethode)	6.1 Akzeptieren von Informationen aus einer unzuverlässigen oder nicht vertrauenswürdigen Quelle
Angriffsvektor:	Angrenzend

Beispiel eines Angriffspfads [WP-15-05]:

1. Ein Angreifer verbindet sich mit dem Steuergerät über einen ungeschützten Kommunikationskanal.
2. Der Angreifer sendet gültige Anfragen an das Steuergerät (z. B. das Erstellen oder Abspielen von Nachrichten).
3. Das Steuergerät akzeptiert die Anfragen ohne Überprüfung und antwortet mit der Bereitstellung von Daten.

Kompromitierte Cybersecurity-Eigenschaft und Ursache [RQ-15-03]:

Vertraulichkeit: Sensible Daten können durch die Anfragen offengelegt werden.

Integrität: Manipulierte Daten können in das Steuergerät eingeschleust werden.

Beschreibung der Bedrohung (Schwachstelle/Angriffsmethode)	6.2 Man-in-the-Middle-Angriff/Session Hijacking
Angriffsvektor:	Angrenzend

Beispiel eines Angriffspfads [WP-15-05]:

1. Der Angreifer gibt sich als Mobilfunk- oder WLAN-Hotspot aus, indem er spezielles Equipment (evil twin) in der Nähe des Fahrzeugs verwendet.
2. Der Angreifer fängt den gesamten vom Fahrzeug übertragenen Datenverkehr ab, z. B. sensible Daten wie Benutzernamen und Passwörter.

Kompromitierte Cybersecurity-Eigenschaft und Ursache [RQ-15-03]:

Vertraulichkeit: Die Vertraulichkeit kann durch Offenlegung von sensiblen Daten verletzt werden.

Integrität: Die Daten können bei der Übertragung manipuliert werden.

Authentizität: Der Angriff kann dazu verwendet werden, Credentials zur Authentifizierung zu stehlen und sie für einen späteren Angriff zu verwenden.

Tab. A.20 (Fortsetzung) Bedrohungskatalog aus der UN-Regelung Nr. 155, einschließlich unserer Beispiele für Angriffspfad, Cybersecurity-Eigenschaften und Angriffsvektor

6 Kommunikationskanäle ermöglichen den Empfang nicht vertrauenswürdiger/unzuverlässiger Nachrichten oder sind anfällig für Session Hijacking ode Rply-Angriffe

Beschreibung der Bedrohung (Schwachstelle/Angriffsmethode)	6.3 Replay-Angriff, z. B. ein Angriff auf ein Kommunikations-Gateway, der es dem Angreifer ermöglicht, die Software eines elektronischen Steuergeräts oder die Firmware des Gateways herabzustufen
Angriffsvektor:	Angrenzend

Beispiel eines Angriffspfads [WP-15-05]:

1. Der Angreifer kompromittiert die Kommunikationseinheit des Fahrzeugs.
2. Die Malware in der Kommunikationseinheit ist in der Lage, Diagnosemeldungen zu identifizieren, die für Software-Updates verwendet werden.
3. Wenn das Gateway oder das Zielsteuergerät ein Update anfordert, ändert die Malware in der Kommunikationseinheit die Anforderung und kündigt ein Update auf eine ältere Softwareversion an.

Kompromitierte Cybersecurity-Eigenschaft und Ursache [RQ-15-03]:

Integrität: Die Integrität des Software-Updates ist gefährdet; der Angreifer nutzt bekannte Schwachstellen in der alten Software, um weitere Angriffe durchzuführen.

7 Informationen können leicht offengelegt werden, beispielsweise durch Abhören der Kommunikation oder die Ermöglichung des unbefugten Zugriffs auf sicherheitskritische Dateien oder Ordner

Beschreibung der Bedrohung (Schwachstelle/Angriffsmethode)	7.1 Abfangen von Informationen/Störstrahlung/Überwachung der Kommunikation
Angriffsvektor:	Angrenzend

Beispiel eines Angriffspfads [WP-15-05]:

1. Der Angreifer schließt ein Sniffing-Device an das Ethernet-Netzwerk des Fahrzeugs an.
2. Ungeschützte Nachrichten werden vom Sniffing-Device erfasst und gespeichert.

Kompromitierte Cybersecurity-Eigenschaft und Ursache [RQ-15-03]:

Vertraulichkeit: Die Vertraulichkeit kann verletzt werden, indem ungeschützte sensible Informationen erfasst werden.

Beschreibung der Bedrohung (Schwachstelle/Angriffsmethode)	7.2 Erlangen von unbefugtem Zugriff auf Dateien oder Daten
Angriffsvektor:	Angrenzend

Beispiel eines Angriffspfads [WP-15-05]:

1. Der Angreifer baut ein Steuergerät aus dem Fahrzeug aus und verschafft sich Zugang zum Board.
2. Der Angreifer identifiziert JTAG-Anschlüsse auf einem Chip und schließt ein Debugging-Tool an.
3. Über das Debugging-Tool startet der Angreifer einen Brute-Force-Angriff, um das JTAG-Passwort zu finden.
4. Das Passwort wird gefunden, und der Angreifer erhält Zugriff auf den Speicherbereich auf dem Chip.

Kompromitierte Cybersecurity-Eigenschaft und Ursache [RQ-15-03]:

Vertraulichkeit: Die Vertraulichkeit kann aufgrund von unbefugtem Zugriff auf Daten verletzt werden.

Authentizität: Die Authentizität kann verletzt werden, wenn der Zugriffsschutz gebrochen wird.

Tab. A.21 (Fortsetzung) Bedrohungskatalog aus der UN-Regelung Nr. 155, einschließlich unserer Beispiele für Angriffspfad, Cybersecurity-Eigenschaften und Angriffsvektor

8 Denial-of-Service-Attacken über Kommunikationskanäle zur Störung der Fahrzeugfunktionen	
Beschreibung der Bedrohung (Schwachstelle/Angriffsmethode)	8.1 Das Fahrzeuginformationssystem wird gezielt mit so vielen Anfragen bombardiert, dass es die Aufgaben nicht mehr bewältigen kann
Angriffsvektor:	Angrenzend
Beispiel eines Angriffspfads [WP-15-05]:	
1. Der Angreifer verwendet ein Sendegerät, das sich in der Nähe eines Fahrzeugs oder einer Gruppe von Fahrzeugen befindet (z. B. ein Gerät, das stärkere Funksignale sendet als die legitimen WLAN- oder V2X-Sender).	
2. Das Fahrzeug des Opfers erhält falsche Informationen und kann nicht normal funktionieren (z. B. durch Spoofing von GNSS-Informationen).	
Kompromitierte Cybersecurity-Eigenschaft und Ursache [RQ-15-03]:	
<i>Integrität:</i> Dienste, die sich auf externe Kommunikation verlassen, erhalten falsche Informationen.	
<i>Verfügbarkeit:</i> Dienste, die auf externe Kommunikation angewiesen sind, werden gestört.	
Beschreibung der Bedrohung (Schwachstelle/Angriffsmethode)	8.2 Black-Hole-Angriff; um die Kommunikation zwischen Fahrzeugen zu stören, kann der Angreifer Nachrichten zwischen den Fahrzeugen blockieren
Angriffsvektor:	Angrenzend
Beispiel eines Angriffspfads [WP-15-05]:	
1. Der Angreifer verwendet ein Sendegerät in der Nähe eines Fahrzeugs oder einer Gruppe von Fahrzeugen.	
2. Der Angreifer gibt sich als Fahrzeug oder Kommunikationsknoten aus, der die beste Route zu einem möglichen Ziel hat.	
Kompromitierte Cybersecurity-Eigenschaft und Ursache [RQ-15-03]:	
<i>Integrität:</i> Die Integrität ist verletzt durch Übermittlung falscher Informationen.	
<i>Verfügbarkeit:</i> Eine Störung der Fahrzeug-zu-Fahrzeug-Kommunikation führt zu einer Verletzung der Verfügbarkeit.	
9 Ein unprivilegierter Benutzer kann Sonderzugriffsrechte auf Fahrzeugsysteme erhalten	
Beschreibung der Bedrohung (Schwachstelle/Angriffsmethode)	9.1 Ein unprivilegierter Benutzer kann Sonderzugriffsrechte erhalten, z. B. Root-Zugriff
Angriffsvektor:	Angrenzend
Beispiel eines Angriffspfads [WP-15-05]:	
1. Der Angreifer baut ein Steuergerät aus dem Fahrzeug aus und verschafft sich Zugang zum Board.	
2. Der Angreifer identifiziert JTAG-Anschlüsse auf dem Board und schließt ein Debugging-Tool an.	
3. Über das Debugging-Tool startet der Angreifer einen Brute-Force-Angriff, um das JTAG-Passwort zu finden.	
4. Das Passwort wird gefunden, und der Angreifer erhält Zugriff auf den Speicherbereich im Chip.	
Kompromitierte Cybersecurity-Eigenschaft und Ursache [RQ-15-03]:	
<i>Vertraulichkeit:</i> Die Vertraulichkeit wird aufgrund von unbefugtem Zugriff auf Daten verletzt.	
<i>Authentizität:</i> Die Authentizität wird durch Brechen des Zugriffsschutzes verletzt.	

Tab. A.22 (Fortsetzung) Bedrohungskatalog aus der UN-Regelung Nr. 155, einschließlich unserer Beispiele für Angriffspfad, Cybersecurity-Eigenschaften und Angriffsvektor

10 In Kommunikationsmedien eingebettete Viren können Fahrzeugsysteme infizieren

Beschreibung der Bedrohung (Schwachstelle/Angriffsmethode)	10.1 Ein in Kommunikationsmedien eingebetteter Virus infiziert Fahrzeugsysteme
Angriffsvektor:	Lokal

Beispiel eines Angriffspfads [WP-15-05]:

1. Ein ahnungsloser Benutzer schließt ein USB-Gerät an das Infotainment-System an.
2. Das USB-Gerät enthält einen Virus, der vom Infotainment System ausgelesen wird.
3. Der Virus gibt sich als Software-Update aus und wird ausgeführt.

Kompromittierte Cybersecurity-Eigenschaft und Ursache [RQ-15-03]:

Vertraulichkeit: Die Schadsoftware kann durch die Ausführung von Anfragen auf Daten zugreifen, die im Infotainment-System oder in anderen Steuergeräten gespeichert sind.

Integrität: Die Software des Infotainment-Systems wird verändert.

Verfügbarkeit: Die Schadsoftware kann verwendet werden, um bestimmte Dienste oder Funktionalitäten zu stören.

11 Vom Fahrzeug empfangene Nachrichten (z. B. X2V- oder Diagnosenachrichten) oder innerhalb des Fahrzeugs übertragene Nachrichten enthalten schädliche Inhalte

Beschreibung der Bedrohung (Schwachstelle/Angriffsmethode)	11.1 Schädliche interne Nachrichten (z. B. CAN-Nachrichten)
Angriffsvektor:	Angrenzend

Beispiel eines Angriffspfads [WP-15-05]:

1. Der Angreifer nutzt eine Schwachstelle im Bluetooth-Stack des Fahrzeugs aus.
2. Der Angreifer kann Befehle senden, die vom Fahrzeug akzeptiert werden (und z. B. zur Codeausführung führen).

Kompromittierte Cybersecurity-Eigenschaft und Ursache [RQ-15-03]:

Vertraulichkeit: Im schlimmsten Fall wird unberechtigter Zugang zu Daten erreicht.

Integrität: Die Integrität wird durch Veränderung der Daten des Fahrzeugs durch Angreifer verletzt.

Beschreibung der Bedrohung (Schwachstelle/Angriffsmethode)	11.2 Schädliche V2X-Nachrichten, z. B. Nachrichten zwischen Infrastruktur und Fahrzeug oder Nachrichten zwischen Fahrzeugen (z. B. CAM oder DENM)
Angriffsvektor:	Angrenzend

Beispiel eines Angriffspfads [WP-15-05]:

1. Der Angreifer verwendet ein Sendegerät, das sich in der Nähe eines Fahrzeugs oder einer Gruppe von Fahrzeugen befindet (z. B. ein Gerät, das stärkere Funksignale sendet als die echten WLAN- oder V2X-Sender).
2. Das Fahrzeug des Opfers erhält falsche Informationen und kann nicht normal funktionieren (z. B. durch Spoofing von GNSS-Informationen).

Kompromittierte Cybersecurity-Eigenschaft und Ursache [RQ-15-03]:

Integrität: Dienste, die sich auf externe Kommunikation verlassen, erhalten falsche Informationen.

Verfügbarkeit: Dienste, die auf externe Kommunikation angewiesen sind, werden gestört.

Tab. A.23 (Fortsetzung) Bedrohungskatalog aus der UN-Regelung Nr. 155, einschließlich unserer Beispiele für Angriffspfad, Cybersecurity-Eigenschaften und Angriffsvektor

11 Vom Fahrzeug empfangene Nachrichten (z. B. X2V- oder Diagnosenachrichten) oder innerhalb des Fahrzeugs übertragene Nachrichten enthalten schädliche Inhalte

Beschreibung der Bedrohung (Schwachstelle/Angriffsmethode)	11.3 Schädliche Diagnosemeldungen
Angriffsvektor:	Angrenzend

Beispiel eines Angriffspfads [WP-15-05]:

1. Der Angreifer nutzt eine Schwachstelle der drahtlosen Schnittstelle (z. B. Bluetooth) aus.
2. Diagnosemeldungen werden an das Fahrzeug gesendet.

Kompromitierte Cybersecurity-Eigenschaft und Ursache [RQ-15-03]:

Vertraulichkeit: Böartige Diagnosenachrichten werden für den Zugriff auf Daten verwendet.

Integrität: Böartige Diagnosenachrichten können Daten in die Fahrzeugsysteme schreiben.

Beschreibung der Bedrohung (Schwachstelle/Angriffsmethode)	11.4 Schädliche proprietäre Nachrichten (z. B. solche, die normalerweise vom OEM oder vom Lieferanten eines Bauteils, eines Systems oder einer Funktion gesendet werden)
Angriffsvektor:	Angrenzend

Beispiel eines Angriffspfads [WP-15-05]:

1. Der Angreifer nutzt eine Schwachstelle der drahtlosen Schnittstelle (z. B. Bluetooth) aus.
2. Diagnosemeldungen werden an das Fahrzeug gesendet.

Kompromitierte Cybersecurity-Eigenschaft und Ursache [RQ-15-03]:

Vertraulichkeit: Böartige Diagnosenachrichten werden für den Zugriff auf Daten verwendet.

Integrität: Böartige Diagnosenachrichten können Daten in die Fahrzeugsysteme schreiben.

12 Missbrauch oder Beeinträchtigung von Aktualisierungsverfahren

Beschreibung der Bedrohung (Schwachstelle/Angriffsmethode)	12.1 Beeinträchtigung von drahtlosen Softwareaktualisierungsverfahren; dazu gehört auch die Fälschung des Programms oder der Firmware zur Systemaktualisierung
Angriffsvektor:	Angrenzend

Beispiel eines Angriffspfads [WP-15-05]:

1. Der Angreifer nutzt eine Schwachstelle in der Head-Unit einer Fahrzeugplattform aus, die die Installation von Malware in der Head-Unit ermöglicht.
2. Die Malware identifiziert Software-Update-Prüfungen von den Steuergeräten des Fahrzeugs.
3. Wenn ein Steuergerät eine Softwareaktualisierung anfordert, weist die Malware auf der Head-Unit die Anforderung zurück oder meldet, dass keine Aktualisierungen verfügbar sind.

Kompromitierte Cybersecurity-Eigenschaft und Ursache [RQ-15-03]:

Integrität: Das Softwareaktualisierungsverfahren wird im Kern geändert.

Verfügbarkeit: Der Update-Service ist für die Steuergeräte nicht verfügbar.

Tab. A.24 (Fortsetzung) Bedrohungskatalog aus der UN-Regelung Nr. 155, einschließlich unserer Beispiele für Angriffspfad, Cybersecurity-Eigenschaften und Angriffsvektor

12 Missbrauch oder Beeinträchtigung von Aktualisierungsverfahren

Beschreibung der Bedrohung (Schwachstelle/Angriffsmethode)	12.2 Beeinträchtigung von lokalen/physischen Softwareaktualisierungsverfahren; dazu gehört auch die Fälschung des Programms oder der Firmware zur Systemaktualisierung
Angriffsvektor:	Physisch

Beispiel eines Angriffspfads [WP-15-05]:

1. Der Angreifer verfügt über genügend Insiderwissen (z. B. ein ehemaliger Mitarbeiter) und kann ein eigenes Image für ein Software-Update erstellen.
2. Das geänderte Software-Update wird über die normalen Offline-Diagnosetools in das Fahrzeug eingespielt.

Kompromittierte Cybersecurity-Eigenschaft und Ursache [RQ-15-03]:

Integrität: Eine manipulierte Software wird in das Fahrzeug eingespielt.

Beschreibung der Bedrohung (Schwachstelle/Angriffsmethode)	12.3 Die Software wird vor dem Aktualisierungsprozess manipuliert (und daher beschädigt), obwohl dieser intakt ist
Angriffsvektor:	Lokal

Beispiel eines Angriffspfads [WP-15-05]:

1. Der Angreifer manipuliert eine Software-Update-Binärdatei auf dem OEM- oder Lieferanten-Backend-Server, also fügt eine Schadroutine in diese ein.
2. Der Angreifer erzeugt eine gültige Signatur für das zuvor manipulierte Software-Update-Binärdatei und dieses wird mit Hilfe von standardmäßigen Over-the-Air-Update-Mechanismen in die Fahrzeuge installiert.

Kompromittierte Cybersecurity-Eigenschaft und Ursache [RQ-15-03]:

Vertraulichkeit: Der manipulierte Code kann unbefugten Zugriff auf Daten im Fahrzeug erhalten.

Integrität: Eine manipulierte Software kann in das Fahrzeug eingebracht werden.

Beschreibung der Bedrohung (Schwachstelle/Angriffsmethode)	12.4 Beeinträchtigung von kryptografischen Schlüsseln des Softwareanbieters, um eine ungültige Aktualisierung zu ermöglichen
Angriffsvektor:	Angrenzend

Beispiel eines Angriffspfads [WP-15-05]:

1. Ein interner Mitarbeiter oder ein Angreifer, der ausreichend Zugriff auf die Softwareerstellungsumgebung hat, nutzt den Signierungsprozess, um eine eigene Software-Binärdatei zu signieren.
2. Der Angreifer verwendet die gültige Software-Binärdatei, um sie in das Fahrzeug einzubringen.

Kompromittierte Cybersecurity-Eigenschaft und Ursache [RQ-15-03]:

Vertraulichkeit: Unbefugter Zugriff auf Daten ist möglich (z. B. könnte Software ungewollt Zugriff auf geschützte Bereiche erhalten).

Integrität: Manipulierte Software wird in das Fahrzeug eingebracht.

Tab. A.25 (Fortsetzung) Bedrohungskatalog aus der UN-Regelung Nr. 155, einschließlich unserer Beispiele für Angriffspfad, Cybersecurity-Eigenschaften und Angriffsvektor

13 Erwünschte Aktualisierungen können abgelehnt werden

Beschreibung der Bedrohung (Schwachstelle/Angriffsmethode)	13.1 Denial-of-Service-Attacke gegen den Aktualisierungsserver oder das Netzwerk, um wichtige Softwareaktualisierungen und/oder die Freigabe kundenspezifischer Funktionen zu verhindern
Angriffsvektor:	Netzwerk

Beispiel eines Angriffspfads [WP-15-05]:

1. Der Angreifer verfügt über spezifische Kenntnisse über die Backend-Dienste, wie z. B. verwendete Protokolle, IP-Adressen und grundlegende Schutzmechanismen.
2. Der Angreifer bereitet einen groß angelegten DDoS-Angriff gegen das Backend vor.

Kompromittierte Cybersecurity-Eigenschaft und Ursache [RQ-15-03]:

Verfügbarkeit: Die Software-Update-Dienste sind vorübergehend unterbrochen.

15¹ Berechtigte Akteure können ohne ihr Wissen Maßnahmen durchführen, die einen Cyberangriff begünstigen

Beschreibung der Bedrohung (Schwachstelle/Angriffsmethode)	15.1 Ein unschuldiges Opfer (z. B. Eigentümer, Bediener oder Wartungstechniker) wird zu einer Aktion verleitet, mit der unbeabsichtigt Malware geladen oder ein Angriff ermöglicht wird
Angriffsvektor:	Lokal

Beispiel eines Angriffspfads [WP-15-05]:

1. Der Angreifer kompromittiert den Kundendienst eines OEM und erhält eine Kundenliste, einschließlich der E-Mail-Adressen.
2. Der Angreifer sendet eine Phishing-Mail an jeden Kunden, einschließlich echter Namen und Fahrzeugkennzeichen.
3. In der Phishing-Mail wird erklärt, dass der Benutzer, um einige neue Funktionen des Fahrzeugs nutzen zu können, ein über einen Link bereitgestelltes Update herunterladen und über USB auf das Fahrzeug laden muss.
4. Der Nutzer lädt die Schadsoftware herunter und spielt diese in das Fahrzeug ein.

Kompromittierte Cybersecurity-Eigenschaft und Ursache [RQ-15-03]:

Integrität: Bösartige Software wird in das Fahrzeug eingebracht.

Beschreibung der Bedrohung (Schwachstelle/Angriffsmethode)	15.2 Festgelegte Sicherheitsverfahren werden nicht befolgt
Angriffsvektor:	Lokal

Beispiel eines Angriffspfads [WP-15-05]:

1. Das Verfahren zur Zuweisung von Serienschlüsseln in der Produktion durch eine Konfiguration in der Stückliste wurde nicht korrekt ausgeführt.
2. Das Steuergerät wird mit Serienschlüsseln und Schlüsseln produziert, die nur für die Entwicklung gedacht sind.
3. Der Angreifer, der sich der Schwachstelle bewusst ist, kann mit Entwicklungsschlüsseln auf das Steuergerät zugreifen.

Kompromittierte Cybersecurity-Eigenschaft und Ursache [RQ-15-03]:

Vertraulichkeit: Der unbefugter Zugriff auf Daten ist möglich.

Integrität: Eine Daten- bzw. Softwaremodifikation ist möglich.

Authentizität: Authentifizierungsmechanismen werden umgangen oder nicht wie erwartet verwendet.

¹ Der aufmerksame Leser mag sich fragen, warum die Zahl 14 fehlt. Das ist Absicht, denn die Bedrohung Nr. 14 ist in dem Dokument der UN-Regelung Nr. 155 tatsächlich nicht enthalten.

Tab. A.26 (Fortsetzung) Bedrohungskatalog aus der UN-Regelung Nr. 155, einschließlich unserer Beispiele für Angriffspfad, Cybersecurity-Eigenschaften und Angriffsvektor

16 Ermöglichung eines Cyberangriffs durch Manipulation der Vernetzung von Fahrzeugfunktionen; dazu gehören Telematiksysteme, Fernsteuerungssysteme und Systeme, die drahtlose Kommunikation mit geringer Reichweite nutzen

Beschreibung der Bedrohung (Schwachstelle/Angriffsmethode)	16.1 Manipulation von Fernbedienungs-funktionen für Systeme wie Funkschlüssel, Wegfahrsperre und Ladestation
Angriffsvektor:	Lokal

Beispiel eines Angriffspfads [WP-15-05]:

- 1. Der Angreifer führt eine Software-Manipulation der Konnektivitätseinheit des Fahrzeugs durch.
- 2. Die installierte Malware ist in der Lage, Remote-Funktionen zu steuern, z. B. Funktionen zu aktivieren oder zu deaktivieren, wenn der Angreifer dies wünscht.

Kompromittierte Cybersecurity-Eigenschaft und Ursache [RQ-15-03]:

Integrität: Die Integrität wird durch Manipulation der Software verletzt.
Verfügbarkeit: Remote-Funktionen sind teilweise oder vollständig nicht verfügbar.

Beschreibung der Bedrohung (Schwachstelle/Angriffsmethode)	16.2 Manipulation der Fahrzeugtelematik (z. B. Manipulation der Temperaturmessung empfindlicher Güter, ferngesteuertes Entriegeln von Frachttüren)
Angriffsvektor:	Lokal

Beispiel eines Angriffspfads [WP-15-05]:

- 1. Der Angreifer führt eine Manipulation der Software der Telematikeinheit durch.
- 2. Eine installierte Schadsoftware modifiziert die von der Telematikeinheit empfangenen Nachrichten.

Kompromittierte Cybersecurity-Eigenschaft und Ursache [RQ-15-03]:

Integrität: Die Software wird manipuliert.

Beschreibung der Bedrohung (Schwachstelle/Angriffsmethode)	16.3 Interferenzen mit drahtlosen Systemen oder Sensoren mit kurzer Reichweite
Angriffsvektor:	Angrenzend

Beispiel eines Angriffspfads [WP-15-05]:

- 1. Der Angreifer führt MITM auf drahtlosen Systemen mit kurzer Reichweite durch und kompromittiert ungeschützte Nachrichten.
- 2. Der Angreifer kann Nachrichten erstellen, die aussehen wie von Sensoren erzeugt, und das Fahrzeug erhält die falschen Sensormessungen.

Kompromittierte Cybersecurity-Eigenschaft und Ursache [RQ-15-03]:

Integrität: Sensor- oder Telematikmeldungen werden manipuliert.

Tab. A.27 (Fortsetzung) Bedrohungskatalog aus der UN-Regelung Nr. 155, einschließlich unserer Beispiele für Angriffspfad, Cybersecurity-Eigenschaften und Angriffsvektor

17 Gehostete Software von Drittanbietern, z. B. Unterhaltungsanwendungen, die zum Angriff auf Fahrzeugsysteme genutzt werden	
Beschreibung der Bedrohung (Schwachstelle/Angriffsmethode)	17.1 Manipulierte oder unsichere Anwendungen, die zum Angriff auf Fahrzeugsysteme genutzt werden
Angriffsvektor:	Lokal
Beispiel eines Angriffspfads [WP-15-05]:	
1. Der Angreifer erstellt eine bösartige Anwendung und stellt sie über die im Fahrzeug verwendete Anwendungsvertriebsplattform zur Verfügung.	
2. Der Endbenutzer installiert die Anwendung und verwendet sie.	
3. Die bösartige Anwendung führt einen Dienst aus, der es dem Angreifer ermöglicht, Zugriff auf das Fahrzeug zu erhalten.	
Kompromittierte Cybersecurity-Eigenschaft und Ursache [RQ-15-03]:	
<i>Vertraulichkeit:</i> Der Angreifer könnte Zugang zu sensiblen Daten erhalten, die im Fahrzeug gespeichert sind.	
<i>Integrität:</i> Die bösartige Anwendung oder der Angreifer kann andere Anwendungen oder das gesamte Fahrzeug kompromittieren.	
<i>Verfügbarkeit:</i> Einige Funktionen des Fahrzeugs könnten durch einen Folgeangriff, der durch die Malware ermöglicht wird, gestört werden.	
18 Mit externen Schnittstellen, z. B. USB- oder OBD-Anschlüssen, verbundene Geräte, die zum Angriff auf Fahrzeugsysteme genutzt werden	
Beschreibung der Bedrohung (Schwachstelle/Angriffsmethode)	18.1 Externe Schnittstellen wie USB-Anschlüsse oder andere als Angriffspunkte genutzte Anschlüsse, z. B. für Code-Injektion
Angriffsvektor:	Physisch
Beispiel eines Angriffspfads [WP-15-05]:	
1. Ein USB- oder OBD-Dongle, der zu Diagnosezwecken verwendet wird, enthält Schadsoftware und Konnektivitätsfunktionen.	
2. Der Endnutzer verbindet den Dongle und die Malware wird automatisch in Steuergeräten des Fahrzeugs installiert.	
3. Der Dongle mit seinen Verbindungsmöglichkeiten und die installierte Schadsoftware ermöglichen dem Angreifer den Fernzugriff auf das Fahrzeug.	
Kompromittierte Cybersecurity-Eigenschaft und Ursache [RQ-15-03]:	
<i>Vertraulichkeit:</i> Der Angreifer könnte Zugang zu sensiblen Daten erhalten, die im Fahrzeug gespeichert sind.	
<i>Integrität:</i> Die bösartige Anwendung oder der Angreifer kann andere Anwendungen oder das gesamte Fahrzeug kompromittieren.	
<i>Verfügbarkeit:</i> Einige Funktionen des Fahrzeugs könnten durch einen Folgeangriff, der durch die Malware ermöglicht wird, gestört werden.	

Tab. A.28 (Fortsetzung) Bedrohungskatalog aus der UN-Regelung Nr. 155, einschließlich unserer Beispiele für Angriffspfad, Cybersecurity-Eigenschaften und Angriffsvektor

18 Mit externen Schnittstellen, z. B. USB- oder OBD-Anschlüssen, verbundene Geräte, die zum Angriff auf Fahrzeugsysteme genutzt werden

Beschreibung der Bedrohung (Schwachstelle/Angriffsmethode)	18.2 Mit einem Virus infizierte Datenträger werden an ein Fahrzeugsystem angeschlossen
Angriffsvektor:	Physikalisch

Beispiel eines Angriffspfads [WP-15-05]:

- 1. Der Endbenutzer installiert eine Anwendung oder verbindet ein Gerät ein, welches Malware enthält.
- 2. Die bösartige Anwendung führt einen Dienst aus, der es dem Angreifer ermöglicht, Zugriff auf das Fahrzeug zu erhalten.

Kompromitierte Cybersecurity-Eigenschaft und Ursache [RQ-15-03]:

Vertraulichkeit: Der Angreifer könnte Zugang zu sensiblen Daten erhalten, die im Fahrzeug gespeichert sind.

Integrität: Die bösartige Anwendung oder der Angreifer kann andere Anwendungen oder das gesamte Fahrzeug kompromittieren.

Verfügbarkeit: Einige Funktionen des Fahrzeugs könnten durch einen Folgeangriff, der durch die Malware ermöglicht wird, gestört werden.

Tab. A.29 (Fortsetzung) Bedrohungskatalog aus der UN-Regelung Nr. 155, einschließlich unserer Beispiele für Angriffspfad, Cybersecurity-Eigenschaften und Angriffsvektor

18 Mit externen Schnittstellen, z. B. USB- oder OBD-Anschlüssen, verbundene Geräte, die zum Angriff auf Fahrzeugsysteme genutzt werden

Beschreibung der Bedrohung (Schwachstelle/Angriffsmethode)	18.3 Ein Diagnosezugang (z. B. Dongles am OBD-Anschluss) wird zur Begünstigung eines Angriffs genutzt, z. B. durch Manipulation von Fahrzeugparametern (direkt oder indirekt)
Angriffsvektor:	Lokal

Beispiel eines Angriffspfads [WP-15-05]:

1. Ein billiger OBD-Dongle, der für Diagnosezwecke verwendet wird, enthält Malware und Konnektivitätsfunktionen.
2. Der Endnutzer steckt den Dongle ein, und die Malware wird automatisch in anderen Steuergeräten des Fahrzeugs installiert.
3. Der Dongle mit seinen Konnektivitätsfunktionen und die installierte Schadsoftware ermöglichen dem Angreifer den Fernzugriff auf das Fahrzeug.

Kompromittierte Cybersecurity-Eigenschaft und Ursache [RQ-15-03]:

Vertraulichkeit: Der Angreifer könnte Zugang zu sensiblen Daten erhalten, die im Fahrzeug gespeichert sind.

Integrität: Die bösartige Anwendung oder der Angreifer kann andere Anwendungen oder das gesamte Fahrzeug kompromittieren.

Verfügbarkeit: Einige Funktionen des Fahrzeugs könnten durch einen Folgeangriff, der durch die Malware ermöglicht wird, gestört werden.

19 Extraktion von Fahrzeugdaten/-code

Beschreibung der Bedrohung (Schwachstelle/Angriffsmethode)	19.1 Extraktion von urheberrechtlich geschützter oder proprietärer Software aus Fahrzeugsystemen (Produktpiraterie)
Angriffsvektor:	Physisch

Beispiel eines Angriffspfads [WP-15-05]:

1. Der Angreifer demontiert ein Steuergerät aus dem Fahrzeug.
2. Der Angreifer verbindet sich mit dem Steuergerät und erhält Zugriff auf ungeschützte Daten und Software-Binärdateien.
3. Reverse Engineering wird an der Binärdatei durchgeführt.

Kompromittierte Cybersecurity-Eigenschaft und Ursache [RQ-15-03]:

Vertraulichkeit: Die Funktionsweise der Software wird dem Angreifer offenbart. Außerdem könnten sensible Daten ausgelesen werden.

Beschreibung der Bedrohung (Schwachstelle/Angriffsmethode)	19.2 Unbefugter Zugriff auf die personenbezogenen Daten des Eigentümers wie persönliche Identität, Kontodaten, Adressbuchdaten, Standortdaten, elektronische Fahrzeugkennung usw
Angriffsvektor:	Physisch

Beispiel eines Angriffspfads [WP-15-05]:

1. Der Angreifer demontiert ein Steuergerät aus dem Fahrzeug.
2. Der Angreifer stellt eine Verbindung zum Steuergerät her und erhält Zugriff auf ungeschützte Daten.

Kompromittierte Cybersecurity-Eigenschaft und Ursache [RQ-15-03]:

Vertraulichkeit: Verlust der Vertraulichkeit durch unbefugten Zugriff auf personenbezogene und personenbeziehbare Daten oder andere sensible Daten.

Tab. A.30 (Fortsetzung) Bedrohungskatalog aus der UN-Regelung Nr. 155, einschließlich unserer Beispiele für Angriffspfad, Cybersecurity-Eigenschaften und Angriffsvektor

19 Extraktion von Fahrzeugdaten/-code	
Beschreibung der Bedrohung (Schwachstelle/Angriffsmethode)	19.3 Extraktion kryptografischer Schlüssel
Angriffsvektor:	Physikalisch
Beispiel eines Angriffspfads [WP-15-05]:	
1. Angreifer hat lokalen Zugriff auf eine ECU.	
2. Diagnose- oder Debugging-Schnittstelle/Protokoll wird ausgenutzt.	
3. Es werden ungenügend geschützte kryptografische Schlüssel extrahiert (z.B. Credentials für die Kommunikation mit Backend-Servern).	
Kompromitierte Cybersecurity-Eigenschaft und Ursache [RQ-15-03]:	
<i>Vertraulichkeit:</i> Die Vertraulichkeit wird durch unbefugten Zugriff auf sensible Informationen verletzt.	
<i>Authentizität:</i> Die Authentizität wird aufgrund von unbefugtem Zugriff über eine manipulierte Schnittstelle verletzt.	
20 Manipulation von Fahrzeugdaten/-code	
Beschreibung der Bedrohung (Schwachstelle/Angriffsmethode)	20.1 Illegale/unbefugte Änderungen der elektronischen Fahrzeugkennung
Angriffsvektor:	Physikalisch
Beispiel eines Angriffspfads [WP-15-05]:	
1. Der Angreifer verschafft sich unbefugten Zugriff auf die ungeschützte Diagnoseschnittstelle eines Steuergeräts.	
2. Durch die Ausweitung der Berechtigungen kann der Angreifer Änderungen an den gespeicherten Daten vornehmen.	
Kompromitierte Cybersecurity-Eigenschaft und Ursache [RQ-15-03]:	
<i>Integrität:</i> Die Integrität wird durch Veränderung von Daten verletzt.	
<i>Verfügbarkeit:</i> Eine echte ID wird geändert und ist nicht mehr verfügbar.	
<i>Authentizität:</i> Durch unbefugten Zugriff über nicht ausreichend geschützte Schnittstelle wird die Authentizität verletzt.	
Beschreibung der Bedrohung (Schwachstelle/Angriffsmethode)	20.2 Identitätsbetrug, z. B. wenn ein Nutzer bei der Kommunikation mit Mautsystemen oder dem Back-End des Herstellers eine abweichende Identität anzeigen will
Angriffsvektor:	Physisch
Beispiel eines Angriffspfads [WP-15-05]:	
1. Der Angreifer verschafft sich unbefugten Zugriff auf die ungeschützte Diagnoseschnittstelle eines Steuergeräts.	
2. Durch die Ausweitung der Berechtigungen kann der Angreifer Änderungen an den gespeicherten Daten vornehmen.	
3. Der Angreifer gibt sich als eine andere gültige Identität aus und kommuniziert mit den Backend-Systemen.	
Kompromitierte Cybersecurity-Eigenschaft und Ursache [RQ-15-03]:	
<i>Integrität:</i> Die Integrität wird durch Veränderung von Daten verletzt.	
<i>Authentizität:</i> Durch unbefugten Zugriff über eine nicht ausreichend geschützte Schnittstelle wird die Authentizität verletzt.	

Tab. A.31 (Fortsetzung) Bedrohungskatalog aus der UN-Regelung Nr. 155, einschließlich unserer Beispiele für Angriffspfad, Cybersecurity-Eigenschaften und Angriffsvektor

20 Manipulation von Fahrzeugdaten/-code

Beschreibung der Bedrohung (Schwachstelle/Angriffsmethode)	20.3 Aktionen zur Umgehung von Überwachungssystemen (z. B. Hacking/Manipulation/Blockierung von Nachrichten wie ODR-Tracker-Daten oder Anzahl der Fahrten)
Angriffsvektor:	Physisch

Beispiel eines Angriffspfads [WP-15-05]:

1. Der Angreifer verschafft sich unbefugten Zugriff auf die ungeschützte Diagnoseschnittstelle eines Steuergeräts.
2. Durch die Ausweitung der Berechtigungen kann der Angreifer Änderungen an den gespeicherten Daten vornehmen.

Kompromittierte Cybersecurity-Eigenschaft und Ursache [RQ-15-03]:

Integrität: Die Integrität wird durch Veränderung von Daten verletzt.

Verfügbarkeit: Eine echte ID wird geändert und ist nicht mehr verfügbar.

Authentizität: Durch unbefugten Zugriff über eine nicht ausreichend geschützte Schnittstelle wird die Authentizität verletzt.

Beschreibung der Bedrohung (Schwachstelle/Angriffsmethode)	20.4 Datenmanipulation zur Fälschung der Fahrdaten des Fahrzeugs (z. B. Kilometerstand, Fahrgeschwindigkeit, Fahrtrichtung usw.)
Angriffsvektor:	Physisch

Beispiel eines Angriffspfads [WP-15-05]:

1. Der Angreifer installiert eine Malware über das Infotainment-Steuergerät (z. B. über ein USB-Medium).
2. Die Malware infiziert andere Steuergeräte und erhält Schreibzugriff.
3. Darüber hinaus ist die Malware in der Lage, manipulierte Nachrichten in den Fahrzeugbus einzuschleusen.

Kompromittierte Cybersecurity-Eigenschaft und Ursache [RQ-15-03]:

Integrität: Software und Daten im Fahrzeug werden verändert. Darüber hinaus werden falsche Fahrdaten geliefert.

Verfügbarkeit: Echte Fahrdaten sind nicht verfügbar.

Beschreibung der Bedrohung (Schwachstelle/Angriffsmethode)	20.5 Unbefugte Änderungen von Systemdiagnosedaten
Angriffsvektor:	Physikalisch

Beispiel eines Angriffspfads [WP-15-05]:

1. Der Angreifer verschafft sich unbefugten Zugriff auf die ungeschützte Diagnoseschnittstelle eines Steuergeräts.
2. Durch die Ausweitung der Berechtigungen kann der Angreifer Änderungen an den gespeicherten Daten vornehmen.

Kompromittierte Cybersecurity-Eigenschaft und Ursache [RQ-15-03]:

Integrität: Die Integrität wird durch Veränderung von Daten verletzt.

Authentizität: Durch unbefugten Zugriff über eine nicht ausreichend geschützte Schnittstelle wird die Authentizität verletzt.

Tab. A.32 (Fortsetzung) Bedrohungskatalog aus der UN-Regelung Nr. 155, einschließlich unserer Beispiele für Angriffspfad, Cybersecurity-Eigenschaften und Angriffsvektor

21 Löschung von Daten/Code

Beschreibung der Bedrohung (Schwachstelle/Angriffsmethode)	21.1 Unbefugtes Löschen/Manipulieren von Systemereignisprotokollen
Angriffsvektor:	Physikalisch

Beispiel eines Angriffspfads [WP-15-05]:

1. Der Angreifer verschafft sich unbefugt Schreibzugriff auf die ungeschützte Diagnoseschnittstelle eines Steuergeräts.
2. Der Angreifer modifiziert die Logs des Steuergeräts oder mehrerer Steuergeräte.

Kompromitierte Cybersecurity-Eigenschaft und Ursache [RQ-15-03]:

Integrität: Die Integrität wird durch Veränderung von Daten verletzt.

Verfügbarkeit: Die Verfügbarkeit ist aufgrund der Löschung von Logfiles verletzt.

Authentizität: Durch unbefugten Zugriff über eine nicht ausreichend geschützte Schnittstelle wird die Authentizität verletzt.

22 Einspeisung von Malware

Beschreibung der Bedrohung (Schwachstelle/Angriffsmethode)	22.2 Einspeisung von Schadsoftware oder Schadsoftwareaktivitäten
Angriffsvektor:	Physikalisch

Beispiel eines Angriffspfads [WP-15-05]:

1. Der Angreifer verbindet sich mit dem Steuergerät über einen zur Verfügung stehenden ungeschützten Kommunikationskanal.
2. Der Angreifer modifiziert die Software-Binärdatei oder schleust Malware ein.

Kompromitierte Cybersecurity-Eigenschaft und Grund [RQ-15-03]:

Integrität: Die Integrität ist durch Manipulation von Software verletzt.

Verfügbarkeit: Die Verfügbarkeit ist verletzt, weil die ursprüngliche Software-Binärdatei manipuliert wurde.

Authentizität: Durch unbefugten Zugriff über eine nicht ausreichend geschützte Schnittstelle wird die Authentizität verletzt.

23 Einspeisung neuer Software oder Überschreiben vorhandener Software

Beschreibung der Bedrohung (Schwachstelle/Attack method)	23.1 Fälschung der Software des Fahrzeugsteuerungs- oder -informationssystems
Angriffsvektor:	Physikalisch

Beispiel eines Angriffspfads [WP-15-05]:

1. Der Angreifer verbindet sich mit dem Steuergerät über einen zur Verfügung stehenden ungeschützten Kommunikationskanal.
2. Der Angreifer erstellt eine gültige Software-Binärdatei.
3. Die manipulierte Software-Binärdatei wird in das Steuergerät eingeschleust.

Kompromitierte Cybersecurity-Eigenschaft und Ursache [RQ-15-03]:

Integrität: Die Integrität ist durch Manipulation von Software verletzt.

Verfügbarkeit: Die Verfügbarkeit ist verletzt, weil die ursprüngliche Software-Binärdatei manipuliert wurde.

Authentizität: Durch unbefugten Zugriff über eine nicht ausreichend geschützte Schnittstelle wird die Authentizität verletzt.

Tab. A.33 (Fortsetzung) Bedrohungskatalog aus der UN-Regelung Nr. 155, einschließlich unserer Beispiele für Angriffspfad, Cybersecurity-Eigenschaften und Angriffsvektor

24 Störung von Systemen oder Vorgängen

Beschreibung der Bedrohung (Schwachstelle/Angriffsmethode)	24.1 Denial-of-Service-Attacken, die im internen Netzwerk z.B. durch Überlastung eines CAN-Busses oder durch Provozieren von Störungen an einem elektronischen Steuergerät aufgrund großer Nachrichtenmengen ausgelöst werden kann
Angriffsvektor:	Angrenzend

Beispiel eines Angriffspfads [WP-15-05]:

1. Der Angreifer verschafft sich Zugriff auf den CAN-Bus des Fahrzeugs.
2. Über ein manipuliertes Steuergerät oder ein spezielles Gerät führt der Angreifer ein Flooding auf dem CAN-Bus durch.

Kompromittierte Cybersecurity-Eigenschaft und Ursache [RQ-15-03]:

Verfügbarkeit: Die fahrzeuginterne Kommunikation ist aufgrund des Floodings auf dem Bus nicht möglich.

25 Manipulation von Fahrzeugparametern

Beschreibung der Bedrohung (Schwachstelle/Angriffsmethode)	25.1 Unbefugter Zugriff zur Verfälschung der Konfigurationsparameter von Schlüsselfunktionen des Fahrzeugs, wie z. B. Bremsdaten, Airbag-Auslöseschwelle usw
Angriffsvektor:	Physisch

Beispiel eines Angriffspfads [WP-15-05]:

1. Der Angreifer installiert eine Malware über das Infotainment-Steuergerät (z. B. über ein USB-Medium).
2. Die Schadsoftware verändert die Funktion des Fahrzeugs in einigen Steuergeräten.

Integrität: Die Integrität wird durch Modifikation von Software und Daten des Fahrzeugs verletzt.

Verfügbarkeit: Die Verfügbarkeit ist verletzt, weil die unmanipulierten Daten nicht verfügbar sind.

Beschreibung der Bedrohung (Schwachstelle/Angriffsmethode)	25.2 Unbefugter Zugriff zur Verfälschung der Ladeparameter, z. B. Ladespannung, Ladeleistung, Batterietemperatur usw
Angriffsvektor:	Physisch

Beispiel eines Angriffspfads [WP-15-05]:

1. Der Angreifer verbindet sich mit dem Steuergerät über einen zur Verfügung stehenden ungeschützten Kommunikationskanal.
2. Der Angreifer kann Daten im Steuergerät verändern.

Kompromittierte Cybersecurity-Eigenschaft und Ursache [RQ-15-03]:

Integrität: Die Integrität wird durch Manipulation von Daten verletzt.

Verfügbarkeit: Die Verfügbarkeit ist verletzt, weil die unmanipulierten Daten nicht verfügbar sind.

Authentizität: Durch unbefugten Zugriff über eine nicht ausreichend geschützte Schnittstelle ist die Authentizität verletzt.

Tab. A.34 (Fortsetzung) Bedrohungskatalog aus der UN-Regelung Nr. 155, einschließlich unserer Beispiele für Angriffspfad, Cybersecurity-Eigenschaften und Angriffsvektor

26 Kryptografische Technologien können beeinträchtigt werden oder werden unzureichend angewendet

Beschreibung der Bedrohung (Schwachstelle/Attack method)	26.1 Eine Kombination aus kurzen Verschlüsselungscodes und langen Gültigkeitszeiträumen ermöglicht es dem Angreifer, die Verschlüsselung zu knacken
Angriffsvektor:	Physisch

Beispiel eines Angriffspfads [WP-15-05]:

1. Der Angreifer nutzt kompromitierbare kryptographische Schlüssel und Algorithmen aus.
2. Der Angreifer erhält vollen Zugriff auf das Gerät, z. B. um neue Software zu schreiben.

Kompromittierte Cybersecurity-Eigenschaft und Ursache [RQ-15-03]:

Vertraulichkeit: Unbefugter Zugang zu sensiblen Daten aufgrund einer defekten Verschlüsselung verletzt die Vertraulichkeit.

Integrität: Daten können durch Angreifer in einer nachfolgenden Aktion verändert werden und damit die Integrität verletzen.

Verfügbarkeit: Verfügbarkeitsverlust, weil Steuergeräte oder Daten auf den Steuergeräten nicht mehr verfügbar sind.

Authentizität: Authentizitätsverlust durch unautorisierter Zugriff aufgrund von gebrochener Kryptographie.

Beschreibung der Bedrohung (Schwachstelle/Angriffsmethode)	26.2 Unzureichender Einsatz kryptografischer Algorithmen zum Schutz sensibler Systeme
Angriffsvektor:	Physisch

Beispiel eines Angriffspfads [WP-15-05]:

1. Der Angreifer nutzt kryptographische Schlüssel und Algorithmen aus.
2. Der Angreifer erhält vollen Zugriff auf das Gerät, z. B. um neue Software zu schreiben.

Kompromittierte Cybersecurity-Eigenschaft und Ursache [RQ-15-03]:

Vertraulichkeit: Unbefugter Zugang zu sensiblen Daten aufgrund einer defekten Verschlüsselung.

Integrität: Daten können durch Angreifer in einer nachfolgenden Aktion verändert werden.

Verfügbarkeit: Steuergeräte oder Daten auf den Steuergeräten könnten nicht mehr verfügbar sein.

Authentizität: Unautorisierter Zugriff aufgrund von gebrochener Kryptographie.

Beschreibung der Bedrohung (Schwachstelle/Angriffsmethode)	26.3 Verwendung kryptografischer Algorithmen, die bereits veraltet sind oder es bald sein werden
Angriffsvektor:	Physisch

Beispiel eines Angriffspfads [WP-15-05]:

1. Der Angreifer nutzt kryptographische Schlüssel und Algorithmen aus.
2. Der Angreifer erhält vollen Zugriff auf das Gerät, z. B. um neue Software zu schreiben.

Kompromittierte Cybersecurity-Eigenschaft und Ursache [RQ-15-03]:

Vertraulichkeit: Unbefugter Zugang zu sensiblen Daten aufgrund einer defekten Verschlüsselung.

Integrität: Daten können durch Angreifer in einer nachfolgenden Aktion verändert werden.

Verfügbarkeit: Steuergeräte oder Daten auf den Steuergeräten könnten nicht mehr verfügbar sein.

Authentizität: Unautorisierter Zugriff aufgrund von gebrochener Kryptographie.

Tab. A.35 (Fortsetzung) Bedrohungskatalog aus der UN-Regelung Nr. 155, einschließlich unserer Beispiele für Angriffspfad, Cybersecurity-Eigenschaften und Angriffsvektor

27 Teile oder Zubehör könnten beeinträchtigt werden, um Angriffe auf Fahrzeuge zu ermöglichen

Beschreibung der Bedrohung (Schwachstelle/Angriffsmethode)	27.1 Hardware oder Software, die entwickelt wurde, um einen Angriff zu ermöglichen, oder die so konzipiert ist, dass sie die Kriterien zur Beendigung eines Angriffs nicht erfüllt
Angriffsvektor:	Physisch

Beispiel eines Angriffspfads [WP-15-05]:

1. Der Angreifer erhält Insiderinformationen über technische Betriebsdetails einer Fahrzeugfunktion.
2. Der Angreifer schreibt eine Schadsoftware, die in der Lage ist, unzureichende Schutzmaßnahmen zu umgehen.
3. Die Fahrzeugfunktion wird kompromittiert.

Kompromittierte Cybersecurity-Eigenschaft und Grund [RQ-15-03]:

Integrität: Die Software oder Daten (z. B. Parameter) werden verändert.

Verfügbarkeit: Ein Fahrzeug wird teilweise oder vollständig außer Betrieb gesetzt.

28 Software- oder Hardwareentwicklung führt zu Schwachstellen

Beschreibung der Bedrohung (Schwachstelle/Angriffsmethode)	28.1 Softwarefehler. Vorhandene Softwarefehler können die Grundlage für potenziell nutzbare Schwachstellen bilden. Dies trifft insbesondere dann zu, wenn die Software nicht getestet wurde, um bekannten, fehlerhaften Code bzw. Programmfehler zu finden bzw. das Risiko von unbekanntem, fehlerhaftem Code bzw. Programmfehlern zu verringern
Angriffsvektor:	Physisch

Beispiel eines Angriffspfads [WP-15-05]:

1. Der Angreifer führt intensive Nachforschungen über ein bestimmtes Steuergerät durch, bis ein Fehler gefunden wird.
2. Der Angreifer schreibt eine Malware zur Ausnutzung des Steuergeräts und erhält Schreibzugriff.
3. Eine modifizierte Software-Binärdatei wird in das Steuergerät eingeschleust und kompromittiert den Rest des Fahrzeugs.

Kompromittierte Cybersecurity-Eigenschaft und Ursache [RQ-15-03]:

Vertraulichkeit: Sensible Daten könnten offengelegt werden.

Integrität: Software wird manipuliert oder Malware wird eingeschleust.

Verfügbarkeit: Ein Fahrzeug wird teilweise oder ganz außer Betrieb gesetzt.

Authentizität: Authentifizierungsmechanismen werden ausgenutzt oder umgangen.

Beschreibung der Bedrohung (Schwachstelle/Angriffsmethode)	28.2 Überbleibsel aus der Entwicklungsphase (z. B. Debug-Ports, JTAG-Ports, Mikroprozessoren, Entwicklungszertifikate, Entwicklerpasswörter usw.) können Angreifern ermöglichen, auf elektronische Steuergeräte zuzugreifen oder sich höhere Berechtigungen zu verschaffen
Angriffsvektor:	Physisch

Beispiel eines Angriffspfads [WP-15-05]:

1. Der Angreifer führt intensive Nachforschungen über ein bestimmtes Steuergerät durch, bis ein Fehler gefunden wird.
2. Der Angreifer kann eine Debugging-Schnittstelle ausnutzen und erhält Schreibzugriff auf das Steuergerät.
3. Eine modifizierte Software-Binärdatei wird in das Steuergerät eingeschleust und kompromittiert den Rest des Fahrzeugs.

Kompromittierte Cybersecurity-Eigenschaft und Ursache [RQ-15-03]:

Vertraulichkeit: Sensible Daten könnten offengelegt werden.

Integrität: Software wird manipuliert oder Malware wird eingeschleust.

Verfügbarkeit: Ein Fahrzeug wird teilweise oder ganz außer Betrieb gesetzt.

Authentizität: Authentifizierungsmechanismen werden ausgenutzt oder umgangen.

Tab. A.36 (Fortsetzung) Bedrohungskatalog aus der UN-Regelung Nr. 155, einschließlich unserer Beispiele für Angriffspfad, Cybersecurity-Eigenschaften und Angriffsvektor

29 Entstehen von Schwachstellen durch das Netzwerkdesign

Beschreibung der Bedrohung (Schwachstelle/Angriffsmethode)	29.1 Überflüssige, offen gelassene Internetanschlüsse bieten Zugang zu Netzwerksystemen
Angriffsvektor:	Netzwerk

Beispiel eines Angriffspfads [WP-15-05]:

1. Der Angreifer führt einen Aufklärungs- und Port-Scan an der Head-Unit des Fahrzeugs durch.
2. Ein sehr relevanter Port, z. B. für SSH, ist offen, und der Angreifer stellt eine Verbindung zu ihm her.

Kompromittierte Cybersecurity-Eigenschaft und Ursache [RQ-15-03]:

Vertraulichkeit: Sensible Daten könnten offengelegt werden.

Integrität: Software wird manipuliert oder Malware wird eingeschleust.

Verfügbarkeit: Ein Fahrzeug wird teilweise oder ganz außer Betrieb gesetzt.

Beschreibung der Bedrohung (Schwachstelle/Angriffsmethode)	29.2 Umgehung der Netzwerktrennung, um Kontrolle zu erlangen. Ein spezifisches Beispiel ist die Nutzung ungeschützter Gateways oder Zugangspunkte (wie z. B. LKW-Anhänger-Gateways), um Schutzmaßnahmen zu umgehen und Zugang zu anderen Netzwerksegmenten zu erhalten und schädliche Aktionen durchzuführen, wie z. B. willkürliche CAN-Bus-Nachrichten zu senden
Angriffsvektor:	Angrenzend

Beispiel eines Angriffspfads [WP-15-05]:

1. Der Angreifer schließt ein externes Gerät an das Netzwerk des Fahrzeugs an (z. B. CAN- oder Ethernet-Netzwerk).
2. Eine Schwachstelle oder eine falsche Konfiguration am Fahrzeug-Gateway ermöglicht den Zugriff auf Steuergeräte hinter dem Gateway.
3. Der Angreifer kann Code einfügen oder unbefugte Signale an die Steuergeräte senden.

Kompromittierte Cybersecurity-Eigenschaft und Ursache [RQ-15-03]:

Integrität: Ein Fahrzeug oder ECU können beschädigt werden.

Verfügbarkeit: Ein Fahrzeug wird teilweise oder ganz außer Betrieb gesetzt.

30 Bedrohungen im Zusammenhang mit physischen Datenverlusten

Beschreibung der Bedrohung (Schwachstelle/Angriffsmethode)	30.1 Verursachung von Schäden durch Dritte. Durch physische Schäden, die etwa bei Verkehrsunfällen oder Diebstahl entstehen, können sensible Daten verloren gehen oder beeinträchtigt werden
Angriffsvektor:	Physisch

Beispiel eines Angriffspfads [WP-15-05]:

1. Der Angreifer verbindet sich physisch mit dem Speicher und liest sensible Daten aus.

Kompromittierte Cybersecurity-Eigenschaft und Ursache [RQ-15-03]:

Vertraulichkeit: Vertraulichkeitsverlust durch unbefugten Zugriff auf sensible Daten.

Tab. A.37 (Fortsetzung) Bedrohungskatalog aus der UN-Regelung Nr. 155, einschließlich unserer Beispiele für Angriffspfad, Cybersecurity-Eigenschaften und Angriffsvektor

30 Bedrohungen im Zusammenhang mit physischen Datenverlusten

Beschreibung der Bedrohung (Schwachstelle/Angriffsmethode)	30.2 Verluste durch DRM-Konflikte (Digital Rights Management, digitale Rechteverwaltung). Benutzerdaten können aufgrund von DRM-Problemen gelöscht werden
Angriffsvektor:	Physisch

Beispiel eines Angriffspfads [WP-15-05]:

1. Der Angreifer entfernt ein Steuergerät wie das Infotainment-System.
2. Der Angreifer ist im Besitz vertraulicher Informationen über die Hardware des Steuergeräts.
3. Der Angreifer nimmt eine HW-Änderung an dem Speicherbereich vor, in dem die DRM-Informationen gespeichert sind.

Kompromitierte Cybersecurity-Eigenschaft und Ursache [RQ-15-03]:

Integrität: Integritätsverlust aufgrund physischer Veränderung.

Verfügbarkeit: DRM-Informationen sind nicht mehr verfügbar.

Beschreibung der Bedrohung (Schwachstelle/Angriffsmethode)	30.3 Sensible Daten bzw. deren Integrität können durch Abnutzung von IT-Komponenten verloren gehen, was zu kaskadierenden Problemen führen kann (z. B. bei Schlüsseländerungen)
Angriffsvektor:	Physisch

Beispiel eines Angriffspfads [WP-15-05]:

1. Der Angreifer ist ein Insider, der die Problematik der nicht ordnungsgemäß funktionierenden IT-Komponenten kennt.
2. Der Angreifer nutzt dies aus und ist in der Lage, gültige Token für die Aktivierung von Funktionen in Fahrzeugen zu erstellen.
3. Die Token werden auf dem illegalen Markt verkauft.

Kompromitierte Cybersecurity-Eigenschaft und Ursache [RQ-15-03]:

Integrität: Ein Mechanismus zur Aktivierung von Funktionen wird beschädigt.

Authentizität: Authentifizierungsmechanismen auf älteren Geräten werden umgangen.

31 Mögliche unbeabsichtigte Übertragung von Daten

Beschreibung der Bedrohung (Schwachstelle/Angriffsmethode)	31.1 Informationssicherheitslücken. Personenbezogene Daten können bei einem Wechsel des Fahrzeugnutzers (z. B. durch Verkauf oder Neuvermietung) in die falschen Hände geraten
Angriffsvektor:	Physisch

Beispiel eines Angriffspfads [WP-15-05]:

1. Der Angreifer führt einen intensiven Penetrationstest am Fahrzeugs durch.
2. Persönliche Daten älterer Nutzer werden in einigen Steuergeräten noch für verschiedene Zwecke gespeichert.
3. Der Angreifer erhält schließlich Zugang zu den personenbezogenen und personenbeziehbaren Daten.

Kompromitierte Cybersecurity-Eigenschaft und Grund [RQ-15-03]:

Vertraulichkeit: Unbefugter Zugriff auf personenbezogene und personenbeziehbare Daten.

Authentizität: Defekte oder unzureichende Authentifizierungsmechanismen.

Tab. A.38 (Fortsetzung) Bedrohungskatalog aus der UN-Regelung Nr. 155, einschließlich unserer Beispiele für Angriffspfad, Cybersecurity-Eigenschaften und Angriffsvektor

32 Ermöglichung eines Angriffs durch physische Manipulation	
Beschreibung der Bedrohung (Schwachstelle/Angriffsmethode)	32.1 Manipulation elektronischer Hardware, z. B. wenn in einem Fahrzeug unzulässige elektronische Hardware hinzugefügt wird, um einen Man-in-the-Middle-Angriff zu ermöglichen Austausch zulässiger elektronischer Hardware (z. B. Sensoren) durch unzulässige elektronische Hardware Manipulation der von einem Sensor erfassten Daten (z. B. wenn mittels eines Magneten der am Getriebe angebrachte Hall-Sensor manipuliert wird)
Angriffsvektor:	Physisch
Beispiel eines Angriffspfads [WP-15-05]:	
1. Der Angreifer öffnet das Steuergerät eines Fahrzeugs.	
2. Eine manipulierte Software wird in das Steuergerät eingebaut oder ein zusätzliches elektronisches Gerät wird so montiert, dass es Daten während der Übertragung einschleusen oder verändern kann.	
Kompromittierte Cybersecurity-Eigenschaft und Ursache [RQ-15-03]:	
Integrität: Ein Fahrzeug oder eine ECU können beschädigt werden.	
Verfügbarkeit: Ein Fahrzeug wird teilweise oder ganz außer Betrieb gesetzt.	

Stichwortverzeichnis

A

Abhören, 167
Abstreitbarkeit, 163, 167
Advanced Persistent Threat (APT), 76
Akteur
 cyberkriminelle, 161
 staatlich gesponserte, 161
Aktoren, 109, 113
Aktualisierungsprozess, 193
Amazon® Web Services, 72, 160
Analyse, statistische, 213
Android™, 160
Anforderung, 56
Angestellte, 75
Angreifer, 76
Angreifermodell, 64, 74, 76, 185
Angrenzend, 181
Angriffsbäum, 165, 170
 Effizienz, 171
Angriffskomplexität, 180, 181
Angriffsmethode, 159, 189
Angriffsoberfläche, 157
Angriffspfad, 119, 153, 154, 158, 160, 168, 169, 189, 208
 technisches Niveau, 51
Angriffspotenzial-basierter Ansatz, 173, 174, 184, 185
Angriffspotenzialwert, 79
Angriffspotenzialzuordnung, 77
Angriffsvektor, 41, 157, 159, 180, 182, 183
Annahmen, 64, 65

Ansatz

 angriffsvektorbasierter, 173, 183
 CVSS-basierter, 173
Anwendungen, 112
Anwendungen von Drittanbietern, 108
Anwendungssoftware, 189
APT (Advanced Persistent Threat), 76
ASIL (Automotive Safety Integrity Levels), 18
ASRG (Automotive Security Research Group), 162
Assets, 56, 95, 119, 153, 154, 158, 188, 208
 Automotive Embedded Devices, 100
 Daten als, 104
 Definition, 97
 Gruppierung, 49
 Identifikation, 96
 Katalog, 100, 241
 Statistiken, 215
Attack Path Analysis, 168
Auftragshacker, 76
Ausrüstung, 179, 184
Auswirkung, vernachlässigbare, 211
Authentifizierung, 117
Authentizität, 117, 164, 167, 189, 193, 195, 226
Auto-ISAC, 162
Automobilindustrie, 167
Automobilproduktionsanlage, 197

Automotive Safety Integrity Levels (ASIL),
18

Automotive Security Research Group
(ASRG), 162

Autorisierung, 117, 164

B

Backdoor, 159

Backend-Server, 47, 159, 190

Backend-System, 161

Bedrohung, 49, 56, 153, 154, 157, 159, 160,
162, 163, 193

Identifikation von, 154, 155, 158

Modellierung von, 154, 155

physische, 161

Bedrohungsgruppe, 167

Bedrohungskatalog, 157, 158, 189, 256

Bedrohungslandschaft, 46

Bedrohungsmodellierung, 158

Bedrohungsstufe, 76, 185

Bedrohungsszenario, 47, 49, 50, 119, 153,
154, 158, 170, 208, 213, 237

Bewertung, 153

Modellierung, 153

Benutzereinwirkung, 180, 182

Benutzeroberfläche, 111

Benutzerprofildaten, 106

Besitz oder Kontrolle, 117

Betrieb, 123, 125, 127

Betriebssystem, 111

Betriebsumgebung, 156

Bewertung

CVSS-basierte, 185

der Angriffsmachbarkeit, 154, 182, 183,
188–190, 208, 228

des Schadens, 121

BIA (Business Impact Analysis), 28

Bill of Materials (BOM), 112, 144

Bluetooth, 71, 103, 158, 195

BOM (Bill of Materials), 112, 144

Bootloader, 108

Brainstorming, 154, 156, 157, 159, 193

Brainstorming-Session, 189

BSI-Standard

200-1, 27

200-3, 27

Business Continuity, 28

Business Continuity Planning, 148

Business Impact Analysis (BIA), 28

C

CAL (Cybersecurity Assurance Level), 19, 20

CAN, 49, 68, 69, 101, 104, 118, 156, 158

Nachrichten, 159

CAN-Bus, 138

CAN FD, 69

Cloud, 196

Cloud-Dienst, 196

Code-Injektion, 196, 200

Command Line Interfaces, 200

Common Weakness Enumeration (CWE),
161

CRA (Cyber Resilience Act), 5

CSIA (Cybersecurity Interface Agreement),
70

CSMS (Cybersecurity Management System),
8, 17, 20, 29

CVSS (Common Vulnerability Scoring Sys-
tem), 179, 182

Ausnutzbarkeit-Wert, 180, 182

Base, 179

Basierter Ansatz, 179

Environmental, 179

Exploitability-Metriken, 180

Score, 180

Temporal, 179

CWE (Common Weakness Enumeration),
161

Cyber Resilience Act (CRA), 5

Cyberkrimineller, 76

Cybersecurity, 43

Analyst, 62

Anforderungen, 31

Assurance-Level (CAL), 19, 20

Aussage, 67, 231, 237

detektive Maßnahmen, 227

Eigenschaft, 97, 117, 153, 208

in der Automobilindustrie, 37

Interface-Agreement (CSIA), 9, 70

korrektive Maßnahmen, 227

Maßnahmen, 31, 47, 49, 67, 225–228, 237

präventive Maßnahmen, 227

Resilience Act (CRA), 5

Richtlinie, 214

Risiko, 154, 160
Risikomanagement, 42
Team, 62, 98, 155, 156, 158
Ziele, 48, 71, 225, 226
Cyberterrorist, 76

D

Dark-side Scenario, 165
Data Breaches, 159
Daten
 im RAM, 107
 persönliche, 105
 personenbezogene, 7, 123
 personenbezogene und personenbezieh-
 bare, 105, 226
 sensible bei der Übertragung, 193, 195
 sicherheitsrelevante, 104, 112
Datenleck, 43
Datensammler, 74
Debug/Diagnose-Schnittstellen, 110
Default Credentials, 200
Denial-of-Service, 43, 159, 163, 167
Design, unsicheres, 161
Diagnosedaten, 159
Diagnostic Trouble Codes (DTC), 106
DoIP, 102
Dokumentation, technische, 62
DSGVO, 7
DSSAD, 107
DTC (Diagnostic Trouble Codes), 106

E

E/E-Architektur, 68
ECU (Electronic Control Unit), 38, 48, 51,
 100, 117, 138, 170
 Gehäuse, 109
EDR (Event Data Recorder), 107
Eigentum, geistiges, 125
Einbrecher, 75
Einzigartige IDs, 105
Electronic Control Unit (ECU), 38, 48, 51,
 100, 117, 138, 170
Elevation of Privilege, 164
End-Produkt, 113
ENISA Threat Landscape (ETL), 79, 161
ENX, 20
eSIM, 71, 103

Ethernet, 102, 111, 118, 156, 158
ETSI, 167
 TVRA, 42, 74, 76, 155, 185
EU-Cybersecurity-Strategie, 4
EU-Maschinenverordnung, 7
Europäische Union, 7
Event Data Recorder (EDR), 107
EVITA, 155, 165
Experte, 177
Extraktion kryptografischer Schlüssel, 159,
 196

F

Fähigkeitsstufe, 77
Fälschung, 167
 Fahrzeugsteuerungssystem, 196
 Software, 196
Fachwissen, 176, 184
Fahrernamen, 115
Fahrsysteme, automatisiertes, 22
Fahrzeug, 38
 vernetzten, 117
 vernetztes, 155
Fahrzeugdaten
 Überschreiben, 196
 Löschung, 196
 Manipulation, 196
Fahrzeugidentifikationsnummer, 105
Fahrzeugsteuergerät, eingebettetes, 84
Fehler, kryptografischer, 161
Feldbus, 110
Feldsteuerung, 160
Fernüberwachungsdaten, 107
Fernzugriff, 111
Finanzen, 122, 125, 126
FlexRay, 68, 69, 101
Freshness, 117
Funkgeräteschnittlinie, 6

G

Gegenmaßnahme, 56
Gerät, eingebettete im Automobilbereich,
 156, 159
Geschäftsprozess, 167
Geschäftsziel, 167
Geschwindigkeitsbegrenzungsdaten, 117
Google Cloud Platform™, 160

GPIO, 104

H

Hacking-as-a-Service, 76

Haktivisten, 75, 161

HARA, 114

Hardcoded Credentials, 201

Hardwarearchitektur, 98

Hazard, 114

Head-Units, 160

HEAVENS, 42, 166

2.0, 166

High-Level Structure, 26

Human-Machine Interface, 160

I

I2C, 103

IACS, 16

IEC

61508, 23

61511, 7

62443, 6, 16, 29, 36, 72

Image, 125

IMS (Integrated Management System), 35

Industrie 4.0, 72

Information

Disclosure, 163, 195

eingeschränkt zugängliche, 177

Öffentlich zugängliche, 177

Offenlegung von, 163

sensible, 21

streng vertrauliche, 178

vertrauliche, 178

Infotainmentsystem, 84, 160

Input/Output-Server, 160

Insider, 75, 159

Insiderangriff, 189, 196, 199

Integrated Management system (IMS), 35

Integrität, 116, 164, 167, 189, 193, 195, 226

Internetanschlüss, offen gelassener, 196, 200

Internetverbindung, 195

iOS, 160

iPhone®, 195

ISMS, 18

ISO

19011, 19

21448, 22

22301, 28

26262, 7, 18, 165

31000, 28

60601-1, 7

ISO/IEC

18045, 165

27000-Familie, 42, 72

27001, 4, 18, 25–27, 36, 161

27005, 28, 163

27701, 8

TR 5469, 23

ISO/PAS 8800, 22

ISO/SAE

PAS 8475, 19

TR 8477, 20

ISO/TS 5083, 22

ISO 21448, 114

ISO 26262, 113

ISO PAS 5112, 19

Item, 62

Itemdefinition, 59–61

J

JTAG (Joint Test Action Group), 63, 102

K

Kalibrierungsdaten, 106

KI (künstliche Intelligenz), 22, 72

Kilometerzähler, 106

Kommunikationskanal, 159

Kommunikationsschnittstelle/-protokoll, 101

Kompetent, 177

Komponent, 156

Kreditkartendaten, 195

L

Laie, 177

Lateral Movement, 164

Lebenszykluszustand, 106

Leitsystem, 160

LIN, 68, 69, 102

LINDDUN, 155

Linux, 71, 160

Logistikdaten, 112

Logs, 106

Lokal, [181](#)

M

Machbarkeit, [169](#)

macOS®, [160](#)

Man-in-the-Middle-Angriff, [196](#)

Managementsystem, integriertes, [35](#)

Manipulation, [163](#)

elektronischer Hardware, [196](#)

Maskerade, [167](#)

Mehrfachexperte, [177](#)

Microsoft 365®, [160](#)

Microsoft Windows®, [160](#)

Microsoft®, [160](#)

Microsoft® Azure, [72](#)

Microsoft® Azure Active Directory, [160](#)

Missbrauch von Berechtigungen, [196](#), [199](#)

MITRE ATT&CK®, [159](#), [160](#)

Enterprise, [160](#)

ICS, [160](#)

Mobile, [160](#)

MOST, [69](#), [102](#)

Motivationsstufe, [77](#)

N

Name, [195](#)

Netzwerk, [180](#)

Netzwerkentwicklung, [98](#)

Netzwerkkomponente, [113](#)

Netzwerktrennung

Umgehung, [200](#)

Nichtabstreitbarkeit, [117](#), [164](#)

NIS-2, [4](#)

NIST Cybersecurity Framework (CSF), [161](#)

NVM, [109](#)

O

OBD (On-Board Diagnostic), [102](#), [159](#)

OCTAVE, [155](#)

OEM (Original Equipment Manufacturer),
[117](#)

Anwendungen, [108](#)

On-Board Diagnostic (OBD), [102](#), [159](#)

OWASP® Foundation, [160](#)

OWASP® Top 10, [153](#)

P

Passwört, [104](#), [115](#)

PASTA, [42](#), [155](#), [167](#)

Patches und Fixes, [47](#)

PCB (Printed Circuit Board), [113](#)

Penetrationstest, [42](#)

Person, betroffene, [123](#)

Physisch, [181](#)

PKI (Public Key Infrastructure), [90](#)

Printed Circuit Board (PCB), [113](#)

Privatsphäre, [117](#), [123](#)

Privileg, erforderliches, [180](#), [181](#)

Produktionskontrollplan, [31](#)

Produktlebenszyklus, [37](#)

Prozedur, [160](#)

Prozess der Bedrohungsdefinition, [154](#)

Public Key Infrastructure (PKI), [90](#)

R

RACE, [155](#)

Rechenschaftspflicht, [117](#), [118](#), [167](#)

Rechteauserweiterung, [164](#)

Rechtsnorm, [25](#)

RED (EU Radio Equipment Directive), [6](#)

Replay-Angriff, [196](#)

Repudiation, [163](#)

Reputation, [125](#)

Restrisiko, [30](#), [228](#), [232](#)

Risiko, [44](#), [46](#), [49](#)

Akzeptanz, [230](#)

Behandlungsentscheidung, [157](#)

Bestimmung, [157](#)

mitigiertes, [232](#)

unvermindertes, [30](#)

vermindertes, [232](#)

Risikoformel, [211](#)

Risikomanagement, [43](#)

Tool, [56](#)

Risikomanagementprozess, [27](#)

Risikomanagementsystem, [26](#)

Risikomatrix, [211](#)

Risikoreduzierung, [225](#)

Risikotoleranz, [224](#)

Risikovermeidung, [225](#)

Risikoverteilung, [230](#)

Risikowert, [208](#), [214](#)

Root-Zugriff, [196](#)

S

SAE (Society of Automotive Engineers) J3061, 165

Safety, 121, 237

Safety Of The Intended Functionality (SOTIF), 114

SAHARA, 155

SBOM (Software Bill of Materials), 112

Schadensszenario, 118, 119, 188, 208, 237

- Gruppierung, 50
- Identifikation, 120
- Statistiken für, 214

Schadsoftware

- Einspeisung, 200

Schlüssel

- öffentliche, 104
- privater, 104, 115

Schnittstelle, 156

- externe, 196
- physikalische, 104

Schutzanforderung, 30

Schwachstelle, 41, 47, 159, 161–163, 167, 189

- Während der Produktion, 31

Schwachstellenanalyse, 46

Scope

- Automotive Embedded Devices, 68

SDV (Software Defined Vehicle), 47

SecOC, 145

Secure Onboard Communication, 145, 252

Seitenkanalangriff, 193

Sensor, 109, 113

Server, 113

Session Hijacking, 196

Sicherheit, funktionale, 2

Sicherheitsfehlkonfiguration, 161

Sicherheitskonzepte, 160

Sicherheitsverordnung, allgemeine, 6

Sicherheitsziel, 166

Signatur, digitale, 117

Skalierbarkeit, 127

Skript-Kiddie, 74

Smart Cars, 161

Software

- bösartige, 46
- Manipulation, 193
- Signaturprüfung, 70

Software Bill of Materials (SBOM), 112

Software Defined Vehicle (SDV), 47

Software Update Management System (SUMS), 3, 109

Software-as-a-Service, 160

Software-Updates, 108, 112, 197

Softwareaktualisierung, 159

Softwareaktualisierungsverfahren, 200

Softwarearchitektur, 98

Softwarekomponente, 156

Softwaremanipulation, 159

SOME/IP, 69

SOTIF (Safety Of The Intended Functionality), 114

Speicher, nichtflüchtiger, 109

Speicherbereich, 156

SPI, 104

Spoofing, 163, 195

Standortdaten, 105

State-Sponsored Actor, 76

Steuergerät, 46

Steuerungssystem, industrielles, 160

Straßenfahrzeug, 9

STRIDE, 155, 157, 158, 164, 189, 195, 197

STRIDE-LM, 164

Stromversorgung, 110, 113

Subtechnik, 160

SUMS (Software Update Management System), 3, 109

Systemarchitekt, 62

Systementwicklung, 98

T

Täuschung, 163

TAF (Targeted Attack Feasibility), 19, 20

Taktik, 160

Tampering, 163, 195

TARA, 71, 101

- 3-Tage, 48
- 30-Tage, 49
- 300-Tage, 51
- auf Fahrzeugebene, 70
- für die Produktion, 46
- für eigenständige Steuergeräte, 68
- generisch, 69, 119
- große, 51
- initiale, 44
- Komponenten, 70
- Komponentenebene, 119
- kurze, 48

- nach Software-Änderung oder Schwachstelle, [47](#)
- Out-of-Context, [70](#), [119](#)
- während der Entwicklung, [46](#)
- Target-Attack-Feasibility (TAF), [19](#), [20](#)
- Technik, [160](#)
- Telekommunikationssystem, [76](#)
- Terrorist, [76](#)
- Threat Vulnerability and Risk Analysis (TVRA), [167](#)
- TISAX®, [20](#), [29](#)
- Tuner, [74](#)
- TVRA (Threat Vulnerability and Risk Analysis), [167](#)

U

- UDS (Unified Diagnostic Services), [69](#)
- UN-Regelung Nr. 155, [3](#), [8](#), [9](#), [72](#), [159](#), [189](#), [195](#)
- Angriffswirkungen, [121](#)
- UN-Regelung Nr. 156, [3](#)
- Unautorisiert
 - Internetzugriff, [196](#), [199](#)
 - Zugriff, [167](#), [196](#), [226](#)
- Unbefugt
 - Physischer Zugriff, [196](#), [200](#)
- UNECE, [2](#), [8](#)
- Unified Diagnostic Services (UDS), [69](#)
- Unsicher
 - Anwendung, [196](#)
- USB, [110](#)

V

- V2V, [1](#)
- V2X, [1](#), [117](#)
- Validierung, [20](#)

- VAST, [155](#)
- VCS (Vehicle Cybersecurity), [21](#)
- VDA-ISA, [21](#)
- Vehicle Cybersecurity (VCS), [21](#)
- Verfügbarkeit, [116](#), [164](#), [167](#), [189](#)
- Verhinderung von Bedrohungen, [160](#)
- Verifizierung, [20](#)
- Verkehrsbedingung, [117](#)
- Verlust oder Verfälschung von Informationen, [167](#)
- Verschlüsselung
 - Knacken, [196](#)
- Vertraulichkeit, [115](#), [164](#), [167](#), [193](#), [195](#)
- Videodaten, [105](#)
- VIN, [105](#)
- Vorschrift, [43](#)

W

- White-Hat-Hacker, [75](#)
- Wiederverwendungsprojekt, [49](#)
- Wissen über das Item oder die Komponente, [177](#), [184](#)
- WLAN, [71](#), [103](#), [110](#), [158](#)
- Wohnadresse, [115](#)

Z

- Zahlungsinformation, [105](#), [115](#)
- Zeit, abgelaufene, [174](#), [184](#)
- Zeitübertragung, sichere im Fahrzeugnetzwerk, [105](#)
- Zertifikat, [104](#), [226](#)
 - öffentliche, [117](#)
- Zielsicherheitsniveau, [30](#)
- Zugangsdaten, [104](#)
- Zugriffsgelegenheit, [178](#), [184](#)
- Zuliefereranwendung, [108](#)